

CISM Comprehensive Exam Preparation Guide

Consolidated from Training Days 1–8

This document contains an exam-oriented study guide, high-value distinctions, formulas, question-solving logic, and a transcript appendix preserving the source material for completeness.

Important: Trainer statements are preserved in the source appendix. Where terminology is organization-dependent or potentially simplified, the guide flags it rather than silently changing it.

How to Use This PDF

- First study the structured notes and distinction tables.
- Use the question-solving rules when practicing CISM-style scenarios.
- Review the day-specific sections before revisiting the corresponding transcript appendix.
- Treat the transcript appendix as the completeness layer: it preserves the supplied training content, including examples and discussions that may not fit neatly into the summary.

Coverage statement

The structured section is a consolidated exam-preparation guide. The full cleaned transcripts are included later as an appendix so that the source discussions, questions, explanations, repetitions, and examples are not discarded.

Day 1: CISM Mindset, Governance, Strategy, and Risk

CISM mindset

- Think like a manager rather than a technical implementer.
- Prioritize governance, business objectives, risk, accountability, and strategic alignment.
- Read qualifiers such as first, best, most important, and next.
- Answer according to the question context, not automatically according to your own organization's structure.

Governance and management

- Governance establishes direction, policies, accountability, oversight, and alignment with business objectives.
- Management plans, builds, operates, monitors, and executes.
- Governance evaluates, directs, and oversees; management implements.

Strategy, policy, and program

- Strategy defines long-term direction and objectives.
- Policy establishes mandatory rules and governance expectations.
- The security program implements strategy through initiatives, controls, processes, and activities.
- A set of policies, BCP plans, DR plans, and crisis plans does not automatically equal a complete strategy.

Risk and sequencing

- Risk is a future possibility involving uncertainty and potential impact.
- An event is an occurrence; an incident is an event with actual or potential adverse consequences requiring response.
- Risk assessment is often the correct first management step before selecting or prioritizing controls.
- Security strategy must align with business objectives and risk appetite.

Executive reporting

- Executives need business impact, major risks, trends, KPIs, KRIs, and decisions required, not raw technical vulnerability output.
- Security governance is broader than compliance and is not the same as daily operations.

Day 2: Strategy Development, Stakeholders, Gap Assessment, BIA, and Data Ownership

Data ownership

- The data owner is accountable for classification, protection requirements, and appropriate use.
- The data custodian implements and maintains controls and handles data according to the owner's requirements.
- Policy compliance is everyone's responsibility.

CMMI maturity

- Level 1 Initial: ad hoc and unpredictable.
- Level 2 Repeatable: basic repeatable processes.
- Level 3 Defined: documented and standardized.
- Level 4 Managed: measured and managed.
- Level 5 Optimizing: continuous improvement.

Strategy development sequence

- Understand business objectives and current state.

- Assess capabilities, risks, resources, and constraints.
- Identify gaps and define the desired future state.
- Define objectives, initiatives, priorities, and a roadmap.
- Implement, measure, and improve.

Business linkage and stakeholders

- Map security capabilities to business requirements such as availability, integrity, confidentiality, privacy, and resilience.
- Senior management provides business direction; security leadership translates it into security objectives and programs.
- Cross-functional buy-in depends on communication and collaboration.

Gap assessment versus BIA

- Gap assessment compares current and desired states and produces gaps and a roadmap.
- BIA identifies critical business processes, consequences of disruption, and recovery priorities.
- Risk assessment evaluates threats, vulnerabilities, controls, and exposure.

Day 3: AI Governance, Policy Hierarchy, Frameworks, Architecture, and Metrics

AI governance lifecycle

- Discover and inventory AI models, GenAI tools, AI agents, and AI usage.
- Classify by criticality, exposure, business impact, sensitive data, and training data.
- Assess risks.
- Approve, restrict, or reject use.
- Establish IAM, network, data, human-oversight, and monitoring controls.
- Continuously monitor and improve.

AI scenarios

- For sensitive information entered into public GenAI, conduct risk assessment before deciding whether to block, report, or provide an approved alternative.
- For third-party ML used in loan underwriting, verify contractual and regulatory data-processing requirements.
- For shadow AI, establish a cross-functional steering committee with business, legal, risk, compliance, and security stakeholders.

Policy hierarchy

- Policy: high-level, mandatory, nontechnical direction.
- Standard: specific mandatory requirement.
- Baseline: minimum implementation or configuration requirement.
- Guideline: recommended, flexible advice.
- Deviation from a mandatory standard normally requires an approved exception and risk acceptance.

Frameworks and architecture

- GDPR, HIPAA, CCPA, SOX, NIST, and DORA have different purposes and legal or guidance status.
- Zachman and TOGAF relate to enterprise architecture; COBIT relates to governance and control.
- NIST AI RMF, ISO/IEC 42001, and the EU AI Act were discussed for AI governance.

Metrics

- KGI measures achievement of a goal.

- KPI measures performance or progress.
- KRI indicates or predicts future risk.
- A measure is not automatically a KRI merely because it is security-related.

Day 4: Risk Assessment, Treatment, Ownership, SDLC, Third-Party Risk, and Recovery

Risk assessment and evaluation

- Assessment identifies threats, vulnerabilities, controls, exposure, and residual risk.
- Evaluation analyzes likelihood and impact, compares risk with appetite or tolerance, and prioritizes treatment.
- Risk assessment is continuous and should be updated when conditions change.

Risk concepts

- Aggregated risk combines multiple smaller risks into a significant overall risk.
- Cascading risk occurs when one failure triggers a chain reaction.
- Appetite is the amount/type of risk willing to accept or pursue.
- Tolerance is the acceptable level or variation.
- Capacity is the maximum risk the organization can absorb before viability is threatened.

Risk treatment and ownership

- Avoid, mitigate, transfer, or accept.
- Transfer shifts financial or contractual consequences, not ultimate accountability.
- Risk owner is accountable for risk outcomes and acceptance.
- Control owner designs, operates, maintains, and monitors the safeguard.

SDLC and change

- Use threat modeling and secure design early.
- STRIDE and MITRE ATT&CK; were mentioned.
- Test patches and changes in nonproduction before production.
- Assess changes against configuration baselines.

Third-party and recovery

- Perform pre-contract due diligence and risk-based ongoing monitoring.
- Maintain an exit strategy for data return, migration, replacement, continuity, and cost.
- RPO concerns acceptable data loss; RTO concerns restoration time; MTD concerns maximum tolerable downtime.

Day 5: Security Program, Business Cases, Architecture, and IAM

Security program

- The security program implements the security strategy.
- Activities include control implementation, awareness, monitoring, incident management, resilience, and continuous improvement.
- A program charter establishes authority, scope, objectives, governance, accountability, and executive sponsorship.

Program development

- Define context and objectives, assess current capabilities and risks, identify gaps, create a roadmap and business case, obtain resources, implement, measure, and improve.
- Assessment is a key input, but the program must first have a mandate and defined context.

Business case

- Explain the risk, potential business impact, proposed response, expected risk reduction, cost, resources, and business value.
- A business case is not merely a request to purchase a tool.

Architecture and IAM

- Security architecture translates strategy into high-level design principles and integrated controls.
- Enterprise architecture designs the overall environment; security architecture protects it.
- Identification states who you are; authentication verifies; authorization determines permissions; accountability associates actions with users; auditing reviews records.
- PAM, RBAC, ABAC, JIT access, access reviews, and deprovisioning were discussed.

Day 6: Metrics, Controls, Control Objectives, ROSI, and Program Measurement

Security culture

- Culture requires sustained leadership, repeated awareness, accountability, reinforcement, and time.

Metric levels

- Strategic metrics support board and executive decisions.
- Management metrics support CISO and program management.
- Operational metrics support daily process management.
- Technical metrics measure specific systems and controls.

Effective metrics

- Use SMART principles: specific, measurable, achievable, relevant, and time-bound.
- Good metrics should also be accurate, reliable, actionable, and appropriate for the audience.
- Metrics should drive decisions and action, not merely populate dashboards.

Controls

- Controls reduce risk, support business objectives, prevent or detect problems, correct issues, and support compliance.
- Controls may be technical, administrative, physical, procedural, or people-based.
- A control objective states what the control is intended to achieve; one objective may require multiple controls.

ROSI and ALE

- The trainer gave $ROSI = ALE_{\text{before}} - ALE_{\text{after}} - \text{cost of safeguard}$.
- $ALE = ARO \times SLE$.
- ROSI is a security investment analysis concept focused on avoided loss and risk reduction.

Program success

- Continuous monitoring, compliance verification, stakeholder engagement, metric development, and adaptive security.

Day 7: Third-Party Risk, Supply Chain, Shared Responsibility, Contracts, DMZ, and Noncompliance

Third-party risk

- Classify providers by criticality, data sensitivity, access, dependency, regulatory exposure, and impact of failure.
- Review frequency should be risk-based.

Supply chain

- Trusted suppliers, software libraries, APIs, SaaS providers, cloud services, and AI providers can become attack paths.
- The trainer referred to MOVEit as an example of widespread downstream impact.

Shared responsibility

- Provider and customer responsibilities vary by IaaS, PaaS, SaaS, and AI services.
- The contract and applicable law determine responsibilities and liability.
- Customers commonly remain responsible for their data, identities, configuration, access, and customer-managed applications.

Contracts and assurance

- Include security responsibilities, data protection, incident notification, escalation, audit rights, continuity, RTO/RPO, compliance, and exit requirements.
- A SOC 2 report or ISO certificate does not automatically prove effectiveness for every customer environment; review scope, period, exceptions, and covered services.
- Right to inspect is generally narrower than a formal right to audit.

Cloud, DMZ, and noncompliance

- Rapid elasticity makes consistent baselines difficult unless provisioning is automated and governed.
- A DMZ separates public-facing systems from trusted internal networks and supports defense in depth.
- Noncompliance should be identified, risk-assessed, assigned, remediated, validated, and tracked.

Day 8: SIEM/SIM, SOC, Incident Management, Containment, Forensics, Recovery, and Awareness

SIEM/SIM

- Primarily a detective capability.
- Collects, aggregates, normalizes, correlates, and analyzes logs from many sources.
- Supports alerts, investigation, threat hunting, compliance evidence, dashboards, and reconstruction.
- SOAR automates predefined response playbooks.

APT and SOC

- APTs may remain undetected, move laterally, and operate in multiple stages.
- SOC performs detection, triage, investigation, escalation, and containment support.
- Incident teams may include security, cloud, application, network, database, identity, legal, communications, HR, and executives.

Containment

- Reduce blast radius and prevent further spread.
- Isolate systems, disable accounts, block malicious traffic, restrict access, and stop command-and-control communication.

Communication

- Be timely, accurate, consistent, approved, and audience-appropriate.
- Report facts, impact, containment status, actions, remaining risk, and decisions required.
- Avoid speculation, unsupported attribution, and contradictory statements.

Forensics, recovery, awareness

- Forensics investigates entry point, timeline, attacker activity, affected systems, and data exposure.
- Post-incident review improves roles, escalation, communication, playbooks, coordination, and training.
- RTO is restoration time; RPO is acceptable data loss; MTD is maximum tolerable downtime.
- Awareness includes secure behavior, phishing, data protection, acceptable use, authentication, policies, and reporting.
- Completion rate alone does not prove training effectiveness; behavior metrics matter.

Integrated CISM Decision Rules

- Start with business objectives, organizational context, and risk.
- When asked for the first action, identify the correct sequence rather than choosing the most technical action.
- Use risk-based prioritization. Not every issue deserves the same urgency or investment.
- Governance sets direction; management executes.
- Strategy defines direction; roadmap defines how and when; program implements.
- Risk owner is accountable for the risk; control owner is accountable for operating the safeguard.
- Compliance or certification is evidence of a defined scope, not automatic proof of effective security.
- A control's effectiveness must be evaluated through testing, monitoring, assurance, and outcomes.
- For incidents, distinguish detection, containment, eradication, recovery, communication, forensics, and lessons learned.
- Metrics should support decisions, funding, remediation, and continuous improvement.

Important qualification notes

- Strategy time horizons are organization-dependent; a fixed five-year rule should not be treated as universal.
- Vendor review frequencies are illustrative and should be risk-based.
- Cloud shared-responsibility details depend on service model, contract, and law.
- RTO, RPO, MTD, MTO, SDO, and PTO terminology may vary by organization or framework.
- Risk transfer does not remove ultimate accountability.
- ROSI is not simply ordinary ROI with a different name; it focuses on security risk reduction and avoided loss.

Appendix: Source Transcript Preservation

The following sections contain the cleaned text of each supplied training transcript. This appendix is included so that detailed discussions, examples, questions, explanations, and repetitions remain available for review.

Day 1: Full Cleaned Transcript

Approximate source length: 32,802 words.

Neethu: Hello? InfosecTrain Trainer: Yeah, hello, hi. Neethu: Hi, I'm just checking whether the audio is on, yeah. InfosecTrain Trainer: Yes, yes, yeah, I'm just waiting for all the participants to join, then we'll get started, yeah. Just wait for one more minute, yeah. InfosecTrain Trainer: Alright, we'll get started, so... InfosecTrain Trainer: So, good evening and good morning, everyone. I'm not sure which particular time zone you are. I can see a couple of people, even from some different time zone. So, I'm going to be your instructor for this training session, right? InfosecTrain Trainer: So, before we get started, let me quickly introduce myself, right? InfosecTrain Trainer: So, I'm already CISSP CISM certified, right? I hold a couple of other certifications. InfosecTrain Trainer: So, I have close to more than 20... 14 years of experience, right? So, I've worked in third-party risk management, cyber intel... cyber threat intelligence, AI governance, cloud security, and other couple of domains. And I am also a vet... InfosecTrain Trainer: Excuse me? Yeah? InfosecTrain Trainer: If someone is trying to say something? InfosecTrain Trainer: All right. So, I'm a veteran, I've served in the Indian Air Force, and I retired as a squadron leader before joining the corporate. So, I've worked in a couple of corporates, and also I am an active speaker and in a couple of cybersecurity forums, like ISACA, ISC Squire, ISMG, and CSA. InfosecTrain Trainer: And, so that's... that's a quick introduction about me. But before we get onto this, right, so let me just share some couple of how... InfosecTrain Trainer: A couple of items, right? First thing, I hope all of you are now part of the WhatsApp group. InfosecTrain Trainer: Is there anyone here who is yet to join the WhatsApp group?

Mukesh Thakur: Yes, I'm not able to join. Actually, whenever I'm clicking on the link, getting some side... some error, so can you please help me with that? InfosecTrain Trainer: Yeah, yeah, so you can note down this number. InfosecTrain Trainer: This is the number of Saxam. InfosecTrain Trainer: You can just directly ping him, he'll, he'll help you. InfosecTrain Trainer: Surely. Not only with the group, any other issues also, whatever you are facing, right? InfosecTrain Trainer: throughout, during the course of the training, even after the training, till the time you clear the CISM exam. Anything related to resources, not able to access that shared drive, not able to get the recording, anything, you can just directly ping him. InfosecTrain Trainer: Yeah. InfosecTrain Trainer: So, I'm also there, part of the WhatsApp group, so as you are aware, this is an IST time. InfosecTrain Trainer: So, we'll be conducting the session over the weekend. It's going to be the 7pm to 11pm Indian Standard Time. Just, actually, I complete the session in, back-to-back in 32 hours in 8 consecutive weekends, but this time, actually, there is 1.15 August, which is coming in between, so we'll have an off. InfosecTrain Trainer: Apart from that, on the weekend of the 28th and 29th, actually, I have some commitments, so I'm going to be there out of town for those two days. InfosecTrain Trainer: So, won't be able to contact the session. So, we'll just have the gap of 3... InfosecTrain Trainer: particular weeks. That's why... InfosecTrain Trainer: will be able to complete this session by 12th of September, right? That's what... you people have already got the schedule, right? So, we'll be having classes over this weekend.

Next weekend, we'll have only one class on 16th, then we'll have the class on 27th and 23rd. InfosecTrain Trainer: 29th and 30th, there's going to be no class, and then we'll have one more class on 5 and 6, and the last class would be on 12th. InfosecTrain Trainer: So by this, we'll be able to conclude or complete the complete syllabus of the CISM. InfosecTrain Trainer: So we'll be starting everyday session sharp at 7, right? So I request all of you to please join on time so that we can get started as InfosecTrain Trainer: quickly as possible, right, without wasting time. We'll be taking a break in between, approximately 15 minutes, right? So I'll try my best to cover each domain in 2 days, but it may go here and there, and if needed, we'll extend by 10-15 minutes at the end, if needed. InfosecTrain Trainer: Right? But yeah, one thing, please plan your exam before 5th November. InfosecTrain Trainer: After 5th November, the syllabus of CISM is getting changed. I have one specific slide where I'll explain you exactly what are the changes, what currently ISACA has published in their blog. InfosecTrain Trainer: on their website. Other than that, there is no information available. There are not even books which they have published, so they are planning to publish those books after September. InfosecTrain Trainer: So, even... we don't know what kind of changes there. They add their blog on their website, they have published some couple of topics, but by looking at it, it looks like not going to be very drastic changes, just... InfosecTrain Trainer: They, probably, you can exp... A change of 8-10% in overall syllabus. InfosecTrain Trainer: So that won't just derail your complete InfosecTrain Trainer: kind of preparation, what you are doing here. Also, I have told the team.

InfosecTrain Trainer: I will conduct one, probably a two-hour of a master class, specifically on those topics which they have introduced new, right? Probably in 2 hours would be more sufficient to cover all the new topics which they have introduced, so I'll probably cover that session somewhere in the October mid. InfosecTrain Trainer: Because if the people, those who are not able to write before November, they can attend that session and get an understanding around what are the changes which have happened, what are the new topics, you can understand those topics and get an understanding, right? So don't worry, even if you're not able to write before November. InfosecTrain Trainer: You can attend that session and go and write your exam, right? InfosecTrain Trainer: And please remind me to start the recording, however it gets started automatically, but if I'm not able to, please let me know, to start the recording. So, these are some couple of the housekeeping items, which I just want to discuss before we get started. InfosecTrain Trainer: So now, getting on to the exam... InfosecTrain Trainer: CISM. First, we get over here, how many of you are already certified by ISACA, hold any certification, like, something from the ISACA or IS Core, like CISSP, CCSP, C-Risk, CISA, any such certification? Not... I'm not talking about the ISO 27001 or 42001, those certifications, any InfosecTrain Trainer: certification which you got from the IST Squire or ISACA? Anyone here? Pudir: Sir, good evening, and Pudir... Pudir demish. Pudir: I got a CIS at Fitz. InfosecTrain Trainer: Okay, good, good. So it's good that you are already CIS, so you might be aware about the ISACA, how is the experience, right? How to register for the exam, so it's good that you are already certified, right?

Pudir: Yes, yes, thank you. InfosecTrain Trainer: So, before we... I get onto here, let me show you... InfosecTrain Trainer: ISACA page. So this is the ISACA page, you can just Google it, and go here and create your account. InfosecTrain Trainer: So, creating an account is absolutely free of cost. They are not going to charge you anything. InfosecTrain Trainer: Today, after the session, or tomorrow morning, you can go ahead and create your account on the ISACA. This is the first step which you should do, right? Here in the credentialing, you can see which all certifications ISACA provides. So, these are the list of all certifications which they provide, right? InfosecTrain Trainer: So, this is the CISM for which you people are here, right? So, you go here, you click on CISM, InfosecTrain Trainer: Here you can see complete details, what ISATA syllabus is, what are things going to be there as part of the ISACA, right? You can even check the candidate guide. InfosecTrain Trainer: These are there. However, we will be providing you those guides, so don't worry. And you can see InfosecTrain Trainer: you can see all the details which are listed over here, right? Now, there are 4 domains, 1, 2, 3, 4, which we are going to study over the course of this session. InfosecTrain Trainer: Apart from that, what are the next steps? Once you complete the training, right, then you have to register for the exam. So learn and prep, this is where you are at this point of time, right? This is the phase. InfosecTrain Trainer: Once it is done, then this is going to be the register. InfosecTrain Trainer: I'm not sure how many of you have purchased the voucher via, InfosecTrain. If you have purchased, you can apply that voucher.

If you don't, you have not availed that facility, then you can go ahead and purchase. This is the cost. InfosecTrain Trainer: So, there are two kind of costs which is associated. One is the member cost, and there is the non-member cost. So you can go ahead, take an ISACA membership. InfosecTrain Trainer: So, ISACA membership, if you take, that will also cost you somewhere around 100 plus some dollars. You can see that amount is already getting discounted in overall certification. So, for first year, if you want, you can take a membership so that you get that discount. So, what are the benefits of InfosecTrain Trainer: getting a membership, you can go ahead and check, but at a high level, you can be a part of the local ISACA chapter, right? You can go ahead and attend those chapter meets, which keeps happening. You can connect with the overall ecosystem of the cyber InfosecTrain Trainer: peers across different, different industries, those who are already ISACA certified, right? So these are advantages. Apart from that, to maintain certification, also, you would require some CP credits. InfosecTrain Trainer: Those... so if you attend a 1 hour of session, you get one CP credit. If you attend a 8-hour conference, you get 8 CP credit. That's how ISACA do. So, if you keep attending those CPE credit, you can go ahead and report, which will help you to maintain your certification. It's not like that, that you wrote the exam, you cleared the CISM certification, you got the certification that you forget. InfosecTrain Trainer: Every year, You have to pay a certificate renewal fee. InfosecTrain Trainer: Plus, every year, you have to report minimum 20 CPE. That's what... so that ISACA want all of you to maintain the adequacy, maintain the, the learning, right? It's not like that.

If you don't do that, then your certification gets revoked. InfosecTrain Trainer: That's what I'm saying. Please, every year, go ahead, log into ISACA portal, keep reporting those CP credits, and keep doing the renewal, right? InfosecTrain Trainer: Once you do that, then there is a next tab called the schedule. Here, you can go ahead, and then you can schedule your exam, right? So there are two methods to write the exam. One, you can write from your home. InfosecTrain

Trainer: Right? Which is an online mode. There is one more mode, you can go ahead and write from a center. So, ISACA has a tab with the third party, where they offer the CISM exam. You can go ahead and write from those centers. InfosecTrain Trainer: So I recommend all of you, if... wherever you are, I'm not sure, the... InfosecTrain Trainer: particular, city you are. If you have availability of those centers, once you create your account, you can check. InfosecTrain Trainer: So once... you can check, and then you can understand if there is a center nearby, I would recommend go ahead and go right from there, because at home, you may have other kind of disruptions. There can be a disruption with respect to your laptop from where you are writing, there can be an issue with your power supply or your internet connection, right? So if something goes wrong in between. InfosecTrain Trainer: your certification may get revoked, right? Sorry, your exam, it's going to be the proctor-led. Proctor would be sitting at that side of the camera, watching you continuously. If he sees some issues, he may InfosecTrain Trainer: probably mark it as disqualified, right? So that's why I recommend to go ahead right from a center, but if there is no option, you can do it from your home, right?

At center, the best thing is that you InfosecTrain Trainer: need not to be worried about anything from those administrative steps, you just go ahead, log in in a computer, which they will provide you, right? You can take breaks also, you can get up from your chair, go InfosecTrain Trainer: sip of water, and come back and sit. So you can relax, because it's a 4-hour exam. InfosecTrain Trainer: And I feel most of you might not be having a habit of writing continuously for our exam, right? That's why it becomes very important for you to practice, and then do that. So that's scheduled, and then once you certify. InfosecTrain Trainer: So once you clear the exam, after that, there is a \$50 processing fee. InfosecTrain Trainer: Which you have to pay. InfosecTrain Trainer: to the ISACA. InfosecTrain Trainer: To get the certification. InfosecTrain Trainer: Right? So that fee you will pay, then you will get a certification, issued by the ISACA. So these are the sum of the fees which you have to pay, right? So that's overall from the ISACA perspective, from the CISM. So I gave you familiarity with this. InfosecTrain Trainer: Now, coming to the application process, right? So you have to go ahead and submit the application, which I just told you, right? InfosecTrain Trainer: Now, coming to the overall exam passing marks, right? So, exam, as I told you, has total 4 domains. InfosecTrain Trainer: So, overall, exam consists of 150 multiple-choice questions, and each domain has some weightage. InfosecTrain Trainer: Like, 17%, 18%, 33%, 30%, so you will... that... InfosecTrain Trainer: a number of questions would be coming from each domain, right? But the questions in the exam are jumbled up.

They are not... they'll not be coming in a sequence that first they'll ask questions from domain 1, then they'll go to domain 2. No. InfosecTrain Trainer: You will get jumbled up questions, and all these domains are related with each other. There are some cross topics. InfosecTrain Trainer: which are cross-referred from a domain 1 between domain 2, 3, and 4, right? So that's why understanding around all the domains becomes essential. It's not like that, that you just... domain 3 and 4 have the maximum weightage, I'll just study them, I'll ignore domain 1 and domain 2, maybe I'll be able to pass no. InfosecTrain Trainer: That's why understanding around all the domain is important. Now, coming to the passing scores. So, these 150 questions are not InfosecTrain Trainer: equally numbered. That one, every question consists of four marks and all. That InfosecTrain Trainer: marking no one knows that AISACA has never published also, but overall total exam is numbered of 800. So, out of 800, you have to score 450. And that 800 average, they will calculate for all the domains. So, all the domains InfosecTrain Trainer: you have to, whatever questions are there, out of that, you have to score more than 450, right? But... InfosecTrain Trainer: 450 is an average. So, suppose in the domain one, you got 480, this domain you got 420, this domain you got 500, this domain you got 410. So then they will average out, if average comes out to be more than 450, you are past. InfosecTrain Trainer: So it's not like that, that each domain, you have to get a... InfosecTrain Trainer: mark of more than 450, right? So that's why... that's how it happens, right? So this is how the passing InfosecTrain Trainer: This is how you will pass the exam.

So, if you get 450, and you see 450 of 800 means approximately 58 to 59%, InfosecTrain Trainer: These many questions you have to correct. InfosecTrain Trainer: It means, if you correct more than 85 to 90 questions in the exam, you can pass. InfosecTrain Trainer: So there is a huge probability of almost you have 60, 70 questions, right? Which, even if you go wrong, you'll be able to pass. But don't target this. InfosecTrain Trainer: That's why I keep everyone... the target is 70%, all of you. InfosecTrain Trainer: All the practice exams you do, all the questions you solve, always keep the target of 70% in mind. 70% is the baseline, which all of you have to achieve. InfosecTrain Trainer: Because you don't know that in the exam, probably a difficult question may also come, because the questions randomly comes from a big database. InfosecTrain Trainer: From there, they'll throw you 150 questions, so you don't know from that database which particular set would be coming to you, right? That's why you have to always prepare for the difficult InfosecTrain Trainer: So, always keep this particular baseline in mind, and then prepare. So, this is the passing. Now, next, coming to the InfosecTrain Trainer: experience. I hope all of you InfosecTrain Trainer: have minimum 5 year of experience. Anyone here who has less than 5 year experience? Here. InfosecTrain Trainer: In the training session. InfosecTrain Trainer: Anyone? InfosecTrain Trainer: Who has less than 5 years of industry experience. Fatha: Okay, total experience, you mean to say, right? Not, specific to Infosec. InfosecTrain Trainer: No, no, that Infosec is required, but you can showcase it. It can be cross-verified, that's not an issue. InfosecTrain Trainer: At least 5 years of experience you should have. Fatha: Yeah, yeah.

InfosecTrain Trainer: Yeah, so I hope all of you have. Shivaganeshan S: Four years, myself for Shivan. InfosecTrain Trainer: But do you hold any four-year degree? Shivaganeshan S: Yes, yes, I have completed the OB Tech. InfosecTrain Trainer: Then you will get in concession, so no issues for you. Shivaganeshan S: Oh. InfosecTrain Trainer: Yeah. InfosecTrain Trainer: So I think then this side, all of you are clear, right? All of you hold that amount of experience. Once you... InfosecTrain Trainer: submit the application for the exam. Once you clear the CISM certification, then you have to pay the \$50 fee, as I showed you, and fill out one form. InfosecTrain Trainer: That form is equivalent to once you apply for any job, right? So then, in the job, when you apply over the workday and all, they ask you for the experience, right? In this year, from this year, I worked in this company, this year to this year, I worked in this company. So that's how you have to show at least 5 years of experience. InfosecTrain Trainer: But if you have that degree, or InfosecTrain Trainer: you have probably any other certification. Someone told they already hold CISA, so they'll get a discount of 2 years. InfosecTrain Trainer: In that, so they have to only show the experience of 3 years. So that, once you fill out those details, automatically that concession will get applied to you, right? InfosecTrain Trainer: But what experience you have to show? It's a three... InfosecTrain Trainer: year, at least experience across 3 domains. Out of 4, at least 3 domains, you have to show some experience. Suppose you are a developer. InfosecTrain Trainer: You are not in cybersecurity, but as a development work also, you might be engaging in some security aspect.

InfosecTrain Trainer: You might be working with the OASP, you are... might be something doing with the risk management, right? Some experience you can show, so that's not an issue. You can always draft that experience accordingly. Once that is done, once you submit the application, someone from your organization need to validate or verify. InfosecTrain Trainer: You have to write their email ID, where they'll get a link through which they have to verify and validate that I know this person. InfosecTrain Trainer: He has this experience, and that person is not mandatory to be an ISACA or IST Squad certified. Anyone can do that. Either your colleague, your lead, your manager, whomsoever you have a good, probably, understanding, you can share their details, and then they'll get a link. InfosecTrain Trainer: they can validate. So that's what is the process, and then there is some ethics code, which ISACA want you to agree, because InfosecTrain Trainer: so that you won't be sharing those questions outside to the people and all, that's what the ethics course said. So this is an overall application process, which I explained to you. InfosecTrain Trainer: Any question here in this application process? InfosecTrain Trainer: Alright. Johnny Souriar: Also not. InfosecTrain Trainer: Yes, Johnny? InfosecTrain Trainer: You have a question, Johnny? Johnny Souriar: No, sir, no, sir, can't proceed, please. InfosecTrain Trainer: Okay, sure, sure. So now, coming to the registration, so I've already explained you in detail how to register. I have showed you the ISACA portal. You go there, create your ID, pay a fee. InfosecTrain Trainer: to register for the exam, which is not necessary you do it now.

You can create an account, registration you can do once you complete the training, or... or in between the training. InfosecTrain Trainer: How many here... InfosecTrain Trainer: already have some date in mind when they want to write the exam and clear. How many of you have? InfosecTrain Trainer: probably someone would already have a date in mind, right? I'll be probably... because the training is getting concluded in a September 2nd week, so probably you might... you can write any time after 3 weeks. InfosecTrain Trainer: So, 12th September, we conclude the training. Any time in October onwards, you can write. Pudir: Yeah, Sep, sir, I am planning in September ending. InfosecTrain Trainer: Okay, good. InfosecTrain Trainer: So, all those, those who are trying... so, 12th will complete, conclude the training. After that, you require 2 to 3 weeks of effort. Now, that also depends on the level of understanding currently you have. InfosecTrain Trainer: If in current company, you already probably working in a governance, information security domain, you have a good amount of experience, for you, digesting this content would be easy, but someone probably who is from InfosecTrain Trainer: maximum experience is from a non-security background. Probably someone was a developer, someone was in IT service management, or in some other domain. Now they are jumping into this particular cybersecurity for them. InfosecTrain Trainer: It may require more effort, probably a month's worth effort. InfosecTrain Trainer: So, that is more than sufficient to clear the exam, right? Now, I've already told you about the fee, certification cost, right? So, that you have to use, then you can schedule your exam.

InfosecTrain Trainer: October end, yeah. That's why I told you, 5th November is the date.

So, any date before that is, good enough. InfosecTrain Trainer: And ISACA offers you to rescheduling two days before your exam. You can reschedule at free of cost. Two times you can do that. InfosecTrain Trainer: So suppose you, you kept the date as, probably, 30th September, and due to some reason you are not prepared and all, you want to push the date by 10 days, you can do it, at free of cost. InfosecTrain Trainer: So, that is also there. InfosecTrain Trainer: Now, coming to the relevance. So, we talked. Mukesh Thakur: It's a shunk. InfosecTrain Trainer: Yeah, yeah. Mukesh Thakur: I have a question. So do we also get any, re-attempt option in case, suppose in first attempt we are not able to clear? InfosecTrain Trainer: No, that kind of facility is not there with ISACA. ISC Squire has a voucher code where you can pay an additional amount, and you get two attempts in that. InfosecTrain Trainer: Right? They call it the peace of mind. But here in Ayesaka, there is no such thing, so... InfosecTrain Trainer: You only get an attempt. If you don't able to clear, again, you have to pay this fee, once again. InfosecTrain Trainer: That's why when you are fully confident, then only go and write the exam. Mukesh Thakur: Got it, thanks. InfosecTrain Trainer: So, you can see there are 4 domains, right? And this is what the weightage I was talking about. So, domain 1 consists of 17%, 20% is the next domain, which is the risk management, 33% is the program management, and the incident management has 30% weightage. InfosecTrain Trainer: So that's how the weightage is divided. So all the 150 questions would be InfosecTrain Trainer: Coming from these domains as per the weightage which is given here.

InfosecTrain Trainer: So, maximum number of questions coming from the last two domains, almost 63%. So, if you have a very good understanding around these two domains, then InfosecTrain Trainer: You have a high probability of clearing the exam. InfosecTrain Trainer: However, all the four domains are important and related, but you will get a good question... a good number of questions from these two domains, right? InfosecTrain Trainer: No. InfosecTrain Trainer: Can someone tell me what this first statement means? What is the security practitioner? Fatha: It means not individual contributors, it is for the managers. InfosecTrain Trainer: it's not only about individual contributor. A lot of individual contributor may also be working as a InfosecTrain Trainer: kind of a role as a manager, right? A lot of their individual contributor role, but they are in the leadership role, in the security. So, individual contributors can also write the CISM exam, right? But InfosecTrain Trainer: It's mainly about the mindset. InfosecTrain Trainer: So, if I ask all of you, which is the best cloud provider, what do you... what do you suggest? So, my organization is looking for... to migrate to a cloud. InfosecTrain Trainer: So, my management is asking, which is the best cloud provider, which one we should go for? What would you suggest? Johny Souriar: private cloak. Fatha: Thank you. Fatha: depends on what exactly in detail we need, right? The capacity, the encryption, The connectivity, all those stuff. InfosecTrain Trainer: Depends on the business. InfosecTrain Trainer: Depends on the organization needs, depends on the budget. InfosecTrain Trainer: All those things need to be factored in, right? That's what's called the manager mindset. So, any question in the exam.

InfosecTrain Trainer: All the questions which you will get, you have to think like a manager. You have to build that mindset. InfosecTrain Trainer: Just don't go with the correct option, just don't see A, B, C, D4 option, what is the correct? Go ahead, just take it, no. InfosecTrain Trainer: You have to read all the four options, understand what question is trying to ask, always go with the option which is aligned, which is talking from the risk, strategy, management, all those things, those options which suffice. Only that option is going to be correct. InfosecTrain Trainer: In most of the questions, all the four options would look correct. InfosecTrain Trainer: That's what I'm saying. Almost 60% question in the exam you will get, where four... all the four options will look correct to you. You have to choose that right option. That's why you have to build this mindset. I will share you some couple of videos, right, which you can watch. However, we will also discuss here InfosecTrain Trainer: That... what is that think like a manager mindset, how to choose, and... InfosecTrain Trainer: Over the course of this training also, we will be solving close to InfosecTrain Trainer: 50 to 100 plus questions, more than that, which will help you to build that mindset, that how you follow the elimination, how you choose the correct answer, right? So, don't worry, we will discuss that strategy. InfosecTrain Trainer: Now, these 150 questions I already told you, exam is of 4 hours. Now, how do you InfosecTrain Trainer: Utilize that complete 4 hours, So, if I say 4 domains, Right? InfosecTrain Trainer: So, if you have a good understanding, if you have a very good knowledge, probably 50-minute InfosecTrain Trainer: For each domain is more than enough.

InfosecTrain Trainer: So, 15, InfosecTrain Trainer: not 50 minutes for each domain, 50 minutes for 50 questions. So you have to... you have to attempt 50 questions in 50 minutes. 10 minutes is the buffer, which is kind of a breakage you can take, right? InfosecTrain Trainer: That's how, in 3 hours, you will be able to complete the exam. Now, best part of the CISM is that InfosecTrain Trainer: Once you see the exam. InfosecTrain Trainer: you will be able to see all question 1, 2, 3, till 150 here at the right-hand side. There is going to be one UI, which will show you all the questions at one go. You can jump to any questions if you want, plus you can flag any questions. InfosecTrain Trainer: It's not like that if you solve one, you will be redirected to two, and then you cannot come back to one, question number one, right? So you can flag any questions. So once you are attempting the question, so this is more from the strategy perspective, continue your flow, continue your pace. InfosecTrain Trainer: First, second, third, fourth questions, you... it's very difficult for you to understand, you can flag it. InfosecTrain Trainer: 5, 6, don't waste too much time on a question where you don't understand InfosecTrain Trainer: the concept, or you are confused, you can flag it, but don't mark more than 15 to 20 questions, because at the end InfosecTrain Trainer: you probably... InfosecTrain Trainer: would be already exhausted, may not have a good, probably that, that kind of mindset when you started, so don't match 50 questions for the review, then InfosecTrain Trainer: it becomes very difficult. Don't mark more than 15 to 20 questions for that. InfosecTrain Trainer: Review, which you can review at the later, and then you can choose the correct answer, right?

InfosecTrain Trainer: So this is a good part of the CISM, where you can flag the questions, you can mark it, you can revisit later, and don't break the flow. InfosecTrain Trainer: Continue to solve the questions till the end, right? InfosecTrain Trainer: And the center, which I was talking about, is called the PSI Center, that's what I'm saying. So this 10-minute break, you want, you don't, it's up to you. Probably after 2 hours, you can take a break. So in a break, you can take... get out of the chair, and you can drink water, come back and sit, relax. InfosecTrain Trainer: But clock won't stop. Clock will continue to run. Don't think that, if you take a break, so you can pause the clock, no. Clock will continue to run, but you can take a break. InfosecTrain Trainer: If you're writing it from your home, online, there is no breaks. InfosecTrain Trainer: Because continuously, Proctor is looking at you, right? He won't let you go out of a screen. You have to finish, you have to probably keep all the water bottle and everything next to your PC, and that you have to sip it there only. There is no option to go. If you... InfosecTrain Trainer: take complete 4 hours, so you will be continuously sitting 4 hours in the chair. There's no options to you. So that's why I recommend go right from the PSI Center. SrinivasanJ: So, if we are, writing this exam from a center, there won't be any practice? InfosecTrain Trainer: So, so their assets... no, so that center is asset proctored. So, so there is an exam room where they will not let you take anything. InfosecTrain Trainer: You cannot take anything with you. Everything they'll keep outside, so as such, you cannot do anything there, right? InfosecTrain Trainer: So, it's kind of a proctored only.

They'll check your ID and everything, they'll tell you to keep your bags in the locker outside, then you can go ahead and write the exam. SrinivasanJ: Mr. InfosecTrain Trainer: So these points we already discussed, right? 450 score, 5-year experience, 1-year concession. If you have a 4-year degree, someone already told. If you have an ISACA certification, like someone has CISA, he'll get 2-year concession, so only 3-year experience they have to show. InfosecTrain Trainer: And you can then verify it, validate it through manager or team lead, and you get certified. Fatha: So, Saxena, do we need to... sorry, InfosecTrain Trainer: Yeah. Fatha: So, do we need to declare this experience, everything, during the registration of the exam? InfosecTrain Trainer: No, no, no. That will come once you want to claim for the certification. Fatha: After the exam. InfosecTrain Trainer: Yes. Fatha: Okay, thank you. Mukesh Thakur: So, after passing the exam, we have to claim for the certification from ISACA by submitting this 5 years of experience in Saka. InfosecTrain Trainer: I've got it. Mukesh Thakur: Yeah? Okay. InfosecTrain Trainer: And you get 5 years for that. InfosecTrain Trainer: Suppose someone only has 3-year experience, you cannot... InfosecTrain Trainer: show that you are certified in CISM, you have just cleared the exam. InfosecTrain Trainer: So you... you can submit that experience after... within any 5-year window also. So that flexibility ISACA provides. So probably after one year you want to pay that \$50 fees and do it, you can do it. Or immediately you want to do, you can do it immediately also. Mukesh Thakur: So, after passing the exam, we don't get certified. Do we get any kind of scorecard or something that we have passed the exam? InfosecTrain Trainer: Yes.

Yeah, a scorecard you will get, not at the center. InfosecTrain Trainer: At the center, on a screen, you will just get a prompt that, Mukesh, you have InfosecTrain Trainer: pass the CISM exam. That's it. InfosecTrain Trainer: nothing other than that. Then after a week, 10 days, automatically a result would be shared with you over your email ID, registered email ID. Mukesh Thakur: Got it, thank you. InfosecTrain Trainer: Now, coming to the material which you will be using for the study, right? InfosecTrain Trainer: This is all the reference material, but how many of you don't like reading the books? Because I hope you have come here to the training, you are doing a training. I... I feel... I'll try my best to teach it in a manner that you need not to read a book. InfosecTrain Trainer: You can just refer the book wherever you feel you are... you don't have a better understanding around the topic, but InfosecTrain Trainer: You can listen to the recording, you can attentively listen to me, what I'm teaching in the session around the topics. That is more than enough to clear the exam and write the exam.

InfosecTrain Trainer: So, that's the good thing. Now. InfosecTrain Trainer: there are some official material, which we will also provide. I hope all of you have got access to the Google Drive. InfosecTrain Trainer: Let me show you that Google Drive. InfosecTrain Trainer: Nick. InfosecTrain Trainer: So, this is your Google Drive. InfosecTrain Trainer: Which all of you have access to. So, all the. Johnny Souriar: Received the link, yeah. I have not received the link yet, yeah. Sreya Mathew: We have no access yet. InfosecTrain Trainer: Okay, okay, no problem. I'll share it here in the group, then. InfosecTrain Trainer: I can ping you here.

InfosecTrain Trainer: someone, if they have opened the WhatsApp web, they can probably InfosecTrain Trainer: do it. Probably you can check your, registration or the welcome email. You would have got it there. InfosecTrain Trainer: So, if you don't... you are not able to access to this Google Drive, you can probably... InfosecTrain Trainer: Talk to, InfosecTrain Trainer: to the person who is Saxa, right? You can ping him, he'll extend you the access. InfosecTrain Trainer: Well, by the end of today or tomorrow, you will get that access, don't worry. InfosecTrain Trainer: This is what is there in the Google Drive, so I'll just walk you through so that InfosecTrain Trainer: A lot of people get confused which questions to use and all. You see something called the CISM Practice Test. InfosecTrain Trainer: Don't use them now. InfosecTrain Trainer: park it InfosecTrain Trainer: for the practice once you complete the CISM training, right? So don't use them now. So, whatever thing which is sitting here on the route. InfosecTrain Trainer: You can use this... these tests after, once you complete the training, right? InfosecTrain Trainer: Now, go here, there is a... InfosecTrain Trainer: there are two folders. One is book, one is domain-wise notes. InfosecTrain Trainer: If you go here in the book, so we have already provided you two books. InfosecTrain Trainer: This is a reference guide, CISM official reference guide. InfosecTrain Trainer: Which is an official guide from CISM, which is there with you, you can use it. Also, we are providing you the Haman Doshi book. InfosecTrain Trainer: That you can use. So these are the two books which have been provided to you.

This is the question-answer manual which you will be utilizing throughout this particular training to practice and solve the questions. InfosecTrain Trainer: So, I'll tell you how to use it. InfosecTrain Trainer: This particular QA manual has almost 700 to 800 questions, so each domain has some questions. Once we complete a Domain 1 by end of InfosecTrain Trainer: Tomorrow. InfosecTrain Trainer: I'll tell you to go and start solving the questions. So if you continue to solve these questions with me. InfosecTrain Trainer: Over this period of training, so that once we complete the training, you can InfosecTrain Trainer: do the revision for 3 weeks, and you can go ahead and write. But if you don't do that, then it will take you a longer time to do that. So please continue to follow my instruction. InfosecTrain Trainer: But this question bank is designed in such a manner, you have the answers for each question which is available immediately after the question, right? So how I used it when I was practicing? InfosecTrain Trainer: So I used to only scroll up to the question and the options, not seeing the answer, and then used to record those correct answers in some Excel sheet, and then later on, compile InfosecTrain Trainer: You see, correct answer is there, so you just scroll up to here, solve question number one. InfosecTrain Trainer: then do two, and likewise, you can do it. So that's how you have to use this. InfosecTrain Trainer: So this is the... Study material which you have got. InfosecTrain Trainer: So these are the two official material, which is already sitting there in the day... in that drive, which you will get an access to. Apart from that, there is one more book, which is the Hemang Doshi book, which is there.

InfosecTrain Trainer: Don't go ahead and read multiple books. That won't solve anything. You will get confused, you will waste a lot of time, because so many topics and so many things are there, explained in a much more detail. If you want to become an instructor, you want to probably do a PhD on InfosecTrain Trainer: ISACA, then you can do it. But if you... your aim is to clear the exam, understand the topics. InfosecTrain Trainer: the training and one odd book is more than enough, not more than that. But this book, why I recommend, I don't recommend this review manual, because this InfosecTrain Trainer: book is written in a very plain language. Like, you will get bored after reading two, three pages. But this pocket prep from Hemang Doshi, this book is written in a comics format. So he has written each and every topic. InfosecTrain Trainer: You have explained them in the form of a comics, which you've read when you were kids, right? And after each topic, there is going to be a practice test of 10 to 15 questions. InfosecTrain Trainer: So, once your training is done, once you are solving the questions, you understood that you are getting one particular topic questions wrong every time. Like, suppose you InfosecTrain Trainer: could not understand the roles and responsibilities. So, you can go ahead, read that topic, solve the questions, clear your doubts. So, that's what you will use the Hemang Doshi for, right? Other than that. InfosecTrain Trainer: there are some other resources, like, I'll be sharing the links of the Paramas Coffee Shot. So, he has a YouTube channel, he's also from the InfosecTrain, I'll be sharing his coffee shop, he has a YouTube channel, so you can follow those videos for revision. InfosecTrain Trainer: Also, to clear your doubts.

InfosecTrain Trainer: Then there are things like a Manager video, which I'll share, which is from the Gwen Beckwy, which will help you to understand how to select the correct answer out of those four questions, how to read the questions. InfosecTrain Trainer: how to think like a manager. So, I'll share this, and then this instructor-led course, which you... people are already doing it. So, these are the... some of the resources which you will be utilizing. InfosecTrain Trainer: For preparing for the exam. InfosecTrain Trainer: Now, coming to this particular thing, which is the most important thing for the CISM exam. InfosecTrain Trainer: And... If you want, you can make a note of it. InfosecTrain Trainer: Whatever you study, even if you study for 6 months straight, but if you don't have this particular mindset, every time you will be... end up getting questions marking incorrect. InfosecTrain Trainer: That's why I'm telling you, please. InfosecTrain Trainer: start forgetting what you had learned, and start approaching the questions from the ISACA perspective. That's why this certification is a little difficult. InfosecTrain Trainer: They don't ask you very straightforward questions related to some technical topic, where some technical topic would be there, and you just know that... if you know that technology, you just go ahead and take InfosecTrain Trainer: This is not like that. That's why the exam is designed for the managers. InfosecTrain Trainer: You have to think from the strategy, risk, all those things you have to apply. You have to engineer your brain accordingly, and then answer. So you see, what is the technical mindset?

InfosecTrain Trainer: So, if you are... rather than directly solving problem, any option in the exam which is directly solving any situation, that would be 90% of the time would be incorrect. InfosecTrain Trainer: Anything which is talking about InfosecTrain Trainer: doing the risk assessment, creating the strategy, understanding the business, those are the correct answer. Like, directly fixing the vulnerability. No. InfosecTrain Trainer: You have to first understand the risk, prioritize, then you fix. InfosecTrain Trainer: Even these things are applicable in your day-to-day, in your organization also. You don't directly go ahead and fix something. You first understand the situation, then you do that. If tomorrow there is an incident going on, suppose there is a priority one or priority 2 incident going on, will you directly jump... go ahead and contain the issue? InfosecTrain Trainer: First, you will understand, right, what is the blast radius, which all systems are affected, where the things are going bad, then you see, okay, then this looks a better strategy, then you go ahead and deploy, right? That's what the approach you take. So that is the mindset you require, right? Like, patching all the systems. InfosecTrain Trainer: You have to always balance the cost versus risk reduction. InfosecTrain Trainer: Patching all the systems won't work. You have to see how many of those systems are low priority, probably sitting in a non-production environment, probably not accessed via directly to the internet. InfosecTrain Trainer: So, they become less critical. Something which is in production, something which is directly internet-facing, they become the high priority. So, that you have to do. InfosecTrain Trainer: blocking the suspicious traffic immediately.

You have to first evaluate the impact, because if you block the traffic, probably the business who is sitting on the other side of the firewall, they will also not be able to access those things, right? So that's why you have to first evaluate the impact, business operations, then you have to choose. InfosecTrain Trainer: Also, Deploying a very high technical control. InfosecTrain Trainer: just by deploying any sophisticated technical control won't solve your problems, right? You have to always align security with the business objective. If I know that setting of 18 to 20 character password is a good, but is it feasible for the people to remember 18 to 20 character password? InfosecTrain Trainer: Probably not. InfosecTrain Trainer: So that's why what I'll do, I'll say, okay, let's set a InfosecTrain Trainer: 12 to 14 character password, and... Establish SSO. InfosecTrain Trainer: So that's how you have to balance between the security and the business objective. InfosecTrain Trainer: deploying additional security measures or two. You have to always look for the findings to the leadership, and then understand, then deploy. InfosecTrain Trainer: So these things you have to be very clear in your mind, now coming to the questions. Each question in the exam would contain these kind of keywords. InfosecTrain Trainer: And they changed the answer to the question. InfosecTrain Trainer: So... so each So, each question... InfosecTrain Trainer: So, each question will have either of these options. Either you will see the greatest, first, most, best, and main, and sometimes it's there in the same... written like the same in caps. InfosecTrain Trainer: So you need... you need to understand these keywords very properly. What is the meaning of each, and why it changes the question, right?

First thing coming to the greatest. InfosecTrain Trainer: Greatest means... something which is... Something which is an umbrella answer. InfosecTrain Trainer: Something which covers all other options. That becomes a greatest. InfosecTrain Trainer: Right? So you will be seeing some questions, I'll discuss those options, right? Which probably cover all other three options. InfosecTrain Trainer: Right? InfosecTrain Trainer: Like, if I talk about... if I say any

misconfiguration in the policy. So, misconfiguration in the policy, or non-compliance with respect to policy. So, policy is a broad term. InfosecTrain Trainer: Right? So policies are applied to firewall also, policies are applied to your AD... your AD also, policies are applied to other technical controls also. InfosecTrain Trainer: So, if you see the policy, so it's an umbrella answer, right? InfosecTrain Trainer: This is about the sequence. InfosecTrain Trainer: So, if I ask. InfosecTrain Trainer: that there is an phishing incident, phishing email reported by an employee to a SOC team, what is going to be the first step for them? What will they do first? Sreya Mathew: validate the... SrinivasanJ: Equid. Sreya Mathew: incident post. InfosecTrain Trainer: Yes, first you will validate, right? InfosecTrain Trainer: you have to validate that was it a true positive, was it a false positive, right? Then only you will go ahead and then take the next steps. So that's how... so there are going to be the questions where you have to see what is the sequence the question is talking about, which InfosecTrain Trainer: step would be coming first than this. So, those are one. Now, most... most is something which is the very often and the regularly followed. Which is the most important book for the CISM profession?

InfosecTrain Trainer: Animal, which is the most important book for the CISM preparation. Sreya Mathew: I sucker for sure. Fatha: Okay. InfosecTrain Trainer: Correct. Because the ISACA official guide is something written by the ISACA, published by the ISACA, covers all the important topics what ISACA wants you to check in. So, that is the most. But I will say, what is the best approach to clear the exam? InfosecTrain Trainer: What would you suggest? Sreya Mathew: instructor-led training. InfosecTrain Trainer: Best would be, donor... Fatha: Questions. InfosecTrain Trainer: yeah, do the training, watch the video recording, right, and then read the topics from the books, which probably you don't have understanding on, then you clear the exam. That is the best approach. InfosecTrain Trainer: And the main, main is something which is the primary. InfosecTrain Trainer: Primary in that particular question, which is the main reason InfosecTrain Trainer: In that particular question, or the context, that becomes the main. InfosecTrain Trainer: So these are the keywords which you have to look into all the questions I have. InfosecTrain Trainer: a couple of questions after the slide, which you can... which will discuss that how these options are changing that particular perspective. Now, apart from this, there are a couple of other things which you have to keep in mind. InfosecTrain Trainer: Let me tell you, CISM exam is... is sometimes test your English. InfosecTrain Trainer: I'm telling you, you have to be very careful with the tenses. InfosecTrain Trainer: You have to be very careful with what question is trying to ask. InfosecTrain Trainer: Right? Just don't just directly read the question and just jump onto the correct option, no. You have to read the questions properly, right?

InfosecTrain Trainer: So, what does writing need to be validated? So, whenever you are attempting the question, right, you have to keep one thing in your mind, that InfosecTrain Trainer: something which is written does not mean that it is being followed, right? You have to keep this particular theme in mind. Always, you go look and verify. InfosecTrain Trainer: If your third party says that we have all the good security controls implemented, will you believe them? No, you will tell them that please share your SOC2 report. I would like to have a look at the SOC 2 report. If it's a SaaS solution, you will say to them, please share me your latest pen testing report. InfosecTrain Trainer: Right? So, that's... it means. Writing needs to be validated. Whatever is written does not mean it's happening. You have to always go look and verify. Next, coming to the sequence. So, the first, next, these kind of keywords talk about the sequence. InfosecTrain Trainer: Right? So when you are doing the risk assessment, so what is the sequence? First, you take an inventory of asset. InfosecTrain Trainer: Once the inventory of asset is there, then you will be doing the vulnerability assessment and threat, you will be identifying the threat, then you will be creating a list of vulnerability. That's how the sequence works. InfosecTrain Trainer: So there are topics in this particular, in the CISM exam, which InfosecTrain Trainer: Are directly related to the sequence. InfosecTrain Trainer: So that's why you have to understand those topics and understand the sequence, so that you can answer those kind of questions. And I'll tell you, these are the easiest questions in the exam.

InfosecTrain Trainer: If you know... if you have a good understanding around the topic, you know the sequence, you can easily reach to the correct answers, right? InfosecTrain Trainer: Next, coming to the scoping. InfosecTrain Trainer: So there are... these are kind of the... InfosecTrain Trainer: umbrella answers. That's what I talk about the greatest, right? InfosecTrain Trainer: some... You have to always look for the option which covers all other. InfosecTrain Trainer: Probably it's not necessary that that option might be covering all the rest of three. Probably that option might be covering two options, or one other option, right? So always look for a question which is covering multiple choices. That is going to be the correct answer. So if I talk about the InfosecTrain Trainer: risk management. InfosecTrain Trainer: So the risk management is a process which includes the risk identification, the risk analysis, and risk treatment. InfosecTrain Trainer: So, risk management is an umbrella answer. InfosecTrain Trainer: Right? Now, coming to the users of Pence. Policy... Has been developed. InfosecTrain Trainer: Policy is being developed So, it changes the perspective, right? InfosecTrain Trainer: In the first, which I told the sentence, the policy is already existing. InfosecTrain Trainer: In the next, the policy do not exist, it exists, it is being developed, right? So that's why you have to understand this usage of tense, and accordingly choose the correct answer. And next, coming to the outcome, you have to understand the output of couple of processes. So what is the outcome of a risk management? Reduce the risk to an acceptable level. InfosecTrain Trainer: This is an outcome. What is the outcome of this training? InfosecTrain Trainer: you want to clear the CISM exam, right?

InfosecTrain Trainer: That's what is the outcome. InfosecTrain Trainer: So... so you have to understand these particular things, that's why... I'm yet to start the CISM syllabus. I'm just only talking... so every training I take, initial one and a half to two hours to first make all of you understand about the CISM, understand this mindset, then I'll start the training, right? InfosecTrain Trainer: Now... how these things are applied, right? What we discussed, right? InfosecTrain Trainer: So, sometimes, all the questions which you will see the exam, you have to follow these four principles. InfosecTrain Trainer: Right? So you have to see that what is technically correct, but sequence is wrong, right? InfosecTrain Trainer: So, can you patch a server before doing a risk assessment? InfosecTrain Trainer: You cannot, right? First, you have to assess the risk. InfosecTrain Trainer: What if... if you deploy a patch, and something goes wrong, and then your production gets impacted? InfosecTrain Trainer: That's why what you do, you go and test the patch in the non-production environment, right? First you verify, then you do that, right? InfosecTrain Trainer: So, this is the first thing which you have to understand. So, always assess, plan, then act. InfosecTrain Trainer: This sequence, you remember. InfosecTrain Trainer: Then, always take a proactive approach. Always go for a proactive approach rather than reactive. InfosecTrain Trainer: What is a proactive approach? If you do an assessment, you deploy a control, you keep validating those controls, so it's a proactive approach. Rather than looking for an incident, once incident will happen, then I'll go and fix the issues, right? InfosecTrain Trainer: So, like, blocking traffic versus identifying the root cause.

So, identifying the root cause is a productive approach, so that the next time that issue won't occur. InfosecTrain Trainer: So, ISACA... Expect all of you to have this proactive approach, strategic thinking, rather than reacting to the situation. InfosecTrain Trainer: Next thing is the good answer and the wrong priorities. InfosecTrain Trainer: So, like, you are training all your employees instead of implementing the control. InfosecTrain Trainer: First, you have to implement the control, then you have to train the employees, right? Then the overall posture will become correct. InfosecTrain Trainer: So, this thing is next. Next thing is the true granular toolkit. Any question, any option which you see, which seems to be very technical in nature, very technical. InfosecTrain Trainer: topics, or technical keywords, or jargons which are getting referenced to. Most of the time, those are not going to be the correct answer. InfosecTrain Trainer: So, from a manager perspective, manager, think from a governance, risk, strategy, right? Manager, don't get into a very deep technical control. So, always InfosecTrain Trainer: look for those things. Now, let's discuss some questions. InfosecTrain Trainer: Yes. InfosecTrain Trainer: Yeah, all of you can just... InfosecTrain Trainer: Solve these questions and drop your answers in the chat. InfosecTrain Trainer: Alright, let's discuss the correct answers. InfosecTrain Trainer: Which of the following is the greatest risk that an information security manager must address when an organization rapidly adopts cloud services without adequate governance?

InfosecTrain Trainer: Increased complexity in managing multiple cloud vendors, potential for data exfiltration due to misconfigured cloud security settings, difficulty in integrating cloud security logs with on-premise SIM solution, reduced control over physical security of cloud data centers. InfosecTrain Trainer: the first thing. InfosecTrain Trainer: Always, whenever you are attempting the questions, always go with the elimination technique, which I'll... which I'll just teach you. InfosecTrain Trainer: Read all the questions, and then say that why this option is not correct or incorrect. InfosecTrain Trainer: Next, first option, increased complexity in managing multiple cloud vendors. InfosecTrain Trainer: Is the question talking about adopting multiple cloud providers? Is it referencing somewhere? InfosecTrain Trainer: No, right? So, eliminated. Let's path B for the later. Difficulty in integrating cloud security logs with on-premises SIM solution. It's a very technical InfosecTrain Trainer: very technical option, right? As I told you, don't always go with a very technical... only referencing to one particular... will you only select or deselect or adopt the cloud services and only issue with the CIM solution? No. InfosecTrain Trainer: Reduce control over physical security of cloud. So that is always an acceptable risk for all the organization. Whenever you go with the cloud, you always know that there is no, control over the physical security, right? But if you see option B, InfosecTrain Trainer: misconfigured cloud security setting. So, misconfiguration Cloud Security Setting can InfosecTrain Trainer: be... it's a kind of an umbrella answer.

There can be the misconfiguration in the... in the rules, there can be the misconfiguration in the policy, there can be the misconfiguration in any other thing, right? So, when you are rapidly adopting to the cloud services. InfosecTrain Trainer: you don't have a proper governance in place, and people are rapidly deploying the things without that governance, it will cause these issues, right? So that's why correct answer, option B. InfosecTrain Trainer: Which of the following represent the best approach for an information security manager to regularly measure and report on the effectiveness of information security program to executive management? InfosecTrain Trainer: Think from an executive management perspective. Providing raw technical vulnerability scan report. Will executive management be able to understand the raw technical report? InfosecTrain Trainer: They'll not. InfosecTrain Trainer: As such, eliminated. B will park it InfosecTrain Trainer: C, submitting a detailed list of all security incidents with their immediate step, remediation steps annually. InfosecTrain Trainer: What will they do with the detailed list of security incidents? If you submit a list of 50-20 incidents, what will they do with that? InfosecTrain Trainer: Will they be understand, able to probably take out any important data out of it? No. They probably would be only interested in the priority incident, which had some significant impact, right? InfosecTrain Trainer: Conducting an ad hoc meeting whenever a significant security event occurs. This do not show a good culture. InfosecTrain Trainer: That only reporting or only doing something when some bad happens, no? InfosecTrain Trainer: So, option B is something which you will see most of the, time, a good practice, right?

Presenting a quarterly dashboard, summarizing the KPIs and the KRIs with business objective. InfosecTrain Trainer: Looks to be a good option, right? Because executive management would be able to understand what are the key risks, what are the key performance indicators, and then we would take decision, right? So these were two keywords. Now, let's discuss questions on other three keywords. InfosecTrain Trainer: Alright, let's discuss the... Correct answers. InfosecTrain Trainer: I think I can see most of you got most of the answers, correct? Okay. InfosecTrain Trainer: Upon discovering a potential information security incident, which of the following is the first action an information security manager should ensure is taken? Now, see how I'm taking and approaching this question. First means talking about the sequence. InfosecTrain Trainer: Right? InfosecTrain Trainer: Always look for what are the important keywords in the question, right? So. InfosecTrain Trainer: So here, in this question, first thing is the... this particular keyword, and then... InfosecTrain Trainer: What are the actions which need to be taken in case of there is a security incident going on? Notify all affected external stakeholder and regulatory body, yes, that is going to be a step. Isolate the affected system to prevent a further spread of the incident. Will A happen before B? No. InfosecTrain Trainer: A will follow after B. InfosecTrain Trainer: Conduct a detailed forensic analysis to identify the root cause. Forensic analysis will also happen after the B, so this is eliminated. Restore the affected system from the latest known good backup. This will also happen, the B. First, you have to isolate the spread, then you will go with the other option. So, correct option here is B.

InfosecTrain Trainer: When determining the information security strategy, which factor should be... should the information security manager consider most significantly? InfosecTrain Trainer: The latest cybersecurity technology trend and vendor offering, yes, that also is going to be part the organization's overall objective and risk appetite. If you do not understand this craver, don't worry, we'll discuss in detail. InfosecTrain Trainer: the current skill set and the training level of security team, okay, benchmarking against industry leaders in security spending. So, out of all A, C, and D, can you InfosecTrain Trainer: Create a strategy without understanding what organization objectives are, what organization want to achieve, and what is their risk appetite. You cannot. InfosecTrain Trainer: So? InfosecTrain Trainer: That's why correct option here is B, not A, C, and D, they are eliminated. What is the main purpose of establishing an information security governance framework within an organization? InfosecTrain Trainer: Main means primary. What is the primary purpose of doing that? InfosecTrain Trainer: To ensure compliance with all applicable legal regulatory requirements, yes, do you want to do that? To define technical security control for all IT systems, to provide strategic direction, establish accountability, and ensure that information security support business objective looks to be a good option. InfosecTrain Trainer: to manage the day-to-day operations of security teams. So, if you read option A, B, and D, option C looks to be a better answer. InfosecTrain Trainer: to the problem, right? So that's why a correct option here is C. subaveena pugalenth: Sorry, I just have a question.

So, here it states what's the main purpose of establishing a security governance framework within an organization, right? So, like, legal and regulatory requirements is also one of the main purposes, right? Like. subaveena pugalenth: to me, under that would follow C, like A, and then C. subaveena pugalenth: But I'm not... InfosecTrain Trainer: It says... but it says all applicable legal and regulatory requirements. Do you InfosecTrain Trainer: show compliance with respect to all the legal and related requirements, you cannot, right? Some of them you probably avoid due to strategy, or probably due to the business requirement. subaveena pugalenth: here it says applicable legal and regulatory, right? So, which are applicable to the organization objectives, or something like that? InfosecTrain Trainer: Yes, but is it... is it, sometimes you may accept the risk with respect to some legal InfosecTrain Trainer: Right? Sometimes you may accept the risk because of the business strategy. InfosecTrain Trainer: Right? Suppose a DPDPA law has come in India, and to establish that particular DPDPA framework, a big investment is required. InfosecTrain Trainer: Currently, in this financial year, a company do not have that particular big investment in that direction, so they'll say, okay, we'll accept the risk for two quarters. After that, we'll go ahead and purchase that solution to do InfosecTrain Trainer: Solve the purpose, right? So you accept the risk, right? So always the strategic direction and that, those things will always, and the business objective always comes on priority. InfosecTrain Trainer: than other. InfosecTrain Trainer: Understood? subaveena pugalenth: Okay, I still have confusion, but that's... I'll... I'll try to research.

InfosecTrain Trainer: Yes, so always business... We'll always take a precedence with... even if it's the legal and regulated requirement. subaveena pugalenth: But that's a regulatory requirement, right? Like, that can put you in... like, different situation. InfosecTrain Trainer: Yeah, but sometimes, sometimes business accepts the risk with respect to that. So, regulatory requirements are bought. They will, they will tell you, they will, they will fine you with something, right? InfosecTrain Trainer: Yeah. Some amount, they will say, so if business is ready to accept the risk, they'll accept. They'll say, okay, our company is not, probably do... collecting much of the PII data at this point of time, so we need not to show with the complete InfosecTrain Trainer: We need not to run the complete program with respect to GDPR. So, they can accept the risk. subaveena pugalenth: Okay, okay, now it kind of makes sense. Thank you. Ashwin: I have a question. You don't mount. InfosecTrain Trainer: Yeah, Ashwin: On the previous slide, the third question, the one at the top, so, the options A and B, Ashwin: Now, the question is framed in such a way that the first action an information security manager should ensure is taken. Now, when a potential information security incident occurs, usually it is the SOC team or the relevant technical person who's gonna run the playbook. Ashwin: So they will take care of the technical thing, because isolating an affected system is part of the playbook. Ashwin: Right, the SOC playbook, or whatever it is. And they would inform the information security manager, or the SOC manager, like, so-and-so has happened. Ashwin: the manager is not the one who's gonna go and isolate the system.

His job is to convey that to the stakeholders, or the upper management, right? So, his first action would be to... okay, fine, that has happened. The team is gonna... already taken care, or they're gonna follow the playbook. My job is to ensure, okay, if something happened, I have to inform the stakeholders, or the client, or whoever it is. Ashwin: So let me explain you, let me explain. InfosecTrain Trainer: Explain you. Ashwin: Okay. InfosecTrain Trainer: In the ISACA, we will discuss about the roles and responsibility, but... InfosecTrain Trainer: In any question, you see a keyword Information Security Manager. InfosecTrain Trainer: It's not... do not reference it with the information security manager which is there in your organization. You may have multiple managers, no. Information security manager means leading that particular function which is being referenced in the question. Question is talking about the incident, it's talking about the incident commander. It's talking about the stock manager. InfosecTrain Trainer: So if there is an incident going on, will SOC Manager go ahead and do the reporting first, or he'll first make sure that the incident impact is InfosecTrain Trainer: reduced. Ashwin: Coming back radius, yes. InfosecTrain Trainer: Right? So any question in the exam, don't reference. That's why... yeah, one more thing which I forgot to mention. Never, ever attempt a question from what is happening in your organization. InfosecTrain Trainer: Always attempt and see question what I'm teaching you here, what AICA says. Always forget what is happening in your organization. Every organization, follow a different approach. Every organization has a different org chart. InfosecTrain Trainer: Every organization follows different mechanism.

So don't go approach question from that perspective, that in my organization, things happen like this, so I'll go with this, no. You will end up getting question incorrect. So forget InfosecTrain Trainer: Never, ever take the reference, what is happening in your organization. If you... probably in your organization, probably if your board of directors is very finicky about legal and regulatory, they will say legal and regulatory will always take precedence. But in some organization, other things may be doing... they are doing, right? So always think what ISACA says. Don't go from what is happening in your organization. Sandeep Saxena: I would like to add here, I've managed a global SOC, an incident response. Sandeep Saxena: Incident is not event. There may be hundreds of events stock team is handling. Incident means something bad has already happened. Sandeep Saxena: In that case, as a manager, my first job is to ensure that the Affected system is, you know? Sandeep Saxena: isolated. I have some time for regulatory bodies. For example, I need to report to, what do you call certain. So I have some time for that, for example, 24 hours or something. But the first step has always been, in my experience, you know, to isolate the

system, to ensure that as a manager. InfosecTrain Trainer: First, you have to reduce the blast radius, right? If you don't reduce the blast radius, probably that thing may get spread to other organization systems. Then it would become very difficult for your organization to contain the incident, right? So that's the first step, always. Ashwin: No, I get that part, and I was thinking from, like, my organization perspective, right? Yes. InfosecTrain Trainer: That's why I mentioned all of you.

So all of you, please remember, never ever approach a question from what is happening in your organization. Always approach what I'm talking here. So forget, you have to just... InfosecTrain Trainer: relearn yourself and think, just learn what I'm talking about, then it's going to be very good for you to clear the exam, right? Now, understand how the four domains are related, right? That's what I was talking about. SrinivasanJ: Can you please go to the first set of questions? SrinivasanJ: I just need... yeah, right, I just want to take a snap. InfosecTrain Trainer: Okay, okay, sure. InfosecTrain Trainer: So, yeah, I'll not be sharing these slides. These slides are there for me to... probably it helps me to conduct the session. There are some separate set of slides which are there in the Google Drive, which you can take help and understand, plus InfosecTrain Trainer: But any slide, if you feel... which feels very important to you, you can take a snapshot of that, right? Also, I recommend all of you, if you have any diary, or probably you can open a notepad or a Word document, just make... keep noting some important things, what I'm talking here, right? Not everything. InfosecTrain Trainer: So that, a day before exam, you can just review those 5 to 10-pager notes, and then you can go ahead and write the exam. However, I'll be sharing you the mind maps for all the domains, which will help you to summarize the complete domain. InfosecTrain Trainer: Reflecting the important topics, which you can use them a day before exam to revise. SrinivasanJ: The previous one, sorry, the first quick, Q1 and 2. InfosecTrain Trainer: Yeah. SrinivasanJ: One... Okay. InfosecTrain Trainer: No, no issues. As such, these are just the practice questions which I am just throwing.

It's not related to some specific domain. We will discuss good number of questions. InfosecTrain Trainer: Now, coming to the domains, how those domains are related with each other, right? So, the first domain is a governance. InfosecTrain Trainer: Can someone tell me, what do you mean by governance? Pudir: Government, sir, this is Pudir. Governance is a policy document which builds... it declares the accountability and the system of the office environment, control environment. Fatha: The framework. InfosecTrain Trainer: Governance is something which will establish overall policies, framework. InfosecTrain Trainer: a system for the organization, right? Let's... Step away from the cybersecurity. InfosecTrain Trainer: You imagine a country where there is no government, there is no police. InfosecTrain Trainer: There is no laws, there are no regulations. Now, imagine such a country InfosecTrain Trainer: And then think from a governance. InfosecTrain Trainer: How the thing will happen there, it's going... everything will go... hey, Varya, please. Neethu: Rules and... or kind of practices, right? Yeah. InfosecTrain Trainer: Correct, correct. InfosecTrain Trainer: So this particular domain is about that. How you establish a security governance in the organization so that things happen in a way or a manner, right? How governance happens in a country? You have an elected government, right? InfosecTrain Trainer: Then you have, after the elected government, you have the... the house, you have the laws, you have the police, you have the military, all of them collectively doing what? They are establishing a governance, right? Similarly, in the organization, how governance happens? Does CEO only drive the company? No.

InfosecTrain Trainer: All the public-traded company, there's going to be a board of directors. InfosecTrain Trainer: So, see your report to board of directors. InfosecTrain Trainer: So, board of director, then CEO, then CEO appoints other C-level executives, like chief operations officer, chief financial officer. InfosecTrain Trainer: Right? InfosecTrain Trainer: Chief Information Officer, all C-level executives, right? InfosecTrain Trainer: Like, we... and then... InfosecTrain Trainer: the CISO would be appointed. Now, CISO may report to CFO, COO, or CIO, depends on organization to organization, but InfosecTrain Trainer: As per the ISACA, CISO should report as higher as possible in the chain. InfosecTrain Trainer: Right? So, best possible is the best kind of org chart is if CISO is directly reporting to CEO, but you will never see this kind of scenario where CISO is reporting to CEO, because InfosecTrain Trainer: CEO don't want to take this accountability, so he'll generally transfer this accountability either to COO, CFO, or CIO. InfosecTrain Trainer: Now, coming to the... the next domain, right? So, governance will help you mandate InfosecTrain Trainer: you to establish a risk management in the organization. What do you mean by risk, as a word? What is a risk? Supriya Mhatre: uncertainty. InfosecTrain Trainer: Something which has not yet happened. InfosecTrain Trainer: something which has a probability of happening in the future. Something which has already happened is an incident, or an event for you, right? InfosecTrain Trainer: So, risk management is something which is talking for the future, right? That my organization may get impacted with a ransomware incident. There can be a ransomware attack, so I have to build a resiliency, right?

InfosecTrain Trainer: There can be a data breach in the organization, right? There can be a information disclosure in the organization. These are all the risks, which are the future. It has not yet happened, it has a probability of happening, right? So that is called a risk management, right? InfosecTrain Trainer: So, this particular domain, governance, once you have, you have the... all the policies, you have the strategies, you have the framework in place, then you can conduct the risk management. Once you have the risk management, it will help you establish the program. InfosecTrain Trainer: What does a keyword program mean? What does program stands for? Fatha: Set of sequence of activities. InfosecTrain Trainer: So, program is actually consists of multiple projects. InfosecTrain Trainer: Project is something which always have a definitive start and end date. InfosecTrain Trainer: Like, you want to migrate from on-prem to cloud, so there is going to be the definitive start and end date, that by... in 3 years, we'll do that. InfosecTrain Trainer: But the program is something which consists of multiple projects, which will continue to run, but don't have a definitive start and end date, right? So security, whatever happens in your organization, is a program. InfosecTrain Trainer: you have one, SOC team, You have an IDAM team. InfosecTrain Trainer: You have a GRC team in the organization, right? InfosecTrain Trainer: you may have other end number of... you have an application security team, you have a cloud security team, you have an AI security team, so... so all these teams, they are doing what? They are running some small, small projects, small, small initiatives.

They are securing the SOC, they are securing the identities, they are, overall establishing the governance, so... InfosecTrain Trainer: All these activities which happens in the organization collectively are called as an information security program. InfosecTrain Trainer: So, once this is established, then it will help you to manage incidents. Incident is what is an end goal. InfosecTrain Trainer: If tomorrow, even after having all this, if tomorrow there is an incident, there is an event. InfosecTrain Trainer: How you are going to manage? InfosecTrain Trainer: So, that's how all the four domains are connected or related to each other. InfosecTrain Trainer: Now, what is the relationship between the strategy, policy, and program? InfosecTrain Trainer: Strategy is something which is always created for minimum 5 plus years. InfosecTrain Trainer: 4 to 5 years. InfosecTrain Trainer: You will never see a strategy getting created for one year or two years. A strategy is something which is a long-term thinking. InfosecTrain Trainer: organization want to achieve the digital transformation. So if you... if you refer to your organization strategy, this is going to be at very high level. InfosecTrain Trainer: It will never, ever go into very specific details. So, digital transformation is a keyword which will probably InfosecTrain Trainer: include multiple things. So, as part of digital transformation, you can probably move from on-prem to cloud, you can have AI-based tools and technologies, you can modernize your stack, all those things would be there as part of the digital transformation, right? So, strategy is something which is created for a long term.

InfosecTrain Trainer: But strategy at high level will give you a vision and direction where organizations want to move in the next 4 to 5 years. InfosecTrain Trainer: So you want to achieve a digital transformation, so you will be adopting AI, you will be moving to the cloud, you will be enhancing your tech stack, but before doing that. InfosecTrain Trainer: A CISO needs to establish the policy. So, CISO will create the AI security policy. InfosecTrain Trainer: Cloud security policy, because policy is something which will help you establish the governance in that particular initiative. InfosecTrain Trainer: So, policies are also always written at a very high level statement. They are... never ever go into the detail exactly what is going to be done and on the ground. InfosecTrain Trainer: Then comes the program. InfosecTrain Trainer: So you... once you have the multiple policies establishing governance around those functions, identity and access management policy, cloud security policy, information security policy, probably data security policy, all those policies, once you have, it will help you provide guidelines and rules for the overall program, and the program... InfosecTrain Trainer: will help you implement and enforce the strategy. That's how all those things are related and connected with each other. InfosecTrain Trainer: Can someone tell me what... so you, you, you keep hearing the word, sometimes people reference to cybersecurity, sometimes they say information security. What is difference between the information security and cybersecurity? Fatha: Cybersecurity is, only related to IT infrastructure. Fatha: Like, firewalls. Fatha: Vulnerability assessment, management, and all those things.

Fatha: Information security is more on a digital form, like, you know, access control. Fatha: The physical security, as well as the... Information security, both. InfosecTrain Trainer: So, information security is an umbrella term, and cybersecurity is a part of a subset of it. How? InfosecTrain Trainer: You build a data center. InfosecTrain Trainer: In a data center, you have multiple servers which are kept. Inside the servers, then you have a data, you have the information, right? Everything is being kept in this particular servers, right? InfosecTrain Trainer: So to protect those things, you will have the digital control, you will have a

firewall, you will have a network security-related rules, and all those things, right? That is the cybersecurity, but InfosecTrain Trainer: to physically protect these servers so that an unauthorized person should not go enter into this particular data center and do some malpractices. For that, what you will have, you will have the security cameras installed. InfosecTrain Trainer: On the gate, you will have some biometrics installed, right? So that only authorized person is able to enter. So that is what the information security... InfosecTrain Trainer: So, overall protection of the... everything in the organization is the information security. That's why physical security is also part of the information security, right? Like. InfosecTrain Trainer: You protect the data which is in the digital form, but once you take a printout, that also needs to be protected, right? If someone takes a physical copy of that particular data, still it contains the sensitive information for your organization, right? That also should not get breached. InfosecTrain Trainer: So that's how you have to think from a holistic perspective.

That is called the information security. Cybersecurity is a subset of that. InfosecTrain Trainer: Now, what is the difference between the governance and the management? This is more of a ITSM term, right? InfosecTrain Trainer: So, governance is something which helps you establish the directions, right? It helps you evaluate the needs. InfosecTrain Trainer: It will help security, create a security strategy, and then it will help you manage. So once the governance is established, then the management will help you implement those things. InfosecTrain Trainer: On the basis of governance, the management will plan the security initiatives, they will build the capabilities, they'll run the operations, and then they will monitor the activities. So if you see this particular diagram. InfosecTrain Trainer: So the governance do what? It evaluates, it direct, it manage. InfosecTrain Trainer: And the management help you plan, build, run, and monitor. InfosecTrain Trainer: So that is the difference between the governance and the management. InfosecTrain Trainer: So, we would be discussing both. We'll be talking about the governance also, we'll be talking about the management also. So, incident management, last domain is about management. InfosecTrain Trainer: The first two domains is about governance. InfosecTrain Trainer: Now, this is the very important thing which I would like all of you to know. InfosecTrain Trainer: This slide is about the changes. InfosecTrain Trainer: Changes are getting effective from 3rd November onwards. InfosecTrain Trainer: Right? InfosecTrain Trainer: But, what is getting changed, what is not getting changed, let me tell you. InfosecTrain Trainer: Currently, these are the weightage, which you can see. 17%, 20%, 33%, and 30%.

Only changes are happening between Domain 1 and 4, so domain 4 weightage is reduced from 30% to 29%, and they are increasing the domain 1 weightage from 17% to 18%. InfosecTrain Trainer: Now, what are the overall changes they are bringing from a thinking perspective? So, currently, the CISM syllabus or CISM thinking on the domain one is more based on the frameworks. What are the framework? NIST framework. InfosecTrain Trainer: COVID framework, ISO-related specific standard, they are giving more focus on the strategy in the new changes when they are doing. But what changes they'll do, that we'll get to know after. InfosecTrain Trainer: Here, in the risk, it's moving from, assessments to the appetite. InfosecTrain Trainer: They are giving more weightage to the appetite. In a program, they are introducing the new topic related to enterprise architecture and the information security architecture. So, I have, at a high level, already included couple of content with respect to this, which we will talk about, so... InfosecTrain Trainer: So, I'm not sure what are the changes they are getting, but I have myself done some research and created the topic around it, so that you have an understanding on that. And in the incident management, they are moving from the response and the recovery to the resilience. InfosecTrain Trainer: These are all the changes they are... but the main content which is getting introduced is the enterprise architecture and information security architecture, which are going to be the big topic. InfosecTrain Trainer: getting introduced, so those are going to be the new thing, or the changes.

So, first September onwards, they will publish the new exam prep InfosecTrain Trainer: model, all the new books, like this ISACA manual, and all, all the newly get published from 1st September. And after 3rd November, any exam given post, given post this. InfosecTrain Trainer: would follow the new exam strategy. InfosecTrain Trainer: Clear, everyone. InfosecTrain Trainer: And I told you I will keep a 2-hour masterclass on the basis of understanding what are the changes which are being done, but not now. I'll do it probably in... somewhere in the October. InfosecTrain Trainer: Because September, they are launching, so it will take some time for me to also understand what are the changes being introduced. Johnny Souriar: So here, the exam, we had to register before 31st of... November 3rd of October, right? November, right? 3rd November. InfosecTrain Trainer: You have to write. InfosecTrain Trainer: It's a date when you write. So, if you choose a date to write an exam post 3 November, it will follow the new pattern. If you write even on the 2nd November, it will follow the new, old pattern. InfosecTrain Trainer: That's why, if you want, you can finish it before October. Complete it within the October. Still, if you're not able to write, probably you don't... are confident, you still want to follow the new pattern, you can wait. InfosecTrain Trainer: And then I'll give you the MasterCard, probably I'll give you other content also related to the new exam, probably the new ISACA QAE manual will also get published. We'll share all those things with you, then you can prepare and write as per that. InfosecTrain Trainer: But all those things will remain same, 150 question, 4-hour exam, 450 passing, and all, there are no changes there.

InfosecTrain Trainer: So, so information security, basic principle, or the basic topics will always remain the same. InfosecTrain Trainer: That's why, even in this domain, you will hardly see any changes. So, what I can analyze overall, out of this, 10% syllabus make a difference. Only 10%, 10% to 15%. So, rest 85% will remain same. InfosecTrain Trainer: All the topics and everything would be same. Just, they may probably change the strategy around those topics. They'll frame those questions in a different manner. That's it. InfosecTrain Trainer: So, I am done. So, I'm done with the basic, InfosecTrain Trainer: kind of the overview of the CISM. Now, from here onwards, we will be starting with the first domain. InfosecTrain Trainer: So, as I discussed. InfosecTrain Trainer: The domain carries 17% weightage. Currently, in this particular exam pattern, you can expect approximately 25 questions out of 150 questions. InfosecTrain Trainer: This is the syllabus of this particular domain, so domain is divided into the two parts. One is talking about the governance, another one is talking about the strategy. InfosecTrain Trainer: Yes. InfosecTrain Trainer: Now, coming to the very important topic, CIA threat. InfosecTrain Trainer: Can someone explain me what is confidentiality, integrity, and availability? Sreya Mathew: Oh, so good. Johnny Souriar: confidence. Sreya Mathew: means it is only accessible to the people who are supposed to access that. Integrity means that the information should be correct, and availability means that it should be available whenever we need it. InfosecTrain Trainer: Alright, anyone else? SrinivasanJ: Protecting sensitive data. SrinivasanJ: Confidentiality. SrinivasanJ: Availability is having redundancy, and integrity Currency.

Pudir: Sir, confidentiality information should have any confidentiality that should be meant for the persons authorized to go through it. Pudir: The integrity, another agent changes, it won't be allowed. The integrity shall be maintained, and availability, whenever you require the required person, the data shall be available to the person authorized. InfosecTrain Trainer: Okay, let me explain with a very simple example, right? InfosecTrain Trainer: You have your computer. InfosecTrain Trainer: in your computer, you are logging in into your email account. Let's say it's a... Gmail account, right? InfosecTrain Trainer: So when you are trying to log into this Gmail account, what you're using, you are using your email ID, InfosecTrain Trainer: Which is known to everyone, right? You... InfosecTrain Trainer: might have sent email to multiple people, so they know your email ID. But what... InfosecTrain Trainer: What is the important factor here, which is keeping the data or information within your email not get... being accessed by unauthorized people, is your password. InfosecTrain Trainer: Apart from password, what you can do, you can have a multi-factor authentication, where you receive an OTP or something, or you have an authenticator app. InfosecTrain Trainer: To authorize this. InfosecTrain Trainer: Apart from that, what you can do, you can... employ encryption. InfosecTrain Trainer: Once you are logging into it, there is an encryption in place, so the data is getting encrypted. InfosecTrain Trainer: So, all these controls ensure the confidentiality, like. InfosecTrain Trainer: Only you as an authorized person should be able to access the information which is sitting in your email account, the emails and the data which is there, not unauthorized people.

So, this is ensuring the confidentiality. Now, you sent it InfosecTrain Trainer: The one emailed to your friend, through internet. InfosecTrain Trainer: Now, you sent some... you attached one particular document with some data, information, with the email body, but attacker InfosecTrain Trainer: Got into between, and then he changed the content of the email. InfosecTrain Trainer: It means the integrity of the information is lost. What you were trying to send to the person, person is receiving something different, it means there is no integrity here. InfosecTrain Trainer: How you ensure the integrity? InfosecTrain Trainer: What are the controls to ensure the integrity? Anyone? Neethu: Encryption, or... InfosecTrain Trainer: Okay. InfosecTrain Trainer: Hashing, you have heard about the... Neethu: Yeah, hashing, yeah. InfosecTrain Trainer: Yes. Hashing, digital signature, your access control list, so that only authorized people access. If someone, apart from that, accesses it, it means the integrity is lost, right? Now, coming to the availability. InfosecTrain Trainer: Now, every time you log into the Gmail, Gmail should open. InfosecTrain Trainer: If there is an issue from Google, Gmail is not available to the entire world, or a section of the population because of some issue or error, it's an issue with the availability. InfosecTrain Trainer: So, I think at high level, you understood what is the confidentiality, integrity, and the availability. InfosecTrain Trainer: Let's do one thing. So, we have been talking about and all, so let's start this topic after the break. Let's take a 15-minute break. InfosecTrain Trainer: Let's take a 15-minute break, and see you all after the break. InfosecTrain Trainer: I hope everyone is back. Supriya Mhatre: Yes. Pudir: It is... prem: Yeah.

InfosecTrain Trainer: Alright, good. InfosecTrain Trainer: So now let's get started with the next topic. InfosecTrain Trainer: So, one thing is very important to understand. InfosecTrain Trainer: Security does not generate any revenue for the organization. InfosecTrain Trainer: Right? InfosecTrain Trainer: Security always brings the value in form of providing the protection to the organization, reducing the data exposure. InfosecTrain Trainer: giving value to the business so that business can continue to operate without any disruptions, right? Giving... so that's how the value is InfosecTrain Trainer: Created through security. InfosecTrain Trainer: So, if you see from a security as a function, right, how it generates the value, first thing. InfosecTrain Trainer: Security helps you optimize the, the value between, InfosecTrain Trainer: So, you always have a couple of resources which are available to you, right? The resources in terms of the process. InfosecTrain Trainer: People and Technology. InfosecTrain Trainer: Right? InfosecTrain Trainer: So, all these resources which are available with you, all those resources should be optimized in such a manner so that they provide the maximum output or maximum kind of security to the organization, right? InfosecTrain Trainer: Also, when you do that, you have to always take in... you have to always consider the cost. InfosecTrain Trainer: probably a company like a Google, Microsoft, those who have a revenue in a trillion dollars, they... InfosecTrain Trainer: can probably afford a budget of probably \$1 billion for their security function. But for smaller companies with probably 3 to 5 billion dollars, can they afford? No. Their security budget would be in some millions.

InfosecTrain Trainer: So they have to manage the security within the budget, within the tools, within the technology, whatever are the available resources. Within that, all you have to manage, right? InfosecTrain Trainer: And then there are some enterprise-specific benefits. InfosecTrain Trainer: So, like enterprise want to get and benefit, let's take an example of quick delivery apps. So, the people who are in India, you have heard about the Zepto with Instamart, or Blinkit, right? InfosecTrain Trainer: What is their objective? InfosecTrain Trainer: To provide the delivery of the items to the customers as quickly as possible. InfosecTrain Trainer: in 10 to 12 minutes, whatever you are putting in the cart, they should be able to do that. But to achieve it. InfosecTrain Trainer: there are multiple things in the background which come into the force. First thing is start with the application. InfosecTrain Trainer: which you are using to add item in the cart and then place the order. If that application is not working properly, there's going to be an issue. Then the application is synced with the warehouse data and the SKUs which are there in the warehouse, right? InfosecTrain Trainer: If the SKU information is not correctly synced here, then probably it's showing some item is available, but actually it is not there available with the warehouse. InfosecTrain Trainer: Customer placed an order, paid the payment, every time you have to return that, money to them, it's going to have a bad experience. InfosecTrain Trainer: Now, delivery rider have to quickly go and then deliver the item. For that, also, he require a quick directions, where he'll be using probably GPS or whatever means you have provided. So, all these systems, if there is an attack.

InfosecTrain Trainer: any of them are not available, you will not be able to achieve the objective, right? So that's how all the enterprise-specific benefits will differ. For them, this is the benefit. Probably for a bank, the benefit would be if they're able to protect the data. InfosecTrain Trainer: Their payment gateway, their customer information, that is the benefit. For a manufacturing organization, if the factory lines are working fine, then that is a benefit. So every organization have a specific benefit that you want to achieve. Then you have to have a stakeholder-driven approach. InfosecTrain Trainer: So you have to make sure that the stakeholders' needs are being met. So all the business departments, those who are receiving your services. InfosecTrain Trainer: they have some needs which you want to fulfill, right? There is an application team, those who are developing the applications, there is a business who is probably providing the consultancy, there is a business those who are providing some other services. Their needs should be met by the security and the strategic transformation. InfosecTrain Trainer: So, all the stakeholders' requirements should be, should be, compiled into the... InfosecTrain Trainer: into the action-enabled strategy, right? If business says that, we, we want a strong, strong, confidentiality and authentication-related control in place, so what you will say, okay, we'll not set a very big number string of the password, but InfosecTrain Trainer: With the password, let's have a multi-factor authentication, and also make it SSO mandatory. InfosecTrain Trainer: So, that's how you create a value. InfosecTrain Trainer: Now, how do you generate a value through security? First thing is the cost versus value.

InfosecTrain Trainer: Whatever investment you have received, or a budget you have got as a CISO in the organization for the security function to operate, you have to make sure that within that budget, you are able to provide the appropriate level of security to the organization. InfosecTrain Trainer: then you will be able to achieve it. Then, control optimization. You have an end control, you have a firewalls. InfosecTrain Trainer: you have an EDR, InfosecTrain Trainer: in place, right, you probably can have other IAM-related control. If all these controls are not effectively optimized, if a firewall rules are not optimized, then probably attacker would be able to bypass them, right? InfosecTrain Trainer: if your IAM rules are not strictly defined, so they'll be... attacker would be able to take leverage of it, right? That's why all the controls which you have in the organization, they should be optimized effectively so that they provide the consistent level of security. InfosecTrain Trainer: then security should always be business enabler, right? You should never force the security requirement to the business. You have to always make sure that business continue to run InfosecTrain Trainer: and how you can provide security. Like, suppose, in the organization, they say that there is an AI adoption going on. InfosecTrain Trainer: They want to make sure that your internal teams, internal people are able to use the AI-based tools. InfosecTrain Trainer: like, ChatGPT, Cloud, and all you want them to use to improve their productivity. But how you will make sure that they don't upload information, company information and data, what you do?

InfosecTrain Trainer: You make sure there is a control in place, there is a DLP in place, there are some rules with respect to endpoints in place, which make sure that the data, whatever data they are using, it's only public data. They're not using any company information. So that's how you are... InfosecTrain Trainer: You are ensuring, there is a business also able to do. InfosecTrain Trainer: And then you are providing the security. Rather than, as a CISO, you say, no, block everything. InfosecTrain Trainer: If you block everything, then... Obviously, you'll be able to get a good security, right? Then the efficiency. InfosecTrain Trainer: all the resources, be it your people, be it your technology, be it your processes, all should be operating at effectively. That's why for the people, you provide the awareness training, for the internal teams, you do a red team, blue team, purple team exercises, so that they are effectively trained. InfosecTrain Trainer: for the tools and technology, you do the rule validation, you, you check, you have a control... you have a control governance, so that all the things are optimized and working effectively. That's how you ensure a value. InfosecTrain Trainer: Now, coming to the GRC. InfosecTrain Trainer: Governance, risk, and compliance. So, how these three things are related with each other? InfosecTrain Trainer: Right? So, how governance works in the organization, right? Let me explain you. InfosecTrain Trainer: So, if you see... Broad terms, any public InfosecTrain Trainer: listed company. I'm not talking about any Lala company, like a person and his wife only owns and runs the company. I'm not talking about those companies being run by 2, 3, or 10 people, no. I'm talking about the public listed company.

InfosecTrain Trainer: Any public-listed company, they will always have a board of directors, which is mandatory. InfosecTrain Trainer: What is the board of directors? Board of Directors will have, first thing, the shareholders, the one who owns the company. Like, if I see from the Reliance Industries. InfosecTrain Trainer: Who is the highest shareholder in the lands industry? Mr. Amani and his family. He would be their part of the board, but InfosecTrain Trainer: Apart from this, there are going to be a couple of 4, 5 more members in the board. How the board works? Board works democratically. InfosecTrain Trainer: How work? Any decision which need to be taken in the board, there is going to be a voting. InfosecTrain Trainer: And the one who... if it wins with the majority, then the decision is taken. If it's not, it can be... it can be rejected, right? That's how the board works. InfosecTrain Trainer: It's not like that, that all the decisions in the company which you want, you can just take an autonomino. Everything will go with the board. InfosecTrain Trainer: The board appoints the senior management. InfosecTrain Trainer: And what does senior management mean? Board will appoint a CEO. InfosecTrain Trainer: C-O-O-C-F-O. InfosecTrain Trainer: They are the senior management in the organization. InfosecTrain Trainer: Right? Now, these people will select the CISO. InfosecTrain Trainer: Other than CISO, there are other roles, like Chief Risk Officer, Chief CHRO, Chief HR Officer, right? InfosecTrain Trainer: There can be the CIO or CTO, whatever you call it. InfosecTrain Trainer: In the organization, and there are other C-level executives, chief compliance officer, something, something like that, roles you will see, right?

InfosecTrain Trainer: Then under CISO, you have a security organization. InfosecTrain Trainer: Now, this is how the role structure looks like, and this is how the governance is established. InfosecTrain Trainer: So, any decisions which are being taken, so board of directors will establish the vision InfosecTrain Trainer: and mission for the organization. Senior management, with help of CEO, will create the org strategy. InfosecTrain Trainer: And then CIO or CTO will create the IT strategy. On the basis of that, the inputs will be coming, CISO will create the security strategy. InfosecTrain Trainer: Then you have the policies, framework, guidelines, and all those things. This is how overall governance is established in the organization for the InfosecTrain Trainer: security. InfosecTrain Trainer: That's what it's talking about. So the governance is something which sell... which helps you have the strategic direction and accountability framework. InfosecTrain Trainer: You have a corporate management, strategy, and policy management. That comes at the governance. Once you have a governance, then you want to do a risk management. InfosecTrain Trainer: What is the risk? InfosecTrain Trainer: Let's take a very simple

example. I am here to deliver the training on CISM. InfosecTrain Trainer: What is the risk? There is a risk, probably, I'll not be able to deliver the training effectively. How? There can be a power disruption, there can be an internet disruption, there can be some issue with my laptop. Anything can happen, right? InfosecTrain Trainer: These are all what? These are risks. InfosecTrain Trainer: How you manage those risks? InfosecTrain Trainer: Can you eliminate the risk? InfosecTrain Trainer: In... from the environment, is it possible to eliminate the risk completely?

prem: No, no. InfosecTrain Trainer: You always reduce risk to an acceptable level. InfosecTrain Trainer: there is nowhere you can eliminate the risk. Any number of control, any number of measures you take. InfosecTrain Trainer: you can never eliminate the risk. I can have a power backup, I can have a standby internet, I can have a standby laptop also, but still, risk would be there. What if that also do not work? So, risk cannot be eliminated, it can just be reduced to an acceptable level, right? InfosecTrain Trainer: Through governance and risk management, then you adhere to the laws, regulations, compliance. So, compliance is not only limited to the external laws and regulations. Compliance also with respect to your internal policies. InfosecTrain Trainer: Internal guidelines, internal standards, compliance with respect to your strategy, compliance with respect to your objective. InfosecTrain Trainer: So, all the internal rules InfosecTrain Trainer: You want to follow all the external rules you want to follow, that compliance you will achieve through this. InfosecTrain Trainer: This is how the governance, risk, and compliance is related to each other. InfosecTrain Trainer: Now, coming to the enterprise governance. InfosecTrain Trainer: So the enterprise governance, so what we discussed, right, in terms of the board of directors, senior management, CEO, CISO, then who developed the strategy, who developed the policies and all, right? InfosecTrain Trainer: That is what's called the enterprise governance. InfosecTrain Trainer: how enterprise is governed overall. So, every organization in the world will have some vision and mission, and those vision and mission statements are always kept at a very high level.

InfosecTrain Trainer: You can go and read vision of your company also. Whatever is there, it will help InfosecTrain Trainer: Direct... give the direction to other departments to align with respect to that. InfosecTrain Trainer: Right? So, if you see the enterprise governance, I'll take a very simple example of any country. InfosecTrain Trainer: Let's take example of India. InfosecTrain Trainer: how governance works... if you consider country India as an enterprise, how governance works here in India? We have a democratically elected government, right? Every five years, there are elections where people vote. InfosecTrain Trainer: They choose a government, then from that majority, there are going to be the... some legislative InfosecTrain Trainer: Legislative people, those who will be elected, and then They, choose one. InfosecTrain Trainer: person with the majority for the Prime Minister. InfosecTrain Trainer: Right? On top of Prime Minister, then you have a president of India. InfosecTrain Trainer: Right? Then you have two houses, right? You have a lower house, you have an upper house, so... and how the laws are made? Anything which are being InfosecTrain Trainer: Passed through those houses becomes a law. InfosecTrain Trainer: Right? Then there is a... then there is a... there is legal bodies, right? You have a... you have a district court, you have high courts, you have a supreme courts. They make sure whatever the laws are passed from the parliament, they are being adhered to. If someone is not InfosecTrain Trainer: Following those, they are breaking them, it means they are breaching it, right? That's why we have the BNS, right? InfosecTrain Trainer: Earlier, it was, InfosecTrain Trainer: it was named differently.

Currently, we call it a Bharti Naya Sahita, where all the rules, anything you break is governed through that. Similarly, in the enterprise also, all the things happen in a similar fashion, right? InfosecTrain Trainer: So you... so the... all the senior management people, they create an org strategy. Any decision they take, they have to take the approval from the board. InfosecTrain Trainer: And classical example, you see there are a good number of layoffs happening these days in the big tech giants because of the AI transformation. How those decisions are coming, is the CEO InfosecTrain Trainer: autonomously taken that decision? No. So, in the Microsoft, if you read what they did, they... InfosecTrain Trainer: did some restructuring. They want to take out that money which they were investing, probably on the regular rolls, or some operational task, and they want to strategically move that money to build new product related to AI. So they were... they restructured some \$18 billion InfosecTrain Trainer: they moved it into the AI-related tools, AI-related tech stack. InfosecTrain Trainer: This decision was taken by who? With the help of board, right? So the enterprise governance helps you establish directions. It sets the strategic objective, goals. InfosecTrain Trainer: stakeholder values, right? Enterprise governance help you establish controls. InfosecTrain Trainer: So there are... there are some controls with respect to finance, there are controls with respect to the spending, there are controls with respect to how you behave, how you perform things, right? You have oversight, you have a risk management, you have a resource allocation, all this happens in form of the control, right? Then you have a compliance.

InfosecTrain Trainer: So, governance helps you comply with respect to some laws, regulations, internal policies, and then you measure. If you do not measure the performance, you cannot improve it. Keep it in mind. InfosecTrain Trainer: So, even here, in this particular CISM training, what you are doing, if you are not measuring how many questions you are getting correct, how much marks you are getting in those exams, how you are going to improve your performance. InfosecTrain Trainer: If you see, okay, I'm getting 55% in, in the practice test, my target is 70%. How you'll improve? You say, okay, 15% to 20% questions which I'm getting wrong on all which topic. InfosecTrain Trainer: I'll probably again watch the videos, understand those topics correctly, see where I'm getting them wrong, what is the understanding gap I have, and then I'll try to implement. InfosecTrain Trainer: Now, coming to the outcome. InfosecTrain Trainer: We discussed about the governance. After you have a governance, what is the outcome? If you have a good information security governance within the organization, what you will achieve? First thing is the strategic alignment. InfosecTrain Trainer: So, there is a business strategy. I gave example of the Zepto. So, the Zepto, what it want to deliver the product in 10-minute InfosecTrain Trainer: to the customer, that's what business want to achieve. If you're not able to do it, then blink it, Sugi. InfosecTrain Trainer: Suigi Instamart, or probably Amazon, now will probably take over your business, right? They'll take over your customers. People are getting delayed deliveries. InfosecTrain Trainer: So, strategic alignment. What... Business want to achieve that alignment information security should provide. InfosecTrain Trainer: Right?

Then the risk management. InfosecTrain Trainer: So, all the risks which are there within your enterprise, within your environment, you want to make sure risk is within the acceptable level. InfosecTrain Trainer: Right? InfosecTrain Trainer: Risk is reduced to an accept... that acceptable level will differ from organization to organization. InfosecTrain Trainer: So, if I talk about an... InfosecTrain Trainer: Startup versus a big organization, established organization. InfosecTrain Trainer: Who will have the... Bigger, appetite. InfosecTrain Trainer: To take the risk. InfosecTrain Trainer: The startup, or the big organization? SrinivasanJ: Standard. Siva Krishna Kalipatnapu: Big organization. InfosecTrain Trainer: How come big organization? Siva Krishna Kalipatnapu: Okay, you said appetite, right, okay. InfosecTrain Trainer: It's always going to be startup, right? Big organization, they cannot afford to take the risks like this, because if there is a small data breach, there is a small issue in their organization, they will lose a big amount of business, big amount of revenue, but a startup is growing. InfosecTrain Trainer: they can take the risk, they can expand the business, they can continue to ignore a couple of things to expand the business, right? So that's how things happen. So that's how strategic alignment will differ. InfosecTrain Trainer: And then the risk management will also differ. Probably for them. InfosecTrain Trainer: \$1 million would be, kind of a very bigger category of the risk, but for big organization, \$1 million is a very small amount. InfosecTrain Trainer: Now, value delivery, which discussed, right? You want to, with governance, you will be able to deliver... provide the value through security.

InfosecTrain Trainer: So, all the security investment, all the controls, all the people, process, technology, all you will optimize, you will give them training, all will be working in sync and providing a better level of security. Then the resource management. InfosecTrain Trainer: So all the resources which you have in the organization, right, in terms of the people, process, technology, those resources you'll be able to manage effectively. InfosecTrain Trainer: you will onboard the tools who provide you the effective amount of security. The people, those who you onboard, you will provide them right amount of training, resources, and then you will do proper exercises so that they InfosecTrain Trainer: pro... they, work effectively in case of any incident, right? Then the performance measurement. InfosecTrain Trainer: Which is very important. InfosecTrain Trainer: So if you have a good governance, you will be able to define the proper objective, and you will be able to InfosecTrain Trainer: have the... measure the performance. So, for this CISM training, what is the threshold we gave? I gave you threshold of 70%. InfosecTrain Trainer: So, if you are able to get the 70%, it means that InfosecTrain Trainer: you have a better understanding around the topics. Yes, sure. Siva Krishna Kalipatnapu: Ape Mano Tienesa and Andro. Siva Krishna Kalipatnapu: That's it. InfosecTrain Trainer: Siva, can you please go on mute? InfosecTrain Trainer: Yeah. InfosecTrain Trainer: Next comes the integration. InfosecTrain Trainer: So, there are a couple of assurance factor, right, which provide you assurity that the... the information security is... is... InfosecTrain Trainer: is working effectively, right?

If information security is providing all the intended output what organizations want to achieve, so that you will be able to integrate properly. InfosecTrain Trainer: So, these are a couple of outcomes which you get with the better in security governance. Now, what is the charter? InfosecTrain Trainer: Someone here who... Have heard about the word charter. InfosecTrain Trainer: Someone who have worked as a project manager or a program manager. InfosecTrain

Trainer: At some point of time, you would have already heard about the charter. InfosecTrain Trainer: It's a very important thing... For a project to begin with, a charter. SrinivasanJ: Implementation plan. Johnny Souriar: Open authority. Fatha: Glenn. Neethu: What's a project, document to start a project? Neethu: It's reauthorizing the usages or resources. Neethu: What a. Sreya Mathew: Alternatives of the project? Ashwin: SOW scope of work. subaveena pugalthi: I think charter is something that encompasses of subaveena pugalthi: What's the scope, who is responsible, and who is accountable, and who will be involved, and all those details. InfosecTrain Trainer: Oh. InfosecTrain Trainer: Chatter is something which gives authority to the person to begin that particular thing. InfosecTrain Trainer: So, for overall information security program, if suppose your organization has set aside a 10 InfosecTrain Trainer: Million dollar as a budget. InfosecTrain Trainer: Also, there is going to be some emergency funding, other things, some resources, all those things would be allocated to the CISO, right? InfosecTrain Trainer: But he need some authorization, some approval from the senior management, right? Okay, so you have this much budget which is allocated to you to run the security in the organization.

InfosecTrain Trainer: But if there is any significant incident, we can give you the emergency funding up to \$1 million. InfosecTrain Trainer: At that mode of time. InfosecTrain Trainer: So, this is what the Charter says. So, Charter is a document which sets aside a specific scope InfosecTrain Trainer: Boundaries, what is going to be the key InfosecTrain Trainer: deliverables as part of the information security program. InfosecTrain Trainer: not deliverables in terms of very specific deliverables, it's going to be a high level, those things, right? So it's first thing, it's a... InfosecTrain Trainer: it sets aside the scope and the responsibilities for the key roles, right? It's the, this particular document helps you formalize the security boundaries, responsibility, authorities, right? All those things, and the charter would always be approved by senior management. InfosecTrain Trainer: It will help you provide a strategic alignment so that information security is Achieving what organization want. InfosecTrain Trainer: Right? And sets aside an accountability framework. InfosecTrain Trainer: For what? Who is ultimately accountable for security in the organization? Anyone? Who is the ultimate... who has the ultimate accountability for the security in the organization? InfosecTrain Trainer: And who is responsible for the security? Johnny Souriar: It's so... Fatha: Even... InfosecTrain Trainer: Correct. InfosecTrain Trainer: Any question in the exam? InfosecTrain Trainer: You see ultimate and those kind of work is the ultimate accountability, final accountability, something you see. InfosecTrain Trainer: Always, the answer would be the senior-most person who is there in the option. If there is a CEO, he's going to be there. If there is a senior management, that is the answer.

If there is a board of director, that is going to be answer. InfosecTrain Trainer: CISO is never, ever ultimately accountable. CISO is accountable for running the security program. InfosecTrain Trainer: output and outcome of that security program, that accountability sits with the CISO. But if there is a security incident in the organization, ultimate accountability is board. Board is the one who will answer to the media. Board is the one who's going to answer to the government. InfosecTrain Trainer: what... and then what is the security governance? We discussed about the enterprise governance. Now, what is the security governance like? InfosecTrain Trainer: We have an information security, enterprise governance. Similarly, we established the security governance, right? So, CISO, InfosecTrain Trainer: will create a security strategy. On the basis of the strategy, he will create the Information Security Policy. InfosecTrain Trainer: Under this policy, there are going to be other policies, like IAM policy. InfosecTrain Trainer: data protection policy, incident management policy, probably AI security policy, depends which all policy you want at high level. So, those policies... after the policies, you will have some standards. InfosecTrain Trainer: Guidelines, frameworks, what all these things are doing, these things are establishing a governance, security governance in the organization, right? InfosecTrain Trainer: Can someone tell me the difference be- to eat... Framework... InfosecTrain Trainer: guideline versus... the standard. What is the difference between three? Framework, guideline, and standard? Fatha: Framework is an umbrella that has all this... Guidelines and standards.

Fatha: It's a high-level, Pudir: Framework is the structure of activities, standards, how it should be done. Guidelines are optional. It can be done or not be done. InfosecTrain Trainer: Okay. SrinivasanJ: Standards are mandatory. SrinivasanJ: And, guidelines are optional advice. SrinivasanJ: Framework... SrinivasanJ: Sorry, client lens is flexible, like, it's a suggestion. Fatha: All three is the same. Siva Krishna Kalipatnapu: Framework is like a path to a destination, and guidelines are like, Siva Krishna Kalipatnapu: I mean, follow the traffic signals, or whatever it is, and standard is, like. Siva Krishna Kalipatnapu: Walk or drive only towards the left end. Siva Krishna Kalipatnapu: Right is something that we should avoid. InfosecTrain Trainer: Correct. Let me explain. Framework is something which you can customize. InfosecTrain Trainer: framework is something which you can customize, like, if you... InfosecTrain Trainer: NIST framework. NIST framework you can customize. It's not necessary you follow everything what NIST says. InfosecTrain Trainer: Right? But standard is something which you have to follow at, is it. If you say, I am ISO 27001 certified organization, if you want to go with that, as per the ISO 27001, you have to follow as it is what ISO says. If they say the minimum password should be 10 character. InfosecTrain Trainer: You have to follow. InfosecTrain Trainer: If ISO says that all the policies should be annually reviewed, you have to follow. InfosecTrain Trainer: If you don't follow them, you cannot be called ISO certified, right? So standard is something which you have to follow as it is, and guidelines are best practices, right? So let's take a simple example. NIST says that you should have a strong password.

InfosecTrain Trainer: to avoid... to protect, to achieve the confidentiality. ISO will say that you should have a minimum 10 character passwords, but guideline will talk about that how to set a strong password. That is a guideline. InfosecTrain Trainer: Right? That is the key difference, because why I explained? Because we will continue to refer these terms in between also multiple times, so it's very important for all of you to understand the key difference between the framework guideline and standard. InfosecTrain Trainer: Now, what are the key components within the security governance, right? So, the security governance will have strategy development. InfosecTrain Trainer: As part of the governance, you will develop the information security strategy, right? You will establish the high-level roadmap items, objectives, next four to five years roadmap for the security, right? InfosecTrain Trainer: Security governance will help you manage the risks within the organization. InfosecTrain Trainer: Right? And yeah, let me be clear. Risk, whenever I say, it's not always about the information security. Information security is InfosecTrain Trainer: One category of risk. InfosecTrain Trainer: When you talk about risk management, it's about the enterprise risk management. There are financial risks, there are operational risks. InfosecTrain Trainer: There are other categories of risks as well. There are compliance-related risks. So, information security is one category of risks, right? So, security governance will help you manage the information security-related risks. InfosecTrain Trainer: Then, resource allocation.

So, good governance will help you allocate the resources properly, you will be able to maintain a good, good resourcing level within the organization in terms of tools, technologies, right? InfosecTrain Trainer: good governance will help you define the better KPIs, KRIs, KGIs, which we'll discuss in detail, what all three means, right? And then the integration with the enterprise. InfosecTrain Trainer: So, you will need to... and end goal is what? You want to make sure that the enterprise objectives are being met. Whatever the enterprise want to achieve, those objectives are being met. That integration you will achieve. InfosecTrain Trainer: So, and what is the importance, what you achieve out of the security governance? InfosecTrain Trainer: Reduce the risk to an acceptable level. InfosecTrain Trainer: If you have a good governance, you will be able to reduce the risks to an acceptable level. InfosecTrain Trainer: Because you cannot eliminate the risk, always there is going to be a risk. Even if you deploy n number of solutions, can you be sure that there is going to be no attack, absolutely, against your organization? You cannot. Always, there are some loopholes which will be left behind, right? InfosecTrain Trainer: and the incident will come. But you can reduce that risk to such a level that the probability of occurrence or the impact becomes so less InfosecTrain Trainer: So that you will be able to probably absorb that particular kind of thing happening, right? So that risk mitigation, you will achieve through governance, regulatory compliance. InfosecTrain Trainer: How you achieve? GDPR says that you report the incident within 72 hours. InfosecTrain Trainer: This is a regulatory requirement. InfosecTrain Trainer: But how you will achieve it?

If you have a good governance, you will have a good incident management protocol, so that you will be able to InfosecTrain Trainer: notify the regulatory bodies as per that. If you don't have a proper incident management framework, policies, protocol in place, how you are going to help report it on time, right? So, this you achieve. Operational resilience. What is the resilience means? Pudir: When... so, this is Pudir... when something has happened, how effectively, how smartly you are reinstalling resilience? Means, how effectively you are reinstating your business? Johnny Souriar: Sustain. InfosecTrain Trainer: Yes. InfosecTrain Trainer: It's basically, yeah, ability to sustain, ability to continue the operation, even in case of the disaster. InfosecTrain Trainer: How quickly you are able to recover from the incident, how quickly you are able to hand over the operations. InfosecTrain Trainer: Has anyone read about the JLR incident? InfosecTrain Trainer: Jaguar and Land Rover. InfosecTrain Trainer: There was a big ransomware attack against them. InfosecTrain Trainer: A year, year back. InfosecTrain Trainer: Anyone read about this? InfosecTrain Trainer: There was a complete shutdown of the operations almost for 3 weeks. Johnny Souriar: Any case study available with you, sir? InfosecTrain Trainer: Not with me, you can Google it. You can Google it, you will easily get an article on this, GLR. InfosecTrain Trainer: Jaguar Land Rover attack. InfosecTrain Trainer: ransomware attack. InfosecTrain Trainer: They lost close to, I think, some billion dollar worth of business they lost.

InfosecTrain Trainer: So there was a ransomware attack against one of their manufacturing facility, and then it got propagated to other, other facilities within the enterprise, and then there was a big impact. InfosecTrain Trainer: So, so this is a kind of ex... InfosecTrain Trainer: You can say, not a good example of resilience, right? InfosecTrain Trainer: if... InfosecTrain Trainer: organization would have been a good resilient, properly, they would be able to quickly recover from this, and at least resume all the critical functions within InfosecTrain Trainer: As soon as possible, right? And then it gives you competitive advantage. InfosecTrain Trainer: Will you open an account in a bank who had suffered probably 3-4 cyber attack in past year? You will not. InfosecTrain Trainer: Will you purchase a SaaS solution? InfosecTrain Trainer: had discovered a couple of zero-day vulnerability in couple of quarters, you will not. InfosecTrain Trainer: So you will lose that competitive advantage. So that's why if you are not keeping your product secure, you are not keeping your business secured, you will lose that competitive advantage, and any other third party will take over that business from you. InfosecTrain Trainer: Let's discuss some questions, yeah. InfosecTrain Trainer: Alright, let's discuss the correct answers. InfosecTrain Trainer: Most of you got correct, but I can see the last one. A lot of you are confused, okay. InfosecTrain Trainer: A new stringent data privacy regulation is enacted. InfosecTrain Trainer: directly impacting your organization's core operations. From an information security governance perspective, what is the first action the CISO should take to ensure compliance and maintain the security, information security thread?

InfosecTrain Trainer: Conduct a comprehensive legal and risk assessment to understand the full implication and impact on CIA, okay, looks a good option. Procure new security solutions designed to address specific regulatory requirements. InfosecTrain Trainer: Before doing A, can you do B? No. InfosecTrain Trainer: immediately implement a new technical control to encrypt all affected data. Can you decide this without understanding and doing a risk assessment? You cannot. Train on employees on new regulations, requirements, and potential penalties. That also you will do once you understand what is the risk, what are the key areas. InfosecTrain Trainer: So, correct answer here is A. The board of directors expresses increasing concern about the organization's overall cybersecurity risk posture and its potential impact on strategic objective. InfosecTrain Trainer: From an enterprise governance perspective, what is the most significant outcome of an effective cybersecurity governance in addressing these concerns? We discussed the outcomes, right? InfosecTrain Trainer: 6 outcomes which we discussed at high level. Enhanced capability to recover quickly from a major cyber attack, okay, resiliency. InfosecTrain Trainer: you will get, okay, successful completion of all mandated compliance and audits with no finding. That looks an option, but is actually... is it possible? No findings you will get? No. InfosecTrain Trainer: Reduction in the number of detected security incident and the alerts, yeah, that's what you want to achieve. InfosecTrain Trainer: Apparent and quantifiable understanding of cybersecurity risk aligned with business objective and appetite. InfosecTrain Trainer: But I would always go with the option which talks more about the risk, objectives, appetite.

InfosecTrain Trainer: Strategy, so this option. InfosecTrain Trainer: is a more aligned what you want to achieve. So, D is the correct answer. An organization is implementing a comprehensive GRC framework for its information security program. What is the greatest value delivered by a well-implemented GRC framework in terms of information security value delivery? Automated vulnerability scanning and patch management across all of it. InfosecTrain Trainer: Only talking about one specific problem. InfosecTrain Trainer: not... InfosecTrain Trainer: Do you do GRC streaming only about the vulnerability management? No, it's about the overall organization. Centralized dashboard for real-time monitoring of the event and all. You will have a centralized dashboard, but that is not only purpose of having a GRC. InfosecTrain Trainer: Enhanced physical security measures for the data center and the critical infrastructure. That also you want to achieve would be there as part of the GRC, but if you read option D, holistically covers all. InfosecTrain Trainer: Integrated visibility and management of information security risks, control, compliance obligation, enabling informed business decisions. InfosecTrain Trainer: So, it covers option A, B, and C all. So, D is a holistic umbrella answer. InfosecTrain Trainer: an organization is making strategic investment in new digital transformation initiatives. What does effective cybersecurity governance best enable the organization to do concerning its cyber risk posture in these new ventures? InfosecTrain Trainer: Automate all security compliance report... reporting for the regulatory bodies. InfosecTrain Trainer: Allocate security resources based on the prioritized business risk and the strategic objective.

Ensure 100% elimination of cyber threat and new digital. This InfosecTrain Trainer: statement itself is incorrect. You cannot eliminate InfosecTrain Trainer: threats and all. So, the statement itself is incorrect, so it's all automatically eliminated. Rapidly identify and respond to zero-day exploit impacting new system. It's only talking about one specific type of attack. Do you establish InfosecTrain Trainer: The governance only to target zero-day attack, or holistically overall InfosecTrain Trainer: all the kind of problems you want to address. So, if you read option B, InfosecTrain Trainer: talks more about the holistically all the problem. What are the business risks? So, business risk can be a zero-day attack also, business risk can be a ransomware also, business risk can be a data breach also. Business risk can be a compliance reporting also. InfosecTrain Trainer: So, option B is something which covers option A and option B. So, that's why option B is the correct answer. InfosecTrain Trainer: I don't know, a couple of people selected C. C, as I told you, C statement itself is incorrect. InfosecTrain Trainer: You cannot eliminate InfosecTrain Trainer: a cyber threat. As such, threats, you cannot... you cannot do anything with the threat. Threat is never, ever in your hand. InfosecTrain Trainer: Can you eliminate a cyber attacker, those who is trying to attack, from... to our organization? You cannot. It's never in your hand. InfosecTrain Trainer: You can probably reduce the vulnerabilities InfosecTrain Trainer: But you cannot eliminate those threats which are there. Those threats will always be there. Those are never in your control. InfosecTrain Trainer: Anyone has any different opinion or questions here? InfosecTrain Trainer: Alright, now talk about the vision.

InfosecTrain Trainer: So, let me first show you what does a vision means. InfosecTrain Trainer: So let's see a vision of some big organization. InfosecTrain Trainer: Let's see what is the vision and mission of Microsoft. InfosecTrain Trainer: Our mission is to empower every person and every organization on the planet to achieve more. InfosecTrain Trainer: You see? InfosecTrain Trainer: Does it define what Microsoft do? InfosecTrain Trainer: In detail, yes, it does. InfosecTrain Trainer: But does it... InfosecTrain Trainer: tell in detail what they need to do. They have a huge tech stack of, different, different technologies, which helps all the people like us. InfosecTrain Trainer: We use the Microsoft-related operating system, we use Microsoft-related tech stack, like Microsoft M365, we have a couple of security tools from Microsoft. InfosecTrain Trainer: Which helps all of us empower to do more, right? InfosecTrain Trainer: So this is how the vision and the mission, all those kind of statements are... would be written. InfosecTrain Trainer: So... InfosecTrain Trainer: So the business vision is what is going to define what organization want to achieve, what organization want to InfosecTrain Trainer: 2. InfosecTrain Trainer: So this is a vision what Microsoft has, right? They want to empower the people. So all the tech stack, all the new technologies, all the research and development, whatever the people will do within the organization, they will always be aligned with respect to that vision which they have created. InfosecTrain Trainer: On the basis of this vision, to fulfill this vision, now business strategy would be created. InfosecTrain Trainer: So that business strategy is always a 4-5 year plan. InfosecTrain Trainer: Now, Microsoft is doing what?

If you observe closely, Microsoft is investing much more in an AI-based tech stack. InfosecTrain Trainer: Right? InfosecTrain Trainer: they are doing a lot in terms of AI-based tech stack, in terms of security, in terms of productivity. So all their existing M365 tools, what they have, even their operating system, they have now Copilot, even they have a good number of security-related tech stack with respect to AI. So this is a strategy which their business would have created. InfosecTrain Trainer: That in next to 4 to 5 years, we will invest a lot in developing such a tech stack, because that is going to be the next... InfosecTrain Trainer: Era of the market, right? InfosecTrain Trainer: On the basis of this strategy, then the objectives would be defined. What are the objectives? InfosecTrain Trainer: Against which you will be able to measure the success, against which you will be able to understand what you want to InfosecTrain Trainer: Right? So the objective is digital transformation, objective is building AI-related tech stack, right? So, against which you will be able to measure the success. InfosecTrain Trainer: So, those business objectives would be defined from a strategy. On the basis of this, now organizations want to create an AI-related tech stack. Now, IT team... InfosecTrain Trainer: to support this, they also need to uplift the IT strategy also, right? They will require GPUs. InfosecTrain Trainer: New kind of computers, or the end-user machines, which can support the engineers to do that research and development. InfosecTrain Trainer: Will normal machine support to run a AI program? No. Johnny Souriar: I have multiple colors. InfosecTrain Trainer: What, Johnny? InfosecTrain Trainer: Yes.

So, on the basis of that, the IT strategy would be drafted, where they will say how many IT systems we need, how many new servers we require, how many new endpoint equipments we require, what are the new tools and technologies which we'll onboard. InfosecTrain Trainer: Now, once you onboard those new things, you want to protect it. InfosecTrain Trainer: That IT security strategy will tell, which CISO will create, which security manager will create, right? InfosecTrain Trainer: he will create the strategy to protect overall the objective what business wants to achieve, what IT is creating. He wants to make sure that business is able to function without InfosecTrain Trainer: With minimal disruptions, minimal number of attacks. InfosecTrain Trainer: On the basis of a strategy, then the policy would be created, the policy would define those new parameters. InfosecTrain Trainer: Then, from the policies, you will derive the standards.

InfosecTrain Trainer: You will create the processes, and then you will define some security matrices to measure the performance. subaveena pugalenthi: Yes, this one. InfosecTrain Trainer: Yeah. subaveena pugalenthi: It security strategy is, prepared by the CEO. How about the policy, standard, processes? InfosecTrain Trainer: So, the policy standards are also created by the CISO only. So, the strategy is created by CISO, but not approved by him. Strategy would always be approved by a level up. subaveena pugalenthi: Okay. InfosecTrain Trainer: So, he's also responsible for creating the policies, standard, and procedures and guidelines also, right? InfosecTrain Trainer: That would be created on the basis of the strategy. InfosecTrain Trainer: In your organization, who creates the policy? Who writes the security policy? Who's accountable for that?

subaveena pugalenthi: I'm not sure. InfosecTrain Trainer: You can go and search for the information security policy on internet. You will find out automatically. You will see someone would be responsible, someone would be accountable. subaveena pugalenthi: Okay. InfosecTrain Trainer: So the CISO is responsible for... InfosecTrain Trainer: developing the policies, right? But accountability will always be with the senior management at all. InfosecTrain Trainer: Accountability for implementing the policy is who? InfosecTrain Trainer: Is the security team... subaveena pugalenthi: underneath. subaveena pugalenthi: Yeah. InfosecTrain Trainer: security team. They are accountable for implementing the policy. subaveena pugalenthi: And what about security standards and processes? Metrics is definitely, like, each team would have different KPIs and KRIs to measure the metrics, but how about processes and standards? subaveena pugalenthi: Yeah. InfosecTrain Trainer: So. subaveena pugalenthi: Don't do it. InfosecTrain Trainer: So, standards also CISO will create. Security standards he will create. I'm not saying that he will create them from scratch. He can also... InfosecTrain Trainer: He can also... So that's what I told Sandeep. InfosecTrain Trainer: CISO is responsible for creating the policy, but he's never going to be approving. InfosecTrain Trainer: Approver would always be a level up. InfosecTrain Trainer: It's not always CEO. CEO is the best thing. InfosecTrain Trainer: You will rarely see, in the big organization, CEO approving the policies and all. Generally. InfosecTrain Trainer: probably the CIO, CFO, the whomsoever report to, they will be approving it, right? But the standard and the procedures, right? Standards, generally, you don't... you do not design it from the scratch.

That's why you have the frameworks, like. InfosecTrain Trainer: Nest, ISO, COVID... InfosecTrain Trainer: They help you create those standards, right? So, like, if your organization is a bank who deals with the payment card, so there is a PCI DSS, which is a standard for the payment card industry. Now, PCI DSS says that you should maintain a minimum 10 character password. You have to make sure that InfosecTrain Trainer: There is a, there is a standard which says that there is a minimum 10-character password. InfosecTrain Trainer: PCI DSS says that you cannot store the CVV number. What is a CVV? If you... if you turn your credit card or debit card, you will see a 3-digit CVV number. So whenever you do the payment, the bank will ask you to enter it, but InfosecTrain Trainer: PCI DSS says you cannot store that number anywhere in your servers. InfosecTrain Trainer: So, this is how the standards are derived. So, standards would be created by the CISO only. InfosecTrain Trainer: Now, procedures or the SOPs are there to ensure the consistency. InfosecTrain Trainer: So every time you do that activity, people should InfosecTrain Trainer: Follow the exact same process, right? InfosecTrain Trainer: You don't want them to, every time, reinvent the wheel from the scratch. That's why you create some procedures, so that people follow that process, and then they manage that particular, InfosecTrain Trainer: activity, what they are doing, right? That's what the processes do. And the mattresses are there to track those processes, clear. InfosecTrain Trainer: Suba?

subaveena pugalenthi: Yeah, it's clear, but can you give an example from high level, like, how Vishen... I know you gave an example of AI, and how it can be... subaveena pugalenthi: how IT strategy is based, like, having, like, big GPU endpoints to accommodate those AI researchers and things, but can you drag the same example down until the metrics so that I can easily understand? InfosecTrain Trainer: Yes, let me... let me take the same example, right? InfosecTrain Trainer: So, the organization want to develop the tech stack with respect to AI, right? That is what their strategy, so where they'll be doing the investment in next 4 to 5 years, right? So, Microsoft says that they'll be investing close to \$80 billion in next 4 to 5 years in the AI. InfosecTrain Trainer: Right? Now, this is a strategy they have created. Now, on the basis of the objectives are created, so that the AI-related tech stack, tools, technologies, they are being developed. Now, IT InfosecTrain Trainer: We'll probably rent new servers, they will buy new endpoint equipments, they will buy new InfosecTrain Trainer: Softwares, tools, technologies to support that development. InfosecTrain Trainer: So, security team, what? They want to protect it. InfosecTrain Trainer: So the security strategy would be established, so strategy would make sure that all the tech stack, whatever they are trying to build in the next 4 to 5 years, is protected, right? So the now security team saw, okay, there is a scope, we create an AI policy. InfosecTrain Trainer: Right? There was no AI policy in place, right?

Now security will also make sure there are specific people InfosecTrain Trainer: onboarded to... InfosecTrain Trainer: who have the knowledge in this, probably earlier the AI-related tech stack was not there, so their SOC team and other teams did not have the experts on that, so they'll hire new people, or probably they'll train them now. InfosecTrain Trainer: On the basis of AI, now you require a standard so that there is a consistency InfosecTrain Trainer: So the standard, you will say that AI InfosecTrain Trainer: whatever AI-related developments are happening, you... all the development will follow the OAH... Top 10 for AI... InfosecTrain Trainer: are being followed there. These related vulnerabilities are not being introduced. We will follow InfosecTrain Trainer: the UAI Act-related principle. Likewise, standards would be created very specific. subaveena pugalenthi: And this is not the OS top 10, is not an industry standard, right? Like, it is something that the organization adopts. subaveena pugalenthi: So, like, as per my understanding, what... with your previous example, security standard is something that is making it compliant with industry standard or regulation, like for PCI DSS. InfosecTrain Trainer: No, no, no, it's stranded you also create for your organization also. You can tailor it. subaveena pugalenthi: It's not... InfosecTrain Trainer: necessary that what organizations say? Every organization in the planet won't be ISO 27001 compliant, right? subaveena pugalenthi: Yeah, okay. InfosecTrain Trainer: So you also create your own standard. If ISO says the minimum 10 character password, so you can say, in my organization, I'll follow 16 characters. It's up to you. subaveena pugalenthi: Okay. InfosecTrain Trainer: Now, coming to the strategic alignment.

InfosecTrain Trainer: So we saw a couple of questions also, right, where they were talking about the strategic alignment. How would you achieve this strategic alignment? InfosecTrain Trainer: You achieve it if you are able to fulfill the organization's mission and vision, right? We just saw in the previous example which I gave, right? InfosecTrain Trainer: The organization vision and mission is what? What you want to achieve. That vision, mission you want to fulfill. InfosecTrain Trainer: If you are able to fulfill, your security team is able to fulfill that, it means you say that you are strategically aligned. InfosecTrain Trainer: If you are aligned with respect to organization strategy. If organization is saying we will move from on InfosecTrain Trainer: prem data center to cloud. InfosecTrain Trainer: and security, probably the CISO has not yet worked upon establishing a cloud security, onboarding the CSPM tools, probably training the existing employees and onboarding new resources. It means he's not aligned with respect to the strategy. InfosecTrain Trainer: Right? InfosecTrain Trainer: security should also fulfill the requirement with respect to IT strategy. If IT is procuring new technologies, new endpoint equipments, new machines, new tools, security should be go hand in hand so that you are able to provide that protection.

InfosecTrain Trainer: And then, if you are able to follow the security strategy, whatever InfosecTrain Trainer: These strategies says on the basis of information security, strategy would be created if you are able to align with respect to that, and then you are able to create a good information security program, which you are able to establish and produce InfosecTrain Trainer: So overall, if all these things are being met, you can say that, yes, in your organization, it's strategically aligned. InfosecTrain Trainer: So now, how the strategic planning works... so the vision is something which is why. InfosecTrain Trainer: Why Microsoft exists on this planet? Why the Microsoft name company is there? So that was their mission, vision, right? Which we just saw. InfosecTrain Trainer: Why they are there? Because they... Believe InfosecTrain Trainer: they believe in what people make possible, right? That's why they are here in the planet. And the mission is what? What they are doing to achieve that InfosecTrain Trainer: what kind of actions they are taking, right? To achieve it, they are making people's life easy through InfosecTrain Trainer: The tech stack which they are providing. InfosecTrain Trainer: Right? The new tools and technologies which they are developing, that is their mission. InfosecTrain Trainer: And how to implement, or how to fulfill the vision and mission, that would be defined by the strategy. InfosecTrain Trainer: So, strategy will talk about the how. Long-term objective, directions, how you are going to do that. InfosecTrain Trainer: And what is the technical plan? Technical plan is something which is a short term. InfosecTrain Trainer: Short term means a year, for one year.

InfosecTrain Trainer: Whatever you want to fulfill in one year, that is going to be the tactical plan, and the operational plan is the day-to-day thing, what you do. InfosecTrain Trainer: Right? So day-to-day, you do some review, you do daily stand-up calls, you do day-to-day tasks, right? InfosecTrain Trainer: SOC team monitor the incident, they monitor the SIEM logs and everything, right? So, all these things are day-to-day things, what you are doing, that is an operational plan. That's how the strategic planning flow from top to bottom. InfosecTrain Trainer: So, on the top sits the vision and the mission of the organization, and the bottom layer sits the operations. InfosecTrain Trainer: So, the incident management is operations. InfosecTrain Trainer: Where you are making sure the incidents are mitigated, incidents are not causing bigger impact. InfosecTrain Trainer: Now, next topic is about the frameworks and the standards. InfosecTrain

Trainer: Right, so we discussed a couple of times a reference to the frameworks and the standards. Also, one more thing. InfosecTrain Trainer: In the exam, however, there have been no changes in the syllabus, but InfosecTrain Trainer: the previous students who have written the exam, they told that they are asking AI-related questions. AI-related questions means they'll not ask any AI InfosecTrain Trainer: what is a generative AI, or how the machine learning model works, and all those things they won't ask. There is going to be an AI-based InfosecTrain Trainer: AI as a technology would be there in the questions. But to protect any kind of the technology, the base remains same. So I will be talking about the AI also, I'll be giving you high-level understanding around AI, so don't worry that you can answer those questions.

But don't worry, they'll not go into detail, because CISM is not an AI governance exam. CISM is a security governance exam. InfosecTrain Trainer: So now, what are the frameworks? So, this is the last I've taken from the 2024. Now, there have been a couple of new updates after that, right? So the NIST launched a new framework, NIST CSF 2.0. InfosecTrain Trainer: So there is a new... earlier, there was the... there were five functions, yes, and one more thing. In the CISM exam, they will not ask about any of these frameworks. InfosecTrain Trainer: They will just reference to it over there. There's not going to be any question with respect to NIST, where they will ask you what is there in the govern, what is there in the protect, what is... what kind of controls are in detect, which... how many controls are there in detect, no. InfosecTrain Trainer: So, it's there for your understanding. InfosecTrain Trainer: to understand that how these frameworks are there, and how they help you create information security or established security in the organization, right? Now, there is a COBIT, which is around the governance and the IT management-related framework. InfosecTrain Trainer: There is also CIS CIS... anyone heard about the CIS? InfosecTrain Trainer: Center for Information Security, CIS-based controls. Sandeep Saxena: Even CIS benchmarks for everything? InfosecTrain Trainer: Yes, CIS benchmark, correct. InfosecTrain Trainer: Then, there is a NIST Zero Trust Architecture. Also, these are some examples. Now, coming to the standards. Standards are something which you have to adopt as it is. InfosecTrain Trainer: Right? So, first is the... IESO, so 27001, which we discussed, then ISO 27000... 2, which is about... InfosecTrain Trainer: another standard from the ISO, then there's a PCIDSS.

HIPAA also you would have heard. HIPAA is about the health industries, in the USA, right? InfosecTrain Trainer: So, all the PHI, personal health information-related, things which we have to protect there, we have a HIPAA. InfosecTrain Trainer: Now, coming to the... related to AI. So, InfosecTrain Trainer: So there are some new AI-related frameworks, like NIST AI is a new framework which is there. There is one, NIST AI 601, which is a new publication related to generative AI. There is also new standards InfosecTrain Trainer: for the AI, which is ISO 42001, an UAI Act is also a new regulation which has been introduced. InfosecTrain Trainer: So, how do you implement these frameworks? You have to select the framework as per the industry, right? InfosecTrain Trainer: So, healthcare industry won't adopt the PCI DSS-related controls, right? InfosecTrain Trainer: That's why you have to see which particular industry you are in. Suppose you are not developing the AI, you are not a product company. InfosecTrain Trainer: That's why you will be very much concerned about the EUAI Act, right? So, that's how you have to see which particular industry you are in, what kind of business you are doing, what kind of operating environment you operate. On the basis of that, you will select and choose these regulatory frameworks. InfosecTrain Trainer: Also, in your organization, also, you will see you generally Take a layer of these. InfosecTrain Trainer: Second point. It's not like that you will only choose the NIST. You will choose some best practices from NIST, that's why you say tailor it, right? Some practices from the CIS, some control from the ISO. Likewise, you will tailor, and then you will develop a framework for you. InfosecTrain Trainer: Right? And the governance is the foundational.

So governance is the basic, function which helps you establish everything, so that's why we have been discussing this governance as a topic in this particular domain, which is the first one to establish. InfosecTrain Trainer: After that, then everything will follow. You cannot jump to the next thing without having a governance. InfosecTrain Trainer: Now, what is the business alignment? Pudir: occur in the previous page, HIPAA, I think the acronym is having some spell check. Pudir: One more P will come, I think so. InfosecTrain Trainer: Is it? Okay, okay. Pudir: Health Insurance Affordability and Predictability Acts. Pudir: Sorry. InfosecTrain Trainer: Yeah, no problem, I'll just add it now only. Sandeep Saxena: Just one question, for CISM, how deep I need to go into these frameworks or standards, or I just need to know the relevant industry or person? InfosecTrain Trainer: Whatever I am talking, that is more than enough. You need to just know that which particular industry they apply to, that's it. No need to go into deep, you need not to go and read PCI DSS or HIPAA. You need to just know that where the PCI DSS is applied, where the HIPAA is applied, that's it. Sandeep Saxena: Oh, okay. InfosecTrain Trainer: Now, coming to the business alignment, how do you achieve the business alignment? That's why we say security should always be a business enabler, right? InfosecTrain Trainer: So the security team, or the CISO, make sure that security is enabling business to function. I know that keeping a 16 to 18 character password is a very strong password. InfosecTrain Trainer: I think Correct, right? H-I-P-A-A is the correct one. SrinivasanJ: Yeah, it's Health Insurance Portability and Accountability Act, so 1P, it's not with 2P. SrinivasanJ: Peace.

InfosecTrain Trainer: Yes, correct, correct. Pudir: It is available in CISA manuals, health insurance, portable return, protectability tag. I think I have it in 23. After that, maybe changes or not. Perhaps I might be wrong. I wish. InfosecTrain Trainer: On their official website, also, it calls HIPAA only. Pudir: What is the third... I have mistake. InfosecTrain Trainer: Yeah, no problem, no problem, yeah, shoes. InfosecTrain Trainer: Now, now coming to the business alignment, right? So, I was talking about how the security should enable the business to function, right? InfosecTrain Trainer: Even I gave the example of AI. InfosecTrain Trainer: As a CISO, you cannot go ahead and tell business that I am blocking this, I don't want business to use this. InfosecTrain Trainer: You have to always make sure that there is a balance between the security and the business requirement, right? InfosecTrain Trainer: You know that setting, keeping a very, a big... InfosecTrain Trainer: string of password is highly protected, and probably the... it's very low probability for a brute force attack, but is it possible for the people to remember such a long string of password? Cannot, right? That's why you... InfosecTrain Trainer: keep some compensating control, you keep some other controls, you enable SSO, you do the MFA, so that the adequate number of protection is provided. InfosecTrain Trainer: Right? InfosecTrain Trainer: Like, in these days of the era of AI, right? Suppose you have an official AI tool, but still you want people to continue to use other AI tools, right? You want them to use the Cloud InfosecTrain Trainer: Claude and all, but you don't want them uploading any data there. InfosecTrain Trainer: But to make sure this, first you should have a good DLP in place.

InfosecTrain Trainer: And how the DLP works, what is the baseline for DLP? Baseline for DLP is... InfosecTrain Trainer: sensitivity labels. If you don't have the sensitivity labels, how your DLP will work? So, first thing is that baseline. You should be... you should start InfosecTrain Trainer: doing this... implementing the sensitivity labels for all your documents, right? What is internal, what is confidential, what is restricted, what you want to share with the outside, right? And then. InfosecTrain Trainer: You can implement the rules so that InfosecTrain Trainer: People continue to use those external tools also, but they cannot upload any data beyond public. InfosecTrain Trainer: Right? So that's how you ensure the business continues to function, balancing the security. So first thing is the strategic connection. InfosecTrain Trainer: You need to link the security objective to the business code, including AI initiative, digital transformation-related strategies. That's what I've been talking about, right? A business want to adopt AI, a business want to move from on-prem to cloud, business want to onboard new tech stack. InfosecTrain Trainer: But if they are onboarding, there should be a security which should be established for that, right? So, you should make sure that security is doing that. Then the priority understanding. InfosecTrain Trainer: There are n number of things which are going on in the organization. InfosecTrain Trainer: Can CISO able to manage all of them? Can CISO probably be able to provide protection to all of them? It's probably not possible, right?

InfosecTrain Trainer: So that's why you have to see that which all of them are high priority items, what need to be addressed first, so that InfosecTrain Trainer: the security... Is maintained at a consistent level in the organization, right? InfosecTrain Trainer: So, those projects and the priority you need to understand. Then, business communication. InfosecTrain Trainer: You need to translate security concept into business language. InfosecTrain Trainer: Did your CISO go and talk about the vulnerability priorities and all to the board? No. InfosecTrain Trainer: Will your CISO go and talk about the, the attack pattern, and what kind of the attack profile was followed by the people? No. InfosecTrain Trainer: Because the people, those who sit in the executive management, right, they do not understand those things, right? So you have to always convert the security requirements into the business language so that business understand what you are trying to say, right? InfosecTrain Trainer: That's why you have to always talk in terms of impact. Like, if you do not implement this, if you do not follow this regulation, if we do not do this, there is going to be a significant impact, impacting us \$3 million, and something like that. InfosecTrain Trainer: So if your board says, why do we need to follow, like, like in India. InfosecTrain Trainer: They say, why do we need to follow DPDPA? No, we are... InfosecTrain Trainer: will not follow DPDPA. Then you have to tell them, right? If you do not follow the DPDPA, there is a fine up to 250 square. InfosecTrain Trainer: There are other regulatory-related things or sanctions which may come in force with us. InfosecTrain Trainer: So... They will understand this.

InfosecTrain Trainer: Now, business enablers, so security should make sure that they are enabling business to function, right? InfosecTrain Trainer: So... so you should deploy the new tech stack, new tools, new technologies, which helps you accelerate the operations, right? Automation... automated methods to

solve the problems, so that business continue to operate. InfosecTrain Trainer: Now, how do you develop this strategy, right? Let me... show you Or... strategy document. InfosecTrain Trainer: This is a sample strategy document of one university. InfosecTrain Trainer: You see, they have created this strategy for 5 years, 18 to 23. InfosecTrain Trainer: So, cybersecurity strategy at high level talks about the vision, what is the executive summary, what is the background, context, threat landscape, what are the key themes, and how they will implement in other categories. InfosecTrain Trainer: So you can see here the executive summary of the strategy, right? How the strategy is placed, how those things are there, which is defined here. InfosecTrain Trainer: Then there is a summary which is available. InfosecTrain Trainer: Then what is the background? What is the context in which threat landscape the university operates? InfosecTrain Trainer: See, different threat actor group that may have a desire to disrupt the university have been identified and are detailed below. Their motive, tactics, capabilities have been considered when developing the strategy. InfosecTrain Trainer: What kind of people have a motive to attack this university? InfosecTrain Trainer: What is hacktivist? InfosecTrain Trainer: Not relevant from the exam, but yeah. InfosecTrain Trainer: What is Hectivist? InfosecTrain Trainer: Anyone heard of this word? Hector. Mukesh Thakur: We hackers as activists?

Sandeep Saxena: Yeah, just to prove a point, there's no financial... Sandeep Saxena: motive behind that. For example, in the war of two countries, people do face Everyone's websites, right? Sandeep Saxena: studies activism. InfosecTrain Trainer: Activist is basically someone who is a... InfosecTrain Trainer: who is motivated by any cause? So, anyone who is motivated by any political cause, any, any, any cause with respect to, any specific... InfosecTrain Trainer: ethnic background, any specific activism they want to do, right? Like, animal rights activists, or any... InfosecTrain Trainer: people, those who kind of target, so those are called the hectivists. Any group who is motivated due to political, social, or religious purpose are called the hecktivist. InfosecTrain Trainer: So this is how the strategy is defined and written, right? Then you can see the vision of this overall security function, then what are the themes, what they will do in the identify, protect, detect, respond, recover, and govern, all those things. That's how the strategy is created, right? InfosecTrain Trainer: So when you are developing the strategy, First, strategy will start With these 3 tiers, right? InfosecTrain Trainer: It will start with the Tier 1. First, you need to understand the business goals. What are the key business goals? InfosecTrain Trainer: What organization actually want to achieve? InfosecTrain Trainer: what business want to have, right? Like, revenue growth, digital transformation, they want to have a compliance with respect to specific regulations like GDPR, InfosecTrain Trainer: CCPA. What is CCPA? InfosecTrain Trainer: Anyone heard of this regulation, CCPA? InfosecTrain Trainer: California Consumer Protection act. InfosecTrain Trainer: It's for the state of California in the US.

It's almost similar to GDPR only, but specific to the California... InfosecTrain Trainer: citizens. InfosecTrain Trainer: basically California residents apply to them. Then, how you want to achieve the risk reduction, how you want to have an operational resilience, so these are the business goals. InfosecTrain Trainer: Once business goals are there, then next year would be, you want to have a business and overall integration. You want to align with respect to the organization goals. InfosecTrain Trainer: Governance, and all those things, right? InfosecTrain Trainer: So if organization want to achieve the AI governance, you want to ally with respect to that, right? You want to map the security controls with respect to the frameworks. You will integrate the security with respect to the AI objectives. You will also identify what are the regulations which are there. InfosecTrain Trainer: Right? InfosecTrain Trainer: And then you will align. And then last year would be, on the basis of this, you will create some security objectives. InfosecTrain Trainer: Because against those objectives only, then you will measure the success. InfosecTrain Trainer: how much you have achieved. Like, if you want to migrate from on-prem to cloud. InfosecTrain Trainer: Can you migrate the entire infrastructure in a short time? No. InfosecTrain Trainer: This is going to be a big activity, right? Which will probably take probably 2 to 3 years... 3 years, or 4 to 5 years' time. InfosecTrain Trainer: So, against which you want to... InfosecTrain Trainer: measure the success, right? You say, okay, first year will migrate 20%, next year will migrate another 30%, likewise, you will InfosecTrain Trainer: And then, against these objectives, you will measure the success.

subaveena pugalethi: Sorry, I just have a question. The strategy development fundamentals is for the security strategy that the CISO builds, or is this something else? InfosecTrain Trainer: Yes, this is for the security strategy, for CISO Wells. subaveena pugalethi: Okay, so the first tire would be understanding the business objectives to align the security objectives towards the business goals, right, tire want. InfosecTrain Trainer: first would be understanding the goals, right? Once you understand the goals on the basis of the business goals, then you will align InfosecTrain Trainer: your security with respect to those goals, and then on the basis of those goals, you will create the security objectives. Understood. subaveena pugalethi: No, okay. InfosecTrain Trainer: It will always start from top to bottom, right? It will always start from the organization to the security, not from security to the organization. You will create the security strategy on the basis of what organization want to achieve. subaveena pugalethi: Okay. InfosecTrain Trainer: I gave a couple of examples, I gave example of that Zepto, right? InfosecTrain Trainer: So Sepo want to deliver InfosecTrain Trainer: the products to their customers as quickly as possible, but to achieve that quick delivery, there are a couple of things which are working in background, right? There is a delivery app where people are placing the order, then there is a... there is a database, there is a warehouse, SKUs, and the inventory which they are managing, then there should be a delivery InfosecTrain Trainer: a boy who is going to go and deliver the product, right? That delivery partner also need to quickly reach to the location. All those things coming together, right?

InfosecTrain Trainer: Then the business objective would be achieved if all those things are protected and secured. InfosecTrain Trainer: Now, what are the business goals and the objective? What business actually want to achieve, right? So, these are business goals. In all the organization, what are goals they want to achieve? First thing is the revenue. InfosecTrain Trainer: Every organization want to have a good revenue growth with innovation. InfosecTrain Trainer: Right? They want to expand the business, they want to have a good revenue growth year on year, right? They want to enable their product and the services as per the new digital transformation, as per the changes which are being done in the market, right? All those things your business want to do. InfosecTrain Trainer: Next thing is the risk reduction and resilience, right? Overall, whatever are the threats against your organization, whatever new initiatives you are doing, right? If you are expanding your business to the new countries, overall, you want to reduce the risk. InfosecTrain Trainer: Right? And you want to make sure your system becomes resilient, so that the issue like GLR don't happen. InfosecTrain Trainer: Or even if tomorrow the issue, like, the CrowdStrike happens, you remember that there was a CrowdStrike, event, probably two, two and a half, three years back? InfosecTrain Trainer: Where there was a complete outage all across the world. The people, those who were using the Microsoft, there was some... yeah, there was some security patch launched by the CrowdStrike, due to which there was a blue death screen. InfosecTrain Trainer: Entire... all... all airports to all the important infrastructure, they all... got affected.

InfosecTrain Trainer: So if something happens tomorrow, how your organization would recover from that, how quickly they will be able to recover from that, that would be determined on the basis of resilience. Probably, if you have a recovery priorities. InfosecTrain Trainer: you have properly done your business continuity planning and disaster recovery planning, your team will have a recovery priority. What they will do? InfosecTrain Trainer: Can they restore and recover all the systems at one go? No. What they will do, they will... they know that which are the critical business. First, they will go ahead and recover them. Probably other systems will follow. InfosecTrain Trainer: Right? So you want to minimize the overall breach probability and impact. InfosecTrain Trainer: You want to manage the supply chain risk. What is the supply chain risk? subaveena pugalethi: Any incident or risk that emerges from a third-party supplier or service that the business takes, From a vendor. InfosecTrain Trainer: Correct. InfosecTrain Trainer: Correct. InfosecTrain Trainer: So, any risk which, which, originates from, originates from some teneth party. InfosecTrain Trainer: And then they reach to your organization, which disrupt entire supply chain. It's called supply chain risk, right? Then there are other risks with respect to AI models, which are new, right? Now there are the DORA compliance, and also all are the new things which are there, right? Then. InfosecTrain Trainer: Next object... subaveena pugalethi: Compliance, never heard of it. InfosecTrain Trainer: Yeah, so this... this DORA is basically related to the financial sector. subaveena pugalethi: Okay, okay.

subaveena pugalethi: And is it specific to India, or... InfosecTrain Trainer: No, no, no, this is not specific to India. This is Digital Operational Resiliency Act. This is basically in the EU. subaveena pugalethi: Okay. InfosecTrain Trainer: They actually launched... they recently introduced in 2025, right? InfosecTrain Trainer: So they want all the banks, insurance firms, and then critical third-party provider to ensure that they can... InfosecTrain Trainer: They can withstand and recover from any kind of cyber attack. Basically, more focused toward the resiliency. There is one more new act, which you have heard about, the NISTU. InfosecTrain Trainer: which is there... it was recently, passed in the EU, which is more around... InfosecTrain Trainer: overall security around the manufacturing organization, production organization, they are also included. They are also being covered, because earlier, EU has mainly GDPR. So GDPR, if you see, is more focused around the data protection. subaveena pugalethi: Yeah. InfosecTrain Trainer: They did not have other acts which probably protect InfosecTrain Trainer: they... the organizations, those who are serving them, in terms of other security threats. So that's why they have introduced the new sets of laws and regulations. InfosecTrain Trainer: Then comes the regulatory compliance. So what kind of regulations applies to your organization, right? Your

organization should be able to fulfill those obligations, right? InfosecTrain Trainer: If organization is doing business in India, so they should be DPDPA compliant. If you are doing business in the EU, you should be GDPR compliant. If you are a healthcare industry, you should make sure that you are HIPAA compliant, right?

InfosecTrain Trainer: So, all the regulatory compliance which are InfosecTrain Trainer: applicable to the organization, should make sure the security is making a balance between them. Then there is a new goals, which is recently added to all the organizations with respect to AI governance and ethics. InfosecTrain Trainer: probably at this point of time, I believe the 90% plus organization have already started using AI, right? Those who are not probably have already left behind. It can be more than that. So any... in any form. I'm not saying that they are developing any machine learning models. InfosecTrain Trainer: Probably they are using generative AI tools, or they are doing some part of AI, so they have introduced, but how ethically you use that AI, that also becomes very important, right? If your AI is taking any decisions, it should not affect someone. InfosecTrain Trainer: So there have been a lot of incidents, because now the AI have got optimized InfosecTrain Trainer: in a much better manner, right? But if you see the earlier or the initial outputs, Which were there. InfosecTrain Trainer: Which were a very... InfosecTrain Trainer: So then they holistically trained the AI. If you see the initial models which were there, launched by the GPT and the Gemini, right, which used to generate the images and all, there were a lot of conflicts coming from the world, right? That these are not generating the actual images, what we want, or probably generating some kind of objectionable content, so... InfosecTrain Trainer: Then they trained it InfosecTrain Trainer: On multiple things, and then now they are able to provide you the better output, right? InfosecTrain Trainer: Now, operational efficiency.

So, you want to make sure that overall operational efficiency in your organization is achieved, right? So that operations are running smoothly. That's why you do the automation, right? InfosecTrain Trainer: Has anyone heard about the SOAR? I think I know one person who have led the SOC would have heard about the SOAR, but anyone else who have heard about the SOAR, what is the SOAR? Ashwin: of February 20th. Pudir: Security orchestration. InfosecTrain Trainer: What does it do? SrinivasanJ: Correlation of, events across multiple platforms, and make an action. SrinivasanJ: Or recommend an action. InfosecTrain Trainer: Basically, automating your playbooks. InfosecTrain Trainer: Right? That's what you do with the SOAR. InfosecTrain Trainer: So, in the SOC team, you have some couple of playbooks, right? You want to automate those things. You want to automate those basic tasks, what you do, day-to-day basis. Pudir: Well, I started the index. InfosecTrain Trainer: Correct. InfosecTrain Trainer: Now, organization, culture, and the structure. How important is the organization culture in terms of security? Can someone... InfosecTrain Trainer: Define, what do you mean by a culture? Johnny Souriar: So, response to the securities, react to... Johnny Souriar: Or it is proactive, or it is resilient. Pudir: Sir, every organization has its own systems. Pudir: follow-ups, environment, the people, their habits, office environment. That itself is a culture. InfosecTrain Trainer: Correct. InfosecTrain Trainer: That's why. It all depends on organization and differ from organization to organization. So, which industry is the most regulated industry in the world? Ashwin: Banking. InfosecTrain Trainer: Banking, yes.

So you will always see the tools, technologies, and adoption within the banks happening always at the slower pace than other type of industries, right? InfosecTrain Trainer: Why? Because there are so many regulations which are coming on them, right? So their culture is totally different. InfosecTrain Trainer: If you see from the product organization or the organization, those who are developing or producing the products, they are going to be the much more aggressive in terms of the technology adoption, because if they do not do that. InfosecTrain Trainer: They do not evolve. InfosecTrain Trainer: their competitor will take their place, right? So that's how the culture differs. InfosecTrain Trainer: So, I'll take the example from my experience, right? I have worked in the banks also. I'm now working in a manufacturing organization, right? So, when I was in a bank. InfosecTrain Trainer: the emailed... Domain was completely blocked. InfosecTrain Trainer: No one in the organization can send or receive emails from the outside domains. InfosecTrain Trainer: That's what they are. Only with a specific approval, like some specific people, those InfosecTrain Trainer: who want to probably talk to the external people or external parties, they only had external to the... access to the external device. So, security is completely... from the phishing side, the organization is completely protected, right? Now, in this organization, the... InfosecTrain Trainer: Due to the manufacturing, due to the product-based organization. InfosecTrain Trainer: There is an extensive responsibility for the people to talk to external customer, engage with them. InfosecTrain Trainer: So that's why we cannot do it, right?

So to balance it, what you have to do, you have to have a very strong email gateway-related protection control. You should always have a good awareness-related program so that people can detect and they can find the incident, right? So that's how the culture is changed from organization to organization, right? InfosecTrain Trainer: There should be a function integration. Each unit in the organization, be it from the finance to the engineering, everyone should understand the responsibility towards security. That's why we say security is the responsibility of everyone. InfosecTrain Trainer: Right. InfosecTrain Trainer: So, if... if you have a software development team, if they are following the SDLC secure development lifecycle, they should make sure that the security is embedded there. InfosecTrain Trainer: Whatever product and tools they are developing, it's fully secured, following the organization policies and guidelines, right? InfosecTrain Trainer: Security is universal responsibility. Everyone's responsibility InfosecTrain Trainer: So, so whatever you use, whatever you do, you have to do that. InfosecTrain Trainer: And have you heard about the policy name EUC? Acceptable Use Policy? How many of you heard about this policy? Acceptable Use Policy? It should be there in all your organization. SrinivasanJ: Yeah, right. Supriya Mhatre: It's... InfosecTrain Trainer: So the acceptable use policy is something which will define exactly what is allowed, what is not. Which tools you can use, which social media website you can browse, what you can post on your social media, what you can attend, what you can do, right? InfosecTrain Trainer: So this particular policy also sets a good culture within the organization, right? Then the hierarchical alignment.

InfosecTrain Trainer: So, everyone from a hierarchy, from board of director to the senior management to the last person in the organization, they should understand their InfosecTrain Trainer: Overall responsibilities, right? InfosecTrain Trainer: And... If you see which is the weakest link in the organization, it's always going to be the human. InfosecTrain Trainer: Because... InfosecTrain Trainer: Breaching a traditional tech stack, even if he is a very sophisticated black hat hater, is very difficult, right? InfosecTrain Trainer: Going via your firewall, network, and everything, you will never, ever see an attack which has happened via this way. They will always found a different traditional method. Probably they will InfosecTrain Trainer: They will, they will found out a vulnerability in your, in your external-facing infrastructure. They will deploy some payload there, or they will send some phishing email to someone, and from there. InfosecTrain Trainer: They will try to elevate the privileges and move InfosecTrain Trainer: to other systems, right? So that's why... InfosecTrain Trainer: The culture and the people, those who are the weakest link in the entire security chain, their security becomes very important. InfosecTrain Trainer: And why the organization culture matters, why it is so important to have InfosecTrain Trainer: First thing is that the security... InfosecTrain Trainer: Security should be the... security should provide InfosecTrain Trainer: the... so the culture, whatever you have in the organization, it should provide the basis for all security activities, what you do. What people can use, what they cannot, right? How the technical control are in place, right? And if they are bypassed, what is going to be there. InfosecTrain Trainer: Right?

If there is a shadow IT which is being used, if there are people using some unauthorized tools, they are browsing the social media or any unauthorized websites, so... InfosecTrain Trainer: those kind of foundational elements should be in place to establish that culture. Then, shared responsibility should always be understood. That's why you define a RACI. InfosecTrain Trainer: Responsible, accountable, consulted, and informed. InfosecTrain Trainer: Any project, any initiative you take, you will always see a RACI being defined there, so that everyone should understand what is their responsibilities, right? Like, HR team, when they are onboarding a new candidate, they should make sure there is a background check being done. InfosecTrain Trainer: When he's onboarded, what kind of training you do once you, once you join a new company? First day? InfosecTrain Trainer: I think most of you might be doing the basic... once HR complete the basic onboarding to you, after that, definitely, you will be doing a security awareness training, without... InfosecTrain Trainer: without that, no organization will give you access to the production data. They will first let you do that security awareness training, then only they'll give you access to the production data, right? InfosecTrain Trainer: So that people understand what are their responsibilities. InfosecTrain Trainer: We, being from a security fraternity, we know, but there are people joining in the finance, in the marketing, in the operations, in other departments, right? Those who have a very less understanding around security, so they should also know what is their responsibility from a security perspective. InfosecTrain Trainer: If there is an phishing email, where to report? Whom to tell. InfosecTrain Trainer: Whom to inform, right?

Then the awareness around the risk. InfosecTrain Trainer: So all the... all the... so all the risks, right? InfosecTrain Trainer: how to determine what is a phishing email, how to determine which is a risky software, how to determine what is a risky activity, or every employee should be aware of. They should have a literacy around it, right? And then the security behavior. All the daily actions which people take, right. InfosecTrain Trainer: Like, once you are leaving your desk, you should make sure that the computer is locked. InfosecTrain Trainer: When you are traveling in a metro from office to your home, you should make

sure, if you're working on any confidential or the secret document, the screen is not visible to the person who is sitting next to you. InfosecTrain Trainer: Right? Whenever you are generating any data from the AI, you are making sure you are checking it for the correctness. It's, InfosecTrain Trainer: It's applicability, then only you are, you are providing the access, right? InfosecTrain Trainer: So that's why it's very important. Now, AI-aware culture. This is a new thing. InfosecTrain Trainer: which is a new concept, have been introduced, right? Like... InfosecTrain Trainer: how the AI tools are being used. There was an incident, I think, last year, where one of the big InfosecTrain Trainer: for consultancy, they shared one report to one of their clients, and that complete report was generated through AI. They found out it, and then they filed a lawsuit, and they had to pay a big fine to them. Anyone heard about this? InfosecTrain Trainer: So this was a big failure in terms of AI, in terms of the culture, right?

InfosecTrain Trainer: They need to make sure that whatever data or information they are sharing to the client, they have to see... adhere to what contract says, right? They should not use the AI to, probably generate the information, right? And then the... InfosecTrain Trainer: Yes, correct, correct, yeah, it was the Deloitte. InfosecTrain Trainer: Now, the measuring the culture, right? So, culture, also, how you measure the culture? InfosecTrain Trainer: That's why there is a security awareness training, you do the phishing simulation exercises, you... you probably engage them in a training and awareness, you want to understand that... how much they have an understanding. What is the best measure or best matrix to determine the effectiveness of a InfosecTrain Trainer: Security awareness training. What is the best matrix? Johnny Souriar: Reporting of incidents. InfosecTrain Trainer: Yes, total number of security incidents reported, right? If people are able to report, identify the phishing, and they're able to report it, it means that InfosecTrain Trainer: your training was effective, right? That's what you taught them there, right? So, that is what... which will measure the success. InfosecTrain Trainer: Yes. InfosecTrain Trainer: Now, coming to the acceptable use policy. InfosecTrain Trainer: We discussed at high level, right? Acceptable use policies. So, when you join a new organization, they give you... they help you, the HR team will share you the acceptable use policy, they make you read it. InfosecTrain Trainer: And accept it. Understand it, what is acceptable, what is not acceptable in the organization, right?

InfosecTrain Trainer: So that people and the employees in the organization understand the risk around it, they understand what are the risks InfosecTrain Trainer: Of not following the organization policies, right? InfosecTrain Trainer: So that each and every employee, from a CEO till the last person, they understand their responsibilities, right? So what does acceptable policies include? Always, there's going to be scope and applicability. InfosecTrain Trainer: who and what systems, what people, what are things are covered, right? Like, bring your own devices, SaaS, GenAI apps, personal computers, and all those things, right? Then they will also define what are the permitted activities. InfosecTrain Trainer: clear guidelines, which things you can use, what tools you can use, how to request for a new tool, can you browse the social media website, what you can post on those websites, that is the permitted activities. Then comes the prohibited activities. They will also explicitly mention InfosecTrain Trainer: what is allowed, what is not. You cannot send any confidential data, confidential information from your computer to your personal ID. InfosecTrain Trainer: Whenever you are taking a printout of any secret or confidential data, make sure those hard copies are destroyed or destructed. InfosecTrain Trainer: Right? InfosecTrain Trainer: All those things. InfosecTrain Trainer: you will see, and if... Also, if a company's monitoring your activities. InfosecTrain Trainer: They have to inform the employees, right? InfosecTrain Trainer: So that people should know what are the things which are being monitored, right? What are the logs which are being captured, which activities are being looked into, so that users know, and what are the violation consequences.

If InfosecTrain Trainer: You do not follow these practices, you do not follow these protocols, and you continue to do this. InfosecTrain Trainer: what is going to be the consequences? You can be fired, you can have a legal notice, or something like that. So, all these things are generally covered as part of the acceptable use policies at a high level. So, if you InfosecTrain Trainer: go and read your organization acceptable use policies, you will find all these things. Acceptable Use Policy would be structured around this. InfosecTrain Trainer: Now, coming to the organization, structured and the elements. InfosecTrain Trainer: Every organization in the world, if you see. InfosecTrain Trainer: Any roles they create, right? So, any roles will be tagged with two things. Every roles have some responsibilities, they have some responsibilities, and to fulfill those responsibilities, they will check you on some basic skills. InfosecTrain Trainer: Correct. InfosecTrain Trainer: So, whenever you apply for a new role, you always read the job description. What is a job description? InfosecTrain Trainer: Job description will... InfosecTrain Trainer: Define that what are the responsibilities means what exactly you will be performing as part of that role. InfosecTrain Trainer: Also, it will mention some skills. InfosecTrain Trainer: So, there are some specific skills which are needed to become a CISO. InfosecTrain Trainer: If you don't have that skills, you cannot become a CISO, right?

You... if you don't have the strategic, you have no understanding around the strategy, you don't know how to manage the budget, how to manage the people, how to talk to the board of director and the senior management, you don't have a good communication skills, you don't have a good technical understanding around the security, overall cybersecurity. InfosecTrain Trainer: you cannot become a CISO. InfosecTrain Trainer: Right? That's how the things are aligned. So, every roles will have some responsibilities, and those responsibilities you can achieve on the basis of specific skills. Now. InfosecTrain Trainer: how the operating structure works. So, if you see, you would have... the people, those who are seniors, they would... you would have probably worked in multiple organizations. Every organization has a different kind of structure. InfosecTrain Trainer: If I talk from a security perspective. InfosecTrain Trainer: There are 3 types of structures, centralized, distributed, and hybrid. InfosecTrain Trainer: In a centralized, you can say there is one single cybersecurity function led by CISO, every... InfosecTrain Trainer: Function, everyone will follow whatever the strategy, policies, direction he's setting. InfosecTrain Trainer: Suppose you have a headquarter in US, you have your offices in India, EU... InfosecTrain Trainer: or probably you have office in Australia. All of them will work under the CISO. CISO will set the strategic direction, everything, they have to all follow that. There is no specific... you may have a distributed team sitting over here, but they will report to the single CISO, he'll only create the strategy and everything. InfosecTrain Trainer: What is a distributed security staff?

If, suppose, imagine a country, a company who has a headquarter in one country, but InfosecTrain Trainer: Their business is such vast in nature, they probably have a InfosecTrain Trainer: business in 50-plus countries. Can one single CISO manage InfosecTrain Trainer: All things, they cannot. And suppose all the countries have their own revenue, they have their own security, local security, all the countries have the local laws, regulations, which they have to follow. A single person cannot do that. So what they do, they do the distributed security stuff. InfosecTrain Trainer: How it works? InfosecTrain Trainer: All the countries will have a separate security heads. InfosecTrain Trainer: Those security heads will have an autonomy to decide how the things will work, how the things will function, right? InfosecTrain Trainer: And then they will... InfosecTrain Trainer: Create their own... they will have their own security budget to adopt tools, technology, some basic InfosecTrain Trainer: The responsibilities and reporting they'll do to the headquarter country. InfosecTrain Trainer: Hybrid is something which is mix of them. InfosecTrain Trainer: How it works, rather than having a distributed security, what you do, You maintain one. InfosecTrain Trainer: central CISO, and every country will have a security head. InfosecTrain Trainer: Rather than managing one single SOC team, what you will do, you will have a distributed SOC, a hybrid structure, where you will have one SOC in US, who is maintained for 8 hours, you have one SOC in EU who is maintaining 8-hour ship, you have one SOC in India who is maintaining 8R ship. InfosecTrain Trainer: So, you are providing the 24 cross-7 coverage. InfosecTrain Trainer: Which is a hybrid model, which is a mix of centralized and distributed.

InfosecTrain Trainer: And what is the matrix reporting? Generally. InfosecTrain Trainer: When the person is reporting to the multiple people, it's called the matrix reporting. InfosecTrain Trainer: Right? So this is called the operating system. Now, coming to the roles. So, every organization, every security organization will have roles like CISO, security architect. InfosecTrain Trainer: security operations team, like L1L2, L3 analysts, security governance-related roles, security analytics-related roles, and what kind of responsibilities they have. CISO is responsible for the policy development, strategy development, right? Architects... InfosecTrain Trainer: We'll have some specific architecture-related roles. Some responsibility would be with respect to risk assessment, control implementation, incident response, and compliance monitoring. InfosecTrain Trainer: This is how the operating structure, roles, responsibilities are structured in the organization. InfosecTrain Trainer: Now, how important it is to map the roles to the skills? InfosecTrain Trainer: Right? InfosecTrain Trainer: So, every role... Need some specific skills. InfosecTrain Trainer: Without that, that role won't be able to InfosecTrain Trainer: to probably fulfill the responsibilities, what they want, right? CISO want to do what? He want to create a strategy, he want to do the board reporting, he should know how to create, understand and create policies. If he don't have executive communication risk management at the leadership skill, he'll not be able to do that. InfosecTrain Trainer: And if you do not have that, then what is the gap? He'll have a poor board alignment, he probably will not be able to seek funding for the specific initiatives, right? InfosecTrain Trainer: Next thing is the architect.

InfosecTrain Trainer: So if you say there is a security architect, what responsibility they should have? They should have a technical security design and the framework understanding, right? They... what skills they have, they should understand the system architecture, secure by design, and threat modeling.

InfosecTrain Trainer: Analyst, if suppose, someone is working in a InfosecTrain Trainer: SOC team, as analysts, they should understand... they should... they will be doing the threat detection and the investigation. But to do that, they should know how to analyze the logs, how to gather the threat intelligence, how to do the forensics, similarly, like, engineer and the GRC specialist. InfosecTrain Trainer: So, every role which you see, they have some specific responsibilities, and to fulfill them, they require some specific set of skills to fulfill it, right? InfosecTrain Trainer: So that's how it is structured, right? InfosecTrain Trainer: So let's do one thing. Let's... Continue... InfosecTrain Trainer: From here in the next class, but before we break off. InfosecTrain Trainer: Let me share you all some couple of... InfosecTrain Trainer: Things which you people can probably go over before coming to the next class. InfosecTrain Trainer: So, I am sharing some videos with you. InfosecTrain Trainer: If someone has access to WhatsApp Web, probably they can. InfosecTrain Trainer: Drop the link there as well. InfosecTrain Trainer: Now, what I want all of you to do... InfosecTrain Trainer: If you have got access to that Google Drive, right, which I showed you. InfosecTrain Trainer: So, in that Google Drive, there... there are some notes which are available. InfosecTrain Trainer: I'll show you, probably, once again. InfosecTrain Trainer: You see, there is a folder named Domain Wise Notes.

InfosecTrain Trainer: So, you can just give a very high-level reading to Domain 1 nodes. I'm not saying you go in deep, read everything, just InfosecTrain Trainer: Probably sit for one or two hours, if you have time tomorrow. Just give a high-level reading, so that whatever we have InfosecTrain Trainer: understood or studied today, those concepts also get clear in your mind, plus what we are going to discuss tomorrow, that also will get clear in your mind, so that once you start solving the question from the Monday onwards. InfosecTrain Trainer: you will be able to get a best output. You will be able to probably get the maximum number of questions correct, right? So that's why... so this particular folder has all the four domain InfosecTrain Trainer: notes. InfosecTrain Trainer: 1, 2, 3, and 4. InfosecTrain Trainer: So, Siva, this recording would be shared to all of you with a link. InfosecTrain Trainer: Right? InfosecTrain Trainer: You will get a link over the email. InfosecTrain Trainer: Let me share the link to the WhatsApp group. InfosecTrain Trainer: Can someone has the WhatsApp? InfosecTrain Trainer: Open, probably you can share the link to the people. InfosecTrain Trainer: Look, me, shit. InfosecTrain Trainer: Let me share the link with you all here. InfosecTrain Trainer: Yes, this is the WhatsApp group link. You people can join. InfosecTrain Trainer: And Google Drive link also... I can share once again. InfosecTrain Trainer: Yeah, so this is a Google Drive link. So, all those who have not yet got the access, or probably if you don't get InfosecTrain Trainer: those recordings and all, I would recommend please ping Saxam. InfosecTrain Trainer: He's there in the group. InfosecTrain Trainer: He... he will help you out with that.

InfosecTrain Trainer: So, what you need to do tomorrow, please go over these recordings, these, videos which I've shared. If you have time. InfosecTrain Trainer: It's good if you can just InfosecTrain Trainer: go over those notes quickly, which I shared, which is there in the Google Drive. InfosecTrain Trainer: So yeah, so that's all. I hope all of you are able to follow the pace which InfosecTrain Trainer: I have for the training. If anyone has any issues, anything, I'm going too fast. InfosecTrain Trainer: I'm going too slow, please let me know. Also. InfosecTrain Trainer: This is an interactive session. It's not like that, that I'm just teaching from my side, and new people will be just listening to me. Anytime in between, you can just stop, ask any question if you have. If... if you cannot InfosecTrain Trainer: You can... you can probably... you can probably drop it in the chat. Pudir: Sir, this is Pudir. I joined a bit 5 minutes later. What are the weekends that are not having classes? InfosecTrain Trainer: I'll just share. I'll just share in the chat. So the classes won't be there on the 15th August, because it's, independence. Fatha, can you please go on... Pudir: Pacific. InfosecTrain Trainer: It's not going to be there on the 15th. InfosecTrain Trainer: And... on the... 29th? InfosecTrain Trainer: And 30th, that weekend. InfosecTrain Trainer: That's it. Rest, all, we'll have the classes. Pudir: Okay. Sir, one more data. This CISA exam guide, some supporting tasks are there 1237. I think they are covering in this PTS also. InfosecTrain Trainer: Yeah, yeah, yeah, all those, all those supporting tasks and everything is covered. InfosecTrain Trainer: That supporting task and everything is actually, it's a part of the syllabus only. Pudir: Okay.

InfosecTrain Trainer: So... so as part of this, whatever case studies and whatever we are discussing, right, those things are getting covered as part of that. Pudir: Thank you. subaveena pugalethi: Sorry, I just have a couple questions. So, does... does this mark the end of first domain, or are we, like. InfosecTrain Trainer: No, no, no. We are only completed, I think, 30-40%. It's a... we'll... there's a big part left, which we'll be covering tomorrow. subaveena pugalethi: Okay, okay. And, like, for someone that completed CISA certification, like, any of the domains. subaveena pugalethi: From there, relate to here as well, or it's completely independent? InfosecTrain Trainer: CISA is more structured around the audit, right? Probably some of the topics you will see similarity, like this governance and all you would have also learned there also, like, what is policies, what are standards, and those things, but InfosecTrain Trainer: CISM is more structured around the cybersecurity, right? So... InfosecTrain Trainer: It covers at, at, it covers and touch across all the things, which you probably would not have studied in this... InfosecTrain Trainer: CISA. Pudir: CIS is more related to audit side. I am working for Government of India, Indian Audit and Accounts Department, so that my department works to complete that exam. InfosecTrain Trainer: Yeah, yeah, that's what I'm saying. CISA is not that technical, or will not get into very core cybersecurity-related topics. Pudir: Listen. SrinivasanJ: And what about the CISSP? Like, what we learn in CISM? The domains that we learn here? Is that something related to CISSP also? InfosecTrain Trainer: Yes, so CISSP also, I've done the CISSP, right? So once I passed the CISM, I think after a couple of months, I did CISSP also.

So the CISSP... InfosecTrain Trainer: It's very broad in terms of syllabus. InfosecTrain Trainer: Right? CISP... so, first domain, and the last domain, which is the incident management. Even other domains also, some couple of topics which you will find which is common. InfosecTrain Trainer: But CISP has a very extensive topic around specific domains with respect to identity and access management, right? It has a very specific domains with respect to... it even all talks about the physical security, all those things. It goes... it has a lot of technical topics. InfosecTrain Trainer: which are not there in CISM. CISM... even in the incident management domain in CISSP, you will talk about the attack types and all, how the SQL injection works, and those things, and those things are generally not there in CISM. InfosecTrain Trainer: The technical topics. SrinivasanJ: Okay, thank you. SrinivasanJ: But this will help me, right? InfosecTrain Trainer: This will help, this will help. But don't think that by doing CISM, you can directly go ahead and write the CISSP, because the question InfosecTrain Trainer: Pattern is totally different there. SrinivasanJ: Cap. InfosecTrain Trainer: Okay. InfosecTrain Trainer: Alright, then. InfosecTrain Trainer: So, thank you so much, everyone, and see you all tomorrow in the class. Supriya Mhatre: Thank you. Thank you. InfosecTrain Trainer: Thank you. Thank you, thank you. Praveen Kumar: So... Sandeep Saxena: Dude. Johnny Souriar: Then go the Batch. Pudir: Thank you.

Day 2: Full Cleaned Transcript

Approximate source length: 30,150 words.

Shivaganeshan S: I'm on the level. Shivaganeshan S: Goodbye. InfosecTrain Trainer: Hello, good evening. Good evening, everyone. InfosecTrain Trainer: So, anyone has any questions from yesterday's session before we get started? InfosecTrain Trainer: Any, any question, any doubt with regards to exam? InfosecTrain Trainer: Or anything else? InfosecTrain Trainer: I hope you people watch the videos which I shared. Johny Souriar: Can I even got... prem: Can anyone... InfosecTrain Trainer: Anyone... anyone got time to watch those videos? Supriya Mhatre: Yes. Siva Krishna Kalipatnapu: I didn't get a chance to... Supriya Mhatre: Yes, I saw Pravnya's governance, video. It was very informative. InfosecTrain Trainer: Great, great. Anyone else? SrinivasanJ: Yeah, I was able to watch two videos. Ashwin: Yeah. SrinivasanJ: Understood. Ashwin: 3 of them. InfosecTrain Trainer: Nice. InfosecTrain Trainer: Alright then. InfosecTrain Trainer: Let's get started. InfosecTrain Trainer: So yesterday, we stopped here, right? We were discussing about the organization structure, roles, responsibilities, and skills, right? InfosecTrain Trainer: So, I hope everyone is clear, and you... InfosecTrain Trainer: You, you know what is the clear distinction between a centralized security function versus distributed versus hybrid. InfosecTrain Trainer: So, this difference is very much important, right, so that you may get questioned in the exam. InfosecTrain Trainer: So that's why... please try to understand what does this mean, what does centralized security function mean, what is distributed, what is hybrid, right? So I told you, right, in the centralized, everything is controlled by a headquarter country.

Like, suppose you have a headquarter in US, InfosecTrain Trainer: you have the offices, probably, in EU, InfosecTrain Trainer: in India, let's say you also have an office in China, right? So... so you will have one central, InfosecTrain Trainer: security function led by CISO. He's the one who will be InfosecTrain Trainer: directing everything, or all the countries and all the countries where your business operates, they'll follow the same. There is no distributed staff. There can be a distributed team or a staff, but the decision and everything, budget decision and everything, would come from a single source. InfosecTrain Trainer: Right? But in a distributed security staff, suppose InfosecTrain Trainer: so you have one CISO, but all the countries will also have one local security function, and those local security functions will also have some budget, some autonomy to decide the tools, technologies, and other things, right? So everything is not being driven by central function. Probably center function will only create your, InfosecTrain Trainer: strategy, REST, every function will follow their own practices. But in the hybrid model. InfosecTrain Trainer: All the policies, all the instructions, and everything would come from the central team, but local team will also have some InfosecTrain Trainer: decision-making powers, right, which they can make. So that is the hybrid model, right? InfosecTrain Trainer: So that's what we discussed yesterday. Now, understand this. Roles with the skills, right? So, all of you might have applied for the roles, right, whenever you applied for a new role, so you look at the job description, right? So, job description. InfosecTrain Trainer: Job description has two things.

One thing, it has the responsibilities InfosecTrain Trainer: Then it also mentions the required skills to perform that role, right? InfosecTrain Trainer: Suppose you are applying for a security architect role. So, security architect role, you will see, okay, what are the responsibilities for the role? But to perform those responsibilities, there are some specific skills which you should possess. Otherwise, you will not be able to perform that task or duty, right? So, those skills InfosecTrain Trainer: Also, you will find in the job description at the bottom, right? So, that's why you have to map the roles with the skills when you are designing the security function within the organization. InfosecTrain Trainer: It's very important for each and every role which you design. You... InfosecTrain Trainer: Select what are going to be the responsibilities for that particular role, and then InfosecTrain Trainer: Is it my screen is not shared? Neethu: Shared. Supriya Mhatre: It is visible in the. prem: Yeah, it is. InfosecTrain Trainer: Is it visible? Okay, okay. Johny Souriar: visible now? Johny Souriar: I'm getting blank screen here. Neethu: Yep. InfosecTrain Trainer: Okay, probably you need to... Log out and log in once again. Johny Souriar: Okay, I will rejoin, okay, thank you, thank you. InfosecTrain Trainer: Sure. InfosecTrain Trainer: And then all other example roles, which you can see here, right, they also follow the same thing. You have a responsibility, and then you map them to a required skills. If there is no direct mapping between them, right. InfosecTrain Trainer: So, you will always find a gap in that particular role. Person would not be able to adequately perform the job or the role for which he's chosen, right?

And then, you will have issues in your day-to-day operations. So, that's what is the role and response. So, this was the last slide which we discussed yesterday. InfosecTrain Trainer: Now, understanding in detail about those structures, right? What I told you in brief, right? Centralized versus decentralized versus hybrid and matrix model, right? InfosecTrain Trainer: So, what is the best advantage of having a centralized approach? So, let me tell you, centralized approach you will mainly find in an organization if there is scale of operations and their reach of operations is limited. InfosecTrain Trainer: If some country is probably operating in 100, 200, 300 country, 100 country plus countries, right, or 50 countries, and... InfosecTrain Trainer: they have a huge business, probably a single security function may not be able to handle all the workload, right? So, that's why centralized approach you will generally find in those kind of organizations, right? Where there is a single security authority. InfosecTrain Trainer: The best advantage of this particular approach is you will have a unified direction. So, CISO sitting at headquarter country will create a strategy InfosecTrain Trainer: He will create the policies, So every... InfosecTrain Trainer: other countries where the business operates, they will follow the same thing. Even the tools, technologies, tech stack, everything would be unified, rather than everyone is using their own tech stack, right? InfosecTrain Trainer: And the controls also would be consistent. InfosecTrain Trainer: probably some, country... in some country, they are not using the, EDR. It's probably not deployed. In few of the places, EDR is deployed. Few of the places, some couple of controls are working in a different manner, so that's why.

InfosecTrain Trainer: Control, consistency also would... won't be there if you are not in a centralized approach, right? And the accountability would be clearly defined, and the resources would be efficiently operating. So these are the advantages, but if you go to the decentralized approach. InfosecTrain Trainer: What is the best advantage of this business unit alignment? InfosecTrain Trainer: So, whatever business you are having in a particular country, right, if that particular country will have some different kind of business, different kind of requirements, that alignment would be much better. All the local laws, regulations, rules, those, also you will follow, follow with InfosecTrain Trainer: with all... Following those rules and responsibility will also become easy, because InfosecTrain Trainer: local team will have a much better knowledge around them, and they'll be able to align the requirements as per that, right? And then, there is going to be the customized control as per the requirement locally. InfosecTrain Trainer: there was... is going to be the local responsiveness and specialized expertise, which you will get. But what is the... which is the best model is always the mix of both. Hybrid or the matrix model, where you are taking the balanced approach. InfosecTrain Trainer: Some responsibility sits with the central team, and then the CISO will delegate some authorities to the local security heads. InfosecTrain Trainer: So, in the GCC kind of setup, right, which you see, India is very popular for having the GCCs, right? We have a good number of GCCs. You will mostly find them in this model.

InfosecTrain Trainer: So the CISO generally sits in the headquarter country if GCC is from the US, so CISO would be sitting there, but always you will find one security head who is sitting locally. InfosecTrain Trainer: has some autonomy of decision-making around hiring, policies, tool selections, and all those things. So, you will see a balanced approach here. InfosecTrain Trainer: And there is a shared responsibility. Some responsibility is sitting with the local representatives, and some responsibility sits with the CISO. InfosecTrain Trainer: And always in GCC setup, you would have seen, right, dual reporting. You will always see a kind of a dotted line. So the CISO who is sitting here, he would be probably reporting to the business head of that country, plus he would be having dotted line to the CISO, central CISO function. InfosecTrain Trainer: That you will always see happening. InfosecTrain Trainer: And then it will have a collaboration around the governance. So, these are some of the advantages between the centralized, decentralized, versus the hybrid approach. subaveena pugalenthi: How would that reporting be in decentralized approach? InfosecTrain Trainer: So, decentralized approach will have the local reporting, not to the central function. InfosecTrain Trainer: So, I think I... so, the best example of this, someone here from the Unilever? InfosecTrain Trainer: So, Unilever has a very big reach, right? So, all the countries where the Unilever operates, their business has the local legal entities, and all those local legal entities has the local CISOs. InfosecTrain Trainer: That's how they operate. subaveena pugalenthi: Okay, so each country has, has its own CISO that they report to? Yes. InfosecTrain Trainer: Yes, yes, correct, correct.

And they have their own budget. InfosecTrain Trainer: Which they can spend. subaveena pugalenthi: Okay. InfosecTrain Trainer: Let's discuss some questions, yeah. InfosecTrain Trainer: I'd like to discuss, I think, first question I can see. InfosecTrain Trainer: A lot of conflicting response, but yeah, let's discuss. InfosecTrain Trainer: A company has a strong technical controls, but employees frequently bypass the security procedure. From a strategic alignment perspective, what is the first and the most crucial step the CISO should take to improve the organization culture? InfosecTrain Trainer: Always remember, Culture, wherever you see a culture, right? InfosecTrain Trainer: Culture always can be improved if you... your senior management is aligned with you.

InfosecTrain Trainer: Right? In your organization also, how the culture can be improved. Can CISO improve the culture just by conducting the awareness training, or if your senior management or your department head, business heads in their town hall, if they continue to tell people that. InfosecTrain Trainer: please be aware about, vigilant about the security. Security is everyone's responsibility. That is going to be the better approach, or only CISO is conducting a mandatory training, you think yourself. InfosecTrain Trainer: then you will get your answer automatically, right? So, first thing is the implementing mandatory annual cybersecurity awareness training for our... just by, having a training does not improve the culture. Training InfosecTrain Trainer: probably might already be happening there, right? But does having the training only improve the culture? No. Probably people may... don't, attend those trainings, right?

InfosecTrain Trainer: procure advanced security automation tools just by deploying automation tools is still there is going to be the error, right? Still people... people are the ones who are handling the processes, so they'll... InfosecTrain Trainer: commit the mistakes. Conduct a comprehensive business impact analysis to identify critical assets. So this is as such, out of context. InfosecTrain Trainer: Business impact analysis is... has no kind of connection to the question what it is asking. Business impact analysis is mainly conducted when you are creating a business continuity plan and the disaster recovery plan, not here. InfosecTrain Trainer: So this is as such illuminated. Now, if you see option B, right, if you... InfosecTrain Trainer: Align the executive leadership, and then they... InfosecTrain Trainer: continue to, in their town halls and whatever meetings they have, they continue to champion or continue to force that the security is an important part of the organization, you will see a change in the organization, right? That's how the culture will improve. InfosecTrain Trainer: An e-commerce company's primary business goal is 50% global customer base expansion, and new payment methods to ensure the best strategic alignment. What is the main consideration for CISO's information security strategy? Implement the latest security technologies for the maximum protection. Just by having a latest security tech stack does not make sure that you are protected from all the kind of threats. InfosecTrain Trainer: Prioritizing security controls directly supporting customer trust, privacy, payment system integrity looks a good option. Achieving compliance with all international cybersecurity standards is relevant to e-commerce.

InfosecTrain Trainer: it says all international cybersecurity standards relevant to e-commerce. Why would you Comply to all relevant, InfosecTrain Trainer: compliance standard, you will comply to only those which are applicable to your organization, right? Even if you're an e-commerce, but it's not necessary... you have to comply to all. You will comply to those where your office is based, right? InfosecTrain Trainer: Minimize the security budget expenditure to maximize profit margin? No. Security... InfosecTrain Trainer: is there to protect the organization, not to show the profit. So, correct option here is B. InfosecTrain Trainer: A global nonprofit organization has diverse regional offices, each with unique operational needs and the local regulatory requirements. To achieve the greatest effectiveness in the information security, which organization is structured for the security would be most appropriate? InfosecTrain Trainer: Just by having a centralized security team, you will have a better decision-making and all, but InfosecTrain Trainer: Probably then local laws and local things which are there, it may get missed. InfosecTrain Trainer: Right? InfosecTrain Trainer: completely decentralized security team operating independently within regional office. It may have a better local alignment with respect to laws, but InfosecTrain Trainer: There is going to be some mis... kind of... there is going to be inconsistency around the control alignment and the policy and the strategy implementation, right? InfosecTrain Trainer: hybrid model is always good, which will balance between the centralized approach, where you have the direction coming from one person. Also, the local team will take care of the local laws and regulations, right? Not this. So, correct option here is C.

InfosecTrain Trainer: I hope everyone is clear here, or anyone has any different opinion. InfosecTrain Trainer: Let's discuss couple of more questions. InfosecTrain Trainer: I think yesterday we discussed less. InfosecTrain Trainer: Yes, please try to answer these four. InfosecTrain Trainer: Alright, let's discuss the correct answers. InfosecTrain Trainer: So, the first question is talking about which of the following roles is responsible for the legal and the regulated liability for failure of security in the enterprise? InfosecTrain Trainer: If in your company there is a failure in the security, there is a ransomware attack, and complete system got shut down, there was a billion dollar worth of impact, who will hold the legal liability? InfosecTrain Trainer: Is this going to be the chief security officer, chief legal officer? InfosecTrain Trainer: Board of Directors, senior management, or Information Security Steering Group. InfosecTrain Trainer: It's always going to be the board of director and the senior management. Any failure of security InfosecTrain Trainer: Legal and regulated liability always sits with the senior management. InfosecTrain Trainer: Not with the chief security officer, legal officer, or the steering group. Steering group, we are yet to discuss. We'll discuss about what are the roles and responsibilities of the steering group. InfosecTrain Trainer: Now, second, so correct answer here is C. InfosecTrain Trainer: An information security manager at a global enterprise has to ensure that the local information security program will initially be compliance with the InfosecTrain Trainer: Always remember. InfosecTrain Trainer: Compliance with respect to the law and the regulation, you have to follow the law of the land.

Where your company is situated, where you are collecting the data, where you are processing the data, not global laws. InfosecTrain Trainer: Corporate data policy, definitely you will follow, but InfosecTrain Trainer: that policy cannot bypass the local laws, right? Data privacy policy where data is collected InfosecTrain Trainer: this is the correct answer, is B. Data privacy policy of the headquarter country, data privacy directive applicable globally. Which one you choose. So, suppose you have a headquarter in US, InfosecTrain Trainer: So, suppose you have headquarter InfosecTrain Trainer: In US, you operate in EU. Suppose you are a healthcare industry, let's take an example. You have office in India, you have office in InfosecTrain Trainer: China. So, US, you know there is HIPAA. InfosecTrain Trainer: Because you might be collecting PII data. EU, you have a GDPR. InfosecTrain Trainer: In India, we have a DPDPA, InfosecTrain Trainer: In China, there might be some local protection law, right? So, which law you will apply? InfosecTrain Trainer: will you only follow the HIPAA, because this is where the headquarters is there in the US, or you have to follow each of them which is there locally, right? So you will follow the local law of the land. InfosecTrain Trainer: So in... you operate in EU, if you are, if you are collecting the data of the people, you have to follow GDPR. In the US, you are collecting processing data, you have to follow HIPAA. In India, also, if you are providing the services, you are collecting the data, you have to follow DBDPR. InfosecTrain Trainer: Similar thing, they apply to China. Not only... InfosecTrain Trainer: the headquarter country law, or the corporate policies, and all. Always remember, you have to follow the law of the land.

InfosecTrain Trainer: So, correct... correct answer here is B. During a stakeholder meeting, a question was asked regarding who is ultimately accountable for the decision of the sensitive data, assuming all the roles InfosecTrain Trainer: exist in the enterprise, which would be the most appropriate? Security Administrator, steering committee, board of director, information security manager. InfosecTrain Trainer: ultimate accountability. InfosecTrain Trainer: Wherever you see the ultimate accountability, it's always going to be the board of directors. InfosecTrain Trainer: The correct answer here is C. InfosecTrain Trainer: Then, from an information security manager perspective, what is the immediate benefit of clearly defined roles and responsibilities? So, why you define the roles and responsibilities, we discussed, right? Enhanced policy compliance, improved procedure flow, segregation of duties, or accountability. It always helps you get a better accountability. InfosecTrain Trainer: Right? So that people know what they have to perform, what they are responsible, accountable, and where they'll be consulted, right? So, correct answer here is D. So, if you... if you see what is the correct answer, so first one is C, this one is B, this one is C, and this one is... InfosecTrain Trainer: B. InfosecTrain Trainer: Alright, so anyone has any different opinion? SrinivasanJ: For B, except, SrinivasanJ: The data privacy policy of the headquartered, or the... SrinivasanJ: Like, I'm a bit confused there. Like, let's say they... InfosecTrain Trainer: That's the way the data is collected. SrinivasanJ: Okay. InfosecTrain Trainer: I gave you example, right? I gave you Kamble. SrinivasanJ: Right, right. Let's say HIPAA compliance, right? PHI is very stringent in the US, but in India it is not.

InfosecTrain Trainer: Yes, so in the US, you will follow HIPAA. In India, you will follow DPDPA. If you have the same... suppose there is an insurance company who provides insurance, in US also, they provide insurance, in India also, EU also, China also. SrinivasanJ: So, which means my data is getting leaked in some other country. InfosecTrain Trainer: While leak, wherever the data is getting collected, you have to follow the law of the line. GDPR says that the data cannot leave GDPR. You... InfosecTrain Trainer: countries, so you should be maintaining a local servers. Similarly, you will do with the US. Similarly, DPDP also says you can... the data of the Indian citizen or their PII information cannot leave the India, so you need to maintain the data center in US also, EU also in India also. SrinivasanJ: What if I'm supporting... so, the company is in India, let's say there is a healthcare company in US, but I'm supporting from India. InfosecTrain Trainer: You will not follow the law, no? InfosecTrain Trainer: You will... so what... what the question says, where the data is collected? That's what question is saying, right? InfosecTrain Trainer: Data privacy policy where the data are collected. If you're collecting the data, you have to follow. If you're not collecting the data, you don't follow. InfosecTrain Trainer: Got it? InfosecTrain Trainer: Wherever you are collecting the data, the law applies. Suppose in the EU, InfosecTrain Trainer: you have only the back office, you don't collect any data and information, so GDPI do not apply to you. Neethu: Like, in GCC, right? In the bank, I'm working in one of the banks for Australia. So, in Australian, we have a GCC over India. So, our laws usually apply to the Australian, right? So, it depends upon that.

So, we are following that, yeah. InfosecTrain Trainer: Always remember, you have to follow law of the land. That will always take a precedence. SrinivasanJ: When it is collected. InfosecTrain Trainer: Yes, where the data is collected. SrinivasanJ: Lected. Not supported. Okay. InfosecTrain Trainer: Yeah, scope. SrinivasanJ: Thank you. InfosecTrain Trainer: Let's take... yeah. InfosecTrain Trainer: Let's go to the next topic now. InfosecTrain Trainer: the roles and responsibilities, right? So what is the... we just... we just discussed a question around it, right? What are the advantages of having a clear roles and responsibilities, right? First thing, it will... you will have a clear ownership. InfosecTrain Trainer: Each and every individual in the company, each and every person in the company, they will know exactly what they own. InfosecTrain Trainer: what a data owner have to do, what a CISO needs to do, right? What a data custodian will be doing, what is going to be the role of an account administrator, what is going to be the role of a database administrator, right? Each and every role will know their roles and responsibilities, right? That is the first benefit. Second thing, you will have a responsibility matters. So, in your organization also. InfosecTrain Trainer: You might be defining the racy charts. InfosecTrain Trainer: who is responsible, who is accountable, who will be consulted, and who will be informed, right? That's... you... that's... in each and every activity, you will create this chart so that person know what they are accountable for, what they are responsible for, right? Where they'll be consulted, and which all information you will inform, right? InfosecTrain Trainer: Then, accountability framework.

InfosecTrain Trainer: There should be a distinct InfosecTrain Trainer: responsibilities and accountability fixed for each and every person. Like, if I ask you, who is accountable for the, for the data InfosecTrain Trainer: data is having the adequate sensitivity labels applied and the protected. Who's responsible for... who's accountable for that? InfosecTrain Trainer: If there is a data, there is a Word document. InfosecTrain Trainer: which sensitivity label should get applied, and it's, having an adequate protection as per the organization policy? Who... which role will be accountable for that? SrinivasanJ: Beautiful. InfosecTrain Trainer: Why is CISO? Data owner. Johnny Souriar: That they don't... InfosecTrain Trainer: It's going to be data owner, right? The one who owns the data, it's... he's accountable, right? InfosecTrain Trainer: How come CISO will be take accountability for the millions number of records which are being, kept all across organization? He cannot, right? Always there is going to be a data owner who is ultimately... who is accountable for the data. InfosecTrain Trainer: Right? InfosecTrain Trainer: So that's how you create an accountability framework, right? And then authority delegation. InfosecTrain Trainer: sometimes everything CISO cannot do, right? In your organization, also, does CISO need... we know that CISO is accountable for creating the security strategy and the policies, but in your company, does CISO go and write the policy? No, right? He might have delegated it to some other person, right, in the organization, those who might be creating those policies and things on behalf of him, and then taking his approval. InfosecTrain Trainer: So, authority delegation, also the roles and responsibilities help you designate.

So, these are the four main InfosecTrain Trainer: Advantages of having a clear roles and responsibility. InfosecTrain Trainer: Now, this is a example, yeah. Sandeep Saxena: So we discussed that board of directors are responsible for a security incident, right? Sandeep Saxena: If it happens. InfosecTrain Trainer: They are ultimately accountable. Sandeep Saxena: Huh? Oh, there you go. InfosecTrain Trainer: ultimate accountability. Sandeep Saxena: They're responsible or accountable? InfosecTrain Trainer: accountable. They are ultimately accountable for the security failure in the organization. They are not responsible. InfosecTrain Trainer: Responsible would be a CISO. InfosecTrain Trainer: Or a person, or a business owner in... InfosecTrain Trainer: Which business the security incident occurs. InfosecTrain Trainer: CISO has applied defined, clear controls, he have created the accountability matrix, he have told all the business heads in the organization what other things need to be implemented, but if they are not implementing it, they are bypassing something, then... so does the CISO will take responsibility for everything? No. InfosecTrain Trainer: It's the local business owner and all, they are the one, they'll take responsibility. But ultimate accountability always sits with the CEO. So, have you ever seen, like, this XYZ organization suffered a cyber attack because InfosecTrain Trainer: the employee named Ramesh clicked on a phishing link. Have you seen such kind of news in the... in the newspaper? You will never see such kind of news, right? Sandeep Saxena: You really... InfosecTrain Trainer: always see a statement coming out from the CEO or the senior management, because they are ultimately accountable. Sandeep Saxena: I'm getting confused between the terms responsible.

For example, I'm a manager. I asked my engineer to go block an IP, okay? Sandeep Saxena: the engineer is accountable, and I am responsible for attack neutralization. Is this correct? InfosecTrain Trainer: How come engineer is accountable? He's responsible, you are accountable. Always the senior person who heads the function, he's going to be accountable. The person who is implementing, they are always going to be responsible. Sandeep Saxena: Right, that's what I was asking. So... InfosecTrain Trainer: Yes. InfosecTrain Trainer: So, like, data owners, data owners. Sandeep Saxena: Hmm. InfosecTrain Trainer: If you see, the data owners are always the senior people. InfosecTrain Trainer: Right? They are always the senior people. Thus, they will do everything at their own. That's why they have the data custodians, like a normal individual contributor, all the people, those who are handling the data on their behalf. InfosecTrain Trainer: The data custodian, they have delegated, okay, you know organization policy as per that, you apply the sensitivity labels, you apply all the controls, you make sure, but tomorrow, if there is a data breach, there is a failure, the who is accountable? Always the data owner, because he has delegated something to them. InfosecTrain Trainer: But ultimate accountability sits with him. You have to take... InfosecTrain Trainer: The ownership of that thing. InfosecTrain Trainer: Understood? Sandeep Saxena: Yes, right, right, right. InfosecTrain Trainer: So, this is, just an example RACI matrix, right? InfosecTrain Trainer: So, to make you understand how the RACI is defined, right? InfosecTrain Trainer: So, if you see, strategy, Who is accountable for creating the security strategy? CISO. InfosecTrain Trainer: Right? Board and executives would be informed.

InfosecTrain Trainer: what security strategy you are creating, what are the changes you are introducing. Director, IT director would be consulted, because they will be providing some inputs. Security team would be responsible, because InfosecTrain Trainer: CISO himself won't be creating the strategy, right? He won't be going and writing those strategies at his own, right? Some security team would be helping him creating the draft and creating the record, right? And business unit and data owner would be informed about it. So this is just an example. If I talk about the risk assessment, so risk assessment, CISO would be accountable, IT director would be consulted, and you can see. InfosecTrain Trainer: If you see about a data classification. InfosecTrain Trainer: CISO is consulted, because he'll be creating the data classification policies and controls and all, but accountable would be the business units, and data owner would be responsible. InfosecTrain Trainer: Got it? InfosecTrain Trainer: This is just an example. InfosecTrain Trainer: No? Pudir: small services that I mentioned. InfosecTrain Trainer: Yeah. Pudir: I have smiled out regarding the... Pudir: Classification of posts, CISO, Information Security Manager, both are same, and any differentiation is there between the posts. InfosecTrain Trainer: So, in the CISM, wherever you see reference as a security manager, it's referred as a CISO only. InfosecTrain Trainer: So sometimes in the exam, they will distinctly call out CISO, sometimes they'll refer at a security manager. So wherever you see security manager, security manager, don't just compare with your organization, where there are multiple security managers reporting to the CISO.

Consider security manager means someone who is handling the security in the organization, correct? InfosecTrain Trainer: And wherever question talk about... suppose they're talking about security manager, and they're talking about the incident management. So this... there, it's getting referenced to the one who heads the incident management. InfosecTrain Trainer: function. InfosecTrain Trainer: that security manager. So we will... that's why each and every chapter has a distinct topic around the responsibilities of a security manager. InfosecTrain Trainer: So, each domain have that particular topic, one slide, each domain. So, we'll discuss what are the responsibilities of a security manager in the governance, what are the responsibility in the risk management, what are the responsibility in the program management, and what are the responsibility in incident management, so that you will get clear exactly what they need to do. InfosecTrain Trainer: Got it? InfosecTrain Trainer: Yeah. InfosecTrain Trainer: Now, understanding the roles, right? InfosecTrain Trainer: So, from information security perspective, if you see, so the board of directors, as I discussed, are the ultimately accountable. So, what does board do? Board will define the vision InfosecTrain Trainer: And mission for the company. InfosecTrain Trainer: But board actually work... work like a democratic organization. There would be 10 to 15 people in the board. Even the CEO would have the... is going to be the one of the member of the board. InfosecTrain Trainer: Right? So, board of director, what they do? InfosecTrain Trainer: They actually vote.

InfosecTrain Trainer: If, suppose, there is a decision where both say, okay, we need to acquire this XYZ organization, we need to... we'll be purchasing this organization is \$2 billion deal. InfosecTrain Trainer: Can CEO alone take that decision? He cannot. He'll take the decision to the board, there is going to be 10-15 members, they all will vote InfosecTrain Trainer: If the majority agrees with this decision, then they go ahead with that, because they... there are going to be a lot of discussions, they will also think about what are the consequences, what are the issues, and all, and then they will take the action accordingly, right? InfosecTrain Trainer: So this is the responsibility of the board. Any decision, anything with respect to the security, anything, they are ultimately accountable. They are the one, those who define the vision and mission. InfosecTrain Trainer: Now, coming to the senior management, so wherever the senior management is referenced to, it is basically the C-level executive, CEO, InfosecTrain Trainer: C-O-O-C-F-O. InfosecTrain Trainer: nowhere in the organization... actually, CISO is considered as a senior management. He will be always a level below to them, right? So he would be reporting someone from the senior management.

InfosecTrain Trainer: So the senior management is the one, those who drive the organization in their respective domains, right? So the senior management is the one, those who actually create an org strategy. InfosecTrain Trainer: Now... Under senior management, before you go to steering committee, there is one more group, which is called the InfosecTrain Trainer: Strategy Committee. InfosecTrain Trainer: What does strategy committee do? Strategy committee is something which actually includes the people from the senior management.

InfosecTrain Trainer: Also, they will have some other subject matter expert. InfosecTrain Trainer: Business owners and other people would be part of it, because once... when you are creating the strategy for the organization, you will require the input from a couple of people, right? InfosecTrain Trainer: So that is the purpose of strategy committee, to create the strategy, which is a temporary body. InfosecTrain Trainer: It's not a permanent role or permanent body, it's a temporary body. Whenever the strategy is being discussed or being created or revised, you will form a strategy community, they will work together to create a strategy. InfosecTrain Trainer: Now, coming to the steering committee, steering committee is a... actually a body, which is a temporary group, like, same, like, strategy committee, but InfosecTrain Trainer: they have a more responsibility toward the security. So, any new security initiatives, any funding, any budget approval, anything, the steering committee will do. But, so, who are going to be in the steering committee? Or the security? CISO would be there. InfosecTrain Trainer: Sponsor would be there. Who is the sponsor? Suppose CISO report to CFO. InfosecTrain Trainer: So, CFO becomes the sponsor. If CISO report to CEO, he becomes the sponsor. If the CISO report to CEO, he becomes the sponsor of that, right? So, one senior management person, and then you will also have the business owners, subject matter expert, people from the legal team. InfosecTrain Trainer: Right? People from the HR departments, all the people, those who are... who are actually subject matter experts and their inputs are needed, those people will form the steering committee. Now, let's take an example and understand. Suppose organization is adopting the AI.

InfosecTrain Trainer: now you are onboarding the AI-related tools, technologies, capabilities in the organization, right? InfosecTrain Trainer: will you just directly onboard the AI on the basis of, if you have, suppose, designated a budget. InfosecTrain Trainer: to the department, they'll continue to onboard? No. InfosecTrain Trainer: You will form a steering committee who will... InfosecTrain Trainer: I do the valuation of this particular AI, this shows the better culture. I'm talking about the better culture. I'm not sure what is happening in your organization. So if there is a steering committee who will see the value? What is the value proposition? InfosecTrain Trainer: what kind of the value that AI brings, how much is the investment we are doing, right? What is going to be the return on investment which we will get? InfosecTrain Trainer: Have we checked the AI on the parameter of the security in case of the compliance, legal, all those people would be there? Then they will decide, okay, this AI is a good thing to onboard, and they'll give go-ahead, and then you onboard. InfosecTrain Trainer: So that's... is the... one of the examples of steering committee. Now, chief information security officer is the one who is the accountable for leading the security program. He is the one who drives the information security program. He is accountable for creating the security strategy and security policy. InfosecTrain Trainer: And he reports to the senior management. InfosecTrain Trainer: Now, what is the business process owner? Anyone here who is from the big four? InfosecTrain Trainer: engineers who have worked in a Big Four. InfosecTrain Trainer: Have you heard about the partners in Big Four? InfosecTrain Trainer: partner concept.

Johny Souriar: Yes, yes, this is particular head then. InfosecTrain Trainer: Yes, so those partners... R... InfosecTrain Trainer: equivalent to business process owner. What those partner do? Those partners lead one particular line of business, right? Suppose there is a partner for the... InfosecTrain Trainer: PIN audit. InfosecTrain Trainer: department. So, all the finance-related, audit-related things will sit under here. InfosecTrain Trainer: Similarly, in all the organizations, you will find similar kind of business process owner. Those who lead one particular function, like head of marketing, head of operations, head of legal, head of compliance, they are all the business process owner. They own one particular business function. InfosecTrain Trainer: And workforce are rest all the employees, they sit in the workforce. InfosecTrain Trainer: So this is how the role structure looks like in the organization, and it's very important to have a clear understanding around these roles, because you will get a couple of questions in the exam, and a lot of people get confused. What this role do, what that role do? InfosecTrain Trainer: So it's very important to understand what is the clear demarcation, and what that role is responsible for. InfosecTrain Trainer: So now, here in the slide, you can see we discussed at a high level what are the road. Now you can see what these roles exactly do. InfosecTrain Trainer: So, the CISO... CISO is a strategic leadership. InfosecTrain Trainer: Right? Who owns the overall security strategy and the program. He reports to the security posture and the risk to the board of director and the CEO. He sets the risk appetite in align with the business InfosecTrain Trainer: And he is accountable for the governance, not for the business risk.

InfosecTrain Trainer: So, business risk would be owned by the business owner, not by the CISO. InfosecTrain Trainer: Then, Information Security Manager, so here you can see CISO is a distinct role, Information Security Manager is a distinct role. So, Information Security Manager is the one who actually handle one particular security area, right? Like the manager of SOC, InfosecTrain Trainer: Manager of IAM team, manager of, manager of probably the GRC. InfosecTrain Trainer: Manager of AppSec. InfosecTrain Trainer: you will find such a role in the organization, right? It's talking about that. Who would lead the operation in that particular area, right? So he'd translate the CISO strategy into daily operations. InfosecTrain Trainer: Whatever strategies CISM has created, he'll make sure those policies and strategies being adopted within that function. He supervise and directs the security team, he manages the security tool, vendor processes, and everything, and first escalation fraud. If there is a security incident, it will always come to him, and then he'll take care of it. InfosecTrain Trainer: And what is the business process owner? Business process owners are the one, they accept the risk with respect to their business. InfosecTrain Trainer: How? Let me take an example. Suppose there is... one particular business process owner is the one who is head of InfosecTrain Trainer: application, development. InfosecTrain Trainer: He is the one who had the application development. Now, there... there is one particular production server. InfosecTrain Trainer: In this particular production server, they are using these production servers to deploy, run the application, and put it into, into the prod, right? Publish InfosecTrain Trainer: the result.

Now, there is a... there is one vulnerability which security team identifies. He notified the business owner. Business owner InfosecTrain Trainer: Tested the vulnerability non-prod environment and saw if InfosecTrain Trainer: this particular thing will get patched, will actually cause an issue in the prod environment, because currently there are some related processes which are not aligned to that. He told, okay, we'll require one month, he'll talk to the InfosecTrain Trainer: to the... to the development team. Development team says, okay, we'll require one month to align those processes, and then we can fix that vulnerability. InfosecTrain Trainer: Who will accept this risk? InfosecTrain Trainer: Will the CISO accept this risk? No. The risk would be accepted by the business owner, the one who is head of application development. He'll accept the risk, he'll say, okay, let's have a compensating control around this particular fraud environment, so that till the time the issue is being remediated. InfosecTrain Trainer: we are... actually, the risk is acceptable. So, who is accepting the risk? Business process owner in their business, right? He accepts the residual risk in their business area. InfosecTrain Trainer: Whatever is left over, he have to accept. InfosecTrain Trainer: He is the one who defined the security requirement for the business processes, because he understands the business process very well. He will tell the CISO and the security team what are the security controls, what are the security requirements his business need. InfosecTrain Trainer: He will validate the controls, for the business are appropriate, and he will fund the security controls within their budget.

InfosecTrain Trainer: Now, coming to the data owner, data owner is someone who is the... accountable for the information. InfosecTrain Trainer: He's the one who classifies the data by sensitivity and the business value. InfosecTrain Trainer: Right? He will decide who may access data and under what conditions the data he'll... the people will access. He will set the protection requirement for the assets, and accountable for delegating tasks to the custodian, not accountability. Someone asked... was asking the question, right? You cannot delegate the accountability to someone. You can only InfosecTrain Trainer: Delegate the responsibilities to someone. InfosecTrain Trainer: Now, practitioner, practitioner are other security roles, like SOC 11 analyst, someone who is a database engineer, someone who is the information security engineer, someone who is a security architect, they are all the practitioners. InfosecTrain Trainer: Who implement and operate the security control? InfosecTrain Trainer: They perform the threat monitoring and the log analysis, they execute the incident response procedures and reports to the IES manager, information security manager. InfosecTrain Trainer: And he... who is the technical doer role? InfosecTrain Trainer: So the CISO, if you see from the exam perspective, CISO is the one who is accountable for the overall security program, business owner is accountable for the business risk, and the data owner is accountable for the data protection. InfosecTrain Trainer: understand this. If you know this particular line, you will be able to get a most number of questions correct. If you know the clear distinction between these roles, what are their responsibilities. InfosecTrain Trainer: It becomes easy for you to answer the questions in the exam.

InfosecTrain Trainer: Now, coming to the detailed responsibility of each InfosecTrain Trainer: Role, which we discussed. Board of Directors. What does a board of directors do? They are a... they have a fiduciary responsibility. What does the word fiduciary mean? InfosecTrain Trainer: Fiduciary means someone who is

the legal liability towards something. InfosecTrain Trainer: If you go ahead, post some objectionable content over the social media, who has the fiduciary responsibility towards that? InfosecTrain Trainer: You are the... are the meta as a platform. InfosecTrain Trainer: you posted some objectionable content in a meta, in, in... probably you posted it in the, in the Instagram, right? InfosecTrain Trainer: So who has the fiduciary responsibility, legal responsibility? You or the meta? Fatha: We agree. Neethu: V. InfosecTrain Trainer: Correct. InfosecTrain Trainer: Similarly, in the organization, the board of directors, they are the legally responsible. We just discussed, right, questions around this, right? So they have a legal duty to provide reasonable security oversight. They have to make sure there is information security InfosecTrain Trainer: is in place, it has the appropriate amount of budget, funding, all the things are being done. They need to make sure that they are continuously monitoring the KPIs, key KPI KGIs and KRIs. InfosecTrain Trainer: To understand that. InfosecTrain Trainer: Then, they have a responsibility toward risk governance. They need to ensure that there is appropriate risk management framework within the organization. They will define the risk appetite for the organization. InfosecTrain Trainer: How much risk is acceptable? How much risk is not?

InfosecTrain Trainer: Probably, let's... discuss, because I have... InfosecTrain Trainer: Mentioned this word a lot of time. InfosecTrain Trainer: Risk? InfosecTrain Trainer: capacity... InfosecTrain Trainer: We will discuss this risk Tolerance. InfosecTrain Trainer: appetite. InfosecTrain Trainer: Understand about this with the example. InfosecTrain Trainer: Can someone tell, if you have an understanding, what do you mean by risk capacity, risk tolerance, and risk appetite? Pudir: His appetite, is the... Fatha: Developer. Pudir: Maximum risk that the institution can handle. InfosecTrain Trainer: Then what is the risk capacity, then? Pudir: How much the capacity it is having. InfosecTrain Trainer: Okay, and then what is the risk tolerance? Pudir: Tolerance means a particular situation, how much it can be tolerated, how the business activities can be tolerated in that particular situation. In that situation, appetite is a bigger turn, capacity is lower, and tolerance is smaller. InfosecTrain Trainer: Okay, okay. I think you... you got all of them mixed and... Confused. InfosecTrain Trainer: Alright, no problem, no problem. Let me, let me explain. InfosecTrain Trainer: Let me explain. Suppose every month, let's take an example, every month, you get a salary worth of... InfosecTrain Trainer: \$5,000. This is your monthly salary. InfosecTrain Trainer: Can you go beyond this in terms of expenditure, and can you plan anything beyond this? InfosecTrain Trainer: You cannot, right? This is what is your... Risk capacity. InfosecTrain Trainer: Same if you replace this in the organization. If an organization has an annual revenue of probably \$5 billion, can they go beyond \$5 billion and plan some initiative? They cannot. InfosecTrain Trainer: have to plan everything within that, right?

So that is the risk capacity. So, risk capacity is the maximum level of risk which organization can take. They cannot go beyond this. So, this is the risk capacity. Now, coming to the risk appetite and the tolerance. InfosecTrain Trainer: Now, from this \$5,000, what you have planned, you will say, you said, okay, \$1,000 is... goes for my household listups and everything, right? InfosecTrain Trainer: \$1,000 I have kept for the travels and everything, right? Suppose \$2,000 is something which you have kept for the investment purpose and all, right? And \$1,000 is your emergency fund. InfosecTrain Trainer: So this \$2,000, whatever \$1,000, \$1,000, \$2,000, these are all different, different projects, or different, different initiatives. Under each project, each initiative, you will have a separate risk appetite. InfosecTrain Trainer: So, appetite is defined at the business level or the project level, not at the organization level. InfosecTrain Trainer: Then, top of this risk appetite, you will always keep a risk tolerance, which is a buffer. Suppose \$2,000 is something which you have kept every month for the investment, but you saw the market is down, there is a better opportunity to invest in a share market. Let's InfosecTrain Trainer: Keep a tolerance of 500. InfosecTrain Trainer: \$500. InfosecTrain Trainer: which is your risk tolerance, right? So you can go up to \$2,500 from this emergency fund which you are keeping. From this, you will add it here, and then you will use it. So this becomes your risk tolerance. InfosecTrain Trainer: So, always the decisions on any initiative and all are taken on the basis of the risk tolerance. InfosecTrain Trainer: Because you cannot go beyond risk tolerance, which is the maximum level of risk you can take, right?

But you always try to keep things within the risk appetite. InfosecTrain Trainer: Understood, everyone. InfosecTrain Trainer: capacity, tolerance, and appetite. Now, there is one more thing which we'll continue to discuss, or this topic will come to... continue to be there. Risk, recy... InfosecTrain Trainer: dual risk, And... inherit risk. InfosecTrain Trainer: What is residual risk, and what is the inherent risk? subaveena pugalenthi: Inherent risk is, all the risks subaveena pugalenthi: In the organization without applying any compensating controls. subaveena pugalenthi: But residual risk is, after applying all the compensating controls, what is the remaining risk that you have got? InfosecTrain Trainer: Correct. InfosecTrain Trainer: Let's take a very simple example. InfosecTrain Trainer: So, I think a lot of people here are from India, so in India, we love having the tea, right? We love drinking the tea, right? Suppose you are preparing a tea, so you are preparing a masala tea. InfosecTrain Trainer: So, what you put, you put that tea masala, and you put the water, milk, everything. InfosecTrain Trainer: So the tea masala is actually... is a very... InfosecTrain Trainer: They have big, big particles. Can you drink tea without this... without applying filter, and can you drink it? InfosecTrain Trainer: I think you will not like the taste, right? That... that the tea masala particles will get into your mouth, which you will not feel good, right? InfosecTrain Trainer: Something which is without controls, without anything which you won't be able to consume, is called the inherent risk. InfosecTrain Trainer: Now, you applied the filter. After applying the filter, once you InfosecTrain Trainer: put the tea in a cup.

It's still in the bottom, some very small particle will go and get settled in, but with this, you will be able to gulp the tea and enjoy the tea, right? InfosecTrain Trainer: This is the residual risk. Still, there are particles, something is left, you cannot 100% eliminate it. InfosecTrain Trainer: something is there, but you can enjoy your tea with these residue particles, which are there in the bottom, so you are ready to accept. Similarly, in the organization, whenever you do the risk assessment, you first calculate the inherent risk. InfosecTrain Trainer: After that, you encounter... you account for what are the existing controls which we have in the organization. InfosecTrain Trainer: Because something would be there to help you protect from that risk, right? After that, whatever is left over, that is... becomes the residual risk. InfosecTrain Trainer: which you will continue to reduce further by deploying additional number of controls with additional number of initiatives. So, I hope everyone is now clear around capacity, tolerance, appetite, inherent in the residual risk. InfosecTrain Trainer: Now... board of directors would also be providing the strategic directions, right? This sets the security priorities. InfosecTrain Trainer: They are aligned with respect to business strategies. They approve Yeah, Johnny. Johnny Souriar: Yeah, here, one more clarity I'm just asking. So, risk capacity is the overall maximum capacity an organization can take for any business. InfosecTrain Trainer: Correct. Johnny Souriar: So, my, organization risk capacity is always below that, risk capacity, right? InfosecTrain Trainer: Can you please repeat the last statement again? Johnny Souriar: Rest capitate, rescapitate would be always below the capacity always, right?

InfosecTrain Trainer: Yeah, yeah, yeah, risk appetite and risk tolerance would always be below, then, the risk capacity. Johnny Souriar: Yeah. But tolerance may up and down from the aptitude, plus or minus, maybe. InfosecTrain Trainer: Yes, yes, yes, plus minus. InfosecTrain Trainer: Alright then, comes the... Executive accountability. So, they are the ultimately accountable, right? InfosecTrain Trainer: And they will hold the CEO, CISO responsible for the security performance, any lapses, any issues which they observe, right? So these are the four primary responsibilities of the board of directors. InfosecTrain Trainer: Now, coming to the Executive Management Security Leadership. InfosecTrain Trainer: Executive management means senior management. InfosecTrain Trainer: What is their role in the security? They are the tone from the top. InfosecTrain Trainer: Whatever... whatever information board of directors want to convey, whatever things they want to implement in the organization, they are the one they are going to help InfosecTrain Trainer: It disseminates till the last person in the organization. InfosecTrain Trainer: Right? That's why an executive needs to visibly champion the security, right? They have to showcase that security is an important part of the organization. They will be attending awareness training, they will discuss the security at all hands meeting, refusing to bypass control themselves. InfosecTrain Trainer: Suppose in your organization, your senior manager himself do not attend the awareness training. Will the people, those who are reporting to that person will do so? InfosecTrain Trainer: How he'll be able to probably encourage them to do that on time.

InfosecTrain Trainer: If your senior manager himself, keep clicking on the phishing simulation, simulated phishing emails. InfosecTrain Trainer: then what kind of example he's setting, right? So that's why you have to become an example, you have to showcase that you follow all the security policies and all the directions properly. Next thing is the resource allocation. InfosecTrain Trainer: they have an adequate amount of budget resources which they allocate to the CISO so that he can run a security program, right? InfosecTrain Trainer: So, they will translate the risk appetite into the investment decisions, and underfunding, and also they will fund the security program. InfosecTrain Trainer: accordingly. InfosecTrain Trainer: If security program is not funded properly, organization is not able to deploy a good number of control, this is not the CISO's failure. It is the failure of the senior management, that they are not giving... providing the adequate amount of due diligence or adequate amount of focus to the security. InfosecTrain Trainer: They are the one, they'll approve the policy. InfosecTrain Trainer: And keep one thing in mind, any policy which is not approved. InfosecTrain Trainer: is actually cannot be enforced. Anyone here who's from the audit background Who do audits. Pudir: Yeah, I am from Madhes. InfosecTrain Trainer: So, do you... do you accept the policy which has expired? Supriya Mhatre: Whoa. InfosecTrain Trainer: No, right? Even if the policy is there, that's why it says, right, whatever the frequency organization has decided to renew their policies, you will check it. When the last the policy was renewed. InfosecTrain Trainer: is the policy is correct. So that, also, you have to make sure.

The CE management have to make sure.

And the performance measurement, they have to make sure that all the KPIs, KRIs, KGIs, they are continuously being monitored, reviewed. InfosecTrain Trainer: And they are taking the feedback from the CISO around that. InfosecTrain Trainer: Now, a steering committee. InfosecTrain Trainer: Right? So the steering community, as we discussed, is a cross-functional... Team. InfosecTrain Trainer: Right? InfosecTrain Trainer: This is a cross-functional team. This is not only the people from the security who would be there in the steering committee, it's a cross-functional team. People from security, people from InfosecTrain Trainer: People from... InfosecTrain Trainer: Senior management, people from subject matter experts from other departments are going to be there as part of that. InfosecTrain Trainer: Right? So the steering community... Also, one thing... Keep note, A point, pointer. InfosecTrain Trainer: If all the security initiatives and the projects are being discussed and approved by the steering committee, it shows a good culture in the organization. InfosecTrain Trainer: Make note of it. Any question in the exam, if you see something like this. InfosecTrain Trainer: you can decide and answer accordingly, right? This is a statement. So the cross-functional collaboration, they bring together the stakeholders from IT, security, business unit, legal, HR, risk, finance, all people would be there. InfosecTrain Trainer: And they will make sure that all the security decisions are taken as per the business priorities, not only on the basis of technical references. They will prevent the security silos problem, so that security is not happening in the silo alone. InfosecTrain Trainer: It's get... it's integrated throughout the organization. They will also do the priority setting.

InfosecTrain Trainer: Right? If, suppose, there are 3, 4 projects which come to the Security Steering Committee, they will see how much budget we have. Accordingly, they will approve or reject those which actually are the very important for the organization. InfosecTrain Trainer: they will do the issue resolutions. If there are any issues which are getting arise due to audit finding, due to any project, any initiatives, there are any funding-related issues, there are legal and compliance-related issues, those issues they will help resolve, and they will continue to monitor the progress around all the projects which are being run within the security. InfosecTrain Trainer: And they will monitor all the important KPIs, KRIs, and the remediation deadlines which I've set. InfosecTrain Trainer: And key... subaveena pugalthi: Do you have a steering committee under CISO or above CISO? InfosecTrain Trainer: They are not under or above CISO, they are a separate body altogether. So, CISO is also part of that. InfosecTrain Trainer: And, as I told you, the sponsor would be there from the senior management, right? So if there is a sponsor from the senior management, who is going to be ultimately taking the decision on rejecting or approving? Not CISO, that person, who is there the sponsor, right? InfosecTrain Trainer: So, it is not under CISO. It's basically above CISO, or CISO would be also part of it. InfosecTrain Trainer: Understood, Supra? subaveena pugalthi: Yeah, thank you. InfosecTrain Trainer: Now, how the structure of the steering committee looks like. InfosecTrain Trainer: Right?

InfosecTrain Trainer: So, if you see the membership composition, you will have the InfosecTrain Trainer: people from the IT, probably your CIO, CTO would be there, or the director of IT would be there, then people from the information security, all business, important business unit, legal compliance, risk management department, your HR team, your auditor regulators, all the important people, those who needed to be there, their decision making. InfosecTrain Trainer: They'll form this composition. InfosecTrain Trainer: Then you will also then decide the meeting frequency, because they need to meet at a regular interval of time, or InfosecTrain Trainer: As defined by the organization, whenever the important decisions are taken, or they can have a regular meeting, probably once in a week, or once in 15 days, which they can define those schedules, and then they will monitor. InfosecTrain Trainer: What is MRM? Shivaganeshan S: Management review meetings, don't... you're telling that. Shivaganeshan S: Okay. InfosecTrain Trainer: Okay. InfosecTrain Trainer: And then, decision authority. InfosecTrain Trainer: So, once the meeting is there, then they will create a matrix how the decision would be taken in that particular situation, how they will decide that is this decision is a go or no go. Should we invest, should we not? InfosecTrain Trainer: That decision authority they will have, and then they will also do the documenting. InfosecTrain Trainer: Whatever decisions they are taking, whatever things they are doing, at that point of time, they'll continue to monitor. InfosecTrain Trainer: So, you can see, steering committee is either chaired by the CISO or CIO, not by CEO. InfosecTrain Trainer: CEO is always a sponsor for it, they'll not share it.

InfosecTrain Trainer: But the... Madhes: I just want to clarify here. Madhes: MRMS management review meeting usually happens in case of ISO 27001 certification kind of arrangement. Madhes: Where, MRM will happen off early. Madhes: What here they're mentioning is a security steering committee, which is, you know, it's an internal committee which discusses security initiatives and also, discusses the projects of different security. Madhes: In banking industry, this is called as Information Security Committee, ISC. Madhes: In, you know, globally, maybe call it a Security Steering Committee. Madhes: Just want to clarify, because... Madhes: Someone in the group mentioned MRM. MRM is totally different. It is for the ISO 27000 certification purposes. InfosecTrain Trainer: Good, good, thank you, thank you so much for clarification. Yes, so... so the steering committee is, is actually a separate body, right? InfosecTrain Trainer: who only helps or take decision around cybersecurity, security-related initiatives, right? Not only specific purpose for some ISO certification or some certification you are taking, you're taking. InfosecTrain Trainer: Now, how the operation... operating model of the steering committee will look like? InfosecTrain Trainer: they will have an agenda management, right? Whenever they meet, they will have some couple of agenda items, what they want to do, right? They will review the security KPI KRIs, risk acceptance decision, policy approval, the major milestone of the security programs, or are they on track, any cross-functional issues, or the InfosecTrain Trainer: problems organization is facing, they will have the agenda around this.

InfosecTrain Trainer: Also, they will have a decision framework, so that InfosecTrain Trainer: whenever there is a conflict, how the decision would be taken, right? Who will be, going... giving the ultimate, decision, and they will do the risk acceptance and other things, right? How much is the risk? Is this within the limit of the organization? Accordingly, they will take the decision. And then, also, documentation. InfosecTrain Trainer: So, whenever such kind of meeting happens, they will formally document the minutes of the meeting. Also, they will notify InfosecTrain Trainer: this approval decisions to the respective, teams, those who have presented their solution or the decision to them, and they'll also have the escalation procedure. If something which is beyond their InfosecTrain Trainer: level, or probably there is an additional fund that is required, or that the risk is beyond their level, probably they will escalate it to the CEO or the senior management. InfosecTrain Trainer: Now, business process owners. So, a lot of people gets confused between the business owner versus data owners. InfosecTrain Trainer: Don't get confused. As I told you, business process owner is someone who heads the business. InfosecTrain Trainer: Right, so someone here, if you have worked in a bank, you will see there are departments in the bank, like consumer lending. InfosecTrain Trainer: commercial banking. InfosecTrain Trainer: Right? InfosecTrain Trainer: Anyone in the bank, you would have heard about such kind of departments, right? Consumer lending, the one who actually do the loans to the people, right? House loan, personal loans, and all. InfosecTrain Trainer: Then there is a commercial banking who actually finance all the, and there is a commercial lending.

InfosecTrain Trainer: the one who financed all the, all the startups or big organizations they do, right? So, all the people, those who head these InfosecTrain Trainer: They are those business process owners. Like, I gave the example of partner. Similarly, one who heads these business verticals, they becomes the business process owners. So what is their security responsibility? They are the one ultimately accepting the risk. InfosecTrain Trainer: Right? So you set a RPO and RTO. InfosecTrain Trainer: What is RPO and RDO? Anyone here can explain, if you've heard about this? SrinivasanJ: Every time objective and point objective. InfosecTrain Trainer: Yeah, but, but what does... actually, it means? SrinivasanJ: Point is, the data loss. It's about data loss. How much data we are losing, like, our point in time we restore. Time is the time we take to restore, SrinivasanJ: the business in the DR side. InfosecTrain Trainer: Correct. InfosecTrain Trainer: So, the recovery point objective is... is actually, suppose you have a 2-hour backup frequency, right? InfosecTrain Trainer: So, 9 AM you took a backup, 11, you took another backup. 1, again, you took a backup, 3 again, you took a backup. So, in your organization, if RPO is 2R, it means you are willing to lose the data worth 2R. Means, suppose there is a... InfosecTrain Trainer: The outage or problems happened at this point of time. InfosecTrain Trainer: before the backup of the 11 was taken, which data you will use. You will use the 9AM data. So whatever data which has been processed between 9AM to this time is lost. InfosecTrain Trainer: So you're willing to lose that data, right? So 2R is the RPO. Now. InfosecTrain Trainer: Suppose there was a failure here at 10.59.

InfosecTrain Trainer: Now, from here onwards, you will take the backup of the 9AM. Now, you will restore the system back to the production, or the normal, right? So, probably for that activity, you need a 3R. InfosecTrain Trainer: That becomes an RTO. InfosecTrain Trainer: We will discuss these terms, but it will continue to come in between. That's why I'm just explaining you, so that you understand that what does RPO mean, what does RTO mean? InfosecTrain Trainer: So, suppose there is a business continuity planning, right? With respect to one particular business vertical, what is the RPO, what is the RTO, who will take the decision? Always the business one. InfosecTrain Trainer: He knows how much revenue the business generates, how much data he's willing to lose, so the ultimate decision he will take. InfosecTrain Trainer: Right? Then the requirement definition. InfosecTrain Trainer: whatever application, whatever

processes, all the kind of things which are being done under his particular business, he's going to be the one who will define those requirements, right? He'll be the one who will be actually notifying all those requirements, right? InfosecTrain Trainer: So... He'll also understand what are the security-related requirements within that particular process that he will do. InfosecTrain Trainer: He'll also do the control validation. InfosecTrain Trainer: all security controls which are deployed to protect the assets under his particular business. He'll make sure, he'll validate that all those controls are effective, they are working as they are supposed to. InfosecTrain Trainer: and also will play a major role during incident.

If there is a cyber incident impacting his particular business, so he will be there contributing to the incident management team in case of the remediation, recovery, and all the process which incident management follows, he will be there, part of that. InfosecTrain Trainer: Now, data owner versus asset owners. InfosecTrain Trainer: So, there are two roles. InfosecTrain Trainer: One thing is the data owner and the asset owner, right? So that all the both roles are almost same. Data owner is something... someone who owns a data. InfosecTrain Trainer: data in terms of whatever is the digitally formed, right? The data which is stored in a server, in your databases, in your hard drives, right? He is the data owner. Asset owner is someone who owns a physical asset, like your laptop. InfosecTrain Trainer: your data center, your office building. So, always there's going to be an asset owner, right, for that. InfosecTrain Trainer: He will make sure that asset is maintained, there are appropriate controls applied to that particular asset, right? InfosecTrain Trainer: So, that is the asset owner. So, data owner is someone, or the asset owner is someone who is ultimately accountable for making sure the appropriate security classification and appropriate controls are applied to that particular asset or data which he owns. InfosecTrain Trainer: Right? InfosecTrain Trainer: So... InfosecTrain Trainer: He will do the asset classification, he will identify, classify the information asset by the sensitivity, criticality, like, categories in your organization also, you will be having public, internal, confidential, restricted, right? InfosecTrain Trainer: And classification, drives all downstream decisions.

So, in your organization also, the decision would be taken on the basis of that, right? That public information can be shared outside the organization, but internal confidential restricted should remain within the organizational boundaries. InfosecTrain Trainer: Now, the protection requirement, right, he will make sure that all the protection requirements which is defined as per the information security policies and standards, those are being adhered to. InfosecTrain Trainer: Right? If the confidential information needs to be encrypted before sending it, or the confidential data need to be kept in some secure share drive, that he'll make sure that those things are being InfosecTrain Trainer: performed. InfosecTrain Trainer: Also, access-related decision he will take. He will only be the ultimate person who will be approving access to that particular data. InfosecTrain Trainer: He can delegate that responsibility to the custodian on his behalf, but the one who's accountable. If the data access is given to some wrong person, and due to which there is a data breach, he'll be the one who will hold accountable for that. InfosecTrain Trainer: And the compliance verification. What kind of InfosecTrain Trainer: data is under his purview. Is it a PII data? Is it a PHI data? What kind of laws and regulations applies to that data? Is it a CCPA? Is it a HIPAA? Is it a GDPR? Or is it DBDPA? He'll review and he'll do that. So here, if you see in summary. InfosecTrain Trainer: data owner versus custodian, right? So, data owner... InfosecTrain Trainer: Example would be a senior management. InfosecTrain Trainer: He will classify the data, he'll decide the access rights, sets the protection requirement, and accountable.

InfosecTrain Trainer: Custodian is someone who is the IT or the technical role, who will implement the controls, runs backup, reviews the access per the owner direction. He's responsible, not accountant. InfosecTrain Trainer: Everyone clear on the responsibilities of the data owner and the asset owners? InfosecTrain Trainer: Now, data custodian, the someone who handles the data on behalf of data owner, right? InfosecTrain Trainer: who is the one... he's the one who will be doing the day-to-day execution of the security processes, technologies, as directed by the data owner. So, whatever data owner has defined. InfosecTrain Trainer: As per that definition, he will make sure that those things are being implemented, like database administrator or the system administrator. They are the data custodians. InfosecTrain Trainer: He will implement the control, right? InfosecTrain Trainer: So... InfosecTrain Trainer: So, if there is access control list, there is a DLP-related controls, there is encryption which needs to be deployed, right, or a database, if there is a database administrator who... InfosecTrain Trainer: what kind of security controls which should be there in place, he will make sure those controls are deployed and implemented. InfosecTrain Trainer: Also, he will monitor and report to the data owner, right? All the data which is... he's holding, or he's handling, he will monitor it, he will make sure that there is a surveillance, audit logs, and everything is being done, and then he'll report to the data owner. InfosecTrain Trainer: Also, he'll play a major role during incident detection and response. If there is any incident, any issues with respect to the data which he is handling, he'll make sure he's reporting those incidents to the incident management team.

InfosecTrain Trainer: So, if you see, at a nutshell, the custodian is someone who is responsible, right, who performs the task on behalf of data owner. Data owner is accountable, who owns the outcome. Owner cannot delegate the accountability to the custodian, only tasks can be delegated. If breach results from a custodian's alert. InfosecTrain Trainer: error, the data owner is accountable for the leadership, not custodian. Probably some legal action or some disciplinary action can be taken against him, but ultimate accountability sit with the data owner. InfosecTrain Trainer: Other than these roles, what we discussed, there are a couple of other roles which you will see in some organization, right? Like, chief risk officer. InfosecTrain Trainer: Anyone heard of this role? Chief Risk Officer in their organization? Someone who is probably working in a banking industry, they will always hear about the Chief Risk Officer. InfosecTrain Trainer: At all. InfosecTrain Trainer: In your organization, does this role exist? Chief Risk Officer? Madhes: Uses. Johnny Souriar: It's this. InfosecTrain Trainer: Yeah, but generally, in the product organization, you will not find, but banks, definitely, this role exists. So generally, the risk management is not limited to cybersecurity, as I told you yesterday also, right? So, there is something called the Enterprise Risk Management Program, like. InfosecTrain Trainer: CISO runs the cybersecurity program. InfosecTrain Trainer: the ERM is being run by CRO, right? So, all the time kind of risk, be it the operational risk, be it the business risk, be it the financial risk, be it the IT risk. InfosecTrain Trainer: Be it the security risk, Be it the legal risk, all the risks.

InfosecTrain Trainer: would get... go and merged into the ERM, and the ERM team, which is headed by the CRO, who is the ultimately person who will be going and reporting those risks to the board. InfosecTrain Trainer: And to the senior management. InfosecTrain Trainer: That what are the high... what are the top risks which... which are there in the organization? InfosecTrain Trainer: Then, Chief Information Officer, this is also someone who actually heads the IT department, right? Head of the IT. InfosecTrain Trainer: all the data centers, all the IT service management-related things, all the IT assets, all the IT-related things would sit under him. InfosecTrain Trainer: So, he is the one who will create the IT strategy, on the basis of which the CISO will create the security strategy. InfosecTrain Trainer: And systems and information owner, which we already discussed. So, CISM and the information owner are equivalent to the asset or the data owners, right? InfosecTrain Trainer: then there are business function managers. Other than business function owners, there are the business function manager who reports to those owners, who work under them, handle one particular InfosecTrain Trainer: process under that particular business, so they also play a major role during the incident management, during reporting, or aligning with respect to security. Information security manager, we already discussed. Also, organizations, some of the organizations, they have specific people, those who handle the awareness training. InfosecTrain Trainer: They are the subject matter expert, and they are the one, they create the training modules, impart the training to the people, so that they have an understanding around this. InfosecTrain Trainer: Right?

InfosecTrain Trainer: Let me show you one thing where you can take a screenshot of this. So, we discussed. So, senior management of a company might include the CEO, CFO, COO, and other senior executive who are responsible for the day-to-day operation and management of the company. InfosecTrain Trainer: A steering committee for a new product launch might include a representative from marketing, sales, engineering, manufacturing department, and as well as a sponsor from the senior management. A strategy committee for a non-profit organization might include a board member, senior executive, and subject matter expert in the organization's field of work. InfosecTrain Trainer: Clear. InfosecTrain Trainer: These are the definitions. InfosecTrain Trainer: If you want, you can take a screenshot of this so that you remember these particular definitions. InfosecTrain Trainer: Alright, so this is a kind of, InfosecTrain Trainer: a mind map, which I have created for all of you, you can take a screenshot of this. So this will help you revise InfosecTrain Trainer: All the roles and responsibilities in one picture, so that it will help you memorize these things, probably a day before exam, or whenever you are doing the revision. InfosecTrain Trainer: This particular slide will help you understand that what each role means, from... it defines all the roles, from board of director to the security practitioner. Shweta Sundar: Hi, this is Shweta here. Would you be able to share this as a standalone pic or something? Because I think screenshots might not lose the resolution. InfosecTrain Trainer: Okay, let's... Shweta Sundar: Is it possible to maybe include it in a slide or something? InfosecTrain Trainer: I'll... I'll post it probably here.

InfosecTrain Trainer: I've just... pasted here in the chat. You can... InfosecTrain Trainer: You can download from here, yeah. InfosecTrain Trainer: I'll just paste it, you can download from YouTube. InfosecTrain Trainer: Now, coming to the integration. InfosecTrain Trainer: How the security is integrated with overall organization, right? InfosecTrain Trainer: So, there are two kind of models which generally followed in terms of the security integration within the

enterprise, right? InfosecTrain Trainer: one thing called the separation model, another one is called the convergence model, right? Let me take an example. InfosecTrain Trainer: I hope all of you are familiar at high level what does SDLC looks like. Software Development Lifecycle. Neethu: Yep. Johnny Souriar: Yes. InfosecTrain Trainer: So you do, first, requirement gathering when you do... design, right? Then you... develop... Then you test. InfosecTrain Trainer: Then you deploy... And then finally, you retire. InfosecTrain Trainer: Right? So this is the typical SGLC life cycle, which you follow, right? So, let's take this same model and then try to explain the separation and the convergence model, right? InfosecTrain Trainer: Suppose if the organization is following a separation model, security won't be integrated within these processes. Rather than, security will run in a parallel as a distinct, independent function, like your audit team do. InfosecTrain Trainer: How does your audit team function? Audit team generally in the organization report to the senior management or the CEO, right? And they do an audit. Similarly, like this, a separation model would be there. Security won't be integrated within this. Rather than security is going to be a separate function.

Consulting InfosecTrain Trainer: the secure development, so they will be developing the policies, procedure, guidelines, and continue to keep watch InfosecTrain Trainer: on the overall process, right? So the security is working as a distinct function. There is an independent reporting line for the security. There are clear demarcation of the duties. InfosecTrain Trainer: But always, there is going to be the conflict of interest. Security is raising some observation. They may not agree, because there is a separate reporting line, right? InfosecTrain Trainer: there, but there is a better independence and get greater visibility to the leadership. Now, coming to the convergence order. I think you have heard about the dev... InfosecTrain Trainer: Sick. InfosecTrain Trainer: Ops. InfosecTrain Trainer: Earlier, there was something called the DevOps, which was there, right? Where whenever a product or the software is being developed. InfosecTrain Trainer: how it gets deployed to the production, there is a DevOps pipeline which is there in place, right? So rather than security doing an independent review, you integrate the security within the process. InfosecTrain Trainer: So, at each stage, there are security people or security persons sitting within the software team itself. So, the testing tester person, the one who is doing the testing, he is a security expert, there is an independent application security expert within the development team, who is guiding InfosecTrain Trainer: the developer, if the code is developed securely, the code is following all the organization principle and the practices.

If InfosecTrain Trainer: If, before the... during the designing also, there is going to be the person from the security evaluating the design, understanding all the threat modeling has been carried out. InfosecTrain Trainer: all the design and the flaws-related issues has been taken care of, that's how the convergence model works. Where security is integrated within the process itself. InfosecTrain Trainer: And there is going to be the shared responsibilities. So, some responsibilities that security team will share. InfosecTrain Trainer: some IT will share. So here, the security person who is sitting within the team, he will look after this, but there is going to be one more independent security team also, those who will be creating the policies, the strategies, and all, which this person will follow and enforce. InfosecTrain Trainer: So, embedded security resources within the team. InfosecTrain Trainer: There are potential for the enhanced collaboration. InfosecTrain Trainer: Between them, right? And risk for the subordinated priorities. InfosecTrain Trainer: And there is a streamlined resource allocation here. InfosecTrain Trainer: So this is the separation model and convergence model. None of these models are good or bad, it all depends on the situation or the organization need, which particular model they want to adopt. InfosecTrain Trainer: Right? That you have to keep in mind. InfosecTrain Trainer: Now, what are the key attributes for a successful organization structure? InfosecTrain Trainer: Right? We discussed about the separation model, convergence model, right? How you will choose that.

InfosecTrain Trainer: And how you will decide that your organization should be there in a central security function, distributed security function, or should follow a hybrid approach, right? InfosecTrain Trainer: So, whatever approach your organization is following, they should make sure there are 7 InfosecTrain Trainer: success criteria for that. Always, it should be the formally established and approved. InfosecTrain Trainer: It should be explicitly documented and approved by the executive leadership. InfosecTrain Trainer: Right? InfosecTrain Trainer: It should not have been that something CISO has created at his own and he's driving, right? There should be the operating principle, clearly articulated guiding principle that should align with respect to the enterprise values and the risk appetite. InfosecTrain Trainer: how that operating principle will look like, how things will happen, that should be the clearly defined. Also, there should be the authority definition. Who is doing what? Who is... InfosecTrain Trainer: doing what roles. There should be clear RACI metrics, which should be clearly documented and defined. There should be a delegation framework. InfosecTrain Trainer: What level the delegation will happen, which all things can be delegated to the lower level, and... InfosecTrain Trainer: After that, who will do what? InfosecTrain Trainer: Also, there should be the escalation procedure. If something goes bad, if something goes beyond the control of the people. InfosecTrain Trainer: whom they will escalate the things to. Till which level, till which situation, which condition they'll escalate to. InfosecTrain Trainer: That also should be well-defined.

There should be clear channel for the communication, so that in case of any formal information... in case of any issues, any things, there should be a formal and informal channel which should help them to communicate, and the performance evaluation. InfosecTrain Trainer: There should be clear mattresses, clear KPIs, KRIs, and all things should be defined so that you can measure the performance of overall organization structure if it is actually operating effectively or not. InfosecTrain Trainer: Now, what are the key security program components? Probably, let's take a break, and probably after the break, we can resume from here, okay? InfosecTrain Trainer: Yeah, someone has any question? InfosecTrain Trainer: Alright, then let's take a break. Neethu: Hello? Neethu: One for customers. InfosecTrain Trainer: I'm so sorry. InfosecTrain Trainer: Yeah, actually, the... you know, due to this Mythos class, Microsoft is releasing so many updates every day. InfosecTrain Trainer: So my system, by force, got restarted, yeah. Let me quickly share my screen. InfosecTrain Trainer: Yes. I hope my screen is visible. Neethu: Yes. InfosecTrain Trainer: Yeah, sure. InfosecTrain Trainer: Alright, then let's get started, so... InfosecTrain Trainer: So, we were, before this, we were talking about the key attributes of successful organization, right? Now, understand what are the key components of the program. InfosecTrain Trainer: So, let me tell you one more thing. The domain one covers a small, small part, or small, small topics, from each other domains. So, you will see InfosecTrain Trainer: topics from the domain 2, Domain 3, and Domain 4 also being discussed at a very brief level at this domain, right?

So, similarly, the Domain 3 is about the information security program, so at a brief level, it's being discussed, right? So. InfosecTrain Trainer: So, there are 3 main components, or 3 main themes within a security program. One is the business resilience. So, as part of the resilience, you will create the business continuity planning, disaster recovery planning, right? You will have a InfosecTrain Trainer: Crisis Management Plan. InfosecTrain Trainer: Can someone tell me the difference between the business continuity plan and disaster recovery plan? SrinivasanJ: Business card. Pudir: Several... SrinivasanJ: E. subaveena pugalenithi: Sorry, please. SrinivasanJ: PR is just restoring the service, and business continuity is to make sure that the end user is able to access, so it's a complete call tree involved. subaveena pugalenithi: I think business continuity is irrespective of you handling an incident, the business still operates its core functions. So the business is still continued, and users are able to be accessed subaveena pugalenithi: And disaster recovery is... Recovering from an incident without having the need to have a business continuity in place. InfosecTrain Trainer: So, business continuity plan is a plan which actually covers your entire organization. InfosecTrain Trainer: And disaster recovery plan is a subset of business continuity plan. So, business continuity plan talks about the overall recovery of a complete business, which has a small part of recovering your data, recovering your technology tech stack. InfosecTrain Trainer: So your technology tech stack sits in your data centers, right? So how the data center recovery will take place, that DRP will ensure.

But other aspects of the business recovery, continuity, because business continuity also talks about the people, processes, as well as your workspace where you operate, all those things will cover as part of the BCP, and DRP will support it, right? InfosecTrain Trainer: So these all plan are part of the business resilience. InfosecTrain Trainer: Now, program will also include the security operations, like day-to-day InfosecTrain Trainer: activities which you do to handle the security operations, like threat monitoring, vulnerability management, incident response, all other activities which you do, right? Then security audit. InfosecTrain Trainer: So the audit is actually... it's basically independent assessment of control, like control testing, compliance verification, any gap analysis. That is part of the security audit as a function. So these are some of the key components within the security program. InfosecTrain Trainer: Whenever we refer to the overall security program. InfosecTrain Trainer: Now, what are the responsibility in terms of the monitoring? InfosecTrain Trainer: Right? So whenever you monitor your program performance or your overall information security program, right, what you do, you first do control and audit. InfosecTrain Trainer: So, every organization has a separate control and audit department, right, who has some ITGC InfosecTrain Trainer: and other kind of security control. They continue to collect the feedback, monitor those controls, they audit. InfosecTrain Trainer: the evidence and understand if the control is operating frequently, effectively. So this particular control and audit ensures that the control are operating as they are supposed to.

InfosecTrain Trainer: Apart from this, you will also have a regular mattress... mattresses and the reporting. InfosecTrain Trainer: So you will track, communicate your security performance in form of KPI, KRIs, and KGIs. InfosecTrain Trainer: What is the difference between the KPI, KRI, and KGI?

InfosecTrain Trainer: We have a very detailed topic in Domain 3, where I will cover how to create KPI, how to create KJI or KRI, but at high level, you should understand, because we will be referencing this at multiple times. InfosecTrain Trainer: Yeah. What is KPI? What is KRI, KJI? Any... with any example. Johnny Souriar: API is the performance indicator, how well you are performing. Johnny Souriar: KRI is the key risk indicator, so what are the potential risks? Is there any flag? Is there? Johnny Souriar: of risk indications. Johnny Souriar: AGI is the key goal indicator, means business objective or a security objective are achieved or not, how much you are achieved. InfosecTrain Trainer: Correct. So, number... Total number of... Employee... InfosecTrain Trainer: attended the awareness training. What is this? It is KPI, KRI, or KGI? Johnny Souriar: Scan it. InfosecTrain Trainer: How come this is KRI? Total number of employees who have attended the security awareness training? What is the risk here? Pudir: Indeed. Ashwin: Dude. Pudir: This is a KP... InfosecTrain Trainer: KPI, right? No, this is the KPI. This is the KPI, because this tells you the performance of awareness training as a function. So, awareness training process, you will understand, okay, how many people we have, the thousand employees, out of which 800 attended, it means 80%. InfosecTrain Trainer: Effective. InfosecTrain Trainer: Now, what is the risk?

Now, after the training, you launched a phishing simulation exercise, now you track the result. How many number of people clicked on phishing link? What is this now? Johnny Souriar: I have... InfosecTrain Trainer: This is KRI. InfosecTrain Trainer: Yes, Johnny. Johnny Souriar: See, number of employees, completed the training is a KRI, because Johnny Souriar: Awareness training is, as per your policy. How many awareness training has to be conducted is a KPI. If you've done 2 times, or 3 times, or 4 times in a year. That is your performance. Johnny Souriar: But how many people are completed is a KRI. If nobody's attended, then it is a highly risk to the organization. If 100% is attained, your risk is going down. Johnny Souriar: So that way, we can... InfosecTrain Trainer: How come there is a risk if people are, less... Johnny Souriar: that people are not aware, so it is a high risk for them, boy, because awareness is not there. People are not attended. Johnny Souriar: You initiated a tour awareness training program during a year, but nobody attended. So your KPI, you achieved, but your KRI is not achieved. InfosecTrain Trainer: So, KRI is basically which highlights a risk within the process, right? So, this particular matrix, number of people attending the training, do not highlight any risk. InfosecTrain Trainer: The risk would be there if people do not understand that training. Whatever training you have provided, if people are not able to understand that particular training, they are still clicking on the phishing link, they are still not able to report the incident, that becomes risk for the organization. InfosecTrain Trainer: Right?

So that's why this is the KPI, and the KRI is how many people did not understand the training, and they are clicking on the phishing link, because this is highlighting the risk. InfosecTrain Trainer: Understood. InfosecTrain Trainer: I hope it's clear, Johnny. Johnny Souriar: No, I'm not... I'm not agreeing to that concept. I don't know, definitely me speaking. Johnny Souriar: We'll see later in the Chapter 3, then. InfosecTrain Trainer: Yeah, sure, sure. InfosecTrain Trainer: Now... InfosecTrain Trainer: Now, there is other responsibilities, like work measurement, right? You will also assess that how the security teams are performing their duties, how is their output. So, someone who is from the incident management team, they... you would have seen the matters, like mean time to detect InfosecTrain Trainer: Mean time to report. InfosecTrain Trainer: This is a kind of a work measurement matrix, which tells you that how effectively that particular process or that controls are working, right? InfosecTrain Trainer: Then you will also do the performance evaluation. You will review the individual performance, you have the annual feedback, annual reviews, how many tickets they are able to result, how quickly they are able to understand and respond to an incident. So, that is a InfosecTrain Trainer: And then you will establish a 360-degree feedback, where you will collect the feedback from the business, other stakeholders, other business partners, right? And then you do a position benchmarking. So, whenever you have the security-related, InfosecTrain Trainer: Positions, you will always benchmark them with respect to the industry peers, so that you have the most effective number of roles within your organization.

InfosecTrain Trainer: Now, coming to the security governance implementation, right? InfosecTrain Trainer: So this is a very important topic. Let me explain you this, because this will be coming on and off multiple times, right? Suppose InfosecTrain Trainer: you are hired as a CISO for a newly established startup. InfosecTrain Trainer: So, startup is there, but now a startup has grown, so they think that there should be an independent CISO who should be onboarded and hired. When you went in the organization, you saw that things are happening in a very fragmented manner. How you will go ahead and establish the security governance? What is going to be your first step? InfosecTrain Trainer: Can someone tell me? What is going to be a first step? InfosecTrain Trainer: in this... Pudir: Understanding the environment. Ashwin: Assessment. subaveena pugaltheni: I think understanding the business objectives and the current security culture. InfosecTrain Trainer: Alright. InfosecTrain Trainer: So... There is a process called, gap assessment. InfosecTrain Trainer: Someone heard of this? GAAP assessment? InfosecTrain Trainer: Current... current estate versus future estate. InfosecTrain Trainer: Now, you joined as a CISO in a company, you want to establish the security governance there. InfosecTrain Trainer: there should be something in the organization, right? Probably they would be running a small SOC team, they would have deployed some small firewall, application security tools, and all those things they would have already in place at a fragmented level, probably run by the business and run by a few people, right? But still, there are gaps which exist, right?

So how you will do that gap assessment, you will define a few InfosecTrain Trainer: So, future state, you will determine with respect to a framework. That's why we discussed a couple of frameworks and all, right? So, you need to pick one framework, or you need to tailor or create your own framework. Suppose I chose a NIST InfosecTrain Trainer: CSF. InfosecTrain Trainer: as a framework, I'll list down all the things what NIST says. With respect to that, then I'll do a gap assessment. Then I'll map all the existing processes I have, and then I'll understand the maturity level of the current organization. Then I'll say, okay, out of InfosecTrain Trainer: the control, what NIST says, there is only InfosecTrain Trainer: 40% of them are in place, 60% we need to implement. InfosecTrain Trainer: Now, those 60% gaps, how you will... you will create a roadmap. InfosecTrain Trainer: You cannot fix those issues in a day or in 6 months, right? You will need to create a roadmap, probably you will create a InfosecTrain Trainer: 3- to 5-year roadmap. InfosecTrain Trainer: 2... InfosecTrain Trainer: bring the organization up to the speed with respect to this future state, and then those roadmaps will have some key deliverables. So, as part of this roadmap, then you will establish and improve the governance. Like, suppose you say there is no formalized information security policy that you will create. InfosecTrain Trainer: You say there is no formalized roles and responsibilities structure that you will create, so all those things will become a deliverable as part of this activity. InfosecTrain Trainer: This is how the Security governance is implemented in the organization. Yes, Renewash. SrinivasanJ: See, if you go back to that, SrinivasanJ: whiteboard.

Like, for me to, SrinivasanJ: define or determine the future state, I need to first understand the business objectives, right? InfosecTrain Trainer: Yeah, so that's what I said, no? Current state versus future state. So, future estate, I just took an example of the nest. InfosecTrain Trainer: you will take the input of all the things. Just on the basis of NIST, I'll not create or establish a security governance. There is going to be the input from all the things. You will take the input from the business strategy, you will create the... you will take the input from the IT strategy, you will create, if it is not there, a security strategy. InfosecTrain Trainer: that input would be there. Business objectives, all those things will also be there as input. InfosecTrain Trainer: Then only you will determine and understand. Even the NIST framework, if you choose, does all the NIST control apply to your organization? Probably not. InfosecTrain Trainer: You will see which all controls apply to you on the basis of the business risk or the IT requirements. InfosecTrain Trainer: Understood? SrinivasanJ: Yeah. InfosecTrain Trainer: That's why I tell you have to tailor it as per your organization. So, you will do that maturity assessment, you will evaluate the current state of the security governance, where we are, then you will define and develop a roadmap, which I just discussed, right? Then you will do the resource planning, because to InfosecTrain Trainer: fulfill those roadmap items, you will require the people, process, and technologies, right? InfosecTrain Trainer: You cannot alone, as a CISO, fulfill all those things.

You will see, okay, there is a need to establish one IAM function, there is a need to establish one GRC function, there is a need to establish, suppose you are a... you are a product organization, there is a need to establish one AppSec function. Likewise, you will do that, and then you will do the resource planning. And then. InfosecTrain Trainer: Any changes which you are introducing in the environment will follow the change management practices. InfosecTrain Trainer: Let's discuss some questions. InfosecTrain Trainer: Alright, let's discuss the correct answers. InfosecTrain Trainer: Board of Directors of a... InfosecTrain Trainer: Board of Directors of a public-traded company is ultimately accountable for the enterprise risk management from a cybersecurity InfosecTrain Trainer: security perspective. What is the greatest responsibility of the board regarding information security? InfosecTrain Trainer: Approving all measures. InfosecTrain Trainer: all major... InfosecTrain Trainer: Approving all major information security technology procurement, ensuring daily operation security control, establishing the organizational cybersecurity appetite and oversight, conducting detailed technical vulnerability assessment. InfosecTrain Trainer: We discussed this, right? InfosecTrain Trainer: when we discussed about the responsibilities of the board. So, what does board do? Board do not approve InfosecTrain Trainer: the procurement, they do not do the daily operational need check, and they do not do the vulnerability assessment. They are the one, they'll be establishing the overall risk appetite and the oversight. InfosecTrain Trainer: Now, a new critical customer database containing sensitivity... sensitivity PII is being developed from a data governance perspective.

What is the main responsibility of data owner for this new database? InfosecTrain Trainer: implement... the database security control and patches, defining the classification, usage policies, and access requirements we just discussed, right? InfosecTrain Trainer: Not this, not performing the backups, this... the custodian will do. Physical security of the server also that, he will not take care. And information security steering committee is being formed. What is the primary InfosecTrain Trainer: focus, purpose of this committee in an organization with a hybrid security structure. To execute daily security operations and incident response, to provide the strategic direction, prioritize security initiative, and ensure the alignment with business goals, yeah, looks to be a good option. To conduct the technical audit of the penetration testing this steering committee won't do, to manage the security awareness training InfosecTrain Trainer: program of the employee, this also. InfosecTrain Trainer: someone else will do not security. InfosecTrain Trainer: steering committee. InfosecTrain Trainer: So, B is a... Think what they need to perform. InfosecTrain Trainer: Now, a business owner is launching a new cloud-based application vital for customer engagement. From an information security perspective, what is the responsibility of a business owner for this application? InfosecTrain Trainer: Approving the final security architecture and design, ensuring the application data is classified and protected according to the business value. InfosecTrain Trainer: conducting a comprehensive vulnerability scan before launch, providing a budget for security tools and the personnel for the application. However.

InfosecTrain Trainer: B also is in the purview of the business owner, but if you choose between B and D in this particular scenario. InfosecTrain Trainer: In this particular scenario, who knows the business value of that particular application which is being developed? Business owner knows. InfosecTrain Trainer: Does security know? What is the business value of that application? No. InfosecTrain Trainer: So, as per that, he will make sure that all the development work takes place accordingly, so that the application is appropriately protected InfosecTrain Trainer: from all threads while being developed, right? That's how you have to choose. Sometimes, there are two options which are close to each other, so you have to choose which is the best among them. InfosecTrain Trainer: So B is the one which is the best with respect to D. InfosecTrain Trainer: Anyone has any different opinion here? InfosecTrain Trainer: Now, ethics in information security. InfosecTrain Trainer: Right? So whenever you do any work in case of whatever business your organization is doing, right, whatever work you do, you have to follow the ethical practices, right? InfosecTrain Trainer: So, there are concepts like secure by design, there are concepts like security by default, right? InfosecTrain Trainer: So all these things came in what? It's because of the ethics. InfosecTrain Trainer: Because you need to make sure that you are following all the ethical practices, all the ethical thing whenever you are managing the security within the enterprise. InfosecTrain Trainer: So, how you do that? So, in your organization also, or whenever you download any new application, any tool, they always take your consent, right?

Where your data would be shared, where your data would be collected, which all information, whom we will be sharing this. InfosecTrain Trainer: They share you consent, right? InfosecTrain Trainer: Not like the people in the Bajaj finance, who keep calling InfosecTrain Trainer: all around the day, right? Now, probably after the DPDPA coming into the picture, these things will get sorted out. So... so those things, what happens in India are not ethical, right? Like, you go log into one particular InfosecTrain Trainer: property management portal, you will start getting calls all around the day from different, different property advisor. That they should not do, right? You just went and visited something, they should not share your details with other people, right? So this is not ethical practices. InfosecTrain Trainer: Similarly, in the information security, whatever purpose you are collecting the data, you should make sure that you are only using or utilizing the data for that purpose only. InfosecTrain Trainer: Right? InfosecTrain Trainer: So, ethical conduct mean InfosecTrain Trainer: which is beyond compliance and the moral principle. Not... you... you do not follow the ethics just because there are compliance rules, there is a DPDPA, GDPR, HIPAA compliance. That's why you are doing it. No. You have to go beyond that and make sure whatever purpose you are collecting your data, whatever things you are doing, they are in the ethical boundaries. InfosecTrain Trainer: You have to always make sure there is a balance between the security and the privacy. InfosecTrain Trainer: Right? You need to respect the individual rights while protecting the system.

InfosecTrain Trainer: Now, also, you have to do the ethical data handling, and there is a classical case recently in India, you saw that student protests happened, and when the Indian government summoned the meta... InfosecTrain Trainer: Senior Executive, they claim... they came in and they accepted that they actually took money from certain people to boost InfosecTrain Trainer: search for some certain class of data, which they should not do, right? Because they are a social media platform, they should always remain neutral. Whatever people are posting, they should only InfosecTrain Trainer: keep it wherever they are want to post, right? They should not boost any specific type of content to probably promote one kind of, thinking, right? That's... that's what is the ethics coming to the picture. InfosecTrain Trainer: Now, coming to the transparency, honest communication about the security practices. InfosecTrain Trainer: Right? Whenever you are... there is a data breach, there is a data loss, or something happens, you should make sure you are telling the employees, telling the customers that your data was involved, there was a data breach, there was security incident, which we have met with. You should not hide those things. InfosecTrain Trainer: Now, this is a very important topic. Legal, regulatory, and contractual requirements. InfosecTrain Trainer: What is a key difference between the legal regulator... what is the difference between a law And... regulation. InfosecTrain Trainer: Why there is a law, why there is a regulation? What is the difference? InfosecTrain Trainer: Who makes the law? Who makes the regulations? Ashwin: Like, the law is absolute, it's more or less black and white.

Ashwin: Whereas the regulation is like the FSA say I, like, you know, how much... some are attrition, what is the limit, so things like that are considered as regulation rather than a law. InfosecTrain Trainer: Okay. Fatha: Law is a rule, and regulation is something to enforce the rule... law. InfosecTrain Trainer: You'd have heard about the bodies in India, like, say. Ashwin: Yeah, seriously. InfosecTrain Trainer: FSSAI, right? InfosecTrain Trainer: RBI... InfosecTrain Trainer: if someone is from the European or worked in the bank, it's called the ECBA, European Commission Bank, which is equivalent to RBI in the Europe, right? InfosecTrain Trainer: In the US, there is something called the Fed. InfosecTrain Trainer: Fed is basically government-related departments, right? So, what are these? These are all the regulatory bodies. They create the separate regulations InfosecTrain Trainer: in their specific area of responsibility. Like, SEBI will create the regulation with respect to the public-traded company. Any company who is trading in the stock exchange, they should follow the SEBI guidelines. InfosecTrain Trainer: Right? If you commit any financial fraud, any issues, or anything, then there is a law InfosecTrain Trainer: which will help you to penalize, right? Regulation can only regulate or define the things. Regulation cannot InfosecTrain Trainer: enforce or penalize anything. For that, there is going to be law. So, in the India earlier, we had an IPC, now it's converted into BNS, Mhathi Nya Sahita, right? So, there are different, different categories of the BNS, right? InfosecTrain Trainer: BNS Act, so, so, so, number, so-and-so, so-and-so, like... So, likewise, there are going to be the multiple sections which would get applied to you if you do not follow those things.

InfosecTrain Trainer: So that is the key difference. Now, the laws are made in the parliament. In the country, the laws are made by them, so all the things which gets, probably discussed and published, that becomes a law. InfosecTrain Trainer: Right? And regulations are created and decided by these regulatory bodies. InfosecTrain Trainer: Which are, which every country have. Every country has multiple regulatory bodies, which they create. InfosecTrain Trainer: So, what is the regulation... regulatory compliance? Regulatory compliance are statutory requirements. InfosecTrain Trainer: So, all these legislative bodies, when they mandate some specific practices, security controls, specific things, whatever they define, organizations are supposed to follow them. InfosecTrain Trainer: And on the basis of those statutory requirements, there are some regulatory obligations. So those regulatory obligations will come into force in your organization if you are doing or dealing with some specific kind of InfosecTrain Trainer: Business. InfosecTrain Trainer: So, if I'm not... In healthcare, HIPAA won't apply to me. InfosecTrain Trainer: If I'm not collecting any personal data of the people, then probably the Personal Data Protection Act won't apply to me. InfosecTrain Trainer: So if I'm not a public-traded company, I do not trade in the NSC or BSC, then things won't get applied to me, right? So that's how it gets applied, right? InfosecTrain Trainer: Then there are contractual commitments. So, whenever you engage with any third-party business. InfosecTrain Trainer: With that third-party business, you have to abide to some contractual obligations, right?

If they say you report incident in 24 hours, if they say that if there is a security breach, you should be reporting to us, and if our information and data is lost because of lack of security controls in your area, then InfosecTrain Trainer: you have to pay for the fines, or pay for those things that you have to oblige to that, right? That's why you sign a contract, and the contract, which is assigned by two parties, becomes a legal document. InfosecTrain Trainer: On the basis of the contract, you can drag that body or that person to the court of law, where they'll be treated on the specific sections which are applied to them. InfosecTrain Trainer: Now, what are the legal requirements with respect to organization? So, all the legal requirements, they follow the jurisdictional scope. InfosecTrain Trainer: Right? Let me take an example. Suppose your organization has a headquarter in US, your organization is doing business in EU, your organization is doing business in India. InfosecTrain Trainer: Your organization is doing business in in, suppose Singapore? InfosecTrain Trainer: So, US says you should store the record of the people, minimum. InfosecTrain Trainer: 7 years, EU says you should record or store the data for the people for 8 years, India says 6 years, and Singapore says you need to store it for 9 years. So I see, okay, I can say, okay, the US is our headquarter, let's follow the US law. InfosecTrain Trainer: let's ignore local laws. Let's go with what our headquarter country says. Can you do that? Supriya Mhatre: None. Fatha: No. InfosecTrain Trainer: But that's what I was saying. You have to follow the law of the land. InfosecTrain Trainer: So, the law of the land, Singapore says minimum 9 years, so you have to

store minimum ride year.

So, that's why every country, if you'll say, they will always talk about the minimum years. InfosecTrain Trainer: They will not talk about the maximum years, right? So, probably, that's why in your organization, also, the data storage guideline would be set on the maximum number, whatever, wherever you are doing business, whatever is the maximum number, you will pick that, and then you will store the data according to that. InfosecTrain Trainer: Right? InfosecTrain Trainer: Now, how the law of land applies. Suppose, in India, whenever you check into any... check in into any hotel, you have to produce your, ID proof, right? Your Aadhaar card, or your passport, whatever you are getting, right? You have to go InfosecTrain Trainer: produce that, they will take a Xerox copy, and then they will let you check in. If a European citizen comes here checking into India, can he come and deny, and say that I am a European citizen in my country, this is not a practice, I'll not produce the document? He cannot. You have to follow the law of the land. InfosecTrain Trainer: So, same thing for the companies, whatever the law of the land says, you have to follow, and it gets applied to you, right? So, you need to understand which law apply based on your geography and the operations and the area of scope and responsibilities, right? InfosecTrain Trainer: Then there are some industry-based regulations. There are some specific sector-specific requirements, like specific to healthcare, specific to the payment car industry, specific to the banking. InfosecTrain Trainer: Specific to the manufacturing organization, so you have to follow those specific industry-specific regulations, right?

InfosecTrain Trainer: And then there are data protection laws, which is... involves the personal data of the people and the individual, and as per them, you have to follow the breach notification, like. InfosecTrain Trainer: GDPR says within 72 hours, you have to notify. NIST to say within 24 hours, you have to give the early warning, and in the 72 hours, you have to provide a detailed report to them. InfosecTrain Trainer: So, likewise, every law, every regulations also talk about the breach notification. If tomorrow there is a cyber incident. InfosecTrain Trainer: with so-and-so conditions, you should report to us. So, that's how the legal requirement works. InfosecTrain Trainer: Now, coming to the regulatory and compliance requirements. InfosecTrain Trainer: Right? InfosecTrain Trainer: So, there are the global variation. InfosecTrain Trainer: Right? So every organization, you will say, whenever there is a legal department. InfosecTrain Trainer: The legal department will maintain the list of all the regulations, all the laws which applies to your organization. InfosecTrain Trainer: So, if your business area responsibility is a global, so you have to make sure that all those InfosecTrain Trainer: legal requirements are being met, and your legal team is making a note of all of them, right? And in those laws, then there are some security requirements which CISO or the security manager need to make sure those security requirements are being adhered to. InfosecTrain Trainer: Then comes the... policy, policy harmonization, right? So, something called the baseline. What is the baseline? Johnny Souriar: Can you mind a quote. InfosecTrain Trainer: Minimum requirement rest.

So, the baseline requirement you will always set, which should meet these requirements, what are being set, right? So, we discussed the example about the minimum InfosecTrain Trainer: Number of years to store the data. InfosecTrain Trainer: So that minimum number of years for which you will be storing the data of the people, that becomes the baseline. InfosecTrain Trainer: like... Character of the password. InfosecTrain Trainer: expiry of a password. So, all these are specifically mentioned. So, if you are compliant to one particular thing, you have to make sure that you InfosecTrain Trainer: Follow those baseline principle, and then you create the policy according to that, so that you are able to meet those legal and the regulatory requirements, and always you need to respect and adhere to the local laws while maintaining the consistent security principle across enterprise. InfosecTrain Trainer: Now, coming to the contractual requirements. InfosecTrain Trainer: So, whenever you do a business, let's say there, your organization is XYZ, FinTech? InfosecTrain Trainer: You... InfosecTrain Trainer: host your data in a AWS infrastructure. You don't maintain any of your own infrastructure. You host your... you maintain your data center in the AWS environment, right? Now, tomorrow, there was an issue at the AWS data center, due to which InfosecTrain Trainer: there was a security incident, and your customers are not able to access the data. Who is responsible for this? InfosecTrain Trainer: Who will be held accountable in this situation? Pudir: Education. Fatha: CISO XYZ. Pudir: No, no, I agree with you, Chi. Fatha: It's lazy. Pudir: F... SrinivasanJ: Sir? InfosecTrain Trainer: Got... InfosecTrain Trainer: It's going to be the XYZ FinTech.

I am hosting data in AWS, I will be held accountable, not AWS. Whatever AWS contract I have for that, I can penalize them, I can work with them mutually, whatever I have agreed. InfosecTrain Trainer: That's why there is something called the Shared Responsibility Model. Shared Responsibility Model Contract, which always exists when you host data in the cloud environment, right? That InfosecTrain Trainer: will be able to do, but ultimate responsibility sits with me. I'm putting the data in my own data center on the cloud, my customers and my, people do not care. InfosecTrain Trainer: That, I have to make sure that AWS is adhering to all those things. That's why you create a stringent contractual requirement. You define some SLAs, you define some specific KPIs and KRIs, which you will check. InfosecTrain Trainer: So, there are some third-party obligations. The third party will also define some specific requirement. They will say that you need to report an incident to us within 24 hours. InfosecTrain Trainer: In 72 hours, whatever they say. So, they say that you need to maintain this level of security at any given point of time. Those contractual obligations you have to meet. Also, there are going to be some service level agreement. InfosecTrain Trainer: Which is, like, you have to maintain the 99.999% availability. InfosecTrain Trainer: Right? Likewise, you will have other service level agreements. These are the kind of services we want. Those becomes the contractual requirement. Then, assessment, right? So there... there are two things. There is something called a right InfosecTrain Trainer: to audit. InfosecTrain Trainer: There is one thing called a right... to inspect Right?

InfosecTrain Trainer: So, whenever you... whenever you fulfill the contractual requirement, you have to specifically mention either of these. So, right to audit is a very strict requirement where you can give them an advance notice, you can physically go audit their infrastructure, you can check their records, you can... you can check their policies, you can check their processes in detail. Right to inspect InfosecTrain Trainer: It is a less formal approach, which is the most common approach you will follow in the industry, where you have a third party InfosecTrain Trainer: Continuous monitoring, or something kind of, where you will send some assessment questionnaire to them, and then they will reply, respond, and then you will check the efficacy. InfosecTrain Trainer: Also, you will set across some liability provisions. If they do not follow those things, what is going to be the financial liability on them? InfosecTrain Trainer: this is the amount of fine which you have to pay, this is... you have to bear the cost for the legal, you have to bear the cost for whatever you can define. That provisions you have to specifically mention in the contract. InfosecTrain Trainer: Now, managing the third-party contracts. Anyone here who is working or have worked in the Third-party risk management. InfosecTrain Trainer: Someone here? SrinivasanJ: We do for raw. SrinivasanJ: Teams. InfosecTrain Trainer: Okay, so how do you manage the third-party contracts? InfosecTrain Trainer: Have you seen the third-party contracts? SrinivasanJ: contracts I have not worked on, but we do assessment, the risk assessments. So we form some questionnaires, like how the tapes are being stored, and how the tapes are being accessed. Those, we do, and it's an assessment I have not worked on correctly.

SrinivasanJ: Can MSB be, MSP can be considered that as a third-party contract here? SOWs? InfosecTrain Trainer: No, no, so SOW summary of Work is not a third-party contract. Contract is something which is a legal document where your organization and their organization, someone would sign. SrinivasanJ: like MSA, Master Sale Agreement. InfosecTrain Trainer: Yes, anything which is known as an agreement where both the people signed, both the body signs, like NDA, non-disclosure agreement. SrinivasanJ: Okay. MSA, yes. InfosecTrain Trainer: Yeah, so all those things. But those are not the contracts, those are just an agreement. Contract is something which is going to be the much more deeper in nature. Contract is something which will include everything. InfosecTrain Trainer: It will cover the NDA till everything, and contract. If you will read of any of the third parties, it's going to be very extensive. It will include all the things, what kind of services, what kind of things you need. So, more extensive contract you create is the better for your organization, right? InfosecTrain Trainer: So, what contracts will include? Contract will always have a clear, defined scope and the boundaries. InfosecTrain Trainer: It will define the service level agreements. What is service level agreement? Like, 99.99% availability, 24 hours you have to report the incident to us. InfosecTrain Trainer: This is all the service level agreement. The kind of services you want. InfosecTrain Trainer: Then security requirements and control, right? You will say that we want SSO to be enabled, we want multi-factor authentication to be there. If you are hosting... if it's a SaaS, we want you to have a web application firewall. We want you to have a DDoS InfosecTrain Trainer: related protection in place.

If you are... you are AI-based, you are providing some AI-related features, we want the AI InfosecTrain Trainer: poisoning and AI-based attack, prompt injection attack, AI poisoning and data model biasing-related control should be there. Likewise, you will mention the specific security requirements and control. Also, data handling processes. InfosecTrain Trainer: how the data would be processed, how the data would be managed, that you will mention. Also, incident notification timeline. What InfosecTrain Trainer: timelines you need incident, because if you are a GDPR-compliant organization, you are sharing your customer data with them. Now, if they met with an accident where there is a breach of your data, you need to report further to GDPR, right? That your customer information got InfosecTrain Trainer: lost, because someone else was handling that data on your behalf. So if they will report you on time, then only you will be able to disseminate that information further, right? InfosecTrain Trainer: So, the incident notification timeline should be there. Right to audit, a right

to inspect should be there. Then, what is the risk management? InfosecTrain Trainer: So, third-party contracts need to be InfosecTrain Trainer: treated... whenever you onboard any new third parties, you have to take a risk management approach. You have to check and determine what are the risks, and then, accordingly, you have to go ahead and then manage it, right? Some... first thing is the outsourcing governance framework. InfosecTrain Trainer: how the outsourcing will work, till which party they can share data, right?

That's why you sometimes have the NF Party contract, because you are giving them services, they are further sharing your data information with someone else, then it becomes a problem for you. InfosecTrain Trainer: Also, what are going to be the regulatory compliance requirements? Suppose whenever you are assessing the third parties, you will specifically mention that we will only do business if you are GDPR compliant, if you are HIPAA compliant. InfosecTrain Trainer: Likewise, you have to specifically mention those clauses, and that's why organizations say, okay, our organization is GDPR compliant, our organization is HIPAA compliant, right? They will make sure that the server InfosecTrain Trainer: the data and everything is being rerouted to only the server which is there in the EU region, EU data center, right? Also, subcontractor management, exit strategy. Suppose tomorrow we terminate the contract for how many years the data InfosecTrain Trainer: Data would be stored InfosecTrain Trainer: Right? How many years the data would be deleted, all those things. Also, the continuous monitoring. InfosecTrain Trainer: So, how you create a legal and the compliance-related strategies, right? First thing, you have to do a compliance mapping. InfosecTrain Trainer: So, in my organization, I... my organization InfosecTrain Trainer: is compliant to GDPR. We have a business in US, so we even comply to CCPA. We are doing business in India, so we need to comply to DP. InfosecTrain Trainer: DPA... We need to also comply to NIST 2. InfosecTrain Trainer: Even EU AI Act apply to us. InfosecTrain Trainer: You see, so many laws, regulations, right? InfosecTrain Trainer: So, it becomes very important to maintain a compliance framework.

InfosecTrain Trainer: So that you... you make a list of all the requirements, what these specific regulation says, and you should make sure that you are fulfilling your compliance requirement with respect to them. InfosecTrain Trainer: Also, you need to maintain extensive documentation, because if tomorrow there is a cyber incident. InfosecTrain Trainer: And there is a data breach, and there is one investigation which is being conducted or redirected in your organization. So what is going to be to save you? InfosecTrain Trainer: this documentation. So you have to make sure you are maintaining extensive documentation, log, audit records, and everything. Also need to collect the evidence. InfosecTrain Trainer: That's why there is expiry policies, right? You retain the logs for some certain period of time, 90 days or 6 months, whatever is your philosophy your organization is following. After that, you will destroy it, destruct it, or probably some organizations say, will move it into the archive. InfosecTrain Trainer: Dear. InfosecTrain Trainer: So, archive tier is... bit cheaper as compared to the normal tier. From there, you can... InfosecTrain Trainer: Collect the data. Now, audit preparation. InfosecTrain Trainer: So whenever there is an audit being done, or the regulatory body do an audit, so RBI, InfosecTrain Trainer: Do audit of all the banks. InfosecTrain Trainer: ECB. InfosecTrain Trainer: do an audit of all the European banks, right? Fed... InfosecTrain Trainer: in the US, do audit of all the US-based financial organizations. InfosecTrain Trainer: So, all these regulatory bodies, those who go do perform an audit on your infrastructure, you have to be ready and prepare for those audits also. InfosecTrain Trainer: Now, coming to the data retention requirement.

InfosecTrain Trainer: Which is very important. InfosecTrain Trainer: for an information security team to understand, right, for how many years you have to store the data, right? So, as I gave you example, right? The headquarter in US, you have a business in EU, you are doing business in India. InfosecTrain Trainer: you are doing business in, probably, Middle East. InfosecTrain Trainer: You are doing business in Australia, so every country has a specific data retention requirement. So you have to make a balance and make sure that you create your organization data retention requirement in such a manner, so it should fulfill all these requirements. InfosecTrain Trainer: Rather than having a separate, separate data retention requirement for all the countries, it will become very difficult for organization to manage in such a situation. So you will create a baseline in such a manner so that all these local guidelines are being met. InfosecTrain Trainer: you need to create and classify, right, so data as soon... as soon as the data is created, that time it would be classified. If you, InfosecTrain Trainer: So the document and the data security governance cannot be established in the organization if you don't have classification labels. InfosecTrain Trainer: If in your organization, there are no classification labels, you cannot have the data security. I'll tell you. InfosecTrain Trainer: If you want to establish, this is a baseline. You should first create the consistent level of data classification level, and on the basis of those data classification, then appropriate controls gets applied, right? InfosecTrain Trainer: like, public... InfosecTrain Trainer: internal... Right. InfosecTrain Trainer: confidential... InfosecTrain Trainer: restricted.

So, likewise, you will have some data classification label in your organization. As per these, the controls will get supplied. InfosecTrain Trainer: Also, the active use period. So, data need to be maintained with the appropriate control, right, when the system and the data is being used actively. InfosecTrain Trainer: Right? InfosecTrain Trainer: After the active use period is done, what you will do, you will move it into the archive tier. InfosecTrain Trainer: So, archive storage cost is much cheaper, but archive tier require... so you require a... InfosecTrain Trainer: a little more time to retrieve the data and record from the archived tier. So that is the only disadvantage there, right? Then you have to also mandate the retention. InfosecTrain Trainer: how many days and year the data would be retained to fulfill the legal regulatory requirements. Also, then, you will move it to the archive tier, and then you will do the secure destruction. InfosecTrain Trainer: Once the lifecycle ends, you have to securely destroy the data. InfosecTrain Trainer: Now, we discussed, so far, enterprise governance, also we discussed the security governance. What is the key difference between both of them? InfosecTrain Trainer: So, enterprise governance, we discussed board of directors, senior management, all those steering committees, strategy committee, and what are those things? Those are the enterprise governance, which helps you InfosecTrain Trainer: govern the enterprise, right? So, enterprise governance sets the org... the direction for the organization. InfosecTrain Trainer: It will set the risk appetite for overall business and the organization. Enterprise governance will help allocate the resources, funding, budget, and all those things.

It will establish the accountability framework for all the InfosecTrain Trainer: important roles, right? And also establish some specific KPIs, KRIs, so that you monitor the performance and ensure the regulatory compliance and the balance, the stakeholder interest. InfosecTrain Trainer: That's what the enterprise governance do. But if I talk about the security governance, security governance will make sure the security strategy is being implemented. InfosecTrain Trainer: All this information security-related risks are being managed, tackled, or handled. InfosecTrain Trainer: Security controls are properly defined and implemented and tested. InfosecTrain Trainer: Right? You are ensuring the compliance with respect to the security laws, regulations, right? You are measuring the effectiveness of the security, right? And whenever you do an investment, wherever you purchase, procure any tool, you will make sure it's optimized InfosecTrain Trainer: And the security investments are providing the value, which we discussed. InfosecTrain Trainer: Right? And then you will continue to report the security posture to the senior management. InfosecTrain Trainer: So, security, strategy. InfosecTrain Trainer: I showed you an example of the security strategy also, right? But how do you create a security strategy? Here, also, the same principle applies, which I took an example of that current state versus the future state, right? InfosecTrain Trainer: Any question in the exam where you see current state, future state, such kind of the keyword is coming, always the answer is going to be the gap assessment. InfosecTrain Trainer: Keep it in your mind. InfosecTrain Trainer: Now... InfosecTrain Trainer: Let's take the same example.

You are appointed as a new CISO or a security consultant in a new organization. The organization want to create the security strategy. Is it a new or old? Doesn't matter. They want to now create a security strategy for next 5 years. InfosecTrain Trainer: They hired you as an external consultant to create this. InfosecTrain Trainer: How you will do that? What you will do, you will first understand the current environment, what are the things they have at this point of time. InfosecTrain Trainer: what is the current business? What is the current business strategy, what are the business objectives, what are the key initiatives, and then you will determine a future state. What organization want to do after 5 years? InfosecTrain Trainer: Do they want to expand their business? Do they want to purchase new organization? Do they want to do some digital transformation, or do some AI-related innovations? All those things you will account for. Once you have that future state in mind, then you will InfosecTrain Trainer: Understand what are the key gaps. InfosecTrain Trainer: Right? Now, organization want to adopt AI, but there is no AI policy. InfosecTrain Trainer: There is no AI-related skills InfosecTrain Trainer: in your enterprise, right? There is no tech stack, or your infrastructure do not support the AI to run in current environment. So all those things will become key goals for you, right? And to fulfill those goals, you will create a high-level security strategy, right? InfosecTrain Trainer: So... so you will do first the current state assessment, what currently your organization has, what currently things are running. On the basis of that, you will do the strategic objective definitions. What are the clear strategic objectives, what you want to achieve?

InfosecTrain Trainer: Through this strategy, then after the gap analysis is done, you will identify those key gaps, and then you will create the roadmap. InfosecTrain Trainer: to fulfill them. And that roadmap should get translated into the information security strategy. InfosecTrain Trainer: Understood, everyone.

InfosecTrain Trainer: This is how you create a security strategy in the organization. InfosecTrain Trainer: Now, what are the things which gets added as part of the security strategy? You will include the control framework. InfosecTrain Trainer: which particular framework you are adopting. Suppose you have an AI also, you'll say, okay, we'll take some controls from NIST, we'll also take control from the NIST AI, InfosecTrain Trainer: Right? If you... your organization is probably ISO compliant, or you have an ISO certification, you will say, we'll... we'll pick up the control from ISO 27001, ISO 42001, all those things you need to define, right? It will also define that how the risk management will happen. InfosecTrain Trainer: how the risk would be treated, identify which kind of methods you will use, qualitative, quantitative, what kind of methods you will employ, that it will define. It will also help you define the policies and the governance. InfosecTrain Trainer: who is going to be the authority, responsible, decision rights, everything? And what is the... how the security culture would be established in the organization? Who... at what frequency you will conduct the awareness, training, behavioral incentive, right? InfosecTrain Trainer: Which sort of technology is tech stack you will have, right?

InfosecTrain Trainer: What are the security tools, platforms you want, and how you will ensure the assurance with respect to the testing, validation, review, and conformance with respect to the policies. InfosecTrain Trainer: So, this all thing should be... get added as part of the security strategy. InfosecTrain Trainer: Let's discuss some questions, yeah. Fatha: I have one question, actually, on the previous slide. Krishna. Yeah. Like, so is there any specific name for this document, that defines the strategy? Fatha: I've already seen that. InfosecTrain Trainer: Information Security Strategy only is the name of the document. InfosecTrain Trainer: Your organization will also have an information security strategy. That is what the document called, information security strategy. Fatha: Oh, thank you. InfosecTrain Trainer: Alright, let's discuss some questions. SrinivasanJ: First, two questions seems to be... Repeater. InfosecTrain Trainer: Alright, let's discuss the correct answer. InfosecTrain Trainer: I think the first question we already discussed, right? InfosecTrain Trainer: So, which of the following roles is responsible for legal, regulatory failure security in the enterprise? This is already discussed Board of Director and CD Management. An information security manager is global enterprise, has to ensure that the local information program will initially be compliant with the InfosecTrain Trainer: Where the data is collected. Which of the following is the most important in developing a security strategy? Understanding the objective. InfosecTrain Trainer: Without understanding the key business objective, you cannot develop any strategy, right?

InfosecTrain Trainer: positive environment, reporting line to the senior management, allocating resources, and the fund is important, but without understanding the business objectives, you cannot create a strategy, right? So that's correct answer. Let's discuss some more questions. InfosecTrain Trainer: Alright, let's discuss. Who is accountable for ensuring that the information is categorized and that specific proactive measures are taken? InfosecTrain Trainer: So, you don't see a data owner here as an answer, then who is the best, next best answer? InfosecTrain Trainer: He's a senior management. InfosecTrain Trainer: Security officer, how come security officer wouldn't be accountable if people are not, InfosecTrain Trainer: actually categorizing the information. How come an end user is accountable? How come a custodian? Custodian is responsible, not accountable. So, if a data owner is not there, the next best answer is the senior management. They become accountable for that. InfosecTrain Trainer: The data access requirement for an application should be determined by the legal department, compliance officer, information security manager, business owner. Who will determine? Business owner. InfosecTrain Trainer: He owned the data, he owned that application, so he will determine who InfosecTrain Trainer: will have an access to that particular information, right? So, correct answer here is business owner, who in an organization has the responsibility for classifying information? Data custodian, database administrator, information security officer, or data owner. It's data owner. InfosecTrain Trainer: We discussed, right? InfosecTrain Trainer: Who is responsible for classifying the information is the data owner. subaveena pugalenthi: ease. InfosecTrain Trainer: to respond.

subaveena pugalenthi: And data custodian is responsible for the classification, right? subaveena pugalenthi: Because in the first question, Accountability lies with... data owner. subaveena pugalenthi: Ensuring that the information is, categorized. InfosecTrain Trainer: Correct, correct, correct, yeah, yeah. InfosecTrain Trainer: Yeah, it's data custodian who will become the responsible. Accountability would be data owner, responsibility would be data custodian, correct. InfosecTrain Trainer: So here... Madhes: But the correct answer is... I differ here, just... Madhes: Who's an organization that has the responsibility for classifying the information? Madhes: See, who will classify the information? Custodian is usually IT, right? IT never classifies the information. Madhes: In this context, actually, the person who is creating the information is... Has to classify. InfosecTrain Trainer: So, who is creating. Fatha: Check the data here. Madhes: Data is created by the end user, right? Madhes: Information is created by the end user. Madhes: suppose I am creating one, public document, or consensual document, I am classifying, right? Pudir: So, data classification is the responsibility of the data owner. Pudir: will come into picture? Madhes: Yes. Johnny Souriar: I will not be able to sponsor. Johnny Souriar: See, you created a document, I am consuming the document. Pudir: Data owner is the best person to decide and judge, which is the client. Johnny Souriar: We are discussing on the third question, right? InfosecTrain Trainer: Yeah, yeah, yeah, we are discussing on the third question. Johnny Souriar: The owner is the responsible right, but... Ashwin: Yeah, data owner is what I also think.

If there's a project that implements cost and everything, and I decide, like, that has to be confidential information, I get to decide whether it's confidential or it should be public information. So I create this document, I'm the data owner, so I decide that, right? Sreya Mathew: Custodian can be accountable, is what I feel. No, no, no, how come... how... InfosecTrain Trainer: come custodian be accountable? No, no. Custodian is... custodian is something who is handling the data on behalf of owner, right? Like, suppose there is a database... there is a database where a data is being kept, so database administrator who is managing the data, he becomes a custodian of that particular database, but InfosecTrain Trainer: What data is there in that? What data is being pushed into that particular database, that only data owner knows. So data owner becomes responsible. We need to make sure that appropriate control... suppose the organization is GDPR compliant. If there is a PII data. InfosecTrain Trainer: that PII data should be... should not leave the EU boundaries, so that who will make sure that? Data owner will make sure, right? So, correct answer here is D, not A. Correct. Yeah, thank you, thank you so much for correcting. Madhes: Yeah, and one more thing, madam was confused, because the word responsible, we made it in the first questionnaire. Madhes: Seed custodian is responsible for protecting measures. InfosecTrain Trainer: Custodian is someone where the data... where the data owner has delegated some couple of responsibilities. Madhes: First question is, who is accountable Madhes: For ensuring that information is categorized. Madhes: And that specific protective measures are taken. Madhes: See, protective measures are taken by the IT, not by the senior management.

Madhes: Why is he... InfosecTrain Trainer: How come... how come custodian becomes an accountable for that? Madhes: No, that is okay. Accountable word is confusing here. My question is that specific protective measures are taken, senior management may not involve in day-to-day, you know, activity of defining the specific protective measures. InfosecTrain Trainer: It's talking about the accountable. That's what the changing answer here, right? Accountable. It's talking from the racy matrix. Madhes: Yeah, so it's tough. InfosecTrain Trainer: model? Madhes: Oh, InfosecTrain Trainer: Yeah, yeah, so suppose tomorrow there is a... InfosecTrain Trainer: Whereas tomorrow, there is a data breach, there is a data loss, will... who will be accountable for that? Is the custodian is accountable for that? Pudir: Sir, number one question is I'm having... Pudir: Sir, excuse me. Sir, number one... question number one is having data one or one of the options. Which would be the best answer, sir? Ashwin: It'll become. InfosecTrain Trainer: It's a data owner. Pudir: Yeah, yeah. Then, in the case, it's a senior management. Pudir: Because Data Warner is not available. Ashwin: Accountable is a key word. Pudir: Yeah, yeah, comfortable in thinking. InfosecTrain Trainer: That's what I'm saying. Accountable is the keyword which will change the answer. Here, the accountable is there. If accountable would not have been there. It says that who is... InfosecTrain Trainer: who... which role ensures that the information is categorized with respect to specific protective measures are taken? Then, answer is custodian, correct?

InfosecTrain Trainer: If you remove the accountable word from here, you say that who... which role ensure that the information is categorized and the specific protective measures are taken, then the custodian becomes the answer, correct? Ashwin: Got it. InfosecTrain Trainer: Compliance with the security policy, the standard responsibility of whom? InfosecTrain Trainer: Everyone, I told, right? InfosecTrain Trainer: Compliance with respect to the security and policies and standard and responsibility of each and every individual in the organization. So, answer is all organization units. InfosecTrain Trainer: It's not only in the responsibility of security manager, executive management, or compliance officer. Everyone in the organization is responsible for that. So for this, the answer is all organization units. InfosecTrain Trainer: So I think by this discussion, looking at these questions, now you people are clear with respect to roles and responsibilities. I know this is a little confusing topic, but as you will, continue to solve more number of questions. InfosecTrain Trainer: you will get clear on these topics. It's very important to understand this topic, because a lot of people get confused. Some questions you will see the database administrator as an option. Some questions you will say, see the application owner as an option. InfosecTrain Trainer: That kind of question you will get in the exam. So, don't get confused. Always be clear what that role means, what is the parent role that particular role is playing, read the question properly, what question is asking, and then answer. A single keyword may change the question, so you need to be very clear, right? InfosecTrain Trainer: Now, coming to the maturity model.

InfosecTrain Trainer: So, when you test how mature your organization is with respect to a specific InfosecTrain Trainer: framework, or a specific compliance standard, or with respect to your organization's own defined criteria. To test it, there is something called CMMI, which is called the Capability Maturity Model Index. InfosecTrain Trainer: These are the level which this particular model has on which you defined what is the maturity level of your organization. You can do the same exercise for your organization also, but InfosecTrain Trainer: This is not so simple, it's a very complex InfosecTrain Trainer: Process where you have to look the maturity in each and every processes what you follow, just not holistically. InfosecTrain Trainer: Right? InfosecTrain Trainer: So, what does the initial or the level 1 mean? Level 1 means that in that particular process, the things are happening in an ad hoc manner. InfosecTrain Trainer: things are inconsistent, there are no measures, there are no KPIs, KRIs defined, and the process is unrepeatable, means there is no SOP in place, you cannot repeat that process every time, same manner. InfosecTrain Trainer: In the next level, the process becomes repeatable. So you have now a proper SOP in place. Every time you do that activity, you will follow that SOP, and you will get a consistent level of result. InfosecTrain Trainer: When you move from next level, which is the defined, it means that things are well-defined, documented. InfosecTrain Trainer: And you have a proper standardization in place. InfosecTrain Trainer: things are standardized, you have proper standards, baseline controls, everything you have defined, it becomes a defined.

Managed means InfosecTrain Trainer: Whatever process you have defined, now you have a KPIs and KRIs and KGIs in place. InfosecTrain Trainer: Where you are quantitatively measuring the process and the performance of those, and the optimizing means that once you get the details or the data from this, you take that feedback as an input, and you have a continuous improvement cycle in place. InfosecTrain Trainer: So you get the feedback, you get the input, and then you improve the process and performance as per the feedback and the inputs which you are getting. InfosecTrain Trainer: So, this is what the capability maturity model... so you should, at high level, have understanding what does initial, repeatable, defined, managed, and optimizing means. So, you will get a question in the exam where InfosecTrain Trainer: a situation would be given. As per that, you have to determine which level of CMMI level InfosecTrain Trainer: The automation is. InfosecTrain Trainer: So the... I think if you know the stages, it's self-explanatory what that stage means. They'll not go into detail, they'll not tell you to do any CMMI-level maturity assessment, but you should be just familiar with these stages. InfosecTrain Trainer: So... InfosecTrain Trainer: So how then you develop the strategy? Once you have the CMMI, you understood the maturity level, you did the gap assessment, now you want to develop the strategy. So, once you do all this risk assessment, threat assessment, you evaluated your security program, you did the gap assessment, now it's time to develop the strategy. InfosecTrain Trainer: So you first did the assessment. InfosecTrain Trainer: You understood, you performed the gap assessment, you got the roadmap objective, you then... you will set the objectives.

What are those key objectives which you want to define and manage? On the basis of that, you will develop a security strategy with the roadmap, and then you will implement the strategy. InfosecTrain Trainer: Now, what are the objectives, or what are the key outputs which you get while... by implementing the strategy? First thing, you will get a business alignment. InfosecTrain Trainer: So the security strategy will make sure you are aligned with respect to the business objectives. So, your business says that, do the digital transformation. InfosecTrain Trainer: have a safe usage of AI across the organization. So, likewise, whatever business wants, you will be able to fulfill those requirements in... by... through the strategy. Next thing, risk appetite. Whatever business has appetite for. Madhes: I have our question here? InfosecTrain Trainer: Yeah. Madhes: The organization of just having an information security policy in place. Madhes: cyber security policy in place, cyber crisis management plan in place, BCPDR in place. Madhes: So, is it enough to say that information security strategy is in place, or it should be a separately documented? InfosecTrain Trainer: Strategy is something different. Those crisis simulation, all those things, right? Those are a specific... specific policies, or a specific SOPs, or the guidelines for one particular purpose, right? Strategy is something which you prepare for roadmap for 5 years. InfosecTrain Trainer: what your organization will do in next 5 years. That is the strategy. InfosecTrain Trainer: It's not necessary that a strategy should be there only in form of the proper document signed by... signed by an... acknowledged by the CISO and signed by your senior management, no.

InfosecTrain Trainer: It can be probably inform the PPT, or a page, a one-pager, which at high level. InfosecTrain Trainer: Determine what is the vision, what is the mission of your security function. InfosecTrain Trainer: What exactly kind of services you want to provide, and what is your... InfosecTrain Trainer: goal look forward in the next 5 years. Like, you will say, we'll support whatever organization says, we'll support what organization's strategy says, likewise, we'll create a strategy. Understood? Madhes: Yes. InfosecTrain Trainer: Then, effective risk management. So, strategy should also make sure that InfosecTrain Trainer: The risk management is there in the organization, right? All the information security risks are being effectively treated and managed. Also, the security is determining the value for the business, the value which we discussed initial slide, right, when we started the domain. InfosecTrain Trainer: about the value. InfosecTrain Trainer: delivery through information security, that you should be able to ensure also the optimization of the resources. InfosecTrain Trainer: So, all the resources which you have, they should be optimized effectively to determine the result, and the assurance process integration. So, all the assurance with respect to compliance, audit, legal, regulatory, that you are following all those things, that assurance process should be there. InfosecTrain Trainer: Now, coming to the next topic, information secure is information valuation and the classification. InfosecTrain Trainer: What is the difference between the Criticality and the sensitivity. InfosecTrain Trainer: What is the difference between the criticality and sensitivity?

You will... you keep hearing that this... this business or this information is very critical in nature, or you will say this data or this information is sensitive. InfosecTrain Trainer: So, criticality, wherever you say criticality, refers to the availability. InfosecTrain Trainer: If this particular data, this particular server, this particular application, this particular information, if InfosecTrain Trainer: Not available, what impact it will cause to the business. InfosecTrain Trainer: It means criticality. If you say it's a highly critical, medium, low, whatever you say. InfosecTrain Trainer: That's what it is referring to. But if you talk about the sensitivity, sensitivity is always referred to the confidentiality of the data. If the data is lost, stolen, or not available, what kind of confidentiality impact you will have, right? So sensitivity is most of the time referred with the individuals. InfosecTrain Trainer: Right? So, criticality is something which measures the impact to the business operation if the information is not available. InfosecTrain Trainer: Right? Critical means the operation sees immediately. If the information is not available, immediately the business will stop. InfosecTrain Trainer: And you will not be able to support that. High means the information is significantly impaired, medium and the low, these are just the example definitions. Sensitivity is something which measures the impact if the information is disclosed inappropriately. InfosecTrain Trainer: So that's why the sensitivity labeling which you have, right, in your organization, like your Word document, Excel, and PPTs, you might be labeling public, confidential, restricted, internal, or something like that, that is referred to the sensitivity.

InfosecTrain Trainer: So, BCP plan and the DRP plan, which you create, that is determined on the basis of criticality, because BCP and DRP plan is helping you to protect the availability of the data and information, right? InfosecTrain Trainer: So, this key difference is very much important for all of you to understand. A lot of even senior people, senior leadership people also always gets confused between the criticality and the sensitivity. InfosecTrain Trainer: Now, how do you ensure the business objective and all the business goals which are defined? Those are integrated within the security function. InfosecTrain Trainer: So, first thing what you will do, you will do the business linkage analysis. What does it mean? InfosecTrain Trainer: All security capabilities which you have, all the security objectives which you have defined, Right? Those should be... InfosecTrain Trainer: perfectly linked with respect to the business objective. If the business InfosecTrain Trainer: Says that we want to adore, we want to move from a on... prem to cloud. InfosecTrain Trainer: And there is a... InfosecTrain Trainer: plan in place, so CISO should make sure that he makes sure that there are tools, technologies, and the process and the people to support this migration, right? So what... he need to probably create a cloud security as a department, he need to probably deploy a CSPM tool. InfosecTrain Trainer: Cloud Security Posture Management. InfosecTrain Trainer: We need to... InfosecTrain Trainer: deploy one CASB cloud access security broker. These are all specific security controls with respect to the cloud, right? InfosecTrain Trainer: he need to have this capability, he needs to train his people on the cloud, specific cloud-related handling, on-prem people.

So then you will have the business linkage analysis. You need to map the security capabilities to a specific business requirement and the objective. InfosecTrain Trainer: If organization is adopting AI, so, for that. InfosecTrain Trainer: CISO should create a specific role's responsibilities so that he can support those AI-related issues. InfosecTrain Trainer: Then the business plan review. You need to regularly examine the strategic business plans to define the security implications. InfosecTrain Trainer: Right, so whatever business plans and the business documents you have, you need to regularly review them and make sure the business InfosecTrain Trainer: related issues are being addressed, they are being, being looked after, right? InfosecTrain Trainer: then you will also align with respect to the activities. You need to ensure the direct connection between the security activities with respect to business goals. I think someone asked a question, right? Does business goals need to be considered when you are creating a strategy? So that's why you have to do this linkage analysis. Without that, you cannot make sure that your business objectives are being met. InfosecTrain Trainer: Yesterday, I took an example of a Zepto. InfosecTrain Trainer: A quick delivery app who delivers the... the products to your doorstep within 10 to 15 minutes. InfosecTrain Trainer: So, this particular business has good...

InfosecTrain Trainer: Their business objective is what? To deliver the product as quickly as possible to the doorstep of a customer. But to fulfill this requirement, what does business want? InfosecTrain Trainer: Business want the availability of that application. InfosecTrain Trainer: through which you are placing the order.

Business want a database should reflect the accurate record of your SKUs, which are available in your warehouse, so that once people are placing the orders, it's actually reflecting correctly. InfosecTrain Trainer: Then the delivery rider who will be going and delivering the product, he should have a clear GPCS map. InfosecTrain Trainer: And... The system should automatically and correctly calculate the total travel time. InfosecTrain Trainer: It should not happen that you commit that we'll deliver the item in 10 minutes, and you are coming in 30 minutes. InfosecTrain Trainer: Right? So these are all the business objectives. Business want to achieve this, but to achieve this particular one task, you see so many things what security need to look after, and security need to manage. That's how you have to link the objectives and the business integration with respect to the security. InfosecTrain Trainer: And need to understand what are the critical information flow. InfosecTrain Trainer: Now, desired state assessment. InfosecTrain Trainer: So, as I told you, any question in the exam where you see InfosecTrain Trainer: The keyword, current state, future state, desired state. InfosecTrain Trainer: It's referring to gap assessment only. InfosecTrain Trainer: Right? The answer would be gap assessment, keep in mind. InfosecTrain Trainer: So, a lot of people gets confused between the Gap... Assessment. InfosecTrain Trainer: Versus... InfosecTrain Trainer: Viruses. InfosecTrain Trainer: business impact... Business Impact... sorry, Business Impact Analysis, BIA. InfosecTrain Trainer: Can someone tell me what is BIA? InfosecTrain Trainer: If you have heard of this. However, we are here to discuss. InfosecTrain Trainer: But yeah, what is BIA? Fatha: Business Impact Analysis.

Johny Souriar: business process. SrinivasanJ: Yay! Johny Souriar: And associated systems are evaluating and classifying based on that. Johny Souriar: with the attic. Johny Souriar: RPO, RPO... InfosecTrain Trainer: Yes, somehow close. InfosecTrain Trainer: So the business impact analysis is done to determine the criticality of the business, to set the priority list. InfosecTrain Trainer: which particular business would be restored first? Which particular business will have the highest amount of impact? Which particular applications, servers, databases are the highly critical in nature and need to be restored? So, BIA gives the output of a priority list, and GAAP assessment gives you InfosecTrain Trainer: Output as a roadmap. InfosecTrain Trainer: That is output. You need to understand this key difference, so when you will see in the context of the question, a lot of people get confused between both of them, and they end up choosing either of them, right? InfosecTrain Trainer: So keep... InfosecTrain Trainer: this definition, understanding clear in mind. So, you need to do a current state analysis, right? You need to have a InfosecTrain Trainer: Detailed assessment of existing security capabilities, what you have, what currently you are having at this point of time, then you will have a definition of the desired state, which will InfosecTrain Trainer: Get an output from some framework. InfosecTrain Trainer: some regulations. InfosecTrain Trainer: business objective. InfosecTrain Trainer: Right? InfosecTrain Trainer: your IT strategy, your org strategy, all of those things will give... provide you the input to form the desired state.

With respect to that, then you will see what are the gaps which you have, then you will select a framework to fulfill those gaps, and then you will InfosecTrain Trainer: Develop a roadmap to... complete. InfosecTrain Trainer: or achieve your desired state. So this is called a desired state assessment. InfosecTrain Trainer: This is a very important slide. If you want, you can take a screenshot of this. InfosecTrain Trainer: From business strategy, risk management, and from the policies and standards, which all role is responsible? Who all play an important role in that? InfosecTrain Trainer: So the senior management are the ones, those who create a business or the organization strategy. InfosecTrain Trainer: So once they create it, then the... it gives the output as a business objective. InfosecTrain Trainer: So, business objectives are output from this. InfosecTrain Trainer: Then, steering committee and executive management create a security strategy. InfosecTrain Trainer: Right? InfosecTrain Trainer: So, steering committee consists of the CISO also, right? InfosecTrain Trainer: CISO will create it, and then they will approve it. What does it provide? It provides the security attributes. InfosecTrain Trainer: Now, CISO and steering committee will create the security action plan policies and the standards. InfosecTrain Trainer: it will... InfosecTrain Trainer: Help you to create a security program, then you will implement it, and whatever security objectives you have, that will go as an input to this steering committee. InfosecTrain Trainer: If you want, you can take a screenshot of this, so this particular slide kind of summarizes what we have discussed so far in this chapter. InfosecTrain Trainer: Now, coming to the... common... Pitfalls or common biases.

InfosecTrain Trainer: when CISO or anyone who is creating or defining a strategy, creating a roadmap, what kind of issues they handle at that point of time. InfosecTrain Trainer: Right? InfosecTrain Trainer: So, what are the common pitfalls? InfosecTrain Trainer: First thing is the overconfidence. InfosecTrain Trainer: if... you have... InfosecTrain Trainer: an overconfidence on current controls, current technology, tech stack, current processes, current resources. You say that all things are going so well, there is no problem in the organization, we never had a security incident in so many years. InfosecTrain Trainer: So, everything is going well, so need not to create a strategy or define it, right? So, that's called the core confidence. Optimism. If you are very optimistic in nature. InfosecTrain Trainer: Right? You underestimate InfosecTrain Trainer: the challenges and all, you are highly optimistic in that particular place, you will be able to fail. You will fail if you have over-optimism. InfosecTrain Trainer: then technology focus. If some CISO or some executive who are very focused on technology, they feel that if you buy a high, sophisticated tech stack tools from top vendors in the world. InfosecTrain Trainer: you are protected from all the threats, but who are the weakest link? It's the human. InfosecTrain Trainer: If you don't have a proper processes, they will... InfosecTrain Trainer: fail some point of time, right? So, that's why over-focus on the technology also is a common footfall. Also, compliance myopia. So, a lot of CISOs and a lot of people, a lot of executives, they feel that if we are able to comply with respect to all the applicable laws, standards. InfosecTrain Trainer: It means we are secure.

InfosecTrain Trainer: Those laws only InfosecTrain Trainer: define some specific set of controls, right? They do not cover the entire tech stack or entire organization-related practices, right? So, just by showing compliance with respect to them won't save your organization from any security incident. InfosecTrain Trainer: Now, cognitive biases. InfosecTrain Trainer: So, there are some cognitive biases which are triggered with respect to your cognitive, your mental cognitive abilities, right? Confirmation bias. InfosecTrain Trainer: Sometimes, you will... what you will do, you will... You want to prove? InfosecTrain Trainer: That the techno... having an excessive technology or deploying one particular kind of tool will protect your organization, you will support that information with some data. InfosecTrain Trainer: Right? Now the next... InfosecTrain Trainer: bias is almost related to the same. You will remember the information that support the current view, right? You will collect some data, you will do some research, industry research, you will pull out some data and information from there, and then you will say, okay. InfosecTrain Trainer: this information is correct, whatever I'm saying. InfosecTrain Trainer: then biased assimilation means the interpreting ambiguous information to support existing positions. Sometimes you will create some ambiguous data, ambiguous information, ambiguous data points, and then you will support, you know, deploying this particular tech stack is only thing which will protect my organization. InfosecTrain Trainer: And sometimes going with the good thinking. If all the organization is going with the AI, let's go with the AI. And that's what's called the AI myopia, which is very popular these days.

Organizations are deploying AI to rule, like, left, right, center. They don't know how to manage. InfosecTrain Trainer: Now, you can see a couple of articles which are coming into the market, or getting published, where they're saying that they have exhausted complete IT budget only on the token's conception of the AI. InfosecTrain Trainer: Because they could not see what is the input and output tokens. They extended the Claude licenses to all the employees in the company. Now, they were continuously using the Claude InfosecTrain Trainer: to probably write some XYZ prompts, and the token consumption is gone. You would have heard these articles. InfosecTrain Trainer: That's called the group thinking. You need to understand what your organization needs are. InfosecTrain Trainer: how that AI will solve your organization problems, then only go ahead and use and create a strategy to fulfill those things, not what world is going into the direction. You have to go into that direction only. InfosecTrain Trainer: So, if you address these pitfalls or the biases, you will be able to create a very solid strategy. InfosecTrain Trainer: Which will help you protect your organization. InfosecTrain Trainer: Now, to create a strategy, what are the resources which are available to the CISO, or the security, or the steering committee, right? So, there are some proactive, operational, and the reactive resources. So, what are the proactive resources? You will have some list of policies InfosecTrain Trainer: Do you already have an information security policy, some IAM policies, data security policies? Already there would be some standards which are defined within your organization, right, which your organization is using. You will have an architecture diagram.

InfosecTrain Trainer: the enterprise architecture and the security architecture, both the architecture which you will have. You will also have the security personal. InfosecTrain Trainer: And all the previous assessments, analysis, audit findings, whatever you would have done, those findings also would be available. So these are proactive resources which you can take input. Then there are some operational resources, which on day-to-day basis, people use, like procedures and SOPs. InfosecTrain Trainer: People use the guidelines. There are roles and responsibilities which are defined for the people, what they need

to do, right? Then, also organization structure. InfosecTrain Trainer: Also, training requirements. So, all these are the operational resources which you will have to create a strategy, and then there are some reactive resources. If some issue, some incident, something has occurred after that, you are taking the action, like education and training. InfosecTrain Trainer: sometime you deploy or create... so, training is an operational resource also, training is a reactive resource also. Like, suppose there was a cyber incident. InfosecTrain Trainer: And you identified that people are not trained on one particular technology tech stack, they could not identify that particular threat actor, they could not, able to determine what was the indicator of attack, an indicator of compromise. InfosecTrain Trainer: So, you will impart the specific education and the training. InfosecTrain Trainer: Next thing is the audit. InfosecTrain Trainer: Sometimes, when there is a ransomware attack, or there is a big attack against the enterprise, then senior management will say, let's audit. InfosecTrain Trainer: Also, compliance enforcement.

InfosecTrain Trainer: So, once you do the compliance enforcement with respect to some compliance regulations, that also become a resource. So, all these resources a security manager or a CISO can utilize to create a good strategy for the organization. InfosecTrain Trainer: Now, what are the constraints when you implement the strategy? InfosecTrain Trainer: And it's applicable all across the organization. You want to implement a strategy, but there are some legal boundaries in that country. InfosecTrain Trainer: If you see the German laws, if you see the European laws, if you read the EU AI Act. InfosecTrain Trainer: It actually puts some of the AI solution in a prohibited category. InfosecTrain Trainer: So even if you want to deploy that particular kind of solution, you are a EU-based country, that solution may help your organization to improve your business and all, but you cannot deploy it because EU AI Act says so. InfosecTrain Trainer: Right? InfosecTrain Trainer: So, you cannot. That is a restriction. InfosecTrain Trainer: So, some legal restrictions you will have, because... InfosecTrain Trainer: With respect to some law, regulation, there are some physical restrictions. InfosecTrain Trainer: like... which country is prone to maximum number of tsunamis and earthquakes? Japan. InfosecTrain Trainer: Right? InfosecTrain Trainer: So, if your organization infrastructure is based out of Japan, you have to design it in such a manner so that you have to determine for all the crisis and all those things, right? So, physical limitations you have. InfosecTrain Trainer: then ethics. InfosecTrain Trainer: So, if overall culture of organization is not meant to InfosecTrain Trainer: To handle those kind of ethics.

InfosecTrain Trainer: You will have a constraint in implementing a specific kind of strategy, right? InfosecTrain Trainer: like, Vijay Finance. InfosecTrain Trainer: They are like this since the beginning, right? The people, those who are here attending from India, they know how many calls the Bajaj Finance make you every day. InfosecTrain Trainer: So that's how it is, right? So that is ethical. Suppose you join as a CISO in the Vijay Finance, and you want to implement some kind of the strategy there, you won't be able to, because that's how the organization is structured. InfosecTrain Trainer: Then the culture, same thing. InfosecTrain Trainer: If your culture is like that, it's very difficult to change the culture in the organization, right? It takes time year to change a focus and the culture. InfosecTrain Trainer: Suppose organization had all the access to the internet tools, all the tech stack, technology, people were able to use all the generative AI tools, they can go use cloud. InfosecTrain Trainer: GPT and all, even if you have the internal solution. InfosecTrain Trainer: Can you, as a CISO, go ahead and just straightaway block everything? You cannot. There is going to be a lot of escalation, a lot of... InfosecTrain Trainer: pushback which you will get from the people, right? So that's what this culture says. So you... and if you want to change it, so you have to slowly go into that. Then the personal. InfosecTrain Trainer: So, it depends on what kind of the tech stack people have, what kind of the knowledge and resources you have, right?

If you see the level of people, those who are working in the Google, Microsoft, and big tech giant, and the technology appreciation and technology understanding of other company, people would be different, because they have a big InfosecTrain Trainer: Money, they can buy those, they can pay a high amount to those people, and they can onboard them, right? InfosecTrain Trainer: Also, organization structure. Centralized structure, hybrid structure, we discussed, right, every kind of structure has their own limitation and challenges. Then the resources. InfosecTrain Trainer: what kind of tech stack you have, how much money is available, right? If I have a \$50 million to \$1 billion budget, I can definitely InfosecTrain Trainer: buy very sophisticated tools, technologies, have a good tech stack, but if... but if I don't have that, how I'll manage? InfosecTrain Trainer: Then, capabilities. InfosecTrain Trainer: What kind of capabilities organization has, then time. InfosecTrain Trainer: If, if your board wants InfosecTrain Trainer: adopt AI within 6 months, then time is very limited, right? You have to quickly, deploy some things, you have to probably skip a couple of things, right, to implement that thing. And the risk appetite. How much risk your organization can handle, that will also determine, InfosecTrain Trainer: how you can effectively deploy the strategy, right? So these are some couple of constraints. InfosecTrain Trainer: So once you have understand the constraint, you understood the biases, you will do the security, strategy. So what you account for, you will do the proactive control enhancement. InfosecTrain Trainer: So, strategy is being developed for the same thing, right? You want to proactively enhance your existing controls, right? Tech stack.

You want... InfosecTrain Trainer: to improve the incident handling, incident visibility, right? Whatever detection capabilities you have, you have a SIM and SOAR solution in place. They will make sure that the log InfosecTrain Trainer: integration and everything is also happening in a better manner, right? You want to optimize your incident response plan. You will... you want to improve the mean time to detect InfosecTrain Trainer: Main time to respond. InfosecTrain Trainer: Right? Overall, you want to reduce the risk. InfosecTrain Trainer: whatever is the residual risk rating you currently have, you want to further bring it down to one certain level, right? That you will be able to do through security strategy. Then cost optimization. InfosecTrain Trainer: If you want to optimize the call cost, right? So, in your organization also, you can see, if you see from a tech stack perspective, right, a lot of organizations have tech stack from InfosecTrain Trainer: 100 different vendors. InfosecTrain Trainer: So there are always opportunities to probably club it or buy a license from a single vendor who is offering you multiple capabilities, so your overall license cost gets reduced, right? Overall administration gets reduced. So that is the best option for doing the cost optimization and the resiliency. InfosecTrain Trainer: Overall strategy, you want to make sure there is a business is resilient, business continue to operate, you have a proper RPO, RTO, and all the BCP and DRP plan in place to make sure the business continues to run and operate in event of any eventuality or any incident. InfosecTrain Trainer: Now, gap assessment, right? So... so to implement a security strategy to accomplish the objectives, you will be doing a gap assessment, right?

So first, so what do you do as part of gap assessment, you will be first doing the business alignment analysis. InfosecTrain Trainer: You want to understand how much your security function is aligned with respect to what business wants. InfosecTrain Trainer: So, current security initiative, current security, security capabilities, are they fulfilling what business want to achieve or not? If they are not, you will InfosecTrain Trainer: put those things in the strategy. Then you will review the existing strategy. You will review the existing security strategy, IT strategy, you will review your business strategy, you will also determine the charter we've discussed, right? Charter. InfosecTrain Trainer: What does Charter says? What is the accountability? How much authority I have? How much funding expenditure capabilities I have? What is the policy framework currently in place, right? InfosecTrain Trainer: how many policies we have, which all places we don't have a policy, so all these things at a broader level, you will analyze as part of the gap assessment. InfosecTrain Trainer: And then you will do the SWOT analysis with respect to security strategy, right? So there are strengths and the weaknesses, opportunities, and threats. InfosecTrain Trainer: So, any sort analysis, strength and the weaknesses are always internal. InfosecTrain Trainer: And opportunities and threats are external to your organization, which you don't have a control on, right? So, strength, you know your organization's strength, right? So, with the gap analysis which you conducted, as per that, you will know that, okay, these are things which are already in place. InfosecTrain Trainer: Right?

We have a good executive support, we have a strong technical expertise, there is a matured incident response plan, we have a good security policies, our mean time to detect and respond is good. These are all strengths. InfosecTrain Trainer: then you will find out some weaknesses. So, probably the security tooling which I told, right? There is a fragmented security tooling, there are InfosecTrain Trainer: Different, different licenses being run from different, different vendors. InfosecTrain Trainer: sometimes security operations are happening in silos. You find out that there is a huge amount of tech stack from, probably, shadow AI is running, right? There are inadequate third-party risk management. InfosecTrain Trainer: And what are the opportunities? Opportunity is something which is external, right? So... InfosecTrain Trainer: suppose you do the cloud migration, it will help you. Suppose you adopt the AI, InfosecTrain Trainer: technologies, it will help you improve. If you do the partnership with some InfosecTrain Trainer: particular industry partner, it will help you. If you deploy or hire some good consultant like Gartner Forrester, it can improve your infrastructure. And threats are something which is not in control, right? Some political changes, some global changes, or some... InfosecTrain Trainer: Shortage in the talent, there is attack surface being increased. InfosecTrain Trainer: there is a new kind of the threats which are being emerged, so this is how you do the SWOT analysis. Let's discuss this last question, and then we'll InfosecTrain Trainer: Close the date after this, yeah. InfosecTrain Trainer: Alright, let's discuss.

InfosecTrain Trainer: So, the first question is talking about when developing an information security strategy, a CISO must ensure it supports the organization goals. What is the main input for the defining the scope and objective of the strategy? We discussed. InfosecTrain Trainer: The latest cybersecurity threat intelligence report. InfosecTrain Trainer: this is not a very important thing to define that, right? Results from the most recent vulnerability assessment, this is also a very small thing, but organization, business strategy, and risk appetite. Without this, you cannot build a security strategy, right? InfosecTrain Trainer: Standards and framework also is required, but without business strategy and risk appetite, you cannot build a strategy. So that's very important. A security manager is struggling to get cross-departmental buy-in for a new security strategy. What is the greatest constraint impacting successful strategy implementation in this scenario? Lack of advanced security technology tool, insufficient budget allocated for the security initiative. InfosecTrain Trainer: Poor communication and collaboration across, organization CLOs, rapidly evolving cyber threat landscape. InfosecTrain Trainer: So if you read the question properly, the keyword is cross-departmental buy-in. InfosecTrain Trainer: There is a less collaboration from the departments, right? Business heads, business owners. So, how you will mitigate this? With a communication, right? InfosecTrain Trainer: It means that there is less communication or poor communication, there is no collaboration, that's why you are not able to get their buy-in for the strategy, right? InfosecTrain Trainer: So you need to improve the communication.

That's why correct answer is, see, an organization completes a security gap assessment. What is the primary purpose of comparing the current state of security against the desired state? InfosecTrain Trainer: To identify discrepancies and to prioritize action for improving the security posture. InfosecTrain Trainer: To prove the compliance with all regulatory updates. InfosecTrain Trainer: to determine the exact financial cost. If you see, whenever you do the desired state assessment, it's basically this, we discussed multiple times, right? You want to identify the gaps InfosecTrain Trainer: And prioritize the action to improve the security posture. InfosecTrain Trainer: Just a minute... InfosecTrain Trainer: Yeah, a healthcare organization is reviewing its data retention requirement. What is the main driver for establishing a specific retention period for patient healthcare information, right? To minimize the storage cost for the old data, to reduce the scope of the data for future security audit, legal, regulatory. InfosecTrain Trainer: Compliance obligations. InfosecTrain Trainer: Or industry best practices for data lifecycle management. InfosecTrain Trainer: So, always, the data handling. InfosecTrain Trainer: personal data-related things, you have to do it for the legal, regulatory, and compliance obligations, right? Not A, B, and D. So, correct answer is C, yes. So, anyone has any InfosecTrain Trainer: Questions or doubts here? InfosecTrain Trainer: So, we have concluded this domain, so this is the next topic which I'll discuss. This is the new topics which I have introduced for the AI and all, which we'll discuss in the next class, but there are... there is only 5% content which is left for the domain. One rest I have completed, right?

InfosecTrain Trainer: So, now what you have to do in the next week, right? First thing, those people, those who have not yet watched those videos which I shared yesterday, please go ahead and watch. InfosecTrain Trainer: them, right? I am sharing two important videos, because once you will start solving the questions, you have to InfosecTrain Trainer: You have to watch this video. InfosecTrain Trainer: One video is this, how to read the questions. That is very important. However, we discussed that at high level. InfosecTrain Trainer: first class, I explained you, but still you read it. InfosecTrain Trainer: And then... This think like a manager will do. InfosecTrain Trainer: These two videos are very important. InfosecTrain Trainer: I recommend all of you to watch them. InfosecTrain Trainer: to understand, and then start solving the Domain 1 question. So, I showed you the Google Drive. I hope all of you have got access to the Google Drive. Johny Souriar: It's just... Vijayakumar: And it would be fun. Johny Souriar: WhatsApp group, please? InfosecTrain Trainer: Yeah, if someone can put it, I don't have a WhatsApp web opened in my... browser, currently. InfosecTrain Trainer: If someone has it opened. Pudir: Yeah, I'm keeping Siva. Pudir. SrinivasanJ: Okay, sure. InfosecTrain Trainer: Sure, sure, please, please, thank you, thank you so much. And also, Saxam has... Saxam has shared one, the feedback link. InfosecTrain Trainer: Right? Please provide the feedback, so it's a... it's the... we have completed the two sessions, so whatever the feedback you have with respect to the class, please do share that. InfosecTrain Trainer: looking forward to, right? And also.

InfosecTrain Trainer: You will be sharing the feedback, but apart from that, also, if you feel the pace InfosecTrain Trainer: anything... anything with respect to some topic, or anything you have any issues, please let me know, right? I'll be able to probably stop in between, explain you those things, so don't worry. It's... it's not a one-way communication where I'm just teaching some topic, and you people are just listening. InfosecTrain Trainer: at the end, right? We can have a discussion. If you are not able to understand, you want to understand with some topic, with some example, with some case study, I'll be able to do that as well, right? So you need to just let me know, so I'll explain any complex topic. However, I already have kept some couple of. Vijayakumar: case studies, which I keep. InfosecTrain Trainer: using them to explain the topic, but still, if you found out there are gaps, I'll help you understand those topics. So, in the next week, watch these videos and InfosecTrain Trainer: Please. InfosecTrain Trainer: Start solving the questions. InfosecTrain Trainer: So, in the first domain, I showed you there is this folder named Books. InfosecTrain Trainer: in the Google Drive, go to the books, open that ISACA QA Manual Number 10, I think it's the 10th edition, which you have to open, and then from there, start solving the Domain 1 questions. So by next week. InfosecTrain Trainer: Try as many as you can, 70%, 80%, whatever number of questions you can solve from that domain is going to be the very good, because then we'll go with the domain too. All clear to everyone? Mukesh Thakur: Yes. Vijayakumar: Yes. Vijayakumar: Yeah. InfosecTrain Trainer: So if you actually want to write exam by end of September or mid of October, please continue to follow my guidelines.

If you continue to follow this. InfosecTrain Trainer: Probably by end of the session, you will be always... you will already be 70% ready for the exam. You have to just, again, revise some couple of topics, and you can go ahead and write the exam. InfosecTrain Trainer: Alright, anyone has any questions before we close the session? Fatha: You mean to say whatever recommended videos you're asking to watch, right? Those things? InfosecTrain Trainer: Yeah, yeah, yeah, and also solve the questions. Fatha: So. InfosecTrain Trainer: Now we have concluded the domain one, right? So you understood all the topics. Before that, if you want a revision, quick revision, you can go ahead and read the notes. So there are notes InfosecTrain Trainer: For each domain, so domain one note quickly you can read, so that you are ready and understood. Fatha: That's true. Fatha: Sure, thank you. InfosecTrain Trainer: Alright then, thank you so much, everyone. Everyone have a great day. Fatha: Thank you. Vijayakumar: Thank you. Thank you. Supriya Mhatre: True. Vijayakumar: Thank you, sir. SrinivasanJ: Thank you.

Day 3: Full Cleaned Transcript

Approximate source length: 28,624 words.

InfosecTrain Trainer: Hello, good evening, everyone. Mukesh Thakur: Hi, good evening. Supriya Mhatre: Hello, forgive me. InfosecTrain Trainer: Hello, I hope everyone had a good week. So, so before we get started, so last week we actually almost completed the Domain 1. How many of you have started, practicing the questions from the QA manual? InfosecTrain Trainer: An event, right? Supriya Mhatre: Yes, I tried, but I think the time was 300 minutes, so I couldn't sit for that long, but yeah. InfosecTrain Trainer: No, no, I'm not talking about that. I'm talking about the QA manual questions, which is a PDF version. Supriya Mhatre: Okay, okay. InfosecTrain Trainer: Yeah, that's what I said. Please start with that, so that you... you continue to solve the questions along with me. Then you build that mindset, you have an understanding how to approach questions. Keep those simulation InfosecTrain Trainer: simulated questions for the last. When you, when you... once we complete the training, right, that time also you will need. Pudir: them do it. InfosecTrain Trainer: Hi, Pudir Putin. InfosecTrain Trainer: temporary, would you like to say something? InfosecTrain Trainer: So, so, what I was saying, that keep those questions, simulated questions, for the last, so that once we complete our training, you will have something to practice, right? InfosecTrain Trainer: So these questions, which is there in the QA manual, will help you build that approach, right? How to read the question, how to probably follow the elimination technique, then understand which particular option is wrong, which particular option is correct, because you have a good explanation also provided below each and every question, right?

InfosecTrain Trainer: So once you have that particular mindset build, then it would be easy for you to go with those simulations, right? So, keep those simulated questions at the last. Supriya Mhatre: Okay. Pudir: Sadness is Pudir. InfosecTrain Trainer: Yeah, Pudir. Pudir: Sir, actually, Dr. Mano questions are available to 54 questions. Whether, it will standard for exam preparation, as can we accept an exam? InfosecTrain Trainer: Can you please repeat again? Pudir: Yeah, the questions available in the domain questions, 25 questions are available. Pudir: The standard is enough for examination, or more standards are limited. InfosecTrain Trainer: No, no, this is the same standard of the questions which you will get in the exam. There is not going to be any difference. InfosecTrain Trainer: You will not get the same question. Pudir: Oh, yeah, yeah, yeah. InfosecTrain Trainer: Yeah, but the understanding around the topic, understanding around the concept, you will be able to test using those questions. InfosecTrain Trainer: So, I have interacted with a couple of people, even, even a couple of people, those who cleared recently, means last week itself, right? So... so I will be sharing, what I got the insights from them, probably in the last session, right? So that... InfosecTrain Trainer: In that session, we will also discuss about the strategy, how to go about it. InfosecTrain Trainer: But one thing you need to be clear, right, so that's what is the concept around the topics. That need to be very much clear, right? If you know the topic. InfosecTrain Trainer: clearly, if you understand the difference, right? Like, for example, you know what is a gap assessment, what is BIEA, and what is the risk assessment, right? It becomes easy for you to, solve the questions.

Pudir: Thank you. InfosecTrain Trainer: Yeah. InfosecTrain Trainer: So, so this is what, so in the last session, we started with the domain one, right? We discussed the strategy for the exam. I also covered at high level that exam is planning to be changed from InfosecTrain Trainer: the next, in the November 1st week, right? Then the new pattern would get introduced, so it's a good time to write the exam now. InfosecTrain Trainer: Right? InfosecTrain Trainer: And then, second thing, what I would like to mention is here that please make sure that you InfosecTrain Trainer: clear your understanding around each and every concept, right? Be very clear what does it mean, and when in the... in the session, also, I keep telling you, right, if you see this particular keyword in the exam, then this is going to be answer. Keep those InfosecTrain Trainer: Points noted somewhere in your notebook, so that you remember them when you are revising before the exam. InfosecTrain Trainer: And one thing. InfosecTrain Trainer: be more, be very clear around one thing which I would like to give a tip. InfosecTrain Trainer: always follow the elimination technique. People have... InfosecTrain Trainer: failed in an exam, they were getting almost 80% in the practice test. But in the original exam, they failed because they were overconfident. InfosecTrain Trainer: They did not, went with the elimination technique, directly read the question, they thought that this is the answer, and then they keep, solving those questions like this. Don't do that. InfosecTrain Trainer: Always follow elimination technique, because in the exam, the question will get changed. InfosecTrain Trainer: write what you are studying, the question will get changed, only the concept remains same.

So that's why if you follow the elimination technique, you will be able to narrow down to the correct answer clearly. So follow this technique for each and every question. That's what I'm saying. InfosecTrain Trainer: start solving the QA manual question along with the sessions. InfosecTrain Trainer: So that, you build that particular understanding, right? As such, this week, we only have one class. Next week, we'll have the two class, where we'll finish the Domain 2, start the Domain 3, and then you will have a long gap, because InfosecTrain Trainer: 27th, 28th weekend, we are not having any class, so you will get almost a gap of a week. InfosecTrain Trainer: plus 10 days, so I would recommend everyone to please complete all the QA manual questions till domain 2. InfosecTrain Trainer: by first week of September, right? So that you can cover up on the time, okay? Then let's get started. So, anyone has any doubts from the previous session, or any questions if you solved InfosecTrain Trainer: You did not understood? Pudir: complicated. Supriya Mhatre: Krishank, regarding the maturity levels, what we saw, that those are not the standardized ones, right? Or they may differ organization to organization, or they are something which are permanent, like initial, repeatable, defined. Supriya Mhatre: once we lose. InfosecTrain Trainer: No, no, no, that is a standard CMMI level. Supriya Mhatre: Okay, okay, good. InfosecTrain Trainer: to not differ. It's a universal, InfosecTrain Trainer: CMMI levels, which you can Google also. Supriya Mhatre: Okay, okay, so sometimes we use, initial, then planned, if it is repeat. I mean, the terminology is also, they are standardized?

InfosecTrain Trainer: Sometimes they... the wording may interchangeably be used, but the definition of that particular level remains the same. Supriya Mhatre: Open. InfosecTrain Trainer: So, I have... I have added the new topics, right, around artificial intelligence, but InfosecTrain Trainer: This is not yet added as part of the syllabus. Why I have... I'm giving a high-level overview around the AI? Because what I got to know from the students, that they are using a couple of AI-related concepts in the questions, but InfosecTrain Trainer: the... InfosecTrain Trainer: Basic remains same. So, like, they will say that there is an AI being implemented in your organization. What... to establish the AI governance, what is going to be the first step? InfosecTrain Trainer: So you... they will say that... establish the AI policy, establish the AI strategy, something like that. Roll out the generative AI solution from a vendor, right? Something like that, options would be there, right? InfosecTrain Trainer: But... InfosecTrain Trainer: they are saying... talking about AI, but the basic remains same, right? So to establish and governance, you will first build a strategy, right? Then you will... then you will introduce a policy, and then you go on, right? So that's how you have to approach. So, yeah. InfosecTrain Trainer: Anyone here who is working currently in AI governance in their organization, or has any experience around AI, InfosecTrain Trainer: Other than using it as a generative AI tool in the organization. InfosecTrain Trainer: Alright, so let me... give a basic understanding AI, right?

InfosecTrain Trainer: So, if you talk about AI, InfosecTrain Trainer: The basic definition of AI is that any machine which has intelligence of its own, and then it can take some decisions on the basis of that intelligence, would be called as an AI. InfosecTrain Trainer: Any machine. So AI is not something which is recently introduced, it's been there in the industry from the last 30 plus years. InfosecTrain Trainer: Only the generative AI is something, and the large language model is something which InfosecTrain Trainer: was introduced recently. REST, everything was there. Machine learning was already there. InfosecTrain Trainer: Deep learning is something which they have... which got evolved recently, right? So AI means any machine which can InfosecTrain Trainer: take the decision at its own. That's going to call AI, right? Like, self-driving car. InfosecTrain Trainer: Alexa at your home, so any, any, anything like that, like ChatGPTs, which is an example of generative AI, any image recognition tool, right? Or a very basic thing, spam filtering, which is there in your email gateway. InfosecTrain Trainer: Even in your Gmail, right? InfosecTrain Trainer: Whenever an email comes, automatically it classifies it into the promotional email, regular update, or something which is a spam, it will put it in the spam folder. InfosecTrain Trainer: Now, coming to the capabilities, right? So, AI also gets distinguished on the basis of the capabilities it offers. So, first thing is the narrow AI. Narrow AI is something which is built for a very specific task. InfosecTrain Trainer: to solve one particular specific problem, right? Your smart switch, or your smart bulb, or AI, which is there in the self-driving car. InfosecTrain Trainer: very specific usage, not a general.

Now, coming to the general AI, AGIs, artificial general intelligence, this is an AI which is still in the conceptual state, still the current InfosecTrain Trainer: level of the AI models are not able to distinguish this level of interest. This is basically an AI which can outsmart any humans in the world. InfosecTrain Trainer: whatever humans are doing, AI should be able to do it in a better manner, right? The AI should be able to generate the paintings, better articles, should be able to compose music better than A.R. Rahman, right? Would be able to direct or create a movie InfosecTrain Trainer: better than probably Nolan. So, like, like

that. InfosecTrain Trainer: Now, superintelligence is something which, if someone is here is a fan of Marvel, right, you would have seen the Tsarvis, or the Friday, right? The superintelligence which helps the Iron Man, right? So that is a superintelligence, something which is... InfosecTrain Trainer: Beyond human capabilities, can do anything. InfosecTrain Trainer: Right? That is a superintelligence, still a concept. Now, coming to the... from a broad field category, so machine learning is basically... which is since the edges. So, it learns the patterns, then it, on the basis of it, predict and classify. It's very generally used within the cybersecurity domain, right? Like, InfosecTrain Trainer: machine learning in your email account, which helps you declassify that. Machine learning algorithm sitting on your EDR, right? Machine learning algorithm in your firewall rules. Machine learning algorithm in your incident management playbooks.

InfosecTrain Trainer: So everywhere, the machine learning would be there, which actually train on the basis... basic of the past data, or the current event, and on the basis of that, it will give you the InfosecTrain Trainer: the correct output. Now, coming to the deep learning, deep learning is which is the basis for the generative AI, right? So, deep learning actually works on the neural networks. InfosecTrain Trainer: So, in our brain also, we have neurons, right? InfosecTrain Trainer: So, there are neurons. InfosecTrain Trainer: which are connected with each other. Likewise, the change would... So this... I have drawn... draw a very simplified diagram. Imagine the billions or trillions of neurons. InfosecTrain Trainer: So, all the new class of models like Opus, GPT so-and-so class, and so-and-so, whatever, you can check, Google it, they will say that it's based on the so many million number of neurons. So, more number of neurons, the better the output the model will give. InfosecTrain Trainer: And that, also, you can see, right, the GPT, when it was launched, probably 3 years back, you can compare the kind of output which it used to produce then versus now, because they have now increased the number of neurons. InfosecTrain Trainer: the data quality got improved, now the models are better trained, right? So it would be able to, on the basis of neurons, it would be able to classify, and it will be able to generate the data. InfosecTrain Trainer: Right? Now. InfosecTrain Trainer: Generative AI, which is very common, like your Gemini, ChatGPT, image recognition, generate the music videos, generate the images, generate some PDF document, some Word document, PPT, anything is an example of generative AI.

InfosecTrain Trainer: So, what you need to remember overall, AI is an umbrella term. InfosecTrain Trainer: Anything which can think, has mind of its own, becomes AI. ML is subset of AI. Machine learning is on the which the AI works. Machine, which can think at its own, which can learn at its own. Deep learning is subset of ML. InfosecTrain Trainer: And the generative AI is built with the deep learning. InfosecTrain Trainer: Right? And then a basic, basic example, if I take, like, the chess. InfosecTrain Trainer: Right, so you... so you build a chess using AI, so chess will, as soon as you play, against the opponent where the AI is sitting, as soon as you play something in the chess. InfosecTrain Trainer: on the basis of that, AI would be able to predict your next move, and it will also, InfosecTrain Trainer: play accordingly. ML is the spam filter, which I already told. Deep learning, the best example is face recognition, speech recognition, right? And the generative AI is a chatbot, like GBT, Gemini, and all. InfosecTrain Trainer: Now, coming to the governance. InfosecTrain Trainer: So, we are in the security domain, so how you establish the AI governance? InfosecTrain Trainer: So when you introduce the security... so for security, we establish a governance, right? How we establish the governance? We established the governance, by putting up the roles and responsibilities, then we created a strategy, then we created the policies. InfosecTrain Trainer: And on the basis of that, then you establish an overall broader governance. Similarly, for the AI also. InfosecTrain Trainer: You have to establish governance, right?

InfosecTrain Trainer: And it's very important InfosecTrain Trainer: govern the AI, because if you don't do that, there is going to be uncontrolled adoption of AI within the organization, which may cause InfosecTrain Trainer: cyber attackers to exploit that. A data exploitation may take place, right? People are using public AI tool to upload your company data, information, something bad may happen, right? InfosecTrain Trainer: now you need to establish the same thing, policies, guidelines, and accountability. So, there are specific standards and the frameworks which are introduced specific to AI. So, we have a NIST AI framework. InfosecTrain Trainer: We have an ISO 42001. Other than that, we have an OAF Top 10 for AI. InfosecTrain Trainer: We have one regulation also, EU AI Act, so there are a good number of things which is available to establish governance around AI, right? How you establish? First step would be discover. InfosecTrain Trainer: You need to discover what is there in your organization parameter. InfosecTrain Trainer: I hope you would have taken the screenshot of this slide. InfosecTrain Trainer: Because these two slides are very important for you people to just revise, and this is more than enough to attempt any AI questions in the exam. InfosecTrain Trainer: Yeah, someone else's seeing something? InfosecTrain Trainer: Or, like... InfosecTrain Trainer: So, first, you need to discover. InfosecTrain Trainer: Are you having your own machine learning models? Are you having your own generative AI models? What types of AI are being used? How many AI agents are built and sitting in your environment? First, you need to discover. InfosecTrain Trainer: Without having an inventory, you cannot establish a governance. InfosecTrain Trainer: Then you need to classify.

You need to classify like you do in the data, right? InfosecTrain Trainer: You need to classify which of them are critical for the business, which of them are less critical, how many of them are facing internet, how many of them, if not available, will probably have an impact on the business, how many of them trained on your organization's sensitive or confidential data. InfosecTrain Trainer: So if those models get compromised, so the attacker would be able to gain an access of the information, right? InfosecTrain Trainer: Then you need to assess. InfosecTrain Trainer: Once you classify, then you need to perform an assessment on all of them. Risk assessment, you need to categorize, then you need to approve. InfosecTrain Trainer: which is... InfosecTrain Trainer: which needs to be approved for the organization, which needs to be disapproved or not recommended, then you will establish the controls around them, right? Overall, you will put the network-related boundaries, you will put the human-related boundaries, you will put the identity and access management-related controls, right? And then you establish the monitoring. InfosecTrain Trainer: So, monitoring, also, you can establish using the SISEM, you will have the inventory tool. There are a good number of things which are available. All the new... all the security tech stack vendors are now coming with a good, good new solution, so I have also done the demo of a couple of them. Like, Microsoft recently launched called the Agent InfosecTrain Trainer: 365. InfosecTrain Trainer: Heard of it? InfosecTrain Trainer: So this is their new AI governance tool. InfosecTrain Trainer: Similarly, Palo Alto has something, Zscaler has something, right?

Even all the DLP solution providers are also coming up with the good controls around AI. InfosecTrain Trainer: Data which is being input. InfosecTrain Trainer: So, this is an overall... AI governance, at nutshell, what I wanted to cover. InfosecTrain Trainer: So... So this is more than enough to attempt any questions in the exam around AI. InfosecTrain Trainer: If you want, you can take a screenshot of this slide as well. InfosecTrain Trainer: Now, last topic of this domain. InfosecTrain Trainer: I hope you would have, so far understood the difference. Can someone tell me what is the difference between the policies, standard, and the guidelines? Fatha: Policy is, like, outcome of a strategy or ways to achieve the... like, the strategy. And then, Fatha: Guideline is operational level, guys... Standards are, like, Fatha: the NIST and all the standards that has to be configured, you know, like, Something like that. Supriya Mhatre: Policies are designed based on your organization's, oh. Supriya Mhatre: You know, internal, Objectives and procedures, and guidelines are best practices. Supriya Mhatre: to follow. And standards are something... it's a shall requirement. InfosecTrain Trainer: Okay, okay. So understanding the key difference is very important, right? Because once you see these terms in the exam, in the question, right? If you know the key difference between them, it becomes very... it will be very easy for you to reach out to the correct answer, right? First, coming to the policy. InfosecTrain Trainer: After strategy. InfosecTrain Trainer: So, strategy is something which is there for the long term. You created a strategy 5 to 6 years term, right? Then. InfosecTrain Trainer: implement that strategy, you have to create a policy.

Policy is the first document which helps you establish governance. And policies are always high-level statements. They are never, ever written in a detail. InfosecTrain Trainer: Right? You will never, ever write any kind of the technical details and all. So, if you want, you can go to your organization and read your org policies, probably your information security policy, or any other policies which is available to you. You will get an understanding how the policies are written. InfosecTrain Trainer: And policy is something which becomes an internal law and regulation, like, which everyone needs to follow. InfosecTrain Trainer: So, if an audit happens, they will check the compliance with respect to policies. If policy seems something, the auditor will come and check that is this being implemented or not. InfosecTrain Trainer: Right? InfosecTrain Trainer: And they are also mandatory, always approved by the executive. So, if the CISO is writing, he's not going to be approving it. Approving... approver would be a level up. InfosecTrain Trainer: And they need to... they help you align with respect to business objective and non-technical language, like... InfosecTrain Trainer: you are estab... you are establishing the AI governance in the organization, so first document which you should write is AI policy. InfosecTrain Trainer: Without that, you cannot establish a governance in the organization. InfosecTrain Trainer: Now, coming to the standards. Standards are something which is very specific with respect to a technology, very specific with respect to one particular domain area, and they need to adopt... need to be adopted as it is. And from standards, you create a baseline. InfosecTrain Trainer: Which is the minimum requirement from that standard, right?

Like, standard would say minimum 12 character password. InfosecTrain Trainer: Password expiry should be 90 days. InfosecTrain Trainer: These are all the standards. InfosecTrain Trainer: No hard-coded... no hard-coded secret in any code. InfosecTrain Trainer: These are all the standards. InfosecTrain Trainer: So, they are very specific... Yeah. Fatha: Sorry, like, is the standard derived from the policy, or it is based on the policies? InfosecTrain Trainer: This is based on the policies. So, policies, as I told you, is a very high-level statement. Policy which says that all the documents in the organization should be properly InfosecTrain Trainer: there should be a sensitivity label defined. All the documents should be, labeled accordingly. So, policy will say there are 4 labels in the organization. What does public mean? What does confidential? What is restricted? What is... what is internal, right? InfosecTrain Trainer: Now, on the basis of that, then you have to create a standard. InfosecTrain Trainer: Which is going to be very specific, that any document which includes this information would become a confidential document. Fatha: Okay. InfosecTrain Trainer: Right? Like, you say that all the data which is being transported will follow minimum TLS 1.3. InfosecTrain Trainer: Algorithm. This is the minimum encryption standard for all the data in motion in the organization, so... InfosecTrain Trainer: This becomes a standard. So if any system is probably following something below than this, then it means that they are violating the standard. And anything which is not InfosecTrain Trainer: in line with the standard, there should be an exception in place, need to... risk need to be accepted, approved by someone. Then only you can have it in the organization.

InfosecTrain Trainer: They are mandatory for implementation, they are technical and uniformly applied. That's why you create a baseline from the policy standard, so that the baseline is implemented everywhere in the organization. Now, coming to the guideline. Guideline. Siva Krishna Kalipatnapu: One question at standards. InfosecTrain Trainer: Yeah. Siva Krishna Kalipatnapu: So you said, in case if there is a risk, or in case if there is an exception with respect to standards. Siva Krishna Kalipatnapu: It should be accepted and approved. Approved by whom? InfosecTrain Trainer: Accepted, it's always going to be the accepted by the business owner. Siva Krishna Kalipatnapu: Okay. InfosecTrain Trainer: Always the business owner will approve it, and the approval by the someone who has approved the policy. Siva Krishna Kalipatnapu: Okay, that'll be within the company. InfosecTrain Trainer: Yeah, yeah, within the organization, not outside people. Siva Krishna Kalipatnapu: shuffle. InfosecTrain Trainer: Now, coming to the guidelines. Guidelines are something which is the recommended or the best practices. InfosecTrain Trainer: It's not necessary, it's not recommended to follow that, but guideline is something which helps you adopt something like InfosecTrain Trainer: How to set a 12-character password. InfosecTrain Trainer: How to... how to create rules in the DLP. How to formalize the sensitivity label and configure them in DLP. Likewise, the guidelines you need to create. InfosecTrain Trainer: Right? So they are discretionary in nature, they have a flexible adoption, and operationally focus. InfosecTrain Trainer: Now, Kami, understanding some couple of frameworks.

As I told, these frameworks are not tested in the exam in detail, just you should have a high-level understanding what does they mean and where they are applied. That's it. InfosecTrain Trainer: That much understanding is more than sufficient. Like, you should know that GDPR is a data protection law which applies to the European Union. InfosecTrain Trainer: HIPAA is a healthcare information-related regulation which applies in the US region. InfosecTrain Trainer: CCPA is a California Protection Act, which applies to the... any... any residents of the California state of the USA. SOX is something, Stribex-Oxley Act, which applies to the financial InfosecTrain Trainer: reporting-related controls, right? So, these are only... there are new ones which got introduced, like NIST to... InfosecTrain Trainer: is there, now we have a DORA. InfosecTrain Trainer: We have a... EU AI Act... InfosecTrain Trainer: We have a DPA, DPA, so there are a lot of new ones which came in recently. If you just have a higher level understanding, where does they apply? That's it. InfosecTrain Trainer: Now, what are the goals if you apply the framework in your organization to establish the governance? InfosecTrain Trainer: First is the cost effective. InfosecTrain Trainer: Imagine creating your own framework like NIST. InfosecTrain Trainer: how much cost you need to incur to tailor and create such a huge framework for your organization. A lot of things would be involved, a lot of effort would be involved, not a cost-effective way. InfosecTrain Trainer: So, if you adopt any framework, it helps you first InfosecTrain Trainer: align your security with respect to that framework, it helps you establish the security in a better manner, so that's why it's cost-effective. Also helps you align with respect to business.

So if you read any framework, be it NIST, COVID, or any other. InfosecTrain Trainer: you will see that it has a wide range of controls covering all the domains of the security. So, if you adopt them, it helps you align InfosecTrain Trainer: to the business requirements, right? What business want to do? You will have that. Also, help you protection assurance. So, if you say, I... my organization is fully NIST compliant, my organization controls are also fully optimized. InfosecTrain Trainer: So, it gives you a good assurance, okay? It means that my organization is C... InfosecTrain Trainer: From majority of threats, but not give you 100% guarantee, Because those controls InfosecTrain Trainer: need to be effective also, right? It's not necessary just you have shown the compliance with respect to one standard or one particular framework, you're free from all the threats, no. InfosecTrain Trainer: Then, regulatory compliance. InfosecTrain Trainer: So, regulations, what does regulations require? They will say you should have a business continuity plan in place, you should have an incident management plan, you should have a proper risk assessment practices in there, you should have an inventory of asset, you should have an inventory of all your data, you should classify it. Likewise, regulation also says. So, same thing, you will be able to show your compliance towards them using InfosecTrain Trainer: frameworks. InfosecTrain Trainer: Then you will achieve operational consistency.

InfosecTrain Trainer: So, everywhere, all the business units, all the business vertical, all the countries where you operate there, you will have a good operational consistency, and also, all these frameworks also help you measure the performance, so you'll be able to set some KPIs, KRIs, which will help you measure how effectively your organization is operating. InfosecTrain Trainer: Now, there are a couple of frameworks which are related to the architecture. InfosecTrain Trainer: Probably not now, but in... once we have the new InfosecTrain Trainer: new syllabus change, probably they will include them in detail, the Jackman and the TOGAF. InfosecTrain Trainer: Currently, it's covered at very high level, what they are, what they do, that's it. InfosecTrain Trainer: They are not covering them in detail, but probably once the new exam pattern gets changed, we will have them in detail, because they are adding an architecture as a new topic altogether, right? So there are two frameworks with respect to architecture. One is called the Jackman, another is the TOGAF. InfosecTrain Trainer: Jackman is an enterprise architecture framework, right? So whenever you establish an enterprise architecture, it actually helps you build the architecture on these five phases. Contextual, conceptual, logical, physical, and detailed. InfosecTrain Trainer: TOGAF is another open architecture framework which helps you create an enterprise continuum, resource base and the reference model. InfosecTrain Trainer: COBIT is another framework which is related to the control objective for information and related technologies. It's mainly related to ITSM-related processes.

So it's a governance framework, helps you InfosecTrain Trainer: Provide the reference model, establish the controls, objectives, management guidelines, and has the maturity models associated with that. InfosecTrain Trainer: Let's discuss some questions, yeah. InfosecTrain Trainer: Alright, let's discuss... the correct answer... InfosecTrain Trainer: Most of you got it correct. So, an organization's marketing department begins using public third-party generative AI tools to draft, copy, containing sensitive proprietary business strategy. What should the information security manager do first? Immediately block access to all public generative AI domains at a perimeter firewall. InfosecTrain Trainer: Formally report the marketing department head to human resource for policy non-compliance, conduct a risk assessment. InfosecTrain Trainer: for a data exposure to present finding to the steering committee, acquire enterprise subscription for a private generative AI platform to replace public tool. So, first thing what you will do, first you need to understand the risk, right? InfosecTrain Trainer: then you will take the actions A, B, and D accordingly, right? So correct answer here is C. InfosecTrain Trainer: A financial enterprise plans to use a third-party hosted machine learning algorithm for automated loan underwriting. From a governance perspective, what is the most critical activity before contracting? Perform a detailed algorithmic analysis of the training data set to ensure the mathematical fairness. Verify that the AI vendor data processing agreement set is InfosecTrain Trainer: by industry regulator compliance. InfosecTrain Trainer: Incorporate automated security technical scanning on SaaS vendor and APIs and endpoints.

InfosecTrain Trainer: Require all vendor data scientists to hold active security management certification. InfosecTrain Trainer: So here, the correct answer, the best answer would be this. InfosecTrain Trainer: Right? InfosecTrain Trainer: Performing a detailed algorithmic analysis is not feasible, right? Very technical in nature. Incorporating automated scanning SAS vendor API, just talking from the one perspective, require all vendor data scientists to hold active security management certification. This will not help you if they have the InfosecTrain Trainer: certification. InfosecTrain Trainer: Last one, an enterprise experience. InfosecTrain Trainer: Enterprise experienced a... InfosecTrain Trainer: A sudden surge in an independent AI integration across business department, adoption of a shadow AI. Establish sustained oversight, what should the security manager recommend first? InfosecTrain Trainer: Draft a specific standalone AI security policy and publish it on the employee portal. Implement automatic endpoint software discovery to terminate unauthorized AI runtime. Charter a cross-functional AI steering committee with business, legal, and risk leader. InfosecTrain Trainer: purchase an expensive artificial intelligence posture management security tool. So, first, you will establish a InfosecTrain Trainer: steering committee, which will help you take the decision to establish the governance and the oversight, right? Now, that steering committee will provide the oversight to establish the policies. InfosecTrain Trainer: Then they may recommend, okay, let's...

InfosecTrain Trainer: do a POC and adopt new tools, and if needed, terminate the... any unauthorized AI tools, right? So, first step would be C, then A, B, and A.

InfosecTrain Trainer: These are the... some of the example kind of questions you may get in the exam, right, on the AI. InfosecTrain Trainer: This is a very important slide... Right? With... InfosecTrain Trainer: in lines the difference between the gap assessment, the risk assessment, and the BIA. InfosecTrain Trainer: You will get minimum 10 to 15 questions in the exam. InfosecTrain Trainer: And people will... people do get confused between these terminologies, right? So the risk assessment always happens before starting any initiative. InfosecTrain Trainer: Any project, any onboarding, any tool, any initiative, anything you are doing, you always do a risk assessment to understand what are the risks, and the outcome is to reducing the risk to an acceptable level. InfosecTrain Trainer: Gap assessment is always wherever you see something talking about the current state versus the desired state. InfosecTrain Trainer: that the gap assessment is being done. Here, you will identify the gaps between the current and desired state, and outcome would be a roadmap. InfosecTrain Trainer: BIEA is actually done to determine the criticality, so this particular criticality will help you understand the recovery priorities, which particular business need to be recovered first, which is the next, that priority you will get from BIA. InfosecTrain Trainer: Now, coming to the mattresses, KPIs, KGIs, and the KRIs. We have referenced them multiple times, right? InfosecTrain Trainer: So, let's take a simple example. However, we have a very detailed topic in the domain 3 around this, where we will discuss the detailed examples and everything, how to create these, what are the principles and the things to follow when you are creating the mattresses. We have a distinct topic.

So here, we'll be just touching upon them at high level, right? InfosecTrain Trainer: Goal means something which you are InfosecTrain Trainer: Tracking or checking with respect to the objectives. InfosecTrain Trainer: Your objectives coming from the policies, objectives coming from your strategy, objectives coming from your org strategies, anything related to that are called the key goal indicators. InfosecTrain Trainer: Right? Here you can see the examples, like percentage of systems compliant with the security baseline. InfosecTrain Trainer: So you... so achieving the security baseline in the organization is a key goal, right? InfosecTrain Trainer: Vulnerability remediation completion rate. You want to have a better InfosecTrain Trainer: the security incident impact reduction, program maturity level. Now, coming to the KPIs, KPI is something which tells you the performance of one particular business. InfosecTrain Trainer: one particular process, one particular thing, right? So, one last time, we discussed one particular example where there was a confusion, right? That there is a phishing campaign in the organization, number of... InfosecTrain Trainer: People attended the training. InfosecTrain Trainer: The number of... InfosecTrain Trainer: people clicked on the phishing link. Someone was saying that this is also KRI. KRI is something which predicts the future risk. InfosecTrain Trainer: directly if there is a KRI which can tell you that if this is the KRI, this is the future risk. That is a KRI. Does this particular thing predict any future risk to you immediately? InfosecTrain Trainer: How many people attended the training? Does it predict any future risk? No. InfosecTrain Trainer: This is just telling you the performance of a process.

Okay, we have a security training in place, we have a thousand employees, they all are supposed to attend, 80% of them attended. It means InfosecTrain Trainer: 80% is the efficacy of your train mature... your overall security awareness training process, right? InfosecTrain Trainer: But once, after the training, you launch a phishing campaign where you saw InfosecTrain Trainer: 20% of the people clicked on the phishing link. This is directly a KRI, because it tells you the risk that these many people are the risky one, they are not able to understand the outcome of the training, and if actual phishing email comes, they are the... InfosecTrain Trainer: People, they may click there, and there is a possibility of risk, possibility of a breach, possibility of any malware getting embedded in the organization, right? InfosecTrain Trainer: So, KPI is something like mean time to detect a security incident. InfosecTrain Trainer: Telling you the performance of your security incident detection process. InfosecTrain Trainer: Patch deployment timelines, tell you the performance of the patch deployment process. Number of people attended the training, or what is the completion of the security awareness to tell you the performance of the awareness training process. InfosecTrain Trainer: how many people... much excess review has been completed tells you the performance of this. But KRI is talking about the risk. InfosecTrain Trainer: Lao... Total number of vulnerabilities InfosecTrain Trainer: Detected is, actually a KPI bus, but total number of unpatched critical vulnerabilities becomes a KRI, because if those critical vulnerabilities are not patched. InfosecTrain Trainer: There is a risk.

InfosecTrain Trainer: Some attacker may get, get, they are able to discover the exploit for that vulnerability, and they'll be able to get into your system. Failed access attempt. InfosecTrain Trainer: security policy exceptions. InfosecTrain Trainer: If there are a lot of policy exceptions in your organization, it means there is a risk, because people are not adhering to the policies. Third-party security rating is a KRI. So this is the key difference between KGI, KPI versus KRI. InfosecTrain Trainer: Now, when you create these mattresses, you need to make sure these basic principles are being adhered to. First thing, they should always be aligned with respect to the audience. You will not report InfosecTrain Trainer: The vulnerability details, or how effective your incident management process is. InfosecTrain Trainer: Or how... what kind of the malwares are being detected by your anti-malware software to your board of directors? InfosecTrain Trainer: It does not make much sense to them, right? InfosecTrain Trainer: How much your organization is compliant with respect to a particular standard? What is the maturity level of your security? Those are going to be the better mattresses which you can report to the senior leadership. InfosecTrain Trainer: So, always need to be aligned with respect to audience. Measurability. InfosecTrain Trainer: It... all mattresses should be always provide you some quantitative measurement. InfosecTrain Trainer: If there is no quantitative measurement coming out of that particular matrix, it's not a good matrix, right? So that's why it should be always quantifiable. InfosecTrain Trainer: So that you get some data which is coming out of that matrix. Then, actionability.

InfosecTrain Trainer: If some matrix you design and there is no further action can be taken on it, then also it's not a good matrix. So all the matrices which you get, there is some action involved, right, so that you can improve upon it. InfosecTrain Trainer: If there is a 20% phish click rate, so you can do something about it, right? Probably, you need to engage with those people properly, you need to make them understand how to distinguish between a phishing email, you need to probably make your training more interesting. So there is action involved. InfosecTrain Trainer: Then, it should be relevant. InfosecTrain Trainer: whatever security program you are running, whatever initiatives you have in the organization, there should be relevance with respect to the KRIs, right? So, something which helps you track the progress. InfosecTrain Trainer: Then, trend analysis. Always, it should show the trend. That's why in your organization, when you see the Power BI dashboard, or probably if you're using the Excel, you will be able to see a trend, right? Month on month. InfosecTrain Trainer: How much there was a decrease, how much there was increase, so there's a trend. InfosecTrain Trainer: Now, we will be touching upon this topic at very high level here. However, we are about to start the next domain, where we will discuss this in detail, right? InfosecTrain Trainer: So there, So, risk management. First thing coming to the risk. What is risk, actually? Fatha: some, unpredictable That could, event that could... Fatha: Cause, negative effect on... or maybe even sometimes positive effect on our Goals, business, outcome. Pudir: In an unprecedented event that may affect the organizational purpose. Johnny Souriar: Some events, which is stopping to achieve the business objectives.

InfosecTrain Trainer: Yes. So, risk is something which is a future event, which has not yet occurred, right? Become a risk. Something which has an uncertainty, which is causing uncertainty on achieving your objectives. InfosecTrain Trainer: Anything which causes uncertainty in achieving your objectives becomes a risk. InfosecTrain Trainer: Keep note in mind. InfosecTrain Trainer: Any risk, you name it. InfosecTrain Trainer: You will always see there is uncertainty in achieving some objective, that's why it becomes a risk, right? InfosecTrain Trainer: Now, what is the overall risk management process? So, this is the overall risk management process, which we'll discuss in detail in the next domain, and complete domain is placed around this. InfosecTrain Trainer: So, first you identify risk, then you analyze those risks, then you trade those risks, right? InfosecTrain Trainer: So, first step is to identify all the assets which is there in your organization, right? InfosecTrain Trainer: You need to take an inventory of all the assets. Once you have the inventory, then you will identify the threats against them. So, there are threat assessment techniques, like you would have heard about the Stride InfosecTrain Trainer: Pasta. InfosecTrain Trainer: Had someone heard about this, right? SrinivasanJ: Straders. InfosecTrain Trainer: Spoofing, tempering, repudiation, information disclosure, denial of service, and elevation of privileges. Right. InfosecTrain Trainer: Similarly, there is one more called the pasta. InfosecTrain Trainer: These are the framework which helps you identify the threat against a set or against a process. InfosecTrain Trainer: Once you have a list of threads, then you will identify the vulnerability.

So, vulnerabilities can be identified using a technical process which all organization has, right? You might be using the call list, Nessus, or any vulnerability assessment tool. InfosecTrain Trainer: which helps you identify the technical vulnerabilities, but there are other things, right? The vulnerability may also get identified through audit. InfosecTrain Trainer: Through, process analysis, through security review. InfosecTrain Trainer: So that's how you identify the vulnerabilities. InfosecTrain Trainer: Now, any... Thing, where there is a threat InfosecTrain Trainer: Which is able to exploit a vulnerability, it becomes a risk to you. InfosecTrain Trainer: there is a SQL... injection... InfosecTrain Trainer: Vulnerability in a web application. There is a threat actor who can exploit this, becomes a risk. InfosecTrain Trainer: Simple. InfosecTrain Trainer: Now, once you have the list of all the risks. InfosecTrain Trainer: So you will get a huge list

of the risk, right? But can you treat all of them? No, it becomes very expensive. So you need to analyze them and prioritize them so that you can only focus on those which are the high priority one, right? InfosecTrain Trainer: So, there are two techniques to this. One is a qualitative. Quantitative, there is one more, which is in between this, called the semi... InfosecTrain Trainer: quantitative. InfosecTrain Trainer: So, qualitative means you use the qualitative technique, right? So, any risk which you identify would be measured on two parameters. InfosecTrain Trainer: probability, Or likelihood of happening. And second thing is the impact. InfosecTrain Trainer: What is the probability of occurrence, or the likelihood of happening this risk, and what is going to be the impact, right?

Like, suppose if I talk about this example, XQL injection vulnerability a threat detector is able to exploit, you say the probability of happening this is inequalitative, is high. InfosecTrain Trainer: And impact, if this gets compromised, if that web application is very important and critical in nature, would be high. InfosecTrain Trainer: So your risk become high. InfosecTrain Trainer: So, this is a qualitative technique. InfosecTrain Trainer: In a semi-quantitative technique, you replace these particular qualitative parameters with the numerical values. InfosecTrain Trainer: So, high being treated as probably 4, critical being 5, Moderate being 3, low being... InfosecTrain Trainer: tool, a very low being one, likewise. Similarly, you do with the impact, and then you substitute in a heat map InfosecTrain Trainer: You will create a... InfosecTrain Trainer: the matrix you will substitute once you get that rating, and then you will calculate the risk. Become semiconductive. InfosecTrain Trainer: Quantitative is where you use the quantification, or you use the mathematical formula to calculate and analyze the risk. I'll not go into detail now, because we have a detailed topic around this in the next domain. InfosecTrain Trainer: So, there are... there are measurements, like. InfosecTrain Trainer: Annuous loss expectancy, single loss expectancy, asset value, annual rate of occurrence, all these things we will discuss in the next domain, right? Once you have the risk analysis done. InfosecTrain Trainer: then there are 4 treatment methods, which you can choose. Accept means anything which is below your appetite level, you will accept. InfosecTrain Trainer: Even after the treatment, whatever risk is left over, you will, as such, accept.

Transfer something which has a InfosecTrain Trainer: high impact. InfosecTrain Trainer: But low probability you will try to transfer. A good example is your health insurance, car insurance. InfosecTrain Trainer: So, happening, or the probability of happening, health-related issues is low. But whenever it will happen, you know the impact is going to be very high on your pocket, right? InfosecTrain Trainer: Because hospitals' bills are so expensive, that's why you take a health insurance. Similar with the car. InfosecTrain Trainer: Happening of an incident with your car is low, but whenever something happens, then the damage cost and all those costs which you need to pay to the showroom is going to be the huge, so that's why you take an insurance, similar with the cyber insurance. InfosecTrain Trainer: Mitigate means when you deploy some control to reduce the risk, like SQL injection vulnerability is there, you deploy a patch to fix it. InfosecTrain Trainer: If there is no fix available at this point of time, you place this particular web application behind a web application firewall, you have some other rules, you have a proper access control risk. InfosecTrain Trainer: You proper have an input validation, so you mitigate the risk. Avoid means something which is beyond your risk appetite and the tolerance level. InfosecTrain Trainer: You will avoid having such kind of risks. InfosecTrain Trainer: A very hypothetical example. Today, the ISACA is costing... charging you \$760 for a certification exam. Tomorrow, if they charge you \$10,000, how many of you will go and take this exam? I feel no one will. InfosecTrain Trainer: It's beyond your risk appetite, right?

Because if you fail in the exam, the money which you will lose is way beyond your appetite level, so you will never ever take this risk. InfosecTrain Trainer: So you will avoid. InfosecTrain Trainer: This is the overall risk management process, which we'll discuss in the next domain. InfosecTrain Trainer: So now, coming to the appetite versus tolerance, right? We discussed this also with an example, right? Your monthly expense example. So, appetite InfosecTrain Trainer: Intolerable risk or risk capacity is the maximum level of risk which organization is willing to take. InfosecTrain Trainer: Appetite is always set at a project, or a process, or the business level, right? How much risk that they can take. So, like, suppose you are, having one project where you are creating a, probably a web application. So, web application, to create the web application, the budget which organization has set is a \$1 million. InfosecTrain Trainer: Dollar is a budget. InfosecTrain Trainer: This 1 million becomes a risk capacity, and this particular thing needs to be delivered within 2 years. InfosecTrain Trainer: this two-year timeline also becomes your list capacity. You cannot go beyond this 2-year, because then the... you will either lose business, or suppose you are making this particular platform for your... one of your clients, so they'll charge you fine and all, right? InfosecTrain Trainer: Now, you will set a risk appetite. If there are any issues and also, you will set the timeline as a InfosecTrain Trainer: Probably the 18... 2... 20 months? InfosecTrain Trainer: This becomes your... InfosecTrain Trainer: risk appetite, right? So, 18 months being the risk appetite, 20 months being the risk tolerance.

You cannot go beyond 20 months, so that you have a buffer available for the 4 months with you. InfosecTrain Trainer: So, for the budget side, you will keep the budget, so that you will say, okay, 1 million is the budget which is set aside, but we will try to complete it within the \$900,000. InfosecTrain Trainer: Only. InfosecTrain Trainer: So, becomes a risk appetite. InfosecTrain Trainer: So, this is how the risk capacity and appetite is calculated. InfosecTrain Trainer: We have a detailed topic, because next domain is around this only, so I'm covering it at high level, so this is a mind map of Domain 1, which all of you can take a screenshot of it. Also, I will share you one mind map, which I have prepared for all of you. InfosecTrain Trainer: Yes, so this is an image which I have shared in the chat. InfosecTrain Trainer: window. InfosecTrain Trainer: This is a Domain 1 mind map, which I've created. InfosecTrain Trainer: Which will help you a day before exam to revise all the topics. InfosecTrain Trainer: At high level, it covers all the things what we discussed in this domain. Siva Krishna Kalipatnapu: One question I have... InfosecTrain Trainer: Yeah. Siva Krishna Kalipatnapu: for the information security guards, only for this particular domain, if I have to get, Siva Krishna Kalipatnapu: specific questions, the exam practice questions, what will be the place that I have to visit? InfosecTrain Trainer: It's already there in the ISACA QA manual. You also have the... the... the simulator, or the Domain 1 questions provided by the InfosecTrain. InfosecTrain Trainer: For this domain? InfosecTrain Trainer: Which you can access via your student portals. It's already there, shared with you. Siva Krishna Kalipatnapu: Okay, that's in the website, right? Not in the Google Drive.

InfosecTrain Trainer: In the Google Drive, also, you have the QA manual from the ISACA, official QA manual, which you can use. Siva Krishna Kalipatnapu: You're good. Siva Krishna Kalipatnapu: Sure, thank you. I'm sorry I would have missed earlier. InfosecTrain Trainer: Yeah, no problem. InfosecTrain Trainer: Alright, then let's go to... the next domain... InfosecTrain Trainer: So, we are now beginning with the domain 2. Domain 1 is done. InfosecTrain Trainer: So Domain 2 is about the risk management, right? So this... these are the high-level topics which we will touch upon. Risk, threat landscape, vulnerability control deficiency analysis, risk assessment, evaluation analysis, information risk response, risk monitoring, reporting, and communication. These are the topics which you will touch, and this is how the domain is, InfosecTrain Trainer: distributed between the two particular sections. One is the information security risk assessment, another is the information security risk response. InfosecTrain Trainer: dome... InfosecTrain Trainer: And then this is a high-level, kind of mind map of this domain. If you want, you can take a screenshot of this. However, I will share one more mind map with you at the end. InfosecTrain Trainer: So this is how... These are the high-level topics which we'll be touching upon in this particular domain. InfosecTrain Trainer: Also, if you want, I can... Probably copy this and share. InfosecTrain Trainer: In the chat. InfosecTrain Trainer: Let me just... I've shared this. InfosecTrain Trainer: Yeah, so domain carries a weightage of 20%, approximately 30 questions you can expect from this particular domain. InfosecTrain Trainer: Yes. Now, it's very important to understand the key difference between the risk versus incident.

InfosecTrain Trainer: What is the key difference between the risk versus incident? subaveena pugalethi: Risk is something that could happen, an incident is something that has already occurred. Siva Krishna Kalipatnapu: I think it's vice versa. Risk is about to happen, and incident is... Happened. InfosecTrain Trainer: Risk is something which has a possibility or a probability of happening in the future, a possibility of occurrence. Incident is something which is already happened or occurred. InfosecTrain Trainer: Right? InfosecTrain Trainer: So, if I say, there is a risk of a ransomware attack against my enterprise. InfosecTrain Trainer: So, it has not yet happened. There is a possibility of a ransomware attack, which may happen. For this, what I will do, I will establish a good number of cybersecurity control, I'll purchase the cyber insurance, I will make sure there is a data backup available for my key critical systems, right? So that I can restore and recover in case of... I will make sure that there is a proper InfosecTrain Trainer: BCPDRP plan in there. So... InfosecTrain Trainer: These are the controls which I have to potentially mitigate the ransomware-related risk. But now. InfosecTrain Trainer: Tomorrow, there is an active cyber attack. Someone probably InfosecTrain Trainer: sent a phishing email with a payload to one of your employees, your employee clicked on the payload, some malware got installed and downloaded on your end user machine, and the attacker could, took a control to that. So, becomes an incident. InfosecTrain Trainer: So, risk is something which has a potential for loss, damage, or compromise based on threat likelihood and the vulnerability for the exposure.

InfosecTrain Trainer: An incident is something which is an actual security event that has already occurred. InfosecTrain Trainer: Where a response and the remediation is required immediately. InfosecTrain Trainer: Now, if you see, all the risk which happens, always you need to make sure that you InfosecTrain Trainer: able to convert that into opportunities for gains. How? InfosecTrain Trainer: You are a bank. InfosecTrain Trainer: You know the banking industry is

very prone to, various cyber attacks. InfosecTrain Trainer: And if you get InfosecTrain Trainer: Those cyber attack, active cyber attack, there is a data breach, there is a, there is a, InfosecTrain Trainer: There is a disruption in your services, you will end up paying a hefty regulatory fines. InfosecTrain Trainer: You will end up losing business. InfosecTrain Trainer: You will lose the trust. InfosecTrain Trainer: So, these are all the things which you will face. So, if you keep your organization safe, secured, your controls are fully optimized, you will InfosecTrain Trainer: Have an opportunity for gains, right? InfosecTrain Trainer: So that's why sometimes risk management also helps you do this. InfosecTrain Trainer: So you have opportunity for gain, because if your competitor banking industry is having the cyber attack, but you are not, then you have a high potential that the customers and consumers would be turning to you, rather than going with them. InfosecTrain Trainer: Then, having a risk management helps you reduce the number of vulnerabilities in your system. InfosecTrain Trainer: Be it your system, platform, technical vulnerabilities, any process-related vulnerabilities, so risk management will help you do that, and also reduce potential for loss.

InfosecTrain Trainer: So, even if tomorrow an attack happens, if you have a good resiliency plan, crisis management plan, BCBDRP plan, your incident management team is well trained, they know their duties and responsibilities correctly and properly, they will quickly InfosecTrain Trainer: recover and quickly hand over a system for the operations, so you will have a less amount of loss with respect to your business operation, with respect to trust. InfosecTrain Trainer: All those types. InfosecTrain Trainer: So, risk does not always help you protect, it also helps you realize the opportunities, and also help you reduce the loss. InfosecTrain Trainer: But ultimate goal of the risk management is what? InfosecTrain Trainer: If I ask you, it's basically... reduce... Risk, too? Fatha: Acceptable. InfosecTrain Trainer: acceptable level. InfosecTrain Trainer: Because you cannot eliminate the risk, that is not at all possible. InfosecTrain Trainer: you put any number of controls, any number of sophisticated tools, technologies, whatever you can do, you establish any number of processes, you cannot 100% eliminate the risk. Maybe you can reduce the probability and likelihood to a very low level, so that you can manage from there. InfosecTrain Trainer: Now, risk management, it does not only happens within cybersecurity. InfosecTrain Trainer: All the organization has a risk management program in place. InfosecTrain Trainer: Right, so there is an enterprise risk management program, which all the organization runs. InfosecTrain Trainer: Right? So that enterprise risk management programs help organization protect and govern the risk management-related activities within the enterprise, right? So... so there, what are the key contributors to that? There is going to be absolutely the cyber risk.

InfosecTrain Trainer: IT risks, Compliance risk. InfosecTrain Trainer: Then you will have the... InfosecTrain Trainer: Then you will have the operational risk, Then you will have the... finance risk. InfosecTrain Trainer: business risk, likewise, legal risk. You can have any number of different, different risk categories within the enterprise risk management framework, right? But the core to this would be risk assessment. InfosecTrain Trainer: You need to assess these risks, you need to understand these risks, then only you will be able to treat, mitigate, and reduce them to an acceptable level, right? InfosecTrain Trainer: And you need to understand the evolving enterprise landscape, right? So, in enterprise, there is always multiple things which are happening, right? There are market-related factors, there are geopolitical factors, there are technology-based changes which are happening. Those may impact you due to the new kind of threats InfosecTrain Trainer: being, there in the environment due to technological advancement. Your competitors are doing something that may impact you. So, always the enterprise landscape is ever-evolving. InfosecTrain Trainer: And to have a better risk management within the organization, you should always have a good support from the management, because they are the one, they will provide you the adequate amount of funding, support. InfosecTrain Trainer: Right? They are going to be helping you purchase the cyber insurance, and give you funding for those additional controls to operate it. You will require some resources, training. InfosecTrain Trainer: People, everything, they are the one, they'll support you. InfosecTrain Trainer: And to achieve it, you have to always understand the nature and extent of the risk information.

InfosecTrain Trainer: What are the risk data, type of risk you have, what kind of threats, vulnerabilities, consequences they have. You should understand that. You need to have a potential impact on enterprise activities. That is very important. InfosecTrain Trainer: If ransomware happens, what kind of impact it will have? If DDoS attack happens against my critical business application, what kind of impact it will bring? InfosecTrain Trainer: If tomorrow there is a power failure in one of my data center, and data center is not available, what kind of potential impact it will bring on my enterprise activities. So that potential impact you should understand, and also you need to associate them with the financial implications. InfosecTrain Trainer: If this particular business is not available for one day, how much impact I am getting? How much million dollars I will lose? InfosecTrain Trainer: and also requires you to change across enterprise. Sometimes the risk management will require to have some culture, some basic InfosecTrain Trainer: Methodologies or basic things, what you do, the way you perform, you need to do those changes also. InfosecTrain Trainer: Now, what are the factors which affect the enterprise risk management? First one is the culture. InfosecTrain Trainer: If you are a startup, You will have a high-risk appetite. InfosecTrain Trainer: You will probably not, have a proper governance in place, you will not let, tell your employees what tools to use, you will just tell them, okay, do whatever, we just want our business to grow. InfosecTrain Trainer: So, this is one culture. But you are a very well-established organization, probably 50 to 100-year-old organization, who has a widespread business across the globe.

InfosecTrain Trainer: Can you do The same thing what a startup was doing, you cannot. InfosecTrain Trainer: Because a single attack, single failure, single non-compliance issues will put you on a multiple InfosecTrain Trainer: Regulatory fines. Also, you will end up losing the business, customer trust, and... InfosecTrain Trainer: Have a loss of revenue. InfosecTrain Trainer: Then the mission and the objectives, what organization want to achieve. InfosecTrain Trainer: Right? Organization want to expand the business in the new country, organization want to adopt a new set of technologies, controls, tools. So anything what organization want to do differently, that will also have an impact on the enterprise risk management. Then the structure. InfosecTrain Trainer: So, so we discussed about the structure, right? Centralized structure, Decentralized structure. InfosecTrain Trainer: hybrid... Yes, for the... Siva Krishna Kalipatnapu: It's the unknown, yes. InfosecTrain Trainer: Yes, yes, so all of these have a different kind of impact from the risk perspective, right? Centralize helps you, helps you provide a better level of consistency, central level of controls, better level of compliance with respect to policy and the strategies. InfosecTrain Trainer: Decentralize, help you with the better level of compliance with respect to the local rules and laws, and some autonomy given to the local leaders. Hybrid InfosecTrain Trainer: balance both of them. So, all of them have some different... InfosecTrain Trainer: consequences, different kind of risk involved with this. So, those structure, what kind of structure the organization operate, that will also impact. Then the leadership support.

InfosecTrain Trainer: If your leadership don't care about the risk management, they do not give you funding for those initiatives, how you will be able to improve your risk management posture, you cannot, right? InfosecTrain Trainer: But in an organization, if your leadership is supportive of it, they are providing the good funding to the risk management activities, then you will be able to gain that. Loss absorption. InfosecTrain Trainer: So, how much revenue your organization generates, what is the total, net worth of the organization, what is the total valuation of the organization? On the basis of that, how much InfosecTrain Trainer: Loss you can absorb. InfosecTrain Trainer: If there is a \$2 million impact due to this particular activity, will you be able to absorb it easily? InfosecTrain Trainer: that loss absorption capability also should be there, then the kind of product and services you operate in. So every organization, manufacturing has a separate risk, InfosecTrain Trainer: IT and the software product organization has a separate risk, consultancy has a separate risk, banks have a different kind of risk, healthcare industry has a different kind of risk. So, kind of product and services you operate in, you will have a different risk. InfosecTrain Trainer: Suppose you are a food manufacturing, so always food items are perishable in nature, right? InfosecTrain Trainer: So if you do... there is a risk, if probably there is an impact on your supply chain activities, your product probably get, stuck in your warehouse, so your lifespan of that product is gone. InfosecTrain Trainer: Then the processes, the kind of processes you have, and the organizational practices.

Like, like, you have a good ethical practices being followed, you have a good strategy, policies, and everything in place, so all these things are the factors which affect the enterprise risk management. InfosecTrain Trainer: Now, when you want to build a very effective risk management within the organization, you need to make sure, first thing, to build a culture. InfosecTrain Trainer: First thing is the culture, so that each and every employee in the organization should know their responsibilities, they should know that, what are the things they have to do. InfosecTrain Trainer: Right? InfosecTrain Trainer: like... In your organization, also, once you do normal awareness training, they highlight this, right? InfosecTrain Trainer: if there is any workplace safety-related risk, you should always report and tell them, right? Suppose there is a... there is a open wire hanging around somewhere, if there is a... there is a floor which is slippery in nature, if some... something which is broken. InfosecTrain Trainer: Which can have a potential impact. InfosecTrain Trainer: Such kind of things you have to identify, and that comes from a culture. InfosecTrain Trainer: If your leadership team always highlights this. InfosecTrain Trainer: They say that if you click on the phishing links more than two times, then it will have impact on your annual performance, so this reflects the culture. InfosecTrain Trainer: Then comes the mission alignment. InfosecTrain Trainer: You need to ensure that the risk-related controls Support the business rather than Making business to operate difficult. InfosecTrain Trainer: That's why the information security control should not be too restrictive in nature, so that business is not able to function and operate.

InfosecTrain Trainer: So you, earlier in your organization, the employees has access to all kind of AI-related tools. Suddenly, you said, no, you cannot use it. InfosecTrain Trainer: This is the only AI which you can use. We have purchased one enterprise license, and suppose that particular enterprise license software has... do not offer the kind of capabilities those other tools used to give, so... InfosecTrain Trainer: It will have an impact on the mission, right? Then the governance structure. InfosecTrain Trainer: What kind of clearly defined roles, responsibilities, all the accountability framework, if you have, that will also help you establish a good risk management practices. InfosecTrain Trainer: Now, this diagram. So, we already discussed at a high level in the previous, domain, but let's discuss in the detail. InfosecTrain Trainer: How do you identify assets? InfosecTrain Trainer: Right? InfosecTrain Trainer: So, there are two types of assets. First is the InfosecTrain Trainer: tangible. InfosecTrain Trainer: And non-tangible assets. InfosecTrain Trainer: So, what are the tangible assets? Tangible assets, which are the physical hardware, physical systems which you can touch, you can feel, you can look, you can account for them. InfosecTrain Trainer: Like, your number of endpoint equipment, machines, your office buildings, your data centers, the servers which are placed inside those data centers are the tangible assets. Non-tangible assets, which are virtual in nature, which are InfosecTrain Trainer: your data. InfosecTrain Trainer: your network security controls, your identity and access management related controls, right? All of those are non-tangible in nature.

InfosecTrain Trainer: So, first, you need to create a... InfosecTrain Trainer: A very extensive inventory of your tangible and non-tangible assets, and also with the InfosecTrain Trainer: type of money they involve, right? You need to define one asset value to InfosecTrain Trainer: all those assets, so that you understand how many of those are very critical in nature. If those assets are gone, how much impact the organization will have. InfosecTrain Trainer: Once you have that, then you need to identify the threats with respect to that, right? So, I discussed about this, right? InfosecTrain Trainer: spoofing, tampering... InfosecTrain Trainer: repudiation... Information, disclosure, Denial of services, Elevation... Oh... privileges. InfosecTrain Trainer: So, any asset you take, Suppose the asset is a web application. InfosecTrain Trainer: So that is an asset which you have taken for the threat InfosecTrain Trainer: mapping with respect to Strite Framework. Now, you will see that how many of the spoofing-related threats this has. InfosecTrain Trainer: What are the tampering-related threats which apply to this? InfosecTrain Trainer: what are the techniques which repudiation-related attacks can be done? Then from the information disclosure perspective, denial of services, elevation of privileges, and then you create a list of those threats against that particular InfosecTrain Trainer: asset. InfosecTrain Trainer: So, that's how you get the threats. InfosecTrain Trainer: So, there is a separate threat hunting InfosecTrain Trainer: Someone told that someone is from SOC, right? InfosecTrain Trainer: There's a specific, function in the organization known as a threat hunting. Sandeep Saxena: Yes, yes, I was feeling that.

InfosecTrain Trainer: So, threat hunting is a function in the organization who InfosecTrain Trainer: it looks for all the threat actors which are active in the world. Like, there are some ransomware groups, right? There is a very popular one, Gentleman ransomware group, there was an Akira InfosecTrain Trainer: which was there previously popular. Likewise, there are a number of. Then you see that that particular threat actor, how the threat actor can impact your organization. So all these threat actors have some techniques or a method they use to get into your organization. So you know InfosecTrain Trainer: Those, techniques, and then you, use the cyber kill chain. InfosecTrain Trainer: Which we'll discuss. So, cyber kill chain is a method where you kill that chain which attacker is trying to establish to get into the organization. So that's how you do that. Now, coming to the vulnerabilities. InfosecTrain Trainer: So, there are vulnerability assessment, you need to identify the vulnerabilities against these assets, right? So you already do the vulnerability scanning, which is a technical method. InfosecTrain Trainer: You have a call list, NSS and any other tools which you used for this. InfosecTrain Trainer: Then you have other methods. So, first thing is the technical, where you do that. Next is the through process, through audit, you can identify vulnerabilities. Through security. InfosecTrain Trainer: review, you can identify vulnerabilities, right? So that's how you identify the vulnerabilities within the process. InfosecTrain Trainer: Once you know that there are vulnerabilities, there is a vulnerability in a system. InfosecTrain Trainer: There is a threat actor who can exploit that vulnerability, becomes a risk.

InfosecTrain Trainer: So there is unpatched vulnerabilities. Threat actor is one who is able to use that technique and exploit that, so it becomes a risk of disclosure. InfosecTrain Trainer: Now, there are two methods to analyze this. One is a qualitative, another one is the InfosecTrain Trainer: semi-quantitative and the quantitative. Qualitative is where you use the qualitative technique. So, any vulnerability threat, there is a risk, so this risk, you will evaluate on two parameters. InfosecTrain Trainer: So, what are the two parameters? One is the... Prohib... probability or likelihood? InfosecTrain Trainer: And next one is the impact. InfosecTrain Trainer: So, in the qualitative probability and impact, you will give them a rating. So, probabi- qualitative, you will say. InfosecTrain Trainer: critical. You will have some definition associated with that. InfosecTrain Trainer: Hi. InfosecTrain Trainer: Moderate and low. InfosecTrain Trainer: So, this is how you give the rating to the probability or likelihood also, to impact also, and then you, you put it in a matrix form. InfosecTrain Trainer: Critical, critical becomes a critical, critical, high becomes a critical, high, high becomes a high, high, moderate becomes high. Likewise, you give, and then you create a heat map where you place all of these. InfosecTrain Trainer: And then you see that where this risk stands. InfosecTrain Trainer: In the semi-quantitative, you replace either of or both the values with the numerical values, right? So you say the critical becomes 5, high becomes 4, moderate becomes 3, low becomes 2, and then you will do the same for the impact, you will multiply them, and then you associate them in a chart, and then you see that what is the rating, so this becomes a semi-quantitative.

InfosecTrain Trainer: Quantitative is something which is basically a numerical value. So there is something called the single loss expectancy. Single loss expectancy means asset value InfosecTrain Trainer: Multiplied by exposure factor. InfosecTrain Trainer: And then you calculate the annual loss expectancy, means single loss expectancy multiplied by annualized rate of occurrence. What it is, let me give an example. InfosecTrain Trainer: You have one data center. InfosecTrain Trainer: This particular data center is in... in a region that... that region is very prone to a kind of earthquakes. InfosecTrain Trainer: So there is a region in the world called the Rings of Fire, part of it, where the Indonesia, Japan, and all those countries sits, right? So, these all countries are very prone to get a kind of a... InfosecTrain Trainer: earthquakes, which keeps happening around these countries. Thailand. InfosecTrain Trainer: all these countries, right? So your data center is one of those countries which is very prone to, InfosecTrain Trainer: Natural calamities, like earthquakes, tsunami, or something may happen, right? InfosecTrain Trainer: So, on the basis of this, you will have some... you will create the couple of mattresses. How? First thing is the asset value. You say, my data center total value is \$1 million. That is the total asset value. InfosecTrain Trainer: If one time. InfosecTrain Trainer: an earthquake happens. How much of my asset would get exposed, or how much of my total asset value would be lost? InfosecTrain Trainer: So if one time an earthquake happens, I would say the 50% of my asset would be gone. InfosecTrain Trainer: 100% cannot go, because I have my building designed it in a such manner so that it can protect itself.

So... so my single loss expectancy becomes of 500,000. InfosecTrain Trainer: 1 million multiplied by 50% becomes a \$500,000. This is a single loss expectancy. Now, coming to the annualized loss expectancy, in an hour, how much loss I will have. InfosecTrain Trainer: So, it becomes SLE multiplied by annual rate of occurrence. How many times an earthquake can happen? InfosecTrain Trainer: I will see the past data, I will see the meteorological data, I will analyze from past 10 years, 20 years data, and I'll say, okay, every year, two times, there is a high probability earthquake may happen, so... so ALE becomes a \$1 million. So if... InfosecTrain Trainer: So this much is the loss I will bear in a year. However, we will discuss in a detail, there is a detailed topic around it, so this is how you follow the quantitative. InfosecTrain Trainer: Now, coming to the treatment, once you have this, you will... you probably, earlier, you have a 50 risk. subaveena pugalthi: After... InfosecTrain Trainer: Yeah. subaveena pugalthi: So, is the risk analysis before the risk treatment, or, like, after the risk treatment, we do the analysis and get the values of ALE and SLE? InfosecTrain Trainer: How come you do the treatment before doing analysis? InfosecTrain Trainer: So, treatment options would be, actually. InfosecTrain Trainer: Decided on the basis of analysis only, right? subaveena pugalthi: Okay, to make a decision on if I wanted to accept that risk, or transfer, I would... subaveena pugalthi: Okay, I get it. Without considering any risk. subaveena pugalthi: or without any compensating or mitigation controls, I would do a risk analysis, get the value, and then decide what I want to do with it. InfosecTrain Trainer: Correct. First, you need to analyze.

You had a 50 risk, you analyzed them, you saw the 5 are critical in nature. InfosecTrain Trainer: 10 are high in nature. InfosecTrain Trainer: 10 are moderate, and rest are low. So now you know that these critical high are the top priority for you, where you want to reduce them to an acceptable level, right? InfosecTrain Trainer: So once you have this list, rather than deciding the treatment option for all of them, you will do... follow this method, right? InfosecTrain Trainer: So, first thing is the accept. Accept means something which is below your appetite, like maybe all those which are sitting in a low-level category are something which you will accept. You will not invest a lot of money and effort to treat them. InfosecTrain Trainer: Transfer is something, any risk, which I told you in the question exam also, any risk which has a... InfosecTrain Trainer: high impact. InfosecTrain Trainer: and low probability are the one you will transfer, like your health insurance, car insurance, cyber insurance. So, happening of those events is low, but whenever it will happen, it will have a very high impact. InfosecTrain Trainer: So, those kind of events, you will transfer. InfosecTrain Trainer: Mitigate means all the risks which are sitting here, you have to deploy

some form of control to mitigate them, right? You will, you will place them against the firewall, you will have the EDR solution in place, you will have other ways and means. InfosecTrain Trainer: You'll mitigate, and avoid is something which is actually not acceptable to you, you will avoid, which is beyond your tolerance and appetite, you will avoid. Like, suppose you know that there is a war going on between Russia, Ukraine from a long time.

If tomorrow I am a startup, I get an investment opportunity in the Ukraine, will I take the risk? I'll not. I'll avoid, because I know InfosecTrain Trainer: there is a high probability I'll lose that money, So I'll avoid. InfosecTrain Trainer: Yeah, Johnny. Johnny Souriar: So here, asset divide you, for example, I have a core banking system server. Johnny Souriar: How to arrive asset to value in financial terms? Is any formula is available, or how... is it judgmental base? InfosecTrain Trainer: No, no, this is a judgmental basis. There is no formula available for asset value. And as such, the asset value can only be determined for the tangible assets. For intangible assets, there is no method to determine the asset value. It's always going to be in the case of the business impact. InfosecTrain Trainer: If you say that there is a... there is a sensitive data or information available in the organization, you say this particular data is lost, how much business impact it will cause, you will say, okay, we'll end up paying... InfosecTrain Trainer: the \$500,000, so that becomes asset value. So it's always a judgmental basis, there is no hard and fast rule to define it. InfosecTrain Trainer: Got it? Johnny Souriar: Yeah, okay, thank you, yeah. InfosecTrain Trainer: Let's discuss some questions. InfosecTrain Trainer: Alright, let's discuss the correct answers. InfosecTrain Trainer: The first question is talking about an organization is rapidly adopting AI and IoT technologies, significantly altering its operational landscape.

From an enterprise risk management perspective, what is the first and the most critical step InfosecTrain Trainer: for the CISO to address the evolving risk profile, implement new technical security controls for the AI and IoT, update the organization risk assessment methodology to incorporate new threat factor and the vulnerabilities. InfosecTrain Trainer: conduct immediate security awareness training focused on AI IoT risk for all employees. InfosecTrain Trainer: procure cyber insurance policies, specifically covering AI, IoT, as you said. InfosecTrain Trainer: So, A, C, and B are something which are the actions. InfosecTrain Trainer: but without... Understanding the current risk landscape, How you can... InfosecTrain Trainer: decide that which option to take, A or C or D. So, as the question is take, what are the first and the most critical step? So, first and the most critical step would be, first, you will update the risk assessment methodology to incorporate these new threat factors and vulnerabilities, then you will InfosecTrain Trainer: Choose the option A, C, or D, so correct answer here is B. InfosecTrain Trainer: The CISO proposes a significant investment in a new enterprise-wide risk management program. To gain best senior management support, what should be the main focus of the CISO's presentation, considering factors affecting InfosecTrain Trainer: enterprise risk management. Detailing the technical specification of new risk management platform. How come InfosecTrain Trainer: the senior management would be appreciative about the technical specification. What would they do by knowing this? Highlighting the potential compliance failure or the regulatory fines without the program. Always only talking from the failure or the negative aspects is not a good approach.

InfosecTrain Trainer: articulating how the program... so it's always the best approach to always talk that how this initiative will help them support the business objective and achieve the competitive advantage. That is the best one, not D also. InfosecTrain Trainer: So, correct option here is C. InfosecTrain Trainer: When documenting risk treatment plan, which of the following is the best approach for ensuring the clarity and the actionability? Yeah, Johnny. Johnny Souriar: Sir, this is regarding the question number 2. Johnny Souriar: So, the option B is more about regulatory compliance and the law of the land, okay? So, the always priority will go there, right? First, Steve. Johnny Souriar: Rather than strategic business alignment. Compliance 2... Johnny Souriar: Regulatory is much, much high priority. Johnny Souriar: What do you say? InfosecTrain Trainer: But... InfosecTrain Trainer: Is that a business objective for the organization or not? How come you know? Probably the... this can be one of the business objectives, right? InfosecTrain Trainer: So business objective is a very broad term, right? Business objective means anything which helps organization to achieve the business, to grow, operate, and make profit, right? So that is going to be the more important for them, not only specific to regulatory fines and the InfosecTrain Trainer: Compliance. InfosecTrain Trainer: Sometimes you accept some couple of the regulations, for business to achieve. InfosecTrain Trainer: You do that. InfosecTrain Trainer: Like, DPDPA came into India, and suppose you need to... you need to have a compliance with respect to that. Currently, probably your budget do not support that much thing, what DPDPA says.

To say, we will have one very specific InfosecTrain Trainer: Basic compliance, which we'll show currently, and the rest, everything we'll do in the next financial year, because we don't have budget to do that. InfosecTrain Trainer: Right? InfosecTrain Trainer: So, always, it's a business decision to go with that, correct, Johnny? Johnny Souriar: Yeah, yeah, okay, okay, yeah, yeah, thank you. InfosecTrain Trainer: When documenting risk treatment plans, which of the following is the best approach for ensuring the clarity and the actionability? Include only high-level summaries for the senior management to review, provide detailed technical specification for each control, clearly define responsibility timelines, expected outcomes, focus primarily on financial aspect of the risk mitigation. InfosecTrain Trainer: It says that when you are documenting a risk treatment plan, what is the best approach to ensure clarity and actionability? How come a clarity and actionability comes? InfosecTrain Trainer: If you have a clearly defined roles and responsibilities. That's how you have to always pick up what is a keyword in the question. So here, in the Kish question, it's talking about the clarity and actionability. Actionability will only come if you have a clearly defined roles, responsibility, time, expected outcomes. So correct answer here is C. InfosecTrain Trainer: Anyone has any different opinion or questions? InfosecTrain Trainer: Alright, then, let's take a break, and probably after the break, we'll resume from here. InfosecTrain Trainer: Alright, let's... Get started before everyone is back. InfosecTrain Trainer: Now, let's understand why the risk management is so important in the organization, right? InfosecTrain Trainer: First thing is that culture integration.

InfosecTrain Trainer: So, if the risk management-related practices, if the risk management is integrated well within the culture of the organization, then InfosecTrain Trainer: it gives a better... better result. Like... InfosecTrain Trainer: All the processes, like, if you are onboarding any third party. InfosecTrain Trainer: So you have a third-party risk management process. If you are creating any new tools, so SDLC process should have a risk management integrated into it. InfosecTrain Trainer: If you are taking any new business decision, there should be a risk management process there. InfosecTrain Trainer: If you are taking... if you are purchasing any new SaaS platform, there should be a risk management there. So, all the processes, all the activities, if you hire any new employee. InfosecTrain Trainer: there is going to be the onboarding rated check, and all the activities. If you fire any employees, there's going to be a other level of... So, all the activities which you can think of in the organization, if you have proper risk management getting integrated there, right? So, it actually helps you manage all the risk properly, right? InfosecTrain Trainer: So that's why effectiveness of the... InfosecTrain Trainer: of the organization risk management depends on how you embed the risk management into organizational culture, and making everyone responsible for that. All the people, all the processes, all the technology leaders, everyone should be responsible. Then, mission alignment. InfosecTrain Trainer: Now, whatever is the organization mission, vision. InfosecTrain Trainer: strategy, structure, their product and services, their... all the... all the business values they offer, right? If risk management is integrated well within them, it will offer a better result.

And then the adaptability. Risk management is something which needs to be adopted as per the physical, environmental, and regulatory environment. InfosecTrain Trainer: So, there are going to be challenges, there are going to be changes with respect to the overall landscape, so risk management should get adopted, right? InfosecTrain Trainer: Like, has everyone, foreseen that there's going to be the war between Russia, Ukraine? Has everyone foreseen that there is going to be the war between the Israel, Iran, and US, and the crude oil prices all across the world will increase? No one predicted that, right? InfosecTrain Trainer: And that might have caused multiple people impact. InfosecTrain Trainer: impacted, right? Like, has anyone foreseen that AI would have so much integration or so much impact across all the lines and all the verticals? Has anyone, predicted that initially? No. InfosecTrain Trainer: So, it got adopted like this, now there's impact on the job, there is impact on some skills, so that's why organizations need to adapt with respect to that. InfosecTrain Trainer: Now, what are the outcomes of having a good risk management? First thing, you will have a better understanding around the threats which are there with respect to your organization. You will do proper threat. InfosecTrain Trainer: Management, you will do the threat mapping, you will understand how your organization is operating, so that you will have a good understanding around the threat, vulnerability, and risk profiles. InfosecTrain Trainer: For all your organizational activities, and the assets. InfosecTrain Trainer: You will have an awareness around the exposure.

InfosecTrain Trainer: So, if tomorrow there is an attack, tomorrow there is a ransomware incident, tomorrow there is a, there is an earthquake, tsunami. InfosecTrain Trainer: against where my data center is located, any process. If tomorrow there is a data breach, tomorrow there is a DDoS attack against my web application, anything, you will have a good exposure awareness. InfosecTrain Trainer: Around all the activities, then you will have a prioritization. InfosecTrain Trainer: So, you cannot treat each and everything what is happening in the organization, right? You cannot have a mitigation plan or the budget allocated for each and every activity, because it's very expensive for even the big organization. So, you will have a good prioritization, so that you will prioritize those activities, those processes, where you see there is a highest amount of impact. InfosecTrain Trainer: Then, mitigation strategy, you will create an

effective strategy to achieve the InfosecTrain Trainer: acceptable outcome. Your main goal of risk management is what? To reduce risk to an acceptable level, right? And to bring that risk to an acceptable level, you should mitigate InfosecTrain Trainer: The causes, mitigate the vulnerabilities, mitigate the risk overall, so that mitigation strategy you will create, and you will have a better resource efficiency. InfosecTrain Trainer: Now, how do you identify the risk? InfosecTrain Trainer: First, you will do a threat analysis. InfosecTrain Trainer: So we discussed, right? InfosecTrain Trainer: First, you do a threat analysis. So, once you have an inventory of assets, you will analyze what are the realistic threat scenarios, what are the realistic threats against my organization. Has my organization prawn to ransomware?

InfosecTrain Trainer: Has my organization prawn to DDoS? InfosecTrain Trainer: Is my organization prone to any sensitive data breach? InfosecTrain Trainer: Is my organization prone to any regulation? InfosecTrain Trainer: related fines. Likewise, you will create all the threat scenarios. What are the different threats which are against? Has my organization very volatile with respect to geopolitical changes? All of these are threats. Threat does not only mean a cyber attacker. InfosecTrain Trainer: Don't make a picture of a threat as a cyber attacker only. Cyber attacker is a one kind of threat. There can be other kind of threats. InfosecTrain Trainer: Even your internal employee can do some... InfosecTrain Trainer: some mismanagement, or some error, or probably it can be intentional or non-intentional, that can also be treated as a threat only. InfosecTrain Trainer: Then you will create a profile of all the threats on the basis of their motivation, capabilities, what are the potential adversaries who can target your organization. You will do that. Then you will do a vulnerability assessment. InfosecTrain Trainer: So, all the vulnerabilities which you identified, will all of them will be able to export it by thread actor? No. InfosecTrain Trainer: You have to see from an environment perspective where the vulnerability sits. Is my environment... is it production, it's a non-prod? Is it a standalone PC not connected to internet? Everywhere, you have to see all those things, and then you have to check. InfosecTrain Trainer: Then the asset valuation. InfosecTrain Trainer: So, what is the value of asset which is impacted by this threat and the vulnerability? That matters a lot. InfosecTrain Trainer: Right?

So... so if any asset which is a tangible in nature, you can predict a replacement cost for that, right? InfosecTrain Trainer: How much cost it will require to replace that asset. InfosecTrain Trainer: That becomes your asset value. InfosecTrain Trainer: What is the value in the black market? What is the operational value? How much is the revenue generation being done by that asset? All these things you have to factor in, and then on the basis of that, you will determine the impact. InfosecTrain Trainer: Now, identification will happen in two ways. One is the top-down approach, another is the bottom-up approach. Let me explain with the example. So, these days, all the organizations, they are adopting AI. InfosecTrain Trainer: Right? So your board of directors and the senior management decided, let's go with the AI and the transformation journey. InfosecTrain Trainer: Now, the senior management, when they initiated this topic for AI transformation strategy, they identified some couple of risks. They say, before we start a transformation journey, let's establish a proper governance structure. InfosecTrain Trainer: Let's establish a proper risk appetite for the same, so that we know that what is allowed, what is not allowed, how much funding, how much budget. So, all these things are coming from top down. InfosecTrain Trainer: Your leadership, your board of directors, your senior management. So, top-down approach is something which begins with organization objective and the strategic priorities. InfosecTrain Trainer: It's an executive-driven process that cascade downwards. It focuses on business impact and the mission criticality, and it establishes the risk appetite and the tolerance threshold. Now, coming to the bottom-up approach, when the AI transformation journey starts.

InfosecTrain Trainer: Individual contributor or an engineer identified, there is a prompt InfosecTrain Trainer: injection vulnerability available there. Engineer... network engineer identified that there is a heavy shadow AI tools being used InfosecTrain Trainer: Something which is identified, or which is being done by bottom-up. InfosecTrain Trainer: A lowest level in the organization hierarchy, something which starts with the technical asset inventory and the vulnerability level. Operational team identifies some specific threats. InfosecTrain Trainer: You will look for the granular control assessment and implementation, and then the overall aggregate these findings, and then you will have a bigger picture. InfosecTrain Trainer: I hope everyone understood what is a top-down, what is bottom-up. subaveena pugalethi: Not adjusted a question. InfosecTrain Trainer: Yeah, so... subaveena pugalethi: Can we use both the approaches for risk identification, or it depends on the management to go with whichever approach they prefer? InfosecTrain Trainer: No, no, both approaches are followed. Some of the risk... InfosecTrain Trainer: would be for... would be actually suggested by the senior management, some of the risk which you identify from the, process level. Understood? subaveena pugalethi: Okay, thank you. InfosecTrain Trainer: Now, this example will help you understand how these topics, or how these particular terminologies are related with each other, right? InfosecTrain Trainer: What do you call a threat actor? InfosecTrain Trainer: Threat is a ransomware attack against organization, but threat actor is a ransomware group, a gentleman threat actor group, or a Kira threat actor group.

Any threat actor group who is targeting against your organization, that becomes a threat actor, and that particular activity becomes threat. InfosecTrain Trainer: Now, vulnerability is... there was an inconsistent backup, and one particular machine was unpatched. That was a vulnerability which InfosecTrain Trainer: Factor leveraged and got into your system, then there was an inconsistent IDAM-related control. He elevated the privileges, went on to, he gained a privileged admin user, and then went ahead and then encrypted all your backups. InfosecTrain Trainer: And risk is non-availability of critical asset, loss of trust, lot of business value, and asset was your critical business server. So this is an example, let's see another example. InfosecTrain Trainer: So, our malware is deployed to exploit the system. InfosecTrain Trainer: This is what a threat actor did. Now, what was the vulnerability? There was system which was not patched. InfosecTrain Trainer: What are the risks? Malware can gain access to system through exploit. This is a risk, and what was the asset? Asset was a server. InfosecTrain Trainer: where the... it was unpatched, that particular server becomes an asset. Even clear how the threat actor, threat vulnerability, risk, and assets are related with each other. InfosecTrain Trainer: Now, what are the risk identification techniques? InfosecTrain Trainer: how you identify... so we understood two approaches, but even in those two approaches, there are some techniques. First one is the brainstorming. InfosecTrain Trainer: Like, couple... you conduct a workshop. InfosecTrain Trainer: where your key CISO... suppose you are doing a cyber... you are identifying risk with respect to cybersecurity. So you will invite CISOs, or your directors, your senior people, probably.

InfosecTrain Trainer: application security experts, your threat intelligence person, your SOC team manager, and all those people, those who are InfosecTrain Trainer: people, those who understand the risk threat landscape, those who understand the vulnerabilities, you will invite them. They always sit together. There is going to be the workshop, where all of them will discuss, and then they will reach out to a conclusion. What are the key risks? InfosecTrain Trainer: which are against our enterprise, they will identify. InfosecTrain Trainer: Next is the process analysis. So, if you have one particular process. InfosecTrain Trainer: Like, say, there is a process of a third-party vendor onboarding. InfosecTrain Trainer: Right? InfosecTrain Trainer: So there is a... third party? InfosecTrain Trainer: Vendor... onboarding process. InfosecTrain Trainer: how it happens, you first send out the request for proposal, then you receive... once the RFPs are sent, then you receive the request. InfosecTrain Trainer: You... you first send the RFIs, request for information, then you receive the proposals and everything. Once you get that, you evaluate those vendors, then you do the risk assessment of those vendors, then you see the criticality rating and everything, then you do the contracting. After the contracting is done, then you onboard the vendor. InfosecTrain Trainer: all those activities are followed. So this is one process. So, you will analyze end-to-end process, and then you will see, are there any gaps? Are there any things where there are risks? InfosecTrain Trainer: This is an example. Next comes the what-if analysis. InfosecTrain Trainer: So, what if analysis is, what if a threat actor is able to get into one of my endpoint equipment?

InfosecTrain Trainer: through a... through a... probably he went via phishing email, he deployed a malware. What if a threat actor is able to elevate the privileges to an admin and went on to our critical server? InfosecTrain Trainer: What if he is able to go to other systems which are interconnected? InfosecTrain Trainer: what if he's able to deploy a ransomware? So, it's a what-if scenario, like, you will see where the attacker can go, up to what level, and then on the basis of that, you will identify the risk in the complete process. Then the structured assessment, where you will have an structured questionnaire, or a structured set of things, what you will do, and then those particular structures InfosecTrain Trainer: Setup questionnaire, and the framework will help you determine the risks. InfosecTrain Trainer: in the process. InfosecTrain Trainer: So, these are the techniques which you use to identify the risk. InfosecTrain Trainer: Now, coming to the vulnerabilities and threats. InfosecTrain Trainer: So the vulnerability are... InfosecTrain Trainer: technical vulnerabilities. Technical vulnerabilities, SQL injection vulnerabilities, there is one HTTP port which is open, there is one, there is one SSL bypass, which is there, or some... some web application has some key vulnerabilities. So, these are all the technical vulnerabilities for which InfosecTrain Trainer: There are patches available or fixes available. InfosecTrain Trainer: So, these are the technical, which is identified by your tool, like, call as... your Nessa's... InfosecTrain Trainer: some... some tools which are there in the market, right, which helps you identify the technical vulnerabilities. Now comes to the business process-related vulnerability, which cannot be identified there.

For business process, you need to do an assessment, right? You will either do an audit, you will do a rec team. InfosecTrain Trainer: Assessment. InfosecTrain Trainer: Where you will analyze a business process, right? Red team assessment will analyze your complete InfosecTrain Trainer: process of your... how your

blue team inter... blue team reacts, how your controls are operating, how your systems are operating, and then you will identify the vulnerabilities or the weakness there. InfosecTrain Trainer: Lack of awareness. InfosecTrain Trainer: If people are not aware about their duties, responsibilities, roles, or things, what they need to do, that is also a kind of vulnerability. InfosecTrain Trainer: outsourcing services. Something, if you outsource to a third-party provider. InfosecTrain Trainer: Does not mean, even if you have a contract, always accountability sits with you. InfosecTrain Trainer: And there was a classical example. Recently, you saw there was a big InfosecTrain Trainer: cyber incident where TCS employees were a service provider to one of the organizations, and a phishing email came to the TS employee InfosecTrain Trainer: Mailbox, they clicked on it, and from there, attacker went to a parent organization, and then caused a cyber attack. InfosecTrain Trainer: So, outsourcing does not means that, even if you have a contract, it can help InfosecTrain Trainer: risk, right? Always there can be a vulnerability which can be exploited, and they can come into your organization. InfosecTrain Trainer: So, for that, you should have a strict, probably the scrutiny, strict level of network security control, VPN, and what systems or the processes you give access to those outsourced providers, so that InfosecTrain Trainer: That vulnerability can be mitigated.

InfosecTrain Trainer: No threats. InfosecTrain Trainer: So, there are two types of threats. One are the internal threats, another one are the external threats. Internal is something which is within the organization, your internal employees, right? So, your internal employees, there can be intentional as well as unintentional threats. InfosecTrain Trainer: I hope you would have heard about the... the crypto... InfosecTrain Trainer: currency exchange broker company named CoinDCX. InfosecTrain Trainer: Out of it. InfosecTrain Trainer: They help you with the... They help you... Siva Krishna Kalipatnapu: CoinX before? InfosecTrain Trainer: Yes, yes, yes. Now it is called the Coin DCX. Siva Krishna Kalipatnapu: Yeah, yeah. InfosecTrain Trainer: So, there is a classical case InfosecTrain Trainer: A year back, one of the internal employees, he got InfosecTrain Trainer: He actually, collaborated with some external threat actor, and then... InfosecTrain Trainer: through his help, they were able to steal some million dollar worth of money from the crypto wallet of the CoinDCX. InfosecTrain Trainer: This is a classical example of the internal employee. There can be unintentional threat also, like person clicked on the phishing email without understanding the process and all, it was not intentionally done, that is unintentional. InfosecTrain Trainer: External is all the external environment, right? It can be legal, it can be all the cyber hackers, attackers which are there, all of them are external threats. InfosecTrain Trainer: Now, vulnerability identification will happen in these four methods. InfosecTrain Trainer: So, audit.

InfosecTrain Trainer: So whenever an audit is conducted against your organization, so that audit generally comes with some set of InfosecTrain Trainer: set of principles or set of objectives, what they want to achieve, right? Suppose you are doing an audit with respect to ISO 27001. Your organization want to go with the ISO 27001 journey. InfosecTrain Trainer: So the auditor will come with the ISO 27001 framework. He will see what are the applicability against your enterprise, and against that applicability, that particular auditor will audit extensively your organization. InfosecTrain Trainer: As part of that audit, the auditor will say, okay, these are the processes, these are the activities which are not available. InfosecTrain Trainer: So those processes, if they are not available, it means there are weakness in the existing process. So audit is identifying the vulnerabilities. InfosecTrain Trainer: Second thing is the security review. So, what is the key difference between the audit and the security review? Someone can tell me? Siva Krishna Kalipatnapu: Audit is, like, Siva Krishna Kalipatnapu: just to ensure that the team... I mean, the company is implementing what has been defined. It could be a regularity, a policy, or a standard. A security review is kind of to identify Siva Krishna Kalipatnapu: Or, Siva Krishna Kalipatnapu: To learn what exactly is happening currently, so that we can take a decision as in what needs to be implemented, or... Siva Krishna Kalipatnapu: Or anything else. InfosecTrain Trainer: So, audit is a formalized process, where person comes with an objective, scope, and everything. Security review is a less formal process, which can happen every day. So, every day.

InfosecTrain Trainer: Your engineer, once he's logging in, he can just go over the logs and see. InfosecTrain Trainer: If any, any issues he identifies. InfosecTrain Trainer: Right? You do the log reviews, you even do review of your firewall rules, you do the reviews of your privilege identities, how they are being managed. Even in the software development lifecycle, whenever a person creates a code, there is going to be a supervisor or kind of a team lead who will review the random code of the person who has created. So these are all the security review process. InfosecTrain Trainer: So that security review process will also identify some vulnerabilities. InfosecTrain Trainer: Vulnerability scan and the penetration testing. InfosecTrain Trainer: Both are interrelated with each other. How? That's why we call it a VAPT. InfosecTrain Trainer: Vulnerability Assessment, Penetration Testing, VAPT assessment. InfosecTrain Trainer: So, in the VAPT assessment, so vulnerability Scan will identify all the list of vulnerabilities in your organization, right? But once they identify the vulnerabilities, do you patch all of them? InfosecTrain Trainer: No. InfosecTrain Trainer: So, there is something called the CVSS. InfosecTrain Trainer: What does CVSS stand for? Ashwin: Is it critical? Security Score? Pudir: Common vulnerability. Pudir: Excluding this... InfosecTrain Trainer: I literally... SrinivasanJ: So. InfosecTrain Trainer: Vulnerability Scoring System, CVSS. InfosecTrain Trainer: So, Common Vulnerability Scoring System, CVSS. So, in your organization, once the caller is necessary, whatever tool you are using, as soon as it actually generates a list of vulnerability, do you fix all of them? No. InfosecTrain Trainer: You do not.

InfosecTrain Trainer: So, there is something called the CVSS scoring. InfosecTrain Trainer: So, any vulnerability which are identified by any third party, probably by Microsoft or whatever software provider you have, so there is something called the CVE database. InfosecTrain Trainer: Has anyone seen this CVD database? Common Vulnerability Enumeration Database. InfosecTrain Trainer: So, there is an organization who actually... InfosecTrain Trainer: So, there is the organization. Madhes: Is it CVE or CWE? InfosecTrain Trainer: It's called the CVE, CW is the organization name. InfosecTrain Trainer: Common vulnerability and exposures. InfosecTrain Trainer: So CVE is a common vulnerability exposure database managed by US, which is an open source website. Anyone, you me, anyone can come here and report any set of vulnerabilities. So, this particular database has lists of all the vulnerabilities around the world. InfosecTrain Trainer: Someone identifies any vulnerability, you come put it here with a scoring. InfosecTrain Trainer: So, there is a scoring mechanism from 1 to 9... 1 to 10. In range, you will score the vulnerabilities, but InfosecTrain Trainer: Once you report those vulnerabilities, those are the score which you have given in the generic term. But once that particular system gets deployed within your organization, how many controls you have, right? InfosecTrain Trainer: how is your network infrastructure? How is that system deployed in the prod or non-prod? Where that system is placed, behind firewall or before firewall, what kind of control you have, it will change the score for that particular system. InfosecTrain Trainer: That score is called the CVSS, which will help you determine, is that vulnerability need to be fixed immediately, what is the priority?

And on the basis of that, then you create a priority, right? You will say that these are the critical vulnerabilities. InfosecTrain Trainer: high vulnerabilities, moderate vulnerabilities, low vulnerabilities. You say critical need to be fixed within 30 days, high and moderate in 60 days, and low 90 days. InfosecTrain Trainer: That you determine on the basis of this. Now, once the vulnerability assessment is done, you identify these are the critical vulnerabilities, you want to test it through penetration testing. You want to understand, are those vulnerabilities exploitable or not in my organization environment? InfosecTrain Trainer: That's why you do the PT. InfosecTrain Trainer: So, organization has a VAPT teams. InfosecTrain Trainer: Those who first do the vulnerability assessment, once they have the vulnerability list, they will create a payload with respect to those vulnerabilities, and then they will try to penetrate the application to understand how many of them are exploitable in nature. That is called the vulnerability scan and the penetration testing. InfosecTrain Trainer: So these are the methods for the vulnerability identification. InfosecTrain Trainer: Now, coming to the threat sources. InfosecTrain Trainer: So, as I told you, threats are not only the cyber attackers or hackers. Madhes: One second, Jess. Madhes: See, CB is basically technical in nature. There are one more line item called the CWE. Madhes: Common weakness enumeration. Madhes: which may not have a direct vulnerability, like, it may be linked to Mhre framework attack, so that, say, for example, if you're having public-facing application, if, public-facing application not having the two-factor, then that will be identified under the CWE. Madhes: It's called, cwa.mythread.in. Madhes: My3.org.

InfosecTrain Trainer: Yeah, you're talking about the MITRE, Madhes: Yes, yes, yes, yeah, yeah. Madhes: cw.mytree. InfosecTrain Trainer: Common weakness enumeration, right? Madhes: Yes, yeah, because most of the time, audit includes CW observation also. InfosecTrain Trainer: Yeah, so vulnerabilities is more technical in nature. InfosecTrain Trainer: Weakness is overall about the system. So, weakness can also encounter for the design-related flaws. InfosecTrain Trainer: Got it? InfosecTrain Trainer: Like, there can be design-related issues, so vulnerabilities won't encounter account for the design-related flaws, so that's why you have a CWE and CVE, both are... so CWE, you can say, a kind of an umbrella, which covers both CVE also. InfosecTrain Trainer: Because vulnerability is more around the technical technology. Madhes: Yeah, just want to give, yeah, no. InfosecTrain Trainer: Yeah, thank you, thank you. But this CVSS is the kind of the scoring system which all the organization follows. Probably if someone is working, has a hands-on experience with the college, or you can probably talk to a college team in your organization, you will understand this process, how it works in your organization. InfosecTrain Trainer: Now, coming to the threat sources. InfosecTrain Trainer: So, all the threat categories, right? InfosecTrain Trainer: they are divided into four broad categories. One thing is the natural threats, which you don't have any InfosecTrain Trainer: you have no control over it, right? It's a natural threat. Basically, depends on the... InfosecTrain Trainer: Nature, any flood, flood, fire, earthquake, storm, tsunami. InfosecTrain Trainer: So, not in your control. If there comes, it will have an

impact on your organization.

So, for that, you need to be prepared according to that. There are some unintentional threats. InfosecTrain Trainer: So, unintentional, something where you did not plan for it, or someone was not deliberately wanted to do that, but it happened. InfosecTrain Trainer: Some equipment got failed because of some issue. Some person conducted some error. InfosecTrain Trainer: You would have seen, in banking industry, person, by mistake, transferred so many CR worth of money to someone's account. InfosecTrain Trainer: So, cause because of the human error. InfosecTrain Trainer: Or some service loss. InfosecTrain Trainer: they are unintentional. Intentional is something which someone intentionally doing it, like some... InfosecTrain Trainer: Someone is stealing some information, someone is subattaching something, someone is causing the vandalism. InfosecTrain Trainer: Intentional non-physical threats are something which is technical in nature, or conducted virtually, like you're hacking some malicious code or malicious software getting deployed, someone is doing a social engineering against your organization and extracting the data and information. These are intentional non-physical threats. InfosecTrain Trainer: Now, there are emerging threats. You will see in question about these InfosecTrain Trainer: Has anyone heard about the APT? Can someone tell you what does APT mean? InfosecTrain Trainer: Remember when you heard about the word APT, Advanced Persistent Threats. InfosecTrain Trainer: Okay, let me explain you. InfosecTrain Trainer: There are some highly... Sophisticated, or highly InfosecTrain Trainer: modernized, or highly, I would say, InfosecTrain Trainer: Technical, technically sound threat actor group.

InfosecTrain Trainer: Which come, gets into your system, exploits your system, elevate the privileges, be there unnoticed. InfosecTrain Trainer: none of your log... log detection technique, none of your security assessment technique, none of your penetration testing activities would be able to understand or able to identify that there is some APT threat setting. InfosecTrain Trainer: And that's how, in current day scenario, big cyber attack happens. InfosecTrain Trainer: Don't... InfosecTrain Trainer: what do you... what do you say? That... that those attacks, what you say that there is a cyberattack against this enterprise, just happened in a day? No. Attacker would probably be sitting in their system from last 6 months, even they sit for the year also. InfosecTrain Trainer: They just wait, they just learn your environment, they learn your organization flow, your network architecture, and then they just take a day. InfosecTrain Trainer: Which they will choose to attack. And then, on that same day, they will so quickly InfosecTrain Trainer: Move or cause a damage to your enterprise, then you will not be able to, kind of mitigate the impact. InfosecTrain Trainer: So, to understand these emerging threats, you need to understand the ever-changing threat landscape and what are the effects on your enterprise, right? InfosecTrain Trainer: So there is a AI adoption, there are quantum-related technologies in development, now there are a... there are a volumetric DDoS attack. InfosecTrain Trainer: Someone heard of this? Volumetric DDoS attack? SrinivasanJ: Now, what is volumetric DRAS? SrinivasanJ: Hard about data. InfosecTrain Trainer: So there is something called a DDoS as a service.

InfosecTrain Trainer: So, volumetric DDoS attacks is actually a kind of a DDoS attack, where they... they put so much traffic against your organization, right? It's going to be probably in the petabytes. InfosecTrain Trainer: petabytes worth of traffic would be coming to your organization, which none of the DDoS existing mechanism would also be able to mitigate them. InfosecTrain Trainer: it will actually saturate your bandwidth, your... everything would be gone. So that is called the volumetric DDoS attack. You can read about it. This is the new threat, which is very prevalent these days. InfosecTrain Trainer: So, these are some of the ever-changing threat landscape, or the threats which are there, right? So, if you don't have a lack... if you have a lack of effective threat monitoring, this can lead to a security incident in your enterprise. InfosecTrain Trainer: Now, what are the indications? As I talked about the APT, if they are sitting in your organization, you will not be able to understand that with the normal logs. InfosecTrain Trainer: Norval's SIEM rules. InfosecTrain Trainer: normal EDR, malware, and all those, your email gateway filters, they'll not be able to detect it. InfosecTrain Trainer: You have to look for the unusual activity on a system. Something which usually do not happen, something which is InfosecTrain Trainer: Generally not supposed to happen. InfosecTrain Trainer: Like, suppose if you see employees in your organization generally log in from morning 9am to 9pm. InfosecTrain Trainer: But you saw a very heavy activity, suppose, in the night around 2PM, multiple days. It means that something fishing is going on there. InfosecTrain Trainer: Some attacker is doing something in the night, right? InfosecTrain Trainer: If system performance, go slow.

If system is taking a lot of time to boot, if the memory space utilization has increased, the process, multiple processes are running in the system. InfosecTrain Trainer: So, it gives you an indication that something bad is happening there. InfosecTrain Trainer: If, in the logs, you know what is the general pattern or the general thing what logs generate. If there is an excessive level of log activities, excessive level of logs are being generated, that will help you determine that there is some emerging threats. InfosecTrain Trainer: If there are repeated alarms, repeated number of alerts being generated by your log management solution, repeated such alarms can indicate an indication of emerging threats. InfosecTrain Trainer: Now, what is an APT, as we discussed? InfosecTrain Trainer: So, how an attack take place in an environment? InfosecTrain Trainer: If I, as an attacker, want to exploit any organization or infrastructure, how I'll do that? InfosecTrain Trainer: first... in the first phase, I'll do an... Reconnaissance. InfosecTrain Trainer: In the reconnaissance, I will probably go to the social media of the organization, I will scan all the internet-facing infrastructure, so that InfosecTrain Trainer: I... I'll scan only those things, whatever is available over the general internet. I will not do any... InfosecTrain Trainer: intrusive testing where organization will be able to detect my activities. So, they are not aware I'm doing this. I'll go to probably social media account of their employees, I'll see the LinkedIn account, I'll see, has someone put InfosecTrain Trainer: any list of any technical tools, any things what organization is doing? Has anyone put that they are admin users, or something like that?

Server... handling the server administrator, handling something like that, they are put. I'll do that complete reconnaissance. InfosecTrain Trainer: Then, after that reconnaissance is done, I identified one admin, couple of admin people, I will launch a phishing attack against them. Madhes: CyberKill Chain Matravity, right? InfosecTrain Trainer: Yes. InfosecTrain Trainer: So, cyber kill chain is, against, is just an opposite to this. InfosecTrain Trainer: This is an attack methodology. Cyber kill chain is just opposite to it, where you try to kill InfosecTrain Trainer: These chains in between, so that the attacker cannot go to the next step. InfosecTrain Trainer: Where the miter comes into the picture. InfosecTrain Trainer: Now, on the basis of this, I launched a phishing attack, person clicked on the link, I got an initial compromise, initial hold of that particular machine. InfosecTrain Trainer: Now, I'll maintain my presence there. InfosecTrain Trainer: I will monitor it for a couple of days, months, that what activities the person is doing, which all platform it goes, which all tools it access, at what time he generally logs in in the system. InfosecTrain Trainer: then I'll see a ways and means I'll elevate the privileges to a next level. I will, from that admin, I'll probably gain a more level of privileges. InfosecTrain Trainer: Once I have an escalated privileges, I will be able to now move laterally to other systems. I will be able to move to other solutions, probably I will gain an access to the Intune InfosecTrain Trainer: or probably the route access, or other systems, or from where the people launch the policies and do changes, I will move laterally to that, then I'll maintain the presence.

InfosecTrain Trainer: I'll maintain that presence for a good number of time, and once that is done, I will try to remove the logs and all the things which I carried out in the back, so that they cannot detect me, and then my mission is accomplished. InfosecTrain Trainer: So this is what's called the Advanced Persistent threats, a prolonged targeted cyber attack where hacker gains unauthorized access to a network and remain undetected for an extended period of time. InfosecTrain Trainer: Can someone explain me? So this is not, from the syllabus perspective, but a lot of people get confused between this true positive, false positive, false negative, true negative. SrinivasanJ: So it's something related to use case creations. Ashwin: Yeah, it's related to threat. So true positive is an actual threat, malicious. False positive is the tool has considered, let's say an email as a threat, but it is not a threat, so it is a false positive. Ashwin: So, false negative is, like, you know, that a phishing email came through, and the tool did not recognize it, so it becomes a false negative. It's supposed to be a positive, but the tool deemed it as negative, so it's a false negative. Ashwin: A true negative is an Azure email, which is not a threat at all, and the tool also did not flag it. It's a true negative. InfosecTrain Trainer: Okay, let me, let me take an example. There is a positive threat, there is a malware. InfosecTrain Trainer: in your endpoint equipment, and you have an anti-malware solution. The malware solution detected malware as a malware calls the true positive. InfosecTrain Trainer: There was a malware. InfosecTrain Trainer: But your anti-malware solution did not detect a date, it's also false positive. InfosecTrain Trainer: Oh, sorry, my mistake.

False positive means there was no malware, there was no malware, there was no malware, but your system says that you have a malware. It caused a false positive. InfosecTrain Trainer: False negative means, that, InfosecTrain Trainer: The system says that... system says that there is no malware, but actually there is a... there is a malware. InfosecTrain Trainer: There, right? It calls a false negative. InfosecTrain Trainer: And true negative means... InfosecTrain Trainer: that there was... there was a malware, and it got detected as a malware becomes a true negative. So that's a key difference. Ashwin: No, let's. InfosecTrain Trainer: Veter, the... Ashwin: what you explained last is, I feel, true positive. There was... there was no malware, and the anti-malware did not detect anything, becomes true negative, because it's a negative scenario, there is nothing. If there is a malware, and the tool, anti-malware says there is a malware, that becomes true positive. The positive. InfosecTrain Trainer: Yeah, yeah, correct, correct. There is no malware in the system, and your system

detected as a no malware, becomes a true negative, correct? Ashwin: Yep. InfosecTrain Trainer: Let's discuss some questions. InfosecTrain Trainer: Alright, let's discuss... InfosecTrain Trainer: So, the first question is talking about an information security manager has been assigned to implement more restrictive preventative control. By doing so, the net effect will be primarily reduced. InfosecTrain Trainer: You have a... sorry. InfosecTrain Trainer: You have a web application. InfosecTrain Trainer: there is one of the vulnerabilities. You place this particular application behind a web application firewall. You probably had one intrusion detection system, intrusion prevention system in place.

You enabled a restrictive log management and everything you did. InfosecTrain Trainer: what you did. By doing this, how you can reduce the threat. InfosecTrain Trainer: threat is something which is external. Can you... are you reducing a threat actor's capabilities? Who is coming... sitting outside? You cannot do that. He can probably come by a fishing route or some other route he can take. He'll still be there, you cannot reduce this. Loss, also, if this application InfosecTrain Trainer: goes bad, or the information gets captured, or gets access... threat actor is able to gain an access, that loss also you cannot reduce. InfosecTrain Trainer: So, a lot of people would have got confused between the probability and the vulnerabilities. InfosecTrain Trainer: But it talked about primarily Primarily, what it does, when I deployed so many things, what it did. InfosecTrain Trainer: It actually reduces the overall vulnerability or the weakness in the system. Don't treat vulnerabilities only as one particular single vulnerability. Vulnerability is overall weakness in the system. InfosecTrain Trainer: As many controls you deploy around a system, the system becomes less vulnerable to any threat. InfosecTrain Trainer: So, you are reducing vulnerabilities, not probability. InfosecTrain Trainer: Net effect would be reducing the vulnerabilities, and then that would result into reduction of the probability of happening that event. InfosecTrain Trainer: And probability also, how you can reduce. If a earthquake will happen 5 times, it will happen 5 times. If a threat actor will attack your organization 10 times, it will do 10 times. Can you reduce that 10 times? InfosecTrain Trainer: activity. He will try, because Only the effect probably can be reduced.

InfosecTrain Trainer: Only the net effect is the vulnerability reduction, not probability loss and threat. InfosecTrain Trainer: After implementing a mature information security risk management program, what is the main outcome that a senior management should expect to achieve demonstrating its effectiveness? Elimination of all security incidents, that is not possible. InfosecTrain Trainer: a quantifiable reduction in the organization's overall residual risk to an acceptable level, that's what you want to achieve. We discussed multiple times, reduce the risk to an acceptable level, full compliance with every applicable regulatory framework. InfosecTrain Trainer: That also is not the main objective. Automation of all risk assessment and reporting processes, that's also not the key objective. T objective is B. InfosecTrain Trainer: A CISO is initiating a comprehensive risk identification process for a complex global organization to ensure the most thorough and accurate identification of risk, which approach should be prioritized. InfosecTrain Trainer: solely top-down approach, solely bottom-up approach, always it's better you take a combination of it, so that some of the risks are identified by your stop leader senior management, which are more focused around the overall strategy. InfosecTrain Trainer: your organization risk appetite and everything. Then, couple of risks are identified your technical teams, which are more granular in nature, so always a combined approach is good. InfosecTrain Trainer: Not this. InfosecTrain Trainer: Anyone has any different opinion here? Madhes: Beautiful! Madhes: First of all... sorry, Srini, you can go. SrinivasanJ: Yeah, okay. The first one, why not probability? Like, see, there are multiple ways an exploitation can happen.

SrinivasanJ: So, implementing more restrictive, preventive controls, we can reduce the probability of exploitation. SrinivasanJ: Or the source of attack. InfosecTrain Trainer: you will reduce the probability, that's what I'm saying, but question is talking about the primarily. Madhes: Now, I'll give one more example to, second that, opinion. Say, for example, I am having an endpoint. Endpoint is having the internet, normal internet, port 80 only, just, you know, browsing purpose. So, in the name of restrictive preventive control, I am blocking that internet also. Madhes: So, basically, I'm just, you know, probability of attack, I'm reducing. Madhes: Having internet is not a vulnerability. InfosecTrain Trainer: It's talking about the primarily. Primarily means primary thing what it will reduce. InfosecTrain Trainer: More number of controls you will deploy, primarily what it will have an impact. It will first reducing the vulnerability. It's first reducing the weakness in the system, and then as a result of that, the probability and impact will also get reduced. Got it? InfosecTrain Trainer: So, primarily is the keyword here. That's it. Johnny Souriar: Plus here, vulnerability is a totality you had to see as a weakness in the system, not a single, single vulnerability. InfosecTrain Trainer: That's what I'm saying. Johnny Souriar: That's what I said. Yeah. InfosecTrain Trainer: You just don't talk about one specific vulnerability's overall weakness in the system. How the exploit can take place. InfosecTrain Trainer: And you know that it's never that there is only one vulnerability in a system. There are going to be multiple weaknesses, right? Multiple paths exist. InfosecTrain Trainer: So, primarily is the keyword here.

However, as I told you, probability also you can... will reduce. InfosecTrain Trainer: Indirectly by doing that, but primarily here is the keyword, that's why. InfosecTrain Trainer: But that's how these keywords change the answers. InfosecTrain Trainer: No... InfosecTrain Trainer: two more questions, and the first question, please read it properly. It's more around the testing your concept and the English. InfosecTrain Trainer: Alright, let's discuss. InfosecTrain Trainer: So the first question I told you, read the English properly. It says, a recent penetration test to identify a critical unpatched vulnerability is in a widely used web server. From a risk management perspective, what does an unpatched vulnerability means? InfosecTrain Trainer: Distinct from a threat. InfosecTrain Trainer: what I told you, when a... when there is going to be the risk, when there is a threat, and there is a vulnerability, it becomes a risk, right? InfosecTrain Trainer: But the question is saying, there is a vulnerability which exists, but there is no threat for it. InfosecTrain Trainer: If there is no threat for it, then how come it becomes a risk? It's just a vulnerability. Let's take an example. InfosecTrain Trainer: You have one particular computer, there is one particular vulnerability, which can only be exploited if the system is connected to the internet, but you are currently using the system in stand-alone mode, there is no inter... InfosecTrain Trainer: net connected at all. System is kept in one particular logged room where person goes, logs in, and uses it. How come it can be a risk here? InfosecTrain Trainer: It's just a vulnerability which is sitting on the system. That's what question is asking. It says, represent distinct from a threat.

If there is no threat against a vulnerability, it's just a vulnerability, not a risk. It will only become a risk if there is a threat which can exploit that vulnerability. So, correct answer here is C. InfosecTrain Trainer: When documenting the result of a risk assessment, which of the following element is the most critical to include? Detailed technical description of all vulnerabilities, what will you do with that? InfosecTrain Trainer: Complete inventory of all IT assets, yeah, that is an important thing to take, but can you do that without understanding the business impact? InfosecTrain Trainer: Correct answer, here is C, yeah. InfosecTrain Trainer: Anyone has any questions or comments? InfosecTrain Trainer: So the first question is just to test your English. InfosecTrain Trainer: That's what I'm saying. In the exam also, read the question, read between the lines. Johnny Souriar: The question is, from the risk management perspective, right? InfosecTrain Trainer: Yeah, that's what it's saying. Risk man... this is risk management only what you are stating, right? Risk is threat multiplied by vulnerability. Threat exploited by vulnerability becomes risk. That's what is the risk management perspective, right? InfosecTrain Trainer: So, if there is no threat for a vulnerability, how come you say that there is a risk there? Ashwin: Okay, in that case, I could also think about it this way. If there is no threat, but if it is not exposed to the internet. Ashwin: Then it... you can't call that vulnerability a critical vulnerability, right? InfosecTrain Trainer: Can you please repeat again? Ashwin: If there is no... if there is no chance of a threat or anything, right? You said if it's a... if the device is locked away somewhere and, you know, it's not exposed to the internet.

Ashwin: then the vulnerability cannot be classified as a critical vulnerability, right? Because the first line, it says critical unpatched vulnerability, right? So, how could that be a critical vulnerability? InfosecTrain Trainer: Yeah, so it's a critical unpatched vulnerability which is sitting here in this particular system. InfosecTrain Trainer: But currently, system is, working in a standalone mode, and that's what it says, right? Distinct from threat. There is no threat against it. Threat is not there. InfosecTrain Trainer: then what do you call it? It's just a vulnerability. Question itself is saying represent distinct from threat. If there is no threat, how can you say that there is a risk? InfosecTrain Trainer: If... even if there is a critical unpatched vulnerability, if there is no threat, there is no exploit which has been created in the world, how come it can become a risk for you? Even if you don't patch it. InfosecTrain Trainer: There is no risk, right? Ashwin: I agree to that point, though. I think the critical key word there is long, it's... Ashwin: Probably threw me off. InfosecTrain Trainer: It's just an English question. Ashwin: Yep, yeah. InfosecTrain Trainer: Yeah. Ashwin: Google. Madhes: And just a practicality perspective... Does it mean that, that particular system need not be patched? InfosecTrain Trainer: Yes. InfosecTrain Trainer: It's not necessary that you patch each and every system. InfosecTrain Trainer: In your organization, do you patch all the systems? It's not necessary you patch all the system. InfosecTrain Trainer: Have you... Madhes: We have, see, we have the, you know, in case if it is identified as a critical or high, it has to be patched. Madhes: So, here it is mentioned as a critical and patched.

Madhes: But, as per my internal... Madhes: methodology of CVSS calculation need not be that I have to follow the, what is available in the map. So, based on my environment, like UAT, or test environment, or production environment, where it has been placed, my scoring system will change. Then, it automatically becomes non-critical. Madhes: So that's... InfosecTrain Trainer: What I'm saying, in the CISM exam, don't compare what is happening in the environment, just

see what is InfosecTrain Trainer: seen in the situation, in the question, just go by that. That's it. InfosecTrain Trainer: That will determine the answer. If you start putting too much analysis, a lot of people actually get a lot of questions wrong, because they put a lot of InfosecTrain Trainer: too much analysis. That is not required. You just read the question, what question is saying, read four options, and then see what is the good answer. That's it. InfosecTrain Trainer: No need to... InfosecTrain Trainer: actually do a good analysis, okay, this is what is happening in the organization and all, right? Probably, Madhesh, your analysis would be correct also in your environment. Even I know that if you say any vulnerability which is... which you are identifying as a critical, it... it's always... there is always going to be an, probably a risk associated with that, right? InfosecTrain Trainer: That I know, but question is simply saying, if there is a critical vulnerability, unpatched vulnerability, but there is no InfosecTrain Trainer: threat to it, it's distinct from a threat, what do you call it? That's what it's asking. That's as simple. InfosecTrain Trainer: Got it? InfosecTrain Trainer: Nope.

InfosecTrain Trainer: how do you actually... what are the approaches which you take to actually manage the risk within the enterprise, right? Security risk management. First thing, you need to use a reference model. InfosecTrain Trainer: What is the reference model? So, there is a risk management framework from an ISO. InfosecTrain Trainer: There is a risk management framework from the NIST, InfosecTrain Trainer: There are... there is a fair... InfosecTrain Trainer: Institute Risk Management Model. Has anyone heard of FAIR Institute? InfosecTrain Trainer: Pear Institute. Mukesh Thakur: Nope. InfosecTrain Trainer: you can probably Google it. You can go to their website. InfosecTrain Trainer: They are like NIST. So, like, NIST developed the models for, all the frameworks for the cybersecurity. FAIR Institute develops the methodologies and the framework for the risk management. You can go to their website, they have very good articles and the reads, which you can read. InfosecTrain Trainer: to develop your good understanding around risk management, right? So, FAIR Institute also has them. InfosecTrain Trainer: So, you need to adopt any reference model. InfosecTrain Trainer: to begin with the risk management, right? So that reference model will help you decide or understand how the risk would be treated in your organization. Then you will InfosecTrain Trainer: tailor it to the enterprise circumstances. So, probably the risk management methodology, what I was doing in my current organization, probably I was in a consultancy firm. InfosecTrain Trainer: From consultancy, I moved to a manufacturing. Probably same thing won't be applicable there, right?

In the manufacturing, there is an IT OT environment, there are a factory, there are supply chain, there is a... there is a... InfosecTrain Trainer: there is a transportation, all those things gets into the picture, right? So then, those risk management landscape gets changed. So that's why you need to adopt as per the enterprise circumstances. InfosecTrain Trainer: And then you need to reflect what you want to achieve in a future state. Future state would be InfosecTrain Trainer: Adaptability, or adaptability, or your current risk management practices with respect to your future State is 2. InfosecTrain Trainer: Show compliance, or show gaps with respect to the current... this particular framework, what you have adopted? InfosecTrain Trainer: To establish the risk management in the organization, first thing what? You need a policy. InfosecTrain Trainer: You need to create risk management policy, which I... defines how the risk would be treated, which methodology would be used, what is a criteria to distinguish and define risk management, what are going to be the planning and the resources which will be used, right? InfosecTrain Trainer: How you are going to implement it, what is the implementation program, how the management review will take place, and how risk management process are the documented in the organization. InfosecTrain Trainer: So these are some couple of risk management-related frameworks, like ISO 27001, you all know there is one ISO 27005, ISO 31010. InfosecTrain Trainer: So, these are the standards with respect to risk management. NIST has a NIST SP800-37 risk management framework and hyphen 39 Managing Information Security Risk.

InfosecTrain Trainer: There are other industry frameworks which also define risk management as a COVID risk IT framework, RIMS, maturity model. InfosecTrain Trainer: So you can pick any of it, or probably you can tailor it as per your organization need to create that risk management framework for your organization. InfosecTrain Trainer: Now, before we come to this, let me... show you... a risk? InfosecTrain Trainer: assessment framework. InfosecTrain Trainer: Yes. InfosecTrain Trainer: I will talk again around how you do the risk assessment, right? So this is how the risk assessment matrix, or the framework looks like. InfosecTrain Trainer: You can see, I think this will help you understand how the risk management works. InfosecTrain Trainer: I can... InfosecTrain Trainer: Take a screenshot. InfosecTrain Trainer: Yeah. InfosecTrain Trainer: So this is how it works, right? So, it may differ from organization to organization, this is not a universal rule. This needs to be created by your senior management, your enterprise risk management committee, they have to create it. Not... you will not be creating. InfosecTrain Trainer: As a cyber team. InfosecTrain Trainer: So, what does a likelihood of 1 means? InfosecTrain Trainer: No occurrences next two years, no occurrences next year becomes 2, 1 occurrence in every 2 years becomes 3. Four becomes if one occurrence per year, if more than an occurrence becomes a 5. InfosecTrain Trainer: So this is how you will define the likelihood. Then comes the impact. InfosecTrain Trainer: So the impact criteria generally determined on all multiple parameters, and it may increase or decrease as per your organization context.

Financial impact, health and safety, operational, reputational, strategy, legal, regulatory, management effort, or you can have more categories. InfosecTrain Trainer: Financially, 1 percentage of the revenue is getting impacted, called 1, 2.5% is 2, 5% is 3, 10% is 4. InfosecTrain Trainer: And more than 15% becomes 5. Likewise, there are other categories, so this probably gives you an overall insight how you create a likelihood and the impact matrix. InfosecTrain Trainer: How you do the risk assessment, this I will talk later. How you do this coping and all, how you actually do an on-ground risk assessment that I'll talk later. InfosecTrain Trainer: So first, understand how you quantify this likelihood and impact, right? I just showed you. InfosecTrain Trainer: how that particular matrix is created, right? So, risk is something when a threat is exploited by vulnerabilities. InfosecTrain Trainer: Then you will, account for the asset values and the probability. InfosecTrain Trainer: So, in the likelihood assessment. InfosecTrain Trainer: You will... likelihood, or the probability assessment, you will understand exactly how many times that risk has an probability of occurrence. InfosecTrain Trainer: For that, you need an understanding around adversary, how sophisticated threat actor is, what is their motivation and capabilities, what is an overall posture of your organization, all those things will determine the likelihood. InfosecTrain Trainer: Impact? InfosecTrain Trainer: will be determined on the basis of your organization landscape. It will be determined on the finance, operational, reputation, regulatory, customer, or the partner trust. InfosecTrain Trainer: I just showed you that matrix, right?

InfosecTrain Trainer: So, this is how you determine the impact and the likelihood criteria in the organization. InfosecTrain Trainer: Now, to determine it, to create that matrix, first you need to define the external environment. InfosecTrain Trainer: So, external environment for each organization is different. InfosecTrain Trainer: Which particular country you operate in? InfosecTrain Trainer: Or how many country your business operates in, what kind of product and services you are selling, what kind of business you have, right? Like, marketing factor. InfosecTrain Trainer: So, what is the local market conditions? What is the business landscape? What is the competitive environment? Like, earlier, all the people, those who were from India, earlier in India, we only had one or two quick delivery apps. InfosecTrain Trainer: now there is a Flipkart also entered here, now Amazon also entered, now we have a Zepto, we have a Blinkit, we earlier had a Dunzo, now purchased by the Reliance. InfosecTrain Trainer: Also, we have a Swiggy Instawatt, so many players which have come into the market. Now, in Bangalore, there is one more. InfosecTrain Trainer: every month, a new startup comes into the same. InfosecTrain Trainer: So, that's why the... now the market conditions have changed, now the competitive environment has changed for the organizations, right? Regulatory framework. InfosecTrain Trainer: Now, EU AI Act, DPDPA, NIST2, InfosecTrain Trainer: Even recently, I heard the Middle East countries, I think Dubai also got their data protection law, similar to GDPR. So, so many regulations and the things which came into picture, and if you are actually collecting the PII data and those information, then you get impacted. InfosecTrain Trainer: Social context.

What is the culture, conditions, and the external stakeholder expectation? InfosecTrain Trainer: So every country has a different culture and the social context, which changed that particular thing. InfosecTrain Trainer: And the financial environment. What are the economic conditions? What is the business conditions and the revenue generation of your organization? InfosecTrain Trainer: Right? All those things will determine the external environment. InfosecTrain Trainer: Now, you will determine the internal environment, which is internal to your organization, right? InfosecTrain Trainer: Which you have a control on. InfosecTrain Trainer: Like, your market integrators, your competitive advantage, right? So, some companies, they have a competitive advantage, like NVIDIA. InfosecTrain Trainer: So, NVIDIA developed those GPUs firsthand, so they had a competitive advantage. Before developing those GPUs, or a chip which support AI model to run, NVIDIA was worth some billions only. InfosecTrain Trainer: In a year and a half time, NVIDIA have gone from a billion to trillion. Now, they are 4 or 5 trillion dollars worth. You imagine. It's almost 400-500% jump. InfosecTrain Trainer: So, all these things defined. Now, organization structure. InfosecTrain Trainer: How your organization's overall structure is placed, what kind of structure you follow. InfosecTrain Trainer: Right? That will also determine your internal environment. InfosecTrain Trainer: Then, assets and resources. InfosecTrain Trainer: So you're... InfosecTrain Trainer: people, processes, technologies, all those things, right? How critical your people are, what is their technical capabilities, right? How technically sound those resources are, that will also determine that, and the strategic objectives.

InfosecTrain Trainer: what are the goals, and what organization want to achieve? What are the timelines which are given to achieve those objectives? So, all these factors affect your internal environment. InfosecTrain Trainer: So, if you see that key difference. InfosecTrain Trainer: Internal forces that directly impact the business, external forces that directly impact the business. InfosecTrain Trainer: It involves within the business, outside the business. This is where we call the... you would have heard the word micro and macro environment, right? So, micro is something which is always being referenced to the internal, and the macro is the external environment. InfosecTrain Trainer: It can be controlled, it cannot be controlled. Can you control the... where the war will go between the... between the Iran and Iran, Israel, and US? Can you control what kind of tariffs the Mr. Trump will put against your country or your business? You cannot, right? InfosecTrain Trainer: So, it affects only certain type of business, it affects all kind of businesses, it shows the strength and weakness, and shows the opportunities and threats. So, this is how you determine the internal and the external environment for your organization. InfosecTrain Trainer: Now, coming to the risk likelihood and the impact assessment. InfosecTrain Trainer: So, as I showed you that matrix, right, this is how you determine there. InfosecTrain Trainer: So that's what I said, that that matrix which I showed you, I've also pasted in the chat, that is not something which is universal in nature. InfosecTrain Trainer: That will vary from organization to organization. InfosecTrain Trainer: That will vary from organization to organization, right?

Like, likelihood of... InfosecTrain Trainer: So, rare being 1, unlikely being 2, 3, 4, 5, like I also showed you that matrix, right? How that particular matrix is derived. InfosecTrain Trainer: this one. InfosecTrain Trainer: So here, it's talking about other aspects, right? InfosecTrain Trainer: improbable remote possible, probable, almost certain. Likewise, your organization can have a different matrix. InfosecTrain Trainer: But this is how you determine the likelihood and the probability of occurrence. InfosecTrain Trainer: Now... InfosecTrain Trainer: how the risk categories are created. I showed you those risk categories, right? Operational, financial, and all those categories, which actually help you determine the impact. InfosecTrain Trainer: So, risk categories are determined on the basis of the organization environment, and these are the four factors which help you determine them. So, the first risk category would come from the InfosecTrain Trainer: Governance and the operational aspect of the organization. InfosecTrain Trainer: How the corporate governance work, which we discussed in the domain work, right? InfosecTrain Trainer: What was the corporate governance? You have the board of director, board of directors appoint the CEO, then CEO helps board of director appoint all the C-level executives, your COO, CFO, and all those things, right? That is the corporate governance. InfosecTrain Trainer: How that works for the organization, that will determine the operational InfosecTrain Trainer: Related risk, then strategic risk. InfosecTrain Trainer: What is a strategic risk? Something which will actually... any kind of risk category, which will have an impact on your strategy.

InfosecTrain Trainer: So your strategy is to go from a regional business to a global business, but there are some factors which will impact that, that you cannot go global. InfosecTrain Trainer: So, that becomes a strategic priority. Your organization want to file an IPO. InfosecTrain Trainer: But to file an IPO, you need to achieve probably 4 consecutive quarters of a growth of 1%. InfosecTrain Trainer: Quarter on quarter. InfosecTrain Trainer: If you're not able to achieve it, it will have an impact there, right? So these are some of the strategic InfosecTrain Trainer: related factors. Human resource. InfosecTrain Trainer: If there is a challenge with respect to the human resources, that also brings a risk. InfosecTrain Trainer: Reputation. InfosecTrain Trainer: Reputation risk also falls under this category. Project management. If you're not able to complete or deliver the projects on time, it has some risk. Suppliers. InfosecTrain Trainer: supplier, third parties, those who help you with your business, facilities and the operating environment. So, these are the governance and the operational. Then technical is something which is related to information. InfosecTrain Trainer: The framework which you adopt, processing and the behavior, and the technology. Like, all tools, technologies, tech stack, what you have. InfosecTrain Trainer: Environmental and safety-related risk will include the health and safety, geopolitical, culture, and the climate and weather-related issues. InfosecTrain Trainer: Legal and regulatory will include the compliance, criminal, and the ethics. So, if I... if I show you this, you see the categories? InfosecTrain Trainer: If you see operation, The reputation, how it says.

InfosecTrain Trainer: For one means the negative coverage resulting in limited local damage to the reputation and minimal issues. InfosecTrain Trainer: If you see the very high, prolonged, extensive, negative national, international media coverage for multiple days, becomes a InfosecTrain Trainer: Very high. InfosecTrain Trainer: This is how you determine the categories on the basis of this. InfosecTrain Trainer: So these are the categories which every organization needs to create, and then they need to determine the impact and the likelihood criteria accordingly. InfosecTrain Trainer: Now, coming to the risk register. InfosecTrain Trainer: How many of you have seen the risk register of your organization? Supriya Mhatre: Yes. Supriya Mhatre: I see. InfosecTrain Trainer: So, the risk register... InfosecTrain Trainer: The risk register. InfosecTrain Trainer: may differ from organization to organization. You may have a different kind of fields altogether there, right? But from a ISACA perspective, you need to understand risk register is a record InfosecTrain Trainer: Which contains the information about the business risk, and the main purpose of Risk Register is to prioritize those risks. InfosecTrain Trainer: Have an accountability set account against those risks, and then track those risks which are sitting in your risk register. InfosecTrain Trainer: Now, let me go to the case study. InfosecTrain Trainer: We saw this likelihood and impact criteria, right? Now, how do you do a risk register... a risk assessment in real life scenario? InfosecTrain Trainer: in your organization, your CISO said that I want to... I want you to do a risk assessment. InfosecTrain Trainer: against one particular tool, technology, platform, something you can name it.

He says that we are adopting the cloud in the organization. I want you to do a risk assessment with respect to the cloud. InfosecTrain Trainer: how secure our cloud infrastructure is, right? So then you need to first do a scoping. InfosecTrain Trainer: what you are going to cover, what all things would be added or covered as part of this, because you cannot just do a risk against all the things, right? So you see here, so, like, you will, you will first, do what kind of assessment you are doing. InfosecTrain Trainer: What is the objective of this particular risk assessment? What is the start date, completion date? What are the countries in scope? InfosecTrain Trainer: you may have a global enterprise, you say, okay, first, this year I'll only do the scoping for India or our US, InfosecTrain Trainer: What are the business units involved? What kind of technologies, what are the system applications in the scope, what are the out-of-scope items, and why you are excluding them, and then who is going to be assessing it. So this is how fast you do the scoping. Once scoping is done. InfosecTrain Trainer: Then you do the risk assessment against it. InfosecTrain Trainer: So this may differ from your organization or someone else's organization, right? But this is just an example to make you understand how the risk assessment is done and how the entries are made in the risk register. InfosecTrain Trainer: This is how the entries are made in the risk register. InfosecTrain Trainer: So, first, there is a risk of the information disclosure due to non-availability of controls. InfosecTrain Trainer: This is a risk. InfosecTrain Trainer: So, there is a possibility that information, sensitive information, get disclosed. What are the causes? InfosecTrain Trainer: Of this risk.

InfosecTrain Trainer: It may happen due to phishing attack, ransomware, lack of email security, lack of information classification control, anything may cause this. InfosecTrain Trainer: What are consequences? If this risk occurs, what are the consequences? It will... you may face a regulatory impact. Suppose you are a GDPR-compliant organization, you will have a reputational impact, operational impact, if that information is not available. InfosecTrain Trainer: now someone is assigned as a risk owner here, then you gave the... this is the inherent risk. There is no control, I'm just assessing on the basis of my current environment, threat landscape, this is the impact likelihood, then I got the severity. InfosecTrain Trainer: Now, I will note there are some existing controls which are there in place in my organization. InfosecTrain Trainer: So I have one information classification policies, I have a backup, RPO is defined, there is XDR deployed, DLP is deployed, but there are some additional gaps which do not exist at this point of time, like DLP policies for data sharing is not there. InfosecTrain Trainer: Backup and storage to offshore location is not being maintained. InfosecTrain Trainer: Then I'll note down the status of all the existing control, who are going to be the action owner, and on the basis of that, I'll determine the residual risk, which I'll accept. InfosecTrain Trainer: So, after deploying these controls, I say, okay, this is, reducing the impact and the likelihood, and as per that, my recurrent risk stand here. InfosecTrain Trainer: Everyone is clear how the risk assessment takes place in the organization. InfosecTrain Trainer: And this comes from the real-life scenario. I do good number of risk assessment in the organization.

From there, only this is coming. So this is on the base of my experience, how I do the risk assessment. Madhes: See, risk register is consolidation of all the risk of the organization, right? Risk assessment, maybe for one particular technology, or before introducing one technology, or after introduction, some, you know, changes, some... one more risk assessment. Madhes: Batch. Also, sometimes we do risk assessment for, identifying the Madhes: in case not, possible to apply, then it comes with some, risk also, like hype. So, whether those risks also captured as part of risk register, suppose, patch risk assessment. Madhes: Whether it should be updated in the risk register. InfosecTrain Trainer: No, no, so the risk register will contain the risks which are actually affecting your overall organization. InfosecTrain Trainer: Then, if you are doing some specific risk assessment with respect to one odd process, right? Suppose you are doing the risk assessment of the unauthorized disclosure. You are doing the risk assessment of your AI solution. InfosecTrain Trainer: you are doing the risk assessment of your critical third parties. So those are the risk assessments which you are driving specific to one particular thing or process. From once that risk assessment is done, then probably from that, whatever are the critical findings or the critical risks InfosecTrain Trainer: which are currently not present in your risk register,

those will come and sit and get mulched here. InfosecTrain Trainer: So, risk register... Do not contain all thousands of the risks which are sitting in your organization. Madhes: The outcome of risk... yeah, the outcome of risk assessment, where, findings of the new technology, risk shall be part of the risk register.

InfosecTrain Trainer: That's what I'm saying. Only the critical one which has a significant impact would come and sit here. And probably there are some risks which broadly covers a lot of things. That's why the risk description InfosecTrain Trainer: And risk causes, you have to design it in such a manner so that broadly, it covers all the things. InfosecTrain Trainer: Now, the information disclosure due to non-availability of control, this is a broad category. It will even include the AI also. Generative AI will also get covered as part of this, right? Sandeep Saxena: One question. Residual... residual risk will not be mentioned in the beginning, right? That will be mentioned only after putting up some controls and then see if this is residual. InfosecTrain Trainer: Yes, correct. Sandeep Saxena: Okay. Second... second question? Sandeep Saxena: Will we use CIA? Sandeep Saxena: For risk description, for example, you have mentioned information disclosure. Second... second row may be... integrity. Third, maybe... Sandeep Saxena: Something else, right? InfosecTrain Trainer: You do not follow that approach. Okay. So, second risk can be... InfosecTrain Trainer: This is another example. Ransomware attack against critical enterprise infrastructure. InfosecTrain Trainer: It do not distinct... distinctly mention that which critical infrastructure. It's a broad category, right? So you have to see in a broad term how many critical infrastructure, critical assets you have, and then you have to define all these things. Got it? Sandeep Saxena: Hmm. Sandeep Saxena: Okay. InfosecTrain Trainer: I can... Sandeep Saxena: I mean, we are discussing about risk assessment, what can happen, right?

So, we thought of information disclosure, we thought of ransomware attack, we can think about, Sandeep Saxena: The availability also, right? InfosecTrain Trainer: Yes, correct. InfosecTrain Trainer: All the things, all the things you will... you can think of. InfosecTrain Trainer: And then, broadly, these description would be on... derived from the CIA only, right? InfosecTrain Trainer: Impact on your availability, impact... so this is the impact on your confidentiality, right? Information disclosure. InfosecTrain Trainer: There can be an impact on integrity. There can be impact on availability. Ransomware is impact on availability, right? InfosecTrain Trainer: So... Sandeep Saxena: So, it's like, whatever I can think of, I can mention, mention over here. Yes. Whatever is, having the severity of, like, for example, more than 16 or something, that can go to waste register. InfosecTrain Trainer: Correct. InfosecTrain Trainer: And this is just one method which I follow. You might be following some different method also. So this is not an asset-based risk assessment, what ISAC has talked about. InfosecTrain Trainer: So, asset-based risk assessment is totally different. InfosecTrain Trainer: So, in asset-based risk assessment, you will first list down all the assets. InfosecTrain Trainer: Against each and every asset, you will carry out this exercise. InfosecTrain Trainer: what I'm doing. InfosecTrain Trainer: And that is actually a very complex process. In your organization, you have a n number of assets. InfosecTrain Trainer: So doing this, it's a very difficult, very complex process. This is a very simplified version of that, where at broad level, you just see broadly your complete organization, and then you do a risk assessment. Sandeep Saxena: Hmm. Sandeep Saxena: Okay.

InfosecTrain Trainer: So this is, another risk-registered example. This is more talking from the project management perspective, right? Pudir: I just milder, so... InfosecTrain Trainer: Yep, indeed. Pudir: We'll add in the extension here. Pudir: It needs something radical. Pudir: I'm gonna... Pudir: Who will be the optimal, level category to finalize the CISM would be in the history district, not in the history district. Generally, general parlance I'm asking. InfosecTrain Trainer: This is always a CISO. InfosecTrain Trainer: So I run the... I run the risk register calls, I manage my organization risk register, right? InfosecTrain Trainer: I have a monthly... cadence call with the CISO and all the key stakeholders, which I do every month. InfosecTrain Trainer: And quarterly, I meet with the Enterprise Risk Management Committee. InfosecTrain Trainer: This is... I'm talking from my experience perspective. I'm not sure how the process works in your organization. Pudir: Yeah, it's varying the... InfosecTrain Trainer: So every month, I sit with my CISO, I go with the complete list of the risk registered, what I have, and then I do my own analysis and put it, that executive summary to them. I say that, okay, last month the threat intelligence team came with these InfosecTrain Trainer: findings. InfosecTrain Trainer: Last month, there was so many true positive incidents. There was one data breach attempt against one particular account, and it got successful, so much data got accelerated, so I recommend that we should increase now the inherent risk rating from so-and-so to so-and-so. InfosecTrain Trainer: But now, suppose that incident got impacted... contained, I'll say, okay, the residual risk remains there. That's how the decision takes place. InfosecTrain Trainer: Got it?

Pudir: Thank you. InfosecTrain Trainer: But keep this in mind, that risk register, what is the purpose, why it is being maintained, right? That purpose needs to be very clear in your mind, right? InfosecTrain Trainer: Let's discuss some questions. InfosecTrain Trainer: Alright, let's discuss. InfosecTrain Trainer: When assessing the criticality of an information asset, which of the following factor is most important to consider? InfosecTrain Trainer: The asset's age and depreciation, the asset's technical complexity, the assets InfosecTrain Trainer: Role in business process are assets physical and the security control? InfosecTrain Trainer: So, if you read the question properly, it's talking about what is the most important factor. So, always, whenever you are understanding the criticality, you have to always see what kind of InfosecTrain Trainer: what kind of contribution that asset has in particular business process, business revenue, right? That's how the criticality is determined, right? If there is a server, it is actually attached to one particular critical business process. If that is not available, it will have very huge impact. InfosecTrain Trainer: So that's how you determine the criticality. InfosecTrain Trainer: Then comes the... an organization is implementing a new asset classification system, who should have primary responsibility for determining the asset criticality. The IT department, the information security team, the business process owners, the compliance department. Who should do that? InfosecTrain Trainer: Always, it should be the business process owners, right? So, business process owner know that what is the criticality of his business. InfosecTrain Trainer: Right?

How much revenue generation it has, what is the clear... InfosecTrain Trainer: contribution of his business to overall organization growth, so he's the better person, right? How come the IT department, information security team, and the compliance department know those information? No, right? So, business process owner is the correct answer. InfosecTrain Trainer: In the context of risk assessment, what is the primary purpose of creating risk register? To document all potential threat to the organization, to track and prioritize identified risk, to calculate the financial impact of each risk, to assign risk ownership to specific individuals. InfosecTrain Trainer: Option B is something which covers a couple of them. So, it helps you track and prioritize the identified findings, right? InfosecTrain Trainer: So if you prioritize, so you assign the ownership as well, right? InfosecTrain Trainer: You also... and it's not... main purpose is not to determine all the threats and these things, but to track and prioritize all the identified risks. InfosecTrain Trainer: Alright, then go to the next topic. InfosecTrain Trainer: Now, understanding the vulnerabilities. So, at high level, we understood that what are the techniques through which we identify the vulnerabilities, right? InfosecTrain Trainer: What are the techniques which we use to understand the vulnerabilities? So, vulnerability, when it is referenced to, do not always go and talk about a technical vulnerability which has a patch. InfosecTrain Trainer: That is not the actual definition of vulnerability. Vulnerability means any weakness. It weakness can be in design, implementation, operational, or the internal control. Anything which is talking about this will become a vulnerability.

InfosecTrain Trainer: And whenever you are doing a vulnerability assessment, you must consider the complete processes, procedures, physical vulnerabilities, additional to the technological weaknesses what you have. InfosecTrain Trainer: And when you consider this, you have to understand one thing. You have to take a context of vulnerability within overall system of the organization. You need to also think of the mitigating controls InfosecTrain Trainer: that you will deploy to reduce the exposure, right? What is the interconnection between the different vulnerabilities, right? That's why you just do not merely consider one vulnerability as a standalone. InfosecTrain Trainer: So, attacker won't just compromise one vulnerability to gain access. He may use the combination of multiple vulnerabilities to take this. InfosecTrain Trainer: Right? InfosecTrain Trainer: So that's how you have to understand. So how... if I take an example. InfosecTrain Trainer: person launch a phishing attack against your employee. So, first vulnerability is that the employee was not aware InfosecTrain Trainer: a process-related vulnerability. He clicked on the phishing link, a malware gets deployed, it means your anti-malware software and your EDR are also not functioning well. They could not detect the malware and mitigate it here. InfosecTrain Trainer: Now... InfosecTrain Trainer: There was no alerts generated on SIEM, another one, vulnerabilities. There is no proper detection mechanism in place to detect that kind of malware. InfosecTrain Trainer: So, you see. InfosecTrain Trainer: So, you have to establish the interconnection between the multiple vulnerabilities, and always purpose consider the technical and non-technical.

So, this is non-technical vulnerability, where a person do not understand the process. InfosecTrain Trainer: He do not know the... he did not attend the awareness training properly, he did not have the understanding around it, that's why he clicked it. InfosecTrain Trainer: Now, once you identify any vulnerabilities, there are 3 phases to it. InfosecTrain Trainer: Identify, validate, and classify. InfosecTrain Trainer: So that's what you do with the CVSS scoring system. InfosecTrain Trainer: First, you identify the vulnerability, so there are two types of things which you consider. InfosecTrain Trainer: Environmental? InfosecTrain Trainer: Mental score, and there is something called the temporal score. InfosecTrain Trainer: What is the temporal score? Temporal score is

something which is given by the vulnerability identify... the person who identified this vulnerability, he gave a temporal score. He says that this is a vulnerabilities. InfosecTrain Trainer: It can be exploited, it has a rating of 9. InfosecTrain Trainer: This is a rating of 9. InfosecTrain Trainer: given by that particular person. But once this system gets deployed in your environment, you have firewall, you have EDR, you have so many things. You have a separation between the prod, non-prod, then a separate score would be given, right? Suppose the system is deployed in a non-prod. InfosecTrain Trainer: and CISM is deployed in a prod, the score will differ, right? Non-prod will have a lesser score, prod will have a higher score, given to the vulnerability. InfosecTrain Trainer: So that's how you do that, so you validate them. InfosecTrain Trainer: And then you classify. So then you classify, you say that which is a critical vulnerability. InfosecTrain Trainer: Right?

Which is a high-rated vulnerability, which are the moderate-rated vulnerability, which are the low-rated vulnerability. So you first identify using a scanning, using audit, using penetration testing, any method you can deploy, you will do that, then you validate, you will check. InfosecTrain Trainer: Are there true positive, false positive, right? InfosecTrain Trainer: Then you classify it. InfosecTrain Trainer: So this is an overall vulnerability management process which any organization follows. InfosecTrain Trainer: Now, to mitigate the vulnerabilities, there are two methods. One is called the safeguard, one is called the countermeasure. Can someone tell you what is the difference between the safeguard and the countermeasure? SrinivasanJ: Proactive and reactive. InfosecTrain Trainer: Nope. InfosecTrain Trainer: Key difference between the countermeasure and safeguard is that InfosecTrain Trainer: Countermeasure is something which directly reduces the threat. InfosecTrain Trainer: And safeguard is something which helps you prevent that thing from happening. Let me take a very simple example. You would have seen a lot of, a lot of war movies, right? You have seen the fighter aircraft flying? InfosecTrain Trainer: When a missile... approach a fire... a fighter aircraft. A fighter aircraft do what? It immediately deploys a flare. InfosecTrain Trainer: seen that, right? They deploy a flare, and due to the flare, that missile get blasted in air, thinking that InfosecTrain Trainer: That particular flare as an actual aircraft. InfosecTrain Trainer: That is a countermeasure. InfosecTrain Trainer: What is a safeguard? InfosecTrain Trainer: In that aircraft, he has couple of, InfosecTrain Trainer: systems, systems, parameter recording systems, he has heat sensing systems and all.

InfosecTrain Trainer: radar system, which give him early warning or the indication that there is a missile which is approaching you, you have to do the evasive maneuver to do that. So that... those are all the safeguards. The safeguards are the practices, procedures, or mechanisms that reduce the risk. InfosecTrain Trainer: Which is reducing the risks of that missile impacting this aircraft. InfosecTrain Trainer: If I take another example of the fire. InfosecTrain Trainer: The fire do not happen in a building. What you do, you... you design a building using a fire-redant material. You make sure there are no open wire. InfosecTrain Trainer: You make sure there are adequate number of fire, fire mitigate... fire extinguishers in the building. InfosecTrain Trainer: You make sure that there are open air systems, so that if a fire happens, there are people, they can evacuate. But if actually a fire takes place, what is thing which is directly reducing the fire is the sprinkler system. InfosecTrain Trainer: A fire alarm and a sprinkler. Immediately, it will deploy the sprinkler, and the fire will get extinguished, right? Those are the countermeasures. InfosecTrain Trainer: So any control... so we have a big topic against these controls in the Domain 3, where we will discuss all the type of control, those preventative control, those detective control, those... InfosecTrain Trainer: directive controls, right? All those things we will discuss in detail in Domain 3. So, controls are something which are designed as part of information security risk management framework, policies, standard procedure, and the organization structure. On the basis of that, you design the controls, so controls InfosecTrain Trainer: Will either act as a safeguard, or they will act as a countermeasure.

InfosecTrain Trainer: And what are the contributing factors when you are designing them? You will take the culture into account, you will consider the ethics, staffing, and the skill level before deploying and deciding on any of the control. InfosecTrain Trainer: No... InfosecTrain Trainer: how you implement the effective security controls, so these are the methods, right, which we will discuss in the next week's class, right? InfosecTrain Trainer: But before we close... InfosecTrain Trainer: Let me share some videos with you all. InfosecTrain Trainer: So, we completed the Domain 1. Please, all of you, start, complete the Domain 1 questions. InfosecTrain Trainer: All of you, please go back today, in the next week, finish the Domain 1 questions from the QAE manual. InfosecTrain Trainer: These are some videos which you can watch regarding the controls, risk management questions, and how the risk management framework is created. InfosecTrain Trainer: Before you come to the next week's class, and also. InfosecTrain Trainer: Please solve those questions from the domain one. Complete it. InfosecTrain Trainer: Because you have 5 days now in your hand, with next week, we will complete the Domain 2 and start the Domain 3. InfosecTrain Trainer: So then, we will have a gap of 1 week, because on 28th weekend, I'm not available. So in that weekend, at least, you can finish the Domain 1, Domain 2, as well as partial part of Domain 3 also. InfosecTrain Trainer: So if you continue to be on track, what I'm saying, it becomes easy for all of you to write the exam on time. Otherwise, you will... InfosecTrain Trainer: Delayed. InfosecTrain Trainer: Yeah. InfosecTrain Trainer: So before we log off, anyone has any questions?

Sandeep Saxena: Are we supposed to read Hemang Dushi's book, or you're already covering that? InfosecTrain Trainer: No, all the topics related to what you have to study for the CISM exam are covered by me. InfosecTrain Trainer: Hemang Doshi book is just for the reference. So, once you are solving the questions, at that point of time, if you identify that you have some gaps, you are not able to understand one particular topic, that time, you can go search that particular topic and read and refer. InfosecTrain Trainer: You don't need to read the entire book. Sandeep Saxena: Okay, thanks. Shweta Sundar: Hi, this is Shweta here. Is it possible to post again the dates when the... I missed it in the last thing. I think there are some weekends we are not going to have the class. InfosecTrain Trainer: Yeah, it's... it's only the... only the... next to next weekend. So, yesterday we had a 15th August, that's why there was no class, and then, 29th and 30th, I'm not available, I'm attending one conference. Shweta Sundar: Okay, okay, sure, thank you. InfosecTrain Trainer: Next... next weekend, we'll have a class. InfosecTrain Trainer: Completely. Shweta Sundar: Okay. Okay, thank you. InfosecTrain Trainer: So 29th and 30th August, we'll have no class. Otherwise, that tool will... Have the classes. Shweta Sundar: It's a twin. InfosecTrain Trainer: Anything else apart from this? Pudir: Can you move this fantastic. Pudir: CP levels. InfosecTrain Trainer: Yeah, CPRs you will get from InfosecTrain for completing this training. You will get 32 hours of CPE credit, which you can also claim also. If you are able to clear the exam this year. InfosecTrain Trainer: So, for this year's quota, you can claim from that... those CPRs. Fatha: Hi, Sashank, do we get a voucher or anything for writing the exam?

InfosecTrain Trainer: Yeah, a voucher, you... you can subscribe for it from the InfosecTrain. Probably for more details, you can talk to the Saxam, who's there in the group. You can ping him, he'll help you with that. Fatha: Okay, thank you. Sandeep Saxena: Thank you. Bye. InfosecTrain Trainer: Alright, then. Thank you, thank you so much, everyone. InfosecTrain Trainer: Yeah, everyone have a great, great weekend. subaveena pugalethi: Thank you all! Manoj Kamble: Thank you, everyone. Bye. Ashwin: Thank you.

Day 4: Full Cleaned Transcript

Approximate source length: 28,628 words.

InfosecTrain Trainer: Hello, good evening, everyone. Let's wait for one more minute, and if more participants join, then we'll get started. Fatha: That shows me. InfosecTrain Trainer: So, hello everyone. InfosecTrain Trainer: So, we... last week, we completed the Domain 1, and we started the Domain 2, right? So, how many of you have, got a chance to solve the practice questions? Sandeep Saxena: I started, I saw around six single shirts for Wimbledon. InfosecTrain Trainer: Okay, okay. How many, how many of you got correct? Sandeep Saxena: I think near to 70%, I think. InfosecTrain Trainer: Okay, okay, good, good. Anyone else apart from Sandeep who tried? Manoj Kamble: Yes, Shashank. From my side, I have started Domain 1. I could able to solve, like, 50, and I've seen, like, progress of success, like, 60%. InfosecTrain Trainer: So, any... anyone has any doubts, or any... any kind of questions before we get started? InfosecTrain Trainer: From previous Doom, in any topic, anything which probably you could not understood, or have some. Fatha: Yeah, actually. InfosecTrain Trainer: Jen. Fatha: Hi, Sushant. Actually, I think in the previous slides, not this, some couple of slides before, I saw business requirements for security strategy. So this is. InfosecTrain Trainer: Actually, risk management domain, so I don't think there was any business requirement here. Fatha: Yep, not here, it's... Because. InfosecTrain Trainer: This is the risk management domain, which we are discussing now. Fatha: Yeah, no. InfosecTrain Trainer: That would have been there in the domain 1, I think. Fatha: Okay, so, like, will there be any requirements, business requirements for security, making security strategy also? InfosecTrain Trainer: Correct. Yes, it should be. So, the security. Fatha: Both of.

InfosecTrain Trainer: Even security as a function itself is there to support the business, to support, to meet the business requirement, right? To fulfill the business. That's what is the main purpose of security. So any question in the exam, right, you have to always give preference to the business requirement. That will always take the precedence. Fatha: Yeah, correct. It means the business requirements are the same as what security business requirements, right? InfosecTrain Trainer: Correct, correct, it. Fatha: Done, okay. InfosecTrain Trainer: Like suppose in your organization, a business is developing probably a software product, right? So, so they will have some business requirement, they would have something, something they would want to introduce in the product, which would probably help them promote it in the market, gain better, generate more amount of revenue and all. So, so from a security point of view, you have to make sure that you put across a compensating control, you make it. InfosecTrain Trainer: more user-friendly, right? Like, if your bank starts telling you that every time you have to enter a 16-digit password. InfosecTrain Trainer: How many people will actually remember a 16-digit password, right? That's why now you see most of the phone banking customers, they have now migrated to two-factor authentication, or you can use your fingerprint, biometric, or your face, or some 8-digit PIN, 6-digit PIN to unlock, right? So these are all the things what organizations do to make sure that the business. InfosecTrain Trainer: Requirements are met, and the customers... there is a trade-off between the security and the business. Fatha: Yeah, but security also itself can be a business, right? Like for security companies. Yeah.

InfosecTrain Trainer: So that's what I'm saying. So even for the security, like Microsoft has a lot of security-related products, right? They have a DLP solution, they have an EDR solution, they have other range of solutions, right? They have a SIEM solution, they have a CSPM solution. So Microsoft is also a security company together, right? They are a big portion of... Fatha: It doesn't. InfosecTrain Trainer: tech stack in security. So, so they have to make sure that all the, security and all the customer requirement, everything is, are being met. Fatha: Yeah, and. InfosecTrain Trainer: So, anyone else before we get started? Anything else? InfosecTrain Trainer: So last... so this domain, right, we started with the introduction of RES, right? So... so if you have not yet got chance, right, so we will complete the domain one... two today. InfosecTrain Trainer: Domain three, we will start tomorrow and probably will complete 40 to 50% of the domain three because the next week, as I told you, right, I'm not available. I'll be traveling for one of the conference. So you people will get a good amount of time to probably complete domain two questions. So at least utilize this break which you have got to complete all the questions till domain two, right? InfosecTrain Trainer: So that you are on, probably, InfosecTrain Trainer: on the pace with the training what I'm giving right and then probably if you want you can because this batch the main thing is that if you actually want to write in this old pattern then you have to follow my pace otherwise then if you wait for a new pattern to come which is getting introduced by November first week then you have to again read some couple of new topics and then.

InfosecTrain Trainer: No one is aware what what kind of question patterns and all they will introduce. Probably some of you will go right, then give me feedback, then I'll understand what kind of changes ISACA has done. So that's why it's better always to write in an old pattern, which all of you are already familiar with. So continue to follow my pace so that probably by. InfosecTrain Trainer: end of September, mid of October, you will have almost a month plus time to complete and then, write the exam. Yeah. InfosecTrain Trainer: Now, coming to this was the topic which we were discussing last time, right? Safeguard and the countermeasures, right? So, whenever there is a risk, so we discussed one case study, right, where I showed you how you to do a risk assessment. So, whenever you calculate inherent risk, to reduce inherent risk to an acceptable level, you have to design and deploy some controls. So, those controls are either going to be in the form of safeguards or inform the. InfosecTrain Trainer: countermeasures, right? But what is the key difference? Safeguard is something which prevents or reduce the risk, like any preventative control, any detective control, any kind of controls which you have, right? But the countermeasures are something which directly reduce the risk once the risk happens, like fire. InfosecTrain Trainer: So suppose you have a risk of fire, so what you do, you design a building in such a manner so that there are no fire take place, right? You will design, you will conceal the wires, you will make sure that there are no open end, no wire, you will use the fire retardant materials, everything you will make sure, right? But still, if tomorrow fire occurs, what is the countermeasure? You have a sprinkler which will immediately.

InfosecTrain Trainer: operate and make sure that the fire is reduced, right? So that becomes a countermeasure, right? And whenever you are designing either a safeguard or a countermeasure, you will make sure that the culture, ethics, staffing, and skills are being taken care of. So this was the last slide which we discussed last time. Now, coming to the type of control. So we have a topic in Domain 3 around the control where we will discuss in detail about. InfosecTrain Trainer: What are each control do, how you design them, how you select them. Right. But here also from a mitigation strategy point of view, we are seeing the control. So any control is divided into three categories. One is admin. InfosecTrain Trainer: technical, right? And... InfosecTrain Trainer: Physical. InfosecTrain Trainer: These are the three categories where you can place all the controls, right? So, admin is something which comes in the form of any direction, written policies, like your acceptable use policies, your information security policy, all the policies, even the instructions. So, whenever in your organization you go, if you have a lift lobby, right, there you can see some instructions which are kept, right? Do not block the doors whenever the doors are getting closed. InfosecTrain Trainer: In case of fire, please follow this route, right? If there is a fire extinguisher placed, so you will see some instructions which are kept there. So those are all the admin controls. InfosecTrain Trainer: Technical control, which are in form of the logic or technology, right? Your identity and access management policies, your firewall rules, your segregation of duties, right? You have a EDR, you have anti-malware software, right? So all those are the technical control.

Physical is something which is physically visible, right? Like your security cameras, your security guard. InfosecTrain Trainer: your physical biometric device, your turntable, whenever you go to the office, you scan your access card, right? So, there is a turntable which let one person enter. So, all of them are physical controls. These are the broad categories, and then, from the theme perspective, from what that control will do. InfosecTrain Trainer: On the basis of that, then there are further categories like preventative control. Preventative control is something which will prevent, issue from happening, like before something happens. Right. Like, firewall. So firewall rule will block attacker before attacker is trying to enter into your, organization perimeter. Right. Like anti-malware. InfosecTrain Trainer: As soon as a malware is detected, automatically the malware will block it or probably mitigate the threat, like encryption. It will make sure that the communication is encrypted so that unauthorized person is not able to access it. Then comes the detective. Detective is something which helps you detect the threat, like your logs. InfosecTrain Trainer: Your, ideas, your SIM solution. Right. All of them are a detective control. Your honeypots, which helps you, detect and, analyze the threat, actors, patterns. Right. Then admin control, as I already explained, corrective controls are something which will come into picture. InfosecTrain Trainer: Once the threat has... the incident has taken place, now you want to recover. InfosecTrain Trainer: risk in your enterprise always remain and maintains within a consistent acceptable level. Like if you have a password or account related control. Manoj Kamble: Minimum security. InfosecTrain Trainer: Correct.

So, it's a minimum level of any control which would apply and baseline is something which will decide your overall security posture. InfosecTrain Trainer: Because baseline is something which is the minimum, right? Like, baseline will say that all the generic accounts, all the normal user accounts, you will have a

12-character password. For all the PAM users or privileged accounts, you should have a minimum 14-character passwords. InfosecTrain Trainer: So, this is the baseline which you have set. You will say that each and every endpoint user laptop should bear minimum. It should contain a so-and-so version of anti-malware. It should have an EDR agent installed. It should have a VPN installed. This becomes a baseline. InfosecTrain Trainer: Right? So, whenever in your cloud, if your organization is cloud, so your organization will decide that this is the minimum level, minimum version of Microsoft Server or Linux Server version, which we will use to create any kind of server, right? Any server, when it is created, it should have a minimum these many things which should be there, right? Like, port 80 should be blocked, this should be done. So, these are all the baselines. InfosecTrain Trainer: line which your organization has, right? So you... so the baseline is something which will determine the collective ability of control to protect the assets, because this is the minimum level of security, right? InfosecTrain Trainer: And it will help you standardize the minimum enterprise security requirements. So what is going to be the bare minimum security which each endpoint, servers, your software, your applications, all those collectively will have what is the minimum level of security they should ensure.

InfosecTrain Trainer: And it will also help you allow the operational management through classification level. So baseline is on the basis of that also, right? How critical the asset is, how sensitive information is. On the basis of that, also some baseline comes into the picture, right? Like if we take an example of this data. So once you define the sensitivity labels like public. InfosecTrain Trainer: internal, confidential, restricted. So, on the basis of that, on the basis of that, then there is going to be some baseline, you say, right? All the public information is need not to be encrypted, but anything internal, confidential, and restricted must be encrypted in nature. InfosecTrain Trainer: So whenever you are sending, you are defining a DLP policies, it will make sure that this information is encrypted. So this also affect that. Also, it will provide the reference point for measuring the security changes and corresponding and all the corresponding changes which are happening, right? So that anything. InfosecTrain Trainer: If you are altering the baseline, it's mandatory you take an approval. You take an exception approval, you take an approval from a security team, whatever is the process in your organization, right? InfosecTrain Trainer: Also, it will help you... also, the baseline changes or any new standard, anything, so this is a good practice if those are being approved by the steering committee. And also, the regular internal audit and the security review you need to perform to make sure the baseline is maintained, right? InfosecTrain Trainer: Also, it will ensure that you are conformance with the assurance that how effective your baseline is, right? So, this is how the baseline is maintained.

So, this particular picture will help you, give you a high-level understanding that what is the difference between a standard and a baseline. InfosecTrain Trainer: And I posted in, our WhatsApp group also, right, by talking to a couple of previous, recent participants. Three, four people itself cleared the exam in last week, right? So I got a feedback from them, right? What they were saying, right? Just don't kind of, mug up. InfosecTrain Trainer: all these topics, right? You need to understand what is the key difference between them. What is a standard? What is the guideline? What is a baseline? Right? What does policy do? What does framework do? If the difference and the top, you have a good understanding around the topics, any kind of question comes in the exam, you'll be able to answer. InfosecTrain Trainer: So that's why you need to have an understand, you should develop an understanding, key understanding around these things, right? Like standard. What does standard means? Standard means something which is applicable across the organization, right? InfosecTrain Trainer: And... and standard is something which you... you cannot do a trade-off, right? It's... it's mandatory to follow, right? InfosecTrain Trainer: So, like, there is a definition for a standard for the formal, specification or guidelines for the password creation and management. It should be adopted by the consensus or regulatory bodies. So, what is the example? So, if your organization is following the NIST framework, it says that any password should contain the minimum secure characters, no mandatory periodic reset, allow all printable ASCII characters.

InfosecTrain Trainer: If your organization is following PCI DSS, it says that minimum seven character password and combination of letter numbers and symbols should be there. So this is a standard. Now coming to the baseline, this is a minimum level of password control based on risk assessment often used internally within the organization. An example, if you are following the CIS password baseline, it says the minimum total characters. InfosecTrain Trainer: Enforce the password history and maximum password age should be 90 days. So this is an example to understand the key difference between standard and the baseline. InfosecTrain Trainer: Now, how do you maintain and establish a baseline? So, the baseline is something which will make sure that the residual risk in your enterprise always remains and maintains within a consistent acceptable level. InfosecTrain Trainer: Like, if you have a password for account-related control, right? So if you make sure that there is a 12-character password limit for all the systems or all the kind of accounts, it will make sure that the residual risk will remain in check. InfosecTrain Trainer: Like endpoints. So all the endpoints should mandatory have an EDR antivirus installed. It will make sure that those endpoints are protected, right? There is no chance they'll, there's any threat or anything with respect to that, right? So that's how the baseline make sure and it's mandatory that you validate the risk level by periodic risk assessment. It's very important. subaveena pugalenthil: Can you explain the first sentence again? Like how does it relate to the baseline and residual? Like how do they both relate? InfosecTrain Trainer: Yes. So, let me go to this example. InfosecTrain Trainer: Right.

So this is a risk of the information disclosure due to non-availability of control, right? So to mitigate this risk, what are the controls you have? You have a backup and RPO defined, you have a XDR deployed, you have a DLP deployed. So if you have a baseline around the XDR and the DLP. InfosecTrain Trainer: which is deployed across organization, then only you can be confident on the residual, right? Suppose in your organization, only 50% systems are covered with the XDR. How you can say that my residual risk is this? Because 50% systems are still exposed, right? Understood? subaveena pugalenthil: Yeah, I understand the residual risk, but how does it relate to baseline? InfosecTrain Trainer: That's what I'm saying. Baseline is the same thing, right? Baseline means the minimum level of security. So, your baseline says all the organization and point should have an XDR deployed. So, this becomes your baseline. So, this will make sure that your 100% of the organization is on XDR. If. InfosecTrain Trainer: suppose 5, 6, 10 systems goes out of, out of this particular... they are not following the baseline, then your residual risk also gets changed accordingly. Understood? That's why you have a lot of KPIs and KRIs to monitor those things, right? InfosecTrain Trainer: So, Sandeep, the standard... so, baseline is derived from the standard. The standard is something which will say that, each and every system in the organization, each and every account should be protected with a password, like this. InfosecTrain Trainer: Which we saw, right? It should have a minimum secure character, no mandatory periodic reset, allow all ASCII characters. So this is what the standards will say, right? But from a standard, then you will create a baseline.

You will say that, okay, this is what is mandatory, but. InfosecTrain Trainer: In our organization, we will make sure that the minimum 12 character passwords are being used. And this will differ from organization to organization. Maybe in your organization, you might be using 10 characters. Some organizations are using 16 characters. So it differs. So standard is something which is consistently available across the organization. Same is the baseline, but baseline is something which is the minimum level which you will define. InfosecTrain Trainer: nothing... if anything goes below this, it means that it is not, kind of compliant in the organization. Got it, Sandeep? Sandeep Saxena: Yeah, so it's like a standard says that every system should be having an EDR, but baseline says at least 90% of those systems should be having. InfosecTrain Trainer: Yes, correct. Sandeep Saxena: Okay. InfosecTrain Trainer: So here in the example, example is given for the antivirus baseline. So what does this say? This says that if there is an antivirus system deployed in the organization, how the baseline would be kept on check. So you will continuously evaluate how many systems are infected, what are the virus alerts generated, how many are the virus incidents which are coming. InfosecTrain Trainer: how many... okay, sorry. Changes, files, updates are taking place. Also, you will get an input from the staffer, software costs, remediation costs, residual risk, and everything. On the basis of all these inputs, you will maintain an antivirus baseline. InfosecTrain Trainer: Anything which is, all the inputs will make sure that the antivirus process is kept at the baseline, right?

Like, all the systems are covered, how many virus alerts are coming, all those will make sure that the antivirus, or anti-malware baseline in your organization is maintained. InfosecTrain Trainer: So, this is a very important slide from the exam perspective. InfosecTrain Trainer: If you want, you can take a screenshot of this because you will get a good number of questions in the exam, which will talk about what is the next, what is the first, what is the risk management process. And also this will, this chart will make sure that you understand that process, right? So whenever you start the risk management in the organization, you want to do a risk assessment. How we started, we started with the scoping, right? InfosecTrain Trainer: We first did what? We did the scoping. That's what it says. Establish the scope and boundaries. You cannot just go ahead and do a risk assessment of your complete organization. It will take, the project will take almost a month altogether to complete and so many resources would be involved, right? So always you need to have a scope and the boundaries. Then you must identify which all assets and what is their valuation. InfosecTrain Trainer: Right? You will say, okay, all the critical applications would be covered this time, or you will say all the critical third parties we will cover, or you'll say we will cover all the systems which are deployed in the India region, and then you will understand their valuation. Then you will do the risk assessment. InfosecTrain Trainer: Once you do the risk assessment, you assess the risk, then you will have a recommended treatment options available, how you are going to treat that risk.

And then once you deploy those treatment controls and everything, then you will have to accept the residual risk and then you will continue to monitor.

InfosecTrain Trainer: and communicate the risk-related changes which happens. So that is a regular process. So this is a chart, yeah. SrinivasanJ: Sorry, the valuation here is, related to business impact. InfosecTrain Trainer: No, no, no, valuation is the asset valuation. If you are doing a quantitative risk assessment, how you will perform it if you don't know the valuation of the asset? InfosecTrain Trainer: Even the control cost would be dependent on that, right? To protect a \$1,000 asset, you will not deploy a \$5,000 control, correct? SrinivasanJ: Okay, understood. So, here we are not considering business impact that the asset holds. InfosecTrain Trainer: Yeah, it's talking about the asset valuation. InfosecTrain Trainer: So this is the risk assessment process, right? We have discussed it multiple times, but this slide kind of summarizes it all. So if you want, you could take a screenshot of this so that you understand, right? First, you identify threat, vulnerability, and exposure. Then you will analyze the level of risk in context of probability and outcome. Once you have that, then you will evaluate whether the risk meet the criteria of acceptance. This is the overall process which we discussed so far. subaveena pugalthi: Sorry, I just have a question about framework standard and baseline. I know how a framework is used in an organization. It gives you an example or how you could drive your organization security posture by following a framework. It gives some level of assurance or a guideline to follow to get to a good security posture, right?

subaveena pugalthi: and standard is something that is set up by the regulatory bodies. So. InfosecTrain Trainer: No, no. Standard is not something that is set up by regulatory body. Standards are derived from those all things. So standard is not only coming from regulations. Standard also comes from your certifications. Suppose you are ISO 27001 compliant or you are a PCI DSS compliant. So all those certifications which you take, you have to make sure that you are following those standards. Then only the certification body will say, okay, you are certified. subaveena pugalthi: Okay, so can you give an example of how these three could be used in an organization with clear differences? InfosecTrain Trainer: Yeah, yeah, sure, sure. subaveena pugalthi: Yes.

InfosecTrain Trainer: So, let's take an example. Let's take, I'll take a very simple example of the password. So, if you go and read NIST, NIST only says that all the accounts should be protected with the, InfosecTrain Trainer: This is... I'm talking about the... there are 3 things, right? We are talking about the framework. InfosecTrain Trainer: standard, and the baseline. InfosecTrain Trainer: Let's take NIST and ISO 27001. InfosecTrain Trainer: should be consistent on the numbers, all those things it will say, and the minimum length of password, which, ISO recommend, is, 8 characters, let's say, example. InfosecTrain Trainer: different also. Now, in my organization context, it's not... so, minimum is 8, but for my organization, I'll say, okay, I'll go with the 10 characters. Is the minimum... is the standard I've created 10 characters? InfosecTrain Trainer: and 14 characters for all the PAM accounts. Then baseline would become... you can have a same as a baseline also, 10 character and the 14 character, or you say.

InfosecTrain Trainer: The minimum baseline is 10 characters. So all the system should at least have a 10 character password, which they should maintain, right? Any system which is below this, and on the basis of that, only your IDAM team will configure it in such a manner that your system won't even accept if you are creating a password which is below 10 characters, it won't accept, it won't allow. That's how the baseline is created, right? Yeah, Johnny. InfosecTrain Trainer: You're asking something. Sorry, sorry, no, no. Yeah. Yes, Subha, it's clear now? Yes. InfosecTrain Trainer: is something that you insist or mandate through, like, as you said, like, system doesn't take characters to do that or something. Correct. InfosecTrain Trainer: 90 days automatically the password will get expired. So even if you want to keep it, you cannot like baseline like screensaver. If you enable a baseline for the screensaver, so automatically all system would be logged out after the 5 minute of the usage. So even if someone want to change the setting in the computer is not allowed. But suppose there is a system in in some critical process where. Johnny Souriar: True. Johnny Souriar: Sorry, sorry, no, no. InfosecTrain Trainer: Yeah. That's why it's clear, no? subaveena pugalthi: Yeah, standard is something you set up, but baseline is something that you insist or mandate through, like, as you said, like, system doesn't take care. InfosecTrain Trainer: Yeah. subaveena pugalthi: Do that, or something. InfosecTrain Trainer: Correct. Like, 90 days, automatically, the password will get expired. subaveena pugalthi: Mmh. InfosecTrain Trainer: Even if you want to keep it, you cannot. Like baseline, like screensaver.

If you enable a baseline for the screensaver, so automatically all system would be locked out after the five minute of the usage. So even if someone want to change the setting in the computer is not allowed. But suppose there is a system in in some critical process where you want to alter it, they have a justified use where that system should be on. InfosecTrain Trainer: for more than 5 minutes, then you will take an exception approval, you will alter that baseline and accept the risk. Got it? subaveena pugalthi: Okay, who is responsible for each of these in the organization? InfosecTrain Trainer: So, security team will create it, and all the users, all the application owners, business owners, they are, respon... they are responsible for... subaveena pugalthi: Security teams, right? Can you be specific? InfosecTrain Trainer: No, no, so cyber security team, I'm saying. subaveena pugalthi: Yeah, yeah, like, within cybersecurity, we have SOC, IAM team, like, risk management team, compliance team. InfosecTrain Trainer: No, no, no, it's not like that. That's what I'm saying. It's not necessary that which team will create. Every organization, probably SOC team might be doing multiple jobs, right? That's why ISACA do not talk in detail that SOC team is the one who will create the baseline, or GRC team is the one, those who are going to be creating a standard. Depends on your organization. Suppose there is a startup, probably five people might be performing all the duties, right? subaveena pugalthi: Okay. InfosecTrain Trainer: So, so ISACA do not talk about this, that, which particular role is accountable for doing the risk assessment and all. It's only talk about the security, that's it. subaveena pugalthi: Mmh.

InfosecTrain Trainer: Security means something which is managed by the security manager, means a CISO. subaveena pugalthi: Okay. Manoj Kamble: Adding to this, Shashank, actually, mostly security architectures will be taking care of this business line, business baselines, the security baseline creations. InfosecTrain Trainer: It depends. Like in my organization, I handle the complete GRC. So I actually create the, maintain the baseline and those things I maintain, but those are created by the respective team leads. Like IDAM team lead will create the baseline for the identity, other team, because I'm not subject matter expert and all the things, right? Suppose I have a AI security team, so they know the better, right? Their system. So they will create it. InfosecTrain Trainer: I will just make sure that it's, created in a consistent manner and deployed. SrinivasanJ: But expectation is set by ISO... sorry, CISO or security architecture. SrinivasanJ: So... InfosecTrain Trainer: The notation is set by your information security policy. That will make sure that all these things are being followed. And that is created by the CISO. subaveena pugalthi: Is it essential to have both in the organization, or would one suffice the other? InfosecTrain Trainer: It's not necessary that you should have a written standard or the baseline. But information security policy is very mandatory in nature. Even whatever is defined in the policy, that also becomes a standard. So whenever an audit happens in your organization, they will check with respect to this only.

InfosecTrain Trainer: If your organization has defined, you have an identity and access management policy, which says that the minimum 10 character for normal accounts and 14 characters for the PAM accounts, so the auditor will fetch the report and he'll check. He will say, okay, in your organization, this thing is not being followed, so he'll write an audit finding. subaveena pugalthi: Yeah, but that is the audit on the policy, right? InfosecTrain Trainer: Yeah. So, so, so that's what I'm seeing everywhere. It's not only the policy, it's on the, all the entire system in the organization which is deployed, right? You say that all the systems, all the end, end equipment should be covered with the EDR agent. And then he fetched the report. He saw that only 75% of them have a EDR installed, 25% the EDR is not running. It means that you are not compliant, right? With respect to that. subaveena pugalthi: So is the policy now a standard or a baseline? What is it set? InfosecTrain Trainer: Policy is always a standard. subaveena pugalthi: Okay, baseline a different document. InfosecTrain Trainer: So all the, all the baseline, let, let me, let me see a simple word. All the baseline is a standard, right? But it's not, so, so anything which is defined in a standard is a baseline also. Simple. InfosecTrain Trainer: You cannot actually... but the standard do not specify that how many systems and how many those things would get covered, right? So, standard is always a generic in nature, right? Baseline is very specific in nature. That's the simple thing. Even your information security policy is generic in nature, and your... InfosecTrain Trainer: your information security policy is generic in nature. Someone posted a picture.

InfosecTrain Trainer: So even your information security policies also is a always a generic in nature. You will never see a policy being defining things very specifically. Have you seen your red red policy where they say that this is the minimum character of the password and all it will always say the all system must be protected with the password. Every system, all the data must be classified on on these four labels. That's it. That's what the policy will say. Then you create a specific standard and the baseline. InfosecTrain Trainer: Got it? Subha? subaveena pugalthi: Yeah, somewhat. Thank you. InfosecTrain Trainer: Now coming to the topic of continuous risk assessment. So the continuous risk assessment, right? So risk assessment is not something which you just perform at one point in time. Risk assessment is something which is a continuous process which continuously being done in the organization, right? So there is a new concept of the risk operations center. InfosecTrain Trainer: Anyone heard of this? Risk Operation Center? InfosecTrain Trainer: So, there is a concept where organizations are moving from a traditional SOC to ROC. InfosecTrain Trainer: So what does this risk operation center do? So whenever your organization might have some set of controls, all the baselines and all the things which are implemented, rather than doing a point in a time assessment where once in a year you do a rec team exercise or once in a year you do some exercise, you check them, you validate them, once in a year you do an audit and you validate them, you do a continuous risk assessment on them.

InfosecTrain Trainer: So there are technological tools and things available where you can continuously check it and then understand that continuously your baseline standards and everything is being maintained. So this is what is related to continuous risk management. So whenever you implement any control, so first thing is that you will identify and assess the risk. InfosecTrain Trainer: Then you will analyze that particular risk. Once you analyze, you understand that high, critical, moderate, what is that and what kind of control is required. Then you will develop a risk management plan to mitigate that particular risk. Then you will do a proactive monitoring of those things and then you implement a control. InfosecTrain Trainer: So, so this is a continuous process. You implemented a control, you understand the risk, then you analyze it. subaveena pugalenthi: But you do the implementation of control at your risk management plan, right? Like even before proactive monitoring. Like once you implement your controls, then you do a proactive monitoring, right? InfosecTrain Trainer: Correct, correct. So the cycle will come into picture once you have something, right? If you're in your organization, you don't even have a DLP, so what continuous risk management you will do? Once I deploy a DLP in the organization, then I will establish the continuous risk management in form of the continuous KPIs, KRIs, reports, so that I understand that how many systems are covered, how much data is currently have the sensitivity labels applied and all. Understood? subaveena pugalenthi: So check, assessing the existing control list was what continuous risk management is. InfosecTrain Trainer: Correct. subaveena pugalenthi: Okay, okay. InfosecTrain Trainer: It's not only limited to the control.

That is an example I give. It's around the overall risk posture of the organization. So like you did a risk assessment once in a year where you identified there are risks with respect to ransomware attack, risk with respect to unauthorized information disclosure, risk with respect to the resiliency. InfosecTrain Trainer: risk with respect to shadow AI usage, right? So these are all risks which you identified. It's not that you just do visit them once in a year. It's basically a continuously you are monitoring those risks. You are continuously checking what are the controls which are mapped against those risks, like suppose I take this example. InfosecTrain Trainer: So these are all the controls which I have, right? Existing controls which are making sure that this particular risk is mitigated. So I'll make sure these controls always remain in the effective manner rather than something is getting degraded. So there is going to be a team who will daily or whatever is the frequency will fetch the report of how many systems are non compliant with respect to the XDR. There is going to be the DLP team who will continuously monitor and check that how many systems. InfosecTrain Trainer: Currently, how many documents in the organization are not actually, sensitivity labels are not applied to them. So this is how the process happens. InfosecTrain Trainer: So, this is what the ISACA defines, right, in their manual, right? So, whenever you... So, first thing is that you identify. InfosecTrain Trainer: You will understand the baseline, you will do the brainstorming, you will do the periodic risk reporting, project portfolio questioning, risk form, all these techniques you will do. Then you will analyze, right?

Analyze with respect to these other analysis, data analysis techniques, which you have probably read in your school days, right? Pareto. InfosecTrain Trainer: and then binary attribute value, bar graph, and those all... these are all the techniques, right? And then you plan. You will understand, on the basis of analysis, you will understand that what are the plans, how you are going to action those particular risks, how you are going to mitigate them. InfosecTrain Trainer: then you will continuously track in terms of bar. These days, you can easily fetch the information from the APIs, you can integrate and create a Power BI dashboard, you can do a continuous risk assessment in form of some... there are a lot of good tools which are available, right? They continuously monitor your organization risk posture and keep giving you alerts. If something goes non-compliant, automatically you will get notified and you can go and immediately go and fix, right? And then you deploy the control. InfosecTrain Trainer: So this is, this is one... subaveena pugalenthi: Can I go back a couple slides? I just have a question. InfosecTrain Trainer: This... subaveena pugalenthi: No, the before one, I think even before that. Yeah, in this one, like, this is the whole process of establishing risk management, right? When you say establish scope and boundaries like, are you setting the scope and boundaries of to which level you will do your risk management, or what comes into picture and what doesn't it? Does that mean scope and boundaries? InfosecTrain Trainer: Yes, that means the scope and boundaries. subaveena pugalenthi: On what basis do we do that? InfosecTrain Trainer: It depends on the organization context, right? It depends on the organization context.

So it's, it's, it's, InfosecTrain Trainer: So, suppose you are establishing the risk management process, right? So, you will say that these are the things which won't get covered as part of this. So, we will only, we will follow, we will only do the risk assessment on these systems, on this particular country and all. So, those are the things. It all depends on the organization, how they want to go about it. ISACA is not saying that you cover all 100% of it. InfosecTrain Trainer: Because... subaveena pugalenthi: Can I... InfosecTrain Trainer: organization. InfosecTrain Trainer: Every organization don't have a resources also, right? Do you have a resources to handle? If you, if you want to do a risk assessment of everything completely in the organization, you need to deploy a long, large team, right? So organization will say no. subaveena pugalenthi: Asking an example, can you give a difference, clear difference, like this would fall under scope and management would consider this. Probably the management wouldn't consider this scope for so and so reason. Just an example to understand like how the scope and boundary is set for an organization and how do they eliminate things which they don't want to fall under the scope for the risk management or assessment process. InfosecTrain Trainer: Correct. InfosecTrain Trainer: risk assessment of all the critical, we will divide all the third parties into four categories, critical third parties, high rated, moderate and the low. So all the, all the low rated third parties will be evaluated once in a five year. All the moderated third parties would be evaluated once in a three years and all the high, high would be in two years and critical every once in a year.

So this is an scope and the established boundaries you established and then you are doing the risk assessment on. InfosecTrain Trainer: them, right? Rather than you are saying that everything, 100%, all the third parties, we will do the risk assessment every year, right? So this is how you establish the scope and boundaries. And there also, suppose your organization. InfosecTrain Trainer: you have a headquarter country in US, you have a system in India, you have system in UK, you have deployed system in the Middle East, right? So you will establish the scope and boundaries that the UK system this year, we are only covering the third parties and the systems which are in our headquarter country US. Next year, we will cover the systems which are there in India likewise. So it all depends on the budget, priorities. InfosecTrain Trainer: the money which you have got, the resources you have got on the basis of that, you will establish the scope and the boundaries. Got it? Okay. Okay. Thank you. So this is what is the key difference between the business impact analysis and the risk assessment and the BCP, right? So the business impact analysis, right, is something which will give you how. InfosecTrain Trainer: much important that system is. And this is more from the. subaveena pugalenthi: Okay. Okay. Thank you. InfosecTrain Trainer: So this is what is the key difference between the business impact analysis and the risk assessment and the BCP. So the business impact analysis is something which will give you how much important that system is. InfosecTrain Trainer: And this is more from the availability perspective. If that particular system, application, server, or that particular database.

InfosecTrain Trainer: or that particular system is not available, what is going to be the impact on your business? So, that is the criticality which you get out of BIA, right? So, BIA also gives you a guiding priorities. That's what we did, right? So, once you did a BIA on your third parties, you determine that how many of those are very critical. If those third parties are not ready to provide us the services, if they are. InfosecTrain Trainer: providing some SaaS solution, and if that SaaS solution is not available, we will not be able to operate. Suppose your organization is completely on cloud. InfosecTrain Trainer: Your organization is completely on Azure. If Azure is not available, how your organization will function, right? Then that particular guiding priorities you get from the BIA that these are the systems, these are the things which you want to cover. And then once you do the risk assessment, risk assessment gives you a total number of threats, what are the issues in that particular process. All these things will go as an input in creating the BCP. InfosecTrain Trainer: plan. So this particular flowchart defines those things. If you want, you can take a screenshot of this so that you remember these topics, right? Whenever it comes in the questions, you'll be able to understand the key difference between them. InfosecTrain Trainer: Let's discuss... oh, sorry, yeah, questions. Pudir: I'm concerned. InfosecTrain Trainer: Yeah. Okay. Pudir: In previous slide, can you please, this input should be business impact analysis. Can we get from risk assessment? InfosecTrain Trainer: So that's what I say, you know, it's a cycle. So risk assessment is giving you what are the relevant threat against those systems. Pudir: Okay.

InfosecTrain Trainer: Then you will understand, then you will do an BIA, right? Pudir: Okay. InfosecTrain Trainer: So it's all a cyclic... it's something... all of them are related altogether. It's not that something you will start this first, and then you will do this next. subaveena pugalenthi: Can you give an example for this again? InfosecTrain Trainer: Yeah, sure. So, like, if I take example of, suppose the AI. InfosecTrain Trainer: Right? So in your organization, you are deploying the AI, right? So AI related technologies and the applications which you are deploying for the improving the productivity of your employees. So then you will first do a risk assessment. Everything always first start with a risk assessment because when you are evaluating four, five, six, whatever number of vendors, you will try to understand, okay, this is vendor is the high critical, this will solve. InfosecTrain Trainer: purpose or not, how secure the platform is, right? Then on the basis of that, that particular risk assessment will also give you the number of threats, what are the issues, how many ransomware attack can take place, what is the RTO/RPO which is required on the basis of that, then you will do a BIA. Now BIA will make sure if that particular AI model which you have deployed, if that particular model is not. InfosecTrain Trainer: available for certain period of time. Suppose, there is a cyber attack and that particular AI model is not available due to which your business function will not be able to do important data analytics, important functions for five hours. So you will say that

they will have a business impact of, \$500,000. InfosecTrain Trainer: So that particular AI model becomes a critical, right?

So in big organizations, you will not only have one AI model, you will probably be running the 100 plus AI models. So once you do the risk assessment, that risk assessment will tell you out of those 100 AI models, how many of them are critical. You will say, okay, out of those 120 are very critical in nature. Rest are. InfosecTrain Trainer: being used for the productivity or small-scale issues, so you will get that understanding. Once you do the BIA, then you will set up the BCP DRP for 20. InfosecTrain Trainer: Any of the organization, you will see same thing is being followed because establishing any disaster recovery, any backup solution and all is very expensive. For everything you require money, you cannot invest money of each and everything in your organization, right? You will always establish those things for the systems which are critical in nature, which brings more value. Other systems, even if they are down, you will continue to operate. Like suppose in your organization, if tomorrow there is a. InfosecTrain Trainer: ransomware attack, and 100% organization is blacked out, which all systems you will recover first? Tell me, Subha. InfosecTrain Trainer: So... subaveena pugalthi: Okay. Sandeep Saxena: clear. subaveena pugalthi: Good question. Sandeep Saxena: So risk assessment we do after scoping in risk management process. And scoping is driven by the business impact analysis. What all system we do risk management for, that is coming from the business impact analysis, what is more critical for me. Right? So in that case, business impact analysis is done first, and based on that, scoping will be done, and based on that, risk assessment will be done. Is it correct? InfosecTrain Trainer: No, this is not correct always.

This is not a series or the serial sequence which is there. It depends on situation to situation. But whenever you, just one statement you keep in mind, whenever you start any new project or any new initiative, the first thing which we will do is the risk assessment. That's the first thing. subaveena pugalthi: I think the output of your risk assessment goes as an input to the business impact analysis. And that's how the criticality of business is determined. And then you do the disaster recovery plan or business continuity plan, right? InfosecTrain Trainer: Correct. So that's what I'm saying. subaveena pugalthi: It happens at the risk assessment level and not the BIE level. InfosecTrain Trainer: So, scoping, why they have given the scoping? Because every organization has a limited number of resources, limited number of people to handle the risk assessment, right? You cannot just go ahead and do, assess everything. Can you do that? I don't think in your organization, all the same thing is being done, right? So, that's how the scoping. InfosecTrain Trainer: comes into the picture. If your organization say that this year we will do a risk assessment of all the important business application. That's what the board of director told that I want to check that how many important business applications you have. So can you go ahead and just start doing if you know organization you have suppose 2000 applications which are being run. Imagine how many number of people. InfosecTrain Trainer: tools, techniques, and things you have to deploy to do the assessment of those 2,000, right? So your business, your important CISO, CEO will take a decision. He'll say, okay, let's do one thing.

Let's do the risk assessment on all the critical business applications which have the important impact. So that's how you do the scoping. Got it, Sandeep and Subha? subaveena pugalthi: Yeah, I got it. So how does informed relevant threats act as an input to a BIA? In my understanding, the criticality level would give me some level of input to my BIA. subaveena pugalthi: I'm not sure, like, can you explain how a threat would be an input to BIA rather than the criticality? Or, like, I identify the level of risk for each of the identified assets, right? subaveena pugalthi: assessment process. InfosecTrain Trainer: So BIA is telling you the criticality, right? So how you get to know which is more critical in nature. So that is also dependent on the threat. So which system has a more amount of threat, more amount of probably possibility of having an attack that automatically becomes a critical. InfosecTrain Trainer: Something which is, public facing or very important for your business or some system which is probably, deployed in an internal network, but equally, equally important as other systems. So which system become more critical? The one which is public facing. Right. Because that has a more probability of having an attack. Got got it. Sandeep Saxena: Critical in terms of security or critical in terms of the business value? InfosecTrain Trainer: Both. Both. Security criticality. Security only tells you what is the threats. Security do not gives you any criticality. How come security can give you criticality? Can you please explain? Sandeep Saxena: No, that's what I'm saying. Something, something can be very important for the business, but we cannot assess many critical threats for that. So, this is still critical because the value of that system is high.

InfosecTrain Trainer: Yes. So, always the business value takes always a precedence from anything. Always business will take precedence, because in your organization also, your organization exists because the business is there, right? From there, the revenue is getting generated. That is the main component of the organization. Sandeep Saxena: Sorry. InfosecTrain Trainer: Yeah, Johnny, you raised a hand. Johnny Souriar: Yeah, sir, I, as per my understanding, so we also done this activity in our organization. Business impact analysis and risk assessment is totally different independent activities. Actually, there is a no input from risk assessment to business impact. Business impact analysis is just analyzing all the processes and application in the organization. After that, they will identify which are the critical, which are the non critical application to that context of the organization, how much RTO is required, how much RTO. Johnny Souriar: RPO is required for each and every application. Arriving that process is a business impact assessment. But risk assessment is entirely different. There is a continuous process. They will analyze each and every process. What are the risks are there? How much residual risk is there? Based on the risk register will be created. That risk team will monitor and mitigate if your risk profile is within that threshold level or not. Johnny Souriar: Business continuities depend upon the business impact output. So business impact assessment will say that okay in my organization out of 50 application maybe 10 are critical and another 40 are non critical applications.

So business continuity policy will be created saying that okay for these 10 critical application my RTO RPO is this much for that these are the my high availability is required, DR is required, how much frequency has to be conducted. All those things will be conducted based on the output. Johnny Souriar: of BIA. But risk assessment is totally different activity. That is my understanding. Is it right or not? InfosecTrain Trainer: No, no, no. SrinivasanJ: No. InfosecTrain Trainer: Don't go by what the organization is following, right? Even if being done by two different teams, a BIA is done by different team, the risk assessment done by different team, right? But BIA team also, once they are doing that, they will also see what are the relevant amount of threats against that. On the basis of that, only the RTO and RPO is coming, right? InfosecTrain Trainer: One thing is what the business required, right? Second thing is how many of threats that particular system is exposed to. That would also become one of the important factors to decide the criticality. Understood? InfosecTrain Trainer: Can you? Johnny Souriar: Yeah, get a... Johnny Souriar: Saudi Arabia. subaveena pugalthi: Sorry, sorry, go ahead, Johnny. Johnny Souriar: Yeah, what I'm saying that in the business impact assessment, we are just identifying which are the application is highly required for the organization if any disruption is happened so that only that critical application I have to identify, I have to. Johnny Souriar: Prepare a BCP for that business continuity for because I cannot run entire application during any disaster time, right? I want only to what is the bare minimum and highly critical which are required to be run my business. So that identification process is the BAA. SrinivasanJ: No.

InfosecTrain Trainer: No, BIA is not only done for the purpose of the only creating a BCP plan. Understood. That's what I'm saying. BIA is a BIA is a process. It's a concept which can be used to define the criticality for any of the activities. Right. So that's why let me take an example. Right. So in your organization, you you identified that there is a sprawl of the AI. InfosecTrain Trainer: agents which are running. Right? So you identify you run a report. You found out that there are total, suppose 1,000 agents which are running at this point of time. Now those agents and then you also identified that those agents are powered by suppose 150 models. InfosecTrain Trainer: which are hosted in different different environments. Some of them are in cloud, some of them are in on-prem and all. That's what you did. Now you want to do assess the quick risk assessment on them. Can you go ahead and do and assess the risk on all of them at one go? You cannot. So then you did a BIA. That's what I'm saying. BIA just do not associate BIA only with the business continuity. No, BIA is something the process which gives you the criticality. InfosecTrain Trainer: Which gives you the guiding priorities. You did a BIA, the BIA will tell you, okay, out of this 1000 and 150 models, out of 1000 agents, only 200 are the ones which are very important for. InfosecTrain Trainer: business operations. And out of this 150 model, there are only 50 models which are more important. The rest 100 models are being done on some non-prod systems or some less critical processes. And then you do the risk assessment. Understood with this example, Johnny and everyone. InfosecTrain Trainer: So BIA, that's what I'm, I'm making it clear to all of you. In exam also, don't just associate BIA only with the BCP.

BIA is a concept or a process like risk assessment and the BIA process gives you the priority or the importance. That's it. That priority and importance can be used to create a BCP also. That priority and importance can be used to do, take some other business decisions also. InfosecTrain Trainer: Understood. Johnny Souriar: Yeah, that is true. InfosecTrain Trainer: that. So this concept, please be clear in your mind. So whenever you are seeing the BIA and risk assessment, these are the two distinct things, but this is what the main purpose of BIA, this is what the main purpose of risk assessment. Everyone is clear now? SrinivasanJ: Can we say, like... subaveena pugalthi: And do... InfosecTrain Trainer: when... yeah. InfosecTrain Trainer: Yeah, she knew us. SrinivasanJ: Can we say BIA is the target to meet the BCP strategy and risk assessment is to identify the vulnerabilities to meet the target? InfosecTrain Trainer: No, no,

risk assessment is not something which is identifying the vulnerabilities. Risk assessment is something which is identifying the risk. Vulnerability is just a weakness in the system. If we already discussed, right? SrinivasanJ: Or vulnerability. InfosecTrain Trainer: If vulnerability is able to be exploited by a threat, then there is a risk. And always, and you never consider the inherent risk. You always consider residual risk, which is more important. Inherent is something which is already there from your external environment, right? Main consideration for is the residual which is left over. InfosecTrain Trainer: How much that threat is there in your organization perspective after looking at your, your infrastructure, your controls, your, your solutions which you have deployed, then you will determine that, how important is this? Correct. Got it.

SrinivasanJ: No, when I meant vulnerabilities, I'm not talking about the exploitations and vulnerabilities. So in my process, right, the business impact, that's my target. And to achieve that, what are the problems I have? That I will identify using risk assessment and then work on a mitigation plan to meet the requirement. InfosecTrain Trainer: That's why you don't... don't... don't mix two things. Just one line, simple definition, which I'm telling you. Keep it in mind. It will probably, clear your... all the doubts. As I told, business impact analysis is a process which will tell you what is critical, what is not. InfosecTrain Trainer: That's the only thing this will tell, which is more important, which is not. Let's take a very simple example from a CISM perspective. You people are preparing for exam, right? You are studying the topics, right? Suppose you only have got one week left. InfosecTrain Trainer: So, which all topics you will pick up and you will read? You did a BIA, Business Impact Analysis, you understood, okay, all of these topics, these are a couple of topics which covers the more of ground, like you will try to first understand the policies, the key difference between the policies guideline and those things, you will probably revise the risk assessment process, you will revise, so you identify 10, 15 topics, you only read them. InfosecTrain Trainer: That's it. That's what the BIA does. Risk assessment is something which will tell you that where you stand at this point of time. So you identified those topics, but how you understood that these are the important topics, these are the things I have to read. InfosecTrain Trainer: You went over to, you probably will be already solving the questions, right? You are solving the questions.

You identified, okay, these are the topics where every time I'm getting question wrong, that is a threat. Every time you are answering them wrong, you don't have a clear understanding around those topics. So that is an issue, right? That issue will help you to understand and then you do the BIA. Got it? SrinivasanJ: Yeah. Conducted to understand the current status, okay. Madhes: Yeah, if required, I can give example to make it very clear because everyone is confused with the end that is this one. InfosecTrain Trainer: Yeah, yeah, please. Madhes: Okay. Madhes: See, BIA basically identifying the critical processes in an organization, irrespective of processes having the support of system or not. Like, you know, an accounts department, someone is sending the checks and sending to the bank. If that is a critical process for that organization, BIA identifies that process as a critical processes. So whether that process is having support of system or not. Madhes: It doesn't matter. It will list out 10 processes. Out of 10 processes, five processes having the system, those systems, they will classify as per the criticality of the processes, maybe critical, high, low, medium. This is a basic understanding about business impact analysis, inclusive of all the processes in the bank or any institution. Madhes: In case of risk assessment, it is purely for the, you know, process and the systems in and around technology and information security. Say, for example, I'm allowing, you know, 10 systems USB access. So I will create one more risk assessment saying that, okay, this is my, against this baseline, I will do the risk assessment. This risk assessment result will be.

Madhes: Included in the risk register saying that this is my risk category and this is the level of risk, this is the acceptable risk everything. This risk register shared with the business impact analysis team to inform the relevant threats. Based on this threat and other processes, they will identify the critical applications. Based on critical application, they'll identify the RTO, RPO. Madhes: All these inputs are required for the BCP and disaster recovery strategy. InfosecTrain Trainer: Correct. Correct. Yeah. Thank you. Thank you. I hope everyone is not clear with this example or still anyone has any doubt. So risk assessment is something which you perform before taking any decision. Even when you decided to write a CISM exam, you would have done this. InfosecTrain Trainer: you... you probably would not have followed the complete process, but you would have definitely done this. You would have seen, okay, what is the total certification cost, how much time it is required, what is my current efficacy level in the... in the information security, right? Then you would have identified, okay, it's better to take a training with the InfoSecTrain, right? You would have taken the decision, right? Or... or shall we... probably I do a self-study. InfosecTrain Trainer: So risk assessment is something which you perform before doing any process, any decisions, even in your business, whenever they want to hire something, when they want to fire something, when they want to purchase any new organization, whenever you want to invest somewhere, everywhere you are doing the risk assessment. Got it, everyone? InfosecTrain Trainer: But I think... I hope everyone is now clear, you understand the key difference between the risk assessment and the BIA. I hope no one is confused between them.

InfosecTrain Trainer: Just one line. Business impact analysis will give you the priorities. It will give you what is the critical, what is the most important thing. And risk assessment is something which will tell you that where you currently stand, will you be able to take that risk or not? Do you have a sufficient number of controls in place or not? And what is the residual risk you have? That's it. Got it. InfosecTrain Trainer: Clear, everyone? Johnny Souriar: You're welcome. Pudir: Is it. InfosecTrain Trainer: Let's discuss some questions. Let me find out some more questions on those risk assessments so that we can discuss those as well. InfosecTrain Trainer: Alright, let's discuss. So, I think most of you got it correct. So, first one is an internal audit has identified a major weakness over IT processing. Which of the following should an information security manager use to best convey a sense of urgency? InfosecTrain Trainer: It's talking about, I think this particular question will clear, right? So most of you are confused. Security matrix report, risk assessment report, business impact analysis, return on security investment. So security matrix report will not give you a complete picture. It will only tell you that what is the current status of that particular process, right? Risk assessment report will cover complete details about the IT process, right? It will talk about what are. InfosecTrain Trainer: relevant threats against that, what are the relevant risk, what is the mitigating control, where we stand, and what is the residual risk. BIA only tells you that it's what is important, what is not. So when internal audit has already identified the weakness in IT processing, what you will do with the BIA with that? BIA won't give you.

InfosecTrain Trainer: anything over there, right? BIA would be done if you have 10 or 15 different, different processes, and then you want to understand which particular process is more important, that only BIA will tell you. And return on security investment, this question is not talking about that how much profit you will make, so this is as such out of context. The correct answer here is risk assessment. Reviewing which of the following would best ensure... subaveena pugalethi: Does the risk assessment report justify the sense of urgency to management? InfosecTrain Trainer: So, risk assessment report will tell you that what is the current residual risk level, right? It will tell that where that IT process stands. If that particular residual risk is beyond acceptable level, so the management will make sure that they are giving adequate amount of funding and resources to fix the issue. Got it? subaveena pugalethi: Okay. InfosecTrain Trainer: Like suppose as a CISO you identified that there is an weakness in the current AI deployment process in the organization. And now you have to convince the management that let's deploy this XYZ solution to reduce the problem and the solution is costing you suppose \$200,000. How you will seek the funding from them? InfosecTrain Trainer: You have to tell them, right, this process, currently, these are the issues, these are the threats, and currently, this is the problem. If you don't fix them, there is a high probability of a failure, high probability of a cyber attack and all, then they will approve this funding to you. Okay, let's go ahead and then purchase it. Got, got, Subha? subaveena pugalethi: Okay, yeah, I get it.

InfosecTrain Trainer: So, reviewing which of the following would best ensure that the security controls are effective? It's a very straightforward question, right? Risk assessment policies, how come risk assessment policies will tell you that control is effective? Return on security investment, return on security investment is also will not give you that how effective the control is. Effectiveness you judge by matrix, right? How many attacks are blocked by your firewall? InfosecTrain Trainer: How many people actually reported the incident? So that's how it tells you the effectiveness of that control, not access user rights. It's only talking about one thing. Security matrix is something which covers all the things. Which of the following factor of risk assessment typically involve the greatest amount of speculation? Speculation is something which you are not aware of. InfosecTrain Trainer: Exposure, you can predict, right? Exposure, you can predict how much asset is exposed, how much asset would get destroyed. Impact, also, you can predict somehow, right? Vulnerability, you already know. InfosecTrain Trainer: But the likelihood is something which is always speculative, right? Probability is something which always speculative. Like suppose you tell that my data center is located in India, but in last 15 years there has been no earthquake. But are you 100% sure that there's not going to be an earthquake next year? You say the last earthquake happens 20 years ago. InfosecTrain Trainer: From last 20 years, there is no earthquake. But what if the next year there is an earthquake, right? So it's always something which is speculative, which you cannot always predict 100%. Let's discuss a couple of more questions. Yeah. Yes.

Pudir: Sir, can you please extend me the readability problem? InfosecTrain Trainer: What? This likelihood? Pudir: No, no, sir. That is second paper, question paper. For reading, it is difficult. Can you enlarge it? It's what I'm saying. InfosecTrain Trainer: Okay, this one you are talking about... Pudir: Yeah, yeah, it's been smooth. InfosecTrain Trainer: It's clear now? Pudir: Yes, sir. InfosecTrain Trainer: All right, let's discuss. So, once the objective of performing a security

review has been defined, the next step for the Information Security Manager is to determine. We just discussed in detail, right? Once you understood what is the objective, next step would be constraint, approach, and result you will do. First, you will understand the scope. InfosecTrain Trainer: First, you will do the scoping, then you will go with the A, B, and D, right? So, scoping is the first which you will do, then you will do A, B, D. Got it. Which of the following items determine the acceptable level of residual risk in the organization? InfosecTrain Trainer: What is accepted for the organization, my management will decide. Not some regulatory requirement, inherent risk as such is out of context and internal audit finding also won't determine that. And the decision would always be by the management. Your CEO will tell you what is acceptable or what is not, right? InfosecTrain Trainer: Your management, board of directors, senior management, their discretion would always take the precedence. When performing a... SrinivasanJ: Sorry. SrinivasanJ: Regulatory... okay, so, I'll maybe wait. InfosecTrain Trainer: Even regulatory requirements also, Srinivasan, are not mandatory in nature that you follow them. You sometimes accept. If you don't have a budget.

InfosecTrain Trainer: You will say that we will only show the limited number of... amount of compliance which is required, rest we will follow the next year. You can do that, right? It's not necessary that you 100% show compliance. You say, okay, rest everything is in place, we will do it next year, because we... our budget do not support at this point of time, right? SrinivasanJ: Okay. But, InfosecTrain Trainer: So regulatory requirement like DPDPA, GDPR, do they come and force you? Those things will come into picture if tomorrow there is an incident, right? Then only those comes, right? Or they will not let your company to function if you do not follow them. SrinivasanJ: When there is an incident, yes. InfosecTrain Trainer: Right? SrinivasanJ: Yeah. Okay. InfosecTrain Trainer: Always there is a balance which you have to take. But that also would come from the management, right? They will say, okay, at what level you have to follow, at how much level you have to follow. Regulatory will also say some hundred thing. Is it necessary to follow all hundreds? You will say, okay, we will follow the 90 of them, rest 10, we will show the limited amount of compliance. Got it? InfosecTrain Trainer: And when performing a review of risk treatment option, the most important benefit to consider is maximum risk mitigation, savings in control options, alignment with regulatory requirement, achieving control objective. InfosecTrain Trainer: If the firewall is not able to block the unauthorized traffic, then there is no purpose. The firewall is not solving the purpose for which it was deployed. If the DLP solution which you have deployed is not able to detect any unauthorized disclosure of information, then its purpose is not being solved by the DLP.

InfosecTrain Trainer: the control objective. Got it. So, so the first one is, is it not maximizing the risk mitigation? Like that's, that's why you go for risk treatment, right? When you identify a risk, you decide what would you do with it to avoid or transfer or accept the risk. So risk treatment is. InfosecTrain Trainer: basically reducing the risk, right? subaveena pugalethi: Not maximizing the risk mitigation like that's that's why you go for risk treatment, right? When you identify a risk, you decide what would you do with it to avoid or transfer or accept the risk. So risk treatment is basically reducing the risk, right? But it is. InfosecTrain Trainer: This is a generic statement. Maximum risk mitigation. What level maximum? What is the maximum for you? Does this particular statement talk about it? That's what this is a very generic statement. Maximum risk mitigation. subaveena pugalethi: Okay. InfosecTrain Trainer: So that's what it's seeing. Most important benefit is the maximum risk mitigation is the most important benefit here. Most important benefit is whatever is the control has been deployed, it should do that. InfosecTrain Trainer: And that control may probably be mitigating some part of the risk, right? It's not that you only just deployed one control to reduce a risk, right? You can deploy 10, 20, 15 controls. Some part is being taken care by this control. Some part, some other control will do, right? So control, its main purpose is why the control is deployed. It should be fulfilling that purpose. That's it. Got Subha? subaveena pugalethi: Okay, yeah. InfosecTrain Trainer: All right, now we will go to the risk evaluation process. InfosecTrain Trainer: How you evaluate a risk, right?

So first thing is that whenever you do the risk assessment, you will get a list of all the threat, all the things, all the information you have collected. You will first analyze those results which you got. And when you are doing the evaluating, you will consider multiple factors. You will understand the consequences, you will understand the likelihood, you will understand the impact. InfosecTrain Trainer: Of all other related events. InfosecTrain Trainer: Then you will prioritize the treatment because you cannot treat all the risk and at what level you are going to treat that risk. That also you have to prioritize. Suppose you identified 100 risk, you cannot treat all of them. You will only focus on the one which are bringing more impact to our organization. So the evaluation process helps you prioritize the treatment and then you will document the decisions. InfosecTrain Trainer: What are the decisions taken? What are the future controls? What are the future initiatives which you will take to further mitigate the risk? InfosecTrain Trainer: Now, whenever you do the risk evaluation, these are the things what you do. These are the four techniques which you used. You first do the impact assessment. I showed you that impact and the likelihood matrix in the last session. InfosecTrain Trainer: So you determine the impact on the multiple areas, right? You will determine the financial impact, regulatory impact, operational impact, strategic impact, right? So all those quantification you have to do, I'll show you again so that you remember this I'm talking about. So impact, you determine the impact on multiple. InfosecTrain Trainer: categories, right?

Health, operation, reputation, strategy, legal, management effort, and you can add couple of more, depends on your organization to organization, right? InfosecTrain Trainer: So that is the impact assessment. Then you do the likelihood determination, which also was there in the same matrix. You will determine that what is the probability or the likelihood of happening that event in my organization. So that you will determine on the basis of the capability of threat actor, what is the historical record, how many vulnerabilities are present, and how effective my controls are. This will actually help me determine the likelihood. InfosecTrain Trainer: Then you do the cost benefit analysis. Let's take an example. Let's take, let's say that you determine that there is a risk of RAN. InfosecTrain Trainer: somewhere. So whenever a ransomware attack take place, so you have to quickly recover from this. Right? So you, so business says that this particular my business application generates a. InfosecTrain Trainer: \$100,000 revenue in a in a every hour. That's what the revenue generates. So you you you have a two options. Either you go with the cloud where you can deploy this at \$10,000 price or you do it on prem on prem, which will cost you the \$50,000. InfosecTrain Trainer: Which one option you will choose? You will choose on the basis of cost benefit analysis. This option is much more cheap, reliable as compared to on prem. So you will go with this. So that's how you do the cost benefit analysis. Then you take a decision and then. InfosecTrain Trainer: You do the risk appetite and the tolerance criteria which your organization will define that what is the acceptable level of risk, right?

What are the treatment actions you will take when you are going to escalate it further and when the executive approval is required. These all the criteria are considered when you are evaluating any risk. InfosecTrain Trainer: And when you evaluate, so this is the criteria how you define. So this is more of a qualitative risk assessment. InfosecTrain Trainer: Negligible, very low, low, medium, high, very high, extreme, insignificant, minor, significant, damaging, serious, critical. So these categories may differ from organization to organization. You may in your organization they might be calling is the critical, moderate, low or something. This example which I showed you here also you see this right? Improbable, remote, possible, probable, almost certain, very low, low, medium, high, very high. InfosecTrain Trainer: See? It depends what name you want to give to that. And then this is how you evaluate the score. Right? So there is a thread that an internal user unauthorized interception of the data. Vulnerability is there is a lack of encryption during the transmission. So impact is five. Likelihood is two. Risk score becomes ten. So it's a moderate risk. InfosecTrain Trainer: That's how you calculate. InfosecTrain Trainer: Now, what is a cascading risk? Someone tell me, what is a cascading risk? Mukesh Thakur: A risk at multiple layers or levels. InfosecTrain Trainer: How many of you have seen the Chernobyl web series? InfosecTrain Trainer: Anyone here who have seen Chernobyl, or heard about the Chernobyl. InfosecTrain Trainer: Million sug. InfosecTrain Trainer: in the Ukraine, then, then called the USSR. You remember there was a button called AZ-5?

InfosecTrain Trainer: And even remember button name AZ5 which they pressed and then immediately the core got exploded in the RBMP. That was called the RBMK reactor which was there in the Chernobyl which got exploded. So that is a very classical example of the cascading risk. How? InfosecTrain Trainer: So if you would have seen that particular web series or if you have not, you can go. It's a very good web series. So what happened? They were doing some testing, some safety check testing where they deployed some solution. So how the nuclear reactor works. So if you increase the power of the nuclear reactor, for that you have to take out the fuel rods. So there are the fuel rods which are there in the reactor. InfosecTrain Trainer: Right. So you take it out, you take it, insert how much you are taking it out, how much you are putting it in on the basis of that, the the capacity or the power capacity of the nuclear reactor increase or decrease. So that's what they were doing. They increased it at a very high level and then rapidly they were supposed to bring it down. But what they did, they increased it so much. InfosecTrain Trainer: high level then when they were bringing it down the cool down did not happen and the AZ5 is a kind of emergency switch off button so they press that emergency switch off button automate is already there was a poisoning which happened within the rod and it exploded right so that is a very classical example of a cascading risk right one risk happened then due to that particular failure some other risk happened. InfosecTrain Trainer: Then there is a chain reaction. Then something else will get exploded with something else will get exploded and then overall you are at risk. So this is how these days the advanced persistent threat actors operate.

They sit in your organization for years. They do all that planning, but the day they will launch an attack within. InfosecTrain Trainer: few hours, you will see one by one system going down. And that is what the cascading risk. Right? So first, there was an initial failure. You initially detected there is a threat. Then there is a chain reaction. Then it gets amplified, and then widespread impact. Probably your organization is not available. InfosecTrain Trainer: Now, something called the aggregated risk. So, what is the aggregated risk? Sometimes, there are some small, small moderate-rated vulnerabilities, or some low-scale vulnerabilities, which you... InfosecTrain Trainer: probably tend to ignore. You say that these are a moderate or low rated vulnerability, probably not that significant, may not bring, bring much value to us and very high low possibility that a protector would be able to exploit it. But sometimes all putting all of them together, it becomes a bigger risk and it can be exploited like the classical example of a bridge. InfosecTrain Trainer: If there is a one small crack, probably may not impact a bridge, but if there are 1,000 small cracks, those 1,000 small crack may together cause a problem for the bridge and bridge will collapse. The definition is aggregated risk occurs when multiple minor vulnerabilities collectively create a significant impact. Multiple small cracks creates a significant impact. So here, what are the characteristics? InfosecTrain Trainer: is a single threat affecting multiple vulnerabilities or multiple threats affecting multiple vulnerabilities and then there is a significant overall risk from one single threat actor.

So that's why whenever you are analyzing you have to follow a holistic approach beyond individual vulnerabilities or the individual issues which you are identified. You have to take it holistically, look and then accordingly take a decision. InfosecTrain Trainer: Now coming to the enterprise risk management, also integration of risk management into other processes. So as I gave you example, right, risk management is something which you do at each and every process. InfosecTrain Trainer: Whatever you are doing in the organization, you, some point of time, you are doing a risk assessment management. However, you might not be formally documenting it, or formally doing it, but you do. Like, when you design an architecture diagram. InfosecTrain Trainer: Whenever you create an architecture diagram, that time also you analyze all the kind of risk, right? Suppose you are creating one software application, you are building an architecture diagram. That time you will do a risk assessment. You will see that which all are the threats at each and every point. Then you think, thought, and then decide, right? We have to place a web application firewall there. We have to look for all these things. So this is one thing. Software development. InfosecTrain Trainer: Same thing with the software development. So that's why we say that security should be involved as early as possible in any process. So in the software development, if you don't do a proper risk assessment initially, then later on it becomes very difficult to bring any changes. So in the initial level itself, you will identify, you will do a thorough risk assessment, understand what are the issues which may come in that application.

InfosecTrain Trainer: And accordingly, you suggest the development team, please make sure these are the things which you follow. Change management. Whenever you implement any change, if you're deploying something, you do risk assessment. You will not just go ahead and then deploy any patch. You will first test that patch in a non-prod environment. You will make sure that the patch is not causing any issues, then you go ahead and deploy in the production. Configuration management. InfosecTrain Trainer: If you are doing any changes in the configuration, if you have a configuration baseline, this is the version, this is the things, these are the things, this should be there. If you're doing any changes, you will make sure that it should not cause any issues. It's not like that you went ahead and that you did some change and due to which there is an incident. Whenever you are handling any incident or tackling any problem, that time also you do the risk assessment, right? InfosecTrain Trainer: Suppose there are four or five incidents happening or whenever an incident is happening, you will analyze thoroughly. You will understand what is the most critical issue which we need to fix first. Physical security. So in your organization, also your physical security, which is designed. InfosecTrain Trainer: like, access gate, then security guard, then security camera, why there are so many layers they have deployed? On the basis of risk assessment only, right? They are thinking on each and every layer, right? Even if a person is able to enter from the main gate. InfosecTrain Trainer: There is one, turntable where only one person can enter. He he need a proper access card. Even if he's trying to enter, probably there is one security guard who is standing.

Then you have a detective control in form of, the security camera. Right? So all level. Also in the information and the enterprise risk management. InfosecTrain Trainer: So this is the overall process where the risk management is involved, human resource management. So whenever you apply for any new role, you get selected, they do a background verification check, right? Without that, they don't let you join the organization. InfosecTrain Trainer: You are, they are providing you access to any production system. What they do, they will do the background, they will give you the security awareness training module so that you understand the risk, then only you will have an access. Same thing with the project management. So whenever you initiate any project, any initiative, you do a risk management, risk assessment, all the things, what is the budget requirement, what is the timeline we'll be able to meet it, how many resources are needed, all those things you. InfosecTrain Trainer: look at holistically then you take a decision and you move ahead. You see risk management is something which is there in each and every process in the organization. Let's do one thing let's take a break and then we'll start with the SDLC process how the risk management is there in this software development life cycle. InfosecTrain Trainer: N. Johnny Souriar: Yeah, hi, yes. InfosecTrain Trainer: All right, let's understand the software development life cycle. So, whenever you design a software, whenever you do a development process, there is a risk management involved there since the beginning. So, whenever you want to create an application, suppose I want to create a mobile application for online banking. InfosecTrain Trainer: So, first thing, you will start with the threat modeling.

You will do the threat modeling. Briefly, we understood about the STRIDE, PASPA, and those threat modeling techniques, right? InfosecTrain Trainer: Or you can use some other new techniques like MITRE ATT&CK framework, right? So you do a threat modeling, you understand what are all different kind of threats which are against this application, from what angles is there can be SQL injection vulnerability, can threat actor come via networks, can threat actor come via the login page, can threat actor come via phishing, anything. You will think about all the possible threat scenarios. InfosecTrain Trainer: And then you will anticipate the potential threat and then you will incorporate design feature to block them. So you have to think around it initially because later on you cannot tell the development team that this is a new threat, please do the changes in the coding and then changes in the design because it becomes very expensive, right? InfosecTrain Trainer: Then comes the coding standards. What kind of coding standards they will follow? Every organization has a specific policies around it, which all open source coding libraries you can use, from where you can use the coding libraries and all those coding standards need to be defined. Then reviews. InfosecTrain Trainer: So whenever a code is developed, always there is a concept where there is going to be the peer review. So that peer review is actually done to understand if there are any defects, any issues, or has person followed all the coding standards and everything. Once that review is done, then you do the scanning. InfosecTrain Trainer: So, there are two types of scanning. One is the SAST, another one is the DAST. Static Application Security Testing and Dynamic Application Security Testing.

There is one IAST also, which is not... InfosecTrain Trainer: One more, integration. So SST and DST. So you will do a static application test, which will be done via there are multiple tools available to do that. Once that is done, once the application is deployed in production, when it's completed, then you will do the application scanning also to understand there are no issues and all. Then you do the overall penetration testing. InfosecTrain Trainer: So all these methods, all these processes which is there in the security SDLC lifecycle, what are they are doing? They are actually helping you mitigate the risk. That's how the risk management is done in the SDLC process. Let's discuss some questions. InfosecTrain Trainer: All right, let's discuss the correct answers. InfosecTrain Trainer: An organization's software development life cycle is being integrated with this risk management process. At which stage the SDLC is the most effective point to identify and mitigate the design level security vulnerabilities impacting overall residual risk? As I told you, it should be done as early as possible. Talking of the design level issues, how come you will identify them? Testing phase would be too late. InfosecTrain Trainer: Design phase is the correct answer. Coding phase also would be too late and deployment phase also would be too late to introduce that. So, correct answer here is B. An organization has defined its risk capacity. What does this term best represent in context of enterprise risk management? So, we discussed around two things, risk capacity, risk appetite, and risk tolerance. Three things we discussed in detail. InfosecTrain Trainer: So, risk capacity is something which is the maximum level of risk.

If the maximum level of acceptable level of risk organization is willing to tolerate, acceptable level of risk is what? This is the residual risk. InfosecTrain Trainer: Maximum acceptable level of risk organization is willing to tolerate, not residual. This is a risk appetite. Risk appetite is the maximum acceptable level of risk organization is willing to tolerate becomes a risk appetite. This is A. The total amount of risk the organization can absorb without. InfosecTrain Trainer: jeopardizing its existence, something which is beyond the existence called the risk capacity. So that is what the definition is. The current level of risk after implementing the control is the residual risk and the amount of risk transferred through insurance policy. It's also not a this is also not the definition of risk capacity. So correct answer here is B. InfosecTrain Trainer: A critical zero-day vulnerability is discovered in a widely used software. Which control type is first implemented to reduce the likelihood of exploitation while the patch is being developed? So, detective control will only help you detect the threat. It will only help you report. It is not actively mitigating the impact, like you are monitoring the log. InfosecTrain Trainer: You will only get to know that there is an attack

happening. Can it directly reduce the threat? No. Corrective control also will do the same. Once incident has taken place, once the exploit has been took place, then you will take the corrective actions. You will deploy patch, you will recover. That is also not a good option. Fatha: But, see, actually, this is already a widely used software, so which means the incident has already happened, right? InfosecTrain Trainer: Where it is saying the incident has already happened?

Anywhere in the... Fatha: Software is widely used. InfosecTrain Trainer: Yeah, so is the question anywhere it is mentioned that it's done? That's what I'm saying, you should never assume. What the question is saying, just go by that. Has anywhere it is saying that the critical zero-day vulnerability is discovered and has already been exploited? Anywhere it is saying? Fatha: No. Fatha: Yeah. So it just says it is used, but still not, I mean, exposed or... InfosecTrain Trainer: Is it talking about that already there is a live incident going on in this? And as such, when the incident has already taken place, then what the preventive control will do? Then you have to correct the issue, right? Fatha: Corrective. Yeah, corrective, it'll be. InfosecTrain Trainer: cloud that it's identified, then what you will do? You will do the prevent. You will... you have to prevent it from happening, right? Fatha: Yep. Johny Souriar: So here in zero day vulnerabilities now see there is a patch is not available that is under progress. So in that scenario for a virtual patching mechanism will implement, right? Virtual patching mechanism. So virtual patching mechanism is actually searching that pattern of that signature, right? Johny Souriar: So it is a type of detective type of control, right? Because anyway, my system is vulnerable, it's not attack, but I cannot apply now because there is no patches available. So I will use, okay, anyway, I have a network segmentation, IPS rule, all those things are standard things are available. So on top of that, I'm just doing a virtual patching mechanism where system is working on detective based control, right? InfosecTrain Trainer: Is this the question talking about anywhere?

Is it mentioning something anywhere that the virtual patching will be done and all anywhere is the question is saying that's what I'm saying. Only read the question and read the option and answer. Never ever assume anything in the exam. I'm telling you you will only get one one line questions. InfosecTrain Trainer: Never ever assume beyond what is given in the question. Just go by question and then answer. If you start assuming, you will never ever reach to a correct option. That's what I'm saying. So that's why once you start practicing, follow the same thing. Whatever the question is saying, read that what the option are saying and go with the correct answer. Don't assume from your side that because the person who have designed the question, they also do not assume that much. InfosecTrain Trainer: write a statement on the basis of a statement. They just want to check that, what is your understanding around the concept, and what is the step which you will take. That's it. Got, Johny? InfosecTrain Trainer: Question is simply saying that the vulnerability is identified. It is a widely used software. And as such, widely used software is just, kind of, there to confuse you. It's only saying that there is a vulnerability in a system. What is the first step you will take till the time the patch is deployed? You have to reduce the threat. You will do the preventive control. That's it. InfosecTrain Trainer: Which of the following is the primary purpose of defining the internal environment in the risk management process? To understand all potential threat to the organization, threat is an external environment. We discussed about the SWAT, right? InfosecTrain Trainer: To understand the organizational culture, capabilities, and risk appetite.

This is what the internal environment means, right? Budget for the risk management activities is not the correct purpose. To determine the optimal organization structure for the risk management, no. The best option here is the primary is what you want to understand. What is the culture? What is the capability? And what is the risk appetite of the organization? Got it. InfosecTrain Trainer: So keep this in mind whenever you are approaching question in the exam also. Always go what the question says and what the option says. That's it. Never ever assume on top of it what is happening in your organization. So too much technical analysis will lead you to a wrong answer. That's a fact. InfosecTrain Trainer: Next comes the valuation of the information, right? So, so whenever you evaluate the information, so the information valuation generally happens on these things, right? Something called the proprietary information, something which is proprietary to you, like. InfosecTrain Trainer: Microsoft has the source code of their operating system, right? This is a proprietary... some organization has some proprietary code, proprietary systems, proprietary thing. If that goes into the public. InfosecTrain Trainer: Then you lose a competitive advantage. Suppose you are introducing a new product in the market and if that particular product information is known to your competitor, they may probably fast pace and introduce that capability before you, you lose the competitive advantage, right? Something called the trade secret formula and all like Coca-Cola formula, which is a trade secret for the Coca-Cola. If someone steal the Coca-Cola formula. InfosecTrain Trainer: They can also produce the same ingredient or the same thing what Coca-Cola offers. So that is a trade secret. Patent.

So a lot of organizations file multiple patents, small changes in a process or a small technological things which they have introduced. So patent also becomes important. And the PII data, PII, PHI, any personal data is also very important because there are a lot of regulations, a lot of. InfosecTrain Trainer: Guidelines around it, which you have to follow. InfosecTrain Trainer: Now, understanding the change management process. So, we discussed the change management process. Also, you do the risk assessment. So, whenever you submit any change in the organization, there are two bodies which actually do that. One is the Change Review Board. Another one is the Change Approval Board. Has anyone heard of these bodies? InfosecTrain Trainer: They are there in your organization also, change review board and approval board. SupriyaMhatre: Yes. Fatha: Yeah. Cab is coming. InfosecTrain Trainer: Correct. So, whenever you submit any change request, suppose you want to introduce any new rule, you want to do any changes. InfosecTrain Trainer: So whenever you do any changes in your environment, those changes need to be reviewed, right? Like then otherwise you will have an issue like the CrowdStrike where you deployed, pushed some patch all across the world and then it's not compatible with some process and then there is a blue death screen which is coming. Same thing may happen in your organization also. InfosecTrain Trainer: So that change review board will first review that change as soon as you submit the request. Request submission may happen with multiple ways.

I'm not sure you can use some ticketing tool like ServiceNow or some other platform, whatever your organization is using, where you will submit the detailed description, justification, implementation team, timing, when it will be pushed on all things. Then the security assessment would be done to analyze if there is a. InfosecTrain Trainer: any impact on the existing baseline, standard, any privacy related issues it is affecting. Then you will implement the change and then you will execute and then you verify has the change been deployed properly, no issues and then you document it. This is a change management process. Similar to change management, you have a configuration management process also. So, there are new tools available in the market. InfosecTrain Trainer: They actually evaluate the configuration drift. InfosecTrain Trainer: So, these configuration drift management tools store information around all the configuration which is there in your organization, right? Like, configuration of your servers, configuration of your databases, configuration of networks, configuration of your firewalls, all the information is stored here. Any changes, if you are doing, you are bringing in that particular. InfosecTrain Trainer: CMDB, or that configuration changes you are doing, that should follow a change management process. Without a due approval, without checking everything, you will not implement those changes, right? So that is a process called the configuration management. InfosecTrain Trainer: Like, your laptop also. Your laptop also has some configuration. So, when company issue a laptop to every employee, all the laptop you will see have some specific configuration, right?

They will make sure that there is a, there is a EDR installed, there is an anti-malware installed, all the patches and everything are installed properly, what are the softwares which are permitted, only those are installed, right? And rest, everything, they will block. InfosecTrain Trainer: Any changes which are happening beyond it would follow this particular process. Got it. InfosecTrain Trainer: Now, understanding the risk analysis techniques. So, once you have understood the risk, once you understood what are the risks in your environment, you need to thoroughly analyze those risks. You need to understand that. InfosecTrain Trainer: that how critical that risk is, right? So that risk analysis has three techniques. One thing is the expert interviews where you will probably go interview some subject matter experts, you will share some questionnaire to them, right? Structured response process or you create a model and simulation, right? You can create a machine learning model, you can feed all the inputs to this and using that you can analyze the. InfosecTrain Trainer: Risk. InfosecTrain Trainer: Three high becomes four, very high becomes five. Similarly for the likelihood. This is a semi quantitative technique. Now understand the quantitative technique. So quantitative technique, this is not that important. InfosecTrain Trainer: get any questions in the exam but for this particular formula you may get so you must have an understanding I think in the last class we even discussed with the example also but let me take again one example let's take an example let's say you have one particular data center right this particular data center has some value. InfosecTrain Trainer: Asset value. Let's say the data center cost is \$100 million, right?

So data center is located in a country which is very prone to any kind of suppose in the rings of fire countries, you know, rings of fire countries like Indonesia and and the Japan and all where they are. InfosecTrain Trainer: tonic plates where continuously any volcanic eruptions or any kind of earthquake keeps happening. Suppose it's there in that particular belt, which is very prone to earthquakes, tsunamis and all. So, you want to do a quantitative risk analysis of this, like if there is a risk of a natural calamity, how much impact it will bring to this particular asset. So, you will need to first. InfosecTrain Trainer: single loss expectancy. So, you know the asset value. \$100 million is your asset value. Then exposure factor. Exposure factor means if one time earthquake happens,

how much damage it will do to my data center. Let's say I have. InfosecTrain Trainer: the data center, it is such a manner that even if such kind of issue happens, it won't damage my 100% asset. Let's say it will only do the 50% damage. So, once you do the 50%, the single loss expectancy becomes. InfosecTrain Trainer: of \$50 million. So, if one time an earthquake happens, my loss would be \$50 million from this particular asset. Now, I have to calculate the annual loss expectancy. So, annual loss expectancy. InfosecTrain Trainer: becomes single loss expectancy which is a \$50 million multiplied by annual rate of occurrence. How many times an earthquake can occur in that particular region? Let's say it's a ring. InfosecTrain Trainer: every year two times earthquake happens so my annual loss expectancy becomes \$100 million. Simple. It's just a simple formula where you have to just substitute the values and then you will get the answer. Anyone any doubts here?

InfosecTrain Trainer: Alright, now coming to the Value at Risk. Value at Risk actually works on the Six Sigma techniques. You would have heard about the bell curve. InfosecTrain Trainer: 3 Sigma, 6 Sigma and all right. It actually works on that. It will compute the maximum probable loss in a defined period with a confidence interval typically 95% or 99% right. So, you create a bell curve by using the values which you identified then you use the Monte Carlo simulation. So, Monte Carlo simulation is a mathematical technique where you run a simulation and. InfosecTrain Trainer: Then you substitute the values with the random variables through historical data, and then. InfosecTrain Trainer: particular analysis. However, this is not going to come in the exam but just for your information purpose this is what the value at risk means which will compute the maximum probable loss in a confidence interval like Six Sigma does. We will discuss a question on this. InfosecTrain Trainer: Quantitative techniques, so that you... you can answer the. InfosecTrain Trainer: scenario analysis. So, this is a process where you will understand, you will note down. InfosecTrain Trainer: all the different, different scenarios. What is an asset which is involved and what is, this is a kind of a table which you will create. If this happens, this is the number of record, this is the loss I will have. Similarly, what this particular thing is doing. If 1% revenue, 2.5% revenue, 5% revenue, like in comes of health safety, it's saying that if. InfosecTrain Trainer: If multiple employees and customer are the fatalities occurs it's a five. If a single employee or customer fatality occur due to a risk becomes a four.

Likewise you do the loss scenario analysis for your organization and you have to create this particular matrix accordingly and this will differ from our core like manufacturing. InfosecTrain Trainer: The engineering organization will have more number of loss scenarios, right? But a software development organization may not have. For them, the most important thing would be probably data or the record or the availability of application. InfosecTrain Trainer: safety, all those aspects also will come into the picture. Let's discuss questions here. So, you can solve the first question which will probably give you an understanding how to calculate the ALE. InfosecTrain Trainer: I'm not sure. I'm not sure. I'm not sure. InfosecTrain Trainer: I'm a big fan. I'm a big fan. InfosecTrain Trainer: I don't know. I don't know. I don't know. I don't know. InfosecTrain Trainer: I'm not sure if I'm going to be able to do this, but I'm going to be able to do this. InfosecTrain Trainer: your. InfosecTrain Trainer: It's like, it's like, it's like, it's like, it's like, it's like, it's like, it's like. InfosecTrain Trainer: I've been experiencing some discomfort in my chest. Could I please have a prescription? InfosecTrain Trainer: I've been experiencing some discomfort in my joints, and I've been experiencing some discomfort in my joints. InfosecTrain Trainer: I think your voice is not audible. Oh, sorry. Yeah. Madhes: I think your voice is not audible. Ashwin: No voice is not heard. InfosecTrain Trainer: Oh, sorry. Yeah, I think my microphone position was not correct. So the first question is actually you have to do the eval, you have to check the SLE and ALE, right? Asset value is given to you, exposure factor is given to you so you can use it.

So even in the exam also, if they ask, they will give you all these details. You have to just substitute and do it. It's, it's simple. InfosecTrain Trainer: Next question is, an organization has adopted a quantitative risk management approach for its critical asset. What is the greatest advantage this approach provide when justifying security investment to the board? What is the greatest advantage of quantitative? This is a quantitative approach. InfosecTrain Trainer: It provides subjective asset. This is eliminated. Subjective means qualitative, not quantitative. Eliminate need for monitoring. How come any assessment, any of the assessment approach cannot eliminate this? 100% elimination of vulnerability. This is also statement itself is wrong. You cannot 100% eliminate anything. Always that's going to be something. It allows for the direct comparison of security control against financial loss. That's what you're doing. InfosecTrain Trainer: Total asset value, what is the financial loss? So, that's what this particular approach does. So, correct answer here is B. Vulnerabilities discovered during an assessment should be handled as a risk even though there is no threat. If there is no threat, why you will term them as a risk? Prioritize for remediation solely based on impact. InfosecTrain Trainer: Do you only consider impact? That's why we are coming, we are calculating the likelihood also, right? Not only basis of impact, basis for analyzing the effectiveness of control. How come, how many number of vulnerabilities will tell you the effectiveness of the control? No. Basically, whenever you discover a vulnerability, you will evaluate for threat, impact, and the cost mitigation. All of them you will calculate, then you will say that this is a risk or not.

InfosecTrain Trainer: Right? That's what the CVSS scoring system do. InfosecTrain Trainer: Anyone has any different opinion or any doubts? InfosecTrain Trainer: Now, coming to the next part of the information risk response. InfosecTrain Trainer: So, whenever you, so we have analyzed the risk, now we have understood that how many of them are, what is the inherent risk currently standing, however you have used the qualitative, quantitative, semi-quantitative, whatever approach you have identified. Now, next step comes is the deciding how you are going to remediate, not remediate, how you are going to reduce the risk to an acceptable level, right? InfosecTrain Trainer: So, the risk response which you will choose, that particular need to align to the desired state of enterprise security. What is the desired state is the residual risk or the reducing the risk to a risk appetite level. InfosecTrain Trainer: You have to reduce it below to the appetite. That is your desired state. That's how much you want to reduce. So, how much is the desired state? On the basis of that, you will choose what kind of response you will use. You have to mitigate, you have to avoid, you have to accept, or you have to transfer. InfosecTrain Trainer: Then, defined risk appetite, tolerance criteria, and capacity provide input to the desired state. That's what I said, right? Desired state would be determined by them and the desired state is management's acceptable risk, tolerable deviations, and total amount of risk. So, how much management want it to be accepted at what level? That is the level which you want to achieve, which you will. InfosecTrain Trainer: accept, and then you will decide what are the mitigation options you have to use.

Now, how do you accept, how do you establish these acceptable risk parameters? InfosecTrain Trainer: So, without clearly defining... Madhes: Hey, I have just one question. Go back to previous slide. Here, this is more, related to risk evaluation also, no? Because in risk evaluation also, we are, you know, identifying the risk appetite and then not identifying. We are just checking with the... No, but... InfosecTrain Trainer: In evaluation, when did we consider the risk appetite? Madhes: No, InfosecTrain Trainer: So, the risk appetite will come in... Madhes: In risk evaluation, we are doing the risk response also, whether we need to go for, you know, insurance, risk transfer, everything, right? InfosecTrain Trainer: Yeah, that's what we are discussing, risk response. After evaluation, then the response will come, right? Once you have evaluated the risk, then you will decide, okay, which risk response option to do. So, this is the next step to that. Got it? Madhes: There. InfosecTrain Trainer: So, that acceptable level risk, right, probably for a small startup, for them, probably the \$1 million is a very big money. \$1 million probably would be a high or a critical risk for them. But for a \$40-50 billion organization, for them, \$1 million is a very small amount. InfosecTrain Trainer: Right? So, for them, a low rating will start from this. InfosecTrain Trainer: right? You will calculate the maximum tolerable downtime for the business function. So MTD is what? MTD is actually a risk, risk appetite only, right? Because if you go. InfosecTrain Trainer: suffer. Also, you need to determine the financial impact threshold requiring escalation. All these inputs will help you understand what is acceptable.

And then you will create a risk acceptance criteria which will involve the business growth initiative. What is the. InfosecTrain Trainer: compliance requirement, reputational protection, operational resilience, all those things you will keep in mind while designing this acceptable risk parameter. And then once that is done, then you will go with the risk response option. So there are four risk response options, terminate, transfer, mitigate, accept. InfosecTrain Trainer: Terminate means avoid something. So, this flowchart will give you a better picture. I will discuss after this. Terminate means something which is. InfosecTrain Trainer: you have to re-engineer, re-create process, or something, you will avoid. Like, if, I gave a simple example, right? Like, today, you know that certification cost for the CISM is something between \$760. Tomorrow, if ISACA. InfosecTrain Trainer: How many of you will take the certification? Tell me honestly. InfosecTrain Trainer: None, right? Because it's way beyond your appetite. If you actually fail in an exam, you imagine the amount of money you will lose. So that's how you decide on the terminate. Transfer is something, any question in exam, when you choose a transfer, when the likelihood of occurrence is low. InfosecTrain Trainer: But the impact is high. You will go for transfer. Insurance. Your health insurance. InfosecTrain Trainer: occur, the impact is going to be the way beyond that, which they... which will probably hamper their annual revenue. InfosecTrain Trainer: You purchase insurance to reduce the impact. And accountability will always keep this in mind. Even if you transfer the risk, accountability will remain with the organization. You can only transfer the financial impact or a regulatory impact or something you can.

InfosecTrain Trainer: Ultimate accountability with always sits with the aggression only. Mitigate means which is the most common technique where you implement the controls. You will deploy some set of controls like you will deploy EDR, you deploy DLP, you deploy the firewalls, and then you will probably modify, eliminate the risky processes. You create the policies, SOPs, guidelines, all the things what you do to. InfosecTrain Trainer: overall impact or likelihood becomes a mitigate and the accept is something which is below the acceptance, below your risk appetite you will accept. Probably there is a risk which is below your appetite level you will probably say okay no need of additionally probably deploying any controls, transferring or something or also. InfosecTrain Trainer: So anything, whatever is left over after doing terminate, transfer, mitigate, that also you have to accept. So this flow chart, if you read correctly, if you want, you can take a screenshot of this. This is actually which help you to decide which option to choose. You think of any risk scenario and then you go by step by step in this. InfosecTrain Trainer: Determine which option to choose. Like if the risk exceeds the appetite level, if it is no, it is below appetite level, no need of unnecessary putting up any controls and all, you will accept the risk. If it is beyond the appetite level, does the risk exceed the defined tolerance criteria? Also, if it is below tolerance. InfosecTrain Trainer: accept. If it is beyond tolerance, will the risk persist beyond acceptable level? Whatever is the acceptable level, if it's below. InfosecTrain Trainer: limit also is the value or benefit to the gain.

If taking that initiative, like does investing \$5,000 for a certification, are there any gain benefit of this? There is no gain, then what you will do, you will avoid. If there is gain, probably by investing \$5,000, you will get a salary increase of. InfosecTrain Trainer: \$50,000. Probably you will take a risk. In that case, do the cost of reducing risk to an acceptable exceed value gain? To deploy the control to reduce the risk to an acceptable level. If it is beyond that, then you will avoid, but if it is below that, then you will mitigate where you will deploy some control. InfosecTrain Trainer: or something, right? Then you will see is the low likelihood probability of, I told you, right? If there is a low likelihood and the probability is more, you will transfer. If it is not, you will avoid. Got everyone? I think once you read, you will input any scenario into this situation and then you go step by step. InfosecTrain Trainer: You will get more clarity which particular option to choose in any of the scenario or any of the situations. InfosecTrain Trainer: For example, we decided that we'll mitigate the risk. And, after that activity, now we know that the risk is below the tolerance criteria. Then we'll accept the risk because now it is below the, tolerance criteria. So initially mitigate, then it's accept. Right? Correct. Since we do the regular monitoring, initially, we'll mark it as mitigate, and later on, we'll mark it as accept. Right? Correct. Correct. Okay. InfosecTrain Trainer: second question we should use the exact term as risk appetite or risk tolerance can please repeat again after mitigating the risk is below my risk. Sandeep Saxena: Just a question. So, for example, we decided that we'll mitigate the risk.

And, after that activity, now we know that the risk is below the tolerance criteria. Then we'll accept the risk because now it is below the, tolerance criteria. So initially mitigate, then it's accept. Right? InfosecTrain Trainer: Correct. Sandeep Saxena: Since we do the regular monitoring, initially, we'll mark it as mitigate, and later on, we'll mark it as accept. Right? InfosecTrain Trainer: Correct, correct. Sandeep Saxena: Okay. Second question, we should use the exact term as risk appetite or risk tolerance. InfosecTrain Trainer: Can you please repeat again? Sandeep Saxena: After mitigating, the risk is below my risk appetite or risk is below my risk tolerance. InfosecTrain Trainer: This is basically below your, below your tolerance. Sandeep Saxena: Yeah. So the exact the term we should use is risk tolerance, not risk appetite. InfosecTrain Trainer: correct risk tolerance. Sandeep Saxena: Okay, thanks. InfosecTrain Trainer: This already we discussed with the Tiwala example, right? What is the inherent risk and the residual risk, right? Once we decided we deployed those controls, mitigate and all, whatever is the leftover, I have to accept. So, before implementing any control, whatever risk is there, it's called the inherent risk. Once the control is deployed, whatever is the leftover that I will accept is called the residual risk. Just. InfosecTrain Trainer: Just keep this thing in mind. InfosecTrain Trainer: Now, once you are choosing a risk mitigation option, right? So you have to deploy some kind of control, right? We already discussed, right? Technical control, administrative control, physical control, operational control.

So any of these control you will deploy, technical control like firewall encryption, access control, monitoring systems, administrative control will come in form of the directions, right? Your acceptable lose policies, your. InfosecTrain Trainer: procedure, guidelines, standards. Physical control is something which is physically visible, right? Like your cameras, your barriers, surveillance systems and operational control is something which is in the form of the operation like training, compliance monitoring and all those things. These are some of the example or theme from which you will choose the mitigation option. InfosecTrain Trainer: And the risk acceptance. So, this particular diagram I have created to make you understand how it happens. The risk appetite is always below the tolerance. Tolerance is something which is the variation which is given in that risk appetite and risk capacity which is the maximum. If you go beyond that then organization will have a huge impact which they will not be able to sustain. InfosecTrain Trainer: So, what are the factors which you will consider while designing this risk acceptance criteria? Mitigation cost exceeds the asset value. InfosecTrain Trainer: If mitigating any control, and the asset value, if it is going beyond asset value, what you will do? You will accept the risk. InfosecTrain Trainer: Suppose you know that there is a threat of ransomware and to mitigate the ransomware, you know the best thing is that to implement an offshore backup option. To deploy this, you did an evaluation. To deploy this, the total budget is coming around \$500,000. InfosecTrain Trainer: Now this year I don't have a budget to fund this. My management said we will be able to fund this next year because we have some other critical things.

What you will do, you will accept for this year and next year then you will go with the mitigation. Sometimes there is a technical infeasibility to mitigate effectively. If there are any, no technology or no option available to mitigate or reduce, you will accept. InfosecTrain Trainer: Like, best example was zero-day vulnerability. If you know that there is a zero-day vulnerability, patch is not available, patch is being deployed at current time, what you will do, you have to accept the risk till the time patch is being developed, right? When the potential impact is low relative to business benefit. InfosecTrain Trainer: So, the kind of business benefit that particular risk is giving, and the impact is low, you will accept, and the remaining risk after the controls are implemented, you will accept. So, these are the four scenarios where you will accept the risk. InfosecTrain Trainer: And the consideration, whenever you are taking the acceptance, right, you will not only restrict to the financial terms, you have to also consider the customer trust, legal, regulatory, all the requirements you have to consider while creating this acceptance criteria. InfosecTrain Trainer: Now, regulatory risk consideration. So whenever all the organization are actually have, have actually they, they, it depends on the kind of environment you operate, right? You are a food industry, you are a banking industry, you are a manufacturing industry. There are different, different regulations which gets applied to you to understand. InfosecTrain Trainer: Any regulation, any regulation which is there need to be treated as a risk. This is a statement, make a note of it from exam perspective. What I mean, GDPR, NIS2, DPDPA, all of them are risk for your organization.

If you are not comply to them, then there is a risk. InfosecTrain Trainer: Now, how much you want to comply, that depends on your management discretion. Simple. That's what I said. Always the management discretion takes precedence. So, they will decide how much we want to show compliance towards them. So, for that, you need to first understand which particular environment you operate, which all kind of different, different regulations apply to you. InfosecTrain Trainer: Then you will evaluate the impact. You will analyze the potential consequences of full compliance, partial compliance, non-compliance, how much impact it is bringing. Then you will also have prioritization factors. You will consider the enforcement likelihood, penalty severity, implementation complexity, alignment with business objective, all those things you will consider when you are considering any regulatory risks. InfosecTrain Trainer: Third-party service provider. So, you deployed your solution in a cloud. Does the accountability shift to them? No. InfosecTrain Trainer: Still, you are liable. You are you have a risk. Right? To mitigate this risk, you will say, okay. I will deploy a redundancy mechanism, or I'll deploy it on some other hybrid clouds. I'll say, okay. I'll deploy in two data centers. Yeah, Shweta. Shweta Sundar: Can you please go back to the previous slide? I have a question. So here, when you were mentioning about the prioritization factor or impact, who does these things? I mean, you kept saying it is you have to prioritize, but is the assessment done by the security manager and then the final decision taken by senior management? How does that happen? InfosecTrain Trainer: No, no. So this matrix, which I'm showing, this is created by the Enterprise Risk Committee.

So every organization has an Enterprise Risk Committee, which is which sits, with the CEO, CEO, all the senior management, senior folks, they are going to create those acceptance criteria, not CSO, not CTO and all. Understood, Shweta? Shweta Sundar: Okay, okay. InfosecTrain Trainer: They create this criteria and circulate to the organization, then all the business units will follow that. So that's what I'm saying. This acceptance criteria is designed by the senior management. Shweta Sundar: Okay, the impact and prioritization is not with the security manager, but with the risk management team, who are dedicatedly doing this particular, factorizations and everything. InfosecTrain Trainer: No, no, evaluation and all security team will do. The one who is doing the risk assessment, he will do that, right? He has this particular matrix. Now, when he's doing the assessment, he will say, okay, by looking at the current risk causes, consequences, probability and all, I'll say, okay, four is going to be the impact, four is going to be the likelihood. InfosecTrain Trainer: So, he will look at this particular matrix and the criteria which is created by the organization, and then on the basis of that, he will choose what is going to be the impact and likelihood. This management won't tell. This, you have to decide. But this overall... Shweta Sundar: I'm sorry to interrupt. When you keep saying he, I mean, who's the actual role you're talking about over here? InfosecTrain Trainer: You can choose between. Shweta Sundar: Just... InfosecTrain Trainer: The one who is doing

the risk assessment. Shweta Sundar: Okay, the risk assess... the risk assessment in this context is with the security, manager, or the CISO.

InfosecTrain Trainer: So, risk management, risk assessment is not only done for the cybersecurity, right? As we already discussed, right? There is a financial risk, operational risk, admin risk. So, this is just for the example purpose I'm talking. So, we are actually learning here for the cybersecurity certification. That's why all the context which I'm taking, I'm talking from the cyber perspective. That's it. Shweta Sundar: the impact evaluation or prioritization factor who create who decides or first of all there is someone who builds this and then someone who will approve it so the someone who is building it is from the risk management team senior management senior management will approve it right yeah senior management will approve it and. InfosecTrain Trainer: Senior management. Shweta Sundar: Senior management will approve it, right? InfosecTrain Trainer: Yeah, senior management will approve it, and the enterprise risk management will create it. Shweta Sundar: Okay, okay. That, now it's clear. InfosecTrain Trainer: So now, in the third-party service, whenever you are giving any... any services, you are taking any SaaS solution, you are deploying something in cloud, right, you are outsourcing something, these are the... these days, a lot of organizations, they use the managed SOC. InfosecTrain Trainer: or outsourcing some kind of thing, always you have to do the risk assessment, right? So, like, whenever you get into contract with them, you will do a pre-contract due diligence, right? You will do a risk assessment, you will try to understand is the organization's financial statement is good or not, how secure their platform or application is. InfosecTrain Trainer: then you will put across all the contractual safeguards.

Suppose you are a GDPR compliant in the contract, you will say that please make sure that you are a GDPR compliant, you are not sharing our customer data and information with anyone, and if tomorrow you breach it, you have to face or pay for the liabilities or pay for the fines which we have to give. InfosecTrain Trainer: Then you will establish ongoing monitoring, a continuous monitoring program like we discussed, right? In the risk assessment, I gave example. So critical third parties you assess every year, high you assess every two years. Likewise, you have to create that program and then also you have to define a specific exit strategy. Tomorrow, if I stop the contract with your organization, how I am supposed to take an exit, how I am supposed to. InfosecTrain Trainer: end this particular contract so they will say okay once we end then the data would be deleted or they will say we will retain the data for next four years five years whatever. This is how the third party service provider risks are managed. Now coming to the control cost and benefit analysis. Whenever you decide to implement a control suppose in your organization you identified there is a. InfosecTrain Trainer: information or data. InfosecTrain Trainer: disclosure risk. To mitigate this, you identified, you thought, okay, let's deploy a DLP solution. So, this is a control which will reduce this particular risk to an acceptable level. But to deploy a DLP, what are the things which you have to consider? You have to consider the acquisition cost. InfosecTrain Trainer: Suppose you are going with the Proofpoint. I think you would have heard about Proofpoint or Checkpoint. These are all the vendors, those who give the DLP solution, right? Even Microsoft has Purview, Microsoft Purview.

So, you have to pay some annual acquisition or the licensing cost, right? Let's say it's costing you \$100,000 a year, is an acquisition cost. InfosecTrain Trainer: Now, once I deploy, that time also I have to pay, right, to the consultant. I have to create the sensitivity labeling, I have to do all the optimization and everything. I have to again pay some \$100,000 for that, to bring it into my system, integrate with everything. InfosecTrain Trainer: Then also there's going to be testing and assessment cost so they will say okay we will require six month testing assessment and all these things so you have to pay for the consultancy cost and everything for six months and then once everything is done project is roll out in the production always there's going to be the maintenance cost which you have to incur so that's how whenever you are we are saying that you have to do the cost benefit analysis whenever selecting a control that. InfosecTrain Trainer: cost which it is being referred to that cost is the total cost of ownership which include the acquisition, deployment, testing and the recurring maintenance. Everything you have to consider then only you have to take a decision okay is the control is suitable for your organization or not. Whenever you see that this particular is going beyond my. InfosecTrain Trainer: budget and all you have to accept the risk you say okay we'll not go with the DLP whatever we are doing we'll manage within that. Also you have to consider the compliance monitoring enforcement you have to reduce the throughput of the controlled processes and consider the training new procedure and the technologies because whenever you deploy any new control you have to provide the training. InfosecTrain Trainer: understanding to your employees, right?

If you are, suppose, replacing your existing CIM solution to a new solution, you have to train your engineering team, right? Otherwise, you have to train your SOC team to understand those mattresses, to read the dashboard and everything. So, for everything, there is a cost involved. InfosecTrain Trainer: That's why it's very difficult in the organization to move from the existing security tech stack to a new tech stack. Always, it's very difficult. Organizations generally try to stick to the existing tech stack. InfosecTrain Trainer: Now, this is very important. Who is the risk owner? Who is the control owner? Yashweta. Shweta Sundar: So, the TCO from the previous domain, what we understand is that it's the entire life cycle of the particular control or whatever solution that we are getting in. So, does this also include the decommissioning or retirement or exit costs as well? InfosecTrain Trainer: No, but that exit cost won't be considered when you are deploying the control, right? Shweta Sundar: Oh... InfosecTrain Trainer: Exiting... when you exit, that exit... during the exit time, you won't be paying something. Shweta Sundar: Okay. InfosecTrain Trainer: That exit cost will come into the picture when you are deciding, suppose whenever you are evaluating any asset value, that exit cost would come in terms of the asset value. When you are considering an asset value, we will discuss the quantitative risk assessment, right? Shweta Sundar: There was one... InfosecTrain Trainer: asset value which we gave. Suppose there is one server, that server is an asset value, so to determine this particular asset value of this server, we will not take the cost which is there in the book. InfosecTrain Trainer: If you see any financial books of record, all the asset has a depreciating value.

Suppose you purchase something at \$100, over a period of time, the cost will continue to reduce, right? So you won't consider the asset value what is currently there in the books of account. You will always consider the asset value as a cost of replacement. InfosecTrain Trainer: Because 5 years back, when you purchased this technology, probably it was costing you \$100, but today, if this gets destroyed, you have to incur the \$200. So this \$200 becomes asset value. Got it, Shruta? Shweta Sundar: Yes. Thank you. Yes. InfosecTrain Trainer: And you will get some questions around this, so please be clear on this. InfosecTrain Trainer: Now coming to the risk owner versus control owner. So whenever you see a control, you say there is a DLP solution deployed. That DLP solution is protecting the PII data of one of your line of business. InfosecTrain Trainer: But line of business is responsible for doing the sensitivity label. They have... they are responsible for deploying the consistent sensitivity labels, choosing the correct sensitivity labels, deploying all the controls which DLP defines, right? InfosecTrain Trainer: But if they are not going with that, they are saying that there is some document where we... I know that it should be restricted, but I am intentionally doing it confidential for some purpose. So, what is the risk? Who is going to accept? The risk would be accepted by the data owner. InfosecTrain Trainer: So data owner becomes a risk owner, but here who is the control owner for DLP? DLP control owner is the engineering team. The DLP engineering team, all the organization, you have a DLP engineering team, those who maintain the DLP solution, any changes or something need to be done, you will go to them, right? Similarly, another example is a firewall.

Firewall is maintained by whom? Network engineer. InfosecTrain Trainer: So, the one who knows the firewall rules, he will set the firewall rules, he's opened the firewall rules, but the firewall is whom it is protecting, it is protecting the business application. InfosecTrain Trainer: So if business application want to open any port for any particular traffic to arrive to the application, then who will accept the risk? The business application owner will accept the risk because he's telling the network engineer, please go open this particular port so that the traffic can flow into my application. But if tomorrow an attacker also leverage this path or he get into the application, who is responsible? Business application owner. InfosecTrain Trainer: Because he understood, he... he... he analyzed this particular thing, he understood, then only he told the network engineer to enable it. So the risk owner always going to be the senior business leaders, they are accountable for the risk outcomes. InfosecTrain Trainer: So, they make the risk acceptance decisions, they allocate the resources for the risk treatment, they set the risk appetite for their domains. Typically, the business unit head or executives would be here, and they focus on the business impact and the strategic alignment. InfosecTrain Trainer: But the control owner is something who is the technical expert who design, maintain the safeguard, monitor the control, report the performance, typically IT or security team members and focus on the technical implementation of this. Clear everyone? The key difference between the risk owner versus control owners. InfosecTrain Trainer: Now, understanding the impact categorization. InfosecTrain Trainer: Right?

So, whenever you evaluate any risk on the likelihood and the impact, you have to consider on the financial loss, legal regulatory loss, reputational damages, operational disruption, same thing we did in... saw this matrix, right? You are understanding the operational loss, reputational loss, legal loss, management effort, financial loss, right? Same thing this is talking about. InfosecTrain Trainer: Now, finding the optimum risk level. So, whenever you are designing the optimum risk level, you have to consider these things. First thing is the business risk profile. What is an overall risk tolerance and appetite for the organization? Overall tolerance and appetite for that particular business. InfosecTrain Trainer: And then you will do the cost benefit analysis. We just understood total cost of

ownership. And then you will say, OK, the overall loss due to the risk is \$20,000, and the control cost is coming to the \$22,000. Will you go ahead with that? You will not. InfosecTrain Trainer: You will always look for the controls, those who are costing less, and bringing the efficiency, right? So that cost-benefit balance you have to maintain, and the diminishing return. This is a very important term. InfosecTrain Trainer: So, to mitigate a risk, you can deploy some number of controls. I will say, okay, to reduce the unauthorized information disclosure, I will deploy DLP, I will deploy other things, I'll create the firewall rules, I will do the training, I'll do this, I'll do this. InfosecTrain Trainer: So you can have some certain number of controls, but after a point, any number of controls you keep adding, it won't reduce the risk further because you have reached that optimum level. So that's how you have to also consider a diminishing return point.

Like beyond that certain point, any number of control you introduce, any number of controls you will add, it won't bring much value to your. InfosecTrain Trainer: particular risk reduction, the residual risk will remain same. So that's why this particular point you have to understand, right? You have to invest only that much which is necessary. It's not like that that some vendor is giving you the presentation and showing you some sophisticated good solution. You keep deploying because you have budget and new solutions to environment because you have to maintain the solutions. You have to optimize those solutions, right? Just by. InfosecTrain Trainer: Deploying the solution is not the thing. InfosecTrain Trainer: Now, risk termination or risk avoid. When to consider risk termination option? When the risk exceeds the acceptable threshold. Something which is beyond your acceptable threshold, you will terminate. Like, suppose your monthly salary is \$10,000. InfosecTrain Trainer: Your monthly salary is \$10,000, and if there is an investment opportunity for, \$5,000, you won't do that. InfosecTrain Trainer: So, if there is an investment of \$28,000, you won't just put your entire monthly salary into that investment, because if something goes bad, you will lose your all money. So, that's why you have to understand that acceptable threshold level. If something is beyond that, you will terminate, you will avoid taking that risk. When the business value doesn't justify exposure, if. InfosecTrain Trainer: You are not getting any business value. InfosecTrain Trainer: By doing that exposure, you will terminate. Like, for example, you know that there is a war going on between the Iran and the Israel, right, and the America.

There are so many restrictions which have been put across on the Iran. Tomorrow, you get a business opportunity from Iran. Will you go ahead and take it? I think you will not, because you know that the consequences and the impact is much more than the value which I'll get. So, I will. InfosecTrain Trainer: Not go ahead with that. And if there is no control available to mitigate it, that also you will accept like zero day vulnerability. You know that there is no patch available. What you can do, you have to accept the risk. Probably you can create some compensating control or something you can do, but you cannot do anything beyond that. And sometimes if the regulatory constraint prohibit. InfosecTrain Trainer: you from doing something, that time also you have to terminate or avoid taking that. Like the financial constraint, US has put across a lot of financial constraint, right, for a couple of countries. So if you start doing the business, you have to incur that huge amount of tariff from them. So you will not take those decisions. InfosecTrain Trainer: And what are the implementation approaches? The activities might... sometimes you have to modify the existing processes, you need to re-engineer to eliminate the risk entirely. InfosecTrain Trainer: Sometimes you have to discontinue a product line of service. You would have seen, right, the, the, when, when the, like, like Microsoft versions, what Microsoft do when they say the previous version has a lot of vulnerabilities, it is not, it's not that effective what they say, okay, the Windows previous version is not decommissioned, we are introducing the new version. InfosecTrain Trainer: And sometimes, even after termination, the liability may remain as long as the previously delivered product or services are being used.

So you will see, they'll say, okay, in next 2 years, we will decommission this particular product, we will provide you the patches and relevant support till this time, but after that. InfosecTrain Trainer: Sorry, yeah. So let's take an example. Let's say you have one particular application, right? So every, sorry, every two hours you take a backup. So you took a backup at. InfosecTrain Trainer: backup you took at 11:00 a.m, then next backup would be 1:00 p.m, then 3:00 p.m, and so on. So, this every two hours you are taking a backup, this is a RPO. InfosecTrain Trainer: a data backup frequency which is there in your organization. So anything which is below this is you are ready to accept because below 2 hours, if any risk occurs, so the backup, if some incident happens between 9am and 11am, you know that the data would be lost. You only have the previous. InfosecTrain Trainer: checkpoint which is the 9am where you will be able to recover right so this becomes the RPO of the application now next thing comes as the RTO so what is the RTO suppose there was a issue which happened and then there was an incident which happened. InfosecTrain Trainer: around there was an incident which happened around 12:30 p.m. There was a data there was an attack or something which happened disruption happens and you lost the system now which is the backup which you will use to require at this time. InfosecTrain Trainer: 11 AM. 11 AM. So you took a 11. InfosecTrain Trainer: 12:30 PM, you have to restore and give it back to the operation, right? So you, suppose, have a 1-hour RTO. So 12:30 PM, the issue happened, you took this backup, you... InfosecTrain Trainer: You checked everything, you deployed the backup and then 1:30 PM you gave business back system to the normal for the operations.

So this becomes a RTO. Clear everyone, RTO and RPO, what is the difference? So RTO is something the amount of time allowed to recover to an. InfosecTrain Trainer: acceptable level of normal operations following a disruption. If tomorrow there is a disruption, there is an activity which has caused issue, how much time you will require to recover from that point onwards? And what is the determining factor for this? It depends on the time sensitivity of the information, how sensitivity data is. InfosecTrain Trainer: discussed like how important the Amazon normal business is with respect to their pharmacy business because their normal business need to be recovered first because pharmacy is probably generating very less amount of revenue for them. Also the interdependencies among systems. Sometimes there are couple of systems which are integrated with each other so if you don't recover those integrated systems probably. InfosecTrain Trainer: The next system won't. InfosecTrain Trainer: Sometimes the same database probably is being used for other systems as well. Then regulatory requirement, also available recovery options and what is the cost which is involved. So the multiple perspectives you. InfosecTrain Trainer: have to consider both the user requirement and the senior management priorities whenever you are establishing the RTO. Got it. So you must have a clear understanding around the RTO and the RPO because when you see this in the exam, if you see the keyword like the backup and all, always it is going to be the backup data or something. It's always going to be the. InfosecTrain Trainer: RPO they're talking about. Now, understanding the RPO, I've already explained this. So, the maximum acceptable data loss, this is the RPO. This is the definition of RPO, right?

RPO is equal to data. Anywhere you see the data, it will. InfosecTrain Trainer: RPO measures the data loss, not system recovery time. Keep this in mind so that don't get confused between the RPO and the RTO. So the last backup was taken at what time when the incident took place? Then you have that last backup to recover back to the normal. InfosecTrain Trainer: to restore that becomes RT. Clear. Now there is one more term which is called a service delivery objective. A lot of people get confused. So when you are operating in a recovery scenario, right, you won't be able to provide them the 100% everything. Suppose in your organization. InfosecTrain Trainer: attack, everything goes down, which all system you will recover first? You will always recover those systems which brings or generate the maximum amount of revenue, right? Which are the business critical, which generates the revenue, which are more important, without which organization will function cease to exist. So those minimum level of services which you will restore first becomes the STO. Minimum acceptable service level. InfosecTrain Trainer: So if tomorrow there is an issue, you will first recover those business-critical applications, rest everything, like your HR portal, your internal grievance portal, or some other kind of the internal communication portal. InfosecTrain Trainer: and all those may get recovered last, because without them also you will, you will continue to operate, right? So as soon as the disaster occurs, that minimum level of services which you will be restoring first becomes the STU. After that, then slowly you will continue to recover, rest, everything, and 100%. InfosecTrain Trainer: You will give it to the normal, right? STO means something related to the recovered services, right?

It is not the overall application that I have in the organization. So if I have an application which I am restoring in the disaster site, so while after the restoration, because of the. InfosecTrain Trainer: data loss or because of some kind of in connectivity to integration, I may have to, I may not be able to restore some features. So without that feature, like what minimum system I can restore is SDO, right? Correct. SDO is referred to the minimum bare minimum what the organization will like here. InfosecTrain Trainer: you will only be able to take the 500 orders. So that 500 orders becomes the SDO. Got Srinivasan? Okay. Now, this particular framework, right, you want, you can take a screenshot of this, this is very important, which this. InfosecTrain Trainer: SDO, is it determined by the senior management? I mean, would they be defining the acceptable level? That the business owner will define. Everything, how the senior management, will get involved. The business knows that what is the most important, they will. SrinivasanJ: RPO is data loss, how much data I can afford to lose, and RTO is the time to recover the service. InfosecTrain Trainer: Correct. Let me... let me explain this with an example. So... InfosecTrain Trainer: Just give me a minute. InfosecTrain Trainer: Sorry, yeah. So, let's take an example. Let's say you have one particular application, right? So, every two hours you take a backup. So, you took a backup at 9:00 AM, next backup you took at 11:00 AM, then next backup would be 1:00 PM. InfosecTrain Trainer: then 3 PM, and so on. So this, every 2 hours you are taking a backup, this is the RPO. InfosecTrain Trainer: a data backup frequency, which is there in your organization.

So, anything which is below this, you are ready to accept, because below 2 hours, if any risk occurs, so the backup, if some incident happens between 9am and 11am, you know that the data would be lost. You only have the previous checkpoint, which is the 9am, where you will be able to recover, right?

InfosecTrain Trainer: So, this becomes the RPO of the application. Now, next thing comes as the RTO. So, what is the RTO? Suppose there was an issue which happened and then there was an incident which happened around. InfosecTrain Trainer: 30 PM. There was a data... there was an attack or something which happened, disruption happens, and you lost the system. Now, which is the backup which you will use to record at this time? SrinivasanJ: 11 AM.

InfosecTrain Trainer: 11 a.m. So, you took a 11 a.m. backup. Now, the RTO comes into the picture. Now, from 12:30 p.m, you have to restore and give it back to the operation, right? So, you suppose have a one-hour RTO. So, 12:30 p.m, the issue happened. You took this backup, you checked everything, you deployed the backup, and then one. InfosecTrain Trainer: 30 PM, you gave business back system to the normal for the operations, so this becomes a RTO. Clear, everyone? RTO and RPO, what is the difference? InfosecTrain Trainer: So, RTO is something the amount of time allowed to recover to an acceptable level of normal operations following a disruption. If tomorrow there is a disruption, there is an activity which has caused issue, how much time you will require to recover from that point onwards? And what is the determining factor for this? InfosecTrain Trainer: It depends on the time sensitivity of the information, how sensitivity data is, right?

We discussed, like, how important the Amazon normal business is with respect to their pharmacy business. Because their normal business need to be recovered first, because pharmacy is probably generating very less amount of revenue for them. Also, the interdependencies among systems. InfosecTrain Trainer: Sometimes there are a couple of systems which are integrated with each other. So, if you don't recover those integrated systems, probably the next system won't also come online, like your databases. Sometimes the same database probably is being used for other systems as well. InfosecTrain Trainer: Then regulatory requirement, also available recovery options and what is the cost which is involved. So the multiple perspectives you have to consider, both the user requirement and the senior management priorities whenever you are establishing the RTO. Got it. So you must have a clear understanding around the RTO and the RPO because when you see this in the exam. InfosecTrain Trainer: if you see the keyword, like, the backup and all, always it is going to be the backup data or something, it's always going to be the RPO they're talking about. InfosecTrain Trainer: Now, understanding the RPO, I've already explained this. The maximum acceptable data loss, this is the RPO. This is the definition of RPO. RPO is equal to data. Anywhere you see the data, it will be RPO. RPO measures the data loss, not system recovery time. InfosecTrain Trainer: Keep this in mind, so that don't get confused between the RPO and the ITO. InfosecTrain Trainer: Right? So the last backup was taken at what time when the incident took place? Then you have that last backup to recover back to the normal. From that point of time onwards, that how much time you will require to restore, that becomes RT. Clear?

InfosecTrain Trainer: Now, there is one more term which is called the service delivery objective. A lot of people get confused. So, when you are operating in a recovery scenario, you won't be able to provide them the 100% everything. InfosecTrain Trainer: Suppose in your organization there is a big ransomware attack, everything goes down, which all system you will recover first? You will always recover those systems which brings or generate the maximum amount of revenue, which are the business critical, which generates the revenue, which are more important, without which organization will function cease to exist. InfosecTrain Trainer: those minimum level of services which you will restore first becomes the STO. Minimum Acceptable Service Level After Recovery. InfosecTrain Trainer: So, if tomorrow there is an issue, you will first recover those business-critical applications, rest everything like your HR portal, your internal grievance portal, or some other kind of the internal communication portals, and all those may get recovered last. Because without them, also, you will continue to operate, right? So, as soon as the disaster occurs, that minimum level of services which you will be restoring first becomes the STO. InfosecTrain Trainer: After that, then slowly you will continue to recover, rest, everything, and 100% you will. InfosecTrain Trainer: Give it to the normal, right? SrinivasanJ: Lately. InfosecTrain Trainer: Yeah, absolutely. SrinivasanJ: STO means something related to the recovered services, right? It is not the overall application that I have in the organization. So if I have an application which I am restoring in the disaster site, so while after the restoration, because of the data loss or because of some connectivity to integration, I may have to.

SrinivasanJ: I may not be able to restore some features. So, without that feature, like, what minimum system I can restore is SDO, right? InfosecTrain Trainer: Correct. SGO is referred to the minimum, bare minimum, what the organization will... like here, the example is given, right? So, normally, you take a thousand order per day, but after the disaster, you will only be able to take the 500 orders. So, that 500 orders becomes the SGO. Got Srinivasan? InfosecTrain Trainer: Now, this particular framework, right, you want, you can take a screenshot of this, this is very important, which this kind of summarizes all the key matrices with respect to the recovery. Yes, Shweta? Shweta Sundar: So the SDO, is it determined by the senior management? I mean, would they be defining the acceptable level? InfosecTrain Trainer: That the business owner will define. Everything, how the senior management will get involved. The business knows that what is the most important, they will say that this is the minimum what we want in case of disaster. Shweta Sundar: Okay, thank you. InfosecTrain Trainer: Yeah. InfosecTrain Trainer: So RPO is something which is actually there before the incidents. You are doing the backup. Every two hours you are doing the backup. Now there is an incident happens at some point of time. As soon as the incident took place, the RTO will take place. So first you will recover the. InfosecTrain Trainer: the processes, right, critical processes, then you will recover the critical system and technicals. Once you have that, you will restore the minimum level of services which are required for organization to operate, right? Once that is achieved, then you will recover the complete business MTD, maximum tolerable downtime.

InfosecTrain Trainer: After the SDO is done at least the business continue to function. If you go beyond this point the business will suffer some business loss but you cannot go beyond MTO. MTO is survival because if you go beyond this time to recover then the organization will suffer a very huge loss probably 20% of your annual revenue would be gone if you go beyond this. So MTO is something which. InfosecTrain Trainer: which is equivalent to the risk capacity. This is equivalent to risk tolerance. subaveena pugalethi: What is P-T-O-R-T-O-S-D-O? InfosecTrain Trainer: As you, we just discussed, right? Service delivery objective. subaveena pugalethi: RT1P2... RTO... InfosecTrain Trainer: RTO also will discover recovery time objectives. subaveena pugalethi: YouTube? InfosecTrain Trainer: PTO is process time objective, process time objective. However, this is not there in the ISACA syllabus, but I have just given it for the reference for you to understand. First, you will recover the processes, basic processes, basic functionality. You will start with this. InfosecTrain Trainer: Understood? subaveena pugalethi: Yeah. Okay. InfosecTrain Trainer: You people can take a screenshot of this, so that you remember how it's interrelated with each other. InfosecTrain Trainer: This is also... SrinivasanJ: Maximum tolerable outage, right? InfosecTrain Trainer: Yeah, yeah, maximum tolerable outage. SrinivasanJ: Okay. InfosecTrain Trainer: This is actually a kind of a mind map which I've created. So this will not only help you with this domain, this will also help you with the domain four, where we have a very detailed topic around this. So you can take a screenshot of this. This is a kind of a mind map which summarizes all of these things, including the definition for each of them.

InfosecTrain Trainer: where is RPO, where is, sorry, PTO is point-in-time objective. InfosecTrain Trainer: So point in time objective means the time when the incident occurs from the time when the recovery will start. So that is called the point of time objective because as soon as the incident occurs immediately you won't start the recovery. You will require some time to analyze the incident, reduce the impact, then you will start the recovery from that point of onwards. Then comes the service delivery objective, recovery time objective, maximum tolerable. InfosecTrain Trainer: disruption and the maximum tolerable outage. Also, definition for each of them, right? What is RPO, what is PTO, what is RTO, what is SGO, MTD, and MTO. Pudir: The dwell time and PTO are same. InfosecTrain Trainer: Which is? Pudir: Dwell, dwell time. InfosecTrain Trainer: Dwell time. Pudir: Mmm. InfosecTrain Trainer: What is this? Can you please explain? I've heard this. Pudir: Lost time. Pudir: dwell dwell time means in any unforeseen event will happen first identification and how much time it resides in our systems once we have identified that point the time between the actual occurrence and identification that is dwell time. InfosecTrain Trainer: Okay, I've actually heard this. Pudir: Okay, okay, please leave. InfosecTrain Trainer: Because dwell time, actually, I have, heard dwell time in a different perspective. Dwell time is basically, generally, I've heard from the web application perspective. Pudir: Yeah, yeah. InfosecTrain Trainer: How much time... Pudir: That's what I. InfosecTrain Trainer: How much time... how much time person spend on one particular website and all, right? Pudir: Oh, no, no, no. Walk us a little. InfosecTrain Trainer: Yeah, so that's what I've heard dwell time, right?

Once person logs into your website, till the time he stays in your website and in exit, that is called the dwell time. subaveena pugalethi: What is the difference between MTD and MTO? InfosecTrain Trainer: So MTD, so in this slide also I explained, right? So MTD is actually at the business levels. So in your organization, you will have five, six, seven, eight line of businesses, right? So MTD, like MTD is equivalent to your risk tolerance or risk appetite. So risk appetite and risk tolerance is always defined at the project or the business level. InfosecTrain Trainer: And the risk capacity is at overall organizational level. So, when you are recovering, you have a 10 line of businesses. For each line of business, you will... they will maintain some MTD, but overall, on an average, they will make sure they should not exceed this particular criteria. InfosecTrain Trainer: Yes, Pudir, I think he shared dwell time. I think same is a reference to

the website. So, in the website, the. InfosecTrain Trainer: Dwell time is this, how much time the person stays on your website, and then it locks up. Pudir: Listens. InfosecTrain Trainer: Yeah. Got, got, got it, Good, MTD, MTD. InfosecTrain Trainer: Your difference is clear. subaveena pugalenthi: So, it is at business unit level for MTD, and MTO is for enterprise. InfosecTrain Trainer: Oregon, enterprise level, correct. InfosecTrain Trainer: Let's discuss some questions. Yeah. InfosecTrain Trainer: Alright, let's discuss... InfosecTrain Trainer: Yeah, couple of you got couple of correct, few of you got few incorrect. Okay, which of the following is the first action to be taken when the information security manager notes that the control for the critical application are inadequate? First means talking about the sequence. Simple, right?

Perform a risk assessment to determine the level of exposure. Okay, looks a good option. InfosecTrain Trainer: Classify the risk as acceptable to senior management. Can you do B without doing A? Eliminated. Deploy additional countermeasure immediately. That also you will do after doing a risk assessment. Eliminated. Transfer the remaining risks to another enterprise. That also you will take that decision after doing A. So, eliminated. So, correct option here is A. InfosecTrain Trainer: Which of the following is key for selecting a third-party information security provider? Contractual review, always go with the option which includes all other options. InfosecTrain Trainer: And I'll tell... I'll explain you how option D includes all. Option D is talking about the risk assessment, right? So, as part of the risk assessment, what you do, you will also assess their contracts, you will also review their audit reports, you will also assess their cost of services, right? InfosecTrain Trainer: All of these things you will review as part of D, right? Whenever you do risk assessment, you do check all of these things, right? So, option D is an umbrella answer, which includes all other options. So, this is the correct answer. InfosecTrain Trainer: A high impact, medium likelihood risk is identified. It's talking about high impact and medium likelihood, right? Exceeding the organization's risk tolerance, mitigation costs are high but feasible. Senior management is hesitant due to immediate budget constraint. They don't have a budget at this point of time. What does CISO's best action to align with risk appetite considering the risk response process?

InfosecTrain Trainer: So, they are saying senior management cannot provide you complete budget at this point of time, but you have to mitigate. Accept the risk as the cost outweighs the immediate benefit. Yeah, looks option. Propose the phased mitigation strategy to gradually reduce risk over time distributing cost. B is better than A. InfosecTrain Trainer: Transfer the risk entirely by purchasing the comprehensive cyber insurance. As such, you don't have a money how you can transfer it to someone else. That will also require some budget, right? Avoid the risk. Madhes: In this option, B is... See, senior management is not having the budget, no? InfosecTrain Trainer: What? Madhes: Senior management is not having the budget. InfosecTrain Trainer: Where it is saying it is not having visits. Madhes: to immediate. InfosecTrain Trainer: Immediate budget constraint, right? It's not saying that they don't have a budget at all. Currently, they don't have, right? In future, they will be able to provide. That's what it's saying, right? There's an immediate budget constraint. Madhes: See, immediate is okay, but immediate is... okay, this is... it's not available this year. So it is going to be next year, right? InfosecTrain Trainer: So that's what option B is saying, right? Propose a phased mitigation strategy to gradually reduce risk over time distributing cost. InfosecTrain Trainer: We're distributing cost. Madhes: Risk assessment happens on the periodic manner. For this year, I am accepting the risk because the cost outweighs the immediate benefit. Next year, I will initiate a risk assessment, then I will see that whether I'll get the budget or not.

InfosecTrain Trainer: on with the option A, but I would go with the option, if, if option B would not have been there, then the next best option was A. But I have option B here. Let's see, take an example. Let's say, let's say that you have to deploy a DLP in this, in the organization to, do the, there was a recent data breach. There is no DLP in your organization, right? InfosecTrain Trainer: But you have to purchase the complete DLP solution, which will cost you some \$200,000 as a licensing cost, then some training cost, and some other things which you have to... you have to do. Will you immediately go ahead and say that we'll not deploy DLP till next year because I don't have a \$200,000 at this point of time? Madhes: See, I got a point. See, my question is, you know, I understood the question. I understood the second answer also. The question is, you know, it's about that particular. Obviously, the risk assessment is on yearly basis, right? Not like, you know, three years. InfosecTrain Trainer: No, no, who said the yearly basis you do risk assessment? Risk assessment is a continuous process. Madhes: Oh, for this particular risk, whatever we assessed, okay, see, this is... InfosecTrain Trainer: But where in the question, it is saying that this risk was done on the yearly basis. It's just, that's what I'm saying. You just read the scenario. Let me, let me read the question once again and highlight what are the important aspects which you have to choose. That's what you have to do in the exam also, right? However, in the exam, you won't get such a lengthy questions, probably one or two questions. I'm discussing this during training so that you understand the, you develop that reading habit to understand what are the key. InfosecTrain Trainer: things in the question.

It's saying a high impact medium likelihood risk is identified exceeding organization risk tolerance. It's as such beyond your tolerance limit, right? That's what it is saying. So if something which is beyond tolerance limit, what you do, you have to reduce it to your acceptable level, right? So reducing the acceptable level, you will go with the mitigate. Mitigation costs are high but feasible. Madhes: Yeah, see, I got it. I was confused with this budget. See, budget is always in the yearly budget, not like, you know, okay, half-yearly budget also comes. But usually the budget, annual budget, based on the annual cybersecurity program, everything, generally we decide. InfosecTrain Trainer: Again, again, you are getting into the same trap. I told you, never ever go what you're. Madhes: I know, I know, that's. InfosecTrain Trainer: Annual budget, half yearly budget, quarterly budget, don't. Madhes: And descendant. InfosecTrain Trainer: Whatever the question is saying, you just go by that. If you go by that, you will end up getting most of the option correct. If you go with that scenario, where you start comparing what is happening in my organization, or what is happening in your previous organization, you will end up getting question incorrect. So that's what I'm saying, you have to take out everything from your mind, just go with the concept, what the question is saying, just read that, read the option, and choose a correct answer, that's it. InfosecTrain Trainer: If you start following this approach, I'm saying, telling you 90% of questions, you will get it correct. Madhes: I understand that the question is actually, still I'm having the doubt, I'll verify, but still I'm having the doubt on this one. I'll check it, because even... SrinivasanJ: Sorry, Mahdih.

See, the first answer is based on the cost control and benefit analysis, right? If my solution outweighs the immediate benefit, so if it... then I will immediately reject it. I will not consider budget. SrinivasanJ: If my solution is expensive than my benefit, then I will reject it. Why will I consider budget there? InfosecTrain Trainer: Yes, so that's correct. And also, if you read this statement, mitigation costs are high but feasible, it says, right? The mitigation cost is high, but it is feasible, you can do it, right? So question itself is telling you that option B is correct. If you read the question properly, and in the exam also, if you read line by line, you will easily be able to understand that which is the correct answer. You have to follow this approach in the exam also, right? InfosecTrain Trainer: Now, next, last question. So, it's good that we are discussing. That's how you will develop that particular mindset. That mindset, getting into that mindset is very much important. Otherwise, in the exam, I have seen the previously people, those who are getting, I'm telling you, those who are getting 80% in all the. InfosecTrain Trainer: all the these assessment questionnaire they were getting 75 to 80% but on the main exam they failed why they failed when I asked them I asked them will you follow the elimination technique they said no because they were overconfident as soon as they read the question they thought okay I know the answer this is the correct answer they went ahead with that I'm telling you. InfosecTrain Trainer: Develop the habit of this elimination technique. If you develop this habit, I'm telling you 100% you will pass.

Even if you don't even have a good understanding around the topics, you will easily be able to understand which is the correct answer. Start following this elimination technique. You will clear this also. You will clear CISSP also. InfosecTrain Trainer: I'm telling you, you can prepare for CISSP, write it after a few months, you will clear CISSP also. You have to just understand the concept if you develop this particular elimination technique method. So please start practicing this elimination technique. That's what I'm saying. InfosecTrain Trainer: Practice the questions when you go back and start following this elimination technique. Next question. A new cloud service introduces a data leakage risk. The head of sales utilizes this service for customer data while the cloud security engineer configure its security setting. Who is the primary risk owner? Who is the primary control owner here? So control owner is always someone who is actually the senior leadership person. So head of sales is a. InfosecTrain Trainer: Risk, is a risk owner, and the control owner becomes a cloud engineer. InfosecTrain Trainer: N. Shweta Sundar: Yeah, I have a question over here. So I'm the QA manual that you shared. Is there a better copy of it, you know, which is more text oriented? Because this one is image and having the answer. InfosecTrain Trainer: That, that, that you won't get, because the QA manual, as such, as such, let's wait. InfosecTrain Trainer: Let me...

Day 5: Full Cleaned Transcript

Approximate source length: 31,363 words.

InfosecTrain Trainer: Good evening, everyone. InfosecTrain Trainer: Any doubts from yesterday's session? InfosecTrain Trainer: Any doubts from the Domain 1 or Domain 2? Because we are about to conclude the Domain 2 today. InfosecTrain Trainer: And we'll start the domain 3. So, any doubts? InfosecTrain Trainer: So, anyone completed the Domain 1 questions? Sandeep Saxena: Not completed, started. Sandeep Saxena: We are not having a session next week, so by the next session, before that, we'll be completing the... InfosecTrain Trainer: Yeah, yeah, yeah, please, please try to complete both the domain, Domain 1 and Domain 2, right? So that... yeah, and then also, if you... you are getting time, you can start with the domain 3 as well. So, Domain 3 is a bigger domain, with the more number of questions, so I would recommend to start with that as well. InfosecTrain Trainer: We will complete almost 40-50% of Domain 3 today, so... so at least two people can start with that as well. Sandeep Saxena: Sure. Sandeep Saxena: The deck you use for the training, is that uploaded somewhere? I know training recordings are there, but the presentation, the deck. InfosecTrain Trainer: No, no, this deck is actually my personal deck, which I used as a reference to teach you all. So this deck I won't be sharing, but yeah, other materials are already available. Sandeep Saxena: Okay. InfosecTrain Trainer: So, any slide where you feel it's important for you people to, you can take a screenshot. Sandeep Saxena: Okay. InfosecTrain Trainer: And also, if you want, I can upload a couple of important, like this slide yesterday, which we discussed. InfosecTrain Trainer: Let me... InfosecTrain Trainer: Copy... important slides.

InfosecTrain Trainer: So that you people can... yesterday we discussed that RTORPO mind map, so let me just... InfosecTrain Trainer: Share it with you all there. InfosecTrain Trainer: So, I have shared this mind map with you all. InfosecTrain Trainer: You all can just... Use it to remember all the important recovery-related, InfosecTrain Trainer: objectives and the mattresses, right? RPO, RTO, SDO, MTD, MTO, and all. Sandeep Saxena: Thank you. Sandeep Saxena: Thanks. InfosecTrain Trainer: So yesterday, we stopped here. InfosecTrain Trainer: We were discussing about the recovery-related mattresses and how that InfosecTrain Trainer: That is an important thing, right? However, we will again discuss about the BCP DRP, how to build a BCP plan, how to build DRP plan. That's a separate topic altogether in Domain 4 as well, because as part of the incident management, recovery becomes an important part, so there they have a specific topic around it. InfosecTrain Trainer: So, yeah. But this is a very important topic. So, understanding around RTO, RPO, and all those things is very important. InfosecTrain Trainer: So, let's start with the... InfosecTrain Trainer: the last topic in this domain, which is building a program, right? So the risk management in... InfosecTrain Trainer: organization, right, is... it does not happen in CLO. All the organizations should have a proper risk management program driven by enterprise risk management function. InfosecTrain Trainer: So, not cybersecurity. Cybersecurity is part of it. Enterprise risk management functions should be established in the organization, and they will drive the risk management program. So, in few of the organizations, they even have the role called the CRO.

InfosecTrain Trainer: Chief Risk Officer, how many of you have that role in your organization? Chief Risk Officer? InfosecTrain Trainer: Or some organization may have a chief compliance officer also. If they don't have a chief risk officer, probably this role might be handling both the things. Risk and compliance. InfosecTrain Trainer: So if someone would have worked in a bank's, any banks, be it the US-based bank, be it the European banks, right, you will always see a role specifically called the Chief Risk Officer, and they have a big InfosecTrain Trainer: vertical, almost equal to the size of, cyber, even more than that. InfosecTrain Trainer: a risk function. InfosecTrain Trainer: So, risk function is, as I told you, right, risk is not only limited to cyber, so you have all the kind of risk, right? Cyber... InfosecTrain Trainer: finance... Operations. InfosecTrain Trainer: business. InfosecTrain Trainer: Compliance, all the kind of risks InfosecTrain Trainer: go and gets merged in an enterprise risk register, right? So how you establish this overall risk management program in the organization, right? First, you have to build a purpose and outcome, what you exactly want to achieve out of ERM function. InfosecTrain Trainer: Right? InfosecTrain Trainer: So, every organization may have a different outcome altogether, which should come out of it. Like, banks. InfosecTrain Trainer: They are the most regulated industry in the world, right? Bank has so many guidelines, processes, so not only those InfosecTrain Trainer: global guidelines. They have to even follow a lot of local regulatory guidelines. Like, in India, all the banks are governed by RBI. InfosecTrain Trainer: They have to follow all their RBI guidelines.

Then, if they are trading, they are dealing with their stock, shares, and all, they need to also InfosecTrain Trainer: follow the SEBI guidelines. So, likewise, in the Europe, they have an ECB. InfosecTrain Trainer: European Commission on Bank, which is equivalent to RBI. InfosecTrain Trainer: So, every country has similar kind of guidelines which they have to follow, right? So, as per that, they have to first understand what is the purpose and outcome they want to achieve out of risk. InfosecTrain Trainer: What are the regulations they want to comply with? How they will drive the risk management function altogether, then they will set up a scope. InfosecTrain Trainer: So, how many different, different risk vertical which we are supposed to create? InfosecTrain Trainer: from an organization, which all vertical are very important functions, which we need to consider as an enterprise risk management, risk register, right? So that, you have to create, and then create a charter and authority. InfosecTrain Trainer: you have to authorize or create one central person who is going to be leading that effort for the complete organization, right? Like I said, the chief risk officer, it can be chief compliance officer, anyone who is directed or probably in your organization who is dealing with that, that guy will handle this. InfosecTrain Trainer: Then, after this, then you have to identify and classify the assets. InfosecTrain Trainer: Because... InfosecTrain Trainer: Then, once the scoping is done, then you have to establish the risk management in the organization. So, first, you need to identify and classify which are the important business functions, how many of them are the most critical in nature, right? And then you have to create an approach.

So, you can create a risk management policy InfosecTrain Trainer: Right? Because you have to set an approach, which particular method you will follow. You will use the qualitative, you will use quantitative, how you are going to... assessing the risk, what is going to be the framework which you will use to create the... to generate the risk register, what is the risk register template which you will follow. InfosecTrain Trainer: Do you have any technical tool, like any GRC platform where your risk register is maintained? So, all those things, methodology you have to set. InfosecTrain Trainer: So, one more thing is very important to understand from an exam perspective, right? You have to always understand before assessing. Without understanding, without understanding the context and scope. InfosecTrain Trainer: You cannot assess anything, so keep this thing in mind. All the questions you get in exam, keep this in mind before approaching those questions. InfosecTrain Trainer: Now, you have to do a gap assessment. So, when you are establishing a risk management program, so you have to do a gap assessment of your organization to understand where we currently stand, right? InfosecTrain Trainer: So you have to set a current state. So you all... suppose you joined an organization as a consultant, they want to establish an enterprise InfosecTrain Trainer: risk management program. They... they invited you as a consultant and told you that, please establish us this particular program. InfosecTrain Trainer: So, first, you will understand the current state. You will say, okay, how many people are maintaining the risk register, how many of them are not. InfosecTrain Trainer: Right? Do we have a separate, separate risk register, or organization is only maintaining one risk register?

All those things you will understand, then you will create a target state. So to... to create a target state, you will use, InfosecTrain Trainer: You will use all the... you can pick up any framework. InfosecTrain Trainer: Right, so there are frameworks specific to risk management, even NIST InfosecTrain Trainer: a NIST risk management framework is there. So you can pick up a framework, you can create that target stage, what you want to achieve. InfosecTrain Trainer: Then, as per that target state, you will understand and note down all the gaps which is there. When you say, okay, organization is only maintaining, the risk registers are being maintained in silos, right? We don't have any combined InfosecTrain Trainer: overall one single functions in the organization, right? Let's tell all the business function and make one person accountable who is going to maintain the risk register. You will say, okay, we will introduce the cyber risk register, we will introduce IT risk register, we will include... introduce the finance risk register, we will introduce compliance risk register. InfosecTrain Trainer: Operations risk register, likewise. InfosecTrain Trainer: So those risk registers, then you will create, you will create a methodology and framework, how many categories, how the probability will be done, how the, InfosecTrain Trainer: How you are going to calculate the likelihood and how you are going to calculate the impact. InfosecTrain Trainer: Because those... without defining those things, how the organization will assess, then you will establish the risk appetite, risk capacity, risk tolerance, all those things also need to be established, right? What is an acceptable level of risk?

InfosecTrain Trainer: Once you have that, then you will prioritize, and then you will remediate, establish the cyber risk management program in the organization. So after doing this, your... InfosecTrain Trainer: Output would be, you will have a gap register, you will understand what are the root causes of the issues, remediation roadmap, and then you will InfosecTrain Trainer: Get a residual risk. InfosecTrain Trainer: Of the complete process. InfosecTrain

Trainer: Now, when you are implementing the risk management in the organization, so the framework is something which gives you a structured approach. InfosecTrain Trainer: So, if you build... pick up any framework that will give you a structured approach that will tell you that how... which methodology you need to follow, how you are going to assess the risk, right? InfosecTrain Trainer: what is the heat map will look like for your organization? What is an acceptable level of risk? Till what level you want to reduce the risk. All those things framework will tell you, right? So it will help you build the risk management in the organization. Then you have to create a context. InfosecTrain Trainer: You have to understand what are the internal and external factors, right? For a bank, they have a different environment, right? For manufacturing industry, they have a different environment. For e-commerce. InfosecTrain Trainer: they have a different environment, right? For consultancy, it's a different environment. For software, product company, it's a different environment. So, that context, internal, external factor, you have to understand. Then you will perform a gap analysis of the current versus desired, which we just discussed.

InfosecTrain Trainer: Where you will compare, and then you will leverage all the support and the resources which are available within the organization. So, support from senior leadership, support from all the stakeholders, all the departments, all those things you will use to improve it. InfosecTrain Trainer: So this is how you establish the risk management program in the organization. InfosecTrain Trainer: Now, reporting is a very important part. Like you do, you have a KPIs KRI is... InfosecTrain Trainer: So, in my organization, we have a risk management committee, We meet every quarter. InfosecTrain Trainer: we meet every quarterly, right? I'm not sure what is the frequency. It can differ from organization to organization. Apart from that, monthly, I... every risk owner is supposed to do a risk register review on monthly basis with their respective functional edits. Like, for the cyber, the functionalate is CISO. IT, it's CIO. InfosecTrain Trainer: For, operation, it's going to be COO. For compliance, it's going to be chief compliance officer. So, with them, the one, the respective person who is handling the risk register, they will have that meeting. InfosecTrain Trainer: They will create, understand, are there any changes in the current risk level? What is the efficiency or efficacy of the controls? Are there any new threat intel report which we received, right? InfosecTrain Trainer: All those things you will check, and then you have to continuously report and monitor all the risks. InfosecTrain Trainer: So, so, so, because the thing keeps changing, right? Like, in the organization, you saw there has been two data breach incidents which got, which reported recently, but however, your tech stack was able to, detect and mitigate the impact.

InfosecTrain Trainer: So what... which particular risk it will increase? If there was a risk, but it got detected and, InfosecTrain Trainer: Mitigated. Which particular risk, inherent or residual, which risk rating you will increase in your risk register? InfosecTrain Trainer: Anyone? InfosecTrain Trainer: Which risk rating you will increase, because... InfosecTrain Trainer: there was two data breaches detected recently. During the review, you are doing the review with CISO, you want to propose him, let's increase inherent or residual. SrinivasanJ: Inherit. InfosecTrain Trainer: Correct. InfosecTrain Trainer: Because, as I told you, right. InfosecTrain Trainer: These data breaches did not have any impact on the organization. It was detected by your control. It means your control remains effective, but the inherent is increased because now you have seen the probability of occurrence of these data breaches has increased. InfosecTrain Trainer: So you will increase the probability. However, impact and all will remain same. So that's how you do the analysis. InfosecTrain Trainer: Also, you need to indicate the enterprise is subject to risk exceeding defining risk level. So, any risk which is going beyond. So, if you saw InfosecTrain Trainer: True positive incident, and it was an impact. InfosecTrain Trainer: So now, probably earlier, your... InfosecTrain Trainer: Risk rating was kept at the moderate, but now it will go to the high levels. InfosecTrain Trainer: Now, it has gone to high, it means it's beyond your appetite level, right? Your organization say, keep all the risk within moderate level. Now, it's gone to high, it's necessary for you to make sure that you bring new tech stack, you review your existing controls, and again, reduce the risk to an acceptable level.

InfosecTrain Trainer: Also, it needs to be customized as per the enterprise. InfosecTrain Trainer: you need to also create and select the mattresses based on the internal and external environment, right? How many risks are at the high level, how many of them are moderate level, what was the changes which was done, and then you need to include all the enterprise stakeholder and identify needs. So, risk is something which is monitored till the CEO level. InfosecTrain Trainer: It's not only the responsibility of the enterprise risk management team, because risk is something which will impact them, right? InfosecTrain Trainer: Not only cyber, other risks. InfosecTrain Trainer: You recently saw there was a war which is happening, due to which there are changes in the InfosecTrain Trainer: it actually did a lot of changes into the environment, right? There was a tariff going on, then product costs have gone increased, the share markets are going up and down. You imagine the kind of pressure all the organizations currently have. InfosecTrain Trainer: Now, AI is also causing a lot of disruption, so... InfosecTrain Trainer: All these things you have to consider and understand, and then take into account before reporting. InfosecTrain Trainer: So, you have to follow this approach. You have to first monitor InfosecTrain Trainer: So monitoring can be done manually, you can create a Power BI dashboard, you can use any brainstorming sessions and all to monitor, to understand the environment, right? InfosecTrain Trainer: Then you will measure with respect to KPIs and KRIs, then you will create and publish a report, and then you will respond to those gaps, right? InfosecTrain Trainer: So, the key risk indicators are something which is... you will report from all the risk, right?

InfosecTrain Trainer: So, key risk indicators. So, major difference between, we discussed earlier also, KPI and KRI is that KRI is something which predicts the future risks. InfosecTrain Trainer: Not current, if something is talking about the current performance, that becomes a KPI, but something which is predicting what may happen if this thing is not being fixed, that becomes a KRI. InfosecTrain Trainer: So, KRI is something which predicts the future risk, and KPI is something which gives... tells you the past performance. InfosecTrain Trainer: Someone asked last time, right, number of people, not attended the training, how it is a KRI, how... why it is KPI, why not KRIE, because that is a past performance, already people have attended the training that they have completed. InfosecTrain Trainer: It's not telling... giving you any future risk. InfosecTrain Trainer: Then... Once you do all these exercises, sometimes you need to alter your baseline. InfosecTrain Trainer: Let's take a very simple example. You know currently the quantum InfosecTrain Trainer: Cryptography is actually... it's under the research. InfosecTrain Trainer: And the analysts and all the researchers are saying that by probably 2030, InfosecTrain Trainer: You need to update and change all the cryptographic algorithms. InfosecTrain Trainer: Now, you are maintaining a baseline, you are maintaining TLS 1.3, you are having some other cryptographic algorithms which are in place in the organization. Now. InfosecTrain Trainer: Once this risk occurs, Your baseline width gets changed. InfosecTrain Trainer: like... earlier, in the MFA, OTP-based authentication used to be considered very strong. InfosecTrain Trainer: Now, it's no more considered as strong, right?

Because it can be easily mimicked, and people can fetch the OTP. Now, organizations are moving from OTP to the passwordless InfosecTrain Trainer: Authenticator app. InfosecTrain Trainer: Because to... InfosecTrain Trainer: to actually do an attack, person need to have your mobile physically, he should first authenticate, log in into that app, and that code also continuously getting rotating, it gets rotated, and it's getting changed, right? So now your existing baseline is altered. InfosecTrain Trainer: That's how the happening of a risk actually alter your existing baseline. InfosecTrain Trainer: So you need to first identify what is a trigger event. Is it due to a threat, vulnerability, or any reassessment which was done? Then you will evaluate the impact, what kind of impact that particular thing is doing. Even some compliance and regulatory InfosecTrain Trainer: Issues may also ha- tend... they also let you change or alter the baseline. InfosecTrain Trainer: So earlier, you were reporting the incidents in 72 hours, now there is a regulatory change, they say you do it in 24 hours, so you have to update the baseline. InfosecTrain Trainer: Right? Then you have to adjust the control, and then document the changes. InfosecTrain Trainer: So, as part of the security risk assessment, sometimes you have to change your existing baseline to reflect those changes. InfosecTrain Trainer: Now, it's very important, you should also establish one awareness program. Like, you have an information security awareness program. Similar to that, you must also create one risk awareness program. InfosecTrain Trainer: Because the risk will... InfosecTrain Trainer: be identified by any person, right?

It's not necessarily the person who is creating risk register and maintaining risk register, only he is the only one who is InfosecTrain Trainer: responsible and accountable for doing the risk assessment. It can be anyone can do it. Probably some SOC person, some network lead, anyone can raise any issues. InfosecTrain Trainer: And once that issue is raised, so they will raise first issue. InfosecTrain Trainer: they identify a gap in the process, they identify some problem. Now, with that issue, after analyzing the issue, you understood that it will have some future impact. You need to create a risk. InfosecTrain Trainer: According to that. So, person should be aware about the risk awareness, otherwise how they are going to be reporting, raising the issues, right? InfosecTrain Trainer: So then you have to create a separate program where you need to ensure the business leader recognizes risk, implication, and decision. Whenever they are taking any decisions, right, they are probably going with the new vendor, they are probably onboarding some person, or they are taking any business decision, any financial decision, they have to follow the risk InfosecTrain Trainer: management approach. InfosecTrain Trainer: Then you have to create a formal risk awareness program, and build the acceptable risk threshold, which you have to make them understand, and you have to promote a consistent risk evaluation, so that consistently the risks are being evaluated, and informed risk-based decisions are being taken. Who has the target audience? You will create the program for the executive leadership, business unit leader. InfosecTrain Trainer: Product service owners, project manager, risk committee members.

InfosecTrain Trainer: the people who are decision makers and risk acceptance authority all must be aware about it, and then you will communicate. You can arrange a formal meeting or workshop, you can create a risk-to-age dashboard, you can create the case study-based thing, so you can follow any of the approach to create the risk awareness program. InfosecTrain Trainer: So, now, coming to the enterprise risk management, right? So, enterprise risk management is very important, which we have already discussed, right? InfosecTrain Trainer: should be there in all the organizations. So this particular slide gives you the perspective, right? You have a financial risk, you have a compliance risk, you have an operational risk, you have an information security risk, you have a strategic risk. InfosecTrain Trainer: So, information security risk is a part of the enterprise risk management you should keep in your mind, always. InfosecTrain Trainer: So you have to align your information security risk with respect to the Enterprise Risk Management Program. InfosecTrain Trainer: Now, continuous improvement cycle, so you have to continuously improve your environment, your information security program, your risk management program, right? So, continuously, you will assess, implement, monitor, and adjust. InfosecTrain Trainer: like, you would have heard about the plan, do, check, act cycle. Similarly is this. Plan, do, check, act. First, you do the planning, which we already discussed, gap assessment, establishing the framework, maintaining the risk register and all, then you will implement those gaps. InfosecTrain Trainer: Then you will check, you will keep the check on the form of the KPIs, KRIs.

InfosecTrain Trainer: And then you will act, you will fix those issues which are being identified by your current InfosecTrain Trainer: cycle, right? So this is a continuous improvement cycle to improve your risk management program. InfosecTrain Trainer: So we are done with this domain 2. InfosecTrain Trainer: Let me... Share you all, mind map for this domain. InfosecTrain Trainer: Yeah, so I have shared a mind map. InfosecTrain Trainer: Which will help you memorize or revise the topics a day before exam. So this is a mind map. InfosecTrain Trainer: It includes all the important topics, right, whatever we have discussed. InfosecTrain Trainer: risk management lifecycle and all, so this will help you to memorize it, what is iner and residual, and all those things, which are also there in this RPO, RTO, MTD, STO, you can use it to revise. InfosecTrain Trainer: Let's start the next domain. InfosecTrain Trainer: So, before we get onto this, anyone has any questions? InfosecTrain Trainer: Any questions? InfosecTrain Trainer: Alright, then get started with... we'll get started. InfosecTrain Trainer: Yeah, someone is asking, any question? Pudir: Not certainly a competitor. InfosecTrain Trainer: Okay, okay. Let's start the next domain, and this is the largest domain, right? A bigger domain, which carries a weightage of 33%, so it's a very important domain also. InfosecTrain Trainer: you will get a good number of questions. So, if you are able to get a lot of questions right from this domain, the passing InfosecTrain Trainer: Your, probability of clearing the exam gets high. InfosecTrain Trainer: So, this particular domain is divided into the two parts. One is the program development, how you develop the program, and then how you manage the information security program.

InfosecTrain Trainer: The domain carries a 33% weight, as you imagine? 50 questions you will get from this domain. InfosecTrain Trainer: Even in the practice question set also, you have close to some 260 or 270 questions from this domain. InfosecTrain Trainer: It's a huge domain. InfosecTrain Trainer: So... so please, stay focused, understand all the topics which are there in this domain, right? InfosecTrain Trainer: First is the understanding the goals. InfosecTrain Trainer: First, let me ask all of you, what do you mean by your program? InfosecTrain Trainer: What is a program? Pudir: The program is a particular activity. It has its own starting and ending. InfosecTrain Trainer: Para, is it? Or you are telling me definition of a project? Pudir: Oh, sir, I'm confused. InfosecTrain Trainer: Yeah, I think you told me the definition of a project, not a program. Pudir: gorgeous. InfosecTrain Trainer: So, project is something which has a... InfosecTrain Trainer: Actually, a definitive start and the ending date. InfosecTrain Trainer: But the program is something which is continuously, continuously running, but... InfosecTrain Trainer: Program is something which is made out of... multiple... projects. InfosecTrain Trainer: How? InfosecTrain Trainer: So every year, in your cybersecurity organization, your CISO, your business leaders, your directors, or functional heads, they might be first creating a program or the activities, what you will do in this year, right? Every one of you do that. InfosecTrain Trainer: This year, we are going to closing these many audit findings, this year we will do so many risk assessments, this year we will do... these are the activities, we will do so many threat hunting exercises in the SOC team, right? We will create 5 new playbooks.

InfosecTrain Trainer: we will improve the MTTD and MTTA. InfosecTrain Trainer: We will conduct one... InfosecTrain Trainer: red team exercise, one purple team exercise. Likewise, you create some activities which is planned for complete year, right? Those activities are what? They all are projects, small, small projects, where you will have some deliverables which you want to end of the day, deliver. InfosecTrain Trainer: So, if I talk about the information security program overall, so Information Security Program is something which consists of... InfosecTrain Trainer: So, Information Security Program... InfosecTrain Trainer: is made out of all the business activities, or all the functions which sits within the information security, right? So, in the information security program, which is led by the CISO, InfosecTrain Trainer: You have one. InfosecTrain Trainer: Cyber Defense. InfosecTrain Trainer: Under cyber defense, you can have a SOC, InfosecTrain Trainer: threat, intel... Right? InfosecTrain Trainer: SOC engineering, the one who looks after, probably, your creation of the playbooks and all those things, automation. So, then you have an IDAM team. InfosecTrain Trainer: So, under IDAM, there's a big function, right? You have identity governance, you have identity management, then you have a privilege identity management, all those things. The team who manage your AD forests and everything, right? Then you have a GRC team, who will do the risk assessment. InfosecTrain Trainer: who will manage the TPRM all those things they will do, right? Then you have a, AppSec team. InfosecTrain Trainer: if you are building and managing the application security, so they will have some program related to this, right? Then you can have some other specific team, like CloudSec.

InfosecTrain Trainer: AIC governance, and all functions. So, all these separate, separate functions, they plan, create, or manage some activities InfosecTrain Trainer: throughout the year. InfosecTrain Trainer: And those activities are under the information security program, right? And for those activities, you have a separate, mattresses to report to, so that you can understand what is the progress which you have made, right? You have a specific KPI KRI, so there are some operational activities. InfosecTrain Trainer: which are day-to-day basis. Like, you have a L1, L2 SOC team, they... every day they check the tickets, they close it. Like, in the IDAM team, if someone raises an access request, they will analyze, they will close the ticket, right? These are the operational activities which you do under all the functions. Then you have some specific InfosecTrain Trainer: Projects which you run. InfosecTrain Trainer: Right? Like, this year you are establishing the new tool, this year you are building something new, this year you want to do something else, so those projects, so all the things, including operational and these projects, is called as an information security program. Clear, everyone. InfosecTrain Trainer: What is the information security program? I hope everything is now clear. This is what the information security program means. InfosecTrain Trainer: Right? Now, what are the goals of having this information security program? InfosecTrain Trainer: So, there are 8 goals, what you want to achieve. First thing. InfosecTrain Trainer: The program is what? It's helping you establish the strategy. Helping you implement the strategy. So, information security is strategy which you have created, right?

That strategy is something which you are implementing using a program, right? InfosecTrain Trainer: Also, it helps you protect the assets. So, we just discussed, right, so many functions. End goal of so many functions are what? InfosecTrain Trainer: to protect the assets. SOC team is doing something, GRC is doing something, application security team is doing, IDAM team is doing something, so... and the goal of all those teams are what? To provide a protection to your organization, assets, your organization data, people, processes, all those things, right? To ensure the confidentiality, integrity, and availability of all critical assets. InfosecTrain Trainer: Also, it will help you enable the business. It will support all the business functions, their innovations, their activity, like business want to create a new application, business want to migrate to a cloud, business want to onboard a new AI solution, so all those enablement activity, also the program will help you, also help you manage the risk. InfosecTrain Trainer: So, how you manage the risk? You deploy controls, right? InfosecTrain Trainer: So those controls are being taken care by all the teams, right? So those controls are being, some controls are being managed via operational activities, and the new controls are being upgraded, or new controls are being created using the project basis, right? InfosecTrain Trainer: So, it is overall helping you manage the risk. InfosecTrain Trainer: also help you ensure compliance. So, if you read any compliance, any regulatory framework, or any standard, or any framework, they have some specific requirements which you are supposed to implement. InfosecTrain Trainer: Those requirements you will implement via program, right?

So they say you should have an incident management program, they say you should have a cyber resiliency program, you should create a BCP and DRP program, so all those things you will implement through program. InfosecTrain Trainer: Then, you will deliver the value. InfosecTrain Trainer: So, if you manage your program effectively, you will be able to optimize all the resources properly. InfosecTrain Trainer: Right? You will be able to bring the ROI, return on investment. InfosecTrain Trainer: Right? You will be able to give a better return on investment to all the stakeholders, so you will bring overall value. Also, it will help you establish the resilience. InfosecTrain Trainer: So, you will be able to improve the empty, mean time to detect, mean time... InfosecTrain Trainer: to respond. Also, you will be able to meet all the RTO and RPO-related targets. InfosecTrain Trainer: So, all these things the program will help you establish, so that you quickly detect and respond to the incident, and then if actual incident occurs, you are able to quickly recover from those incidents. InfosecTrain Trainer: And then you have a continuous improvement cycle, where continuously you improve, right? So there is something called, we discussed, right?

Capability Maturity model, right? CMMI. InfosecTrain Trainer: So, suppose current capability maturity score of your organization is 3.5, so you will say my next... my next year target is to bring it to 3.8. InfosecTrain Trainer: that you continuously improve upon your controls, your processes, so that you achieve your organization objectives. So, what are the outcomes?

InfosecTrain Trainer: From this, first thing is the strategic alignment with the business objectives, that's what the program brings, risk management, managing the risk to an acceptable level. InfosecTrain Trainer: Deliver the value via cost-effectiveness, effectively managing the process, people, and technologies. InfosecTrain Trainer: Measuring the performance via KGI KPIs and KRIs, and then process integration with business and the IT operations. InfosecTrain Trainer: And what are the key success factors? You will achieve executive sponsorship and governance, you will have clear roles, accountability, and ownership. InfosecTrain Trainer: Business-driven and the risk-based prioritization, you will be able to do. Adequate funding, you will be able to receive from the executive management. InfosecTrain Trainer: Achieve the culture, security, awareness, and continuous monitoring and improvement. InfosecTrain Trainer: So, if business... is able to achieve their objective, you can say, my security program is successful. InfosecTrain Trainer: Right? So, if you are able to achieve an acceptable level of risk, it means you have achieved the objectives from your program. So, this is about the information security program. InfosecTrain Trainer: Now, what are the elements which are there as part of the program? InfosecTrain Trainer: First and important point. InfosecTrain Trainer: program helps you implement the strategy. Keep this point noted, because you will get some questions around it. InfosecTrain Trainer: So, if you want to effectively implement the information security strategy, what will help you enable it? The program.

InfosecTrain Trainer: Also, if you want a good support from your stakeholders, your senior management, your CEO, all your executive sponsors, how you will get it? If you are managing your program very well. InfosecTrain Trainer: Right? If your CISO goes and reports that every month we get 3 true positive incidents, and all of them are causing an impact, how... InfosecTrain Trainer: What is going to be the impression upon your executive leadership there, right? InfosecTrain Trainer: But if the CISO says that we... every month, we get a lot of... through positive incidents, but we... our tech stack is very effective, it is able to... InfosecTrain Trainer: mitigate the threat, it is able to, detect them, and also able to mitigate the issues. There are no InfosecTrain Trainer: possible impact because of them. That will showcase that your program is actually working very well. InfosecTrain Trainer: And programs should be able to provide the regular feedback through metrics, so that you understand... so the senior management and all the sponsors, they understand how effectively the program is operating. InfosecTrain Trainer: Right? So that's what, like, I gave example, right? Like, suppose you have a security awareness program. So you would say that last month. InfosecTrain Trainer: We increase the... InfosecTrain Trainer: the KPI. So, earlier, only 80% people were attending the training, but through new methods, new initiatives, we increased it to 85%. Now, the phishing click rate also reduced from InfosecTrain Trainer: 10% to 5%. So, likewise, you have to demonstrate that continuous improvement through the security program. InfosecTrain Trainer: This is an important slide, which will... actually is a kind of summarizes all the four domains.

InfosecTrain Trainer: Not the last domain, but all till here, you will be able to get a summary from this, right? InfosecTrain Trainer: If you want, you can take a screenshot of this. InfosecTrain Trainer: So, the information security strategy, which we discussed in the Domain 1, InfosecTrain Trainer: What you do, you define the objective, you identify asset, you assess threats, and then you develop a strategy. And when you are developing the policy, you first draft policy, then you review, you get approval, you disseminate, and then you continuously review and update. In risk assessment, you identify risk, you analyze risk, you evaluate risk, you mitigate risk, and you monitor risk. InfosecTrain Trainer: And recently, we are into the program management, where you develop the program, you implement the list of controls. InfosecTrain Trainer: You manage the training and awareness, you monitor and review, you establish the incident management, and then you continuously improve. InfosecTrain Trainer: Got it. So, this is something... this is all the processes which we have discussed so far. InfosecTrain Trainer: Now, what is... what are the... InfosecTrain Trainer: How you can call a program effective. InfosecTrain Trainer: So, in your organization, if your board of directors, they tell your CISO, InfosecTrain Trainer: tell me why you are calling your cybersecurity program is working well and it is effective, how he's going to go and justify. He will justify using these things. InfosecTrain Trainer: So, he will first justify if the program is able to meet the security objective. You have some security objectives, which is defined by you, right? By CISO, important objectives.

InfosecTrain Trainer: Like, reduce the incidents, improve the resiliency, whatever you have those objectives, if the program is able to meet those objectives, it shows that program is effective. InfosecTrain Trainer: It should also be able to accommodate changes. InfosecTrain Trainer: Because the new things, new projects, new initiatives keeps coming. There are some regulatory changes which will happen, there are going to be changes which will happen in the external environment, right? Has anyone predicted that AI will come and it will do so much disruption? InfosecTrain Trainer: You did not, right? Now there are, myths. InfosecTrain Trainer: class AI model, which is able to rapidly detect the vulnerabilities. So that's why you will see a huge number of patches which are being created and deployed by the Microsoft these days. InfosecTrain Trainer: Anyone here who manage vulnerability management in the organization? Sandeep Saxena: Earlier, I have managed my previous company. InfosecTrain Trainer: Okay, okay, so if you would have been doing it right now, you will see a huge InfosecTrain Trainer: Amount of increase in the... Actually, number of vulnerabilities which are getting detected. InfosecTrain Trainer: So every month, they are releasing some 300, 400 vulnerabilities. InfosecTrain Trainer: then you want to achieve a benefit from available experience tools and techniques, right? You have resources, you have the technologies, you have all the things. You want to make sure, through this program, you want to achieve that benefit. InfosecTrain Trainer: Also, you want to provide the critical support to the business function. InfosecTrain Trainer: So, business functions, like, like in the organization, right? You have, you have the application development.

InfosecTrain Trainer: function, you have, operations, you have HR team. InfosecTrain Trainer: all those business functions which are there, right? You want to support them in their activities, right? So that they effectively operate and effectively function, and then there are no disruptions in the activities what they do. You will also leverage the partnership to support ongoing requirement. InfosecTrain Trainer: So, CISO alone cannot manage complete program. He alone cannot handle everything. He needs to build a partnership with the people, right? So that he is able to achieve the program objectives. Also. InfosecTrain Trainer: Through effective program, you will increase the likelihood of well-integrated efforts. InfosecTrain Trainer: So, all the well-integrated efforts which you have put across, throughout in the people... Process... InfosecTrain Trainer: Technology, all those well effort you will realize through effective program, and will ensure a consistent level of security. InfosecTrain Trainer: Right? If you are managing your program well, you will have a consistent level, not like that one month you have a huge number of incidents, then two months there are no incidents. Likewise, InfosecTrain Trainer: You don't want to do that. InfosecTrain Trainer: Now, what is the purpose? InfosecTrain Trainer: Why do you create a program? InfosecTrain Trainer: Why you need a security program in the organization. InfosecTrain Trainer: First thing is that you want to protect your organization, right? InfosecTrain Trainer: Why are you all people here, why you work in cybersecurity? Your end goal of whatever role you are doing in... currently, end goal is what? You want to protect your organization from any kind of cyber threats. InfosecTrain Trainer: Right?

It's not only that SOC team is protecting your organization. Any activities, even the IDAM team. InfosecTrain Trainer: Application security team. InfosecTrain Trainer: GRC team, whatever activities they are doing at their part, their end goal is what? They want to make sure that the organization is protected from all kind of cyber threats, issues, and all kinds of issues, right? So that's why you have to make sure that you pro... you create a program which is able to provide you the comprehensive protection. InfosecTrain Trainer: Also, you want to implement the strategy. InfosecTrain Trainer: So you create a 5-year strategy, you want to implement it, you will make sure through program, right? Now, organization, you know, all the organizations, they recently updated their strategy to reflect the AI. InfosecTrain Trainer: So, your board of directors says that please make sure you are introducing AI to improve the efficiency of your operations, efficiency of the way you work. InfosecTrain Trainer: Now, all the business leaders and the business verticals, they started introducing AI. Probably some business unit is working on machine learning models, they are hosting, creating. Some will say, okay, this is a new data analytics AI-powered third-party tool which I'm onboarding. InfosecTrain Trainer: even people will start going, and they will start browsing on cloud model, or open source models, right? They will go to ChatGPT, Gemini, and start querying. So, all these things every department started doing, but InfosecTrain Trainer: the what is the role... what is the role of CISO? InfosecTrain Trainer: He have to make sure that all these things, whatever activities people are doing, they remains protected.

So CISO will make sure that he create... he create a strategy, and he help that strategy implement using a program. He'll say, okay, let's set up an AI governance stream. InfosecTrain Trainer: Let's create a AI security policy. InfosecTrain Trainer: let's establish the... establish the AI NIST AI framework. InfosecTrain Trainer: Right? So all these things you will make sure to... InfosecTrain Trainer: Implement a strategy what board of directors wanted. InfosecTrain Trainer: Then you will establish the enterprise-wide controls, right? So, your password protection, your identity and access management, your incident management, your security awareness, all the control, you name it, they are all the enterprise-wide controls. It's not like that, that only security team is

having a password. Everyone in the organization uses it, right? InfosecTrain Trainer: Then... You want to provide an insight into the risk address and control use for the senior management. InfosecTrain Trainer: So you want to provide the management insights so that they understand how the effective program is being managed, how it is providing a comprehensive level of protection and consistent level of security to the organization. InfosecTrain Trainer: Now, it's very important, charter. InfosecTrain Trainer: We discussed the charter in the domain one. What is the charter? SupriyaMhatre: His authority to begin. InfosecTrain Trainer: Okay. InfosecTrain Trainer: And what does it include... SrinivasanJ: Project plan? Pudir: is an official document on the legal document? Pudir: the organization. SupriyaMhatre: Who will do what, and how much is the budget? InfosecTrain Trainer: Okay. InfosecTrain Trainer: So, the charter, somehow, all of you are right.

So, charter is something which gives authority to CISO InfosecTrain Trainer: To start the program. InfosecTrain Trainer: Right? InfosecTrain Trainer: So, the program, every year, he gets allocated with some budget, right? So, I'm not sure what is, so in your organization, let's say you... CISO is getting \$5 million every year budget. InfosecTrain Trainer: To manage the security for the organization, which will include the InfosecTrain Trainer: People cost. This will also include the... Tech and ops cost. InfosecTrain Trainer: people cost and tech costs, right? So he gets a budget, but how he will get an authority, right? So he will showcase to the senior management, and then they will approve the charter, right? InfosecTrain Trainer: Probably next year, he wants to increase it 5 to 5.5 million. He says that there is a change in the tech stack, change in the environment, there are new things, new initiatives which we have to plan. So again, you have to go and update the charter. InfosecTrain Trainer: So, charter is something which is a formal, written definition of program, objective, timelines, funding, resources, leadership, and executive sponsorship. InfosecTrain Trainer: So, this particular document provide you, help you, gives you the executive supports, and gives authority to the security leader to go ahead and implement the program. InfosecTrain Trainer: It helps you develop and enforce the security policies. InfosecTrain Trainer: Right? It helps you develop and enforce the InfosecTrain Trainer: It helps you develop and enforce the overall, InfosecTrain Trainer: A risk management process in the organization. InfosecTrain Trainer: Also, it helps you develop and manage also. InfosecTrain Trainer: Manage the security governance.

InfosecTrain Trainer: And we'll implement the controls across department boundaries. So. InfosecTrain Trainer: So the program, the funding, and whatever resources you are seeking. InfosecTrain Trainer: Those are not only to manage the resources within the security team, right? Something... whatever you are doing, it's something which is being implemented across organization, and it also directs the key security processes for the implementation. InfosecTrain Trainer: Now, understanding the scope. InfosecTrain Trainer: So the scope... InfosecTrain Trainer: of the program is very important to understand. What is going to be the scope, what all things would be included, which all things under security? Because sometimes, what I have seen, there is some shared responsibility between CIO and the CISO. InfosecTrain Trainer: you would have also experienced it in when you... you jump from one organization to another organization. There are a couple of functions which are under CEU in some companies, there are a couple of functions which are under CISO in InfosecTrain Trainer: companies, like, sometimes the application security is not managed by CISO, it's completely given to the CIU. So the security resources and everyone sits InfosecTrain Trainer: with the CIO, and they will manage it. InfosecTrain Trainer: Because CIO is handling complete development, product development, everything, so CISO won't take that responsibility, it goes to CIO. So that's why it's very important to define the scope. InfosecTrain Trainer: And the boundaries. What the security program will include, what the things it will make sure, right? InfosecTrain Trainer: So, whenever you are starting and creating an information security program, suppose you joined one A, B, C... InfosecTrain Trainer: fintech company.

InfosecTrain Trainer: You join this organization, and in this organization, you are establishing the program. InfosecTrain Trainer: So, how you will start with that? Someone can tell me the entire process, because we have discussed this multiple times. So, so, Sandeep, you are... InfosecTrain Trainer: hired as a consultant in one ABC fintech company, they want to establish the security program from scratch, how you will begin? Sandeep Saxena: Okay. Sandeep Saxena: Similarly in the lines of security strategy and the information security program I will build, right? InfosecTrain Trainer: Correct. Sandeep Saxena: And then defining the scope and the roles of the different departments, for example, APSEC, or for Instant Response, or GRC and all. Sandeep Saxena: And then... Yeah, the current state and the desired state and the targets. Sandeep Saxena: Right? InfosecTrain Trainer: Yes. InfosecTrain Trainer: So, you will first begin with... InfosecTrain Trainer: assessing the current state of the organization, right? You will first assess what does ABC FinTech Company has at this point of time, which all processes they have, what are the policies they are maintaining, which framework they are following, how many teams they have separately, do they have a separate SOC team, do they have a separate GRC team, do they have a separate IDAM team? Do they have a separate application security team? InfosecTrain Trainer: all the things you will assess, right? So that becomes a current state. Now, you will draft a desired state. So desired state, you will create, you will see... seek the input InfosecTrain Trainer: from... org strategy? InfosecTrain Trainer: You will consider IT strategy, You will consider the information security strategy.

InfosecTrain Trainer: Also, then you will pick up a framework. InfosecTrain Trainer: You will take the input from all these things. Also, you will consider other parameters, and then you will create a desired state. Like, this is what we want a program to look like. Also, you need to consider the culture. InfosecTrain Trainer: Like, something... what was being done in your previous organization does not mean will happen in the current organization also. Every organization operates in a different environment and different boundaries. As I told you, like, I have previously worked in a bank also, now I'm working with a manufacturing organization. It's completely cultural difference over there. In the banking industry, everything was blocked. InfosecTrain Trainer: Because they operate in such a regulated environment, they cannot give access. So, and also, banks, you will see, are the last one to adopt any technology changes. InfosecTrain Trainer: They are always going to be the last adopter. InfosecTrain Trainer: They will first see if all other organizations have done that, then they will go and adopt. InfosecTrain Trainer: So they... they are very slow in terms of adoption. So that's... is what the culture difference is. And then, what kind of structure the organization operates in, right? We discussed the distributed structure, the central structure, hybrid structure. So, what kind of structure organization is? All these things will help you define and create an information security program. InfosecTrain Trainer: Now, what is the... What is a business case? InfosecTrain Trainer: Okay, so really, what is the business case? SrinivasanJ: Business cases, strategy developed based on business requirement. InfosecTrain Trainer: No, in general, what is business case?

I'm not talking from the cybersecurity perspective. InfosecTrain Trainer: Why do you create a business case? Pudir: It's a document of our project, sir. InfosecTrain Trainer: Business... business case is something which helps you InfosecTrain Trainer: Show the importance of that particular initiative to InfosecTrain Trainer: The sponsor, simple document, simple definition. InfosecTrain Trainer: Suppose, in your organization, you saw that there is a new AI security certification. You want to convince your CISO that, please approve me the funding and budget, approve me the funding sponsorship for this particular InfosecTrain Trainer: certification, it will help me establish the AI governance in the organization, how you're going to convince the CISO? InfosecTrain Trainer: You will create a business case. InfosecTrain Trainer: You will say that this is what the certificate actually includes. These are the learning modules, these are the learning values the certificate brings, and these are the things what organization want to achieve. InfosecTrain Trainer: And this is the cost and the funding requirements, what I have, and this will help us solve those problems, help me understand the AI governance from a bigger perspective, and then InfosecTrain Trainer: you will go to the CISO with that business case. InfosecTrain Trainer: The CISO can approve or reject on the basis of looking at the initiative and looking at the things, what you are projecting to him, right? InfosecTrain Trainer: Now, coming to the security.

InfosecTrain Trainer: So whenever you are doing any changes, you are introducing something new, you are bringing in any new tools, you are establishing something new, suppose in the organization, you want to establish an AI governance InfosecTrain Trainer: program within the cyber team, so AI governance program will require the tools technology, and process. InfosecTrain Trainer: Right? InfosecTrain Trainer: And this will consume some funding. You have to bring new licenses and all, you have to purchase them. InfosecTrain Trainer: You have to bring in new technical capabilities, that also will consume funding. You are getting the new processes, you are getting the people and resources, all of them will require funding. How you are going to secure that funding from the senior management? InfosecTrain Trainer: You have to go to them with a business case and propose them, this is the thing, and this is how it will help organization achieve its objective. InfosecTrain Trainer: reduce the risk which AI initiatives currently brings in our environment. InfosecTrain Trainer: And then they will approve or reject on the basis of that. InfosecTrain Trainer: So, developing a business case for security adds value, driving the importance of physical and cybersecurity investment within the organization. InfosecTrain Trainer: Right? So whenever you identified a risk, so I identified a CISO identified a risk that AI usage has increased in the organization, all the departments, they are bringing in new InfosecTrain Trainer: tools, technologies, there is a high usage of the shadow AI within the organization. People are even uploading the organization important sensitive data and information into the tool. Also, AI InfosecTrain Trainer: Can be used as an attack.

InfosecTrain Trainer: Also, can be used by an attacker. InfosecTrain Trainer: Right? So we need to bring new AI capabilities for the SOC to quickly detect the tool, we need to create new playbooks and all those things using AI. So all the risk you will identify, you will then identify what are the potential impact of not having this. InfosecTrain Trainer: So if you do not establish this AI governance program, what is going to be the overall impact to the organization? You will say that there is a high probability of InfosecTrain Trainer: having major significant security incident, we may... business may, operations may get hampered, we will have the... this much amount of ransom InfosecTrain Trainer: which we need to pay if we do not go with that. There's a high possibility of ransomware gangs attacking us. So all these things you will analyze. Then you will need to showcase in the business case how it is reducing the risk. InfosecTrain Trainer: So, without having this program, if you say that earlier the risk was sitting at the critical level. InfosecTrain Trainer: After putting up this program, all the initiatives, everything gets complete, we will bring the risk to a moderate level. InfosecTrain Trainer: And then, what is going to be the return on investment? InfosecTrain Trainer: Because if organization is giving you funding, if they say that, they will say, okay, we give you \$1 million to bring... establish the program. If they are giving you \$1 million, they need to understand what is the return they are getting. If they invest the \$1 million. You will say that InfosecTrain Trainer: If you do not have this, the impact would be \$10 million. InfosecTrain Trainer: So, the \$1 million funding is justified here. InfosecTrain Trainer: Clear, everyone. Business case.

What does it do? Why you create a business case? SrinivasanJ: Excellent. InfosecTrain Trainer: And you will get questioned in the exam, on the business case. Business case is going to be there as an option, so if you understand what exactly is the purpose of business case, you will be easily able to answer those questions. InfosecTrain Trainer: This is a very important slide, which actually shows you how you develop a program. InfosecTrain Trainer: I can... Share this with you all. InfosecTrain Trainer: So that you can remember this particular topic. InfosecTrain Trainer: So, we already discussed this, but this particular, InfosecTrain Trainer: Flow chart actually helps you explain how we create a program. InfosecTrain Trainer: First, you need to understand what is the desired outcome, what you want to achieve out of the security program. InfosecTrain Trainer: If you know what are the outcomes you want to achieve, then you will be able to effectively create a program objectives, right? InfosecTrain Trainer: Once you know what are the outcomes, from those outcomes, you will be able to get a... what are the objectives, what you want to achieve, which is the desired state. Then you will next InfosecTrain Trainer: Perform the gap analysis. InfosecTrain Trainer: Right? Once you do the gap analysis. InfosecTrain Trainer: you will create a strategy to close those gaps. This is not security strategy. InfosecTrain Trainer: This is a strategy to tackle those gaps which you identified, then you will create a roadmap to navigate strategy. Whatever strategy you created, you will create a roadmap, then you will develop a program. InfosecTrain Trainer: And then, you will manage program to meet the objectives. InfosecTrain Trainer: Let's take a very simple example.

InfosecTrain Trainer: Like, Srinivasan decided that there is one marathon which is planned after two months. InfosecTrain Trainer: There's one marathon which is planned. So he... he was a marathon runner previously, but currently he has stopped it from a longer period of time because of the busy schedules and all. So he again wants to regain his fitness to run the marathon, right? So if he's running a full marathon. InfosecTrain Trainer: So, he had to, again, regain into shape, build that strategy and all, right? So, how he'll do that? InfosecTrain Trainer: he will first assess the current state. He'll probably go for a run, he'll say, okay, I'm only able to run 5 kilometers effectively. InfosecTrain Trainer: With the current fitness. InfosecTrain Trainer: you'll say, okay, I have also gained a couple of kgs, so I have to first create a InfosecTrain Trainer: diet plan. InfosecTrain Trainer: I have to create a fitness schedule. InfosecTrain Trainer: All these are the gap, right? InfosecTrain Trainer: Tight plan, fitness schedule, then he have to also... also do some changes in the routine. InfosecTrain Trainer: now he'll start working on fixing those gaps, right? So he'll say, okay, this... every week, first I'll start from 5 kilometer, then I'll increase to 10, then I'll go to the 21km. InfosecTrain Trainer: Likewise, I'll continuously improve, increase, reduce the weight, also increase my stamina, and then through this, I'll be able to achieve my end goal, so that I am able to run this full marathon on that day. InfosecTrain Trainer: Right? So, same thing you do in the program or any activity, right? You first understood what is the desired state, desired state to run a marathon. You did a gap analysis. InfosecTrain Trainer: Currently, this is what you are.

Then you created a strategy, how you are going to run a marathon. Then you created a roadmap. InfosecTrain Trainer: This is how we will create a probability a chart. InfosecTrain Trainer: this week, I'll run this kilometer, this kilometer, you did that. Then you created a program, like this overall tight plan, your fitness plan, everything, whatever you have created, and then you will manage this particular overall program to meet your overall objective where you want to run a marathon, right? This is how you do that. InfosecTrain Trainer: And the risk management is something which is always go in parallel across all the activities. InfosecTrain Trainer: Right? You cannot directly go from 5 to 21 kilometer in next day, right? Probably you may get a stroke, or some kind of fatigue, or some kind of injury you may get, right? So all the risks, right? Risk of having an injury InfosecTrain Trainer: risk of probably having some other commitment, or some office project, or office trip due to which probably you got derailed from your progress. So, any risk may happen during this particular activity, right? So, it will run in parallel over all InfosecTrain Trainer: All the activities, right? InfosecTrain Trainer: So, everyone clear on this, how you program, how you develop a program. InfosecTrain Trainer: Alright, let's discuss some questions. InfosecTrain Trainer: Alright, let's discuss. InfosecTrain Trainer: A CISO is developing a business case for a new comprehensive information security program. To secure the executive approval and the funding, what is the main focus the business case should InfosecTrain Trainer: emphasize, we just discussed the business case in detail.

InfosecTrain Trainer: detailed technical specification of proposed security solution, how come see the senior management would be able to appreciate what are the technical specifications and all? They'll not be able to understand, right? InfosecTrain Trainer: how the program's direct contribution to enabling strategic business objective and managing enterprise risk. That's what we discussed. InfosecTrain Trainer: You want to establish an AI governance process within the security, how that will improve the overall posture of the organization in the AI-related environment, how it will reduce the risk. InfosecTrain Trainer: That is what you want to achieve, not comprehensive list of potential cyber threats. So I'll not include that what are the AI-related attacks, profile, and attack threats and all, right? InfosecTrain Trainer: Also, I'll not only adhere to the all-mandated regulator compliance requirement, compliance requirement may also fall part of this. So, if those strategic business objectives include the compliance requirement, so that will also InfosecTrain Trainer: get added as part of this, right? So this is the correct answer. InfosecTrain Trainer: When developing the scope of an organization's information security program, what is the most critical initial step to ensure that its effectiveness and the alignment? InfosecTrain Trainer: Inventorying all existing security tools and technologies, recruiting a dedicated information security program management team, identifying all information assets and their associated business processes, drafting a preliminary budget for program implementation, right? InfosecTrain Trainer: First, you start with the identification of the current environment, right?

InfosecTrain Trainer: without understanding your current environment, your current business assets, your current business processes, how you can decide what are the tools, technologies you want, right? How many resources you want, or how much budget you want. Without understanding C, you cannot decide on A, B, and D. InfosecTrain Trainer: an information security program charter is being developed, what is its primary purpose in the context of program governance? To detail the technical requirement for all security controls, to serve as a comprehensive project plan for the implementation, to formally establish the program, define its authority and secure executive sponsorship. InfosecTrain Trainer: To outline the specific training module for security awareness. InfosecTrain Trainer: So, which, let's go. Okay, which of them you can directly... Kind of, InfosecTrain Trainer: go here and probably eliminate from this A, B, C, D. Let's practice that elimination technique here. SrinivasanJ: Training. InfosecTrain Trainer: Which of them, two of them, you want to eliminate first? InfosecTrain Trainer: Also, also give me logic, why you want to eliminate them. subaveena pugalthi: The charter wouldn't specify the technical requirements, so we should eliminate that, and it has nothing to do with training modules or awareness program. InfosecTrain Trainer: Yes, so likewise you do in the exam also, right? You automatically understood that A and D are eliminated. Now, the B and C is somehow close, but also the pachata do not include the comprehensive details, right? It's just a... InfosecTrain Trainer: high-level deliverables, which you will include, right? So this is also eliminated, so you know the correct answer here is C.

InfosecTrain Trainer: The first step in developing an information security management program is to InfosecTrain Trainer: identify business risks that affect the enterprise, establish the need for creating the program, assign responsibility to... for the program, assessing adequacy of existing programs. So, answer is there in the diagram which I shared in the chat. InfosecTrain Trainer: If you go read that diagram, you will easily be able to understand that B is the first step. InfosecTrain Trainer: So, we discussed... this diagram. InfosecTrain Trainer: without understanding the context, establishing the objective, how you can start the program. Risk management will happen after this stage. First, you need to understand what is the... what you want to achieve out of program, then you will do the risk assessment. So that is the next step. InfosecTrain Trainer: So first, you need to establish the need for creating that program, then other steps will follow after that. InfosecTrain Trainer: Got it. InfosecTrain Trainer: So anyone has any different opinion or questions on this? InfosecTrain Trainer: Alright, let's discuss some couple of more questions. InfosecTrain Trainer: Yes. InfosecTrain Trainer: Alright, let's discuss. InfosecTrain Trainer: Which of the following is

the most important reason that the information security objective should be defined? InfosecTrain Trainer: Okay, so which two options do you people want to eliminate? Anyone? Pudir: TNT, sir. InfosecTrain Trainer: Which one? Pudir: C, under the consistency with applicable standards. Pudir: Regiment to sign up, and... Support initiatives. InfosecTrain Trainer: Okay, why? You want to eliminate these two? Pudir: Information security objective is not consistent with applicable as Beckard.

Objectives are a different, objective. Pudir: And the management sign-up is different from the objectives. InfosecTrain Trainer: Okay, okay, good. So C and D eliminated. Now you are left with the A and B, right? So... so what is the correct answer here? Pudir: I thought PTZ. InfosecTrain Trainer: It's A, correct. InfosecTrain Trainer: So the objective is something which helps you measure the effectiveness, right? Because you set an objective. So you set an objective that you want to achieve the 70% in one particular practice test. InfosecTrain Trainer: So that 70% becomes a objective for you. Now you will measure the effectiveness with respect to that, how you able to... how much you progressed, or how much you were able to achieve there, right? So that's why correct answer here is A. InfosecTrain Trainer: Most standard frameworks for the information security show the development of information security program starting with InfosecTrain Trainer: Policy development and implementation of the process, internal audit and remediation of finding, risk assessment and control objective, resource identification and budget requirement. Which two options you want to eliminate here? InfosecTrain Trainer: Someone else? InfosecTrain Trainer: Yeah. InfosecTrain Trainer: Which two options you want to eliminate from this? subaveena pugalenthi: B&T? InfosecTrain Trainer: B and? subaveena pugalenthi: P? InfosecTrain Trainer: Why you want to eliminate C? subaveena pugalenthi: I think information security... Program wouldn't start with risk assessment, right? InfosecTrain Trainer: But there is a control objective also written here, right? Without understanding the objectives, how you are going to start the program. subaveena pugalenthi: Jesus.

InfosecTrain Trainer: option, if the option, Option would have been something else. InfosecTrain Trainer: Right? Even the risk assessment will tell you which policies you are supposed to develop. InfosecTrain Trainer: That's what I'm saying, do not just go by what the diagrams say. Every question, you have to read all the four options correctly. InfosecTrain Trainer: Right? So, the question, do not talk about the, talk about the creating the need, or those things. That is not here, right? InfosecTrain Trainer: So that option is already known. What is the next step after that? InfosecTrain Trainer: Next step after is that is what? It's the risk assessment, right? InfosecTrain Trainer: If you don't have a need, then next step is what? Next step is risk assessment. What you will do, you will assess the risk, you will understand what is there in your environment. InfosecTrain Trainer: Even the gap assessment, what you are doing is a form of a kind of a... actually, you are doing the risk assessment also as part of that, right? That's why the risk assessment runs in parallel, so your correct answer is C. InfosecTrain Trainer: What was your answer, Subha? subaveena pugalenthi: I put a... SrinivasanJ: Hmm. SrinivasanJ: I also protected. InfosecTrain Trainer: No, not A. It won't start with the policy development and implementation of processes. Policy development and the implementation of processes will happen after A, after C. InfosecTrain Trainer: First, you do the risk assessment, you define what are the controls you want to achieve. On the basis of that, then you will develop the policies, and then you will implement the processes. So, correct answer here is C. subaveena pugalenthi: PR... SrinivasanJ: Talking about the program, right? Like, it is not about... Management.

InfosecTrain Trainer: Yeah, so without understanding the risk, like, suppose... like, let's take an example. Tomorrow, you are hired in one organization. They say, okay, we need to establish a security program. InfosecTrain Trainer: So you will just go and start developing some random policies. InfosecTrain Trainer: What you will include in the policies do you know? What information you will add in the policy? InfosecTrain Trainer: What that policy will address. SrinivasanJ: the current state and, the desired state. So, for the current state, you mean to say, like, we have to SrinivasanJ: Evaluate the current state by doing a risk assessment. InfosecTrain Trainer: That's what it says, no? That's what I'm saying, you only go what the question says. In this question, in these four options, what is the best approach looks like to you? InfosecTrain Trainer: Is doing a risk assessment, or directly jumping onto developing a policy? InfosecTrain Trainer: Yes, Shweta. Shweta Sundar: Why not, option D? Because it says program starting with, right? InfosecTrain Trainer: Yes? InfosecTrain Trainer: So, program is starting with... so, even the resource identification and budgetary requirement, also, you will get to know once you understand what is the risk in... persist in the environment. InfosecTrain Trainer: How you will identify how many resources are needed, how much budget I have to get from the management. Shweta Sundar: So here, resource identification does not mean inventory. InfosecTrain Trainer: Resource identification means the people, processes, technologies which is needed to run the program. Shweta Sundar: Okay, okay. InfosecTrain Trainer: So that's why you read the question once again, then you will understand why the C is correct answer.

You... InfosecTrain Trainer: keep... you imagine any process here, and then you understand that how option C makes sense out of A... InfosecTrain Trainer: If, suppose, I know the B and D is automatically eliminated, but A and C, if you are confused, you tell me which you will do first. You will do the risk assessment first, or you will first develop the policies. InfosecTrain Trainer: what you ought to put in the policies, which all things you want those policies should cover, how many policies you want to develop. You want to create a separate information security policy, identity policies, incident management policies, risk assessment policies, how come you will get to know without understanding what is the risk? InfosecTrain Trainer: In the environment. SrinivasanJ: I'm maturing the... SrinivasanJ: you know, information security program. I'm developing, so I have to first start with creating a process and policy, right? SrinivasanJ: I cannot go and run a risk immediately, so there should be a target set first. So this is what my, you know, target is, and then I have to do the risk assessment based on the target. I don't know the target, then what. InfosecTrain Trainer: Do not say... SrinivasanJ: Everybody... InfosecTrain Trainer: It do not says the creation of process, it says implementation of process. SrinivasanJ: Yeah, first, policy development, and then implementation of process. Okay. SrinivasanJ: So, this development of information security program is, what, confusing. See, if it is maturing, I would understand, okay, I have to do a risk assessment and then do controls. InfosecTrain Trainer: Let's again go back to that particular slide. InfosecTrain Trainer: this. InfosecTrain Trainer: You want to run a marathon, Srinivasan, which is... the date is after 2 months.

InfosecTrain Trainer: Will you directly create a plan, like diet, fitness, routine, and everything you will create directly? That's what the policy means, right? Policy means the same thing? InfosecTrain Trainer: What is the diet, fitness, routine, what you will follow to achieve it? Or first, you will assess where you stand at this point of time. InfosecTrain Trainer: Or first, you will do a risk assessment, and then you will understand what are the risks, in achieving that two-month target, how much kilometer you can run at this point of time, what is your fitness level, what are the issues you have. First, you will do that, or you first develop this. Without understanding the risk, how you will develop that? Tell me. SrinivasanJ: See, in this example, you said for 2 months I have not run, which means I am maturing my process. SrinivasanJ: But if I am developing, if I am doing for the first time, I... I have to first understand what marathon is, right? Only then I can do the risk assessment. SrinivasanJ: So, if I don't have any awareness about marathon, then how will I... SrinivasanJ: do a risk assessment. How will I prepare myself? SrinivasanJ: So, that is what my question is. InfosecTrain Trainer: So, risk assessment also involved gap analysis. You see? From there, the risk assessment starts, from here. InfosecTrain Trainer: You see, it's starting with the gap analysis. InfosecTrain Trainer: Gap analysis, strategy development, and everything is part of the risk assessment. So, risk assessment is running in a parallel. To assess the current state, also, you have to do a risk assessment. InfosecTrain Trainer: So that's what you are doing in that question, right?

You are... if you first want to assess a current state, then you will understand what policy and what things need to be added as part of policy. That's why correct answer here is C. InfosecTrain Trainer: Got it. subaveena pugalenthi: But identifying the current state and desired state, how do you say that that is risk assessment? subaveena pugalenthi: Can you give a solid example to understand? InfosecTrain Trainer: you see this, I'm not saying the gap assessment is a QL to risk assessment, I'm talking about this process, what I've showed you. InfosecTrain Trainer: what are current... what are the gaps in the current process? How... if you want to determine the current state, even for that, also, you have to do a risk management, right? You have to understand what are the risks, what currently is there in my environment, what are the issues, what are the challenges I have in my environment, then only you will create... what things you will include in a policy you tell me. InfosecTrain Trainer: If, suppose, tomorrow, day one, you joined the organization, Subha. InfosecTrain Trainer: You... you want to create a policy, how you will develop the policies, without understanding what are the issues which organization is facing. InfosecTrain Trainer: Are the data security is a challenge for them, or is the resiliency is a challenge for them, right? Is AI a challenge for them? Is the cloud security a challenge for them, or application security? All the things you want to cover as part of the policies. InfosecTrain Trainer: Without understanding all the different, different risks, how you're going to develop policy? InfosecTrain Trainer: Got it? InfosecTrain Trainer: So that's how.

First, you have to do a risk assessment, understand where you stand, what are the issues you have in the environment, what are the risks which persist, and then you create a policy. So policy is going to be there, but it is going to be the next step. InfosecTrain Trainer: So, in the question, the first step is this, next step is the policy. InfosecTrain Trainer: So that's how you have to develop the reasoning, otherwise you will end up getting questioned wrong in the exam. Next

is, which of the following is the best approach for improving information security management processes? InfosecTrain Trainer: What do you feel is the best here? A, B, C, D, which is the best option? InfosecTrain Trainer: Do you understand what does best mean? subaveena pugalthi: Yeah, she is down, sir. InfosecTrain Trainer: Yes, C is the answer. Best means something which is actually the most regularly followed, or generally followed, or best among all these. If you want to improve the process, you have to measure the InfosecTrain Trainer: mattresses. You have to measure the performance, then only you will be able to improve the process to seize the correct answer. How would an organization know if its information security program is accomplishing its goal? Key mattresses indicate a reduction in incident impact. Senior management has approved the program and supportive of it. InfosecTrain Trainer: employees are receptive to change that were implemented, there is an immediate reduction in reported incidents. What is the correct answer here? InfosecTrain Trainer: How would you understand that you are able... you are prepared to... for the CISM exam?

If the key matrices which you are... you are checking, if those indicates that you are able to get a good score, you have a good understanding around the topics. InfosecTrain Trainer: If that is achieved, then you know that the preparation you are doing, it's achieving the result, right? So, correct answer here is A. InfosecTrain Trainer: So that's how you have to follow, probably, not 100% questions, but at least I'm telling you 85-90% questions you will end up getting correct if you follow this approach. InfosecTrain Trainer: Always go what the question says. InfosecTrain Trainer: Don't ever... and one more thing, even in these questions. InfosecTrain Trainer: Never, ever jumped into something which is talking about directly developing something. Without assessing, you cannot develop anything, just follow. InfosecTrain Trainer: In ISACA, first step is assess, then develop. So wherever you see the assessment as an option, 90% of time, the assessment is going to be the correct answer. Just follow this. Think like me and answer. InfosecTrain Trainer: You will get most of the question correct by this. InfosecTrain Trainer: Always, ever assess the situation, then you develop. Simple. Here, also, they are talking about the development. Without assessing, you cannot develop anything. So, if you see the assessment as an option, then assessment is going to be the correct answer. That's it. InfosecTrain Trainer: keep this as a point. Also, if you want, you can note it. InfosecTrain Trainer: So that whenever you are, answering the questions, you will understand which option to choose. InfosecTrain Trainer: Now, next topic is the budgeting. InfosecTrain Trainer: So, when you are developing a program, it becomes essential for you to create a budget, right?

Without money, the program won't work, right? You need a funding. InfosecTrain Trainer: to achieve the targets, right? You need to hire people, so there's going to be the people cost involved, you need to purchase the software licenses, you need to probably build something internally for everything, there is a cost which you have to incur, right? InfosecTrain Trainer: First, you need to assess what is the currently we have, right? Do we have a proper SISEM solution or not? Do we have an endpoint InfosecTrain Trainer: EDR solution or not? Do we have a XDR solution or not? Do we have a, anti-malware software InfosecTrain Trainer: installed on all computer or not. So, all these things you will assess in the current state. What we have at this point of time. Also, you need to check the assets. InfosecTrain Trainer: What are the assets I'm protecting? Do we have AI? Do we have a cloud? Do we have applications? What are there is the infrastructure? Do we have an on-prem setup as well? InfosecTrain Trainer: What are the databases and critical assets we have, so everything you need to assess. Then only you will be able to budget, right? InfosecTrain Trainer: So to protect everything, you require a separate tech stack, or if there is a single tech stack which covers all of them, right? Also, you need a people, those who are trained in that, right? So you... then you will allocate the budgets accordingly. InfosecTrain Trainer: Also, you will consider the short-term and the long-term needs. What are the short-term target you want to achieve? What are the long-term goals? InfosecTrain Trainer: Short-term is something which is very critical in nature, critical gaps which you want to fix immediately, because if you do not fix it at this point of time, it will have a significant impact.

Like, attacker would be able to leverage it. So those immediate gaps is something which you have to first InfosecTrain Trainer: consider in the short term. A long term is probably building a better governance, building a team, training people over a period of time, so those budgets will follow. InfosecTrain Trainer: Then, you will allocate fund for the incident response, because this is an important part of it. Regularly, you review the budget, and then get the management buy-in. And even here, you manage the budget. InfosecTrain Trainer: In... for the security. SrinivasanJ: previous organization, I don'. InfosecTrain Trainer: Yeah, so probably you might be aware of these things, right? InfosecTrain Trainer: If you're managing budget. So there is a people cost, and there is a licensing cost, then there is an innovation and the project cost. All the things are there. Yashweta. SrinivasanJ: Yeah, it's split into two, CAPEX and OPEX. SrinivasanJ: Excellent. Investments and operations, yes. Shweta Sundar: I wanted to understand why the management buy-in is listed in the last. InfosecTrain Trainer: So once you assess everything, then only you will go to the management with the result, right? InfosecTrain Trainer: This is not something which is a step. InfosecTrain Trainer: Okay. Shweta Sundar: Okay. InfosecTrain Trainer: These are not a step or a process, but however, first you need to understand how much budget you want, then you will get a buy-in from the management and assess and get approval for the funding. Shweta Sundar: Makes sense, makes sense. InfosecTrain Trainer: Alright, let's do one thing, let's take a break, and then probably we'll... Continue from here. InfosecTrain Trainer: Alright, let's get started with the next topic.

InfosecTrain Trainer: Now, coming to the outcome or the output, what you achieve by having an effective risk IS program, right? InfosecTrain Trainer: So what are the outcomes? We saw a couple of questions also, right? So that's how you will get a question in the exam. You will get, what are the outcome of an effective information security program, right? So you will have probably one of InfosecTrain Trainer: these... particular thing as an answer there. So you have to just pick and choose. InfosecTrain Trainer: So, the first outcome is the strategic alignment. InfosecTrain Trainer: You want to align with respect to business objective, you want to support InfosecTrain Trainer: Your overall business initiatives, what organization want to achieve that your program will deliver. InfosecTrain Trainer: Then, it also helps you manage the risk in your environment, right? InfosecTrain Trainer: you want to manage all the risk, you want to identify, you want to create the controls for those risks, you want to improve those controls so that risk remain within your acceptable limit, right? You want to keep that residual risk within the acceptable limit that you will be able to achieve here. InfosecTrain Trainer: Then comes the value delivery. InfosecTrain Trainer: So whatever the value you want to achieve out of that business program, right, so that you... you... you optimize all the... InfosecTrain Trainer: security tech stack. Your resources should be able to deliver the best output. InfosecTrain Trainer: Right? All the processes, they should be fully optimized, and there should not be any gaps in those processes, right? So that value delivery you will achieve. InfosecTrain Trainer: And then the resource management.

You will be able to effectively manage the staff, services, tools, all the things, you will be able to effectively manage it, and the performance management, you want to InfosecTrain Trainer: have, effectively established KPIs, KRIs, KGIs, so that you can integrate with the assurance process. InfosecTrain Trainer: So, what is assurance? You get an assurity that your organization is secured. You get an assurity that organization is following the specific policies. You will get an assurity that organization is compliant to InfosecTrain Trainer: specific, standards, tools, or regulations. And then you will be able to, have a realization of better security architecture. InfosecTrain Trainer: These are some of the outcomes which you achieve if you have an effective program. InfosecTrain Trainer: Now, refining those objectives. InfosecTrain Trainer: So the objectives, whatever you have created, is... it's not like that it becomes a kind of a consistent, that you won't update them. InfosecTrain Trainer: Those objectives also will need to be updated as per the changes in the environment, as per the changes in the business, as per changes in the regulatory landscape, right? InfosecTrain Trainer: So your program should be able to accommodate those changes, and as a CISO, as a security manager, you should make sure that you're refining those objectives as per the InfosecTrain Trainer: overall environment-related changes, right? So you need to regularly review them, you need to refine and adapt as per the business needs. InfosecTrain Trainer: Like, suppose organization is going with the digital InfosecTrain Trainer: transformation.

InfosecTrain Trainer: Now, organization is upgrading its tech stack, it's moving from on... InfosecTrain Trainer: BREM to cloud, it's adopting AI, it's doing a lot of changes in the tech stack. InfosecTrain Trainer: It is even... even migrating the applications from the monolithic To the microservices architecture. InfosecTrain Trainer: Okay, someone tell me, what is the monolithic and what is the microservices architecture? InfosecTrain Trainer: Anyone who has worked as a developer previously probably would be able to InfosecTrain Trainer: Explain. What is a monolithic architecture, and what is a microservices architecture? Shweta Sundar: Microservices are, like, individual components, and they are, not interdependent. They have their own, but they function together. Monolith is one... in one system, and it is... Shweta Sundar: More of a... Older method of architecture, where the dependency is clubbed together and it's not so flexible. InfosecTrain Trainer: Yes, let me take a very simple example. You would have seen the e-commerce replication, like Amazon. So, Amazon has so many different, different components, right? It has a... InfosecTrain Trainer: Amazon Pay. InfosecTrain Trainer: It has Amazon Fresh. InfosecTrain Trainer: It has Amazon Quick, it has Normal. InfosecTrain Trainer: delivery, right? So whenever you search an item, it gets reflected here also, here also, here also. Then you can pick and choose. Also, all of them InfosecTrain Trainer: let you pay via Amazon Pay, right? But all of them are separate, separate applications altogether. InfosecTrain Trainer: Embedded in our single module, and InfosecTrain Trainer: communicating with each other via APIs. InfosecTrain Trainer: This is called a microservices architecture.

Rather than building one application as a one single code, one single monolithic architecture, you build that using a small, small subset, and then you integrate them via API, so that if something goes bad here, won't impact this. InfosecTrain Trainer: Right? So this is a new form of architecture, which is very essential to even achieve the zero-test architecture. So this is the backbone of having a zero-test architecture in your organization environment. InfosecTrain Trainer: So now you need to understand what are the strategic objectives, right? You need to align the security with the business goals. Business want to do the digital transformation, migrating from on-prem to cloud, so you need to train your existing security people into cloud. InfosecTrain Trainer: You need to train those people into a new tech stack. You need to adopt and bring in new tech stack. You require a CSPM InfosecTrain Trainer: or CASB solution to... InfosecTrain Trainer: protect the cloud tech stack, right? CSPM stands for Cloud Security Posture Management, and CASB is Cloud Access Security Broker. So these are the tech stack which helps you manage your cloud-related security policies, govern the cloud, right? InfosecTrain Trainer: Then... InfosecTrain Trainer: you require... you need to establish the appropriate risk tolerance level, right? Build security into all the business processes we discussed last time, right? subaveena pugalenthi: How information security program establish risk tolerance? Isn't it the senior management that establishes risk capacity, risk appetite, and tolerance, and we should be uttering with it, right? It's not this that would establish risk tolerance. subaveena pugalenthi: In my understanding. InfosecTrain Trainer: Yeah, program is not establishing the risk tolerance.

We are talking about the strategic objective. InfosecTrain Trainer: Whatever is the risk tolerance defined by your organization, that you want to establish, right? You want to maintain a true program. That is a strategic objective which you want to achieve. That's what it is trying to say. InfosecTrain Trainer: Risk tolerance won't be established by the CISO. It will come from the... this is but one of the strategic objectives, right? You want to make sure whatever is the risk tolerance organization has should remain in the same, so that you have a consistent level of security across organization. InfosecTrain Trainer: Also, you want to have a sustainable security culture. InfosecTrain Trainer: People should know their duties and responsibilities, right? They should know what they need to do, right? And then there are some operational objectives, which you want to achieve, right? Which are day-to-day basis activities, right? You want to establish the effective control framework. InfosecTrain Trainer: You should have an effective incident response and incident management capabilities. Also, establish a matrices for measuring the success and regulatory compliance. InfosecTrain Trainer: Now, what are the resources which you have? InfosecTrain Trainer: enable this particular thing, right? First thing. InfosecTrain Trainer: you need to understand that there are two types of resources which you have. You have management resources, we have a technological resources. So, management resources is something which helps you manage overall programs. So, first thing is the architecture. InfosecTrain Trainer: So, your enterprise architecture diagram, or... and your InfosecTrain Trainer: security architecture diagram, help you manage your overall things, right?

You know that how the outside tools, technologies, tech stack will come and get integrated into overall organization architecture, that thing you have to make sure you understand, right? Then the budgeting. InfosecTrain Trainer: how much budget you have, that will help you manage, then control objective, what you want your controls to do, and the risk management. These are the management resources. Some of the technology resources, like you have application security-based methodology, OS Top 10, InfosecTrain Trainer: or some secure coding practices, which orcoding libraries to operate. You should have a DevSecOP pipeline, all the policies and everything. Then, threat intelligence information sharing. InfosecTrain Trainer: Right? Data integrity-related controls, identity and access management system, remote access, so these are some of the examples. InfosecTrain Trainer: So, these are all the resources. Apart from that, you will have a relevant standards, framework, regulations, your organization policies, your strategies, all those things comes together and help you manage your program effectively. InfosecTrain Trainer: So, the three essential elements for the success is the strategic alignment, management, support, and effective matters. InfosecTrain Trainer: So, if you have a well-developed strategy which is able to support your overall organization objectives, this will make sure that you will go for a success. InfosecTrain Trainer: Like, organization is doing a transformation. InfosecTrain Trainer: Right? They are doing the digital transformation, they are moving from the on-prem InfosecTrain Trainer: Tech stack to the cloud, but your resources are not yet trained on cloud.

InfosecTrain Trainer: Or you have not even budget or decided that what you will do, do you need to hire new people, or do you need to train the existing people on the cloud? You have not yet decided how you will achieve the strategic alignment, because once the day comes when the organization tech stack will be migrated to cloud, security team won't be able to support those initiatives, right? InfosecTrain Trainer: And if you want your program to succeed, you must gain support InfosecTrain Trainer: From the senior leadership and the key stakeholders. InfosecTrain Trainer: Because they are the one, they'll support you with all the risks, all the incident management practices, they'll help you with the budget, resources, funding, all the kind of support, right? And also, effective mattresses. InfosecTrain Trainer: is essential for success. If you do not measure... simple thing is, simple statement is that if you do not measure anything, you cannot improve it. It's simple, it's universal in the world. If you cannot measure something, how you are going to improve it? Because you do not know what are the gaps, what are the issues in the process. InfosecTrain Trainer: Right? Similarly. InfosecTrain Trainer: with your CISM exam journey. If you don't measure, you don't solve questions, you don't understand how many marks I'm getting in those practice tests, how you will understand how much prepared you are to write an exam. InfosecTrain Trainer: Right? So that's why effective mattresses are very important to achieve a success. InfosecTrain Trainer: Now, as part of the program, the first step as, not a first step, it's an essential element to first understand your environment, in that you need to first identify the assets.

InfosecTrain Trainer: Without identifying the asset, without evaluating those assets, without creating a critical business processes. InfosecTrain Trainer: And all, how you are going to understand what kind of policies I need to create, what kind of tech stack I want to protect them, right? InfosecTrain Trainer: Like, hardware... so the asset classes generally are hardware assets, like a servers. subaveena pugalenthi: Asset identification and valuation, like, part of information security program developing plan, or is this topic completely different? InfosecTrain Trainer: This is part of the information security program. subaveena pugalenthi: So, are we discussing stepwise, or... InfosecTrain Trainer: No, no, this is not a stepwise. This is a topic. InfosecTrain Trainer: This is a process which you have to do as part of the information security program, right? You want to create the policies, you want to decide on the budget and funding, you want to decide on the what you need to do in your environment, without understanding what assets you have. InfosecTrain Trainer: And evaluating them, how you're going to get those tech stack. Without identification, how you will do that. subaveena pugalenthi: So is this part of gap analysis step, then? InfosecTrain Trainer: Yes. Yeah, this is part of that. InfosecTrain Trainer: Like, I am establishing the AI governance. InfosecTrain Trainer: without understanding how many AI models I am running, how many agents I am running. InfosecTrain Trainer: which all those agents are critical in nature, how much shadow AI is being run in the organization, how many those agents are processing my PII, or the confidential data, how I am going to establish the governance, right?

So that's why the establish... understanding the asset becomes important, right? The first category is the hardware assets, which are the physical resources, right? Your workstation, network devices. InfosecTrain Trainer: your peripherals. Also, you have some subsystems and the software assets. InfosecTrain Trainer: Right? Your SaaS solution, PaaS solutions. Then you have information assets, like data. InfosecTrain Trainer: You will have the data and all those things which you actually evaluate using the sensitivity labels. Then you will have a cloud-based assets, which are InfosecTrain Trainer: actually hosted in a cloud environment, then some virtual assets, which are virtually running. These are some of the categories of the assets. Sandeep Saxena: Oh, just a question. I'm getting confused. Sandeep Saxena: a risk assessment is done before... before the development of a Infosec program, right? Is it correct? InfosecTrain Trainer: Yes. Sandeep Saxena: And if risk assessment is done before this, then this asset identification and evaluation is already done before even starting the Infosec program. InfosecTrain Trainer: Yes, but Infosec program is a continuous process, right? It's not. InfosecTrain Trainer: do once in a pointed time. So, asset identification, valuation also, valuation also is a continuous process. If you get a new process, if you are creating something new in the organization, every time you have to follow the same step, right? InfosecTrain Trainer: like AI governance, you are establishing the AI governance program, how you will establish it without understanding the assets and all. So that's why it's a topic in this chapter. Just don't go by the process that we discussed first that, then we discussed it. It's just a topic here. Sandeep Saxena: Okay, okay.

subaveena pugalenthi: But I think it is better for us to understand under which category these topics fall, right? Like, because it's here and there to me. subaveena pugalenthi: like, we discuss something else, and then we switch to a different topic. There's not a flow that I could relate everything together. InfosecTrain Trainer: No, no, so this topic which I'm discussing, these are inaccurate flow. If you read the book. InfosecTrain Trainer: If you go and read the ISACA book, you will find these all topics coming in the same sequence. That's the same sequence I have followed here also. InfosecTrain Trainer: So, that's what I'm saying. There are a couple of topics which are kind of interrelated with each particular domain, and the second thing is that you need to understand what InfosecTrain Trainer: that particular topic means, or what that concept means, rather than just going with a step-by-step A, B, C, D, E, F, G, H. That A, B, C, D, E, F, G, H step, which I have already told you, those only gets followed in couple of topics, right? Everywhere, don't go by this step, that this is the first thing, that this is the second thing you will do. There is no sequence for each and every activity. InfosecTrain Trainer: You have to understand what is

happening in the environment, then you have to decide what is going to be the first thing I will do. Understood? subaveena pugalenthi: Okay. InfosecTrain Trainer: Like, even in the security, what you do in your organization, do you have some structured sequence which you follow? InfosecTrain Trainer: Is there an instructor? subaveena pugalenthi: Just sequence, but for me to understand where exactly under the information security program these all fall.

subaveena pugalenthi: Because we are discussing one topic, and... InfosecTrain Trainer: part of the gap assessment and understanding the current state, as part of that, you will do the asset classification, right? subaveena pugalenthi: Okay. Sandeep Saxena: You know, what happened is that, sometimes the questions are like, what is the first? First step, okay? Then I may get confused. For example, in the last question I have, there was the answer. Sandeep Saxena: like, what is the first step in development of Infosec Program, and there was an option, a risk assessment or something like that. Okay, so I thought, it's already done, it's a prerequisite, it's already done. Now I am building... InfosecTrain Trainer: I will show you all the strategy, right? In the last day I discussed. So, there are a couple of things which you have to think like ISACA. So, think like ISACA means any question the priority would be, first, assess. InfosecTrain Trainer: then developed. InfosecTrain Trainer: Remember this, you will get most of the question correct. So, in that question also, I told, if the assessment is there, so first you will assess, then you will develop or deploy, whatever is saying. InfosecTrain Trainer: So the... in any question in the exam, if there is an option as an assessment, so first you need to assess, understand the environment, then only you can develop. That's a simple thing. Sandeep Saxena: Okay. InfosecTrain Trainer: Understood, Sundar. Sandeep Saxena: Thanks. InfosecTrain Trainer: So, as part of that only, you are doing the asset discovery. InfosecTrain Trainer: So if we see, that diagram, which I showed you. InfosecTrain Trainer: this diagram. InfosecTrain Trainer: Right? So this diagram, if you see, the diagram is what?

Once you have the objective, you need to understand... do the gap assessment, right? So in the gap assessment, gap assessment is not only with respect to some framework, right? Gap assessment is a... InfosecTrain Trainer: is a kind of a wide range of activities. In the gap assessment, only you will understand what are the assets in your environment, right? What is their classification level? What do you have in the... that is what the gap assessment means, right? What do you have? InfosecTrain Trainer: So, what do you have is the asset, is one of those categories. Cut, Supa, and Sandeep? Sandeep Saxena: Yes, yes. InfosecTrain Trainer: So, once you understand what are the assets, those assets need to be categorized, right? So, the InfosecTrain Trainer: the assets, which are... there are two categories. One is the tangible, another one's the non-tangible, right? InfosecTrain Trainer: The tangible assets, you can have some value. Probably you can give some dollar value, replacement cost and all. But if something which is in the non-tangible form, how you are going to evaluate them, you have to evaluate them on the basis of the value InfosecTrain Trainer: what that particular asset gives to the business. That is going to be the value, right? So there are two things you would have heard about InfosecTrain Trainer: towards sensitivity. InfosecTrain Trainer: and criticality. Can someone tell me what is the major difference between sensitivity and the criticality? InfosecTrain Trainer: When you say this is very critical, when you say this is very sensitive, what does this mean? subaveena pugalenthi: In sensitivity, it's more about the data or information that we handle, like how we categorize it. subaveena pugalenthi: And criticality is identifying or prioritizing the processes.

Shweta Sundar: Sensitivity is related to personal information, and criticality is business. SrinivasanJ: Intangible or tangible. InfosecTrain Trainer: Sensitivity is whenever you see sensitivity, sensitivity is actually related to the person. InfosecTrain Trainer: your PII data, PHI data, or something like that, which is related to person sensitivity, and criticality means related to availability. InfosecTrain Trainer: The sensitivity, you can say, is related to confidentiality, and criticality represent the availability. InfosecTrain Trainer: So... you say, you say that this particular database is very critical in nature, it means InfosecTrain Trainer: If that is not available, how much impact it will cause to the business, to the process, right? And the sensitivity, we say that this particular thing is very sensitive in nature, it means if that information gets disclosed, how much confidentiality impact organization will have, clear? InfosecTrain Trainer: Remember, sensitivity is equal to confidentiality, criticality is equal to availability, so that you will be able to relate in all the scenarios, right? So, information sensitivity means, like the customer database, if you have any customer database with the payment information, how sensitivity that is. InfosecTrain Trainer: Also, you want to understand what is the operational dependencies of those activities, right? If this thing is not available, how much operational impact it will have to the next activity? That also you need to understand. InfosecTrain Trainer: So when you are doing the information classification, so during that, you need to understand these all things. First thing is the monetary value.

InfosecTrain Trainer: So, monetary value cannot be given to everything, like customer trust, Your, reputation loss. InfosecTrain Trainer: how you can give a monetary value to that, that how much mon... so monetary value only can be given to those assets which has a InfosecTrain Trainer: Which are tangible in nature, or have some value in books of account. InfosecTrain Trainer: plus... InfosecTrain Trainer: There is an alternate method where you say that if this is not available, how much business impact it is bringing in terms of money. InfosecTrain Trainer: That also monitoring value, as... InfosecTrain Trainer: an alternate method you can give, right? Next thing is the operational criticality we just discussed. How critical that system is for the operation if the information or asset is not available for a given period of time, how much impact it will do to the organization, like server images, incident response procedures, right? InfosecTrain Trainer: Next is the accuracy and integrity-related impact. So, if some information which is not highly accurate, it will have a huge amount of impact, like exchange rates. InfosecTrain Trainer: So the dollar to INR exchange rate, if you're transferring some money to someone, if that particular exchange rate is not getting reflected accurately in the system, probably bank will lose money if they have not updated. InfosecTrain Trainer: Right? Even inventory data. If you are ordering something from Amazon, and they accepted the order, but the inventory is not there with me, so it will have a customer trust impact. InfosecTrain Trainer: Right? InfosecTrain Trainer: Sensitivity is something which is related to confidentiality, means personal information.

Like, contact details, financial records, medical records, if those gets public, those gets disclosed, how much impact it will have, and the reputational value. InfosecTrain Trainer: So, all are these... InfosecTrain Trainer: Are the different, different factors which you have to consider when you are classifying the information. InfosecTrain Trainer: So when you talk about the data, or the information, so these are the labels... labels which you have to classify it, like public, confidential, restricted, and the secret, or some company InfosecTrain Trainer: In other places, you will also see the public internal... Confidential restricted. InfosecTrain Trainer: In the military, they say secret... InfosecTrain Trainer: top secret, likewise. So, it's not necessary that it's fixed, that you have to follow this only. InfosecTrain Trainer: So it gets changed with respect to organization, but you should understand that you should have a classification label, and each classification label should have a definition. What does restricted means in the organization? What does confidential means? InfosecTrain Trainer: And what does public mean? What does internal means? Who will have an access to that information? Who all with that information can be shared while designing the classification labels? InfosecTrain Trainer: Now... understanding the DLP and the data protection aspect of it. InfosecTrain Trainer: Right. InfosecTrain Trainer: What is the purpose of DLP? Someone tell me, what is the purpose of DLP? Why do you have a DLP in the organization? What does it do? Sandeep Saxena: Stopping the data export duration. InfosecTrain Trainer: Correct.

InfosecTrain Trainer: So data which is in transit, which is in motion, which is in... data which is kept in the system, the data exfiltration should not happen. That prevention the DLP will do. InfosecTrain Trainer: Right? So there are different stages, or the life cycle of data. So data at rest, data in transit, data in use. So these are the three stages of data in your organization, right? InfosecTrain Trainer: REST means something which is kept in a hard drive in the databases, is kept, or in your archive drives. InfosecTrain Trainer: Or probably you have a hard disk, pen drive, or anything. So that is called the data at rest. InfosecTrain Trainer: Data in transit when you are InfosecTrain Trainer: transferring the data. You are sending it via email, you are sending it via, any other means or channels, right? Any other communication, you are probably in a meeting and doing it something, right? That is a transit. Data in use when in live, you are using or utilizing the data, right? Currently. InfosecTrain Trainer: I'm presenting this particular slide to all of you. This is a data in use. InfosecTrain Trainer: Right? InfosecTrain Trainer: you people can capture the snapshot, you can take the picture of it, right? So, like, in some of the applications, if it's a banking application sensitivity, sensitive information, you try taking a screenshot from your mobile, it won't permit. InfosecTrain Trainer: So in data in use, also, you have some control. So, data at rest, what are the controls you have? You do the encrypt the data, right? InfosecTrain Trainer: You tokenize the sensitivity... sensitive fields, right?

InfosecTrain Trainer: you have an access controls and the audit login enabled, and you encrypt the backups and the key, you manage all the cryptographic keys, right? In transit, you have heard about the transport layer security, TLS 1.3, 1.2, InfosecTrain Trainer: as an encryption protocol, you use the VPN or the MTLS service, you use a secure file transfer protocol for transferring the data. Also, you manage the certificates. So when the data is in use, that time you do the confidential computing. InfosecTrain Trainer: You manage the documentation, you have an application-level controls, also you do the watermarking and masking, so that people cannot InfosecTrain Trainer: Take a snapshot, or even if they take a snapshot, that watermark also will get captured. InfosecTrain Trainer: So the DLP is not a specific topic in the... this particular domain. I am explaining it from the information perspective, right? InfosecTrain Trainer: You

may see DLP as a technology coming in some of the questions, right, so that you should have a high-level understanding what does DLP do? InfosecTrain Trainer: So, DLP also has a tie. One is called the network DLP, which InfosecTrain Trainer: inspect the traffic flowing in the organization, and it acts accordingly as per the policies. Endpoint DLP is something which is sitting on your endpoints. Suppose you are copying some information in a pen drive, in a hard drive, that DLP will detect. InfosecTrain Trainer: You also have a cloud DLP, or the CASB, which actually even protects the data and information disclosure from the SaaS. InfosecTrain Trainer: Right? Like something which is sitting in your web browser.

So in the web browser, if you're opening a chat GPT, you are uploading some organization data, that particular cloud DLP will pick it up and stop it. InfosecTrain Trainer: And the email DLP, whenever you are sending some information outside your organization, that email DLP will InfosecTrain Trainer: do that. But these days, all the DLP solutions offer you all the capabilities bundled up together. There are no separate, separate DLP. InfosecTrain Trainer: what DLP solution will cover all of those things. So, these days, the DLP solution, if you purchase, they will offer everything. InfosecTrain Trainer: But you have to... you have to actually configure the policies. So the way you configure the policies, then these things will come into the picture. InfosecTrain Trainer: Also, the DLP for the base of the DLP is the sensitivity label and the classification. InfosecTrain Trainer: So, in your organization, if you have not yet created a classification labels, you cannot deploy DLP. InfosecTrain Trainer: First, you should create a consistent classification labels, make sure people start using them, then you also check how many documents are not classified, you classify them, then you implement a DLP, then it will give you a better result. InfosecTrain Trainer: So that's why DLP will only work effectively if the data classification is accurately done. InfosecTrain Trainer: If you have probably given a confidential data classification label as internal, probably some... the employee would be able to send it to anyone. InfosecTrain Trainer: No? InfosecTrain Trainer: It's become important... yeah, Shweta, you have some question? Shweta Sundar: No, no, I'm good. InfosecTrain Trainer: Now, coming to the understanding the criticality and the impact.

We actually discussed about the BIA, right? InfosecTrain Trainer: So, when you have the information, you have that asset notified, you know InfosecTrain Trainer: Which all are the important assets, then you need to determine how critical those assets are, and how much impact those assets will have if those assets are not available to you. InfosecTrain Trainer: Right? So that's why you do a BIA, where we had a long discussion yesterday, right? On the BIA and risk assessment, what are the key differences, why we do the BIA, why we do the risk assessment, right? InfosecTrain Trainer: So, BIA is something which helps you determine the criticality and the importance of that particular process. If that particular process is not available, how much impact it will bring into the overall business? InfosecTrain Trainer: Right? Also, it determined the dependency of that process on other resources or other things, right? InfosecTrain Trainer: So the BIE result, is most of the time used in creating the BCP and the DRP planning, right? InfosecTrain Trainer: And what are the, what are the inputs while creating this particular BIA? So, input would be organization structure. InfosecTrain Trainer: Because you need to break the organization into different, different business units and vertical. What are the critical functions within those organization structure, and what is the risk impact of those particular business functions? We discussed this example yesterday, right? InfosecTrain Trainer: So you, your corporate organization is divided into different, different line of business.

InfosecTrain Trainer: under those line of business, what are the important and the critical functions, and those functions have which all critical processes, and are there any dependencies between these processes? Suppose this database is being used InfosecTrain Trainer: for a couple of other processes, so this becomes a very critical. InfosecTrain Trainer: So that's why understanding the criticality and impact becomes an essential. Once you have that, then you create a prioritized list that first we will recover this, then you will recover this, then we'll recover this, then we'll recover this, and then you create a BCP and DRP plan accordingly. InfosecTrain Trainer: That's why I shared one BCP TRP video yesterday, right? InfosecTrain Trainer: This is a... yeah. So this case study is very important. InfosecTrain Trainer: So you people have a lot of issues, and then probably a lot of key gaps, a lot of confusion you get with couple of topics. This is also, let me be clear, this is not a sequence. InfosecTrain Trainer: This case study is just telling you what is actually the significance of each of these InfosecTrain Trainer: key topics which we discussed so far, right? We will discuss about gap assessment, BIE risk assessment, asset classification, and information security program. InfosecTrain Trainer: This is not a sequence. InfosecTrain Trainer: So, let's begin the case study. So, there is a company named InfoVision, which is a fintech company. InfosecTrain Trainer: That handles a vast amount of sensitive financial data, and the company aims to enhance the information security posture to safeguard data and ensure the regulatory compliance. InfosecTrain Trainer: So what they did, they first... you actually, you have to establish a security program.

To do that, you need to do a gap assessment. So I did a gap assessment. InfosecTrain Trainer: What is an objective? What I want to achieve out of gap assessment? I want to identify the key gaps in the data encryption, access control, incident response. Also, I want to identify the gaps in current information security portion. This is the objective of the gap assessment, what I'm doing for the InfoVision. InfosecTrain Trainer: What are the action? InfosecTrain Trainer: you evaluate its existing information security control policies against the industry best practices and the regulatory environment. Suppose you picked up the NIST or ISO. InfosecTrain Trainer: And against it, you are doing it. InfosecTrain Trainer: outcome would be, you identify the gaps in the data encryption, asset control, and the incident response. You have a list of all the gaps. InfosecTrain Trainer: now? InfosecTrain Trainer: You will also want... you want to establish a priority. What is the priority? Where you want to focus? InfosecTrain Trainer: So, you will do a gap business impact analysis. So, objective of business impact analysis to understand the potential impact of information security incident on the business. If there is an information security incident, what is going to be impact? InfosecTrain Trainer: So, action is you analyze the critical business processes and data, you assess the potential impact of their disruption on financial, operational, and the reputational aspects. InfosecTrain Trainer: An outcome of this particular activity is pre... you've got to prioritize critical assets and processes for focus, protection, and the recovery planning. InfosecTrain Trainer: See?

InfosecTrain Trainer: It's not only BIA result is only used for the recovery, it can be used for some other purpose also, right? InfosecTrain Trainer: So, BIA is just an activity which produce a result of the priority setting that can be used for other purpose also, right? Then risk assessment InfosecTrain Trainer: you are doing in the InfoVision. So, objective of risk assessment is to evaluate the risk. InfosecTrain Trainer: to the confidentiality, integrity, and availability of information. Action, what you are taking, you identify the threats, vulnerabilities, you want to assess their likelihood and the potential impact on the critical assets and the processes. InfosecTrain Trainer: And the outcome here is that you develop a risk management strategy to address those risks. InfosecTrain Trainer: Now, you did an asset classification, so objective is to categorize the assets based on sensitivity and importance to the business. InfosecTrain Trainer: Action is you classify the data system into categories, assign appropriate security control to each category. Outcome is ensure the targeted protection of the asset is given... is being provided on the basis of the classification labels. InfosecTrain Trainer: And the program, then, after all this activity, you are creating a program. So, objective is to establish a structured approach to manage the security in the organization. InfosecTrain Trainer: Action, you develop an information security program, incorporating policies, procedures, controls to safeguard assets and ensure regulatory compliance and outcome is InfosecTrain Trainer: Providing a systematic approach to managing information security, ensuring alignment with organization objectives and the regulatory methods. InfosecTrain Trainer: All clear on this.

Anyone has any doubts? InfosecTrain Trainer: Yes, Shweta. Shweta Sundar: So here, all the previous step gap analysis, BIA, risk assessment, and asset classification, these are all input for the security program. That's how we have to consider this flow. Shweta Sundar: I mean, irrespective of the sequence, they are just the input. InfosecTrain Trainer: Yeah, they are producing some outcome. You see, all of these are producing some outcome, and that outcome can be used for the next process. Got it? Shweta Sundar: No, I'm trying to just clarify, this is not a sequential representation, right? InfosecTrain Trainer: No, no, this is not a sequential. Shweta Sundar: Okay. InfosecTrain Trainer: Alright, let's discuss some questions. InfosecTrain Trainer: Alright, let's discuss the correct answer, sorry. InfosecTrain Trainer: Fourth one, I saw a couple of you went with option A. Okay, let's discuss. InfosecTrain Trainer: An organization has invested significantly in its information security program. What is the most impactful outcome demonstrating its effectiveness to the board beyond MERC compliance, right? A quantifiable reduction in the business risk, enabling strategic opportunities looks a good option. InfosecTrain Trainer: zero reported security incident in the last fiscal year. You want to achieve it, but this is not only InfosecTrain Trainer: the purpose you want, right? It's not only related to incident, you also want to... InfosecTrain Trainer: focus on other strategic initiatives, also, what organization has. Full automation of security tasks, that also you want to achieve, but depends on what are the strategic opportunities you have. High employee satisfaction score with security awareness training, this is also one part of the security program, right?

InfosecTrain Trainer: So this option is something which covering all of them. InfosecTrain Trainer: When establishing a new information security program, the CISO must first understand available organizational resources. What is the main reason for conducting a thorough inventory and assessment of these

resources? InfosecTrain Trainer: To identify all existing security vulnerabilities, okay, to determine the budget required for new security tool, to align program capability with existing strength and identify gaps in the personal technology and processes, to prepare upcoming regulatory compliance audit. InfosecTrain Trainer: So, when you create an inventory, So, inventory will be used InfosecTrain Trainer: to identify vulnerability also, but not the main cause. Inventory will also be used to determine the budget also, how much you want to spend in maintaining and those things, but not the important one. InfosecTrain Trainer: However, the main importance of inventory from a program perspective is that you want to understand what is the current issues you have in the current process, in the personal technology and the process side, right? So this is the correct answer. InfosecTrain Trainer: Which of the following is the first action to be taken when the information security InfosecTrain Trainer: Manager notes that the control for the critical applications are inadequate. InfosecTrain Trainer: perform a risk assessment to determine the level of exposure. Looks good. Classify the risk as acceptable to senior management. Can you classify risk as an acceptable without understanding the risk? You cannot. InfosecTrain Trainer: Deploy additional countermeasures immediately, that also you cannot do without understanding the risk.

Transfer the remaining risk to another enterprise, that also you cannot do without understanding A. InfosecTrain Trainer: So, A is the correct answer. InfosecTrain Trainer: Which of the following item is the best basis for determining the value of intangible assets? InfosecTrain Trainer: There is one PII data. InfosecTrain Trainer: You want to determine the value of this particular data. InfosecTrain Trainer: How come you can determine the value through BIA? InfosecTrain Trainer: Tell me, someone, explain me. All those people who went with the BIE as an answer, how BIE will tell you the value of the data. That value of data is going to be input InfosecTrain Trainer: while creating a BIA. InfosecTrain Trainer: BIA will only tell you that this data is how important for the organization, if it is not available, how we are supposed to restore it. InfosecTrain Trainer: It's... it's saying a simple thing that how you determine the value of intangible assets. Intangible assets means data, which is not tangible in nature. The best method is what? How much that asset is contributing to the revenue generation. InfosecTrain Trainer: That will determine the value. Simple thing. InfosecTrain Trainer: Replacement cost, if it would have been a tangible asset, then the replacement cost would have been options or eliminated. Threat assessment is, as such, out of context from here, and the BIA is something which is there to confuse you all. BIA is not what it's asking for, so correct answer here is D. Shweta Sundar: But, from... it's an intangible asset, right? So... Shweta Sundar: more relatable to, say, a reputational damage, or, you know, something in fact, how... how can, Shweta Sundar: How can you measure the reputation?

I mean, how will the reputation contribute to the revenue generation, then? InfosecTrain Trainer: Does reputation as an asset? Shweta Sundar: The, the asset can cause an intangible... InfosecTrain Trainer: about the asset, right? Does a reputation as an asset for you? InfosecTrain Trainer: Tell me. InfosecTrain Trainer: Is... does it sit in your asset inventory? Shweta Sundar: No, no, so what I'm trying to tell you is, intangible means something that you cannot measure. InfosecTrain Trainer: Something which is intangible means what? Tangible, intangible means what? Something which is virtually present, which is not physically located, right? So what is intangible asset? Probably your database, your data or information which you have, your patent information. We discussed in detail, right? InfosecTrain Trainer: patent data, your proprietary record, and those kind of things. Your recipes, those are all the intangible assets, correct? Shweta Sundar: Okay, but InfosecTrain Trainer: It's. Shweta Sundar: B? InfosecTrain Trainer: Simply saying the asset. What is an asset for you? Asset is something InfosecTrain Trainer: which you can say that this particular is an asset. Asset is your PII information can be an asset for you. The patent information can be asset for you, right? Any proprietary code is an asset for you. Even the proprietary code which you say, like, Microsoft InfosecTrain Trainer: OS proprietary code, is this a tangible asset or intangible asset for them? InfosecTrain Trainer: Intangible asset, right? Shweta Sundar: Yeah, great. InfosecTrain Trainer: That's what the question is asking. That's what I'm saying. You probably got confused, you took the example of, so whenever I'm saying asset.

InfosecTrain Trainer: Asset is something which is an asset for your organization, not reputation and the... InfosecTrain Trainer: customer satisfaction and all. That, I just gave an example, that those things cannot be measured in form of the money or value. But the intangible asset also I mentioned, right, can be measured in term of value, that how much contribution it is giving to the revenue generation, right? InfosecTrain Trainer: Got it? Got Shweta? And everyone? Shweta Sundar: Okay, yeah, thank you. InfosecTrain Trainer: Now, understanding the security architecture. Anyone here who is architecture? Architect. InfosecTrain Trainer: Or has worked in a security architecture. InfosecTrain Trainer: So, the new syllabus, which is getting changed. InfosecTrain Trainer: There, in this particular... the old pattern, we only have a limited topic, one small topic around architecture, but the new syllabus, which is getting revised, which will come into the force in the November, there they have a very specific topic around architecture, where they will InfosecTrain Trainer: probably introduce more number of topics around it, I'm not sure, or probably may introduce or talk about other specific architecture-related frameworks and all in detail, but currently, we will discuss whatever this particular thing has, but still. InfosecTrain Trainer: I have added a couple of more information to previously what I used to cover, so that I cover some part of architecture to all of you. InfosecTrain Trainer: Let's go with a very simple example, right? InfosecTrain Trainer: What is an architecture? Architecture is something which is a blueprint to design, security. InfosecTrain Trainer: design your organization assets, how they'll be placed, where they'll be placed, right? Everything, right?

Don't go by architecture, don't restrict architecture only specific to one particular application, like. InfosecTrain Trainer: You are designing something in a cloud, you just created architecture, no. I'm talking about the in... InfosecTrain Trainer: Enterprise Information Security Architecture, which is a big thing. InfosecTrain Trainer: Which you cannot probably design in one particular paper, right? So many inputs, so many things. So this is something which is going to be at very high level, which you will design, right? InfosecTrain Trainer: So let's take a very simple example. I think all of you would have seen a castle. InfosecTrain Trainer: Old castle, Old Fords. InfosecTrain Trainer: Right? You would have seen the old forts, right? How they used to design security, How do you stood... InfosecTrain Trainer: architect the security around these old forts. If you go visit. InfosecTrain Trainer: they used to first has a layer difference in layer, right? They used to first create one trench. InfosecTrain Trainer: This is first layer. InfosecTrain Trainer: That trench itself would be so deep, probably 15 feet deep. InfosecTrain Trainer: Which no one can climb. InfosecTrain Trainer: It's very difficult, right? InfosecTrain Trainer: Then, they used to fill the trench with the water. InfosecTrain Trainer: now it becomes much more complex for you, right? And in that water, they will keep some alligators, poisonous snakes, and all. Now, there is only one way in and out. InfosecTrain Trainer: So this particular bridge is retractable. You retract the bridge when you want to go out. You, again. InfosecTrain Trainer: Pull it back, pull it back. InfosecTrain Trainer: So this is one layer.

Apart from that, even if someone is able to cross this, then they will have snipers, or the arrows, and all those people deployed from atop, so that they can easily look at the enemy who's getting inside, and they can target. InfosecTrain Trainer: Right? InfosecTrain Trainer: Then, inside the castle also, even if you're able to breach a main gate, inside this also, they will design room by room, room by room, right? Now, replace this castle with your enterprise. You are designing the security for enterprise. InfosecTrain Trainer: So, you will design it in a layer, right? You will first design your network parameter. InfosecTrain Trainer: is this going to be in on-prem, or is this going to be in cloud, right? How that on-prem component will interact with the cloud? Do we have a virtual InfosecTrain Trainer: assets or the people, are they connecting virtually? So, when they connect from home, how they will approach our parameter? InfosecTrain Trainer: If they connect from, our company network, how they will approach. If you have any distant, probably, factories or some other locations, how they will connect, then within that. InfosecTrain Trainer: How the information will be encrypted? InfosecTrain Trainer: how the access will be managed, how the endpoints will be secured, so you see so many things are involved, right? So, architecture, if you see. InfosecTrain Trainer: It is so many things which are involved. So, enterprise architecture is both business function and technical model that ensure the IT systems meet the business needs. InfosecTrain Trainer: Right? InfosecTrain Trainer: So, in all the organizations, they have two separate functions. They have one... some function called the Enterprise Architect. InfosecTrain Trainer: and then they have a security architect.

You will see the two distinct roles sitting in the organization. So, enterprise architect looks holistically around all the organization. InfosecTrain Trainer: How, if you are purchasing a new SaaS solution? InfosecTrain Trainer: Is that SaaS solution can easily be integrated within your organization? InfosecTrain Trainer: Parameter or network, or it cannot. InfosecTrain Trainer: Right? So that enterprise architect will help you. InfosecTrain Trainer: decide. InfosecTrain Trainer: Then, information security architecture is a subset of EA which focuses on protective characteristics and specific components that provide preventative and the detective security functions. InfosecTrain Trainer: So, within this enterprise architect, you will have a security architect function, right? And this is an strategic framework. It's a framework, actually. InfosecTrain Trainer: That helps organizations, security control, policies, technologies, all of them working together, protect InfosecTrain Trainer: So that holistic protection can be provided. Like, in my organization, we mandate if any application or a SaaS solution business is procuring, it's mandatory they should have a SSO enabled. InfosecTrain Trainer: if... InfosecTrain Trainer: We cannot have an SSO enabled. We give them concession, we say, okay, at least maintain a 12-character password with MFA, InfosecTrain Trainer: Is the minimum requirement. InfosecTrain Trainer: But that, also, we say if the number of users is more than 10, we mandate them to InfosecTrain Trainer: create a tech stack, and enable the SSO for us.

So, likewise, so whenever... likewise, you have to create an architecture, so that if something is coming, like, if some sensitive... some sensitive application is being onboarded, we also mandate them that they should have a security logs InfosecTrain Trainer: Which should be... integratable with our SIEM solution. InfosecTrain Trainer: So, all these things your architecture will only enable to check, right? So, architecture is something which will provide the basis for identifying and managing all important and critical threats, also helps you improve the safety and security of the organization. InfosecTrain Trainer: So, what are the objectives which you achieve by having an architecture? First thing, it will establish you the structure. InfosecTrain Trainer: You got a structure. InfosecTrain Trainer: like... like, we discussed the example of that castle, right? So, there is a structure already there in a castle. So in... within the castle, if a new building, new tower or something new is getting created or constructed, they will make sure it should support the existing architecture which they created. InfosecTrain Trainer: It also helps you create a roadmap. InfosecTrain Trainer: Right? So once you have an architecture in place, it will help you understand what are the things you want InfosecTrain Trainer: Or things you can do in that environment, right? InfosecTrain Trainer: So, if I say the SSO is mandatory as per the architecture, it means that you will only look for those applications, those solutions which support that. InfosecTrain Trainer: If you establish any SISEM solution, you will make sure only you are onboarding those critical applications which support integration with your CISM solution.

InfosecTrain Trainer: Also, it helps you achieve the alignment with respect to your policies, regulations, framework, and help you enable the strategy, right? So your security business strategy, which you want to achieve, that architecture will support, and help you implement the security. InfosecTrain Trainer: And established a common language. InfosecTrain Trainer: So, common language across organization, what you want to achieve, that architecture will do. So, architecture is something which will InfosecTrain Trainer: Bridge... A gap between the domain 1 and the domain 3. InfosecTrain Trainer: So, Domain 1 is something which helps you create the strategy, policies, and governance. How those policies and strategy will get translated into the security, that architecture will help you create that. InfosecTrain Trainer: Now, what is the significance of having an architecture? InfosecTrain Trainer: It solves the business purpose. InfosecTrain Trainer: what are the business needs, what business want to achieve, that you can solve using an architecture? For example. InfosecTrain Trainer: your architecture says that SSO is mandatory, but still there is a concession. You say business still want to use it. You say, okay, you just change the policy, password policy to minimum 12 characters. With MFA, we'll let you use it. InfosecTrain Trainer: If, suppose... and then the classic example is before and after COVID. So, before COVID, a lot of organizations, they did not have an infrastructure to support remote work.

InfosecTrain Trainer: So all of the people, those who were probably every day going to office, there were still a couple of companies, those who were InfosecTrain Trainer: offering people to connect from home through VPN and all, but a lot of companies, they did not invest in VPN. But as soon as the COVID came into the picture, they have to change in the existing architecture, right? They... all the procured the VPNs, they let their employees work from home. InfosecTrain Trainer: Also, the architecture helps you integrate other components. Suppose you are bringing in new AI capabilities, new SaaS solutions, you are building, integrating any EDR solution, you are getting any XDR solution, everything what you get InfosecTrain Trainer: new capabilities in the environment, how it will come and get integrated with all. Because if you do something, definitely it will have an impact on the existing process, right? InfosecTrain Trainer: probably something is getting blocked because of which the information won't be able to bypass, right? So those component integration the architecture enables also help you achieve structural consistencies, right? You have a resource efficiency. InfosecTrain Trainer: So, all the infrastructure resources, all the resources, what you have in your environment, you will be able to InfosecTrain Trainer: Use them efficiently, Brings scalability and flexibility. InfosecTrain Trainer: If you want to scale up, scale down, your architecture should be designed in such a manner so that it should be flexible enough InfosecTrain Trainer: to integrate and support other kind of integration, also upgradeability.

If tomorrow you want to do a digital transformation, move out of current tech stack to some new modernized tech stack, it should support it, and should be able to extend. InfosecTrain Trainer: So, business value... what is the business value in the architecture? It helps you reduce the long-term cost of ownership, enable the audit compliance and assurance, improves the incident response readiness, supports merger and acquisition, which is very common these days, right? Organization is... InfosecTrain Trainer: procuring any new organization, and then that thing is getting merged, or you are selling some of your entity to some other organization. So, in that, the architecture will help you also bridge strategy with the operation. InfosecTrain Trainer: So, be clear, architecture is not a product. InfosecTrain Trainer: Right? Architecture is not a product. Architecture is not something you created in some... InfosecTrain Trainer: a PDF document, the 10-page document which you created, where you have a network architecture, application architecture, everything is there. You say, my organization architecture is ready, no. That's why you have a separate function, separate people, team of people working all together. So architecture is a blueprint InfosecTrain Trainer: How organization will enable all the things, how things gets... comes and gets merged together, that blueprint, the architecture serves. InfosecTrain Trainer: Right? InfosecTrain Trainer: And from exam perspective, always understand one thing. InfosecTrain Trainer: Business objectives always takes precedent, not technology. InfosecTrain Trainer: what business want to achieve, that first you will see, technology is a secondary thing, right? All of you clear on the architecture?

InfosecTrain Trainer: What does architecture mean? Sandeep Saxena: Well, I don't understand what you mean by information security architecture. Sandeep Saxena: I mean, are you referring to the architecture reviews happen when someone wants to do something new? Is that architecture review you are referring to, or a framework the architects refer to while doing the architecture review, or something else? InfosecTrain Trainer: It's about the framework. InfosecTrain Trainer: That's what I say, the strategic blueprint. So your organization would have created a strategic blueprint, right? What kind of technologies you will allow to enable in organization parameter? InfosecTrain Trainer: What of this... what kind of the solutions you will make them enabled, right? So that's why all the things which you do, right? You have a BYOD. InfosecTrain Trainer: bring your own device policy, right? Suppose some contractor, you are hiring some contractor for some project, you don't want to issue them your own laptop, you have a BYOD policy. InfosecTrain Trainer: That is one of the part of the overall architecture. You say, if BYOD we are allowing, we are enabling access to our organization from some distant laptop, we make sure these are the things which should get installed there. InfosecTrain Trainer: This is also coming from the architecture. InfosecTrain Trainer: Correct, Sandeep? Sandeep Saxena: Actually, for example, BYOD is a policy, okay? Sandeep Saxena: what this information security architecture is all about. What does it, you know, contain? Sandeep Saxena: Is it a single document, or... It's a framework. InfosecTrain Trainer: It's a framework. InfosecTrain Trainer: It's not a single document, it's a framework which you have created in the organization.

How in the organization, the security will work all together? How... InfosecTrain Trainer: how the tools will get deployed, how the information would be shared, which all places you will enable the VPN, which all places you will have an EDR sitting, all those things coming all together. Your overall security program is designed around architecture. InfosecTrain Trainer: Got it. Sandeep Saxena: Maybe not today, but if I can have a realistic example of that, that will help. Maybe next time, in the next session. InfosecTrain Trainer: Okay, okay, let me, let me give you one example on this, right? Sandeep Saxena: Whoa. InfosecTrain Trainer: Let's take... a basic thing. Let's say you are InfosecTrain Trainer: Establishing, there is a new, probably, organization who is establishing the security InfosecTrain Trainer: In their organization, right? They have recently... there is a new startup. They want to now expand their infrastructure and everything, so they are establishing the organization, right? InfosecTrain Trainer: Establishing the security in the organization, right? So the, so the CISO created a security strategy, Right? InfosecTrain Trainer: Now, to implement this strategy, he have created... done the gap assessment, he identified a couple of gaps, couple of things. He said, okay, okay, we need to implement InfosecTrain Trainer: EDR, we should have an DLP, we should have... we should have an antivirus on endpoint, we should have a VPN connections, we also have a cloud InfosecTrain Trainer: where people are hosting the asset. We also have an on-prem InfosecTrain Trainer: component to it, right? So, all these things all together, your endpoints, Your data... endpoints, your data, your people. InfosecTrain Trainer: your process.

InfosecTrain Trainer: your technology, how all of them together would connect, integrate, and work together, that's what the architecture does. InfosecTrain Trainer: Understood, Sandeep. It's a framework, it's a conceptual model. It's not a written model which is there in a document which you will just follow. That's why if you go and interact with your security architect or enterprise architect, they don't have a specific InfosecTrain Trainer: framework or a model, they are the people, they are expert on multiple platforms. They know cloud also, they know endpoint technology also, they understand databases also, they have understanding around AI also, they have understanding around networks also. So that's why you hire an architect, is someone who knows holistically all those things together, so that if you are building something in you, you are bringing in something new. InfosecTrain Trainer: They understand holistically everything, and then they enable it. Understood. InfosecTrain Trainer: Sandeep? Sandeep Saxena: To be honest, I will research more on that. What I have seen is that, for example, someone is building a web application, okay? Then they will come to the architecture team to do the architecting. We are really part of that, so we do how the application will be deployed, whether it is aligned with some of our roads, some of our frameworks. Sandeep Saxena: If someone is bringing in some AI solution, that will go to Sandeep Saxena: another team who are expert for AI, for example, nowadays, who are expert in their domain. But it's not like

we are... we are having information security architecture, and everything has to be fit in, within that. This is something I have never seen.

InfosecTrain Trainer: That's what, that's what ISACA, that's what NIST and all the top regulation says. It should be the ideal case. InfosecTrain Trainer: Residency, probably organization might not be following, but this should be the ideal case. Should be there. InfosecTrain Trainer: So even the architect team, the one whom you share that particular architecture diagram, do they only check how securely that application is created, or they will also check how that application will come and gets deployed within our organizational infrastructure? That also they check, right? Sandeep Saxena: Great. InfosecTrain Trainer: So that integration this architecture will enable. InfosecTrain Trainer: Got it? InfosecTrain Trainer: So, one thing is the architecture of one particular application, another thing is that application, once gets deployed within the organization parameter, how it will interact with all the things which are there altogether, right? So those things are architectural. So, architecture is not... InfosecTrain Trainer: a kind of a specific document, or a specific guideline which you have, you just read, you follow. It's a blueprint. InfosecTrain Trainer: And there are two categories to it. One thing is called the reference architecture, another one is called the solution architecture. This will make things even more clear, right? InfosecTrain Trainer: So the reference architecture is equivalent to a generic framework. InfosecTrain Trainer: Which is a reference. InfosecTrain Trainer: which is not very specific in nature, like a framework, list framework. InfosecTrain Trainer: NIST is a reference material, right? Similarly, in the architecture, also, you have a reference. So you use that reference architecture to... like, zero trust.

You say the Zero Trust I want to establish. Does Zero Trust has a defined criteria or a defined thing that this is the process you follow to achieve a zero trust? InfosecTrain Trainer: There is no, right? You say that I want to achieve cloud security. InfosecTrain Trainer: So, is there a defined steps what you have? So, those steps also you can tailor as per your organization need, right? InfosecTrain Trainer: you may not... may or may not have a CASB in between. You can follow some other approach, right? So that's... the reference architecture is something which is a framework which you will use, which you will tailor. InfosecTrain Trainer: Right? So this is an abstract, technology-agnostic template application applicable all across the platform, all across the organization, right? InfosecTrain Trainer: It can be reused across multiple projects, multiple business units, right? Like cloud security reference architecture, IAM reference architecture, zero trust reference architecture, right? It helps you measure the consistency and reduce the rework. InfosecTrain Trainer: Now, the solution architecture is what, Sandeep, you were referring to. InfosecTrain Trainer: So whenever you take any application or anything to those architecture teams, they are the solution architect. InfosecTrain Trainer: So they use this reference architecture, and then they see that how that application is secure with respect to that reference. InfosecTrain Trainer: So this is very specific to a specific business problem, right? If an application is designed for on-prem, or if application is designed for cloud, the architecture would differ. InfosecTrain Trainer: Right. InfosecTrain Trainer: If you are designing a cloud-native application, the architecture would be different.

If you're designing an on-prem application, the architecture would be different, right? So that's how it happens. InfosecTrain Trainer: And it will also include all the technological choices, vendor configuration, and always owned by the project and the solution architect. Example is InfosecTrain Trainer: How you onboard a SaaS application in your environment, right? How you roll out the DLP in the organization. InfosecTrain Trainer: So, the reference architecture informs solution architecture. Solution architecture informs the implementation, and this is a reusable pattern which you can customize in the organization context. InfosecTrain Trainer: Got it, Sandeep? Sandeep Saxena: Kind of. So, reference architecture, I was also referring to, that, if something is new, we can refer to an architecture, for example, cloud security or zero trust or something, and based on that, the solution architecture, is something, security architecture review, you may say. InfosecTrain Trainer: Which is specific to your organization environment. Sandeep Saxena: No, it's about, 3 or 4 organizations I have worked with. Sandeep Saxena: So after reference architecture, it goes to the security architect for the architecture review. So it's not solution architecture, they are only focused with the security goods and bads of that, like DLP rollout design, so they will tell you the, what's the, what's the ideal, security, architecture for that. The solution architecture is something, I think. Sandeep Saxena: may not be fitting in here, but it's okay, I can also go back and share, you know, kind of research. But... Sandeep Saxena: Reference architecture is used by a security architect to gaze upon the goods and bads of the proposed... proposed architecture.

InfosecTrain Trainer: So, using that, what the security architecture team is recommended. InfosecTrain Trainer: On the basis of reference architecture, that becomes a solution architecture. Sandeep Saxena: Right, solution architecture, okay, that becomes a solution architecture, in the sense, yeah, okay, okay. InfosecTrain Trainer: How that solution would be designed in your. Sandeep Saxena: Cool. InfosecTrain Trainer: environment. Got it? Sandeep Saxena: Huh, okay, okay. Manoj Kamble: So, I have a doubt, actually. So, can we call reference architecture as an enterprise architecture? InfosecTrain Trainer: No, no, no, reference architecture is not an enterprise architecture. Reference architecture is something which is created like a framework, NIST. InfosecTrain Trainer: Has created a framework, or cloud. InfosecTrain Trainer: Security Alliance has created a framework, which is a reference material which you will use, which is generic in nature. That is the reference architecture. InfosecTrain Trainer: On the basis of that reference architecture, when you are designing something for your organization environment, then you will do the solution architecture. For that solution, you will pick up a couple of things from there, and then you will tailor as per your InfosecTrain Trainer: Got it? Manoj Kamble: Yeah, I understand the solution architecture, but I had a doubt, like, the reference architecture is not considered in terms of business perspective. InfosecTrain Trainer: So this, I am talking from a security perspective. I'm not talking from the enterprise architecture perspective. Here, I'm discussing the reference architecture and solution architecture from a cybersecurity perspective, right? You're getting confused between the cybersecurity and the enterprise.

Manoj Kamble: No. Means, like, in our organization, we have solution architecture and enterprise architecture. Manoj Kamble: So, solution architecture are part of enterprise architecture team as well, whereas solution architectures are, like, mainly, dedicated to the domains, like network domain, security domain, the different domains follows. Whereas these solution architectures will Manoj Kamble: Meet with the enterprise architectures, and take the recommendations from them, and we... they implement those recommendations. Manoj Kamble: to implementing these solutions. That's how it works, actually. Means, like, you can correct me if I'm wrong. InfosecTrain Trainer: So, it depends from organization to organization, but generally, it works like the same like you're explaining. So, like we discussed about the Enterprise Risk Management Program, right? Similarly, is there the architecture program in the organization? So, there is a team called the Enterprise Architect. InfosecTrain Trainer: Right? So, under Enterprise Architecture Team, they will define that how the Enterprise Architecture Program will look like. InfosecTrain Trainer: What are the things, what are the components, what are the policies, what are the guidelines you will follow. So every organization will use those reference architecture and create your organization environment. They will create one architecture for them. That becomes a reference architecture. InfosecTrain Trainer: which is a reference architecture for your organization, and then enterprise architecture team InfosecTrain Trainer: will tell all the solution architects. So, there is a solution architect sitting within the security team.

InfosecTrain Trainer: There is a solution architect sitting within the cloud team, solution architect within... sitting within the ML and AI team, security architect within... sitting within the network team. InfosecTrain Trainer: So all of them will follow the enterprise architecture framework, and then when they are creating the respective architecture diagram, they will follow that framework and then implement. Got it? InfosecTrain Trainer: I think that's what you are talking about, right, Manoj? Manoj Kamble: Yeah, yeah, correct, yeah. Manoj Kamble: Thank you. subaveena pugalenthi: I understand the solution architecture, but not the reference architecture. Like, you mentioned it's kind of framework, but I'm not able to relate, like. InfosecTrain Trainer: It's basically reference material. InfosecTrain Trainer: So you go to Google, you say, I want to design an application in the cloud. InfosecTrain Trainer: It will give you a reference architecture, right? InfosecTrain Trainer: So Microsoft, you want to... I want to create a cloud-hosted application in a Microsoft environment. Microsoft will give you one reference architecture, that this is how you can design, right? But is it necessary you will follow the same thing what Microsoft is telling you? No, right? You will tailor it as per your need. InfosecTrain Trainer: So you will solutionize it as per your need, you will say, okay, this thing is not needed for me, I want to add some couple of more layer of security to this, and then you'll create a solution architect. Got, Suba? subaveena pugalenthi: Not really. So, solution architecture is a SME, in my knowledge, because when you say under enterprise architecture, there are different business units, like ML, cloud, network, and different things.

They are SMEs, and they would design their subaveena pugalenthi: solution, and, like, It's them that configures that, right? So, do you mean that they use some references? subaveena pugalenthi: And that is what is reference architecture. InfosecTrain Trainer: without reference, how they will also create, right? They need some reference, right? InfosecTrain Trainer: So if I am... I am doing an audit, if you want... you... you are supposed doing an audit of something, you need some reference, right? With respect to some reference only, you will audit that, right? Similarly, in the architecture, when I'm creating an architecture, so suppose in my organization, I want to establish the zero trust. InfosecTrain Trainer: Right? So there is a zero-trust reference architecture which is available. You can Google it, it will give you some list of things that... InfosecTrain Trainer: this should be there, this should be there, this should be there, these things should be enabled, this should be there, all those N number of things that zero test reference architecture will give you, but is it necessary you implement all

100% of those things in your environment? No, right? You can tailor it. You say, in my environment, probably I'm only sitting on on-prem environment. I'm not even on cloud. InfosecTrain Trainer: Or suppose some organization is completely on cloud. InfosecTrain Trainer: Some organization is having 100% people working remotely. InfosecTrain Trainer: Some organization is giving laptops to their employees, which is configured by organization. They are not letting them use bring your own device. InfosecTrain Trainer: So it depends from org to org what kind of things, systems, solutions, items you are using, then you will tailor as per your organization needs.

That tailoring will be a solution architecture. subaveena pugalenthi: But wouldn't that be messy if every business function uses a reference architecture from Google, and if they implement their own architecture? Like, how is it gonna integrate with the enterprise architecture? InfosecTrain Trainer: No, no, this is... I just gave you an example. I'm not saying that they are taking it Google. You have to create in your own organization. You have to create... like, you are creating the policy InfosecTrain Trainer: Right? You are creating the policies, you are creating the guideline for your organization. Similarly, you have to create this reference architecture and all those things in your organization also. You will see that InfosecTrain Trainer: looking at your organization environment, you will create, you will say that these are the things which organization will follow, and that the people will use. I was just giving you example to make you understand. subaveena pugalenthi: Define a reference architecture for the enterprise. InfosecTrain Trainer: Yes, that need to be defined and created. subaveena pugalenthi: Yeah, like, who? InfosecTrain Trainer: The enterprise architecture team. subaveena pugalenthi: So, would they create it for each business function, and the business... Follow the reference. InfosecTrain Trainer: Correct. Sandeep Saxena: So, for an example, what happens is that if someone is deploying a new application on cloud, maybe, okay? So, what we decided is that we will be using AWS well-architected framework that we decided that we'll use for doing the architecture review to Sandeep Saxena: to establish a uniformity, otherwise there are four architects. Everyone may talk in a different language.

So, AWS, well-architected framework says, like, for example, you should be having a three-tier architecture, you should be enabling the logging. So, all the architects will follow the rules, okay? Sandeep Saxena: So, this is the base, this is the reference architecture, AWS well-structured... well-architected framework. Sandeep Saxena: We, we, we used. Sandeep Saxena: But this is not in alignment with, enterprise architecture, because this well-architected framework of AWS, it's not in the enterprise architecture. It's security team's reference material, right? Sandeep Saxena: And only security team can tell about that, and enterprise architecture cannot guide the security team that you should be using the AWS well architecture framework. We'll decide that, right? InfosecTrain Trainer: So, enterprise architecture team will create a high-level strategy and high-level InfosecTrain Trainer: information, which every... gets applicable. Then, all the SMEs and all the respective teams, like, there is a cloud team, there is an AI ML team, there is a security team, then they will follow that overall organization strategy, and they'll create it. It's... don't just InfosecTrain Trainer: Fix on the architecture means it's going to be some diagram where it will say that you have to enable one web application firewall. After the web application firewall, you have to establish one IDS, then after the IDS, then this is going to be there. It's not like that. It's just a high-level strategy. InfosecTrain Trainer: If you, in your organization, also, if you go and read the strategy, it's going to be very high level. It will say, any solution which is getting integrated in the organization. InfosecTrain Trainer: should be coming via firewall. It should come via our organization firewall.

It should hit there, then the traffic will go next. InfosecTrain Trainer: That's the statement. So it's going to be in the form of the statement, not in the form of some diagrams or some, kind of blocks which is connecting each other. InfosecTrain Trainer: Project, Sandeep? Sandeep Saxena: Yeah, okay. InfosecTrain Trainer: And then there is a process to architect governance, which organizations should establish, right? So whenever a new architecture or new solution architecture is proposed, first, it will... it's as good as a change management process, what we discussed, right? There is going to be an intake. InfosecTrain Trainer: change project submission request would be submitted, then it would be assessed by the architecture team on all the principle, parameter, risk, all the reference material they will use. Then there is an architecture review board InfosecTrain Trainer: Like, we have a change review board, there is an architecture review board that will actually govern, that will approve it. InfosecTrain Trainer: And then they will approve, reject, or they will give the conditional approval. They will say that you go and do these changes, and then they will track and monitor. InfosecTrain Trainer: So the architecture review board, when you establish, it will be having an enterprise architect InfosecTrain Trainer: who will chair, then you will have a security architect, one delegate from the CISO, business representative, IT operational lead, data privacy officer if needed, or some other of things as per the organization. They should be part of this. InfosecTrain Trainer: You will not get cushioned on this. That's what I'm saying. InfosecTrain Trainer: I am... this is not currently part of the ISACA syllabus.

You will not get any questions currently, you will not even see this topic in the book also. InfosecTrain Trainer: I have introduced this topic because couple of you, if you want to take the exam after November, this is a new topic which is coming in. InfosecTrain Trainer: That's why. So don't, get, get, if... even if you do not understand, you just have a high-level understanding, what is the architecture, you will get one or two questions, that's it. InfosecTrain Trainer: But this is a new topic which is getting introduced from a November onwards. InfosecTrain Trainer: And the ARB, whenever they are evaluating, this ARB architecture governance is not there in the book. If you go and read search also, you'll not find this topic. InfosecTrain Trainer: It helps you align to the principle and the reference architecture, risk of exposure or any control adequacy, reuse versus new build justification, right? Cost and operational impact, and any exception request if business is seeking. InfosecTrain Trainer: Now, whenever you are designing an architecture, you also do threat modeling into it, which is a part of the security architect team. InfosecTrain Trainer: Right? InfosecTrain Trainer: So, when you are designing the architecture, you have to see all the aspects that InfosecTrain Trainer: The threats are being looked at each and every component, and these are the three InfosecTrain Trainer: most popular used threat modeling techniques. One is the Stride, which is from the Microsoft, one is the Pasta and LinkedIn. However, InfosecTrain Trainer: You'll not get any question in the exam, it's just for the information and the knowledge perspective, right?

InfosecTrain Trainer: So whenever you are doing a threat modeling, you first decompose, you first InfosecTrain Trainer: decompose that complete architecture diagram, that complete architecture into a small, small portion, a small, small part, then you will identify threat with respect to all these aspects. Is there a possibility of spoofing? Is there a possibility of doing a tampering? InfosecTrain Trainer: Is there a possibility of repudiation in any places. InfosecTrain Trainer: Is there a possibility of information disclosure? If it's a web-based application, is there a possibility of having a DOS attack, and how a person can elevate the privileges? So that, threats you will identify, then you will rate and prioritize those threats, and then you will mitigate. InfosecTrain Trainer: So, it's better to do this threat modeling and the threat activity initially when you are designing, rather than considering it at the later stages. So that is a better strategy which all organizations should follow. InfosecTrain Trainer: Now, what are the domains in the architecture, right? So, you see, technology, application, and data I have shown as integrated with each other. However, the business is not integrated. So, business requirement will come to you, then you have to see what is there in the technology, what is there in the application, what is the data you have, and then you have to create an integration. InfosecTrain Trainer: One statement which you can make note of, you will get a question in the exam, security architecture is something which helps you develop the information security program. InfosecTrain Trainer: So, if you see this in the question, please keep note of it.

So, architecture is something which will give you an, give you a kind of a InfosecTrain Trainer: head start, or give you a blueprint which will help you create an overall security program. And it also helps you organize all elements of security program into the small, small blocks. InfosecTrain Trainer: So when you are doing a gap assessment, you are understanding the current state, current environment, then you will create overall architecture, and then, on the basis of that, you will follow all the steps. InfosecTrain Trainer: Now, identity and access management. This is, also, you would have heard, this is also for the information and the knowledge, because I have heard a couple of people are getting InfosecTrain Trainer: these particular InfosecTrain Trainer: keywords in the questions, and they're getting confused. That's why I have introduced this topic, right? So, anyone here from the IAM domain? Mukesh Thakur: Not executive, but handled a few teams earlier. InfosecTrain Trainer: Okay. InfosecTrain Trainer: So, in the IAM, these are the 5 most important terms they use, right? Identification, authentication, authorization, accountability, and auditing. Consumer, tell me, what is the difference between the authentication and the authorization? Shweta Sundar: Authentication is to, I mean, who you are, and authorization is what you can access. InfosecTrain Trainer: Correct. InfosecTrain Trainer: So, authentication means you entered your login ID and password. So, this will authenticate. Yes, Shweta is the one who is trying to log into, but then, once you get into the application, what you can see, what you can perform, that is called the authorization, right? Srinivasan: Access and privilege. InfosecTrain Trainer: Yes.

InfosecTrain Trainer: So, identification is your ID. InfosecTrain Trainer: So, Shwetweta entered her email ID, that is an identification. Then authentication, she authenticated using a password, a multi-factor authentication biometric. InfosecTrain Trainer: So, system authenticated, okay, Shweta is the one who is trying to log into the application. Once this is done, then the next step comes as authorization. What Shweta can perform within that application, that authorization will

do. InfosecTrain Trainer: And then comes the accountability. So all the actions you are doing in that particular application, you will have audit logs getting generated, right? InfosecTrain Trainer: So if you perform anything, audit things or activities are being captured as part of the audit log, right? So that the forensics, or during the incident investigation, you will get to know, and from accountability then comes the non-repudiation. InfosecTrain Trainer: So if you have an accountability, then you come to the wrong repudiation, where you cannot deny that you did that activity, right? And then you enable the auditing. That's why in your... all the organizations, there is something called the access review, right? Every six months, or every one year, all the managers, they get an email from InfosecTrain Trainer: Identity team to say that, okay, these are the people reporting to you, do they need this access at this point of time or not, right? InfosecTrain Trainer: So these are the key things what used in the IAM, multi-factor authentication, single sign-on. InfosecTrain Trainer: Privilege access management, role-based access control, attributes-based access control, just-in-time access, right? InfosecTrain Trainer: And then this particular concept, the joiner-mover-leaver.

So, as soon as you join a new organization, you become a joiner. InfosecTrain Trainer: At that point of time, the access and everything would be enabled to you. Once you probably get promoted, or you took an IJP internal job posting, you move to some other team, then you don't require the privileges what you were having in the previous team, right? You will be getting access to the new resources, new platforms, so that becomes a mover. InfosecTrain Trainer: Once you drop your paper, you resign from the organization. On the last date you leave the organization, then the access will be deprivations. InfosecTrain Trainer: And then you should do the periodic access review and continuous monitoring of the privilege and the dormant account. So these are, from the identity and access management perspective, what are the activities which you should do. InfosecTrain Trainer: Now, coming to the Zero Trust Architecture. What is a Zero Trust Architecture? Is it a concept, or is it a... InfosecTrain Trainer: kind of a... some kind of architecture, actually. What is a zero-task architecture? Mukesh Thakur: It's a concept. InfosecTrain Trainer: Correct. Don't get confused by the architecture at the end. InfosecTrain Trainer: So, this is a concept. InfosecTrain Trainer: So, zero trust architecture is a concept, right, which, where there's a no... whenever you are entering somewhere, there should not be an implicit trust which should be given to you. A very simple example. InfosecTrain Trainer: All the employees in the company have some access card, right? InfosecTrain Trainer: So that access card gives you generic access to InfosecTrain Trainer: complete company. Let's take another example, very simple.

Whenever you go to any five-star hotels, so these days they have enabled a security, right? So whenever access card is given to you, that access card will only give access to the floor InfosecTrain Trainer: Where you have your own room. You can only go to that floor, or you can go to the lobby. InfosecTrain Trainer: Or a dining area, or the common area, right? That is a classical example of zero trust. InfosecTrain Trainer: Rather than giving you explicit access to all the floors, all the facilities, they are specifically granting you access to those facilities, those rooms, where you are supposed to go and reach. Similar thing in the zero test, also say the same. InfosecTrain Trainer: Whatever activities, whatever privileges you want, or wherever you have, only you should have that many privileges, then once you move around from one system to another system, every time there should be authentication checks. InfosecTrain Trainer: authorization need to be done, then only the access should be given. And zero trust architecture is the best method to actually mitigate the APT. We discussed the advanced persistent threat in the last domain, right? InfosecTrain Trainer: So, when an attacker gets into your environment, when he's trying to elevate the privileges, move laterally, if you have a proper ZTA architecture in place, he won't be able to move InfosecTrain Trainer: From one system to another system. InfosecTrain Trainer: So, zero trust architecture says there should be no implicit trust granted based on the network location. Every access request is authenticated, authorized, and then continuously validated against policy. Then only you will have a InfosecTrain Trainer: Access. InfosecTrain Trainer: So, what are the guiding principles?

There are three guiding principles for the Eurotr architecture. Verify explicitly InfosecTrain Trainer: Use least privilege access and assume breach. InfosecTrain Trainer: Always, you will... InfosecTrain Trainer: Assume that there is a breach scenario so that you always segment, encrypt, and monitor at each level. InfosecTrain Trainer: And so, as per the NIST, there are 5 pillars to the ZCA. Identify. InfosecTrain Trainer: Where you will authenticate any device which is getting into your environment. The device is where you will understand the device posture, compliance, health checks, all those things. InfosecTrain Trainer: Then comes the network, where you will enable a micro-segmentation of the network, rather than designing a network in a single... InfosecTrain Trainer: monolithic manner, you will do the micro-segmentation of a network, so that even if the person is able to penetrate into one network boundaries, he should not be able to go to another one. InfosecTrain Trainer: And then you will, design the applications and the workload, and then you, classify all the data so that the data, on the basis of data also, the access is managed. InfosecTrain Trainer: This is overall what the Zero Trust architecture do. InfosecTrain Trainer: Now, the next topic here is the framework. InfosecTrain Trainer: Right. InfosecTrain Trainer: So the info... so, information security program, you cannot design if you... if you... Create a framework. InfosecTrain Trainer: Right? Without framework, you cannot develop a program, because program has so many components, so many activities, so many functions, so many controls need to be designed, so many processes need to be created. For that, it's necessary that you have a framework.

InfosecTrain Trainer: So, there are a lot of frameworks, but these are the three which are the most popular one, ISO, COBIT, and NIST CSF. InfosecTrain Trainer: So currently, the NIST CSF 2.0 is going on, and ISO 2013 origin... I think it's not 13, it's a 2022, if I'm correct, right? Anyone can confirm? InfosecTrain Trainer: It's ISO 27000-2021 or 2022 is the latest version which we have. SupriyaMhatre: 2022, yeah, it's correct. InfosecTrain Trainer: Yeah, and I think I was hearing, probably, they are planning to revise it in the next year or so, because of the AI and all coming into the picture. InfosecTrain Trainer: So ISO is planning to revise the framework again. InfosecTrain Trainer: Now this... InfosecTrain Trainer: From a framework, you will create a policy, standard, guideline, process, and procedure. We have already discussed in the detail, that's what I'm saying. Domain 1 was something which has a small, small topics from all the domains it have picked up, because it's about the governance, right? InfosecTrain Trainer: But the same topic is here coming in the program also, because as part of the program, you have to create the policies, you have to create the standard, you have to create the guidelines, and then you have to create the processes. InfosecTrain Trainer: And we have discussed this topic in detail, that what exactly policy means, what is a standard, what is a guideline, what is a process and procedure. Anyone still have any slight doubt? InfosecTrain Trainer: We also discussed yesterday also what is the difference between a standard, what is the baseline, what is a guideline. So, a standard is something which is mandatory to follow. InfosecTrain Trainer: Guideline is something which is... best practices. So, let's take an example.

So, standard will say that every InfosecTrain Trainer: Password which is created should contain a... Characters. InfosecTrain Trainer: characters, it should contain the characters, numbers, Special characters. InfosecTrain Trainer: It should also have one capital letter, something like that. It should be minimum of the 12 characters, something. InfosecTrain Trainer: the standard you have created. Now, the guideline is something which will tell you that how to create this strong password. InfosecTrain Trainer: So that's why you... the guideline will say, okay, you can use a passphrase, you can use this kind of technique, please do not use any social security number into it, please do not use your first name or last name, do not use InfosecTrain Trainer: the name of city in your particular password, so that is a guideline. InfosecTrain Trainer: which will guide any user while creating a password. If I don't know how to create a password, Guideline will tell me how to create a password, and the process and procedure is something which is actually there to help achieve consistency, so that if the person is doing that activity every time, he should follow that process and those steps, so that a consistency is achieved. InfosecTrain Trainer: Right? So, as and clear, policy is standard, guideline, and process and procedure. InfosecTrain Trainer: Now, this is, this slide gives you a kind of a... InfosecTrain Trainer: Revision to what we discussed so far. InfosecTrain Trainer: Right? So, Information Security Program Roadmap.

InfosecTrain Trainer: What it does, it helps you do a strategic alignment, it helps you manage the risk within your environment, it brings the value delivery InfosecTrain Trainer: Helps you manage the resources, brings the integration with your assurance program objectives, and helps you measure the performance. InfosecTrain Trainer: And whenever you are developing a security strategy or security program, that time, you have to consider each and every goal in detail, you have to clarify goals as the roadmap evolves over a time period, and need to develop program in stages. InfosecTrain Trainer: It's not like that I'll develop the program at one go, and then I'll implement it. Program is something which is huge in nature, right? So many functions, so many policies, so many things which... so many activities which would involve as part of the program, so you have to develop the program in stages. InfosecTrain Trainer: Now, this also, I have added Recently, because... InfosecTrain Trainer: A couple of students told that they are getting some questions related to AI. InfosecTrain Trainer: So... Any... oh... InfosecTrain Trainer: AI-related questions you see in the exam, right? AI is just a technology, AI is just a... InfosecTrain Trainer: new term which is there. But to secure that technology, the background, the things, and the concept remains same. To secure AI, also, you require... you have to establish a governance, you have to protect InfosecTrain Trainer: That particular technology, right? InfosecTrain Trainer: So, it's the same. So, the AI governance and AI security in the information security program, how it will start. So, in your organization, you want to establish the AI governance, how you will begin with, right? First, you will create... you need to understand the environment.

For that, you need to first create an inventory. InfosecTrain Trainer: without understanding how many AI agents I'm running, how many... InfosecTrain Trainer: AI models I am having, what kind of information those models are processing, and which all of them are critical or important in nature. InfosecTrain Trainer: I have to first create the inventory. InfosecTrain Trainer: Once I have that inventory in place, then I will pick up a governance framework. So there is separate frameworks which are available for AI. We have a NIST AI framework, we have ISO 42001. There are regulatory frame... regulations also which came in for the AI, like UAI Act. InfosecTrain Trainer: The EU AI Act also tells you that each AI is classified into a couple of categories. It says the AI should be classified as prohibited. InfosecTrain Trainer: Hi. InfosecTrain Trainer: And low. InfosecTrain Trainer: So, that's what... Uai access, and then you have to create a secure by design framework for AI, InfosecTrain Trainer: So, whenever you deploy any new InfosecTrain Trainer: machine learning model, or you procure any AI-enabled solution, you have to have a framework to check the security within that platform, right? InfosecTrain Trainer: So, like, you will check that does the solution is doing... has a prompt injection and jailbreaking InfosecTrain Trainer: attack, how it handles the data poisoning attacks, how it handles the prompt injection attacks, right? InfosecTrain Trainer: how it's actually tuned in for the biases and all. So, all these things you will check in the AI Secure by Design, and then you will continuously monitor and have an assurance. InfosecTrain Trainer: If you get any question in... related to AI governance, right, please remember these things.

InfosecTrain Trainer: So, this also, I have added just for the information perspective, it's not there. InfosecTrain Trainer: Currently in the syllabus, but people are getting questions related to quantum. InfosecTrain Trainer: In the exam. InfosecTrain Trainer: They are saying some quantum cryptography is being implemented and all, so don't get confused. Quantum is also a technology. Earlier, we used to have a two... if you say all the computer, they work in bits, right? 0 or 1. InfosecTrain Trainer: Right? InfosecTrain Trainer: So the quantum talks about the qubits. InfosecTrain Trainer: Right? InfosecTrain Trainer: So every bit, either it's a 0, it's a 1, it will have the two stages. Either it can be 1 also, it can be 0, so it becomes a 2-bit, like you, rather than having 2, 0 or 1, you have a 4. InfosecTrain Trainer: That's a... InfosecTrain Trainer: So, qubit can be both at once. It can be a 0 also, it can be 1 also. That's called a qubit. InfosecTrain Trainer: So, qubit is a unit. InfosecTrain Trainer: On which the quantum works. InfosecTrain Trainer: Right? InfosecTrain Trainer: And superposition means It can have multiple states at once, right? InfosecTrain Trainer: And qubits are something which is linked together. Now, what is the impact of quantum in cyber? So, quantum is being used to create a new quantum cryptography algorithms. InfosecTrain Trainer: So we... you would have heard about, the AES, TLS, right? All those previous, or, or, or, WEP wide equivalent InfosecTrain Trainer: see if it's in the Wi-Fi and all. All those previous algorithms which you were using, those will sometimes become obsolete in nature after some times. So the quantum technology is being used to create new cryptographic algorithm.

However, they have already designed it InfosecTrain Trainer: But it's still in the testing and the development phase. InfosecTrain Trainer: So, in the quantum cryptography, there are two terms. What is the QKD, means quantum key distributed, which use the photons to share the keys. So earlier, how you share the keys? You use the fiber optic InfosecTrain Trainer: stable, and then there are other methods which you use to share the key, right? Here, you use the photons to share the key, and the post-quantum cryptography is... is a... is actually... there is also a NIST has created to InfosecTrain Trainer: A framework, and also approved to InfosecTrain Trainer: algorithm, Crystal Kyber and Crystal Delium, which NIST has approved and created, so these... InfosecTrain Trainer: Are something which will come in the future. InfosecTrain Trainer: So once this particular quantum comes, right, so all organization or your security program should be ready to adopt InfosecTrain Trainer: these changes, right? So in my organization also, I have one risk, which I have identified, that how my organization will evolve if tomorrow the quantum cryptography becomes reality, because then I have to immediately migrate to the quantum algorithm, otherwise attacker InfosecTrain Trainer: From 4 attackers, It would become very easy for them to break InfosecTrain Trainer: the older algorithms which were in existence, right? So I think, from a quantum perspective, this is more than enough, which you should know. If you want to, you can take a screenshot of it, that's it. No need to read or study something else beyond that. InfosecTrain Trainer: Now, coming to next thing, how you apply the frameworks and the architecture in building the roadmap. InfosecTrain Trainer: to building the program, right?

We discussed the frameworks also, we discuss the architecture also, right? How you use it. InfosecTrain Trainer: So, very simple example of a building. InfosecTrain Trainer: So, you are designing a house, right? You are designing a house. InfosecTrain Trainer: So the, so you gave an architect that please... InfosecTrain Trainer: Build me a... build me a house blueprint, right? InfosecTrain Trainer: So, he will use a framework InfosecTrain Trainer: Suppose you say that I want to design a European-themed villa. InfosecTrain Trainer: Right? Or I want to design a Greek-themed villa. So he will use a framework that how a Greek-themed villa looks like, what are the, what are the monuments which need to be kept, how the garden would be designed, how the rooms would be designed, how the ceiling would be designed. Using that, he will create one particular architecture for you to approve, right? He'll say, okay. InfosecTrain Trainer: This is where the entry would be there, this is how the gardens would be there, this is where we will place the fountain, this is where we will have the study room, this is where you will have the drawing room, this is where you will have the kitchen and all. InfosecTrain Trainer: That is the architecture, that's what the architecture and the framework do with the program. InfosecTrain Trainer: you use a framework like NIST, ISO, Corbit, which will give you a reference InfosecTrain Trainer: For designing your program, and then you create an architecture using that, which will help you InfosecTrain Trainer: put that particular framework into use. That's the simple explanation of overall. Now, what is a standard here? InfosecTrain Trainer: I have created an architecture. InfosecTrain Trainer: I have designed my room, I have designed everything.

Now it's time... now the framework says that in the drawing room, you should have one TV. In a kitchen, you should have a refrigerator. In the, InfosecTrain Trainer: In the utility area, you should have a dishwasher. InfosecTrain Trainer: So this is a framework is saying. But what is the standard? I'll say I'll purchase a Samsung TV. InfosecTrain Trainer: I will purchase a Whirlpool fridge, I'll purchase a Bosch dishwasher. This becomes a standard, which is very specific in nature. InfosecTrain Trainer: Right? InfosecTrain Trainer: So I hope this particular example helped you understand the framework, architecture, and standards all together. InfosecTrain Trainer: So the framework is something which will give you a roadmap for the project and the services which need to be integrated and need to be delivered. It helps you facilitate team to work across business functions. It will also help you align with the existing standards which you have. InfosecTrain Trainer: And can be adapted to extract the relevant elements to best suit it for enterprise. InfosecTrain Trainer: But the architecture, from a framework, help you address the issues for design and construction of technology, right? That's what it is doing. InfosecTrain Trainer: And successful architecture will consider the goals, environment, and the technical capabilities of your organization when you are designing. InfosecTrain Trainer: So, when you are developing a roadmap, you have to consider three things. You have to first develop, then you have to design, then you have to implement, right? So, first, you will transform the conceptual design into physical architecture, which you will create. So you had a concept, I want to design a InfosecTrain Trainer: Greek architecture-themed villa, that's what I wanted to do.

InfosecTrain Trainer: So I have conceptually imagined, then I have created architecture, then I will plan project initiatives, right? I'll plan that, okay, this is the construction material I will use, this is where I'll place the garden, these are the trees which I'll plant, these are the fountains. InfosecTrain Trainer: design I'll have, this is how I'll design my main entry, this is how I'll design my kitchen and all, right? Then you will consider the tactical project management objective, what you want to achieve, and then you will review existing security controls, existing things, what is there in the environment. InfosecTrain Trainer: In the design, you will design the control that meets those objectives. Once I have an architecture, I will need to create a control, right? I'll say that, okay, we need to have an EDR, which is sitting on endpoints, right? InfosecTrain Trainer: We should have one particular enterprise firewall. All the traffic coming from outside should first hit that firewall, then only InfosecTrain Trainer: The screening would be done, and the traffic would be permitted anywhere, right? InfosecTrain Trainer: You need to also develop the project to implement and deploy test control, and initiate the new security controls. InfosecTrain Trainer: weaknesses that meets those objectives. And in the implementation phase, you will define the requirements to achieve the program objective, you will provide the overall view and the requests and the steps which are needed to InfosecTrain Trainer: To complete those objectives, right? And then you will InfosecTrain Trainer: Deliver it in the milestones. InfosecTrain Trainer: So this is where, from where, we will start in the next to next week, right?

Next week, we'll have the new class, but InfosecTrain Trainer: But before we get onto there. InfosecTrain Trainer: Let me share a couple of things. InfosecTrain Trainer: So I... so first thing, please... complete... InfosecTrain Trainer: the videos, complete the questions till domain too. InfosecTrain Trainer: All of you. InfosecTrain Trainer: That is very important, because if you... InfosecTrain Trainer: complete that, at least in the next week, you will have some doubts and things. And still, while doing that, you can utilize the WhatsApp group. If you feel any questions you are not able to understand, or any doubts you have, you can post those questions in the WhatsApp chat. InfosecTrain Trainer: I'll be able to provide you the answers to that. Got it. InfosecTrain Trainer: No... you can... InfosecTrain Trainer: wants to see... Pudir: This is D. InfosecTrain Trainer: Yeah? InfosecTrain Trainer: You ask me? Pudir: Precise means Rakuten to the Manoj. InfosecTrain Trainer: ISACA, ISACA 2A, Manuel. InfosecTrain Trainer: plus... If you have a time, you can review the notes. InfosecTrain Trainer: for the Domain 3. So there are Domain 3 nodes, if you have time, which is kept in the shared drive, which you can use, and you can read those if you want, I

can show you where are those notes kept. InfosecTrain Trainer: You see this domain-wise notes? SrinivasanJ: Our screen is not shared. InfosecTrain Trainer: I think this Google Drive, you all have access... okay, sorry, okay, I'm not sharing screen. Okay, sorry. InfosecTrain Trainer: So this is... InfosecTrain Trainer: So, if you go to your Google Drive, you have two folders. One is books, one is domain-wise notes, and some material which is kept on the InfosecTrain Trainer: root.

InfosecTrain Trainer: So, if you go to this folder, there are domain-wise nodes for domain 1, Domain 2, Domain 3, Domain 4, right? InfosecTrain Trainer: So, as we are not having any class next week, you can utilize this time to read these notes at high level. InfosecTrain Trainer: to make an understanding around all the topics which we have done, right? So, first thing, you have to solve those Domain 1 and Domain 2 questions, which you can complete. InfosecTrain Trainer: Right? And then read the notes of the Domain 3, so that once we complete the Domain 3 in the next class, you will be immediately start solving the question for the domain 3. Even Domain 3, also today, we have completed almost 40% of it. InfosecTrain Trainer: 60% we will cover in the next class. InfosecTrain Trainer: Yeah, so before we break off, anyone has any questions? InfosecTrain Trainer: Anyone, any questions? InfosecTrain Trainer: Alright, then. InfosecTrain Trainer: So, thank you so much, everyone, and see you all in the first InfosecTrain Trainer: week of September, right? We have the next class on. InfosecTrain Trainer: 5th and 6th September. Manoj Kamble: Thank you. Sandeep Saxena: Okay, thank you. Sandeep Saxena: Brilliant. SupriyaMhatre: Thank you.

Day 6: Full Cleaned Transcript

Approximate source length: 32,632 words.

InfosecTrain Trainer: Hello, everyone. Let's wait for 2 more minutes, and then we'll start, yeah. InfosecTrain Trainer: Hello, good morning. Hello, good evening, everyone. Sandeep Saxena: Hey, good evening. Supriya Mhatre: Good evening. Johnny Souriar: Good evening from... InfosecTrain Trainer: Yeah, I think it was a long break for a week, so yeah. So, how many of you have completed the practice questions? Sandeep Saxena: Not completed. Domain 1 is complete, Domain 2 is almost complete. InfosecTrain Trainer: Not today. Sandeep Saxena: Good afternoon. InfosecTrain Trainer: How about others? Pudir: Yeah, I have completed Domain 1.2% of people. Pudir: This is... Good afternoon. InfosecTrain Trainer: How much, how much, you people are able to score, then? Pudir: So, the main one, it is 78.4. Pudir: Domain 282.3. InfosecTrain Trainer: Nice, that is a good score. InfosecTrain Trainer: Anyone else who's yet to start? I hope everyone is... InfosecTrain Trainer: Has completed at least Domain 1 and completed Midway, Domain 2. InfosecTrain Trainer: Great, so... Then, so we completed the Domain 1, Domain 2, right? This is where we stopped. InfosecTrain Trainer: So we completed halfway through Domain 3 as well, which is the largest domain currently, the program management, and this was the topic where we had a long discussion, a lot of people actually InfosecTrain Trainer: were confused over here, right? So let me take a very simple example, right? Let me give very simple analogy to all of you, so that you people can remember the topic. What is the key difference between the enterprise architecture and the security architecture, right? InfosecTrain Trainer: Let's say, let's say one of you decide to build your house, Right?

InfosecTrain Trainer: And... So, so you decided to put across one villa, right? InfosecTrain Trainer: sold... InfosecTrain Trainer: So you yourself won't be creating it, right? You people are a security professional, working professional, right? So, what you will do, you will go to some architecture, architect, right? You'll go to an architect, you tell that architect person that, InfosecTrain Trainer: So he will come and ask a couple of questions to you, right? He'll say, okay, how... what is your family size, right? He'll say, what is your budget, right? InfosecTrain Trainer: And what sort of... what sort of architecture you would like to have, right? Modern architecture, or old... old pattern kind of house you want, right? All, all, all the questions, right? How many floors you want? InfosecTrain Trainer: Right? So everything he will ask, and on the basis of all the questions and all the things he collects, on the basis of that, what he'll do, he'll create a blueprint. InfosecTrain Trainer: Right? So he'll say, okay, this is where the kitchen will set up for a family of five. This is where, we will have the drawing room. Drawing room size would be this much. Then he'll say that this is where, Fatha: Rakuten similarities. InfosecTrain Trainer: Yes, Srinivasan. So, so, I am just taking an analogy where you are building something from the scratch. InfosecTrain Trainer: something which does not exist, you are doing it from scratch, right? You are building one, something which is InfosecTrain Trainer: Which was not there, right? I'll then relate it to something which already exists also, don't worry, right? InfosecTrain Trainer: So, something which already exists, it would have already gone through this complete process, right?

It would already have the blueprint, it will have all the maps and everything is ready, right? InfosecTrain Trainer: So everything is already there, you're just modifying the house. So, only the places where... a house, you can just replace the house with the software product. That's it, right? InfosecTrain Trainer: So, that's how the enterprise architects look like, right? What that architect is doing, he's asking the family a couple of questions, right? InfosecTrain Trainer: how the things will look like from an overall perspective. Like, you are building one application for the organization, so all the question architect will ask, okay, will it sit in cloud? Will it going to be the hybrid structure? How many number of users would be using this application? What kind of front-end, back-end database structure and everything you want, right? InfosecTrain Trainer: what is going to be the latency, and all the number of questions he'll ask, and on the basis of that, he'll create one architecture, right? Now, next comes the person who is a security architect. InfosecTrain Trainer: Now, that person is only focused and only... InfosecTrain Trainer: concern about protecting that architecture, right? So he created a house, architecture, everything is ready, but how people should remain safe, right? So he'll ask, okay, okay, how many entry-exit you have? Let's protect it with the security camera, right? InfosecTrain Trainer: He'll say, okay, what kind of the lock System you want, right? InfosecTrain Trainer: Should we also, have an elevated fence around the house, right? InfosecTrain Trainer: And then, should we also have the smoke alarms installed if there's a fire, right? InfosecTrain Trainer: Should there be a safe room? InfosecTrain Trainer: Right?

So all those questions, similar if you replace with software. InfosecTrain Trainer: product. So, our software architect will ask all the questions related to security, right? InfosecTrain Trainer: from where the network traffic will emerge and come, right? Are you planning to install a firewall in between, right? Within the application, have you followed all the security development practices? Have you gone through all the kind of testing and everything? So that's what is the InfosecTrain Trainer: security architect will do, right? So, enterprise architect is someone who will build the overall architecture around it, right? How the application and the system will look like in the organization environment, and security architect is only concerned and focused about the security aspect of that. That's it. So that's the basic difference, all of you to remember. InfosecTrain Trainer: However, this topic is not yet there, only the architecture InfosecTrain Trainer: as a topic is there as part of the current syllabus, right? But if you plan to go with the new syllabus, which I'm yet to get the book and everything, they've already launched the new books, which is getting effective from the 1st of November, right? InfosecTrain Trainer: So if you plan to write the exam in the old pattern, then need not to be concerned about the security architecture and enterprise architecture and all, right? And if you want to remember the framework. InfosecTrain Trainer: So the enterprise architect follow the TOGAF framework, and the Jackman. Jackman and the TOGAF are the two frameworks which are used for the enterprise architecture, and for the security architecture, the well-known framework is known as the SAPSA.

InfosecTrain Trainer: SAFSA is a new... is a framework which security architects use. Just, you need to remember that's... that's... InfosecTrain Trainer: It... that's it. InfosecTrain Trainer: Right? So we already covered in detail last time, I just wanted to all of you to revise, understand this, right? Memorize this, so that with this story, you will be able to clear exactly what does the enterprise architecture means, and what does the security architecture means, right? InfosecTrain Trainer: So, all of you solved the question, right? So, anyone has any questions? InfosecTrain Trainer: Because we are yet to start the next topic, we are just revising the previous one. Anyone has any question, any doubt, any topic where you... people were getting confused, not able to understand any questions. InfosecTrain Trainer: Anyone? InfosecTrain Trainer: So, Johnny, the latest book, I've already told InfosecTrain, they will... InfosecTrain Trainer: Download it, print it, scan it, it will take some time. InfosecTrain Trainer: So, because currently the ISACA has changed to the way they share the book, right? There are two mechanisms. If you go to ISACA portal, either you can purchase it online, but that online copy only will open with your own account. InfosecTrain Trainer: You cannot share it with anyone. InfosecTrain Trainer: It's only open when you are logged in, you cannot download it, you cannot copy it, you cannot take any screenshot and all. That's how it works. InfosecTrain Trainer: So... so the Institute will probably purchase a hard copy one, and then they will take a printout, scan it, and then create a complete copy and upload it for all of you. So we'll... we'll take some time. InfosecTrain Trainer: Including the new QA manual also.

So I've already told admin team, they are working on that. InfosecTrain Trainer: Any... anyone else? Any questions from the previous... either it's Domain 1, Domain 2? InfosecTrain Trainer: Or the part which we have completed till domain 3. InfosecTrain Trainer: Alright, good. So... So we discussed about the architecture, we discussed about all the aspects, right? InfosecTrain Trainer: Now, you have to develop a roadmap. InfosecTrain Trainer: you have a security architecture in place, you have completed the gap assessment, so now you have to develop a roadmap. That's what you do in the program, right? Security program is all about developing a roadmap, how you will accomplish those targets and those objectives, right? Like, in your organization, in the next year, you are developing a program, you will say, okay. InfosecTrain Trainer: The AI is a new technology which we have introduced. We will establish the AI governance as part of this. The deliverable will be AI policy. InfosecTrain Trainer: you will update the AI acceptable use policy of the organization, right? You will, so this is the governance side, right? Then in the SOC, you have to transform your SOC also, right? You will... InfosecTrain Trainer: do the AI-assisted playbooks, that's what you will create, right? You will adopt AI into the triage InfosecTrain Trainer: which should help your SOC analysts to probably understand more around it. You will also adopt AI-based technology into the... in your XDR. InfosecTrain Trainer: and EDR solutions. InfosecTrain Trainer: These are all the things which you're planning for the next year, right? In the IAM space, you will work on the NHI's non-human identities, because all the AI agents come with the non-human identities, right?

You will also create some new rules in the DLP, so that people InfosecTrain Trainer: cannot InfosecTrain Trainer: extract the information from the AI agent or the AI tool which you have in the organization, right? They could not upload any restricted and the confidential information while writing the prompts, right? So these are all the things which you are planning for the next year, right? So this all becomes a roadmap. InfosecTrain Trainer: All items, right? So this, I am

talking about a program which is already an evolved program, already running in nature, right? InfosecTrain Trainer: Now, you imagine an organization who is starting its security InfosecTrain Trainer: Infrastructure or a security program. InfosecTrain Trainer: They're beginning to start. Like, everything was in... happening in the silos, right? They had a small team, some SOC team was there, now they had... now they want to build a proper security infrastructure, right? InfosecTrain Trainer: So, for them, they will do all the activities what we discussed. So, they will do gap assessment, and they will do risk assessment also, they will understand what are the key gaps, they will adopt some new framework, right? NIST, InfosecTrain Trainer: framework, or any new framework they will adopt. As per that, they will do the control mapping, and then once they do... are doing the gap assessment, they'll say, okay, these are the things which are missing, then they will build a program, right? So first, you develop InfosecTrain Trainer: Right? Where you... InfosecTrain Trainer: transform the conceptual design into the physical architecture, how your security program will look like for a new organization, right? Then you will InfosecTrain Trainer: plan the initiatives.

You need to have a specific GRC team who should help you. You should, you will be transforming your SOC team, currently you have, but there are no proper playbooks, there are no proper incident management protocol. You need to also establish a IAM team, because now the users will increase. InfosecTrain Trainer: Right? You have to establish architecture team, you have to establish application security team, so all the teams which you will be establishing, those you can consider as a project. InfosecTrain Trainer: Then you will also consider the tactical project alignment. What does... what is the difference between the tactical and the strategic? InfosecTrain Trainer: What is the difference between the tactical and the strategic? Johnny Souriar: Tactical means day-to-day, booking programs. InfosecTrain Trainer: Is it? InfosecTrain Trainer: Or of the operational means day-to-day. InfosecTrain Trainer: Operations means... so there are three terms which you will keep hearing, right? Ops, tactical. InfosecTrain Trainer: And it's strategic. Ops is something which is day-to-day basis. InfosecTrain Trainer: Tactical is something which is short-term, like a quarter to a year, not more than one year, something which you want to accomplish in a quarter to a year. So whatever I ask here, all of them are a tactical objective. InfosecTrain Trainer: which you want to establish or accomplish in a quarter or to a year. Strategic is a long term. Always it's going to be five InfosecTrain Trainer: Year and beyond. InfosecTrain Trainer: Something, right? So... InfosecTrain Trainer: Now, also, you need to review the existing security controls, right? That was a part of the develop phase. InfosecTrain Trainer: Now, coming to the design, right?

InfosecTrain Trainer: So, in the design phase, you already didn't, understood what are the things you have to accomplish. Now you have to design those controls, right? You have to... InfosecTrain Trainer: design, you have to establish new, policies, you have to establish new AI enhanced playbooks, you have to establish an AI inventory, you have to establish the non-human identities, you need to write the new policies in a DLP, so all of these are controls, right? InfosecTrain Trainer: Then you will develop the project to implement and deploy test control. So all the things which you have planned, you have to deploy them in the production and test it, right? InfosecTrain Trainer: And then, you will initiate the new security control weakness and meet new objectives, or whatever are the objectives you have defined, those objectives should be met using those controls. And then, in the last phase, you will implement. So once designing is done, you have to now implement into the production, right? So you will... InfosecTrain Trainer: make sure those controls which you are planning to implement should achieve the objective. So, what is the objective of establishing this all? So, there are... so if you see the AI, right? So AI... InfosecTrain Trainer: works into two things. Something AI... security of AI? InfosecTrain Trainer: An AI... insecurity. These are two... Thanks. InfosecTrain Trainer: So, one thing, the AI which you're bringing in organization, you want to protect that. InfosecTrain Trainer: The second thing is that all the security operations you are running in the organization.

InfosecTrain Trainer: the security program, tech stack you have, you bring AI into it, so that your playbook speeds enhanced, your operation gets enhanced, your GRCT probably don't need not to invest a lot of time in analyzing the manual documents and all, right? They can do it using AI, right? InfosecTrain Trainer: like SOC 2 report. You know the SOC 2 report is 50 to 60 page, how much time it will take you to read through the 60 page, right? You can create an agent which should quickly read the SOC 2 report for you and bring... give you the InfosecTrain Trainer: strategic outcome, or the key gaps as per your organization criteria, right? So that AI insecurity will do, right? So these are all the requirements you want to achieve as part of the program objective, right? Both the objective you set. InfosecTrain Trainer: as part of your program, so you will say how much I have achieved InfosecTrain Trainer: with respect to security of that AI which I'm bringing in, and then what is the AI I will bring in my security tech stack to improve my performance and improve productivity, right? InfosecTrain Trainer: And then... InfosecTrain Trainer: you will provide the overall view of required steps and the sequence, how to achieve these all things, and then you'll bring the milestone. In your organization also, you should be having milestone, right, which your CISO and senior leadership might be tracking, right? End of quarter InfosecTrain Trainer: Q1, Q2, and Q4, likewise, right? End of Q1, we want to achieve this. Q2, we will be doing this. Q4, we will see that we accomplished all the things what we have, probably planned for this year.

InfosecTrain Trainer: And then you start the planning by end of Q3, you start planning for next year also, so that whatever things, by looking at the program you see, you are not able to accomplish this year, or probably as part of the program, you've identified some couple of gaps. InfosecTrain Trainer: you want to fix those gaps in the next year, right? So then you will plan that in the next year. This is how you develop the roadmap for your information security program. InfosecTrain Trainer: So, as part of this, you will be doing the gap analysis. InfosecTrain Trainer: Gap analysis we have discussed multiple times, but still, I know people get confused between the gap InfosecTrain Trainer: Analysis, Risk Assessment. InfosecTrain Trainer: Business Impact Analysis. All these three terms you will see. Any question in the exam you will see, you will see all of them as option. InfosecTrain Trainer: That's how they design, so that people get confused. What is a gap, where to use a gap, where to use risk assessment, where to use BIA. InfosecTrain Trainer: Anyone can tell me the key difference between GAAP, risk, and BIA. InfosecTrain Trainer: Where, where do you... where do you select the gap assessment, and where do you select the risk assessment, where do you select the BIA? Fatha: Gap is during the strategy, when we make the strategy. Fatha: Heck. Fatha: Information. InfosecTrain Trainer: What is the output? What is the output of gap assessment? What do you achieve? SrinivasanJ: Risk. Fatha: Right. Fatha: What are, we achieved? Johnny Souriar: Current state. Fatha: information security, InfosecTrain Trainer: So wherever, wherever you see keyword, like, Current state... Future estate... InfosecTrain Trainer: Right? Such kind of terms, if you see, right?

Or output as a... Deliverable... roadmap. InfosecTrain Trainer: milestone, something you see in the exam, right? Such kind of things you see in the option. Most of the time, the answer would be gap suspect. InfosecTrain Trainer: Read the question properly, and if you see what it is trying to ask, this... InfosecTrain Trainer: Risk assessment, you do. We have discussed multiple times, right? Risk assessment, you do. Any new initiative you want to launch in the organization, you will do a risk assessment to identify the risk, right? InfosecTrain Trainer: So, the risk assessment output is to reduce the risk To acceptable level. InfosecTrain Trainer: That is your key objective. InfosecTrain Trainer: And the BIA is something which you do to understand what is critical InfosecTrain Trainer: Versus non-critical, and also it helps you establish the priority. InfosecTrain Trainer: Now you know that you have planned your exam probably after 2 weeks, and then, so you have very less time which is left. InfosecTrain Trainer: What you will... how you'll prioritize your, study plan. InfosecTrain Trainer: You will do BIA. InfosecTrain Trainer: You will see, you will do a business impact analysis on your study plan, and then you will say, okay. InfosecTrain Trainer: The domain one, I'm good. Domain 2, there are key gaps. Domain 3, these are the topics where I am lacking. Domain 4, these are the topics where I am weak. So, this is a BIA, you set the priority, you say, this is how I will then build a priority plan. I'll say, these are the things which I'll study first, I'll solve the questions, I'll clear my doubts, and then I'll approach the exam. InfosecTrain Trainer: Right?

InfosecTrain Trainer: So now, this key difference is very much important, and that difference you will understood when you start solving the question. So more number of questions you will solve, more number of questions you will answer about GAAP, risk CISM BIA, the things will get clear, because just understanding the concept is not enough. Once you see that particular concept in the context of the InfosecTrain Trainer: question. That time, also, it's very important, it's very important for all of you to understand which concept to apply where, right? So that's why I'm saying. InfosecTrain Trainer: Solve the question. InfosecTrain Trainer: So, at least once you complete the QA manual, you will still have a good question mark. So, we are sharing almost... after that, almost, we are sharing you 600 to 700 questions, which you can solve, clear your doubts on this topic, right? InfosecTrain Trainer: So, where you do gap analysis? So, gap analysis will help you identify where the control objectives are not adequately supported by controls. InfosecTrain Trainer: So, if your current controls are not supporting your AI governance roadmap, it means there are key gaps. InfosecTrain Trainer: So those key gaps, how you will fulfill, you have to design new control. InfosecTrain Trainer: So, for that, you need to identify the control points and assist in monitoring development process. InfosecTrain Trainer: Right? InfosecTrain Trainer: And then you need to concentrate on KGIs and KPIs when executing a new process, right? You need to understand what is the goal and the objective you want to achieve. InfosecTrain Trainer: Are you able to meet them? Also, how your current control is performing?

InfosecTrain Trainer: And then you will validate that is your... the current process is able to met those objectives or not, right? InfosecTrain Trainer: Is my AI governance roadmap is on track or not? Are people still sharing the sensitive information over the AI chats? InfosecTrain Trainer: It means your DLP policies, which you set, it's not working properly. InfosecTrain Trainer: And then you will confirm that progress toward the control objectives is achieved through program goals, right? So this is how you do the gap analysis, and this is the development lifecycle. InfosecTrain Trainer: So this is not a software development lifecycle. This is called a system development lifecycle. Any system you want to develop or introduce, you will follow the same thing. InfosecTrain Trainer: Let's... Let's forget the technical topic, let's go with the house. InfosecTrain Trainer: So you and your spouse decided, okay, let's go with the house. InfosecTrain Trainer: we want to purchase a house, so you have some XYZ InfosecTrain Trainer: amount of budget, which you have set aside, and then you have, said, okay, what is going to be... we'll be purchasing one 3BHK? InfosecTrain Trainer: house, right? InfosecTrain Trainer: So, you will set the criteria. We want 3BHK, we want it in the gated community. You will also say, okay, these are the areas which we, identify, right? A, B, C, D, some 4, 5 areas you will choose. We want the houses only around them. We'll not go beyond this, right? InfosecTrain Trainer: You want the better connectivity, you want the amenities, you want the security, everything you will list down, right? InfosecTrain Trainer: That is what you do in the initiation phase. InfosecTrain Trainer: You list down all the requirements, what you want. Now comes the next step.

InfosecTrain Trainer: development and acquisition. So, you now need to decide, should we purchase a land and develop our own house, or should we go with the ready-to-move-in house, which is there? InfosecTrain Trainer: Should we invest in an under-construction house, or should we go and buy ready-to-move-in house? InfosecTrain Trainer: That's what you do, right? In organization, also, same decision happens, right? If one requirement come from the business, we want this application, you will see, should we develop this application within the enterprise, or shall we go and buy a third-party solution? InfosecTrain Trainer: Once that is done, now comes the implementation. Now you will implement. Now you have got the house, you have to what? You have to... InfosecTrain Trainer: do the interior designing, you have to think about all the aspects, you probably need to purchase the appliances, you need to purchase all the things, right? You will do the painting and everything, right? Everything is done. Now, you have moved in InfosecTrain Trainer: Now comes the operation and the maintenance, like, day-to-day operations, right? You... sometimes your electricity fault will come, sometimes the plumbing issues will arise, right? Probably over a period of time, your paint will get peel-hopped, you have to again do the painting and all, right? Same thing is with the applications also, right? InfosecTrain Trainer: the issue comes, and once you stayed in that house for a couple of years, now you want to decide you want to move to a bigger house, or to a different city, you will dispose it off. You will probably sell it to every... any other party, or... InfosecTrain Trainer: you will, probably do the complete redesigning of that solution, right? So this is how the development lifecycle works.

InfosecTrain Trainer: Right? So always the information security program should be viewed as a lifecycle. InfosecTrain Trainer: So, all the program you run in the organization should always be viewed as this life cycle, that this is how we will develop, right? InfosecTrain Trainer: And... InfosecTrain Trainer: Then you have to decide on the resources also, which are required to build this, because you need to optimize those resources as well, and then you will always plan for incremental updates. InfosecTrain Trainer: You cannot do everything at one go, right? Suppose you identify some 4 or 5 gaps in your current SOC playbook process, can you... and to fix those gaps, suppose there are 15 playbooks which need to be created. Can you create 15 playbooks in a couple of days? InfosecTrain Trainer: It's a lot of effort. InfosecTrain Trainer: you have to do in the incremental manner. You will say, out of 15, we'll... we'll... let's do... let's do the risk prioritization. We'll identify which all of them are very high, in nature, which will solve the biggest issues, then you will say moderate priority, low priority, and accordingly, you will InfosecTrain Trainer: do the incremental changes to that playbook process, right? That's what you do in the current program as well. InfosecTrain Trainer: Let's solve some questions. InfosecTrain Trainer: Alright, let's discuss the correct answer. InfosecTrain Trainer: First question, I can see a couple of people. InfosecTrain Trainer: Went with the A also, okay. InfosecTrain Trainer: Alright. InfosecTrain Trainer: So, the first question is talking about an organization is rapidly migrating to cloud-native microservices. What is the main significance of a well-defined information security architecture in this transformation, right?

InfosecTrain Trainer: So, first one, it ensures the immediate compliance with all cloud-specific regulations. It provides a strategic blueprint to embed secure by design, rather than after, though. InfosecTrain Trainer: It automates the deployment of security controls across all microservices. It eliminates the need for manual security testing in new environment, right? InfosecTrain Trainer: So it is saying, so organization is migrating to a cloud-native microservices, right? InfosecTrain Trainer: So, if you have a well-defined architecture, what it will do? InfosecTrain Trainer: what the architecture... so architecture we know, right? Architecture is a blueprint. InfosecTrain Trainer: how come architecture will help you with the immediate compliance with all specific regulations? Architecture do not help you with all the regulations. Regulations may include a couple of other aspects also, right? That architecture won't help, but it's... InfosecTrain Trainer: We'll visit option B later. See, it automates the deployment of security controls across microservices. Architecture also does not help you with the deployment of controls, right? It eliminates the need for manual security testing in new environments. This is as such InfosecTrain Trainer: out of context, out of scope, answer so eliminated, right? So what does architecture do? Architecture is a blueprint which helps secure by design, right? So that security is embedded into design itself, rather than thinking InfosecTrain Trainer: Later. We'll discuss the example of house. InfosecTrain Trainer: So when the architecture is designing the house, before itself, you have to think, right, what is going to be the height of wall, where you will install the security cameras, where you will install the fire alarms and all, right?

Because after InfosecTrain Trainer: If you think around those items, right, again, you have to break the wall, you have to, again, do all the wirings and everything, so aesthetics would be gone. InfosecTrain Trainer: you will be probably investing a huge amount of money again doing all those things, right? So, that same thing is there, that's what it is helping. Periodically analyzing the gap between the control and the control objective is necessary too. InfosecTrain Trainer: So we also discussed last time the control versus control objective. Prevent an increase in the audit finding, avoid substantial increase in cost, address change in exposure, maintain alignment with regulatory requirement. InfosecTrain Trainer: D and C looks to be a close, but InfosecTrain Trainer: B somehow... C somehow covers the D also. InfosecTrain Trainer: So, as part of changes in the regulatory environment, so the... what it will do, it will do the change in exposure. That's what you are addressing, right? So, if there is a change in exposure, there is a new AI-related tech stack, AI-related technology introduced in the organization, you have to InfosecTrain Trainer: See if there is a gap InfosecTrain Trainer: And you have to fix that gap, right? The primary concern of an information security manager. SrinivasanJ: body. SrinivasanJ: why not D a test? Because, you know, C is more related to risk, right? And we are talking about GAAP. GAP is something which is related to standards and frameworks, which is... SrinivasanJ: Alignment to the regulatory requirements. InfosecTrain Trainer: But is it... is the regulatory is the only kind of the gap you have? SrinivasanJ: But if we are working on the exposures, that is risk, right? So, residual and baseline.

InfosecTrain Trainer: No, no, no, it's talking about exposure is a broad term. InfosecTrain Trainer: Just don't think exposure from a risk perspective. Exposure means any changes in the exposure. If tomorrow you have probably InfosecTrain Trainer: I added a new text star. InfosecTrain Trainer: Tomorrow, earlier in your organization, you had 100 employees, now you have 500 employees. Changes in exposure? InfosecTrain Trainer: Earlier, you had 100 servers to protect, now you suddenly have a 200 servers to protect. InfosecTrain Trainer: Earlier, there were... there were no AI in organization, now you have AI. Earlier, you were relying on the SaaS solutions, now you are establishing your organization's own SDLC practice. All of these are what? These are what? Changes in the exposure. InfosecTrain Trainer: Now, the exposure is getting changed. As per that, your controls also need to be changed. That's what it is saying. InfosecTrain Trainer: You can periodically analyze... Yeah, exposure of your overall organization environment. Exposure of overall your organization. That's what it is talking about. SrinivasanJ: Okay, okay, no, I'm sorry, I... Yeah. InfosecTrain Trainer: Yeah, no problem, no problem. It's good that if someone asks the question, at least it resolves the issues and the doubts for all other as well, so that's good. InfosecTrain Trainer: So, primary concern of an information security manager documenting a formal data retention policy is InfosecTrain Trainer: So, whenever you create a data retention policies, data retention policies are mainly InfosecTrain Trainer: concern, and mainly related with the legislative and the regulatory requirements. First, those things you have to address.

However, business requirement is also a close answer, but InfosecTrain Trainer: Even if the business want to retain the information for a longer period of time, you cannot do it, because the regulatory environment do not say so. InfosecTrain Trainer: Otherwise, then you have to... you have to probably bear that risk of non-compliance with respect to regulation. That's my correct answer here is D. InfosecTrain Trainer: A CISO is developing a new information security program roadmap, which factor represents the most critical constraint that could severely impact the roadmap's realistic implementation and success? InfosecTrain Trainer: It's talking about the blocker. InfosecTrain Trainer: the availability of cutting-edge security technologies, okay, the organization established risk appetite and tolerance, okay, existing organization culture regarding security awareness and accountability, the frequency of new regulatory updates. So, if you read, all of them looks to be correct. Even B also looks to be somehow correct. InfosecTrain Trainer: Closed. InfosecTrain Trainer: Risk appetite and tolerance

can be changed, can be established, can be modified, right? InfosecTrain Trainer: You can do the changes in that. InfosecTrain Trainer: But can you change the culture immediately? InfosecTrain Trainer: If in your organization there is no culture of security, can you change it in a day? InfosecTrain Trainer: You cannot. It will take years. InfosecTrain Trainer: If, suppose your board of directors do not put the emphasis on security, your CEO is not concerned about the security in the organization, right? Your senior leadership also do not give much emphasis on that. Can you change it immediately?

It will take InfosecTrain Trainer: some time, right, to convince them, to build that culture around it. So, culture is something which InfosecTrain Trainer: always take a lot of time to change, a lot of time to establish, so that's why correct answer here is C. InfosecTrain Trainer: Now, coming to the next topic. InfosecTrain Trainer: I told you in the domain one also, right? We will be discussing the... the... a detailed topic around the KPI, KGIs, and the KRIs. InfosecTrain Trainer: Right? InfosecTrain Trainer: So, let's, let's understand with a very, very simple, simple example, right? InfosecTrain Trainer: Let's... I'll take a couple of your names, right? So... suppose... suppose Manoj, right? Manoj decided... InfosecTrain Trainer: that he will be going to Goa, right, with his friend, right? He decided that he'll be going Goa, and then he'll be driving. Suppose... I'm not sure where the Manoj is based out of. Suppose Manoj is based out of Bangalore. InfosecTrain Trainer: Right? So, from Bangalore, the Goa is approximately 600 kilometers, right? So, which is around 10 hours drive, right? So, his friends are very excited, they want to reach Goa on time, right? InfosecTrain Trainer: They are very excited, they want to just reach Goa as soon as possible, right? So he said... he committed that we'll not be taking any break, I'll be continuously driving, I have very good experience. InfosecTrain Trainer: I'll be able to push, and we'll be able to cover the distance in 9 hours, right? InfosecTrain Trainer: So he set a goal, That, in 9R, he'll be able to reach there. InfosecTrain Trainer: That is a goal, that is a KGI, right? InfosecTrain Trainer: He said, I'll not be stopping in between, I'll not be taking any break, that is another goal, which he wants to achieve, right?

InfosecTrain Trainer: Now, over the time when you are traveling, so, you need a... need to check your performance, right? You said that I'll be reaching there in 9 hours, I'll not be taking any breaks and all, right? InfosecTrain Trainer: So the 9Rs, you have to continuously check your speedometer, right? InfosecTrain Trainer: Am I maintaining that constant speed of probably 80, 100, whatever speed you are driving in, right? That becomes a KPI. InfosecTrain Trainer: Now, when you are driving in between, you need to also factor in risk. So, probably there may be a... your tire may go flat. InfosecTrain Trainer: Or probably because of continuously driving, there can be an overheating in your engine. InfosecTrain Trainer: Probably continuous driving, so you have to also take a break in between to get the refueling done. These are all the risks in achieving your goals. InfosecTrain Trainer: Right? So that's the key difference between the KRI, KGI, and KBI, right? So KGI is something which is always related to the objectives and the goals, what you want to achieve. So, all of here... all of you are here for the CISM training. What is your goal? Your goal is to clear the CISM exam. InfosecTrain Trainer: That is your goal, right? InfosecTrain Trainer: But, and how you will, do the K... what are the KPIs you have said? You are solving the questions against which it gives you a KPI. InfosecTrain Trainer: Right? How much marks you are getting, how much things you are getting. And KRI is something which is a risk. If you could not clear the exam, you will lose that money which you have invested, you will lose the time which you have invested, right? InfosecTrain Trainer: So all of those are KRIs, right? InfosecTrain Trainer: So this is how the KPI, KRI, and KGIs are defined, right?

All of them sit in a same dashboard, so whatever Power BI dashboard your organization would be monitoring, or any SaaS solutions, if you have InfosecTrain Trainer: to monitor the security metrics and the dashboard, all of them would come in a single dashboard. It's... there's no clear distinction InfosecTrain Trainer: You will say that this is a KPI, this is KGI, this is KRI. But you have to see what is the behavior of that matrix, what that matrix is trying to tell you. If any matrix which is trying to tell you, predict the future risk. InfosecTrain Trainer: that becomes a KRI. If any matrix which is tracking your progress with respect to an objective which you have set, right? This is how much I want to accomplish, right? I want to deploy the EDR InfosecTrain Trainer: coverage, suppose you are implementing an EDR across organization, I want to have a coverage, server coverage by 95% by end of this quarter. That is a KGI. InfosecTrain Trainer: And the performance is where you check, okay, how much we have deployed, what is the current... okay, 85% completed at this point of time. That becomes a KPA. InfosecTrain Trainer: So now... the... whenever you design the matrix, right? So, matrix are something which helps you InfosecTrain Trainer: Track your program progress. And whenever you design those metrics, you should make sure that those metrics are set at the multiple levels, not just InfosecTrain Trainer: holistically looking at one progress, one particular process, right? So even in your organization, you would see the mattresses being generated from all the business function. InfosecTrain Trainer: So, operations will generate the matrix, your program tracking will generate the matrix. Suppose you have... you are doing the audit, that will generate the matrix.

So, all the things will generate the matrix, right? So, you should always set the mattresses at the multiple levels, not just InfosecTrain Trainer: Managing or checking one particular process, right? InfosecTrain Trainer: And... InfosecTrain Trainer: a good matrix, or the mattresses which you develop, that should help you track the progress and the performance of program, right? So how you will understand that your SOC InfosecTrain Trainer: is effective. InfosecTrain Trainer: SOC is not responsible for... Reducing the incidence. How come SOC can reduce the incident? InfosecTrain Trainer: SOC is there to handle the incident. Reducing the incident is responsibility of the other team, those who are managing those controls, right? SOC is responsible for if the incident is reported, it should be detected InfosecTrain Trainer: Mean time to detect? Detect it fast. InfosecTrain Trainer: And then... It should be responded fast. InfosecTrain Trainer: And reduction is the impact, reduction in the overall, overall cost and everything, right? That is the responsibility of SOC. That's why you have to develop those kind of mattresses, right? And overall information security program will need InfosecTrain Trainer: technical, broader matrices, right? So that the program effectiveness is observed and the resources are optimized. InfosecTrain Trainer: Suppose you are not monitoring your firewall rules. InfosecTrain Trainer: It means your firewall is not optimized properly. InfosecTrain Trainer: It will not block all the traffic, it will probably bypass something. InfosecTrain Trainer: Right?

If you are not monitoring MTD, MTDR, how you will understand how effectively your SOC team is operating, how effectively your tech stack is behaving, how effectively your playbooks are operating, what is their training and the awareness efficacy level, all those things are what? Resource optimization. InfosecTrain Trainer: So your resources will get optimized if you are operating the mattress, and one line. InfosecTrain Trainer: If you cannot measure, you cannot improve. That's a statement. InfosecTrain Trainer: And it's a universal statement. If you don't measure, how you will improve it? InfosecTrain Trainer: If you do not solve the questions, you directly go and write the CISM exam, how you will know that, where you are lacking, which particular domain you are good with, which particular topic you don't have, awareness around, right? InfosecTrain Trainer: So that's why you have to first InfosecTrain Trainer: measure, then only you will be able to improve, right? So you need to select the controls based on their ability to monitor and measure the effectiveness, right? So you will only deploy those controls, you will establish those controls which you can measure and improve. InfosecTrain Trainer: Where you can have a quantitative matrices defined, so that you can measure the performance, right? And if you have any control, which cannot be measured, monitored, it's not a good control. InfosecTrain Trainer: It was how you will understand that that control is operating effectively or not, right? InfosecTrain Trainer: Now, whenever you are designing a matrix, right, so you are, CISO of an organization, right?

InfosecTrain Trainer: You... your board of directors want to understand how effectively your program is InfosecTrain Trainer: managing, or how effective program is operating, and as a CISO, you also want to see that how effectively my overall cybersecurity function is operating, what you have to do, you have to design effective mattresses. InfosecTrain Trainer: So, there are key... some of key principles which you have to follow whenever you design these mattresses. First thing. InfosecTrain Trainer: Any matrix you design, it should be very specific in nature. InfosecTrain Trainer: Right? InfosecTrain Trainer: like... Number... Off... InfosecTrain Trainer: employee attended the awareness training. It's specific. It's... it's actually a KPI to check the performance of your awareness training. It should be measurable. InfosecTrain Trainer: Right? It should be measurable, means it should produce some quantitative data. InfosecTrain Trainer: So you, you say, if I, if I say a matrix, that there, so, so, so the turnaround rate for the awareness training was high. InfosecTrain Trainer: What does it predict? InfosecTrain Trainer: Hi. InfosecTrain Trainer: To your... to you. InfosecTrain Trainer: Can determine that how many people attended? High means what? InfosecTrain Trainer: turnaround was high for, awareness training. Is it a good matrix? It is not. InfosecTrain Trainer: high is no... high has no definition, right? But if you say that, you say that 90% employees have attended and completed the training, it's a... InfosecTrain Trainer: measurable matrix, which says that then 10% have not completed. It means... it shows that those are still a risk, right? It should be attainable, something which you can achieve. InfosecTrain Trainer: Right?

InfosecTrain Trainer: If, suppose, an organization is very big enough, it's widely distributed across the world, you say that I want 100% InfosecTrain Trainer: completion of training probably won't be possible. There are always going to be the people, those who won't complete. There are going to be the people, those who are on holidays, or on business trips, or at the client location, they don't have access, they could not be able to complete, right? So you will say.

InfosecTrain Trainer: 95% is something which we want to achieve. So, 90% you are, 95%. You know the 5% is always going to be a gap. InfosecTrain Trainer: So, it should be attainable. It should be relevant. It should be relevant to the audience whom you are reporting. It should be relevant to the process, and should be InfosecTrain Trainer: done... timely. InfosecTrain Trainer: If you completed your awareness, if you actually organized awareness training in this month, and you're reporting this matrix after the 3 months, there is no relevance to this. InfosecTrain Trainer: Already, things have gone past, right? Again, the next quarter, the next schedule will come, right? It should be done on time. InfosecTrain Trainer: Other than that, what are the additional considerations which you do? I have a sheet where I have all the examples of all of these, which I'll explain you with those examples also, so don't worry. This is just, the example which I'm taking. I have additional example also, so that you people remember these matrices. So some things, some are... them are called the leading indicator. InfosecTrain Trainer: Leading indicator means something which helps you predict the future risk.

InfosecTrain Trainer: So you have to always design a couple of metrics in such a manner which should predict the future risk. InfosecTrain Trainer: something which can happen or cause an issue, right? There should be a casual relationship, right? Does it have a defensible relation to business impact? InfosecTrain Trainer: So, you want your business to operate effectively, you want your business to be, safe and sound. For that, you need to design a matrix which should InfosecTrain Trainer: Help you determine the impact, and it should also help you InfosecTrain Trainer: influence the decision-making. So when you are taking a decision, the matrix should help you InfosecTrain Trainer: take those decisions, right, where the improvements is needed. Do we need to have an additional funding? Do we need to deploy additional control? Are there a gap in the current process? Shall we go with the new vendor, new solution? Or your current solution, which you currently have, is not that effective. That's how the decisions are taking, right? InfosecTrain Trainer: in the organization. Your CISO will say, no, this particular solution is not good, it's not solving our purpose. InfosecTrain Trainer: we should go and replace it. And suppose the next replacement which comes, it's 20% expensive than the previous one. How CISO will go and gain the support from the leadership, how he'll convince them to invest 20% addition. He had to show the data, right? InfosecTrain Trainer: So these are the key gaps, this is the KPIs, these are the KRIs, these are the things what we have been observing for such a period of time, and these are the gaps which we want to fix. InfosecTrain Trainer: So now, these mattresses are designed into four broad categories, right?

So the... so the... so these mattresses can be strategic. Strategic is something, a matrix which is... which is for a long-term objective. InfosecTrain Trainer: Which is actually helping you check how your overall program is behaving. InfosecTrain Trainer: It's not specific to one particular process, it's around entire security program. A broad matrix. InfosecTrain Trainer: Right? And these are the mattresses which are reported to the senior management, your board of director, your CEO, all of them receive these strategic mattresses. Don't worry, I have a sheet where I'll explain you all of them in detail. Operation InfosecTrain Trainer: Null matrix is something which helps you track the day-to-day operations. InfosecTrain Trainer: Mean time to detect, mean time to respond, your number of attacks blocked by the firewall, InfosecTrain Trainer: these are all the operational matters, day-to-day things. Number of people attending the awareness training, fish clicking rate and all, all of them are operational, day-to-day mattresses, which is specific to technical and the procedural, and InfosecTrain Trainer: useful for the IT security managers, and the team leads, and the admin, too. InfosecTrain Trainer: Enhance those controls. InfosecTrain Trainer: Management mattresses are something which helps you manage the program. This is a... so a lot of people get confused with strategic and the management. Strategic is something which is talking from the overall objective, right? Organization want to establish the AI governance. InfosecTrain Trainer: How much overall AI governance from that particular objective, how many objectives you have met?

InfosecTrain Trainer: That is a strategic matrix, because the... your board of directors will ask, okay, where our AI governance program stands currently. InfosecTrain Trainer: But the management metrics is, as part of that AI governance, I want to establish the GRC-related framework, I want to establish the AI SOC, I want to have an AI inventory, all of these InfosecTrain Trainer: Different, different projects which you are running as part to InfosecTrain Trainer: of establishing AI governance that you will report via management matrix. And technical matrix is something which is help you check the machine is operating properly. Machine is what all the technical controls. InfosecTrain Trainer: You have a firewall, you have an EDR, you have an antivirus. InfosecTrain Trainer: All of these are machines, all of these are specific solutions. How effectively that solution is operating, that technical matrix will tell you, right? Now, let's see an example to understand all of them in detail. InfosecTrain Trainer: Yes. InfosecTrain Trainer: So, we discussed about the strategic metrics. So, strategic metrics is something which is reported to the board and the CXO level, right? And what is the purpose? It shows how security supports the business goals and overall risk appetite of organization. InfosecTrain Trainer: And audience is executive management and the board of directors, right? InfosecTrain Trainer: So now... You see two examples here. Percentage reduction in top 5 enterprise risk year over year. InfosecTrain Trainer: So, this is a strategic matrix. They are not concerned around... in your risk register, you have noted 100 risk. They are only focused on the top risk, what organization is posed from a security perspective, right? Security is spent as percentage of IT budget.

InfosecTrain Trainer: That is a concern for them, right? How much we are spending on overall security of the organization, right? So these are the two examples. Now, coming to the management matter rates, which is InfosecTrain Trainer: overall program and the department level, it helps you measure the performance and the maturity of the security management process. So generally, CISO, your senior leadership within the cyber, they are the audience. InfosecTrain Trainer: percentage of system covered by risk assessment annual. Suppose you are doing a risk assessment, you want to see how many of those systems are covered. InfosecTrain Trainer: mean time to close audit findings. Suppose you... there are audit findings, how much time you require to close an audit finding, right? So, these are the management metrics. Now, operational metrics is something which are the day-to-day activities, right? InfosecTrain Trainer: So here, the purpose is to track the operational efficiency and the control performance, how your effectively controls are operating, and the audience are security, operations manager, all the process owners. Percentage of incidents detected within SLA. InfosecTrain Trainer: specific to operation, right? You have an incident management process, how many incidents you are able to detect within the service level agreement. Number of patch compliance deviation. So. InfosecTrain Trainer: you are deploying the patches, entire year, you have a patch management process, you want to see how many of them are deviating from that process, becomes an operational matrix. Now, coming to the technical metrics, which is very specific to the control and the system. Here, the purpose is to provide raw technical data used to drive operational management metrics, right?

Audiences, security engineers, SOC analysts. InfosecTrain Trainer: Number of malware detection per endpoint per month. InfosecTrain Trainer: Tells you an effectiveness of anti-malware solution. InfosecTrain Trainer: False positive rate of IDS IPS alert tells you an effectiveness of IDS and IPS, right? InfosecTrain Trainer: All of you clear? InfosecTrain Trainer: Now, with these examples, what is the strategic management, operational, and the technical metrics? InfosecTrain Trainer: Now, see those smart, also, which we discussed, specific, measurable, Achievable, relevant, and time-bound. InfosecTrain Trainer: Right? InfosecTrain Trainer: Specific means clearly defined and focused. InfosecTrain Trainer: So, specific, like, reduce fish click rate. InfosecTrain Trainer: among employees, very specific. You want to reduce the fish click rate. InfosecTrain Trainer: Right? Specific on behavior of the people, right? Measurable is you want to measure... reduce fish click rate from 12% to 5%. It's a numerical measurable, which you can achieve. Achievable, based on past campaign, 5% reduction is realistic. InfosecTrain Trainer: You'll not say that we'll go down to 0%, 5% is something which you can achieve. InfosecTrain Trainer: through training, awareness campaign, and all, relevant supports objective of reducing insider risk. So, if you... InfosecTrain Trainer: improve this, it will help you manage the insider risk as well. And time-bound, within 6 months, you want to do this reduction. So, this is a time-bound. So, with one matrix, you can see InfosecTrain Trainer: Complete, smart, alignment. InfosecTrain Trainer: Right? InfosecTrain Trainer: All of you clear, now, on the matrix? Pudir: Is it? InfosecTrain Trainer: Alright. InfosecTrain Trainer: Yeah.

InfosecTrain Trainer: Now, you want... you have to have a process of measuring your overall Information security governance as well. InfosecTrain Trainer: Right? InfosecTrain Trainer: So, whenever you create these mattresses, all the mattresses should be based on the attribute, cost, outcome, and security program. InfosecTrain Trainer: All the mattresses which we discussed so far, all of them are based on... based on your overall program objectives, also some cost outcomes they are bringing, right? InfosecTrain Trainer: If people keep clicking on the phishing link, there is a cost outcome to it, right? You, probably someday there can be a major incident occurring because of an employee clicking there, right? InfosecTrain Trainer: And effective measures can be developed using defined objectives. So that's why it's very important to have a clear objective set as part of the program. If you don't have a clearly defined objective, how you will measure it? InfosecTrain Trainer: If you say that I want to set an objective of 75%, InfosecTrain Trainer: score in my... all the practice tests which I say. InfosecTrain Trainer: then only you'll be able to improve, right? You have set an objective 75%. InfosecTrain Trainer: If there is no objective, you don't know that... you will say the 60% is also good. 55% is also a good score. That's why you have to set an objective, right? InfosecTrain Trainer: An objective serves as the reference point to measure the progress of security programs. This is the reference point. InfosecTrain Trainer: which you have said, that this is the reference point, I want to achieve 75%, InfosecTrain Trainer: If I'm able to get consistently 75% in all the exams which I write, then only I'll go

ahead and book the exam.

InfosecTrain Trainer: And mattresses can be reduced to any measure of the result to demonstrate that progress. InfosecTrain Trainer: So you have to tailor these mattresses, you have to reduce it to the measure so that you can have a quantitatively measuring... measured mattresses, so that you can InfosecTrain Trainer: Understand the progress of the process. InfosecTrain Trainer: So... so... and whenever you... now, after designing the mattresses, when you get the mattresses, it's also important to do analysis on them, right? It's not just there, you... InfosecTrain Trainer: have a matrix, and it's every month being shown on your Power BI dashboard, or being generated through some solutions which you have in the organization. InfosecTrain Trainer: It's just being shown, and people are not taking any action on this. You have to take some action, right? InfosecTrain Trainer: So the result-oriented matrix analysis should be done, so that you know that... how to improve that process, right? InfosecTrain Trainer: Also, you have to have a quantifiable performance metric, so that you understand the performance of that particular control process. Also, you should have a practical security policies and the procedures, which should be established to InfosecTrain Trainer: Have reduced the impact, and... InfosecTrain Trainer: Without upper management support, without the strong support from the leadership, you cannot achieve these objectives. InfosecTrain Trainer: Now, coming to the operational risk. InfosecTrain Trainer: So, these are a couple of security-specific metrics. So, row C is nothing, it's a... it's a kind of a, I would say, a... InfosecTrain Trainer: Fancy term given to ROI. InfosecTrain Trainer: So, if Pudir becomes a CISO, he'll not go and say.

InfosecTrain Trainer: to the senior management ROI, right? He'll say the ROSI. It looks fancy. So, it's nothing, it's just a fancy term to the ROI in terms of security. So, whatever you are doing, the investment on the security, that security investment should be justified. InfosecTrain Trainer: Right. InfosecTrain Trainer: If you are invested... investing for, suppose, \$5 million. InfosecTrain Trainer: You should be able to showcase that that \$5 million is bringing result to the organization, overall reduce... reduction in the InfosecTrain Trainer: cost, reduction in the number of incidents, overall improved security posture posture, and everything. So the ROSI has a formula, but don't worry, they won't ask you in the exam, it's just there for your reference, for the knowledge. It's called the ALE before safeguard minus ALE after safeguard minus cost of safeguard. InfosecTrain Trainer: So, we discussed multiple times, if you want to protect a thousand... InfosecTrain Trainer: dollar asset, you will not deploy a \$1,500 solution for the... Right? InfosecTrain Trainer: So, always, it's going to be the less than that, and that's what Rosie does. InfosecTrain Trainer: So, before deploying a safeguard, how much was the annual loss expectancy? Once I deployed, what is the overall reduction in that, minus how much is the cost of that safeguard which I deployed? That will give you ROSI. InfosecTrain Trainer: Value at risk means how much is the risk which you have in that overall process. The formula is asset value multiplied by exposure factor multiplied by confidence interval. InfosecTrain Trainer: Confidence interval is something which comes from the bell curve.

InfosecTrain Trainer: And the ALE, we already discussed the formula also, annualized loss dependency means ALE means ARO multiplied by SLE. InfosecTrain Trainer: All of you want, you can take a screenshot of this slide, but just be clear and understand around these terms, what does they mean? That's it. You will not get any numerical, they will not ask you the formula also in the exam. InfosecTrain Trainer: Just, you should have an understanding what does ROSI means, var means, and ALE means. InfosecTrain Trainer: So whenever you develop a matrix, so we have already discussed a couple of these in the SMART also, right? InfosecTrain Trainer: First thing. InfosecTrain Trainer: Any metrics you design. InfosecTrain Trainer: So this topic is not only important from the CISM perspective, this topic is also very important from your own InfosecTrain Trainer: job which you do in your organization, right? A day-to-day basis. InfosecTrain Trainer: And you have to, at some point of time, design a matrix. Either you are a team lead, you are a manager, you are a director, whatever role you are, whatever process you are managing, if you don't create a proper matrix to measure that performance. InfosecTrain Trainer: How you will be able to understand what are the loopholes, right? InfosecTrain Trainer: So those mattresses should be manageable. InfosecTrain Trainer: whatever result those mattresses are generating, whatever matrix you have designed, should be able to take some action on the basis of that. You should have resources, and the time, and the funding, and all the things to help InfosecTrain Trainer: Remediate the issues which are being highlighted by them. InfosecTrain Trainer: Second thing, it should be meaningful. InfosecTrain Trainer: Meaningful for the audience.

InfosecTrain Trainer: If you start telling the total number of vulnerabilities which are detected to the board of directors, what will they do with that? InfosecTrain Trainer: That in your organization, you have these many number of vulnerabilities. InfosecTrain Trainer: Probably, they might be interested in that, how many are the systems which are, still not passed. InfosecTrain Trainer: How many are the critical systems which remains unpatched? That is a risk. InfosecTrain Trainer: That is a meaningful matrix for them. InfosecTrain Trainer: Next thing, it should be actionable. You should be able to take some action on it. InfosecTrain Trainer: If I say the... if I ask someone that, okay, you people attempted the Domain 1 and Domain 2 exam, okay, how much... how was the score? You say, I... I did not... InfosecTrain Trainer: actually measure the score. As per me, my score was good. InfosecTrain Trainer: So how come you can take action on this? InfosecTrain Trainer: From which point you want to improve, what is a good score, as per you? Probably, as per you, the 60% is a good, but the threshold is 70%. InfosecTrain Trainer: So, always there should be an action, unambiguous. It should be correct. InfosecTrain Trainer: Accurate. Unambiguous and accurate, right? InfosecTrain Trainer: It should not show some false data and wrong information, right? InfosecTrain Trainer: the metric should be reliable in nature, so that people can rely on the information, what you are showing it to them. It should show the accurate data, and should be on time, they discussed, right? InfosecTrain Trainer: If it's not in a time frame, it's not being reported on a time, then it's not a correct matrix, and should be able to predict some future risk, and generate.

So these are all the considerations which you have to keep in mind when you think of designing a InfosecTrain Trainer: Proper metrics for your organization. InfosecTrain Trainer: So this is a slide which I have created for all of you to make sure that you remember this topic from a... you can take a screenshot of this slide. It will help you to revise this particular topic. InfosecTrain Trainer: So, whenever you are measuring the information security program success, So, there are 5 pillars. InfosecTrain Trainer: When you want to measure success of your program. InfosecTrain Trainer: First thing is the continuous monitoring. So, all the organizations these days are moving from point in time... InfosecTrain Trainer: To the continuous monitoring. InfosecTrain Trainer: Why do you... Invest so much on InfosecTrain Trainer: sophisticated solutions, tools, technologies. This is the reason. You want to have a continuous monitoring. Why organization is adopting AI? InfosecTrain Trainer: Because human cannot continuously stay vigilant and alert, right? Why organizations are trying hard to replace the L1 analyst with the AI agents? Because InfosecTrain Trainer: at least the initial step where people take a lot of time to correlate the multiple sources, multiple data, and then take action, AI would be able to help you with that, right? That is the continuous monitoring. Then compliance verification. InfosecTrain Trainer: So... So, you... As part of your organization, you have to comply to some InfosecTrain Trainer: regulations, some directives, some frameworks, right? If you are a payment card industry, you have to InfosecTrain Trainer: comply to PCI DSS. If you are a healthcare organization collecting PHIE, so you have to show InfosecTrain Trainer: HIPAA compliance in U.S.

InfosecTrain Trainer: Right? If you are in EU, you have to show GDPR compliance. You have to comply to NISTU. In India, you have to comply to DPDP, so all the compliance verification, also, you can check through matrix, and help you build an adaptive security. InfosecTrain Trainer: So that... InfosecTrain Trainer: Any gaps, any issues you identify as part of this, you should be able to adapt and adjust your baseline. InfosecTrain Trainer: In your organization, earlier you were considering GDPR. GDPR has a 72-hour incident reporting timeline, but a new regulation comes in tomorrow. It says the 24 hours. InfosecTrain Trainer: You have to adjust. InfosecTrain Trainer: your baseline. You have to adjust your overall, security, SOPs and all, right? InfosecTrain Trainer: Then, stakeholder engagement. So, the mattresses helps you ensure InfosecTrain Trainer: IT owner, business owners, they are all aligned to you. InfosecTrain Trainer: Right? InfosecTrain Trainer: And then you do the metric development, so you have to design a... InfosecTrain Trainer: qualitative and qualitative metrics to outcomes, right? So these are 5 things, or the pillars of measuring success of your program, and the metrics InfosecTrain Trainer: are of three categories, KGIs, KPIs, KRIs, which we have already discussed in detail. InfosecTrain Trainer: So this statement, as I already told you, you cannot manage what you cannot measure, so the matrix turns security activities into evidence of business value. InfosecTrain Trainer: Now, coming to the next topic, which is very important, security controls. InfosecTrain Trainer: And what is a control? InfosecTrain Trainer: First, let me ask you, what is a control? What do you mean by a control? InfosecTrain Trainer: Any example of control?

InfosecTrain Trainer: Anyone? What is the control? SrinivasanJ: Decree. Fatha: Measure or check? Fatha: Measuring and checking and, you know, restricting. SrinivasanJ: I'll... Example, like, MFA must be enabled for VPN access. InfosecTrain Trainer: Okay. InfosecTrain Trainer: And what is the significance of control from a risk perspective? We're discussing that domain, too. Johny Souriar: Ugh. Johny Souriar: After a control, then the risk will be reduced to a residual risk will come. SrinivasanJ: Prevents exploitation. InfosecTrain Trainer: Reducing risk to an acceptable level, right? SrinivasanJ: producing. InfosecTrain Trainer: That's what the control does. Pudir: Primarily, control reduces the risk of exposure, and Perhaps it will... Pudir: Keep the institution as

desired level of objectives. InfosecTrain Trainer: Correct. It will keep your risk within your appetite, right? InfosecTrain Trainer: within your organization appetite. That's what the control does, right? Sandeep Saxena: So, one question. Control is supposed to reduce the risk. Sandeep Saxena: Okay, and risk is based on the impact and the likelihood. Control can either reduce the likelihood, or it can either reduce the impact. Sandeep Saxena: Right? InfosecTrain Trainer: Yes, yes. Sandeep Saxena: Okay, and so this is the main objective. If regulation is also soliciting that, regulation is also soliciting that for the same purpose, or it will also suggest for the same purpose, to reduce the risk, right? InfosecTrain Trainer: So, I told you a statement, right? All the regulations need to be considered as a risk. Sandeep Saxena: Right. InfosecTrain Trainer: Any regulation, you name it, it should go as a risk in your risk register.

InfosecTrain Trainer: Because if you do not comply to that, there is a risk to an organization. So at what level you want to reduce that risk, it's up to your organization with how much compliance they want to show it against it, right? InfosecTrain Trainer: Now, controls are not only the one which you see, like technical control, like firewall, EDR, intergener detection system, encryption mechanism, MFA, and all those things. Controls are also... comes in form of the procedure. InfosecTrain Trainer: That's why whenever you see the NIST ISO and all the mapping you do, they will also name couple of SOPs, policies, standards. InfosecTrain Trainer: All of those are also somehow reducing the risk in some manner, right? Like, acceptable use policies, your information security policy, identity and access management policy, whatever policies you have, right? So controls are procedure, mechanisms, systems. InfosecTrain Trainer: and other measures which are designed to reduce risk through compliance to the policies, right? And they ensure that the business objectives are met, risks are reduced, and the errors are prevented or corrected. InfosecTrain Trainer: On controls you create for what? You either create it for the regulations. InfosecTrain Trainer: There are cybersecurity regulations, your organization is ISO 27001 or 42001 compliant, so you will need to create control to show compliance to that. If your organization is NIST2 or GDPR compliant, you have to create control to reduce it. InfosecTrain Trainer: Once you do a risk assessment, as part of that also, if analysis indicates there is a gap, you have to create a control.

Sometime, audit result will also InfosecTrain Trainer: Show some gaps, audit results will show that there is a risk, there are issues in the environment, you have to create a calculus, right? InfosecTrain Trainer: This is how you generate and design the control, and any control, you keep it, so control will have a... every control has a control objective. InfosecTrain Trainer: Any control you name in the organization, it is designed with some objective. InfosecTrain Trainer: So, firewall has an objective, antivirus software has an objective, multi-factor authentication, which you have enabled, that also has an objective. The EDR solution has objective, DLP also has objective. So, all the controls which you deploy has some objective to meet, and that objective is something which helps you create a matrix around. InfosecTrain Trainer: If you're not able to meet that objective. InfosecTrain Trainer: that objective and the gap between the control is a matrix, right? The control objective is something which helps to describe the desired state or outcome of business operation, right? So, some example of objective? InfosecTrain Trainer: protection of IT assets and the information. You want to achieve a protection. You want accuracy of transactions. InfosecTrain Trainer: You want to achieve confidentiality and privacy in the organization. You want availability of IT systems. InfosecTrain Trainer: How you ensure the availability? There are multiple things which you will do as part of it. You want to control the changes to IT systems. You will establish a change management process. You want compliance with policies and regulations. InfosecTrain Trainer: Now, let's take an example of one control, availability of IT systems.

InfosecTrain Trainer: This is an objective, but can you meet this objective only with one control? You cannot. InfosecTrain Trainer: You have to design some set of controls to achieve this, right? So you will do what? You will monitor all the IT systems continuously. InfosecTrain Trainer: So that if there is any failure, you understand that failure, so that you can fix the issue immediately. Interruption will result in alerts to appropriate person, so that person can immediately InfosecTrain Trainer: immediately follow the containment and the eradication and the recovery SOP, and they can do that, so, right? InfosecTrain Trainer: Systems, all the systems will have the resources measuring capability. InfosecTrain Trainer: IT management will review capacity report monthly. Systems will have an anti-malware control, and there can be InfosecTrain Trainer: long list. I'm not saying that these are the only controls which will help you achieve it, it's just an example. InfosecTrain Trainer: This slide will help you InfosecTrain Trainer: Understand how the control objective, control, and the metrics are created and related with each other. InfosecTrain Trainer: So you have a control objective to ensure the confidentiality, integrity, and availability of customer data. InfosecTrain Trainer: This is a control. InfosecTrain Trainer: Right? You want to achieve the CIA of customer data. What is the control? You have implemented an encryption for data at rest and in transit. InfosecTrain Trainer: And what are the objectives, what are the metrics? Percentage of database encrypted, percentage of data transferred using TLS 1.3, number of data breaches due to encryption failure. Which of these is KPI, and which of these is KRI? Tell me.

InfosecTrain Trainer: all... you can see 3 here, which is KPI and which is KRI. Sandeep Saxena: One question. Controls? Sandeep Saxena: We think about controls right after the risk assessment. Sandeep Saxena: or after some other step. This is the first question, second question. Controls are not part of the strategy, it's a part of the... Sandeep Saxena: security program development. Sandeep Saxena: Right? InfosecTrain Trainer: Can you please repeat that again? Sandeep Saxena: Two questions. First question was, at what time do we think about the controls right up to the risk assessment, or after something else? Sandeep Saxena: And second, controls, we talk about controls not at the strategic level. Sandeep Saxena: But at the information security program development, like, what all controls you'll be having. InfosecTrain Trainer: Connect. Sandeep Saxena: Both the things are correct? InfosecTrain Trainer: Yeah, both the things are correct. Sandeep Saxena: Oh, thank you. InfosecTrain Trainer: Now, anyone tell me which is the KPI, which is the KRI here. You can see 3... InfosecTrain Trainer: metric cells, which are written here, which is KPI, which is KRI. Johnny Souriar: Number of breaches is... KPA. InfosecTrain Trainer: This is KPI. SrinivasanJ: Goal. Johnny Souriar: Prevented, prevented. Johnny Souriar: Rob data, which is prevented. InfosecTrain Trainer: Okay, and then percentage of database encrypted, percentage of data transferred using ETLS is? Mukesh Thakur: Those are performance indicators, so I believe those are going to be KPIs. Mukesh Thakur: And the last one, number of data, is going to be KRI, because it reduces the risk. InfosecTrain Trainer: Correct. This is something which is telling you the risk in the process, right?

InfosecTrain Trainer: There are encryption failure, and there is a... InfosecTrain Trainer: breach because of it. It's a risk in the process, right? InfosecTrain Trainer: This is something which is telling you the objective, how much you have achieved the objective, right? You have set an objective that you want all the database to be encrypted. InfosecTrain Trainer: Here, however, it is not specifically mentioned that what is the objective, but there is objective. InfosecTrain Trainer: You want your 95% database should be encrypted, right? So how much you have achieved, that is an objective, so it becomes KGI, and this is a process. InfosecTrain Trainer: you have a TLS 1.3 encryption protocol implemented, and you are continuously checking against it that how much data is being transferred using this processor. InfosecTrain Trainer: people are not using it, it means that there is a... there is a... the gap in the process, right? It's a process, so it becomes a KPI. InfosecTrain Trainer: So this is... AGI... API and TRI. InfosecTrain Trainer: No. InfosecTrain Trainer: All the controls which you design in the organization, those controls will InfosecTrain Trainer: be categorized into these three categories. Either they will be an administrative control, or a technical logical control, or a fiscal control. Johnny Souriar: Hello, it's low volume, can you just replace my... InfosecTrain Trainer: Okay, is it fine now? Johnny Souriar: Yeah, this is okay. InfosecTrain Trainer: Okay, sure, sure, thank you. InfosecTrain Trainer: So, all the controls which you design in the organization, they are going to be in the three categories. InfosecTrain Trainer: Administrative is something which comes in form of the directions. InfosecTrain Trainer: Policy. InfosecTrain Trainer: Instruction.

InfosecTrain Trainer: All these things are administrative. InfosecTrain Trainer: Like, when you go to your office. InfosecTrain Trainer: In your office corridor, there is a warning sign which is written, right, that do not interrupt the door of your InfosecTrain Trainer: Lift by... when it is getting closed. InfosecTrain Trainer: This is the direction. InfosecTrain Trainer: Right. InfosecTrain Trainer: So, this particular building is anti-CCTV surveillance. InfosecTrain Trainer: Right? You are... your acceptable use policy says that you are not supposed to browse any social media website between the office time, something like that, so... InfosecTrain Trainer: All of these are coming in from the direction, those are administrative. Technical is something, or the logical is something which is there in form of the technology, inform the rule. InfosecTrain Trainer: multi-factor authentication, your encryption, your RBAC control, your identity and access management control, your firewalls, your EDRs. InfosecTrain Trainer: all of them are ideas, IPS, all of them are technical and the logical control. Physical is something which is physical in nature, which you can touch, feel, look. InfosecTrain Trainer: Right? Your security cameras, your access card reader, your biometric security, right? All of them are physical InfosecTrain Trainer: control. So, any control, you name it. InfosecTrain Trainer: would be either coming in this form, this form, this form. You can categorize them, right? Now, this is a categories of control, not coming through InfosecTrain Trainer: What that control actually do? InfosecTrain Trainer: So, what that control do is becomes a InfosecTrain Trainer: The property of that control, right? InfosecTrain Trainer: Let's take a very simple example.

InfosecTrain Trainer: So that you understand all these controls, right? InfosecTrain Trainer: So... InfosecTrain Trainer: you... every day you go to office, right? So, office, I'm not talking about people, those who are probably working remotely, I'm talking about the people, those who go into office, right? So, office would

have given you one access card with a chip, access card reader, they would have issued you, right? InfosecTrain Trainer: So that access card makes sure that only authorized employee is able to get into your organization premise. InfosecTrain Trainer: What it is, it is a preventative control. InfosecTrain Trainer: It help prevent an unauthorized person entering into your organization. InfosecTrain Trainer: It's a preventative control. InfosecTrain Trainer: Right? Now... if... some... InfosecTrain Trainer: unauthorized person is able to get a card from outside, steal something from someone and all, there is a security camera, there is a security guard. He can see the behavior of the person and detect and report. InfosecTrain Trainer: A detective control. Now, one day you forgot to carry this ID card to the office. Will you InfosecTrain Trainer: Go back to home? No. There is a compensating control to it. InfosecTrain Trainer: So you will go to the security desk, he will ask you your employee ID, he will ask your name, number, and all, he'll check in the database, he'll verify, he'll say, okay, this is a person working in the organization, there's going to be a photo, he'll verify, he'll give you a guest card for that day. Becomes a compensating control to the same process. InfosecTrain Trainer: Now, what is a deterrent control? InfosecTrain Trainer: So, when you enter into your office, you will see this particular building is under CCTV surveillance.

InfosecTrain Trainer: any unauthorized person would be pro... prosecuted and would be handed over to the, to the law enforcement, or something like that. These are all the debtor and control. Sometimes in building, you say that if it's a high security zone, if you walk around any military campus, they will say that InfosecTrain Trainer: Say that, that intruders would be shot. InfosecTrain Trainer: All of those are deterrent control. InfosecTrain Trainer: And now, coming to the corrective and the recovery, peace control comes into picture when actually there is an incident. InfosecTrain Trainer: Now, there is an incident, an unauthorized person was able to bypass everything, get into your organization, able to reach to a point InfosecTrain Trainer: now you want to correct the thing, right? Probably he would have stolen some information, he would have done something, so you want to correct it. And recovery is something... InfosecTrain Trainer: restoring everything back to normal. Like, suppose if there is an incident, there is a malware in your computer, what you will do immediately, you will do a corrective control, where you will immediately isolate the system. InfosecTrain Trainer: And... InfosecTrain Trainer: now the incident investigation, everything is done, everything is normal. Now what you will do, you will, again, recover the system from the image. InfosecTrain Trainer: Right? Now, if you see this diagram, this diagram shows you the cycle of all these controls, and which all controls are there before incident, which controls operate post-incident. InfosecTrain Trainer: So your directive control, preventative control, and compensating control, like your access card. InfosecTrain Trainer: Right? And you have to hang your ID card always around your neck.

You would have seen that direction, which your security team will say you, right? If you're keeping those cards in your pocket, they will say, no, please use the same badge, InfosecTrain Trainer: which your organization has given, they would have given one particular strap, right? You have to use that. That's the directive control. Preventative control, that access card. InfosecTrain Trainer: Compensating, I already explained, if you forgot how to do. Now, still, someone else was able to enter your organization, there is an incident. InfosecTrain Trainer: it was detected by some security camera, or security person, or some another employee who was able to see that I don't... I do not know this person, I've seen him first time in the... in this particular floor. InfosecTrain Trainer: detective control. Corrective control, now you want to correct the process, you want to restore, probably he would have gone to some sensitive areas and all, you want to restore, and recovery is permanent recovery. InfosecTrain Trainer: Anyone has any doubts on the controls? Johnny Souriar: Getting backup on media is which type of control? InfosecTrain Trainer: The backup on media is... is not a... is not a recovery or corrective control. InfosecTrain Trainer: Backup you are taking for what? InfosecTrain Trainer: You are keeping that backup so that if tomorrow there is an incident, you should be able to recover the information from there, right? InfosecTrain Trainer: Correct? Johnny Souriar: Yes, so it's recovery control. InfosecTrain Trainer: No, no, no. Recovery control is something which will come into picture once you want to recover the system. Mukesh Thakur: Is this a preventive control? InfosecTrain Trainer: Yes. Mukesh Thakur: 20, let alone. InfosecTrain Trainer: Yeah, so you're.

Johnny Souriar: incident, right? InfosecTrain Trainer: your RTO and the RPO which you set, at what frequency you are taking a backup. InfosecTrain Trainer: that RTO and RPO, what you have set in the organization, like RPO frequency, it is not preventing the things from happening, right? InfosecTrain Trainer: But this is something which is helping you with the recovery. If tomorrow there is an incident, it will help you restore the operations from that particular thing, right? It's not a recovery, this is a... InfosecTrain Trainer: Corrective control. InfosecTrain Trainer: It will correct the process and the recovery, you will use the image, and then you will install the backup, you will recover the operations. InfosecTrain Trainer: Preventative is something which will help you prevent the incident, prevent the thing from happening, because taking backup would not prevent a ransomware attack. InfosecTrain Trainer: The backup would come into picture when the incident has already taken place, right? InfosecTrain Trainer: Now, there is a ransomware attack against your organization. InfosecTrain Trainer: what you will do in this case, you have to have a backup, right? InfosecTrain Trainer: So you will first, you will first, isolate the system where that backup was there, where the issue was there, and then you will use the backup as part of that media to recover. So it's a recovery control. Sorry, my correction. It's a recovery control. InfosecTrain Trainer: The taking backup on media is a recovery control, that media would be help you... that media will help you to recover the operation back to the normal. InfosecTrain Trainer: Got Johnny? Johnny Souriar: Oh, yes sir, yes sir.

InfosecTrain Trainer: So, if you remember this diagram, you will be able to understand which control do what, right? Something which is coming post-incident would become this. Something which is before incident would be this, right? InfosecTrain Trainer: like, if I'd say, You're sinful. Johnny Souriar: Logic, in that logic, backup is taken before incident, right? So that logic will not stop. InfosecTrain Trainer: No, no, backup you are taking before incident, but backup would come into picture after incident, right? InfosecTrain Trainer: Backup would be used post-incident only, right? You're taking it on a regular basis, but when you will operate the backup, only when there is an incident, right? Now, my time, you won't be using that backup, right? Johnny Souriar: Oh, good. InfosecTrain Trainer: Yeah. InfosecTrain Trainer: So, what kind of control is SIEM? InfosecTrain Trainer: Which kind of control is SIM? Johnny Souriar: depicted. InfosecTrain Trainer: CISM is a detective controller, correct? Sandeep Saxena: I was just thinking, there can be some overlapping in preventive controls or compensating controls. For example, there is a VAF, okay? Sandeep Saxena: what do you call it? Preventive control or composite control? You can call it both ways. InfosecTrain Trainer: No, no, no, it depends what it does. If you have multiple layer of firewalls, then it becomes a compensating. InfosecTrain Trainer: Like, one... the first thing which helps you prevent, and the next thing which helps you... InfosecTrain Trainer: as a compensating control. Like, suppose when you design a network architecture, you don't just keep one firewall, and then after that, everything is there, right? You will design the security in depth. We discussed, right, defense in depth.

InfosecTrain Trainer: approach. InfosecTrain Trainer: So that desk is there as a compensating. Even if one firewall person is able to breach and is able to reach, there is another one control which is there to help InfosecTrain Trainer: your organization prevent that time. Got it? InfosecTrain Trainer: Sandeep. Sandeep Saxena: I mean, for the simplicity, let's assume that there is a website domain, and there is only one web application file. Okay. Sandeep Saxena: So, firewall is supposed to block the NATs, or by application firewall is supposed to burn. Sandeep Saxena: It's preventive. Sandeep Saxena: Because it's actually blocking your attacks. Sandeep Saxena: It can be called compensating, it should be called compensating in my view, because it's required, because my application layer controls are not there, so it can block the attacks. What do you think? Sandeep Saxena: I think it's overlapping, you can call it either preventive or convulsive. InfosecTrain Trainer: So, it depends on the objective. InfosecTrain Trainer: If you have a clear objective. InfosecTrain Trainer: of that control. If you read that objective, as per the objective, it will be decided it's compensating or preventative. Got it? InfosecTrain Trainer: What is the objective of that control in that particular process? That will decide. Like, you have a... you have a... whenever you log into your account, you use your login ID and password. InfosecTrain Trainer: That is a preventative control. InfosecTrain Trainer: But after that, even you still have an MFA. Sandeep Saxena: Yes. InfosecTrain Trainer: Which is there as part of... which is there supporting that preventative control, right? Sandeep Saxena: Yes. InfosecTrain Trainer: Can MFA work without login ID and password? InfosecTrain Trainer: It cannot.

InfosecTrain Trainer: So all of them are working together, right? InfosecTrain Trainer: But even if after doing this, someone is able to probably log into the account by stealing some credentials and something, he's still able to get into... and one more thing, it's not necessary the compensating control would be there in each and every architecture, or each and every process. InfosecTrain Trainer: Everywhere you don't have a compensating control. That's also there. InfosecTrain Trainer: So, like, like, whenever there is a fire in the building, you have a sprinkler on the top. That is a InfosecTrain Trainer: Preventative... that is the one control which helps you reduce the fire, right? InfosecTrain Trainer: But after that, still you have one hoses, pipes, and everything. InfosecTrain Trainer: Which is there. Like, like, even if that particular sprinkler do not work, probably there is a manual hose pipe from where people can throw water. InfosecTrain Trainer: To reduce the fire. InfosecTrain Trainer: So that is one more compensating control which is there in the building, given. Got, Sandeep? Sandeep Saxena: Well, I think it's all about... we have different controls in the chain of defensive depth. Sandeep Saxena: we can call Sandeep Saxena: one control as the primary control, which can be called preventive, and all other controls in the chain of defensive depth as compensating control. Correct. InfosecTrain

Trainer: Correct. Sandeep Saxena: Yeah, I agree. InfosecTrain Trainer: Let's discuss this after the break. InfosecTrain Trainer: Automation and the manual. InfosecTrain Trainer: Control. Pudir: Several smile issues. InfosecTrain Trainer: Yeah, Pudir. Pudir: I, Sandeep, can you repeat your statement? Just, I want to go through it.

Sandeep Saxena: Okay, so... so let's, have a simple example. You have a website, okay, and you have a WAF, WAP Decation Firewall, okay? How do you want to Sandeep Saxena: to restrict the SQL engine, okay? So, you say that... Sandeep Saxena: We should write the secure code. Sandeep Saxena: Okay? So that should be our preventive control, and you always have a WAF Sandeep Saxena: This is the second control, which you can call as compensating control. You can have several other controls as well, but one is your primary, which is your secure coding thing. You can have another control, which can be your frameworks, and then you can have another control. One is primary, and all other are compensating controls. Pudir: Okay, okay, okay, nice, I got it. Thanks. Sandeep Saxena: all about... you talk about cross-side scripting, there are many, many controls. One is primary secure code, all others are maybe complex saving. InfosecTrain Trainer: That's... that's correct analogy, yeah, Sandeep. Pudir: Thank you. Thank you, Seth. InfosecTrain Trainer: Yeah, thank you, thank you, everyone. InfosecTrain Trainer: I hope everyone's back. InfosecTrain Trainer: Alright, let's... Get started with the next topic. InfosecTrain Trainer: So now, once you have a controls, right, so... so there are two types of controls. One kind of control which you can automate. InfosecTrain Trainer: Second thing which you cannot automate. InfosecTrain Trainer: It's not necessary that you can automate everything in the organization, like information security policy. InfosecTrain Trainer: Your acceptable use policies, your directions, can you automate? You cannot. InfosecTrain Trainer: Even in the process, also, there are a couple of things which you want to keep manual, like human in the loop in AI.

InfosecTrain Trainer: You would rarely see an AI being deployed as a... taking an autonomous decision. You will always see a human in the loop. What does a human loop in loop do? InfosecTrain Trainer: It's a manual control. The person will verify the output which is being generated, or the decision being taken by the AI, and then it will close the loop. So... so those are the manual controls. So... so... but... InfosecTrain Trainer: Your always focus should be, in the overall program perspective, to automate as many controls as you can, right? InfosecTrain Trainer: First thing, the automation achieved the consistency, right? InfosecTrain Trainer: Every time you will get the same result. So people may miss... commit the mistake, like, I'm... InfosecTrain Trainer: doing the same... I'm reading the same document, I'll probably perceive it differently from another person in my team, so... InfosecTrain Trainer: That's automation. What automation will achieve, right? So, first thing. InfosecTrain Trainer: Any control which is able to perform a function without or no human intervention become automatic control, like the logging pages. InfosecTrain Trainer: Automated, locking security doors, right? InfosecTrain Trainer: But automatic controls are generally more reliable and consistent, right? The error rate would be less, and they can operate continuously without flooding. InfosecTrain Trainer: But there are processes, there are places where you need people to operate them, right? Where you will need the people to operate, right? Like, monthly review of computer, number of people who are using, right? InfosecTrain Trainer: And there could be a higher error rate, as I told you. Like, I am... InfosecTrain Trainer: reading the same document, I would perceive it differently.

If Sandeep is reading the same document, he would perceive it differently, right? And you can apply the human judgment to any complex situation. InfosecTrain Trainer: And these controls are actually established and necessary when you see the automation is impractical. There are places, there are processes where you cannot fully automate those processes. There, you will use the manual controls. InfosecTrain Trainer: So, there are some key cybersecurity practices, processes, which you all should be aware of, which help you achieve the automation. InfosecTrain Trainer: First thing is the logical cont... InfosecTrain Trainer: So all the access controls which you have, be it the RBAC, your PAM controls. InfosecTrain Trainer: your just-in-time control. What are these? These are all the access, or the logical control. These are logical control, which help you achieve the automation, your SSO. InfosecTrain Trainer: single sign-on. What it is doing, it's basically automating the process of your access in the system, right? So these are the logical controls. Even you can automate these processes using a automation technique. Like, SSO helps you automate the InfosecTrain Trainer: Traditional login, log-out process, like. InfosecTrain Trainer: You need not remember your password every time. It's a token-based, it will be done. InfosecTrain Trainer: Next thing comes... so there are two processes. One is called the fail-safe. InfosecTrain Trainer: Versus... Fail secure. InfosecTrain Trainer: Can someone explain me what is the key difference between the fail-safe versus fail-secure? Shweta Sundar: For faith safe, please, for human safety. Shweta Sundar: Where, if, for example, into a ripe, in case of a fire accident, it might... Shweta Sundar: Leave open, and human rights is important.

Fail secure is, the opens with any human thoughts. Shweta Sundar: Often seen in technical controls where it's closed and all access is complete. InfosecTrain Trainer: So, fail-safe is a system which is deployed at some places where you need safety to be a important thing. You want that system to continuously operate and run. InfosecTrain Trainer: Like, if we take an example of firewall. InfosecTrain Trainer: If firewall is working in a fail-safe mode, and if there is an issue with this firewall, it stopped working, what it will do, it will allow all the traffic to pass. InfosecTrain Trainer: So that the system which is sitting at the end won't, won't stop working, right? But if it is working in a failed secure mode, it will completely block all the traffic, nothing would go able to bypass this. InfosecTrain Trainer: So that's the difference between fail-safe and fail-secure, right? And the principle of least privilege, which you deploy. InfosecTrain Trainer: To make sure and to establish a process so that the person should only have a InfosecTrain Trainer: That much privilege, that much access, which he needs to perform that particular job. InfosecTrain Trainer: If there is a software tester. InfosecTrain Trainer: And if it's a software developer... So, why the software tester need, access to the prod? InfosecTrain Trainer: environment, right? He can test it. So that's how you decide that which all-access InfosecTrain Trainer: tester should have, which all access a developer should have. Similarly, in your day-to-day job, right? You... people even do a lot of IJPs, internal job postings. Suppose you are working as an individual contributor, now you got promoted, moved to some other team as a manager.

InfosecTrain Trainer: you are handling some other processes, other key systems, you are probably a database administrator there. But as a manager, you did not to be... have rights of a database administrator, right? So your... those rights would go away. So, principle of least privilege means whatever is the bare minimum needed to perform your job, only those rights should be given to you. InfosecTrain Trainer: Then comes the compartmentalization. Compartmentalization is a concept to achieve zero trust. InfosecTrain Trainer: So, rather than designing a system as a whole, you design system in small, small blocks, and all those blocks should be communicating with each other. InfosecTrain Trainer: with the APIs. InfosecTrain Trainer: That's what the microservices architecture is based on, the compartmentalization. Not only from application architecture perspective, even in your network architecture also, should we design it in such a manner, rather than once person bypass one firewall, he should be able to roam around InfosecTrain Trainer: Within your entire network parameter, that should not be done. InfosecTrain Trainer: Each and every system should be sitting behind different firewall, and there should be an authentication authorization at each end. InfosecTrain Trainer: 2. So that will help you achieve the zero trust. Now, separation of duty is another A concept where... InfosecTrain Trainer: You need to make sure the person... the maker and checker concept. InfosecTrain Trainer: like you generated an invoice for a bill, it should not happen that you yourself are approving the same invoice. There should be someone else InfosecTrain Trainer: About you, who should be... Keeping a check. Like. InfosecTrain Trainer: CEO is the boss who runs the complete organization.

That's why you have a board of directors sitting on top of CEO. InfosecTrain Trainer: So that they are keeping check on what CEO is doing. And you would have seen, instances where CEOs are also sagged. InfosecTrain Trainer: Like your production prod environment, non-prod environment. They're separate. InfosecTrain Trainer: segregation, right? Then comes the transparency. InfosecTrain Trainer: So, you need a transparency in the process through which you build a trust. Like. InfosecTrain Trainer: Like, whenever you log into any website, they give you a consent form, which is 3-4 pages long, which no one reads. Eventually, you just scroll down and just you give the consent, but that's what it means. InfosecTrain Trainer: Right? And there is one more concept, which is called the security by... default. InfosecTrain Trainer: security by design. So, what is security by default? When you install any Android app in your mobile, automatically, by default, all the permissions would be disabled. Then, specifically, it will ask you, like, location. InfosecTrain Trainer: So it... there is an option. You say that I will only give location permission when I use the application. I will not give the location permission all the time to this application. InfosecTrain Trainer: Right? So that's what we all do. Otherwise, if you have given the all-the-time location access permission, then continuously application would be able to monitor and check your location permission. InfosecTrain Trainer: Then trust, through transparency comes the trust, where people should InfosecTrain Trainer: trust the process, you will take the consent from the people for which purpose you are collecting their data and information, and then next comes the zero trust.

InfosecTrain Trainer: So, Zero Trust, anyone can explain to me what is Zero Trust? InfosecTrain Trainer: Is this a... is this a architecture, this is a concept, or this is a solution? SrinivasanJ: Never trust, always verify. Mukesh Thakur: took off. SrinivasanJ: Month. SrinivasanJ: concept. InfosecTrain Trainer: So, zero trust is a concept where you... you will not give a default access to someone to complete parameter, right? At every checkpoint, you will verify, is that person is

actually InfosecTrain Trainer: have access to that process or system or not. A very simple analogy I can give. The same access card example which I gave. InfosecTrain Trainer: If you move into any high sensitivity zone, does person InfosecTrain Trainer: Okay, so every person has a specific area where they can go and get into that particular floor, premise, and all, right? InfosecTrain Trainer: Now, let's take an example of modern hotels. So, if you go to any modern hotels, suppose this is a 15-story hotel. InfosecTrain Trainer: These days, what they do, they don't give you access to each and every phone, so the card which they gave for your room InfosecTrain Trainer: So every time you get into a lift, that card will only give you access to either that floor where you are going, or it will give you access to the lobby, or the common amenities where you can go. Like, it will not give you access to, by default, all the floors. InfosecTrain Trainer: So it's a very good example of a zero trust. InfosecTrain Trainer: Every time it's, checking or verifying that person has an access, or he can go into that area or not. InfosecTrain Trainer: So these are some couple of, topics or kind of concepts which all of you must be aware of at a high-level understanding, you should have.

InfosecTrain Trainer: Now, on the basis of this, then the defense of depth is designed. So, defense of depth, or a layered security, is based on this particular... all the concepts which we studied. InfosecTrain Trainer: So all the... in the... your organization... so... so we are... from a conceptual perspective, we are discussing that there is a control, there is a firewall, there is one EDR, but it does not actually work in any context. So you do not place an application just InfosecTrain Trainer: Behind one firewall. InfosecTrain Trainer: Or you will just have one login ID and password, and then you will place an application. You will always design system in layer. InfosecTrain Trainer: Right? That's how you keep the system secure and safe, right? InfosecTrain Trainer: So let's say how the security layer designed, right? So the first layer would be an administrative control layer, which is a governance layer. InfosecTrain Trainer: You will have a policies, procedure, awareness, all those things comes in a first layer. Next layer. InfosecTrain Trainer: In your organization comes the physical security. InfosecTrain Trainer: The people will have an access card, who will be able to access to data center, who will be able to access to that particular premise. That comes the second layer. InfosecTrain Trainer: Third layer comes as a parameter. InfosecTrain Trainer: Now... You will design a parameter around your organization, so it's a physical security also, then virtual also. InfosecTrain Trainer: So your organization network, where people comes, log in, there's going to be parameter design using VPN, firewall, demilitarized zone, gateways, DDoS protection, everything will come together to design a parameter. Next layer would be a network.

InfosecTrain Trainer: Now, within that parameter, you will do the segmentation. InfosecTrain Trainer: Right? InfosecTrain Trainer: you will do a... you will have an IDS IPS, you will create a network access InfosecTrain Trainer: control, NAC, you will have a micro-segmentation, you will have a east-west inspection. InfosecTrain Trainer: How the traffic is flowing, right? InfosecTrain Trainer: Then the fifth layer would be, after network also, if someone is able to get into your system, comes the host. InfosecTrain Trainer: you have endpoints, you have servers, you have PCs. So, there, then you will again deploy the EDR baseline controls, you will have a patching, you will have a mobile device management solution of your BYOD device, you will have a host firewalls. InfosecTrain Trainer: After that, on top of those hosts, then the application would be running. InfosecTrain Trainer: So, on those applications, you will have a secure... so when you're developing those applications, you will design them securely, you will have a web application firewall for that, you will do the input validation, right? InfosecTrain Trainer: You will have an API security, you will do the testing, and then the last layer is the data. So on those applications, data would be running. You want to secure that data. For that, you will have a classification, encryption, DLP tokenization, you will do the backup and recovery. InfosecTrain Trainer: Right? So even if a control fails, there is going to be the next layer supporting it, still InfosecTrain Trainer: your information, data, and things should be saved. So, this is how the defense in depth concept comes, and this is how the things are designed. So it is from the outer to inner layer. So, outer layer is this, and inner layer is this.

InfosecTrain Trainer: Now... Someone told me they have worked in a SOC. Who has worked in a SOC? Sandeep Saxena: Yes, ma'am, I have a sock, and I have a sore to it. InfosecTrain Trainer: Hmm, good, good. InfosecTrain Trainer: Can you please explain, in brief, what does SOAR do? Sandeep Saxena: SOAR is basically security orchestration Automation Response. Sandeep Saxena: We need this because... The attackers are, you know, distributed, they are automated. Sandeep Saxena: motivated. We cannot fight them with your manual processes. Sandeep Saxena: So... Sandeep Saxena: I can go very technical in that, but the thing is that unless you do automation in your... in your response, event response, security response, you cannot... you cannot handle it. Sandeep Saxena: So, that's the need of that. InfosecTrain Trainer: Yes. So, incident, if I talk about the security incident, right, it's not only one type of incident. So, there are n number of ways to get into your organization parameter. There are n number of ways to launch an attack, right? N number of ways to disrupt. InfosecTrain Trainer: So manually, actually handling all of them for a person is a very difficult task, and every day doing the same thing also will get a person bored, right? Because the most common form of thing what SOC team handles is the phishing emails. InfosecTrain Trainer: Which is the most common. Every day, you will see some phishing emails are coming to your organization, people are reporting it. InfosecTrain Trainer: Now, every day you tell the SOC guy to actually manually check those emails, scan those emails, correlate the information, how much time it will consume. So, what you do, through SOAR, you automate that process.

InfosecTrain Trainer: So, if someone reports the email, automatically you will have a tech stack in place to automatically scan the email. InfosecTrain Trainer: automatically, it will say... it will see if the person has already clicked on the link. Automatically, it will generate an email to that person to reset the password, or automatically actually block or reset the account. Likewise, there can be other processes also. InfosecTrain Trainer: So this is just one example I gave. Likewise, you have a SOAR automation for multiple things. InfosecTrain Trainer: Like, suppose, notification. InfosecTrain Trainer: So you have... you are a GDPR-compliant organization, so as soon as you detect or understood that there is a sensitive information, or the confidential information disclosure was done, you report... you send automated email to your InfosecTrain Trainer: legal team, your DPO. InfosecTrain Trainer: He should automatically send an email with the incident information and everything. He should receive it, rather than people are manually drafting an email and sending it to him. InfosecTrain Trainer: So, the SOAR platform automates the response to the security event, right, either in a standalone system or as part of the SIM. Now, all the SIM solution which comes these days, they come with the SOAR capabilities, so... InfosecTrain Trainer: You can automate the incident response. There are multiple ways and means to do that, and now the Sour platform even comes with the no-code, low-code solution. You need not to InfosecTrain Trainer: do much of the coding, like writing a big program. There are... there are drag-and-drop options. If someone would have worked on the Power Automate and Power Apps, it's almost equal to... equivalent to that. InfosecTrain Trainer: So, there are two things.

One is called the playbook, another one is called the Runbook. So, SOAR helps you implement and automate those InfosecTrain Trainer: Runbooks, right? And what are the benefits? It automates the repetitive and routine task. It relieves the personal from the boredom, like, every day, same task you are doing. InfosecTrain Trainer: So... so that you will only focus on the key... InfosecTrain Trainer: items which require a strategic, kind of focus, right? Helps you improve the accuracy, enable the faster response, and InfosecTrain Trainer: blend the impact of security incident. So you can focus on the key activities rather than focus on the routine task. InfosecTrain Trainer: Everyone clear on the SOAR? InfosecTrain Trainer: So, from CISM perspective, you need not to be master of SOAR, you just need to have an understanding what does SOAR means, what does SOAR solve, what is the problem SOAR is solving? That's more than enough. InfosecTrain Trainer: Let's discuss some questions. InfosecTrain Trainer: Alright, let's discuss answers. InfosecTrain Trainer: Alright, let's... InfosecTrain Trainer: an organization designs a new security control to enforce the strict data access based on job roles. What is the primary control objective in designing InfosecTrain Trainer: Design is intended to achieve. InfosecTrain Trainer: access management-related controls, right? Who will... who can have an access to an information? It's a basic CIA tried. InfosecTrain Trainer: That access do not help you achieve availability. InfosecTrain Trainer: It will not help you achieve the integrity also. How come it's related to integrity. Non-repudiation is something a person cannot deny of what InfosecTrain Trainer: activities you have performed. Just by having an access control, do not do that.

It is something which will help you achieve the confidentiality, right? InfosecTrain Trainer: So, C is the correct answer. An information security manager is tasked with measuring the overall success of the IES program. Which metric, if consistently positive, best indicate the program's strategic effectiveness and value delivery to the business? Annual budget increase for the security department, decreased number of identified low severity vulnerability InfosecTrain Trainer: Higher attendance rate at voluntary security. You see all three of them are insignificant. Improved alignment of security control with critical business process and risk appetite. It's talking about the strategic effectiveness. InfosecTrain Trainer: How you will be able to show the strategic effectiveness if you are able to maintain the, your controls are able to support your business processes, and overall able to manage your risk appetite, that's the better matrix. InfosecTrain Trainer: Which metric would best indicate whether the scope of the information security program is adequately defined? Number of security incidents per year, percentage of IT systems covered by security policies, budget spent on security initiative, number of employees trained in security practices. InfosecTrain Trainer: I told you. Always choose and go with the option which is an umbrella answer. InfosecTrain Trainer: Here, B is an umbrella

answer. What is security policy? Your security policies say InfosecTrain Trainer: your... all the systems which you design are, what, around security policy? Your baseline or security policy? Your security policies say that, the confidential information should be encrypted.

InfosecTrain Trainer: Your security policies say that, if a person clicks on the phishing email, this is what they're going through the process, right? So every process is defined by your policy, so this is something which is an umbrella answer, which is something covers everything. InfosecTrain Trainer: So... so... so your program evolves around the security policies. If... InfosecTrain Trainer: If your security policy is able to cover your... all the program, all the systems, that is a better metric, so B is the correct answer. Which of the following best ensures that the charter of an information security program remains relevant? InfosecTrain Trainer: What is in charter first thing? InfosecTrain Trainer: Charter is something which actually helps you, which gives the InfosecTrain Trainer: CISO an authority to run and govern the program. InfosecTrain Trainer: Right? InfosecTrain Trainer: It has a budget, it has a milestone, it has a list of key deliverables, right? InfosecTrain Trainer: Now, it is saying how it will remain relevant. InfosecTrain Trainer: If there is a change in enterprise architecture, if there is a change in the enterprise environment, if there is a change in the regulatory landscape, if suppose tomorrow there is additional funding which need to be... which need to be... seek for some particular initiative, how he'll make sure that it's InfosecTrain Trainer: Done. InfosecTrain Trainer: Update, regular updates to reflect the changes in the technology. Simple. InfosecTrain Trainer: How business continuity plan is just talking about one aspect. It's not covering everything. Charter is not created only for continuity plan. Formal approver from senior management or board.

Just by taking the approver with the senior management and board, how come the charter will remain relevant? InfosecTrain Trainer: It's saying, if there is a change in a technology, change in an environment. InfosecTrain Trainer: How this particular thing will help with this. Inclusion of metric to measure the security effectiveness. In Charter, you don't add any metrics. InfosecTrain Trainer: Be clear. InfosecTrain Trainer: We discussed. In Charter, you don't add any mattresses and all. InfosecTrain Trainer: Mattresses are not added as part of the charter. Charter is only a document giving authority to the CISO to run the program, so as such, this is also eliminated. So, A is the straightforward answer. Whenever there is a change in environment, whenever there is a change in overall organization perspective. InfosecTrain Trainer: You make sure you are updating the charter as for that. Simple. Pudir: Anyone... InfosecTrain Trainer: Yeah. Pudir: A charter is an epic document that should be approved by the senior management, or what I would address. Pudir: In your provider and a comprehensive look, formal approval from senior management, or the board to... Pudir: Well, I thought that would be the answer, because technology changes always is a continuous process, so how can a charter can be effected with the technology changes? InfosecTrain Trainer: It is saying, if... InfosecTrain Trainer: how you will make sure that the charter of a program remains relevant? Simple statement, the question is asking. Pudir: Hmm. InfosecTrain Trainer: You have created a charter. InfosecTrain Trainer: you created a charter. Before the charter was created, there was no consideration around the AI governance. InfosecTrain Trainer: Now, CIS organization decided to go with the AI rapidly.

Now, as a CISO, I have to establish the AI governance. There are new tools, new technologies, new resources I have to onboard. How I will get those funding? InfosecTrain Trainer: I have to do the changes. I have to update the charter. Now, that is a part of the process. Once I do the changes, definitely it will go to the approval of the board and approval of the senior management. InfosecTrain Trainer: But the question is asking A, question is not talking about C. InfosecTrain Trainer: C is a part of the process which will be followed. Once you update, definitely you have to, again, take an approval of them, right? InfosecTrain Trainer: I cannot just, as a CISO, I cannot just do some changes in the charter and keep it like that. I have to definitely send it for the approval to the sponsor, right? InfosecTrain Trainer: Question is asking about A. C is going to be later, where once... InfosecTrain Trainer: Changes are done, then you will send it... them for the approval. Pudir: Oops. InfosecTrain Trainer: Let's do one thing, let's discuss... Few more questions, yeah. InfosecTrain Trainer: Please try these three. InfosecTrain Trainer: Alright, let's discuss. InfosecTrain Trainer: Which of the following activities is most likely to increase the difficulty of totally eradicating malicious code that is not immediately detected? InfosecTrain Trainer: Which option do you people want to eliminate here? SrinivasanJ: upgrading hardware. Sandeep Saxena: CND. SrinivasanJ: bag of... InfosecTrain Trainer: Why would you want to eliminate option D? InfosecTrain Trainer: Any consent? SrinivasanJ: eradicate malicious code. It can be used to... InfosecTrain Trainer: What Ansar is saying, read again.

Ansar is saying... InfosecTrain Trainer: Which of the following activities is most likely to increase the difficulty of totally eradicating malicious code that is not immediately detected? InfosecTrain Trainer: Like, in my system, there is a malware. InfosecTrain Trainer: My system, there is a malware error. InfosecTrain Trainer: I took a backup. InfosecTrain Trainer: So now that malware also... Got part of the backup, right? SrinivasanJ: Truth. InfosecTrain Trainer: I think you people did not understood the question, what it is asking. It's saying... InfosecTrain Trainer: When there is a... when there is an issue in the system, which of these things, if you do. InfosecTrain Trainer: Would become difficult for a security team to remove that particular issue. InfosecTrain Trainer: So, correct answer here is D. InfosecTrain Trainer: Not option B. A lot of people would... went with B is just a changing... how come access rule changes would impact your eradication activities? InfosecTrain Trainer: Or, patches are something which you apply to fix. InfosecTrain Trainer: If you took a backup of that particular item, then it becomes a very difficult, right? InfosecTrain Trainer: If you have not detected that malware and you took a backup, now the malware is also part of the backup. InfosecTrain Trainer: Now it becomes very difficult to detect it. InfosecTrain Trainer: Got it. InfosecTrain Trainer: Which of the following is the most effective at preventing an unauthorized individual from following an unauthorized person through a secured entrance tailgating or piggyback? InfosecTrain Trainer: What is tailgating and piggybacking, anyone? Pudir: One person, and another person is following, you know, with another agent person. InfosecTrain Trainer: Yes.

So, which two options you people want to eliminate here? Pudir: Card key, door locks. Pudir: Awareness standing. SrinivasanJ: A, B, and C. InfosecTrain Trainer: why you want to eliminate A, B, and C. SrinivasanJ: Let's see, like, if we do not have a varnish. SrinivasanJ: And we are not cautious, like, someone can always... SrinivasanJ: piggyback, right? They can come behind us. SrinivasanJ: Tailgate into the... Promises. But if we have awareness, we can stop them. SrinivasanJ: The first three are, preventive. InfosecTrain Trainer: If I may say, first three are a technical solution to solve the problem, right? They are a technical control. All of them will do the same thing, but if the person is not aware. InfosecTrain Trainer: another person can still bypass them and probably follow along with them and get insight, right? So, awareness training is something which will solve the problem. Which of the following metrics is the most useful for the effectiveness of a control monitoring program? InfosecTrain Trainer: The percentage of key control being monitored, the time between detection and initiating remediation, the monitoring cost versus incident detected, the time between an incident and a detection. InfosecTrain Trainer: What is the correct answer here? SrinivasanJ: D... InfosecTrain Trainer: Why? SrinivasanJ: So how soon, my incident is generated after detection. That is the effectiveness of my monitoring tool. InfosecTrain Trainer: And how come this is giving you effectiveness of all the controls? InfosecTrain Trainer: I'm intentionally asking this question so that you people build that reasoning in your mindset, right?

Whenever you approach any question, you have to have that InfosecTrain Trainer: built-in Kind of a, InfosecTrain Trainer: kind of approach which you have to develop, right? So that any question you approach in the exam, how difficult the question be, you have read the topic or not, you are getting confused, at least if you have this reasoning, you will be able to somehow reach to a correct answer. InfosecTrain Trainer: That's the thing, right? So, it's saying that effectiveness of control monitoring program. So, what are the control... InfosecTrain Trainer: Control whatever number of controls in your organization deploy, end goal is what? InfosecTrain Trainer: to protect organization, and to detect, and to reduce the incident, right? That's the end goal? InfosecTrain Trainer: Any control, your policies, your access management, your EDR, your firewalls, everything is why you are doing it, why you are designing it. Everything... end goal is that, that the attacker should not get into your organization. That's what the purpose is. InfosecTrain Trainer: And how you will... which particular matrix will check you that. InfosecTrain Trainer: If... Incident, the time between an incident and a detection. InfosecTrain Trainer: So, if all the controls are working together collectively effective, they'll be able to detect and tell you the incident time. So, D is something which holistically talk about all the options, not A, B, and C. InfosecTrain Trainer: Got it. Sandeep Saxena: I have a question for question 2. InfosecTrain Trainer: Yes. Sandeep Saxena: So, for tailgating. Sandeep Saxena: what I see is that, you know, biometric scanner is a good solution, because if I am getting inside, I'm not even looking who is coming behind me, okay?

But is it, like, for CISM, if there is a control which is coming from the policy standpoint, we'll... we'll prioritize that? InfosecTrain Trainer: But... Sandeep Saxena: Yeah. InfosecTrain Trainer: But even if you have a technical solution, still. InfosecTrain Trainer: how the tailgating takes place. Tailgating takes place when someone you are entering and someone is going inside. InfosecTrain Trainer: So, tailgating is not... it's not unintentional. It can be intentional also. One of your friends, you want to take him inside the organization. There are ways and means to bypass, right? InfosecTrain Trainer: So any number of technical controls you can deploy, still the person would be able to bypass it. InfosecTrain Trainer: But if he's aware, he knows that what are the consequences, why he should not do that, he'll not perform. So what is the best solution? Sandeep Saxena: Because in this quotient, it's written there. Sandeep Saxena: unauthorized

individual from following an authorized person. So it's not like the authorized person is intentionally keeping someone in, but... but it's like someone is following me, right? I'm not even looking who is coming behind. There are 10 people, I don't know all of them, right? Pudir: Serene, are you also feeling biometric scanner would be the most... Sandeep Saxena: Yeah. Pudir: Sort. Sandeep Saxena: So it's not, it's not, like, which is the best, but... Is it, like, in CISM? Sandeep Saxena: When... whenever there is a control, which is coming from the policy standpoint, we should prioritize that. InfosecTrain Trainer: No, even in the biometric scanner... now, now I have a counter question. I have a biometric scanner, I scanned it, I kept the door open, person would be able to get inside, right?

Sandeep Saxena: No, I will not keep the door open, right? I will just get in, and the door is closed. InfosecTrain Trainer: That's what you are saying, right? You are aware about it. That's why you will not keep the door open. InfosecTrain Trainer: You answered it yourself. Sandeep Saxena: Whoa. InfosecTrain Trainer: Awareness is something which is more important than any technical control for the tailgating activities. Sandeep Saxena: This is what I was saying. Sandeep Saxena: The policy-related controls will take precedence in CISM over... in general, I'm saying, technical controls. InfosecTrain Trainer: Got a... So that is what the Think Like a Manager approach is. Sandeep Saxena: Is it like, in terms of people, process, technology, whenever there is a control which is addressing the people, and there is a control which is looking correct, but that is addressing the technology, we will prefer the people-related thing first. InfosecTrain Trainer: People and the process are always given the... Sandeep Saxena: Yeah, first people, then process and technology, right? InfosecTrain Trainer: Correct, correct. Sandeep Saxena: Okay, and, in the third question. Sandeep Saxena: Most useful for the effectiveness of a control monitoring program. Sandeep Saxena: So, controls can be off... any type. Sandeep Saxena: any, preventive control or detection-related control. So we... we talked about, like, for every control. Sandeep Saxena: we should be able to measure that. We should... we should be measuring every control, right? InfosecTrain Trainer: headache. Sandeep Saxena: So... Sandeep Saxena: That's the most important thing, because if we don't measure it, we cannot improve that, we cannot gaze upon the effectiveness of that. InfosecTrain Trainer: Yes. So... Sandeep Saxena: In that philosophy.

Sandeep Saxena: the percentage of key controls being monitored. So, if there are 10 controls, my first job is to ensure that all of them are being monitored. If only 5 controls are being monitored, 5 controls are not, then Sandeep Saxena: In terms of controls monitoring program itself, I'm doing wrong, right? InfosecTrain Trainer: Yes, you are having a correct logic. Sandeep Saxena: Yeah, my first job is to first ensure that all the controls are being measured. InfosecTrain Trainer: Yes, correct. But... But... but option A is only talking about the coverage of that program, right? InfosecTrain Trainer: It's not telling you effectiveness of program. InfosecTrain Trainer: Does it tell you effectiveness of program? Like, like, you have 100 control, you say the 90 controls I'm monitoring. InfosecTrain Trainer: But is it telling overall effectiveness that you have 90 controls which you are monitoring, but are those 90 controls operating effectively or not? Does it telling you that this matrix? InfosecTrain Trainer: So, question is talking about the effectiveness, right? Question is not talking about the coverage. First matrix only talks that how many controls are there, how many we are monitoring. That's it. InfosecTrain Trainer: It's not telling you overall effectiveness, how collectively effective those things are monitoring. You have... you... suppose you say, okay, I have a metric for firewall, I have a metric for EDR, I have a metric for... a metric for my incident management system, I have a metric for my SOC-related metrics, everything I'm monitoring is there. InfosecTrain Trainer: But are those things are working effectively? Not. InfosecTrain Trainer: Got it? InfosecTrain Trainer: Sandeep? Sandeep Saxena: Oh. InfosecTrain Trainer: This effectiveness is a keyword here.

Sandeep Saxena: Do you think that the scope of the controls It's a Planet Crusade. Sandeep Saxena: For example, there are 10 controls, okay? We are measuring only one, okay? That one is running very awesome, okay? Sandeep Saxena: 9 controls we are not just looking at. We can say that our control monitoring program is very effective. Sandeep Saxena: I'm talking about the program, not a... InfosecTrain Trainer: Yeah. Sandeep Saxena: control the ammonia. InfosecTrain Trainer: what... that's what, DE Matrex is covering, right? InfosecTrain Trainer: D matrix is something talking about the time between an incident and the detection, right? So what all the controls, you name any control which is there in the organization, what it is saying. And the goal is what? InfosecTrain Trainer: to prevent the incidents from happening, right? And even if the incident happened, it should be able to detect it fast, right? InfosecTrain Trainer: So if everything is being done properly, D will solve that problem. So that's why, holistically, we chose the D as answer. Sandeep Saxena: Okay. InfosecTrain Trainer: Now, coming to the next topic, vulnerability assessment and the penetration testing. InfosecTrain Trainer: However, we discussed this topic as part of the domain too, right? InfosecTrain Trainer: But, this is there as part of the, as we are discussing controls. That's why this topic is here. InfosecTrain Trainer: So, you are discussing the controls. How you test the effectiveness of your control? InfosecTrain Trainer: you do this exercise, VAPT. InfosecTrain Trainer: Even the red team exercise, purple team exercise, are what? InfosecTrain Trainer: You are doing the same thing. You are checking the effectiveness of your overall information security program, right?

That black box testing, gray box testing, or those things are doing the same thing. Same thing. The VAPT is something which will help you check the effectiveness of your controls, right? InfosecTrain Trainer: So, once there is a risk. InfosecTrain Trainer: the VAPT will see that what are the vulnerabilities in the system, what are the weaknesses in the system, then the penetration tester will InfosecTrain Trainer: create a payload, the penetration tester will... they'll follow methods to make sure that he's able to penetrate into the system. If he's able to do that, it means the control is not operating effectively, right? InfosecTrain Trainer: So, controlled recommendations result from the risk assessment and the analysis process to provide input to the risk assessment. InfosecTrain Trainer: So, when you do a risk assessment, as part of the risk assessment, you would recommend some list of controls. These are the things which should... we should implement to reduce the risk to an acceptable level. So, you did completed a risk assessment, you identified there is no AI inventory being maintained. InfosecTrain Trainer: You identified that there are InfosecTrain Trainer: 30% of the AI agents running in the organization without any identity or a human identity associated with it. There is no ownership. InfosecTrain Trainer: So you will create a control to it. Likewise, you... once you do a risk assessment, there are going to be multiple instances for which you design a control, right? And then, once you design the control, you perform a cost-benefit analysis to InfosecTrain Trainer: justify the use, why we should have it. If you don't have it, then what is going to be the impact?

InfosecTrain Trainer: And then, those evaluated controls are... those recommended controls are evaluated, prioritized, implemented through this process. InfosecTrain Trainer: Right? And then, in the process, you even take the input from the business owners, all the business heads, all the key important stakeholders, they all will be sharing their input while doing it, and overall, all the controls which you're designing, they will be tested through this process. InfosecTrain Trainer: This is not the only process to test it, but this is one of the processes which help you test the effectiveness of a control. InfosecTrain Trainer: So there are... so there are two things. One thing is control testing and monitoring, and another one is the audits. InfosecTrain Trainer: Right. InfosecTrain Trainer: So, audit it... audit is also one of the processes which helps you InfosecTrain Trainer: monitor your overall effectiveness of controls, right? So whenever the auditor comes, what they do? They actually take you... they will give you to... tell you to give the evidence. They'll probably see the logs, they will check all the screenshots, all the recordings, all the things, they will check the telemetry data and information. InfosecTrain Trainer: To understand and to make sure that the Controls are working effectively. InfosecTrain Trainer: And then this testing and monitoring program is there, where you do the VAPT, and there are other methods and ways and means to do this, right? So when you monitor the control, you have to InfosecTrain Trainer: you have to design a proper methodical program around it so that you keep a watch and monitor all the controls, right? You need to probably tap the exact log information from those controls so that you can monitor the effectiveness.

Like, say, example of password control. InfosecTrain Trainer: So, password control, you know that if person has set a very weak password, it can be easily be cracked using a brute force attack. InfosecTrain Trainer: Right? InfosecTrain Trainer: So what is a control? You have a control so that once people do a 5 concurrent incorrect password he enters, automatically there's going to be the lockout, account lockout. InfosecTrain Trainer: And how you monitor? You will monitor using the audit log entries for each login attempt. As soon as the threshold is achieved, the lockout will begin. InfosecTrain Trainer: And you need to periodically review the logs to check the effectiveness of this particular control which you have. InfosecTrain Trainer: If it is not probably locking out the account after the 5 attempts, it means the control is not working effectively, right? InfosecTrain Trainer: Now, the audit is another process where you have a systematic, repeatable process by competent, independent professional who comes and evaluates. So, there are two types of steps. One is called the internal audit. InfosecTrain Trainer: Another one is called the external audit. InfosecTrain Trainer: like your SOC 2 reports. InfosecTrain Trainer: Who do the... anyone here who do the SOC 2 report audit? Fatha: Yeah, I did, like, the P-shirt you meant to say? Fatha: Defense. InfosecTrain Trainer: Yes. Fatha: Yeah, I've done the B6. InfosecTrain Trainer: So the SOC 2 report audit, mostly the final report which is generated, who do that? You generally invite external people. Even ISO 27001. InfosecTrain Trainer: Have you seen organizations themselves certifying ISO? No.

You always invite external parties, because it gives a genuine or the independent view of the process, because you yourself, operating in your organization, you will always say everything is working effectively, right? That's why you have an internal and the external, two types of audit. InfosecTrain Trainer: Right? Whenever audit is conducted, is... be it internally, be it externally. InfosecTrain Trainer: So, these are the key principles the audit team will follow. First thing, they will have a purpose. InfosecTrain Trainer: What is the purpose of audit? InfosecTrain Trainer: Is it for the ISO report? Is it annual audit? Is it for, gap assessment with respect to some compliance? Or the audit is ordered by some competent authority after a major incident has occurred? InfosecTrain Trainer: Now, they will also need to scope it out, right? Without a scope, you cannot do an audit. Organizations are big enough, they are distributed all across the world. InfosecTrain Trainer: so auditor cannot travel to all the locations, right? So they have to scope it out. They'll say that we... this is in the scope, this is out of scope, right? And then they will do a risk analysis, and then they will allocate the resources based on the risk. If it's a high-risk audit, probably. InfosecTrain Trainer: the more number of resources, more number of fundings, and the budget would be allocated, right? And then they will follow some audit process to do that. InfosecTrain Trainer: And then all the resources which they will encounter for that, personal hours, skills, specialized tools, techniques which are needed, right? And then schedule need to be created for doing an audit. InfosecTrain Trainer: So, audit... It's a process to help you monitor the effectiveness of the control.

InfosecTrain Trainer: Now, what is the difference between the review and the audit? Anyone? InfosecTrain Trainer: But the key difference between the review and audit. SrinivasanJ: Internal, I mean, viewers within, the same business unit checking themselves. SrinivasanJ: Whether they are compliant to the controls. Supreya Mhatre: Maybe in review, you just review, what is being... Supreya Mhatre: followed, or what you're... whether you're complying to any clauses or not. Whereas in audit, there is an outcome in terms of Supreya Mhatre: findings. InfosecTrain Trainer: So, review is a less formal process. InfosecTrain Trainer: Audit is a structured and a formal process. Review is something which you do on a day-to-day basis. InfosecTrain Trainer: which you do on the job, which you do as part of the operation, which you do as part of the normal, regular working, right? Like... InfosecTrain Trainer: Your... your peer is reviewing the code. InfosecTrain Trainer: Or in a GRC team, whenever you are publishing a policy, you are having a review with one of your team lead, who is review the policy and see if wording and everything is correct or structured. InfosecTrain Trainer: Like, the firewall team... network engineer will review the firewall rules at a certain period of time. InfosecTrain Trainer: your access review. So, every year, your, every year or quarterly, whatever is the frequency, your manager will get an email to review, their peer access. InfosecTrain Trainer: which all systems they need to access to, right? If they have left, or they have moved to a different role, they don't need those accesses as part of it, they'll say, right?

So review is a less formal, and the examination of the control, it determines the state of security, how InfosecTrain Trainer: Effectively, the security is performing, and most of the time, you will see the review are a regular routine process. Also, once the audit is ordered, before the audit team comes and do, you will do a self-assessment. As part of the self-assessment, you will do a review. InfosecTrain Trainer: So, audit is a formal, methodical examination. It requires the evidence of the control, design, effectiveness, right, and always conducted by a competent, independent professional. And once the audit is done, they will hand InfosecTrain Trainer: Over you a formalized report, right, and more structured and rigorous it is. InfosecTrain Trainer: Now, whenever an audit is ordered, right, there are some objectives which... on which the audit would be conducted. InfosecTrain Trainer: So... so those objectives will be defined on the basis of this, right? InfosecTrain Trainer: So, if audit is being done on the regulatory requirement, so it's going to be that objective. If it is being done for the compliance verification, then that would be objective. Or some... to met some legal obligations, the audit would be done. InfosecTrain Trainer: or some serious incident, you have to do an audit and submit a report, right? Or after incident at a similar organization, or there can be other objectives also, right? InfosecTrain Trainer: Like, if someone have worked in the banks, so banks have a lot of audits. InfosecTrain Trainer: So, there is going to be... if you work in an Indian bank, so RBI would come and audit you. InfosecTrain Trainer: If you're working in the European, so ECB, InfosecTrain Trainer: is a European Banking Commission, right? ECB, they'll come and audit.

InfosecTrain Trainer: In the US Fed common audit. InfosecTrain Trainer: So, every organization have such kind of auditing, as you see. They come, they audit your infrastructure, key controls, and key processes, right? InfosecTrain Trainer: So, audit objectives are specific goals for an audit, why they are coming to audit, right? InfosecTrain Trainer: And then, it will help you as organization also determine that which all processes, which all controls would be tested as part of that audit, so that you can prepare and modify or improve upon them. InfosecTrain Trainer: Now, coming to the responsibilities. InfosecTrain Trainer: From an information security program perspective. InfosecTrain Trainer: So, in this particular section, this is the last topic, then we will jump onto the next topic. InfosecTrain Trainer: So, Information Security Manager... is responsible InfosecTrain Trainer: From a security program perspective, he should always maintain a balanced approach. InfosecTrain Trainer: So whenever he's evaluating any technology, any solution, he have to avoid excessive focus and reliance on technology. InfosecTrain Trainer: And this is the same to the point to you, Sandeep, right? The question which we discussed, where you were talking about that people process technology, right? So that's what the ISACA says. It says that the manager should avoid excessive focus and reliance on technology. InfosecTrain Trainer: Then, second thing is that there should be clear roles. You should identify document security-related roles, responsibilities, and everything, right? InfosecTrain Trainer: he shouldn't... so... Manager should make sure that he is, security don't... hinder with the... InfosecTrain Trainer: Overall, achievement of the objective of the business, right?

InfosecTrain Trainer: And then, always, whenever he is doing any work, any decision he's taking, any new solution he's onboarded, he has to take the risk perspective. InfosecTrain Trainer: Right? You have to consider from the enterprise risk perspective, security risk perspective, and then take those decisions, and need to include the stakeholders. All the stakeholders, those who are important, considered, they need to be involved, and InfosecTrain Trainer: Design and implement and evaluate the comprehensive control also need to consider around the physical security as well. InfosecTrain Trainer: And anyone here who have gone through CISSP, there is a specific domain in CISSP which talks about physical security. InfosecTrain Trainer: Actually, there is a domain in CISSP on the physical security. Here in CISM, we don't talk about it, but in the CISSP, there is a domain. InfosecTrain Trainer: Now, coming to the awareness and training. InfosecTrain Trainer: And this is very important from an overall information security program perspective. InfosecTrain Trainer: So, overall program, you have to make people aware, right? InfosecTrain Trainer: That security is responsibility of everyone. InfosecTrain Trainer: Because the humans are the weakest link in the organization. InfosecTrain Trainer: And information security awareness and training is not only to all the employees. You will also have a specific InfosecTrain Trainer: on-job role-specific trainings as well. You have the training for your SOC team, you have a training for your leadership team, you have... you do the on-job training and other kind of trainings as well, right? There is one awareness which you impart to each and every employee.

InfosecTrain Trainer: So that they understood that what are the risky processes, what activities they are supposed to do, what activities they are supposed to not. InfosecTrain Trainer: How to determine that something is fishy, something which is not correct, and they can report. InfosecTrain Trainer: So that's why you need to build the overall awareness around the program, you need to connect the policies to the daily tasks so that people understand, you need to tailor information to each and audience, right? And educate the staff involved in implementing the same, and define the InfosecTrain Trainer: KGI KPIs and critical success factor all need to design an awareness program around organization, specific security responsibilities, and also need to include third parties. InfosecTrain Trainer: In your organization, you would be... there would be some third-party contractors, some third-party vendors who would be working, visiting, they also need to be aware. InfosecTrain Trainer: Right? InfosecTrain Trainer: And when you are delivering the training, you can see that probably it can be done in a classroom setup, it can be done via some online e-learning platform, you can also conduct some gamification of those training using quizzes, reminders. InfosecTrain Trainer: And also, some specific management-level workshop, and the training also you will conduct. InfosecTrain Trainer: Now, so whenever you design a matrix for the training, those metrics should be designed in such a manner. First thing, it should be talking about the coverage, which you already discussed. Number of people attended the training. That is the coverage. InfosecTrain Trainer: Right? Number of leadership people attended the training. That is the coverage. Next comes the grading.

InfosecTrain Trainer: So, what is the grading? Grading is where you launch a phishing simulation, or you do some kind of exercise, you do share some questionnaire, or you do some gamification, any method, where you grade or you understand how much they understood InfosecTrain Trainer: About that training which you conducted. That is a grading-related matrix. Next thing is the automation and deployment. InfosecTrain Trainer: So, all this training which you do, you... so, every time, manually, a person conducting a training won't be possible. InfosecTrain Trainer: And even the... the simulation, what you do, right, manually launching every time won't be possible. That's why you have a phishing simulation solutions and the tools available. InfosecTrain Trainer: Which helps you design a sophisticated phishing InfosecTrain Trainer: Simulation, and then send out the phishing email, then you can collect the telemetry data and information from it, and report the matrix. InfosecTrain Trainer: So, this is how you do our awareness training. Let's discuss some questions, yes? InfosecTrain Trainer: Alright, let's discuss. InfosecTrain Trainer: When evaluating the technical components of an information security program, which metric

would provide the best insight into the effectiveness of security architecture? InfosecTrain Trainer: Number of patches applied. InfosecTrain Trainer: Percentage of system with up-to-date antivirus, mean time to detect and respond to an incident. InfosecTrain Trainer: Frequency of vulnerability scan. InfosecTrain Trainer: We discussed this question, I think, right, already? InfosecTrain Trainer: It's talking about... sorry.

InfosecTrain Trainer: about the overall security architecture, and overall security architecture effectiveness can be noted and can be judged if you see the... all the controls collectively, how effectively they are operating, and the option C is a metric which helps you do that. We discussed this. Sandeep Saxena: The previous question was a bit different. So, here we are talking about the security architecture. Sandeep Saxena: And how do we measure, how do we prepare the matter, sir, if there is no incident? InfosecTrain Trainer: No, but, but the matrix is something which you... InfosecTrain Trainer: Which, yeah, so if there are no incidents, it tells you the effectiveness of your architecture. It means that InfosecTrain Trainer: your security tech stack is able to protect your organization. It's not going to happen that there are no attackers trying to attack. And I think, Sandeep, you are from the SOC, you know, right? There is no organization in the world where attackers are not trying to attack. Definitely, attackers are trying to attack, but there are no incidents, it means... it shows that InfosecTrain Trainer: Your tech stack is operating effectively, right? Sandeep Saxena: Here are two points here. First of all. Sandeep Saxena: In this question, we are talking about the incident or the event. Sandeep Saxena: I think we are talking about the events. Incident, it's return, but we are talking about the events, right? The alerts, not the actual incidents, right? Sandeep Saxena: Because incident is something that happens very rarely, once in a year, or once in two years. This is that kind of thing. InfosecTrain Trainer: No, but all, all the things, all the things are incidents only, right? So, incident... categorization is a different thing.

So, in your organization, probably every day you might be having hundreds of P4 incidents. Every organization do? Hundred of P4 incidents come, every day. InfosecTrain Trainer: But those are all low, low-level incidents. Sandeep Saxena: So, in season perspective, incidents and events and alerts are kind of same. In real world, we never call it incident. Incident is something when something bad actually happens. So, but I will remember that, that in season perspective, incident is alert or. InfosecTrain Trainer: No, no, event, event is a separate thing. InfosecTrain Trainer: Incident is something which will have an impact, right? Sandeep Saxena: Yeah. InfosecTrain Trainer: Right? Which will have an impact. However, Which... InfosecTrain Trainer: something which got detected and got mitigated also did not cause an... cause an issue to your organization, will you mark it as an event? Suppose there was a phishing email sent to one of the employees, it was a true positive phishing email. InfosecTrain Trainer: but got detected by your, your XDR system, and got mitigated and got blocked. InfosecTrain Trainer: But still, it was a true positive event only, right? Sandeep Saxena: Yeah, but if nobody clicked on that, it's not an incident, right? InfosecTrain Trainer: Yeah, that probably you might be following in a SOC perspective, but from a CISM perspective, it says that incident is something which is coming in your environment, could have an impact, becomes an incident. Sandeep Saxena: Right, so that's what I was saying. You see the perspective? It's not like something bad actually happened. It's not like that. InfosecTrain Trainer: Yes, got it.

Sandeep Saxena: And yeah, and the second, point, which actually confused me, is that Sandeep Saxena: When we talk about security architecture, This is something, you know. Sandeep Saxena: SOC team does not relate to in general, okay? Security architecture is something, the pen testing team, application security teams, they actually can look into whether the solution which is being deployed is secure architecture-wise, right? InfosecTrain Trainer: Yeah, so you are actually looking that security architecture term from a very small lens. You look that security architecture from a broader lens, from security architecture of your overall organization. InfosecTrain Trainer: That's what it is referring to. Security architecture of your complete organization. Whenever you see security architecture term, it's not referencing that architecture to specific one particular solution, one particular application, it is referencing to overall organization security architecture, like, how your parameter is designed, how InfosecTrain Trainer: The firewalls are placed. InfosecTrain Trainer: How your organization, so people, those who are logging in the remote, how they reach to your organization, which firewall they hit, how they come inside, how the applications are deployed, it's referencing to that. InfosecTrain Trainer: Got it. Sandeep Saxena: Yeah, okay. Sandeep Saxena: Thanks. InfosecTrain Trainer: Implementation of an effective change management process is an example of. So, change management process is for what? To help you prevent InfosecTrain Trainer: A risk from occurring, to help you prevent and... InfosecTrain Trainer: a patch being deployed into a production and causing an issue or harm. That's what you're doing? It's a preventative control.

Corrective control is something which would come into picture, which is correcting some issue, right? That's what not change is doing. Change is something which is doing InfosecTrain Trainer: You are doing it proactively. Detriment... change is not a deterrent control. InfosecTrain Trainer: And compensating also, it's not there. It's a preventative control, what you have, that is the correct definition here. A security manager needs to validate the effectiveness of the newly implemented network segmentation control against a sophisticated active adversary. InfosecTrain Trainer: Which activity provides the most comprehensive assurance of these control effectiveness? InfosecTrain Trainer: Which test is the most effective? InfosecTrain Trainer: something which is done without knowing your system, a testing methodology which can mimic an attacker's behavior, and which of them can mimic that black box? InfosecTrain Trainer: Black box testing is something... so directory type of Saxon you would have heard, right? InfosecTrain Trainer: black box testing. SrinivasanJ: Right. InfosecTrain Trainer: gray box testing and white box testing, right? Three testing which you have. Black box testing is something where you InfosecTrain Trainer: don't have any information about... around the organization, you have to do something... everything from the scratch. You will go look at the organization, you will scan the organization, external perimeter, you will go look InfosecTrain Trainer: people's social media profiles, what kind of information they are sharing, you will look at their web domain and everything, that's what it mimics. This is the best form of the tech. InfosecTrain Trainer: For the technique to evaluate your organization, like, security.

InfosecTrain Trainer: Despite mandatory annual training, employees consistently fall victim to sophisticated phishing attack. To best address this persistent human vulnerability, what should the CISO prioritize in the security awareness program? InfosecTrain Trainer: increase the frequency of mandatory annual training. People are still attending the training, they'll probably not be able to understand, or they're not focusing it. Even if you do it multiple times, they'll not be able to do so, right? So this will not help you. InfosecTrain Trainer: implementing a more advanced email filtering solution to block all phishing attempts. Even if you have a very advanced technical solution, still something would be able to bypass the same, right? InfosecTrain Trainer: Institute stricter disciplinary action for the employees who click on phishing. This is more of a curative action. You are kind of making... instigating fear among people, right? That you do that, it will punish you. So, not a good approach. InfosecTrain Trainer: Developing a targeted, real-world simulated phishing exercise with immediate feedback and personalized coaching. This is a better thing. InfosecTrain Trainer: For a leadership, you design a different kind of phishing email. For privileged user, you define... design a different kind of. For marketing people, you know which kind of vendor did deal with you, tailor it accordingly, so it's going to be a better option. So, seize the correct answer here. InfosecTrain Trainer: Now, coming to the roles and responsibilities. InfosecTrain Trainer: So, information security... InfosecTrain Trainer: program also operates on the different roles, right? So, in your organization, also, all of you might be playing some kind of roles, right?

InfosecTrain Trainer: you might be working as an individual contributor, as a manager, handling one particular process, you are handling some roles, right? So. InfosecTrain Trainer: And as per those roles and your function which is designed, suppose tomorrow you put down your paper, you move to another organization, a new person comes and joins and takes care of those responsibilities, you need to just map that role to that person. Automatically, he will inherit InfosecTrain Trainer: Couple of privileges as part of that role. InfosecTrain Trainer: That's why you create a consistent role, because in the organization where there are 1 lakh people and more than that number of people are working, it is not possible for every time granting them tailored roles and responsibilities, giving them the different, different access, right? Then you need to deploy a huge access IAM team to handle it. InfosecTrain Trainer: Then comes the reduction in the administrative cost due to less changes in the roles, right? It also helps you the same thing. InfosecTrain Trainer: Every time you are designing or tailoring something, you imagine the kind of cost, effort, and all would be needed from the IEM perspective. Also, you need to define the racing. InfosecTrain Trainer: So that everyone is aware what activity, what things they are responsible for, what they will be accountable, consulted, and informed. InfosecTrain Trainer: And whenever you onboard a person, that time only you give them specific roles. Person can inherit multiple roles also, right? He can be some admin also, he can be parallelly performing some other roles also.

So that's why you create standard roles and give some birthright to that particular role, so that once the person is allocated with that role, he inherits those permissions. InfosecTrain Trainer: And you perform a background check for confidential information access. InfosecTrain Trainer: BGV is also a process which all of you might have gone through whenever you onboard into a new organization, right? InfosecTrain Trainer: Now, coming to the change management process in the documentation. So, as part of the information security program, you would be actually doing some changes in your existing process. Anyone here who actually InfosecTrain Trainer: Update or work on policies. Anyone here who do that? Every year, annually, you update the policies? Supriya Mhatre: Yes, I do that. InfosecTrain Trainer: Yeah, so you might be, maintaining a table InfosecTrain Trainer: In that, right? Which helps you track this. Changes

version, control. Supreya Mhatre: Yes, yes, version history table, yeah. InfosecTrain Trainer: Yeah, that's what it talks about, right? So whenever you have any procedure. InfosecTrain Trainer: any document you retire, any document you modify, you have to document those changes, so that people understand those versions, right? What are the changes which were done, right? What are the things which were being changed, right? And you need to gather the input to optimize the cooperation, because I cannot do those changes in Silos, right? Probably I need to gather the input from the legal team, I need to InfosecTrain Trainer: contact the compliance team, I need to probably work with the business team to understand what are the changes have taken place in their environment, and then update the policy accordingly.

InfosecTrain Trainer: And always, I need to assign an owner to update the document. So every document would have an owner. CISO won't be doing and updating all the policies. However, he's responsible for it, but he will make some other person accountable for the same. InfosecTrain Trainer: So, every document, CISO would be responsible, he will make InfosecTrain Trainer: like, identity and access manager becomes accountable for all the policies in his area. SOC Manager becomes accountable for all the policies and SOPs in the SOC team. Likewise, he can do. InfosecTrain Trainer: And you need to initiate the change proposal based on the policy review, right? And need to track proposed policy changes and review in the appropriate forum, which you will have probably InfosecTrain Trainer: Steering committee would be a better forum. InfosecTrain Trainer: to review those changes, and need to include the risk analysis related to proposed changes. Whenever you are doing any changes in the standard, policies, baseline, you have to consider the risk InfosecTrain Trainer: If I'm doing any changes, what kind of risk it will bring to the enterprise, what kind of risk it will bring to the overall process, right? InfosecTrain Trainer: Earlier, the password length was 10 character, now I am moving into the tell character. There is going to be some issues, right? Which people may come, they'll say, no, it's very difficult to remember and all, right? InfosecTrain Trainer: So you have to think all those aspects, or there are some solutions, or the tools which are running which may not support this as a technology. So all the kind of risk you have to consider whenever you are updating any policy or standard. InfosecTrain Trainer: So that's when the steering committee comes into the picture.

So, we already discussed about the steering committee. What does steering committee do, right? We discussed this in the first domain. InfosecTrain Trainer: So, steering committee is a... cross-collaboration body, right, which is created, which helps InfosecTrain Trainer: To mitigate, helps to evaluate, helps to understand all the information security-related decisions, and help you do that, right? InfosecTrain Trainer: So, steering committee would have a CISO, will have, some subject matter expert, it will have probably, legal people also. InfosecTrain Trainer: So all those people will form a steering committee. InfosecTrain Trainer: So, in my organization, we have created a body called AI... Council. InfosecTrain Trainer: Which is equivalent to steering committee. So, any AI-related decisions, solution, things which are being onboarded at this point of time are being tabled here in the AI Council. InfosecTrain Trainer: And who is heading it? Our CIO is the one who heads it, right? There is a representation from security, representation from legal, compliance, project management, all the teams, they are sitting here, right? So any new project which comes, any new solution which is onboarded, they will look InfosecTrain Trainer: All the aspects, from security, compliance, ROI, cost. InfosecTrain Trainer: all the things they will understand. They will also understand how much productivity it is bringing, are there any alternatives? So that's what the role of steering committee, same thing in the security perspective. They will help you with the risk treatment. InfosecTrain Trainer: So once you do a risk assessment, you would identify some couple of risks. To treat those risks, there are going to be a number of solutions.

So, which one to prioritize, which one to go ahead, they will help you approve it. They'll help you with the project coordination. So you, as part of the establishing the governance, as part of the establishing any process, you have to run multiple projects. They will help you prioritize InfosecTrain Trainer: that. They will review the results of the risk assessment. InfosecTrain Trainer: Right? InfosecTrain Trainer: And also help you with the regulatory updates. If there are any new laws, regulations, and all, which require any changes in the environment, any impact happening, so steering committee will help with that as well. InfosecTrain Trainer: Now, coming to the issue resolution through Information Security Program, right? So, as part of the information security program, there are going to be the issues which will come. InfosecTrain Trainer: Right? InfosecTrain Trainer: So, what is the difference between an issue versus risk? Someone tell me. InfosecTrain Trainer: What is the difference between issue and risk? Fatha: Issue is something of... Which is... Unexpected or a problem. Fatha: Risk is when it impacts the... Goals or, strategy? Fatha: Or operations. Fatha: It becomes a risk. Pudir: Sir, this is anticipated, not so far occurred, but issues already existing now. InfosecTrain Trainer: So, issue. Srinivasan: Rescue is a probability, but the issue was... current... InfosecTrain Trainer: Yeah, issue is something which is already present in the environment. InfosecTrain Trainer: Something already which exists, you know. InfosecTrain Trainer: there is a problem. Risk is something which will happen. Through that issue, if you do not resolve that issue, then it will create a risk for your organization, right?

InfosecTrain Trainer: Like, you identified an issue that the firewall rules are not being reviewed. You identified an issue, there is no proper access management review process which is in place. InfosecTrain Trainer: or accessory certification is not being taken on time. So, these are all the issues, right? So, issue... also, you, sometimes you call it the problem management. InfosecTrain Trainer: It's a problem in your system, problem in your organization, which you have to remediate and response, right? InfosecTrain Trainer: So that's why you have to implement a process to tackle those issues which are there in the environment, right? You need to employ the mitigating control, right, if the primary controls do not work, and you need to take an alternative action to protect the information. So what is the... InfosecTrain Trainer: Cycle, what you follow in the issue remediation. InfosecTrain Trainer: You understood the issue. There is one... InfosecTrain Trainer: problem which is... came to you, right? You... InfosecTrain Trainer: define the problem, and that's why the steering committee comes. Steering committee will help understand those issues, they will help determine, are there any risky issues which need to be fixed immediately, right? Then you will define the problem. InfosecTrain Trainer: They will design the action plan to fix that issue. InfosecTrain Trainer: You will assign the responsibility to someone, and then resolution due date you will give. InfosecTrain Trainer: If... InfosecTrain Trainer: that issue is not able to fix within that.

You identify that issue will take a longer time to fix, then you should InfosecTrain Trainer: Make a note and move it to the risk register, because then there is a risk, there is an open issue, which could not be fixed because of budget constraint, your resource constraint, anything can be an problem, right? Sandeep Saxena: What question? So, the workshop in VAPD process, their issues. Sandeep Saxena: the vulnerabilities we find in VR. InfosecTrain Trainer: Yes, correct, correct. Sandeep Saxena: Okay. InfosecTrain Trainer: So, all the weaknesses which you find, those are issues. Those are not yet risk. Sandeep Saxena: Okay. InfosecTrain Trainer: No. InfosecTrain Trainer: So your vulnerability management cycle or program which runs in the organization, that is actually the same issue management only. Now, there is a topic in the CISM and this domain also around the waterfall and the agile model, right? InfosecTrain Trainer: I think most of you might have seen Waterfall and the Agile model. InfosecTrain Trainer: industry was earlier into the waterfall, now they move to Agile, right? Still, there are a couple of processes and industries where you cannot follow Agile. Like, if you are constructing a data center, can you follow Agile approach there? You cannot. InfosecTrain Trainer: Right? You cannot continue to keep doing any changes in that data center, right? You have to initially create a blueprint, architecture, decide that what is going to be the area where I'll be placing server, where I'll be laying out the cables and everything, where is going to be backup and everything, then all you can plan, right? InfosecTrain Trainer: So, any project where you have a clear requirement. InfosecTrain Trainer: You have a clear understanding, clear understanding or goal.

What exactly you want to build, you follow waterfall. You're building construction. InfosecTrain Trainer: they cannot follow Agile. They cannot do... keep doing changes in the building when they are constructing. If they are constructing a 30, 35-floor tower, they cannot keep doing changes, right? They have to do the architecture planning, everything in detail, in advance, in the beginning, and then they will start building. InfosecTrain Trainer: But in the software industry, people have migrated to Agile, because in the software, rather than giving people complete product at one go, you produce that product in phases, in increments, right? InfosecTrain Trainer: Like, suppose I have to design a web application. InfosecTrain Trainer: there are web pages, right? So there are multiple things. So first, I will design a UI, I'll show it to the customer, I'll take an approval. After that, I'll... I'll probably design a feature page. Once that is done, I'll design a cart. InfosecTrain Trainer: Where people can add those items, and all those things, no. Waterfall, something which is sequential and follow a linear approach. It has discrete phases with formal sign-on, right? Requires comprehensive documentation, and changes are very difficult to implement once done. InfosecTrain Trainer: Right? At best. InfosecTrain Trainer: for the project, which have clear timelines, defined architecture, defined requirements. But the Agile is something which is iterative and the incremental in nature, so incrementally, you are developing that web application. InfosecTrain Trainer: And continuously, stakeholder requirements are there, so if you would have heard the Agile Scrum ceremonies, right, daily stand-up. InfosecTrain Trainer: Scrum retrospective, Right?

InfosecTrain Trainer: So all those Scrum ceremonies you would have heard, if you... you work as part of the Scrum team, those are what... those are the same thing, continuous stakeholder involvement. InfosecTrain Trainer: Rapid adoption to change, minimal upfront documentation, and always best for a project

which has an evolving requirement and the need. InfosecTrain Trainer: Now... So they... so with this particular... InfosecTrain Trainer: moving to Agile, then there was a new challenge which came to the security. InfosecTrain Trainer: Now, you are continuously... so, when it was in the waterfall, in the beginning, everything was clear. You, from a security point of view, clearly said, these are the security requirements, these are the things which you have to follow, this is how you have to build a product, these things you will do. But now, you are continuously building the feature. InfosecTrain Trainer: It's an iterative process. How security will make sure that the product and tool and the solution is designed securely, then came the concept of DevSecOps. InfosecTrain Trainer: Where... InfosecTrain Trainer: At each iteration itself, all those iterations itself, you have embedded the security, so that security also is running along with the process of development, right? So with the requirement gathering, designing, development, testing, deployment, and operate, it's a loop. InfosecTrain Trainer: That's what DevSecOps solves, right? So it helps you automate the security in CICD pipelines. So when developer create a code, you push it into the production. InfosecTrain Trainer: Automatically, the testing would be done. When he moved to the next stage case, automatically the testing would be done. So security is there, everything.

When he's developing, that time also the static scanning is happening. InfosecTrain Trainer: And there is a continuous feedback and shared responsibility. InfosecTrain Trainer: like, those developers, security is responsibility of them as well, and fail fast fix. So, key testing types, you would have heard about the static testing, dynamic testing, open source analysis, and hybrid runtime analysis, IAST. InfosecTrain Trainer: So, you need to have a high-level understanding around this topic. They are not going to ask you InfosecTrain Trainer: Any detail around the SSD, DSTSC, or IST. InfosecTrain Trainer: Now, understanding the change management process. InfosecTrain Trainer: So, we discussed this in the previous domains also, alright? InfosecTrain Trainer: So, in the security program, change management is a very important process to make sure all the changes which you are doing in the control, in the baseline, in the policies, in anything, it should follow a change approval. InfosecTrain Trainer: Right? So the change management process works with a proposal where you will InfosecTrain Trainer: You give a proposal, the proposal would be reviewed, then proposal would be approved, then the change would be implemented, then it will be verified if the change have been implemented as it was, and then you will do the change review, post-change review, to make sure that the changes have been implemented the way it was planned. InfosecTrain Trainer: Same, oppose it to the change management, not oppose it. InfosecTrain Trainer: in line with the change management is the configuration management process. So, configuration management process and change management process work closely together.

InfosecTrain Trainer: So, configuration management means all the systems in your organization would be maintaining some configuration, right? Your hardware, your software, your servers, everything maintains the configuration, and if those configurations are being updated, or changed, or modified, should go with the change management process. And then you have one configuration management database. InfosecTrain Trainer: And there is also a process called the config drift. InfosecTrain Trainer: So, if the configuration is drifting from the baseline, you check that drift, and then you follow the change management process to update it. InfosecTrain Trainer: Now, there is one more ITIL process, which is called the release management, so all the new version of the software which you receive is come through release management. InfosecTrain Trainer: If you're using an Android phone, they keep launching the new version. That comes through release management. Your Microsoft OS keep launching new updates, that comes through release management. InfosecTrain Trainer: So, release management is an ITIL process which helps control how applications changes are deployed into the production. InfosecTrain Trainer: Right? So it serves as a crucial final estate, so whenever the software product is put into the production, it should follow the release management process, and should be done via release management, so that version control and everything is maintained, right? InfosecTrain Trainer: So whenever you... in incident management and the problem management perspective, whenever you are fixing any bugs, any vulnerabilities, right, to incidents, right, where application software changes are appropriate or remedied, you will follow this.

InfosecTrain Trainer: Whenever you are doing any new enhancement, new functions, new processes you are creating, you will follow this. InfosecTrain Trainer: Whenever you are designing any subsystems, you are deploying any patches, you are changing the OS or databases, it will follow the same process. InfosecTrain Trainer: Let's discuss some questions, yeah. InfosecTrain Trainer: Alright, let's discuss... InfosecTrain Trainer: Most of you got it correct. InfosecTrain Trainer: So, an organization adopts an agile development model for its critical customer-facing application. From an information security perspective. What is the main challenge this presents for integrating security? InfosecTrain Trainer: We just discussed. InfosecTrain Trainer: security is continuously evolving, continuously, new changes are being deployed, so that's why the DevSecOps was born, right? InfosecTrain Trainer: So, the need to embed security activities continuously throughout the short development sprint, that is a challenge for you. InfosecTrain Trainer: And that's where the DevSecOps comes into the picture. An organization is implementing a new patch management system. Which IT service process is most critical to ensure these security-related changes are introduced smoothly and securely into production environment? InfosecTrain Trainer: Change management. Incident management, problem management, SLA, all of them are out of context here. Change management is something which you use to deploy patches, even same thing you follow in your organization also. InfosecTrain Trainer: Several business units reported problem with their systems after multiple security patches were deployed. What is the first step to handle the problem?

InfosecTrain Trainer: Assess the problem and institute rollback procedure. Okay, looks good. Disconnect the system from network until the problem are corrected. So, A you will do first, then you will do B. Uninstall the patches from the system, that would be part of A. InfosecTrain Trainer: contact the vendor regarding problem that occurred. So first, you will do A, then you will contact the vendor. So, A is the correct answer here. InfosecTrain Trainer: Yes. InfosecTrain Trainer: Now, there is a short topic related to cloud also in the ISACA, so it's... it was there at a very basic level in the previous version. I'm not sure what they have done changes in the next InfosecTrain Trainer: version which is being launched, probably they will add a couple of more things around cloud, not sure. But currently, it is kept at very basic level. I... how many of you have worked in cloud, or have a very basic understanding, or have an understanding around cloud? SrinivasanJ: Yeah, I have worked in Florida. InfosecTrain Trainer: Nice, nice. So I think it should be an easy one for you. But it's very basic. Let me take a very simple or basic example to make you understand, first, the cloud service model. InfosecTrain Trainer: Cloud have been there since ages, right? InfosecTrain Trainer: It got commercialized recently... not recently, it has been time, but it got commercialized when the AWS came into the market, right? InfosecTrain Trainer: Then it got commercialized, right? Let's take a very simple example. InfosecTrain Trainer: you... Actually, you... I'll take an example of a home. InfosecTrain Trainer: Let's say you per... you... you actually rented one particular home. InfosecTrain Trainer: That particular house is completely empty. It's just walls around it.

InfosecTrain Trainer: You have to go... basic thing, it's given, it's given you wall, it's given you a place to live, or a roof to stay inside, that is the IAAS. InfosecTrain Trainer: infrastructure as a service. On top of this, what kind of cupboard you want to keep, what kind of fan you want to install, what kind of the air conditioners you want to have, what sort of electrical appliance you will keep, that is up to you. InfosecTrain Trainer: Now, coming to the next category, PAAS. Apart from those basic, InfosecTrain Trainer: basic infrastructure. They have now given you InfosecTrain Trainer: some basic amenities, like basic infrastructure, like your interior designing is done, your fans are installed, couple of things are there, beds are there. Now you can build on top of it. You can decide which mattress to bring in, which particular appliances to get in. InfosecTrain Trainer: Right? So in this... in the cloud environment. InfosecTrain Trainer: You have given the development environment is given to you. InfosecTrain Trainer: You want to develop the... you want to develop the AI-powered application. InfosecTrain Trainer: Rather than you building everything from scratch. InfosecTrain Trainer: the cloud provider is giving you access to some LLMs, you can choose those LLMs on top of those LLMs, now you can build your application, you can bring the automation, create the agents. That is a pass. InfosecTrain Trainer: SaaS is something fully furnished home. Everything is there. InfosecTrain Trainer: from a bedsheet equivalent to hotel. You just go and stay there, that's it. InfosecTrain Trainer: Just carry your clothes and stay. InfosecTrain Trainer: Only you need to be aware about the security of your information, everything.

InfosecTrain Trainer: the printer will take care, the same as the SaaS. Like, your Gmail, your Netflix, YouTube, all of these are the SaaS solutions, right? InfosecTrain Trainer: Now, these solutions are deployed InfosecTrain Trainer: in the cloud in a different perspective. So, one thing is the private cloud, something which is completely owned by your organization. You have a full control. You can relate it to with your own data center. You have a network of your own data centers, which is completely maintained by you, only your organization uses is a private cloud. InfosecTrain Trainer: Community Cloud is something... suppose you are a group of companies, like Tata Group of Companies. So every data company, like TCS, Tata Technologies, Tata Consumer Limited, each of them probably building their own data center, they have one network of data center being shared between them. InfosecTrain Trainer: It's a community cloud. Public cloud is as good as the AWS Azure, where you go, you host, create, run a machine on their environment, probably multiple people can share, it's a public cloud. Hybrid cloud is if you are InfosecTrain Trainer: managing the either of two combination. If you are managing the public cloud with

private, or community cloud with the public, becomes hybrid cloud. So that's a key difference, or key InfosecTrain Trainer: feature of this. Now, cloud also has some essential characteristics and the features. InfosecTrain Trainer: First thing is an on-demand self-service. So the cloud works as like, your own...

InfosecTrain Trainer: whatever you want to create, whatever you want to build, you can do it. It's... it's on-demand self-service. You want to... you want to spin 100 servers, you can do it.

InfosecTrain Trainer: And the best part of a cloud is the broad network access. InfosecTrain Trainer: They give you the access to the broad network. I can host my infrastructure in the Europe also, I can host in the US also, I can host in the Australia also. So all these cloud providers have a broad network access around the world, and I can do the resource pooling. InfosecTrain Trainer: The same server can be used for the multiple purpose, multiple people can share it, and elasticity. The best thing is that, you know. InfosecTrain Trainer: So these days, whenever you see the cricket matches in the hot star, Normal time, normal routine. InfosecTrain Trainer: routine series which keeps going on, generally the count of the people would be less. But suddenly, whenever there is a World Cup or India-Pakistan match, you see the number of viewership. Probably 15, 20, 30, 40 Karov people are watching at one go. InfosecTrain Trainer: Elasticity. InfosecTrain Trainer: Does, Hotstar keep those many servers running all the time? No. InfosecTrain Trainer: Whenever the demand increases, they increase the number of infrastructure to support it. Once it is gone, they'll InfosecTrain Trainer: power it down. And measured service, it's as good as the electricity meter which is there at your home. The more... the amount of electricity you use, you only pay for that. Same thing in the cloud. InfosecTrain Trainer: The number of time, number of duration you use, you only pay for that. That's the characteristics of the cloud. InfosecTrain Trainer: Now, the next topic in the domain is around the third-party risk management, which is very important. Anyone here from the TPRM domain, third-party risk management domain. InfosecTrain Trainer: Let me explain you.

InfosecTrain Trainer: Every organization, you cannot build, do everything at your own, right? You would be having SaaS solutions, you will be having the contractors working with you, you will be hosting your infrastructure in the cloud environment, probably you will be outsourcing some couple of activities. All those people are what? They are third parties to you. InfosecTrain Trainer: Right? InfosecTrain Trainer: And each organization, be it small to large, all of them would be managing a long list of third parties. You generally maintain InfosecTrain Trainer: I hope we can extend by 2 or 3 minutes, right, so that I can at least cover this topic. InfosecTrain Trainer: And then we can start from a new topic on, yeah, tomorrow. Yeah, so third-party life cycle is something where whenever you onboard a third party, a new third party is onboarded. InfosecTrain Trainer: You need to. InfosecTrain Trainer: Actually mitigate the risk. InfosecTrain Trainer: Why? You are sharing your data with them, you are using their SaaS solution to do your day-to-day job. Tomorrow, that solution is not available, your organization will get impacted, right? So that's why there is a life cycle which comes into picture. When you onboard any third party, you first do an initial assessment. InfosecTrain Trainer: what you will do as part of it, you will... you will share some framework with them to answer. Once that framework is shared, you will analyze their SOC 2 report, their ISO report. InfosecTrain Trainer: You will also analyze their proposal, all the technical capabilities, everything you will do. Once that is done, you probably initially evaluated 3-4 vendors, out of which you found out one to be a best one. InfosecTrain Trainer: Then you will onboard.

InfosecTrain Trainer: So, in the onboarding, then you will do all the due diligence and all the process, onboarding process you have, you will check their financial records, everything, and then you will sign a contract and the legal agreement with them. InfosecTrain Trainer: Which will include all the SLAs, all the incident reporting, quality, pricing, security requirements which you want them to have, everything you will include, and establish an ongoing monitoring. So there are tools called the BitSight. InfosecTrain Trainer: UpGuard. InfosecTrain Trainer: These are a popular tool which helps you do the ongoing monitoring of third-party. They keep going... they keep a check of all the... all the dark web space, all the open source intelligence, their public-facing infrastructure, their... and there are any changes, there are any vulnerability, they keep... InfosecTrain Trainer: giving you that. Apart from this, you will also have a continuous risk assessment on these third parties, or regulated. And once you terminate, as per the contract. InfosecTrain Trainer: Once you end, you will make sure that all the data, information, everything is deleted and removed from the environment. InfosecTrain Trainer: And when you assess any third party, you always keep a broad lens to it. It's not that you only look at, security part of it. You have to consider financial, geopolitical, operational risk as well. Tomorrow. InfosecTrain Trainer: What if that third party go out of business? InfosecTrain Trainer: You did not check their financial, they stopped their business, they are now gone. Now, how... you will immediately switch to a new partner. It's very important. Geopolitical risk. InfosecTrain Trainer: What if there are any restrictions put in due to geopolitics?

You know what is happening, right? Iran, U.S. war and all, a lot of restrictions, lot of tariff war and all those things going on, right? If something happens, what if there is an impact? InfosecTrain Trainer: what if there is an operational impact, right? They'll be able to provide you that level of services, they'll be able to provide you that level of uptime, and then you will also check their security posture, right? How InfosecTrain Trainer: they are maintaining their role or posture, how many incidents they had in past, how they are making sure the data and information is protected. So you look at a holistic lens to do that, and then you do a third. Sandeep Saxena: sheet. InfosecTrain Trainer: Yeah. Sandeep Saxena: In the previous slides, security manager does not look into the financial or operational or geopolitical risk, right? They are only focused on security question, right? InfosecTrain Trainer: Yes, yes, yes, yes. That's why... that's why you have a supply chain or third-party onboarding team. Sandeep Saxena: Here. InfosecTrain Trainer: So that third-party onboarding team will take the input from the security as well. So security will put the input, rest everything, they will look into it. Sandeep Saxena: Yeah. InfosecTrain Trainer: So, let's do one thing, let's start from here tomorrow, right? So, only a couple of things are left to... here in this particular domain to discuss. Probably initial 30, 35 minutes, we'll complete this particular domain, right? We'll close this. InfosecTrain Trainer: And then, we'll start the next domain, right? InfosecTrain Trainer: lit. Sandeep Saxena: What's the next token, I forgot. InfosecTrain Trainer: It's the last domain, Incident Management. Sandeep Saxena: Oh, okay, okay. InfosecTrain Trainer: Yeah.

InfosecTrain Trainer: Let me... Share this incident management video. InfosecTrain Trainer: Which all of you can watch. InfosecTrain Trainer: And all of you, all those who have not yet completed InfosecTrain Trainer: Please complete Domain 2, and now we have completed Domain 3, you can start with the questions. InfosecTrain Trainer: So you can start with the question, answering them, almost it's done, couple of things are left, which I'll complete. And I am hosting one particular, master class on 17th. InfosecTrain Trainer: I hope all of you will get an invitation for the same. InfosecTrain Trainer: To talk about the changes which are being done by the ISACA. InfosecTrain Trainer: As per this new particular syllabus, which is getting changed, right? So I would share those insights, so that you people, all of you can evaluate and see, because I know probably the people, those who feel comfortable, they probably will be able to write. InfosecTrain Trainer: Because we still have almost you people have the 45 to 50 days to write the exam, right? Which is a big window. But still, there are a couple of people, due to some commitments or something, you probably may not be able to write. InfosecTrain Trainer: in this window, and you may be able to write in the December and all, then you will be writing in the new pattern of the exam. However. InfosecTrain Trainer: There is not going to be any changes in the questions. InfosecTrain Trainer: similar kind of questions you will get, and only... InfosecTrain Trainer: you can say 10-15% topics will get changed, that's it. Rest, everything remains same. Security is same, they will just add a couple of topics to it, that's it.

InfosecTrain Trainer: They will introduce some couple of new topics into it, because there has been a lot of changes in the technology and new things which have InfosecTrain Trainer: came into the market, they just want to be relevant to that, that's why they are introducing it. They are not introducing anything related to AI or anything. They'll not. Because for the AI, there is a separate InfosecTrain Trainer: Exam altogether, right? InfosecTrain Trainer: This is not an AI security exam, this is a security governance exam. So, AI is also a technology which falls under the overall security umbrella, so it covers everything. Probably they may introduce small topic around AI to cover what does AI do and how to secure it, or AI governance, that's it. Sandeep Saxena: Just one question. So, currently, I'm just joining the classes, watching the videos, and attempting the questions in QA manual, right? I'm not, attempting the questions in the online portal, student portal. InfosecTrain Trainer: Yeah. Sandeep Saxena: This is the right way, right? I mean, after completing all the trainings, classes. Sandeep Saxena: Then we are supposed to attempt that. InfosecTrain Trainer: Yes, that's why I intentionally keep you all not to attend that, because once you complete the training, you will need some question bank, question database to test your knowledge, right? So once you have a holistic knowledge, right, then it would be easy for you to InfosecTrain Trainer: See from a holistic angle, because there is a... a lot of these domains are InfosecTrain Trainer: kind of related with each other. Now, once we reach Domain 3, you would be able to probably see the kind of a connection between Domain 1, Domain 2, Domain 3, right?

InfosecTrain Trainer: So, that's why... InfosecTrain Trainer: I told you to keep those on hold so that you can practice those questions, so that you can test that how effectively you are prepared for the exam. Sandeep Saxena: Okay. InfosecTrain Trainer: Yeah. Yeah, Shweta. Shweta Sundar: So, in the QA, what percentage, say, if we do the complete the quiz. Shweta Sundar: And scoring what percentage should give us an assurance that we have sufficient hold on the topic? InfosecTrain Trainer: That's why I told... so from the ISACA, in the main exam, the passing percentage is 60%, but I've... I've told all of you to at least

keep 70-75% as a benchmark. Shweta Sundar: Okay, okay. InfosecTrain Trainer: If you're getting 70% to 75%, that gives you assurance that, yeah, you are prepared for the exam. But that does not 100% give you assurance that you're getting 75%, here you will pass. I'll tell you one thing, I just spoke with one lady, she is already a CISSP. InfosecTrain Trainer: She's already a CISSP, but still she could not clear the CISM exam. Why? Because she did not follow one thing I told her. InfosecTrain Trainer: So she told me. InfosecTrain Trainer: In the CISSP, you could not go back and evaluate the previous question, right? But in the CISM, it's a tip for all of you. In the CISM, you can mark the question for review, which I told you first day when we were discussing, right? What she did, she. Fatha: Yeah. InfosecTrain Trainer: She marked a couple of questions, but when she was reviewing, she was left with some time. She read all the 150 questions once again, and she changed the answer in multiple of them. InfosecTrain Trainer: Because first time when you are reading a question and attempting, you are approaching it with a different mindset.

But again, once you go back and read the same question, you will get confused. You will feel like that I've... I've marked it incorrect, and then you'll feel like changing. Don't do that. InfosecTrain Trainer: And I gave the same tip to another student, and day before yesterday only, he cracked the exam. He just marked, I told him, do not mark or flag more than 20 to 25 questions, he just flagged 23 questions. InfosecTrain Trainer: He went back, checked them, and then cracked the exam. So just follow what I'm saying. Otherwise, if you follow your own strategy, it would be very difficult. So exam is designed in a different pattern altogether. It's not designed in a straightforward InfosecTrain Trainer: May. InfosecTrain Trainer: So that's why Dune... InfosecTrain Trainer: go back. First time when you are approaching, follow the same method. Next thing is the... that's why I asked you which all options you want to eliminate, why you want to eliminate. If you build that reasoning and that strategy, it would be good for you when you are approaching the exam. InfosecTrain Trainer: whatever kind of questions they are throwing, it is going to be with the same concepts and same topics, what we are studying, right? They... they cannot change the gap assessment, they cannot change the risk assessment, they cannot change the BIA. The purpose and the things will remain the same, they'll just tweak the language around it. InfosecTrain Trainer: So you have to just figure out what is the correct answer, right? So that's what is the tip. But however, the last day, we will discuss in detail that how to approach the exam, what are the key things which you have to keep in mind. Yeah, Manoj. Fatha: Like, we make points, our notes are documented, right? It'll be good.

InfosecTrain Trainer: Which point? Fatha: And, like, a strategy for, exam, this kind of tips. InfosecTrain Trainer: Yeah, yeah, sure, sure, sure. Last day, last day we will discuss, you all can make a note of it. Fatha: Yep. InfosecTrain Trainer: Yeah. And then, yeah, someone was saying that masterclass, which is happening on 70, don't worry, you all will get the... get the notification, or probably... I'll tell the team to probably ping that link in the chat, WhatsApp chat. InfosecTrain Trainer: All of you will get the notification for the same. Manoj Kamble: Yeah, so I just want to understand what will be the level of competency of the questions. Either it will be similar to QA manual, or, like, the practice test links which was provided. InfosecTrain Trainer: It's almost going to be similar to the QAE manual. InfosecTrain Trainer: And when we are discussing here, right, we see a lot of long, lengthy questions, but exam, it's not like. Exam, you will just see one line, two lines, one-line questions only. Most of the questions would be one line, and one-line questions are more confusing than big paragraph-based questions. InfosecTrain Trainer: Let me tell you, because you have a very less amount... less context given in the question. You need to read that question properly to figure out that... what is the correct answer. InfosecTrain Trainer: But the question would be same. You will see all those cleaved, best, most, first. InfosecTrain Trainer: greatest, all those keywords would be there, almost the pattern and the language would be same the way QA manual says. It's almost the same. You will not get the exactly same question what is there in the QA manual as a repeat.

InfosecTrain Trainer: But the method and the thinking process, what is required, would be almost same, what we are discussing and what is there in the query manual. InfosecTrain Trainer: Quadrick? Manoj Kamble: Yeah, thank you. Fatha: Shank, I have one question, like, generally, like, like... Fatha: when we are, like, certified, then we want to move into a CISM kind of a role. Like, what is the first thing we need to now prepare, or we need to do some additional courses or auditing, like, for example, audit? Fatha: or, similar to that. InfosecTrain Trainer: No, no, courses? Fatha: In terms of law. InfosecTrain Trainer: courses won't help you. You should build a kind of a thought process, or you should have a... you should InfosecTrain Trainer: Because the questions, you will be definitely approaching an interview, right? So the interviewer for a CISM, once you have a CISM, you would be probably applying for a leadership role, right? They won't be asking you straightforward question. What they ask to the specific InfosecTrain Trainer: technology-oriented roles. They will be asking you the situational questions. InfosecTrain Trainer: And that situational question will check your technical know-how, that will also check your decision-making thinking process, and that's what the thinking process the CISM will help you build. InfosecTrain Trainer: So whenever you see... think from your CISO perspective, you go and talk to your leadership, they are not very focused or very focused around some specific technology. They'll be thinking from a holistic perspective. That holistic view, the CISM is building.

You have to InfosecTrain Trainer: See the cyber security from an overall InfosecTrain Trainer: cybersecurity organization perspective, not just one InfosecTrain Trainer: A particular department or a function which you are handling. InfosecTrain Trainer: You are probably working in a vulnerability team, you are working in a cloud security, application security. You build that, you have to broaden your horizon and see everything from that bigger lens. That bigger lens, this particular CISM will help you build. InfosecTrain Trainer: So that you would now start talking in terms of strategy, governance, risk. InfosecTrain Trainer: All those things, you should be... start talking. InfosecTrain Trainer: And also in your... it's not mainly from this exam perspective, from in your own organization, also day-to-day decisions, or whatever actions you take, you all start embedding this risk management approach. InfosecTrain Trainer: You think from a risk perspective, you think from all those perspectives before taking or implementing any actions. Sandeep Saxena: This masterclass, can we have in weekends? InfosecTrain Trainer: So this masterclass, they have planned it on the evening. It's not in the morning time, it's in the late evening, so probably all of you would be able to attend. Sandeep Saxena: No, I won't mapping your strength, so... InfosecTrain Trainer: -Oh. InfosecTrain Trainer: So they have planned it on 17th, it's going to be in the... I think they will have a recording and all, so you will be able to listen to it. They'll record it, you can drop a note, and they'll share the recording with you. Sandeep Saxena: Okay. Manoj Kamble: So, what are the timings and how long it will be for the masterclass? InfosecTrain Trainer: It's going to be there one and a half hour.

It's going to be there in the late in the evening, starting probably around 8 o'clock in the evening, because I also have an office. InfosecTrain Trainer: So... so I'll be taking it in the late in the evening, around 8 o'clock. InfosecTrain Trainer: India time. Manoj Kamble: Yeah, thank you. Means, like, I am based out of UAE, actually, so that's the reason. Thank you. InfosecTrain Trainer: Okay, okay, okay, yeah, yeah. InfosecTrain Trainer: Alright, then. Thank you so much, everyone. We'll see you all tomorrow. Thank you. Sandeep Saxena: We can't play. Manoj Kamble: Thank you, good day.

Day 7: Full Cleaned Transcript

Approximate source length: 31,241 words.

InfosecTrain Trainer: Alright, let's get started, so... So, good evening, everyone. So... InfosecTrain Trainer: So, anyone has any question from the previous session? InfosecTrain Trainer: Any questions, any doubts, anything which you would like to clarify before we proceed? Because we... InfosecTrain Trainer: We are about to complete the Domain 3, some couple of topics are left. InfosecTrain Trainer: And then we will be starting with the next domain. InfosecTrain Trainer: Alright, then get started. So we... yesterday, we were discussing about the third-party risk management, right? InfosecTrain Trainer: So, it's a very important thing, however, looks like a very procedural InfosecTrain Trainer: Or kind of non-technical stuff in the field of information security, but... InfosecTrain Trainer: A very essential or important, because your complete organization runs on the support of those third parties, right? InfosecTrain Trainer: So every organization cannot produce or have their own native or their self-made tools and technologies which they use or consume, right? You have to rely on something to some external sources which they'll provide or share to you. It's not necessary, it should be SaaS solutions, probably it could be, inbuilt, kind of, some libraries. InfosecTrain Trainer: some connections, some APIs which they are delivering to you, which you are using in your products, right? InfosecTrain Trainer: So it's very important to have a better governance around all the third parties, right? InfosecTrain Trainer: So, establish that governance, how the third-party governance works, so you have to do a risk assessment of all those third parties as well.

So, when you are onboarding them in your environment, you have to categorize them specifically on the basis of services they are providing to you. InfosecTrain Trainer: Right? On the basis of, InfosecTrain Trainer: support they are providing to you, right? Also, on the basis of, InfosecTrain Trainer: Kind of, kind of the financial impact InfosecTrain Trainer: it would have if they are not available, right? So, on the basis of that, then you will categorize them, right? You will say. InfosecTrain Trainer: Critical. InfosecTrain Trainer: high... Moderate and low. InfosecTrain Trainer: So, likewise, you have to create your own matrix for your organization, where you fit in those third parties here. Now you have InfosecTrain Trainer: on the basis of this, now the governance would be there, right? Because each and every third party, you cannot do a risk assessment annually, because it's going to be a huge task, or humongous amount of InfosecTrain Trainer: resources which would be required to perform that, right? So you say, critical we'll do every year, high we will do every 2 years, moderate will do three years, low we'll do once in a 5 year. That's how you set a frequency. It's not necessarily this should be there, you will decide for your own organization, but this is how you will do that, and then you will govern those third-party relationships. InfosecTrain Trainer: So, first step is the risk assessment. InfosecTrain Trainer: So you have to do a risk assessment to understand what are the potential risks of InfosecTrain Trainer: that particular third party getting into your own environment, right? It can be a risk of data which is being shared with them. It could be the risk of the criticality of the InfosecTrain Trainer: Services which they are providing to you.

Probably, if they don't share those... that information, if that platform or that third-party support is not needed, probably your main business will shut down. InfosecTrain Trainer: So, on the basis of these parameters, you will then decide this rating, and then you have to do a security impact assessment. InfosecTrain Trainer: So, if... There is a security failure. InfosecTrain Trainer: Right? So, how that security failure will result into impacting you. InfosecTrain Trainer: So there is also one popular cyber attack, which is called the supply chain attack. InfosecTrain Trainer: Anyone heard of this? InfosecTrain Trainer: Supply chain attack? Can someone explain? What is a supply chain attack? SrinivasanJ: Britain in China, right? InfosecTrain Trainer: What? Can you please explain again? SrinivasanJ: It happened in China. SrinivasanJ: like, recent. InfosecTrain Trainer: No, no, no, this is a very... kind of a common kind of attack pattern, which is used by the attackers these days, right? So, the third party is a ecosystem. InfosecTrain Trainer: Right? Suppose you say there is one XYZ application. Will you... there are two cases. Either you design this application completely at your own, or you will borrow some libraries InfosecTrain Trainer: some APIs or some integration from outside, which are not built by you, billed by someone else which you are integrating. InfosecTrain Trainer: So then, this... InfosecTrain Trainer: all triggers a supply chain attack, because someone is creating those libraries for you, which you are enabling. If there is an issue there, it will result into an attack in your tool or environment. This is one way to look at it.

Second way to look at it, like your third-party email gateway getting compromised, and from that email gateway, then the people can send the phishing email to you. InfosecTrain Trainer: So your... your organization is very... like, the people in your organization, those who regularly communicate with them, they would see that, okay, the email is coming from a legitimate source, because we have a relationship with them. InfosecTrain Trainer: they'll click on it, eventually. So, this is another thing. InfosecTrain Trainer: Also, there... there are some third-party applications, right, which Actually being used widely. InfosecTrain Trainer: Around the world. So... so, so, so those widely used applications, if, kind of a vulnerability getting identified there, all the organization will get impacted. You can read about the move it. InfosecTrain Trainer: It happened in year 2023, which had almost a global impact of almost 600 to 700 enterprises. So, that's why the security impact assessment becomes so very important for you to understand the kind of impact InfosecTrain Trainer: It would bring to your environment, and then you have to do the failure management. InfosecTrain Trainer: if... InfosecTrain Trainer: They are... their services are not available, they suffered a ransomware attack, they suffered any kind of an issue, and due to which they are not able to provide you services, so you should have a backup plan for the same. InfosecTrain Trainer: Right? How you will operate in that scenario, and also there should be an engagement model. So all the organizations, they generally have something called a InfosecTrain Trainer: engagement managers, or there is, there are some organizations they call it the relationship managers, or something like that.

So, they... they will be handling lists of some couple of third parties, like, this is handling 20 third parties. So, they'll be the kind of a gateway between that third party and the organization. InfosecTrain Trainer: And then they will balance between the security and all kind of requirements, so the engagement would help you govern the third parties. InfosecTrain Trainer: Now, there is a very widely used InfosecTrain Trainer: term, which you would have heard in the cloud sense also. Also, it is now there in the shared responsibility model. InfosecTrain Trainer: Shared... Responsibility Model. InfosecTrain Trainer: Part of this? Shared responsibility models. InfosecTrain Trainer: Like, some... something are they responsible for, and something you are responsible for. Like, suppose you are using the anthropic model. InfosecTrain Trainer: you purchase the license from them, you are using their model to build your machine learning algorithms, your agent development, and all, so there is going to be a shared responsibility model between Anthropic and your organization. They will say that we are responsible for InfosecTrain Trainer: the data accuracy. We are responsible for the model drift. InfosecTrain Trainer: We are responsible for making sure that the model is trained on the latest data, right? So all those things, we are responsible for that there is no biasness there, right? So all those things, they'll respond, but there are going to be a couple of things which you have to also take the accountability, which you are responsible for. Same this particular slide is depicting. InfosecTrain Trainer: So... So the... you do the risk assessment, and you define the control. InfosecTrain Trainer: So what sort of controls you will put on this anthropic model?

You will place it behind the firewall, you will do the input validation, you will make sure that, InfosecTrain Trainer: Whenever people are inputting the prompt, there is a proper validation of those data and prompts, everything you will make sure, so all the controls you have deployed. You will also do the access management. InfosecTrain Trainer: Now, there are a couple of things which provider is responsible for, right? Like, some control which they have to put from their side, because they are developing these models or these services, like cloud. InfosecTrain Trainer: So, if I talk about the infrastructure as a service, which we discussed yesterday, right? So, the safety, security of data center, they are responsible. You cannot do anything right. Safety, security of the servers which are there, physical security. Someone can InfosecTrain Trainer: get inside and do some changes and all. So, couple of things which they are responsible, but you are putting up your infrastructure, your information you're hosting now. InfosecTrain Trainer: Patching up those servers. InfosecTrain Trainer: Making sure that, the information and the data which you are putting up on top of it, all the kind of security controls are there that you will make sure. So, there are a couple of things which they will do, and they will also do the control monitoring. So, there is a shared responsibility model between you and the provider. InfosecTrain Trainer: And that shared responsibility model would get reflected in form of contract, which you have to InfosecTrain Trainer: agree mutually that what they are responsible, what you are responsible, so that if tomorrow there is an issue, there is an attack, there is a cyber problem, you can mutually agree to it, who is responsible for what, right?

InfosecTrain Trainer: That's why you have to design the controls among different outsource functions in the enterprise. InfosecTrain Trainer: So, there are a good number of functions which are outsourced. InfosecTrain Trainer: to the outside organization. So you should define and design the controls to protect all of them, and also, you should place the measures InfosecTrain Trainer: to protect the information residing on the third-party platform. So the SaaS Gmail has

provided you the email account, they have provided you the Google Drive and everything, but InfosecTrain Trainer: If tomorrow an attacker is able to get into your Google Drive and able to steal your personal information, then Gmail is not responsible for that. InfosecTrain Trainer: You have to make sure that you are... InfosecTrain Trainer: Until unless there is an issue from their side. But if you're not making robust access management control, you're not protecting your ID and password, you are not enabling a MFA multi-factor authentication, then you would be... you are responsible for that, right? InfosecTrain Trainer: So that's why it's very important to place the measures so that the information which resides on those platforms is protected. InfosecTrain Trainer: Now, what is it? Sandeep Saxena: question, InfosecTrain Trainer: Yeah. Sandeep Saxena: slide, organization's Responsibilities Control Definition. Sandeep Saxena: For, if you take the example of AWS, Sandeep Saxena: What's our responsibility? What control definition? Sandeep Saxena: really Workable. InfosecTrain Trainer: So, if you talk from the AWS perspective, it depends on which kind of services you're talking about. It's IAS, PAS, or SaaS, right?

InfosecTrain Trainer: So every model has a unique kind of set of controls which you have to deploy, right? So, whatever is the responsibility on your end InfosecTrain Trainer: Those controls you will define and place. You cannot define the controls on that, how the AWS will protect their data center. InfosecTrain Trainer: That I cannot tell them, right? I can only define those controls which is within my responsibility, got it? Sandeep Saxena: Weird. InfosecTrain Trainer: Now, someone explain me, what is a demilitarized zone? Fatha: It's kind of an intermediate zone between secured and trusted and untrusted, where, you know, web servers are normally hosted. InfosecTrain Trainer: Okay. InfosecTrain Trainer: So... so... so, if you see, we yesterday discussed about defense in depth, right? InfosecTrain Trainer: So whenever you design your network parameter. InfosecTrain Trainer: So, all your trusted area, like your private network, where your database, your important servers, your AD, Active Directory Forest, everything resides on, you don't want the internet traffic directly landing onto that zone, because that is a huge risk, right? InfosecTrain Trainer: If you directly land that traffic directly to it, then InfosecTrain Trainer: one compromise, the attacker would be able to breach or get into that system. So that's why you design a defense in depth InfosecTrain Trainer: approach, and then you segregate the network in a trusted and untrusted, right? So, how it happens, right? So, untrusted is what your public InfosecTrain Trainer: So you will have some public-facing applications, public-facing websites, public-facing infrastructure, which is directly facing to internet, because you want your customers, users, and all to reach to you, right? So that traffic, when it land.

InfosecTrain Trainer: So, you have to then place a layer between that, and then create a semi-trusted zone, right? So you need... you will create a layer. So, just not one firewall. So, firewall is called a... this firewall is called a... InfosecTrain Trainer: Screened subnet. InfosecTrain Trainer: This is one which is screening the first layer of traffic. After this firewall, then you can place InfosecTrain Trainer: IDS, IPS, or any other sort of networking component, and then the traffic would reach to your servers. But those servers are someone... something which is not very critical in nature, like our web application InfosecTrain Trainer: non-critical database of web application, which supports the application to run, or something like that, which is not that critical, even if it gets compromised, not have a significant impact on you. Then you will again design the similar kind of layer. InfosecTrain Trainer: And then you will place your critical infrastructure, which is called the trusted or the private zone, where your Active Directory, your critical database, your PII information database, your employee data database, all those things will be sitting behind this. InfosecTrain Trainer: So this is how the demilitarized zone is designed, right? To protect your private network or private data from the untrusted or the public network. InfosecTrain Trainer: Now... InfosecTrain Trainer: Now, how do you actually do a remediation of issues with third party? I have taken the services of AWS, I have taken services of Azure. InfosecTrain Trainer: I am placing my information in their, their cloud environment, right? If tomorrow there is an issue in their end.

InfosecTrain Trainer: Ultimately, ultimate responsibility still sits with me, because my organization information data I'm hosting on their environment, if something goes wrong, I am the one who will be answerable to my customers, regulators, and everyone, right? InfosecTrain Trainer: But how I manage those issues with them is only through contracts. There are no other means. InfosecTrain Trainer: Through which you can manage, right? InfosecTrain Trainer: So the only leverage which you have against those third parties is InfosecTrain Trainer: Either something related to payment, something related to quality-related issues, all those things, you have to agree, right? So, the contract would include the SLAs. InfosecTrain Trainer: So, SLA is not only about that, how much uptime they will provide, or... SLA is also around other things, like they will report the incident within 24 hours. InfosecTrain Trainer: That you have to define, that if there is an incident involving our data, our information, you must report us 24-hour. It's an SLA. InfosecTrain Trainer: Right? InfosecTrain Trainer: Also, you will define the escalation procedure, problem management, all the communication channel, how they'll be communicating to you, so the SLA is very important from a security point of view. InfosecTrain Trainer: Then, quality standard. What sort of quality of services you want from them? InfosecTrain Trainer: And, and it's... so, so this is third-party... is not only about the software, right? So even... even it's, if suppose you are having a, using, InfosecTrain Trainer: AI agent provided by some third party.

So if there is a Bicing, there is a... there is an issue with the... with the quality of the output which the AI agent is producing, then InfosecTrain Trainer: they need to be responsible, right? Because they agree that they have tested their model for the robustness and everything, right? So, quality standards. InfosecTrain Trainer: Then, the security requirements. So, there is a term called right to audit, which you will see in couple of questions. So, right to audit means that you can audit their infrastructure. InfosecTrain Trainer: If you mention this specifically, then only third party would allow you to do that, otherwise they won't. InfosecTrain Trainer: However, it's very rarely and very difficult to convince them to agree for this. So, right to audit means you have all right to go visit audit, like, you are hosting... you are using IAAS infrastructure as a service from AWS, InfosecTrain Trainer: You can go to the data center and check that what kind of security they have around the infrastructure and everything. InfosecTrain Trainer: And then you will also agree around the business continuity. So, you will agree around the RTO, InfosecTrain Trainer: RPO, all the aspects, because if tomorrow there is a downtime, how quickly InfosecTrain Trainer: We'll be able to recover and share us InfosecTrain Trainer: get back online. Yeah, Johnny, you have something to ask? Johnny Souriar: Nothing, nothing. InfosecTrain Trainer: Okay. InfosecTrain Trainer: So, this is the major difference between the right to audit and right to inspect.

So, right to inspect is a basic, which is without notice, and InfosecTrain Trainer: There are limited constraints, and the right to inspect you won't be... InfosecTrain Trainer: going deeper into it, you will not be asking for any evidence, any kind of a... you will not be looking into their records, or getting deeper into their logs and everything. You will just see that everything is working fine and all well. But right to audit where you will go deep. So you need to give them a notice. InfosecTrain Trainer: Right? It will help you do an in-depth audit of third-party program processes, their qualities, their infrastructure, and all those things, and it will also help you verify and validate their control effectiveness. If in their SOC 2 report, they have mentioned some list of controls, and they have shared you the ISO 27001, InfosecTrain Trainer: as well. InfosecTrain Trainer: But, the report only does not mean that it's... everything is running effectively, right? So, you can go and check the effectiveness. InfosecTrain Trainer: And also, you will include the explicit parameters for the audit, that what all infrastructure and things would be added as part of the scope while you are auditing them. InfosecTrain Trainer: Now, how do you manage the outsourcing risk? So, whenever you outsource. InfosecTrain Trainer: So, there are some risks which you have to manage, which you have to adhere to, right? So, first thing is this risk. InfosecTrain Trainer: security risk. So, you must identify the specific level of protection in SLA and contract. What kind of protection they should provide to your data, to your information.

Also, you need to specify specific audits of certification that InfosecTrain Trainer: We will only onboard the vendor, those who have a SOC 2 report, or ISO 27001 certified, if it's AISO, ISO42001 certified, so you will need to specify them. You need to analyze those third-party auditor comments. InfosecTrain Trainer: So whenever third-party auditors, they do an audit, you have to analyze their comments and see what are the issues and what are the major things they have mentioned there, and what is an acceptable level for you, and need to do a periodic compliance assessment. InfosecTrain Trainer: Then comes the risk management, where you need to include the response and recovery activities and the testing-related aspects. Also, implement an incident response plan. If there is, like, GDPR said, 72 hours. InfosecTrain Trainer: So, if they will report you in 72 hours, then how much time is left for you to go ahead and report to GDPR? So, like, you... you will be seen as a non-compliant, as per the GDPR. So, you say, we will establish the 24-hour incident management protocol. So. InfosecTrain Trainer: If there is an incident, you give us the initial indication in 24 hours, so that we are able to gather more inputs and share it back. InfosecTrain Trainer: Right? InfosecTrain Trainer: And so that it will support the regulatory notification mechanism. And you have to also talk about the vendor viability. InfosecTrain Trainer: Right? InfosecTrain Trainer: So you have to... you have to include the aspects with respect to response and recovery. InfosecTrain Trainer: And need to test the incident response plan with them. InfosecTrain Trainer: Also, support for the regulatory industries with set timeframes.

So, GDPR has a different timeframe, NISTU has a different time frame, so you have to agree upon it and accordingly act on that, right? InfosecTrain Trainer: Let's discuss some questions, yeah. InfosecTrain Trainer: Alright, let's discuss. I can see most of you got it correct. InfosecTrain Trainer: A CISO is reviewing a

proposed cloud services that offers a rapid provisioning of InfosecTrain Trainer: virtual machines and storage or demand, with a pay-per-use model, which essential characteristics of the cloud computing represent the greatest challenge to maintaining consistent security baseline? It's talking about the baseline. InfosecTrain Trainer: Don't go buy... InfosecTrain Trainer: kind of the technology tech stack. I know there is a tech stack available in AWS and Azure, which can help you achieve elasticity with maintaining baseline, right? But you think from a broader perspective. InfosecTrain Trainer: Resource pooling is not related to baseline, so as such. InfosecTrain Trainer: eliminated and measured service also eliminated. They are not related to baseline. Only people would be more, confused between the broad network access and rapid elasticity. So if you see the close... if you closely read both the thing, which would actually be more InfosecTrain Trainer: closest to the baseline-related issues. Rapid elasticity means I have... I have to spin 100 servers. InfosecTrain Trainer: Very quickly. InfosecTrain Trainer: How I'll make sure that all those 100 servers maintain the security baseline what my organization desires? InfosecTrain Trainer: All of them should have antivirus, all of them should have this version of so-and-so, this version of so-and-so. So that is always going to be challenge, right?

So rapid elasticity is something which is closely related with the baseline, not broad network access. InfosecTrain Trainer: When considering outsourcing technical or business processes, one of the main concerns InfosecTrain Trainer: Of the information security manager is whether the third-party service provider will deliver a level of quality acceptable to the enterprise-established customer base. InfosecTrain Trainer: This is not going to be concern of security manager, more of the concern of the business. InfosecTrain Trainer: Agree a SLA with penalties sufficient to upset the potential loss. Provide a technical service at lower cost than would be possible on in-house basis. This is also a business decision. Meet the enterprise security requirement on an ongoing and verifiable basis. Security manager is responsible for security, and his major concern would be that how they are ready to meet InfosecTrain Trainer: the security requirement, and those security requirements are, if part of the SLA, then they need to agree to it. So, B, cover B as well. InfosecTrain Trainer: So, that's why D is the correct answer. InfosecTrain Trainer: How would an information security manager proceed when selecting a public cloud vendor to provide the outsourced infrastructure and software? Insist on a strict SLA to guarantee application availability, verify that vendor security posture meets the enterprise requirement, update the enterprise security policies to reflect vendor agreement, consult a third-party provider to provide an audit report to assess the vendor security program. InfosecTrain Trainer: So, insisting upon SLA to guarantee application availability, this is also a part of security posture.

Probably if you have some SLA which is part of the security posture, which they need to meet, so part of B. InfosecTrain Trainer: Update the security policy. You won't be updating your security policy to meet someone else's requirement. You will be working with some thousand of third parties. You... how many times you will update your policy, you don't do that. InfosecTrain Trainer: Right? Consult a third-party provider to provide an audit report to assess the vendor security program. So, this will also be contributing to B. InfosecTrain Trainer: So B is something which is an umbrella answer, right? You want the vendor to provide the InfosecTrain Trainer: security posture which meet your organization requirement that you would identify through audit, or it may include the SLA. An organization use a DMZ to host its public-facing web server. What is the primary security objective achieved by placing these servers in DMZ separate from internal network? InfosecTrain Trainer: To guarantee 100% protection against external attack, to isolate public-facing service, limiting direct access to internal network outsource, if compromise, we just discussed this. Enable faster data transfer, no, do not do that. To simplify the management of the internal network, no. InfosecTrain Trainer: And it cannot provide you 100% protection against it. So, B is the major InfosecTrain Trainer: issue which you would like to solve using the DMZ, which is the segregation between the public and the private network. InfosecTrain Trainer: Let's go to the last topic of this domain, right? Now, communication and reporting. InfosecTrain Trainer: Right.

InfosecTrain Trainer: So... You need to assess how your program is behaving or progressing at InfosecTrain Trainer: this stage, and that particular stages need to be reported. That's what you do in your organization also, right? You report to your senior management how your program is progressing, how you are with respect to the compliance, how you are respect to the audit, how you are with respect to the number of incidents which are occurring, right? InfosecTrain Trainer: So, you need to assess your current state of the program at multiple intervals, right? InfosecTrain Trainer: So, you will be assessing it with respect to the objectives. So, whatever objectives you have set, right, that I would migrate the 80% of the on-prem infrastructure to cloud by end of Q4. InfosecTrain Trainer: I would roll out the AI policy by end of Q1, something like that. So these are the objectives of your program which you want to meet. InfosecTrain Trainer: So those objectives you will check at all the stage gates so that those are being met or not. Also, it will help you with the managing the program. InfosecTrain Trainer: So that your program should remain on track. You are able to deliver all the things what you planned, right? And also help you manage the security. InfosecTrain Trainer: technical security. So, you, as part of the program, you will have some objectives where you will be defining some technical controls, some security requirements, those you will be able to manage, also the meet compliance requirements. So, in my organization, currently, I am running the NIST 2 InfosecTrain Trainer: program.

InfosecTrain Trainer: So, it's... I'm... I have some objectives to meet by ear, and I will be doing the registration as these countries, I'll make sure that all the gaps which I have identified as part of the NISTU gap assessments are being addressed. So. InfosecTrain Trainer: to meet the compliance requirements. So this meeting the NIST to compliance is a part of the program which I am currently trying to achieve, right? InfosecTrain Trainer: Then, operations management, your SOC, your vulnerability management team, right? Your AppSec team. InfosecTrain Trainer: All of them are do... what? They are all doing the... InfosecTrain Trainer: the operations, right? They are doing day-to-day operations to make sure organization is protected from all kind of incidents, right? And then your CISO also continue to keep an eye on the resource levels. InfosecTrain Trainer: Right? How many people... so you... there is going to be in one resourcing level of your organization, right? Like, suppose you are maintaining a 50-member security team. InfosecTrain Trainer: Out of 50, there are, suppose, 8 managers, then there are 10 team leads, and rest are the individual contributor. So this, your... InfosecTrain Trainer: CISO will make sure that he's keeping a watch on this and making sure that the resourcing levels are maintained at the same level. People will continue to go, leave, join, right? So this resourcing level also is part of the assessing the state of the program. InfosecTrain Trainer: Now, how do you resolve the non-compliance issue which you identify as part of this current state assessment? InfosecTrain Trainer: So, what is a non-compliance issue? Something which is not compliant with respect to your policy. InfosecTrain Trainer: Something which is not compliant with respect to regulations.

InfosecTrain Trainer: Right? Something which is being drifted from your baseline. InfosecTrain Trainer: your standards, so all those non-compliance issues you will identify as part of this, which you need to address. And... InfosecTrain Trainer: Anything which is... you see that this is a very high-risky item can... could have a very significant impact on your organization, is beyond your risk appetite level, need to have a quick fix. InfosecTrain Trainer: And then, suppose you, through this process, you identified 5 non-compliance issues. InfosecTrain Trainer: So, can you put the equal amount of emphasis on all of them? Could you manage to have a budget or funding to fix all of them? Probably not. InfosecTrain Trainer: So, you have to prioritize them, and then accordingly approach it, right? So, whatever budget and the resources you have, you will say, we will first fix these two, which are the very critical in nature. Rest all we'll see in the next year. InfosecTrain Trainer: And then you have to assign the responsibility to someone, so that the person would take accountability of fixing those, and regularly, you have to follow up. InfosecTrain Trainer: Right? InfosecTrain Trainer: So, any non-compliance-related issue will result into the risk to enterprise. InfosecTrain Trainer: So, non-compliance means if you say that the, like, the MFA is mandatory for all the accounts. InfosecTrain Trainer: So, that's why in your organization, also, you continue to check the matrix. You say, okay, there are 3% account without MSA. InfosecTrain Trainer: Then you will continue to check, okay, how many of them have an approved and valid exception, how many of them don't have, then you will follow up with those people and continue to close it. InfosecTrain Trainer: Right.

InfosecTrain Trainer: Then you have to also see... develop the specific processes to deal with these non-compliance timely and effectively, right? InfosecTrain Trainer: And how you identify them, you can also identify through normal monitoring. InfosecTrain Trainer: through audit, what you conduct, they will also give you any security reviews will also give you that, right? Audit also includes your penetration testing, your red team exercises, and all, right? InfosecTrain Trainer: Then, vulnerability scan will also give you the noncompliance and due diligence process. InfosecTrain Trainer: Now, how do you measure the performance of your information security program? InfosecTrain Trainer: So you have to, as a security manager, you need to implement a process and establish a mechanism so that you actually measure the performance of your overall information security program. That's why we discussed the mattresses, right? KPI, KGIs, KRIs. InfosecTrain Trainer: So we also discussed yesterday that if you cannot measure, you cannot improve. So you have to continuously measure the performance of your program, and then accordingly, incrementally improve upon it. InfosecTrain Trainer: You need to implement this process, also need to define the objective, need to track relevant mattresses, and periodically monitor those results. InfosecTrain Trainer: So sometimes the objective may vary on scope and level, but end goal is to meet the business goals. InfosecTrain Trainer: Right? InfosecTrain Trainer: So, whatever objectives you have defined, right. InfosecTrain Trainer: may vary, like, suppose you define that I would meet the 80%, 80% system, I'll move from on-prem to cloud.

Your organization is a digital transformation journey, moving from on-prem to the cloud, but you could not meet it. InfosecTrain Trainer: You're only able to meet 75% because there was some major incident, and there was a lot of effort and resources went there, so that is fine. InfosecTrain Trainer: If the business goals are being met, That is fine, right? InfosecTrain Trainer: then you need to also achieve the acceptable level of risk and loss. What is an acceptable level? So, if you are able to meet 75%, probably this is acceptable. But if you say, we are only able to migrate 50% this year. InfosecTrain Trainer: May not be acceptable, because you are way behind the target, and then you have already paid the cloud provider, you have established a contract with them, and then you will end up paying the additional cost to them, right? InfosecTrain Trainer: You need to support the achievement of overall enterprise objective, what you have set, and establish, maintain the security awareness as part of measurement, right? And maximize the effectiveness of program. InfosecTrain Trainer: framework and the resources. Through this process, you want to gain the maximum level of InfosecTrain Trainer: output, how you will do that if you don't measure, how you will be able to gain the maximum output. If you see your security SOC team is not properly trained, they take a lot of time in the triaging, they are not able to identify the issues and gaps. InfosecTrain Trainer: If you don't monitor it using some KPIs, KGIs, and KRIs, you won't be able to fix those issues. So you need to monitor, and then you need to impart on-job training, or a specific workshop you need to conduct, so that they understand and improve upon them, right?

InfosecTrain Trainer: And then you need to measure and manage the operational performance of the overall program. InfosecTrain Trainer: So, how do you measure the objectives? First thing, you also need to consider any losses you occur. InfosecTrain Trainer: If there is a security incident, there is going to be losses. Probably the business won't be able to work, there is some financial loss, or some ransomware amount which your organization paid to the attackers and all, all those things you have to consider. InfosecTrain Trainer: Also, you need to consider the organizational objective support. How your program is able to achieve the org objective. Org objectives are to InfosecTrain Trainer: rapidly adopt the AI across organization, but CISO could not InfosecTrain Trainer: actually able to establish a proper AI governance. InfosecTrain Trainer: through tools, technologies, process, then he is not supporting the organization objective. If he do not do that, then there is going to be a lack or delay in the adoption of AI, because organization cannot adopt AI without having proper security and governance, right? InfosecTrain Trainer: compliance-related issues. So you... your GDPR compliance, NISTO, DPDPA compliance, you have to continuously measure against them that are you able to meet all those objectives? Are you maintaining all the relevant policies and controls to meet the compliance with respect to that? Then, operational productivity. InfosecTrain Trainer: how productive your teams are, how productive your technical tools are, right? So, operations or day-to-day things, what you perform, they should be performed with proper quality, right? And then awareness.

InfosecTrain Trainer: So you have to maintain an organization-wide awareness, and then we also saw yesterday a couple of examples of the specific KPIs, KRIs, to monitor that how that awareness is effectively being imparted across the organization. InfosecTrain Trainer: And then you will also do the technical security architecture effectiveness check, how effective our architecture is, how effective your management framework and the resources are working, and operational performances, right? InfosecTrain Trainer: So, every organization need to develop specific goals, objectives. Without developing those goals, you cannot measure the success, you cannot measure the effectiveness, right? And those common objectives will suggest the methodologies to measure. So, all these InfosecTrain Trainer: These things, what we discussed, right, all of them could be an objective. There could be an objective with respect to compliance, objective with respect to the risk and loss, how much loss we can bear. There would be an objective and mattresses, and how much result you want to achieve with respect to operational productivity. InfosecTrain Trainer: Around awareness, architecture review, so all those things will be an objective which would be set by the organization which you want to meet. InfosecTrain Trainer: Then you will be monitoring, so... InfosecTrain Trainer: So when... when you monitor the information security program, so... so you need to create the new controls. InfosecTrain Trainer: Right? You need to... all the new and modified controls, which you will implement as part of that monitoring, you also need to make sure that those controls are working effectively. InfosecTrain Trainer: Right?

You deployed one, AI inventory InfosecTrain Trainer: related control, which fetch the data from all your AI agents, all the external sources, and gives you an extensive list of AI agent. InfosecTrain Trainer: who are the owners, where the policies are applied, and the drift, and everything. And if you... this particular control is not working effectively, not able to give you the data from all the sources, then the control is not InfosecTrain Trainer: actually operating the way it is supposed to be done, right? So that monitoring is very important. Also, you need to monitor the technical controls, right? Where you will review the logs, alerts. InfosecTrain Trainer: like, firewall. InfosecTrain Trainer: antivirus. InfosecTrain Trainer: your EDR. InfosecTrain Trainer: So your SOC team continuously get the alert from SIM, right? So they need to correlate and check that are the rules which we have set, are those able to block those attacks? Are those sufficient InfosecTrain Trainer: In those terms, so all those things you have to monitor and then do, right? InfosecTrain Trainer: You also need to do the technical monitoring of the physical processes likely to be most efficient and effective. What are the physical processes and the policies, directions, all those things you have, and then you need to monitor the earlier in process so that you can provide the early warning. So KRIs are something which gives you the early warning. If any process is not InfosecTrain Trainer: Working the way it is supposed to, so you will get an early warning, and you can accordingly work upon it. InfosecTrain Trainer: No... It's very important to... check... keep check on cost efficiency. We discussed the matrix called the row C. InfosecTrain Trainer: Return on security investment.

InfosecTrain Trainer: So, if you think from a CISO perspective, who manage the cost for entire organization, there are multiple costs which is associated to that, right? So there is cost of InfosecTrain Trainer: people. InfosecTrain Trainer: Cost of... CapEx. InfosecTrain Trainer: capital expenditure, some new tools, some new software, or new infrastructure which you'll be purchasing, then OPEX, which is mostly your licensing cost. InfosecTrain Trainer: You are maintaining multiple licenses, right? You are using some third-party SIM solution, you are using cloud, so you'll be paying some cost to cloud vendor, you are using DLP, so DLP licensing cost. InfosecTrain Trainer: So all those things will be there, right? So you have to make sure that all these tools are able to protect your organization overall, and able to support the organizational objective. Otherwise, the cost which you are putting up InfosecTrain Trainer: on all these things. It can be the anti-malware cost, phishing cost, network defense costs, that is all waste. InfosecTrain Trainer: So, when you are checking the cost efficiency, you have to overall look into all the kind of cost which you are investing to InfosecTrain Trainer: Secure your organization. InfosecTrain Trainer: And then, this is a cycle, right, which you have to adopt. You have to continuously evolve and continuously monitor, so you have to first assess. InfosecTrain Trainer: Right? Current state versus the... which we discussed, right? Current state assessment, current state versus the objectives, what you have set.

Then, if you see any gaps, you have to plan, you need to develop the strategies to address those gaps, then you will implement InfosecTrain Trainer: those strategies, those fixes which you identified, and you continue to monitor, so that you improve upon your overall performance of your security program. So we are done with this domain. InfosecTrain Trainer: So, anyone has any doubts or anything on this domain? So before we... Begin with the next domain. InfosecTrain Trainer: Let me share a mind map with all of you. InfosecTrain Trainer: Of this domain. InfosecTrain Trainer: Yeah, I have shared the image. InfosecTrain Trainer: in the chat. InfosecTrain Trainer: So this is the mind map which I have created. InfosecTrain Trainer: So it is... kind of summarizes the complete domain. InfosecTrain Trainer: So, you can use it before the exam, too. InfosecTrain Trainer: Let's start the next domain. InfosecTrain Trainer: So, this is the incident management domain, so domain is divided into two parts. First is the incident management readiness, next one is the incident management operations. InfosecTrain Trainer: Right? So this is... these are the topics which we would be discussing as part of this. Domain carries a weightage of 30%, right? So approximately 45 questions per InfosecTrain Trainer: This is how much you can expect from this domain, right? InfosecTrain Trainer: Let's talk about incident, and why incidents are very important, right? Let's discuss one case study, right? InfosecTrain Trainer: So, in the end of August 2025, right, a major InfosecTrain Trainer: manufacturing organization, a car... a well-known car manufacturing organization, which is a British Car maker, right? InfosecTrain Trainer: their three most important plants across the Britain, right?

They collectively produce approximately 1,000 vehicles a day. That was the production capacity they had, right? So on... somewhere on the 31st August. InfosecTrain Trainer: Right? Something they observed InfosecTrain Trainer: weird activity in their network, right? So, attacker did not leverage any zero-day attack or anything. They used a very simple technique. InfosecTrain Trainer: Imagine, like, it's not necessary the attacker will always use a very sophisticated kind of a technique, some zero attack and all. They always use a very simple technique. They use the social engineering. InfosecTrain Trainer: Right? They... InfosecTrain Trainer: gave a phone call impersonating a staff, and they did the credential harvesting, and then they were able to reach their core SAP system. InfosecTrain Trainer: So... so there are only a handful of, or, kind of providers, those who... InfosecTrain Trainer: provide these supply chain solutions. So, there is SAP is top one, Oracle also provide, there is one from Microsoft, only a handful of them, which provide these... so SAP is well known in the world, right? So, all the organization supply chain and their complete InfosecTrain Trainer: core infrastructure, everything runs on it, right? So they were able to do that. Now, on the 1st September, 31st August, they did that. On 1st September, their IT team detected there is an intrusion. InfosecTrain Trainer: And then, due to which, there was an incident management plan, which they activated, right? Then there was a malware, which they were able to InfosecTrain Trainer:

deploy, and the malware spread so quickly, right? InfosecTrain Trainer: that they could not control it.

Now, there was a situation where they thought that should we pull the plug, completely shut down our network, our complete IT, InfosecTrain Trainer: And they had a 30,000 global employee base. Imagine. If you shut down everything, all of them will not be able to access, and then they have to pull it off. Imagine. InfosecTrain Trainer: They shut down their complete IT network infrastructure, they cut it across there because they could not InfosecTrain Trainer: Actually manage that attack traversing through their network, right? And imagine the kind of impact it had put. InfosecTrain Trainer: They lost 800 million euros, which is a big amount. InfosecTrain Trainer: Only because of this attack. InfosecTrain Trainer: And it took them almost a month for recovery back to normal to the operations. So this is what the incident management plan does. So in your organization, also, if you don't have a proper incident management plan, this is going to be an issue. Anyone here who can guess the name of this InfosecTrain Trainer: This is a very, SrinivasanJ: I go online, too. InfosecTrain Trainer: Yeah, JLR. JLR incident, which happened in last year, August 2025, had a very wide impact. InfosecTrain Trainer: So imagine, so if the organization like them, those who have a sophisticated system, sophisticated infrastructure, everything is well-planned, they have a big... InfosecTrain Trainer: Their annual revenue, everything, very good, but still they had an incident, right? So any organization could have the incident, so that's why there is a domain called incident management, so which is very important. InfosecTrain Trainer: So, incident management is not only about the technical aspect.

InfosecTrain Trainer: So, incident management is about how quickly you are able to recover and get back to normal. InfosecTrain Trainer: So if they would have planned it in a much better manner, they would not have to probably wait for one month to recover. It means that their BCP plan, their DRP plans, their internal SOC team, the way they were working, it was not properly coordinated. That's why they had it, right? So what is an incident? InfosecTrain Trainer: So... What is the difference between an event versus incident? Someone can tell me. SrinivasanJ: Incident is a problem. If something is working, and if it is not working, that is an incident. SrinivasanJ: Event is a notification about the incident, or could be about some transaction. InfosecTrain Trainer: So, event is all the logs which are being generated, they are all events. SrinivasanJ: Yeah. InfosecTrain Trainer: You, you, you entered the password first time incorrect, maybe an event. Second time you entered is an event. Fourth, you entered fifth time, back-to-back. InfosecTrain Trainer: Could be an incident. InfosecTrain Trainer: In the normal time, everyday person go... he logs in from morning 9am, and he works till night, 9pm, he logs off. InfosecTrain Trainer: but suddenly you see the person is logging in in the night time, 3 o'clock, that also from some different country, different IP address. Could be an incident. All the events which are being generated, if it's... InfosecTrain Trainer: Drifting from your policy, and something which could have an impact to the organization would be categorized as an incident, right? InfosecTrain Trainer: So, incidents are unexpected events that can originate from wide spectrum of sources, right? InfosecTrain Trainer: So what are those sources?

It could be a cyber attack, a ransomware attack, a DDoS attack, a data breach, right? A malware implant on your device. InfosecTrain Trainer: Right? Any, anything. InfosecTrain Trainer: It could be... InfosecTrain Trainer: A loss associated with natural disaster. If there is an earthquake, tsunami, cyclone in the area, your data center is not available, that is also an incident. InfosecTrain Trainer: Loss of key personnel. If there's a fatality of a key personnel due to some issue, that is an incident. InfosecTrain Trainer: If there is a workplace incident, there is some incident, there is some workplace failure, some machine... machine failed, some portion of your building fell down, there was a fire in the building. InfosecTrain Trainer: Could be an incident, right? InfosecTrain Trainer: So, whenever an incident occurs, what is the core goal for the organization? What we learned from JLR? InfosecTrain Trainer: The focus should be managing and responding to incident regardless of the origin. First thing. As a security manager, your responsibility is to first InfosecTrain Trainer: reduce the impact, get back to normal operations, right? You are not worried. Keep this statement in mind when you are solving the question. InfosecTrain Trainer: The forensic investigations and all those things will follow at the last. Your first thing is to first manage and reduce the impact, isolate the incident, and hand over it for the operations. Then the forensic and all will continue to happen over a period of time. InfosecTrain Trainer: Right? So your main aim is to contain the incident as quickly as possible, right? InfosecTrain Trainer: So, what are the key things? We discussed incident, problem, and event, right? A lot of people get confused between them.

So, incident is something which is unplanned event. InfosecTrain Trainer: Every incident is an event, but every event is not an incident, got it? InfosecTrain Trainer: So, incident is any unplanned event that may or may cause the disruption. If it is causing any disruption, interruption to your delivery or the quality would be categorized as an incident. InfosecTrain Trainer: And the problem is something which is the underlying root cause of one or more incidents. InfosecTrain Trainer: So there is one vulnerability which may cause the multiple incident. There was one issue in one of the database, due to which the database is probably surveying to multiple applications, all of them are not available, so that is a problem. InfosecTrain Trainer: So, problem or the issue which is there in this server is causing multiple applications to fail. And events are all the observable occurrences. So, all the activities which you capture as part of the logs, all of them are events. InfosecTrain Trainer: So, that's why, on the basis of that, if you do not understand the definition between incident, problem, and event, your security team won't be able to categorize it properly. InfosecTrain Trainer: What should we call an event? What should we call an incident? Probably there is a major issue which is occurring, and they will say, this is an event. Need not to focus on it. InfosecTrain Trainer: That's why it is very important to have a clear distinction so that your security team manages and prioritizes these. InfosecTrain Trainer: Now, what are the type of security incident? So, we are... InfosecTrain Trainer: here for the security certification exam. So, what are the different type of cybersecurity-related incidents which you can categorize, right?

InfosecTrain Trainer: So the role of security manager is to create a proper SOPs, create a proper incident management playbook. InfosecTrain Trainer: proper categorization criteria, proper escalation matrix, prioritization matrix, that's what he need to categorize. And until unless you don't give a category to incident, how come your team will be able to handle it, right? InfosecTrain Trainer: So, so these are some of the categories or the example, like computer account abuse. InfosecTrain Trainer: someone is able to... so what we saw in the JLR incident, what they did, they did the account abuse. InfosecTrain Trainer: Right? They were able to do the credential service, credential harvesting, and due to which they were able to gain access to SAP system, and then from there, they elevated the privileges, right? Computer account abuse. InfosecTrain Trainer: Computer or network trespass. If someone bypassed your firewall, someone bypassed your IDS and IPS, someone bypassed your critical networking infrastructure and get into your environment, is the next. InfosecTrain Trainer: Type of incident, right? InfosecTrain Trainer: If there is an information exposure or theft InfosecTrain Trainer: If, people... if person is able to reach to your shared drive and able to... able to get the PII information of the people, if person is able to get into the database and record of one of your application is able to fetch the details. InfosecTrain Trainer: Isa? InfosecTrain Trainer: Information exposure of that. InfosecTrain Trainer: Malware. InfosecTrain Trainer: If they deploy any Malware or any software... any kind of the, the program which InfosecTrain Trainer: is having a malified intent. It's called the malware. If they are able to do that, that is malware. Ransomware.

It's very popular these days, right? You deploy a ransomware in the system, which was... which happened in the JLR, it encrypts InfosecTrain Trainer: All your critical databases, your infrastructure, and everything, and then the gang will ask you InfosecTrain Trainer: For a money or ransom. InfosecTrain Trainer: To share that encryption key. InfosecTrain Trainer: They'll say, please share us the encryption key, then only we'll be able to decrypt it. InfosecTrain Trainer: Then, denial of service, which is very popular, and there is one more, which is very popular these days, it's called the InfosecTrain Trainer: War... volume... metric... DOS. Anyone heard of this? Volumetric DOS? InfosecTrain Trainer: So here, in the normal DOS attack, the kind of traffic and the flooding which the organization will achieve, they will be able to manage also. There are DOS protection, and the things are available, right? InfosecTrain Trainer: So there is something called the CDN, Content Delivery Network. InfosecTrain Trainer: through which they'll be able to manage. But volumetric DDoS attack, the volume of that traffic would be so high, even your existing DOS protection won't also be able to handle. So you saw, there was a volumetric DOS attack against the Cloudflare. InfosecTrain Trainer: Part of this company? InfosecTrain Trainer: Content hosting. InfosecTrain Trainer: platform. InfosecTrain Trainer: A lot of applications, you use, this, even, even your chat GPT was down. InfosecTrain Trainer: Right? They are also using the Cloudflare for hosting. Even a lot of these social media platforms and all also use Cloudflare. So they were down last year because of the volumetric DOS attack. You can read about it. InfosecTrain Trainer: Then, information system damage.

If there is a damage caused to any information system, they deleted any important database, they deleted your AD forest. InfosecTrain Trainer: If there is a misconfiguration, this is also a most common InfosecTrain Trainer: issue which is causing incidents. Like, there is a S3 bucket of AWS, InfosecTrain Trainer: Which is open to public, people will be able to see all the data information here, right? InfosecTrain Trainer: And someone stole the information. InfosecTrain Trainer: So, what is the goal of overall program? You will get answer. You will get a question in the exam. InfosecTrain Trainer: What are the two major goals? InfosecTrain Trainer: Reduce the enterprise impact, First, and resume and recover operation, second goal. InfosecTrain Trainer: These are the two only major

goal of overall institute management program. So, if the JLR would have met these goals, they would... they would have been able to probably reduce that 800 million euro InfosecTrain Trainer: impact. InfosecTrain Trainer: probably they would have been able to manage this in the \$100 million, or less than that. Would not have cost much, right? InfosecTrain Trainer: And would also be able to recover, so they took 1 month to 45 days to recover. If they would have had a better incident management plan, probably they would be able to manage it within a week. InfosecTrain Trainer: Or less than that. InfosecTrain Trainer: So, these are the two goals which you should meet, right? So, what are the objectives of the program? First thing is the minimal or no interruption to InfosecTrain Trainer: Well, Sunday. InfosecTrain Trainer: So, minimal or no interruption to customer-facing or revenue-producing business operations. So, what is the revenue-producing operations for JLR? They are factories.

InfosecTrain Trainer: Which produce the vehicles. If they are not able to produce those number of vehicles, it means InfosecTrain Trainer: It's a loss of revenue for them. InfosecTrain Trainer: what is in revenue production for the Amazon e-commerce is their platform. If their platform is not accessible to the people, then people will go and buy the product from some other alternate source, right? So their revenue is lost. InfosecTrain Trainer: So that's... is the major goal, that you should make sure that those revenue-producing or the critical systems are available, right? There is no loss of information. InfosecTrain Trainer: If attacker is able to get into your organization, it should not be able to steal any critical information, critical data, right? Your PII, PHI, because that will have a more impact, right? Next thing. InfosecTrain Trainer: Recovery. InfosecTrain Trainer: So, if there is a loss also, you should have a measure, methods, and the controls in place to recover those losses, right? It should not happen that InfosecTrain Trainer: they... the attacker came into your environment, deleted the critical production information of production server, you don't have an image also for the same server. InfosecTrain Trainer: So how much time you will take to then rebuild it, right? So if you have a proper image, or the gold image which you have preserved, probably your recovery would be fast. InfosecTrain Trainer: Right? InfosecTrain Trainer: then there should be a least possible disclosure to the affected parties. So you have to make sure that the controls are effective, so that the overall impact and overall issue is as less as possible, right? InfosecTrain Trainer: least possible disclosure to regulators.

You have regulatory information, as per those regulations, you are supposed to meet InfosecTrain Trainer: some objectives, that particular regulatory information should be as less as possible, should get disclosed. And... InfosecTrain Trainer: it's better the organization should have an insurance, so that whatever are the losses you have incurred as part of it, that insurance should cover. So if GLR would have had a good insurance, probably they would be able to InfosecTrain Trainer: recover this cost. Not sure, probably, entire \$800 million, even if it's able to meet your 50% or 60% expenses, or the loss which you incurred as part of it, that InfosecTrain Trainer: insurance will meet, right? And... Must have an internal and external communication protocol so that people are notified quickly. InfosecTrain Trainer: as possible. InfosecTrain Trainer: So, there are two... InfosecTrain Trainer: things which you need to be very clear about. One thing is the incident management, another thing is the incident response. InfosecTrain Trainer: What do you mean by management and response? Someone tell me the clear distinction between the incident management and the incident response. InfosecTrain Trainer: So, the incident management is overall managing that incident workflow. So, JLR incident. InfosecTrain Trainer: had multiple steps, right? First, attacker came into environment, then there are multiple disruptions, then you have to recover, you have to contain the incident, you have to do all the steps, right? InfosecTrain Trainer: Also, you will be doing forensic investigation, you have to do the lesson learned, you have to do so. Complete that incident which is happening in your environment, managing that overall thing.

So, also, incident management involves the steps which you will take InfosecTrain Trainer: Before an incident has occurred, right? InfosecTrain Trainer: So you will... create the SOPs, you will create the playbooks. InfosecTrain Trainer: You will also have a... have a... InfosecTrain Trainer: exercises, right? Red team, blue team, purple team exercises. So, all these things which you do before, after, and during incident is incident management, but the incident response is something which will come into effect if actually there is an incident. InfosecTrain Trainer: So, activity which you take to manage one particular incident, that is called the incident response, right? So, all actions taken before, during, and after an incident occurs is called the incident management, right? You need to identify the relationship of the task and the processes. InfosecTrain Trainer: Internal and external information exchanges and actions that need to coordinate to successfully manage an incident. InfosecTrain Trainer: Incident response is a process, procedures, and activities which you perform with the goal of resuming normal operations as soon as possible. We will discuss at multiple InfosecTrain Trainer: Time, what is the incident response InfosecTrain Trainer: workflow. And it's very important for all of you to understand and keep it in mind, because you will see multiple questions based on this only. InfosecTrain Trainer: If you don't understand that what is the process, what is going to be the next step, what is the first step, what we will do next, you'll not be able to answer multiple questions, right? So, incident response begins with identification. InfosecTrain Trainer: there is going to be some point where you will identify. So, what was the identification in JLR?

IT team identified something, right? InfosecTrain Trainer: They saw some... Activity in the network, and then they identified it, right? InfosecTrain Trainer: Once identification is done, it's not necessary that all incident would have the same severity level, right? InfosecTrain Trainer: Or what kind of containment steps we need to take, how you will decide it. Until unless you discuss it, you collaborate on it, that is the triaging, like your... InfosecTrain Trainer: security team, your subject matter expert, they all sit together, then they decide. So JLR then decided that the malware is moving too fast in our network, there is no other option to contain it to just InfosecTrain Trainer: Shut down our... network. Just... just isolate it. InfosecTrain Trainer: They knew that it will have a bigger impact, but there was no other option. InfosecTrain Trainer: So, that's what the triaging does. And then they contain it through that process, right? Once containment is done, then next step comes the eradication. Now. InfosecTrain Trainer: That malware will not be able to further spread to other systems in your network, but now you have to purge it, you have to remove that particular malware out of system, right? InfosecTrain Trainer: You'll make sure that you detect where all the person... that malware have gone, into which all systems. We should remove it, delete it, or whatever you do. That is an eradication. And once the eradication is done, then comes a complete recovery. You want to InfosecTrain Trainer: restore back to normal operations, everything, all the production images and all you will put across, and then you will hand it over to the normal operations. So this is a complete incident response process, right?

InfosecTrain Trainer: And what are the major goals of the incident management? First thing, you should achieve the speed. InfosecTrain Trainer: Probably, if they could have detected that incident initially, it could not have probably traversed to the multiple system. There was an issue with the speed, right? They did not detect the incident very quickly and very rapidly. InfosecTrain Trainer: Then comes the accuracy. InfosecTrain Trainer: So when you do the triaging, whenever you understand what is the impact, what is the causes of the incident, and where the incident is causing an impact, if that is not done accurately, your containment action won't be that accurate. InfosecTrain Trainer: And containment is a first step, which makes sure InfosecTrain Trainer: that the long-term impact of incident is reduced. How? InfosecTrain Trainer: If, in the JLR incident, their IT team could have contained it properly initially only, they could not InfosecTrain Trainer: they would not have to shut down the complete network. They did not do that, they did not detect it quickly, they did not do the containment properly. Now. InfosecTrain Trainer: There was no other option to shut down the complete network, right? InfosecTrain Trainer: So, if you contain the incident properly initially, the long-term impact would be reduced. InfosecTrain Trainer: Because the eradication and recovery is something which will take some time. InfosecTrain Trainer: Then comes the recovery to restore the affected service, and the contain to minimize the damage to the system and the data. InfosecTrain Trainer: So, for the... For this, you need to understand what is the root cause. InfosecTrain Trainer: Does this scheme through... InfosecTrain Trainer: a phishing email? Does this came via our network?

Does this came via social engineering? What was the root cause? How that particular malware or that particular attacker InfosecTrain Trainer: get into our environment, that is the first step to understand, right? Then, the next goal is to improve the process. InfosecTrain Trainer: Right? Now they realize, the JLR team realizes that there are key gaps, right? There is a gap, an issue with their business continuity planning, there are gaps and issues with respect to incident management protocol. Now they have to improve that process, right? Then comes the documentation. InfosecTrain Trainer: You need to maintain a comprehensive record of all incident activities. InfosecTrain Trainer: And also the reporting. InfosecTrain Trainer: So that you report on time with respect to all the incident, you have to report to the regulations, you have to report, send report to your stakeholders, you have to report to your customers, you need to also inform to your senior leadership. InfosecTrain Trainer: So that reporting protocol or the communication protocol also need to be defined properly. InfosecTrain Trainer: And what is the significance of having... having an incident management? InfosecTrain Trainer: So that's what I said. Just by having a proper InfosecTrain Trainer: technical control or sophisticated technology or a good incident management team won't save your organization from incident. If you don't have a proper incident management protocol, you have not tested it, you have not practiced it. InfosecTrain Trainer: you will not be able to manage the incident properly, right? So any organization will heavily rely on the processes and the system. InfosecTrain Trainer: Like, they see... they say that, like, in case of JLR, they say that, okay, we are using the SAP.

InfosecTrain Trainer: Which is a well-known... InfosecTrain Trainer: vendor, right? There is an SAP which we are using, so we are well secured. But what was the issue? InfosecTrain Trainer: there was one unpatched. There is a SAP system called the SAP NetWeaver. InfosecTrain Trainer: That particular system was not patched, and that was the vulnerability which attacker was able to leverage and cause an issue. InfosecTrain Trainer: In their environment, right? InfosecTrain Trainer: So, it was just a small issue of not patching one particular system. It means that their vulnerability management and patch management program was not working effectively, right? InfosecTrain Trainer: So that's why just by having a sophisticated tools technology does not make sure that you are protected from the incident. That's why heavy reliance on information processes and systems is also bad, right? Severe impacts due to significant disruptions. InfosecTrain Trainer: So there are going to be unsevere disruptions or the issues in your environment if you do not manage it properly, right? InfosecTrain Trainer: And... Your security team should be... InfosecTrain Trainer: Well equipped, well-trained, and should be having the proper tech stack to faster identification of those incidents, then do a proper and better analysis to that problem, and then respond as quickly as possible, and then recover to... from that incident. InfosecTrain Trainer: So that the overall impact and the cost is reduced. InfosecTrain Trainer: Right? And what are the indicators of the incident? InfosecTrain Trainer: There are always an integrator, right?

There are always integrations which you get InfosecTrain Trainer: And then you will understand that there is a probability, or there is a possibility, that the incident are happening in your environment, right? First thing, if you see, there is an increase occurrences and escalating losses from incident. InfosecTrain Trainer: If you see there are multiple phishing attempts which are being done against your organization, if you see, due to those phishing attempts, people are clicking on it, and every time the machines are getting compromised, and people are not able to work, it gives an indication that there is a possibility of a bigger attack, right? InfosecTrain Trainer: If you see, there are multiple unpatched vulnerabilities which are sitting in your infrastructure. InfosecTrain Trainer: This is an indication that tomorrow, InfosecTrain Trainer: Attacker may leverage those vulnerabilities and launch a bigger and wider attack against your enterprise. InfosecTrain Trainer: If there is a failure of control, so whatever controls you have, you have an EDR, you have a firewall, you have an access management-related controls, if those controls do not work properly, like in the case of JLR, what was the control which got failed? InfosecTrain Trainer: which control actually failed in case of GGLR? SrinivasanJ: Batching and vulnerability. InfosecTrain Trainer: There was one more. InfosecTrain Trainer: Awareness. InfosecTrain Trainer: The first attack started from the social engineering, right? InfosecTrain Trainer: Credential harvesting. Someone gave call to their admin and then was able to get the credential to that SAP. If he would not have shared those credentials with them, they would not be able to get into the system, right?

InfosecTrain Trainer: So... so then you have to see that all your controls are working effectively, right? InfosecTrain Trainer: Then, non-compliance. InfosecTrain Trainer: of legal and the regulatory wrongs. And then, second, probably, the issue would have been probably segregation of duty. InfosecTrain Trainer: Or probably the over privileges given to a person. That's why just having a credential of one person, how they can compromise the complete infrastructure and system. InfosecTrain Trainer: Right? So, there were multiple issues. Then sophisticated and capable threat actors. So, there are advanced persistent threats and the capable threat actors, which cause much damage, and the zero-day attacks. What are zero-day attacks? InfosecTrain Trainer: What is zero-day attack? SrinivasanJ: It is related to patching. InfosecTrain Trainer: Okay. Johnny Souriar: So, system vulnerability where purchases are not available from date. InfosecTrain Trainer: Yeah, right. So there is a vulnerability, it's called the zero-day vulnerability, for which there is no patch available, and that vulnerability was not yet known to the developer, or not known to the application. InfosecTrain Trainer: That is called a zero-day vulnerability. So that vulnerability, if firstly gets InfosecTrain Trainer: Identified by an attacker, they will be able to leverage it and will be able to launch an attack. InfosecTrain Trainer: Now, resources. So, incident management team does not only include your SOC team. InfosecTrain Trainer: SOC team is one of the major source of managing the incidents, but there would be in coordination efforts, and the... the... InfosecTrain Trainer: The collaboration would be needed from other teams as well, right?

InfosecTrain Trainer: Because the SOC team do not have a capability or the knowledge on everything, right? Probably, you will need the subject matter experts, you will need help from the legal team. InfosecTrain Trainer: You will need help from your corporate communication team, because you have to send the comms. InfosecTrain Trainer: Right? You will need the help from the HR team if additional resources need to be onboarded. InfosecTrain Trainer: Right. InfosecTrain Trainer: So, all these teams will help you, right? So, all these teams collectively known as the incident management teams. InfosecTrain Trainer: So, incident management team is someone which will coordinate with the business and the technical resources, right? So, it includes the internal and the external resources, like HR, your InfosecTrain Trainer: Public relations, your legal team, your finance team, your vendors, your providers, all the organizations, they even keep some retainers. InfosecTrain Trainer: like forensic retainers. So, forensic investigation... I don't see any organization keep an internal person for forensic investigation, right? Because InfosecTrain Trainer: the incident don't happen every day. So what you... you keep a retainer, right? Whenever there is an incident, we would call you. InfosecTrain Trainer: Managing that particular incident, helping us recover. So you pay them. InfosecTrain Trainer: some basic subscription costs, right? So there are, there are a couple of organizations well-known in the world, right? Mandiant. InfosecTrain Trainer: Unit 42. InfosecTrain Trainer: now part of... Palo Alto networks. So all of... there are others also. InfosecTrain Trainer: So they will also... Be forming the part of your incident management team, right?

InfosecTrain Trainer: Then, you need to build the incident management and response capabilities. So, you need to InfosecTrain Trainer: create a balance between the capabilities with the baseline requirements. So you will have some baseline requirement which you want to meet, so you should create the capabilities in such a manner so that those baseline requirements are met. InfosecTrain Trainer: Right? Then you need to also determine the cost effectiveness of high capability level. So there are some capabilities level where there is a high cost which is involved, right? Like, doing a forensic investigation, or probably recovery. InfosecTrain Trainer: If you don't have a proper setup for the recovery, then... InfosecTrain Trainer: Recovery is a high-cost item, right? You have to pay a huge amount and money to recover everything, right? InfosecTrain Trainer: You need to also consider in context of the BCP and DRP. InfosecTrain Trainer: Someone tell me difference between the BCP and DRP. What is the difference between this? InfosecTrain Trainer: We will discuss in this domain in detail, but yeah. InfosecTrain Trainer: What is the difference between BCP and DRP? Johnny Souriar: Business Continuity Planning and Disaster Recovery. Johnny Souriar: Bye. Pudir: they act as a part of the city. SrinivasanJ: BCP is functional, how to keep the business continue when there is a disaster. DRP is technical, how to restore a system from a failure. InfosecTrain Trainer: So, BCP is... actually talks about the overall business. Overall business, process, people. So, it will talk about the PPT, people, process, and technology, but InfosecTrain Trainer: DRP will... Mainly considered only on the data centers.

InfosecTrain Trainer: So your data center, your restoration of your data, and restoration of infrastructure, that is part of the DRP, right? InfosecTrain Trainer: Next resource is the system deployment and the implementation, right? You need to enable... InfosecTrain Trainer: you need to enable the active collaboration between the business technical counterparts and the incident management staff, right? You need to collaborate with the line of business, or probably the application owner, business owners, right? And also provide the insights to them on the approaches, what you are developing. InfosecTrain Trainer: Now, it's very important to tailor the incident management program for all organizations. InfosecTrain Trainer: Right? Suppose you are currently working with one of the FinTech company. InfosecTrain Trainer: Tomorrow, you got a role, you moved from fintech company to a... Mano... InfosecTrain Trainer: factoring organization. Can you apply the same incident management protocol there? Can you? SrinivasanJ: Nope. InfosecTrain Trainer: Right? Because the system, processes, technologies is totally different for them. The landscape is totally different for them, the landscape is different. They are more concerned about the safety, security, recovery of their important key infrastructure and the system, the data. InfosecTrain Trainer: the PII, which they are handling. For manufacturing, it's more around the safety and security of their manufacturing sites, their OT network infrastructure. InfosecTrain Trainer: So that's why all of the organization need to tailor. Now, also. InfosecTrain Trainer: two fintech organizations could be different. Probably this fintech organization only serving in India.

InfosecTrain Trainer: And there is one fintech organization which is serving globally. InfosecTrain Trainer: It's going to be totally different, right? So that's why you need to tailor the incident management program as per your landscape where you operate. So what do you mean by a constituency to be served? What does this term mean? Constituac to be served? Fatha: which domain... Which area, or which, industry? InfosecTrain Trainer: So, constituencies will be served means this. InfosecTrain Trainer: What is your line of business? What is your key area where you works? InfosecTrain Trainer: What is your geographical presence where you sit? You... are you a global organization, or are you a regional organization, right? What kind of the system and the services you use? InfosecTrain Trainer: So all those things together will decide this constituency to myself. And on the basis of that, then your incident management program would differ, right? Then, what is the mission and the goals and objective of organization? InfosecTrain Trainer: what actually organization want to put

emphasis on? Are the confidentiality is their key area which they are focusing on, or is the, is the availability is key focus area for them? InfosecTrain Trainer: So, if you see, like, for... e-commerce, And for a bank. InfosecTrain Trainer: So, for e-commerce, what is more important for them? Confidentiality, integrity, or availability? Johnny Souriar: Okay. InfosecTrain Trainer: Yes. SrinivasanJ: E-commerce availability. InfosecTrain Trainer: And for bank. SrinivasanJ: Confidentiality. Fatha: Thank you. InfosecTrain Trainer: Yes, so that's why it differs, right? So, on the basis of that, the enterprise mission and goals and objective will also differ, what you want to do. So.

InfosecTrain Trainer: So, on the basis of what aspect of CIA triad do you want to protect? What is your main focus area? As per that, you will tailor your incident management program, right? Also, what is the services to be provided? What services you are providing? Are you... InfosecTrain Trainer: Are you a consultancy firm? Are you producing some software product, right? Are you a manufacturing organization? Are you a bank? InfosecTrain Trainer: what kind of services you are providing to your customer, that will also affect the incident management. Also, what is the organization model and the stakeholder relationship, right? So we discussed the organization model in the first domain, right? Like, decentralized model, centralized model, distributed model. So, that will also affect the incident management program. InfosecTrain Trainer: Then the budget, very important. So... InfosecTrain Trainer: So, if I have probably the 50 million InfosecTrain Trainer: dollar budget, I can build a very sophisticated SOC with the top InfosecTrain Trainer: ingenious from the world in my SOC team, but suppose I have only \$1 million as a budget, so I have to stick to this budget and maintain everything within this. InfosecTrain Trainer: Then comes the resource requirement. InfosecTrain Trainer: So, how many resources you have, how many resources your organization has provided, that will also affect the incident management. InfosecTrain Trainer: Now, the life cycle. InfosecTrain Trainer: This is a very important slide. InfosecTrain Trainer: You will get multiple questions on this slide. InfosecTrain Trainer: So, it's... please be clear with this life cycle, how the overall incident management lifecycle works, right? First thing, talk about the functions.

InfosecTrain Trainer: So, every incident management team would have these functions specific to those InfosecTrain Trainer: organization, right? First thing is the detection and the reporting. InfosecTrain Trainer: So, detection and reporting is a team who will detect and report, like you, someone who will be managing SIEM solution. Detection and reporting will also come from the people InfosecTrain Trainer: It may come from some technology. InfosecTrain Trainer: So, detection and reporting function will help you detect those incidents, and then report to the incident management team so that they can review and take actions. InfosecTrain Trainer: Then triaging. InfosecTrain Trainer: So once the detection and reporting is done, then this function helps you prioritize those incidents and understand that, what is the incident manage... what is the priority given to the incident accordingly, the action could be taken. InfosecTrain Trainer: Then, incident response, this team will make sure the proper containment InfosecTrain Trainer: recovery, eradication is being done, and the analysis is something which is the forensic investigation. You're analyzing the complete incident management protocol and understanding what is an impact overall of that, right? So this particular are the functions. Now, coming to the life cycle. InfosecTrain Trainer: So, incident management is a complete life cycle, right? Which you have to build, which you have to prepare for, right? First phase is the planning and preparation. InfosecTrain Trainer: So the planning and preparation phase, which is the first phase, where you will create the SOPs, you will create the policy. InfosecTrain Trainer: You will define the playbooks, You will also work with the team on the training.

InfosecTrain Trainer: You will make sure your controls are running effectively, they are properly optimized. So this is something which is before the incident has occurred. InfosecTrain Trainer: Now... Now there is an incident. InfosecTrain Trainer: in your environment, right? Now the incident has occurred. Now, first thing you have to detect InfosecTrain Trainer: Then you have to do the triaging on that incident, and then you have to do the initial investigation does not mean the forensic investigation, you have to investigate the root cause. InfosecTrain Trainer: without understanding what is the root cause, how you can understand what is the containment action you have to take, right? Once you understood where it is coming, then you will contain it InfosecTrain Trainer: Then you will do the post-incident assessment, and then you will close the incident. Let's take an example to understand this complete process, right? InfosecTrain Trainer: So... InfosecTrain Trainer: So, one fine day, early morning, right, a SOC analyst received a notification from SIEM, right, that someone has reported a phishing email. InfosecTrain Trainer: Now, he need to investigate, right? He need to first validate. Does this a true positive, false positive? And he'll also check with the reporting user, have you clicked on that phishing link or not, right? He said, I clicked on it. InfosecTrain Trainer: And then, after reporting, he probably gave call to them and said, my laptop stopped working. Something got downloaded, and my laptop is not working. InfosecTrain Trainer: Now, he did the... InfosecTrain Trainer: detected the incident, your CIM solution detected the incident also, your person also detected and reported.

Now the SOC team went into a triaging call, where your team lead, SOC manager, everyone is sitting, and they're looking into it, exactly what happened, right? InfosecTrain Trainer: So, in this phase, they will analyze exactly what is the issue, what is the root cause, how the incident came, they will probably scan this particular email for any embedded malware, any issues, what was the domain, from where it got originated, and then InfosecTrain Trainer: They need to contain, right? InfosecTrain Trainer: On the basis of it, they will also see, is this only the person where this email came in, or there are other users also in the organization, those who received similar emails, right? InfosecTrain Trainer: So if other users also receive the email, they have to immediately notify organization-wide that there is a phishing campaign being done against our organization, and there is a hidden embedded malware. Please don't click on them, right? InfosecTrain Trainer: So, contain. Now, they identified that only one user so far clicked it, so they need to isolate their laptop, they need to force reset his credentials, so they contain the incident. InfosecTrain Trainer: But... InfosecTrain Trainer: after containing, now they have to eradicate it, right? They have to remove that malware from that particular system, and then they will remove it with the technology which they have, and then they... even after removing, they're not 100% sure that there is no backdoor or something is left by the attacker, so what they did, they completely InfosecTrain Trainer: replaced the operating system with the golden image, which they have. So they did the record, and then they hand it over for the operation.

Now, post-incident assessment, where they will analyze complete process, how our tech stack works, what was the issue, how that email landed into our environment, why our email gateway filter was not working properly. InfosecTrain Trainer: And then is going to be the incident closer. InfosecTrain Trainer: So, post-incident assessment in the incident management lifecycle is not about the forensic investigation. Keep this in my mind, in your mind. A lot of people get confused. It's not about the forensic investigation, it is about the overall incident management process. InfosecTrain Trainer: overall process, how we could have better detected the incident, how we could have better contained the incident, are there any loophole or gaps in our existing policies and SOPs? That's what it's talking about. InfosecTrain Trainer: Let's discuss some questions, and then we'll take a break. InfosecTrain Trainer: Alright, let's discuss. InfosecTrain Trainer: Second question, I just repeated the statement, and I think you probably did not listen it properly. Still people went with eradication, post-incident review, and all, okay? A security manager is establishing an incident management program. What is the primary goal of this program, as distinct from the tactical incident team, right? So, overall goal, we just discussed couple of goals, right? So, overall goal is what? InfosecTrain Trainer: To reduce the impact and recover, right? But here it says that InfosecTrain Trainer: you create a program, it is in such a manner so that it provides a structured and repeatable framework, so that all the incidents are handled, and all the lesson learned are observed and denoted, right?

This is something which summarizes the overall incident management program, not to deploy the security control InfosecTrain Trainer: To manually analyzing each and every security alert, and immediately InfosecTrain Trainer: containing and eradicating all threats. You will not do all the threats, right? You will prioritize and take action. Now, coming to this question. InfosecTrain Trainer: it's always gets tricky between all these options to understand, right, how it happens. In the incident management lifecycle, which phase is the most critical for ensuring that the incident's long-term impact on the business is minimized? InfosecTrain Trainer: Let's take the same example of the... JLR. InfosecTrain Trainer: attack. InfosecTrain Trainer: If they could have contained it in a better manner initially, they would not have to shut down the InfosecTrain Trainer: and cut off the complete IT systems and 800 million euro InfosecTrain Trainer: Would not have been lost, right? InfosecTrain Trainer: So, which action they could have done better, containment. Eradication is something which you will use at the later part, when the containment is... when the damage is already done, then the eradication is being done. InfosecTrain Trainer: Now the already damage is done, it's already there in multiple systems, everything is affected, now you will... you have to, as such, remove it. InfosecTrain Trainer: But the damage and whatever loss was hap- about to happen would have already occurred. And post-incident review, as I told you, is something which is done to analyze the overall process. InfosecTrain Trainer: Which will improve your incident management capability for the future events. InfosecTrain Trainer: Not this event which has already happened.

InfosecTrain Trainer: It's seeing the incident's long-term impact. One incident is happening, any incident which has happened, its long-term impact can be reduced. Post-incident review, you will do it for other incidents which will happen in the future. But for this current incident which has happened, how you will reduce the impact? Through containment. Got it? Pudir: So that has some grants. InfosecTrain Trainer: Yeah, yeah. Pudir: But today... Containment, I think,

minimizes the current impact. Am I correct? Pudir: But the post-incident, look at future impact of GSU, Pudir: Yeah, since I heard from the incident within, DC, Pudir: And that includes an even answer. Pudir: And because of opportunities successfully, Long-term impact. InfosecTrain Trainer: Yeah, long-term impact of an incident. It seems AN incident. InfosecTrain Trainer: Is it seeing all the incidents? InfosecTrain Trainer: Shen is seeing an incident. There is one incident which has occurred InfosecTrain Trainer: their long-term impact. Is it talking about all the incidents? No. So that's why Reid InfosecTrain Trainer: between the lines. It's saying an incident. InfosecTrain Trainer: Now clear? Pudir: Work, bro. InfosecTrain Trainer: Yeah. InfosecTrain Trainer: Why should an incident management team conduct a post-incident review? So, post-incident review is done to InfosecTrain Trainer: Make note of all the lesson learned, right? InfosecTrain Trainer: what you learned from the overall incident, how to improve overall process, what could have been done better, that's why you do that. An organization's new incident management program is being developed. What is the primary significance of well-defined communication plan within the program?

InfosecTrain Trainer: to guarantee that no sensitive information about the incident is ever leaked. Communication plan, how it will help you with the leaking of sensitive information. To provide the technical details of attack to internal stakeholder immediately, you don't provide any technical details. You only provide what is necessary to them to ensure timely, accurate, and consistent information is provided to internal and the external InfosecTrain Trainer: That's what summarized. InfosecTrain Trainer: Total process, right? InfosecTrain Trainer: So So, anyone has any doubts? InfosecTrain Trainer: So, this is the next topic. Let's take a quick break. InfosecTrain Trainer: And then we'll resume from here. InfosecTrain Trainer: I hope everyone is back. Pudir: Oops. InfosecTrain Trainer: So now, next steps comes... the first step, actually, is, to establish the incident management. What is the first step which you need to do, is the... InfosecTrain Trainer: Develop the plan. InfosecTrain Trainer: That was the first step, right, which we discussed, is the developing the plan, right? InfosecTrain Trainer: So, now come... InfosecTrain Trainer: So you need to think from all the perspective, which we discussed, right? Constitute is to be served, what is the business, how many number of resources you have, how much the budget you have, all those things would be catered when you are developing this particular plan, right? InfosecTrain Trainer: So, any emergency, any event, any disaster, what happens, right? So that's why you need to have a proper plan in place, so that that plan would tell you exactly what to handle, what to do, right? InfosecTrain Trainer: What step need to be done, right? First thing, you need to understand your business processes.

Which all are the critical business processes? What kind of business you have? Where all... which all places you can have an incident. InfosecTrain Trainer: Right? Without deep analysis of all those things, you will not be able to understand how to build an incident management plan, right? Let's take a very simple example of Zepto. InfosecTrain Trainer: So, people, those who don't know Zepto, Zepto is a quick delivery platform in India. They deliver the grocery to your doorstep, to your neighborhood, in 10 to 15 minutes. That's what they promise. InfosecTrain Trainer: So what they do, they have all the warehouses close to all the key prominent area is urban city, right? InfosecTrain Trainer: So that, from that particular warehouse, they would be able to quickly deliver those products, right? So they have calculated a distance on the basis of traffic, mobility, and all those things, and then from that particular warehouse, they ship to you. InfosecTrain Trainer: But... Shipping from this place to your place, there are multiple InfosecTrain Trainer: associated systems, platform, multiple associated processes, which are running in between, if those gets disrupted, their business will also get impacted. So when, as a CISO, I am building an incident response plan for them, I... which all things I have to consider, first, I have to consider the InfosecTrain Trainer: the database which maintains the SKU units. What is the SKU? All the items which they keep in those warehouses, be it detergent powder, or food items, and all those, whatever items they serve, right? Grocery items.

InfosecTrain Trainer: those SKUs, there should be a database, right, which is InfosecTrain Trainer: Taking an exact, accurate record of it, and that record is getting InfosecTrain Trainer: Accurately mapped into their web... their application. InfosecTrain Trainer: So, if this someone is able to tamper with this inventory, they will have an inaccurate record, and the person will place an order, and then there's going to be a disruption, one aspect. Second aspect is that, that platform itself. InfosecTrain Trainer: from where people are placing the order, right? If there is an issue with that platform, there is an issue with the, with the latency, there is an issue with the payment gateway, any issues can happen, attack can happen against that platform, which may cause the disruption. Second thing that delivery boy. InfosecTrain Trainer: who is going and then delivering the product to his doorstep. He would be maintaining some maps or something which helps him to navigate to the nearest point and follow a quick route that InfosecTrain Trainer: can get disruptive. So, you see, for this one business to operate, there are so many things. This is just what I listed. There can be other things also, so you need to understand all the critical business processes which helps your business to InfosecTrain Trainer: deliver and function. Then you need to discover all the dependencies, like this SKU. InfosecTrain Trainer: database. It has... so a lot of systems are dependent on this, right? If this record is not accurate, it will impact your people, those who are sitting there to manage, right? InfosecTrain Trainer: Like, SKU shows that there is a detergent available, but actually it is not there in the shelves, right?

InfosecTrain Trainer: So those dependencies you need to understand, and also... first, you will develop a high-level plan. InfosecTrain Trainer: A strategic plan, high-level plan, to overall tackle it, and then you will InfosecTrain Trainer: deep dive and create the specific playbooks to manage all different, different incidents, right? What is going to be the playbook for phishing? What is going to be the playbook for ransomware? What is going to be the playbook for the endpoint malware infection? Likewise, you will develop the multiple playbooks. InfosecTrain Trainer: So, when you are developing an incident response plan, so, first thing what you will do, you have to first do the current versus future state. InfosecTrain Trainer: You have to undo the gap assessment of your processes, right? Understand which all places we have are gaps, right? What exactly you want to be there in the incident management plan? What are the important things, what you want to handle? You have to understand those gaps. InfosecTrain Trainer: Then you have to also understand the critical processes, because you cannot put emphasis or put budget on all the things. InfosecTrain Trainer: Incident management team has a limited budget, limited resources, they cannot monitor and handle each and every system in the organization. You cannot onboard all the log sources to the SIM. InfosecTrain Trainer: how come team will be able to handle so many log sources, so many false positive information, which is getting generated every day, right? So you have to do a business impact assessment and identify the critical processes which would have a significant impact on the business. InfosecTrain Trainer: You will put emphasis on them and create an incident management plan.

InfosecTrain Trainer: Then, escalation process. If, at what level you will escalate, right? InfosecTrain Trainer: when things go out of hand, how you are going to escalate, right? And then, this is very important to do an integration with the help desk. InfosecTrain Trainer: If tomorrow you are not able to access your bank website, whom you are going to giving the call. InfosecTrain Trainer: If that... probably that bank website is not available because of a DDoS attack. InfosecTrain Trainer: whom you are going to give call as a customer, first thing you will call the help desk. If the help desk people are not aware about what is going on in the incident management side, how they are going to help and support the customers, right? So they need to be... first, need to be aware of, and their integration is very much important InfosecTrain Trainer: An essential element in an incident response plan. InfosecTrain Trainer: Now... InfosecTrain Trainer: Why do you record an incident, right? Which is a very important part, right? Why do you keep record of all the incident? Why do you keep all the important information and data points from an incident, right? InfosecTrain Trainer: So, in an incident management plan, you have to also make sure that you notify, you make provision, that how the information would be collected and how the information would be recorded properly, right? InfosecTrain Trainer: Because that record would help your forensic investigation team, record would help you in the post-incident analysis review, record will also help you with the historical record. Suppose in the future, again, the similar kind of incident occurs, you would be able to take reference and the information from that record and able to understand exactly what was the route.

InfosecTrain Trainer: costs, right? InfosecTrain Trainer: So, you need to track all the incident response activities, right? So, all the response activities, starting from detection to InfosecTrain Trainer: Detection to containment, eradication, recovery. All the phases, you have to track it and continue to record, right? InfosecTrain Trainer: Also, you need to provide the information to aid planning activity. If you're not maintaining proper records. InfosecTrain Trainer: how you are going to be requesting for the aid, because aid would also come from outside your enterprise. I told you about the retainers. InfosecTrain Trainer: Those who will be helping you. Also, sometimes you need to involve the law enforcement. InfosecTrain Trainer: like, local police, forensic investigation from the police, all those things also may get involved, right? If it's a critical thing, and then your... probably infrastructure issue may result into some damage to the nation, and also you need to involve them also, right? InfosecTrain Trainer: So how you are going to plan whom to call, whom to do, without recording? So, that's why record is very important. InfosecTrain Trainer: Helps you review all the aspects of the incident, right? InfosecTrain Trainer: Was the detection done properly? Was the triaging done properly? Was the containment method which was adopted or decided was actually an accurate one, was able to reduce the long-term impact of the incident or not? So, all the aspect of the incident, it will help you understand, and you will then properly document all the information, right? InfosecTrain Trainer: And help you prioritize and route incident to correct resources. InfosecTrain Trainer: Right? Who will handle what, which all teams need to be involved, who need to be called upon?

All those things you will be able to prioritize if you are properly recording the incident. InfosecTrain Trainer: Now, what are the benefits for an enterprise for doing so? First thing, it will help you minimize the damage and the downtime. InfosecTrain Trainer: Right. InfosecTrain Trainer: If you're properly recording the incident, you're properly following all the steps, you will be able to reduce the impact of... overall impact of the security incident on the enterprise. Recovery time will improve and also help you prevent the future incidents. InfosecTrain Trainer: So that you will be able to mitigate those gaps, or reduce those gaps which you have identified as part of the process. InfosecTrain Trainer: Also helps you enhance the compliance and trust. InfosecTrain Trainer: So whenever, if you suppose there was a data breach, and you are a GDPR-compliant organization. InfosecTrain Trainer: So, GDPR will definitely check InfosecTrain Trainer: Do you have provision of all the processes, controls, and everything in place to protect it? InfosecTrain Trainer: If you are not able to showcase that particular provision, probably they would put a fine on top of you, right? So, it will help you meet the compliance, also help you maintain a public trust. InfosecTrain Trainer: Right? You will be able to accurately report the people that exactly what was the root cause, why the incident happened, what was the issues you faced, and help you protect the reputation as well. InfosecTrain Trainer: This also helps you improve the overall security posture, right? InfosecTrain Trainer: able to impart the security awareness to the people. You know what are the gaps, where are the issues, like in the JLR.

InfosecTrain Trainer: you know that now the next time JLR, people will enhance their awareness program, right? So that people don't get fall for those, social engineering attacks, where InfosecTrain Trainer: They gave a call to an employee and did a... did a credential harvesting, right? InfosecTrain Trainer: Help you also reduce the cost and strong overhead. InfosecTrain Trainer: role posture, right? Also, this helps you with the streamlining operation, better collaboration, improved efficiency, and coordination among the teams. InfosecTrain Trainer: Now, these are the phases which organization will go through when they are developing an incident response plan. InfosecTrain Trainer: First step is to understand the environment. InfosecTrain Trainer: you assess the organization's current state, your infrastructure, your assets, your key processes, what is the threat landscape where you operate into, right? What kind of the threats are there in the environment, right? All those things you will analyze. Once that is done, then first thing you will develop a policy. InfosecTrain Trainer: So, policy is a high-level document which will give you a direction where... what all the important things need to be covered. Policy is not in a detail. It's going to be a brief to establish a governance on overall incident management process. We'll set the scope, roles, and responsibilities. InfosecTrain Trainer: Once the incident response policy is developed, then you will create the specific procedures. InfosecTrain Trainer: Procedure for incident... handling an incident, procedure for, managing, InfosecTrain Trainer: Procedure for, communication protocol, right? Procedure for other steps, right? InfosecTrain Trainer: Then you will set the communication protocol.

InfosecTrain Trainer: Whom to escalate, whom to inform. InfosecTrain Trainer: How many regulatory agencies, those who need to be informed? What are the external sources need to be informed? In what instances, the leadership team would be informed and involved, and then the detection mechanism you will... InfosecTrain Trainer: Because without detection mechanism, how you will get to know that the incident is happening, right? And then you will develop the containment protocol that InfosecTrain Trainer: If the detection is done, then how the containment happened? And most of the organization these days, they have playbooks, they have a tech stack in place to contain. InfosecTrain Trainer: If the EDR sitting on the endpoint identifies a malware, automatically it will isolate the system from the network. InfosecTrain Trainer: If the system identifies person has clicked on a phishing email, a phishing link and a malware got downloaded, if tech stack is able to detect, automatically the... his credential would get reset. InfosecTrain Trainer: Right? So those containment methods also you need to develop, and then should plan for a recovery, so that eradication and the recovery process can be enhanced, and then you will train and improve. InfosecTrain Trainer: Now, what is the role of a security manager in overall incident management process? InfosecTrain Trainer: So, the security manager is going to be a first point of contact. He is going to be the first responder. InfosecTrain Trainer: If there is an incident in the organization with the cyber InfosecTrain Trainer: any cyber or the IT-related incident, he is going to be the first responder, taking the responsibility of that, and then, accordingly, taking the next steps.

InfosecTrain Trainer: He would also play a role of coordinator. InfosecTrain Trainer: He needs to become an orchestrator, coordinator, collaborate with multiple stakeholders, right? You need a collaboration with legal, collaboration with the HR, collaboration with the PR team. Also, he will do the collaboration upward and the downward, both. InfosecTrain Trainer: Upward means the senior management, downward means all the team member till the last person who is... who will be helping you with that, right? InfosecTrain Trainer: Then he's also going to be the reporter. InfosecTrain Trainer: He'll document. InfosecTrain Trainer: All the aspects of the incident, and then he'll report InfosecTrain Trainer: those aspects to all the people, right? So the information security manager need to InfosecTrain Trainer: we are the hat, and we are the shoes of multiple roles, right? He needs to be... address the responsibilities of regardless of the environment where you operate, right? Also, we'll need to be involved in the BCP and DRP planning activities as well. InfosecTrain Trainer: Because at what instance the DR plan need to be invoked, at what instance the BCP plan need to be invoked. InfosecTrain Trainer: that he will only determine. That now this is the time we should involve the BCPDRP plane, right? And then he will also assist with other departments in the managing the incident, because the impact of the incident would be InfosecTrain Trainer: With the multiple departments in the organization, so he needs to get involved there and support them with the recovery, coordination, and all the activities. InfosecTrain Trainer: Now, how you do a strategic alignment of the incident management plan? InfosecTrain Trainer: Right?

You need to align your incident management plan with the mission... vision... and objective. InfosecTrain Trainer: of your enterprise. InfosecTrain Trainer: what your organization want to achieve, what they want to have. As per that, your plan will reflect that, right? If your organization promised their InfosecTrain Trainer: customers that we support a 99.99% uptime of our SaaS solution, then the incident management plan should be such a manner so that you are able to manage it. InfosecTrain Trainer: You should have a sufficient amount of control, processes, and the recovery mechanism in place, so that even if there is an incident, quickly you will be able to recover and respond. InfosecTrain Trainer: So the first step is the constituency. So, you have to understand, are you a global organization? You are a local organization? What kind of the business InfosecTrain Trainer: you are into all those aspects will understand, so that you will be able to align your incident management plan. Then you need to understand the mission of your organization, as I told you, right? InfosecTrain Trainer: Your organization mission is to InfosecTrain Trainer: promise the better uptime, better services, better SLA to your customers, then you have to stick to that and create a plan accordingly so that you are able to support your organization mission. InfosecTrain Trainer: Then, what kind of services you are providing, right? InfosecTrain Trainer: So, e-commerce is in different services, the... the... InfosecTrain Trainer: like, like, we took an example of Zepto is in different services, manufacturing is in different services, right? If... even if one manufacturing line goes down, it will have an overall impact on the organization, right? So you have to understand that. Then the structure.

InfosecTrain Trainer: So, what kind of structure the organization follows? Is it a centralized structure? Is it a decentralized structure? What kind of structure you are into? That will also influence and help you do an alignment of the overall incident management plan. InfosecTrain Trainer: Then the kind of resources which are available to you. InfosecTrain Trainer: I gave example of the funding, I gave example of the manpower, right? InfosecTrain Trainer: I also included the technology. So, how many number of people you have, how many number of processes you have, how many number of technology you have to support it. All those resources collectively will help you understand and decide and design the overall InfosecTrain Trainer: incident management plan. And then the most important thing is funding. InfosecTrain Trainer: The more budget you have, the better you will be able to plan, right? So, if you have a less budget, but still you have to... as a CISO, your responsibility is to give organization overall protection against the incidents, right? So. InfosecTrain Trainer: Even if the funding is less, it does not mean that you will not provide protection to the enterprise, right? That you have to make sure, and the support from the management. Without their support, without their funding, without their encouragement, you will not be able to achieve any of these. InfosecTrain Trainer: Now, what are the resources which are available in the organization to handle an incident? InfosecTrain Trainer: So, first, you have to develop a clear scope, objective, and the strategy. InfosecTrain Trainer: What is the scope of that incident management plan? What is the objective you are trying to meet with that, right?

And what is the strategy, overall strategy, which you will follow to mitigate the impact and reduce the impact of the incident? InfosecTrain Trainer: And then you will consider all the elements, what you have currently, and what is your desired state, right? InfosecTrain Trainer: So, in the current state of your overall incident management plan, you are only reflecting the aspect of one particular local unit. Now your organization has gone global. you have to consider the aspect around that. Now, you would need a 24 across 7 SOC, InfosecTrain Trainer: Probably you also need an incident management team, which is distributed globally. InfosecTrain Trainer: Even if there is an issue in this local market, there is no communication, at least that global team would be able to handle the incident. So, all the elements you have to consider, and then you need to understand the resources which are needed, and how you are going to deploy them. InfosecTrain Trainer: Right? So all this... this deep level of understanding and deep level of planning you can imagine is needed when you are developing an incident management for the organization. InfosecTrain Trainer: So, what are the resources which you have? First thing is the senior

management. InfosecTrain Trainer: They are the most important resource, right? They are the one, they will support you during that incident. If there is a requirement for emergency funding, they'll approve it. InfosecTrain Trainer: Right? If you need to quickly onboard any new vendor, any new support to help you with the incident management, they'll help you with that, right? InfosecTrain Trainer: Then your privacy officer.

InfosecTrain Trainer: So, privacy officer, or the DPO, Data Privacy Officer, this is a role mostly you will see being played by illegal people, right, in the organization. So, they are the one, they help and deal with all the PII or the PHI-related issues. InfosecTrain Trainer: So if there is a data breach, there is an information which got involved, they will help and determine that should we report it or not, what is the kind of impact we have, so they play a major role. InfosecTrain Trainer: Then the internal departments. All your internal departments, right, your subject matter experts, your service owner, your business owners, you have a different infrastructure team. InfosecTrain Trainer: You have a HR department, you have a legal department, all those departments collectively also support and help you with the incident management. Then, external provider. InfosecTrain Trainer: So you have a SaaS provider, you have a... InfosecTrain Trainer: or other different kind of providers, right? They help you manage and maintain the incidents, right? So those external providers will also help you manage and mitigate, right? I talked about the retainers. InfosecTrain Trainer: Your law enforcement agencies, all those people will help you. InfosecTrain Trainer: Then law enforcement, right? So you would need to probably involve in India CBI, in US, you need to involve FBI. InfosecTrain Trainer: So, you have to take the decision, and they will also support you in that, or local government, if they need to be informed. If you are probably working in the health InfosecTrain Trainer: Industry, you are working in, the energy infrastructure. InfosecTrain Trainer: So, a slightest impact of a security incident would actually disrupt the overall InfosecTrain Trainer: functioning, right?

So you need to... InfosecTrain Trainer: You need to factor in all those aspects. InfosecTrain Trainer: Now, what are the challenges which you face when you are developing a plan? InfosecTrain Trainer: First challenge is leadership. InfosecTrain Trainer: If your leadership is not supportive, they probably don't give much emphasis on the incident management, and then it happens. If they see that there has been a very... there has been probably no incident in a couple of years. InfosecTrain Trainer: So they'll say why to probably invest and give so much funding for this? InfosecTrain Trainer: they'll say why we should invest this. So they... their support and their... InfosecTrain Trainer: Commitment is very much important to manage an incident. InfosecTrain Trainer: Then the constraint on the resources. So, as I told you, if you have a huge amount of budget, probably it will become easy for you to manage, and then InfosecTrain Trainer: build a better incident management plan, but if you have a limited number of resources available, then it becomes so difficult for you to probably create a better plan, right? So, that will... is another issue. Then, technical challenges. InfosecTrain Trainer: If your asset inventory is outdated, your tech stack is outdated, your CIMS rules are outdated, your tech do not support the current way of handling, like, AI. InfosecTrain Trainer: Now, if you've not created the AI-assisted playbooks to improve the detection, you don't have the AI-related telemetry data and information to help you manage it, then you will not be able to probably build a better incident management plan. And any InfosecTrain Trainer: Issues with respect to organization, if the roles, responsibilities, communication gaps, and everything you have in the organization.

So all of these are collectively some of the challenges which a security manager would face when he's designing an incident management plan. InfosecTrain Trainer: Now, there are two aspects. One thing is the incident response plan, another one is the recovery plan. InfosecTrain Trainer: Let's discuss some questions. InfosecTrain Trainer: Yeah, try these four questions. InfosecTrain Trainer: Alright, let's discuss. InfosecTrain Trainer: Why should an incident management team conduct a post-incident review? InfosecTrain Trainer: To identify the relevant electronic evidence, to identify lesson learned, to identify the hacker, to identify affected areas. InfosecTrain Trainer: So, post-incident review, as I told all of you, right, is something which you do to identify what are the lessons which you have learned, how to improve the overall incident management process, right? InfosecTrain Trainer: So here, it's not there for the electronic evidence. For that, you will do the forensic investigation. Identification of the hacker would also be done as a forensic investigation, or identification of affected areas that you will do as part of the triaging and other aspects, right? InfosecTrain Trainer: So it's there, the B is the correct answer here. InfosecTrain Trainer: Which of the following should be performed first? InfosecTrain Trainer: in the aftermath of DOS attack. InfosecTrain Trainer: It's saying the first. What is going to be the first step? Restore the server from backup media, store offside, okay? Conduct an assessment to determine the system status, perform an impact analysis of the outage, isolate the screened subnet. InfosecTrain Trainer: So, first step is, restoration would happen after the beep.

InfosecTrain Trainer: First, you need to understand that, what is the system, how much the system is affected, what are the systems which are in problem, right? That is the first step. InfosecTrain Trainer: A will come after that, so A is eliminated. Perform an impact analysis of the outage. So, impact analysis of an outage is covered as part of B. InfosecTrain Trainer: So, assessment, when you are doing as part of the assessment, you will do the impact analysis also, right? Isolation of screen submit, that decision you will take on the basis of the assessment result. InfosecTrain Trainer: Right? So B is the correct answer. InfosecTrain Trainer: Which of the following choices is the most useful to an incident response team, determining the severity level of reported security incident? Reviewing past incident to determine the impact? InfosecTrain Trainer: Integrating incident management with business continuity, maintaining an inventory of asset and the resources, involving managers from affected operational areas. InfosecTrain Trainer: If you want to determine the severity level of InfosecTrain Trainer: a reported incident. I don't know why a couple of people went with the business continuity. Okay, okay, all of you, tell me, which two options you want to eliminate here? InfosecTrain Trainer: Which two options you want to eliminate? SrinivasanJ: EMT. InfosecTrain Trainer: You want to eliminate B and? SrinivasanJ: T. InfosecTrain Trainer: B and C. InfosecTrain Trainer: Okay, looks good. Why you want to eliminate B and C? Any reasoning to this? SrinivasanJ: Business can... see, this is about, severity of the reported incident. So, we have to... SrinivasanJ: understand the incident or the impact. It is not about continuity. Continuity comes after, restoration.

InfosecTrain Trainer: Correct, so... B is eliminated, how about the C? InfosecTrain Trainer: Even the inventory of the asset and resources would somehow help you with the severity level, but do not help you directly determine that, right? InfosecTrain Trainer: Now, reviewing past incident to determine the impact, how come that will help you? InfosecTrain Trainer: Because past incident, what was exactly the area? Are you sure that all the past incident would be same what currently we are facing? Probably if you don't have any historical record, how it will help. The best thing is to involve the affected department. InfosecTrain Trainer: Only the business owner of that particular area would be able to tell you that what is the severity level, what is the impact. If your factory... one of... one line in the factory is not working, that person will be able to tell you what is the impact of here. InfosecTrain Trainer: Right? So that's why involving the manager of. SrinivasanJ: Nope. SrinivasanJ: I'm sorry. InfosecTrain Trainer: Yeah, yeah, please, go ahead. SrinivasanJ: So this is a security incident, right? It is not about a normal incident. If it is a normal incident, like, we can review, with, SrinivasanJ: The business owners to understand what is, the business impact, and we can... SrinivasanJ: determine a security level accordingly. Like, how many users are affected, how many functions or features are not available. But this is related to security, and we are talking about data compromise, exploitation. InfosecTrain Trainer: There's a moving datamine. SrinivasanJ: Fuck. SrinivasanJ: But do... InfosecTrain Trainer: determine the. SrinivasanJ: inside the business. InfosecTrain Trainer: Why it will not impact the business?

If there is a data compromise from one particular line of business, how come I, as a security manager, can determine the severity? That particular line of business will only tell me that. What is the severity level? How much is the impact level? InfosecTrain Trainer: If one particular database got InfosecTrain Trainer: an issue? Who will tell you that, what is the significance of that particular database? InfosecTrain Trainer: It was a good... SrinivasanJ: Yeah, somewhere I understand. InfosecTrain Trainer: All the kind of, any kind of incident, any kind of incident, be it the ransomware, be it the malware, anything. InfosecTrain Trainer: I'm not talking about the small, small incident that one particular machine got infected with a malware. I'm talking about the overall incident. InfosecTrain Trainer: Any incident which is causing disruption to a business, that business is the first one they will tell you to determine the severity. As per you, what is the best answer, then? If you are not going with D, what do you say the best answer? SrinivasanJ: No, I was thinking, a, like, reviewing the past. InfosecTrain Trainer: Suppose the past incident has not occurred in that particular area, how it will help you determine the severity, then what will you use? InfosecTrain Trainer: You never had a... you never had a ransomware incident in the company. First time you... the incident is happening. InfosecTrain Trainer: Who will tell you that... SrinivasanJ: incident, I... not only the hysteric incident that happened within an organization, right? It is... it can be... SrinivasanJ: like... InfosecTrain Trainer: So, there was a ransomware attack which happened in another bank.

So, how you will determine the severity level in your organization with the ransomware which happened in that bank, for your bank? How you will determine? SrinivasanJ: lessons learned, they will also share, like, for the same incident that we have, discussed, right? Jay, SrinivasanJ: Jack 1. InfosecTrain Trainer: Why I'm asking these questions, so that you people develop that reasoning in the mind, right? InfosecTrain Trainer: Now you think... now you think the practically. Now you think the practical. In the JLR incident, what we discussed. InfosecTrain Trainer: Who will tell you the CBRT level? Those three factory directors. They know exactly what is the line of business is impacted, what is currently the production which is getting impacted, how much cars we are not

able to produce. They will tell you exact data. InfosecTrain Trainer: You need to also talk to the finance team. They'll tell you what is the revenue loss which we are getting. InfosecTrain Trainer: Right? It's only business they can tell you what is the impact. You, as a security, can only work on the technology side of it, you can handle, you can mitigate, you can contain, right? But the severity level, what is the impact that business can only determine. Got Srinivasan? SrinivasanJ: Yep, yep, fun. InfosecTrain Trainer: which. Sandeep Saxena: Incident activity, or... or why incident is happening, or what, involving managers? InfosecTrain Trainer: No, no, this is not pre-incident activity. So, during creation of plan, also, you have to create some mattresses, right? What do you mean, the P1, P2, P3, P4? For that, also, you need their input, right? If tomorrow there is an incident within... InfosecTrain Trainer: of the factory, if you're a manufacturing organization, what will constitute to be one incident?

InfosecTrain Trainer: If tomorrow there is a data breach, that you will determine with your TPO of the organization. Okay, if 100 records are there, then we call it at a P2. If there are more than 1,000 records are there, then we call it a P1, right? So those severity criteria also you will determine with the help of business only, right? Sandeep Saxena: Yes, I mean, this is... this is predefined. For example, if hundreds of machines are impacted, we can call it a P1, okay? If then, we can call it a P2. This is predefined, because. InfosecTrain Trainer: So, there is something which is predefined, but there can be some kind of incident which are not predefined. InfosecTrain Trainer: Which is a surprise to you, which you need to then decide at that point of time, like ransomware. InfosecTrain Trainer: Where all that ransomware will go and impact, what is the severity level you have. High-level understanding, you will say that any ransomware is a P1 for organization, right? Because it will have a wider impact. Likewise, you have to... so something which is a predefined, some of the incident, which you have to also InfosecTrain Trainer: probably elevate the level. Earlier, you thought it was a P2, but over a period of time, you realize that, no, the impact is much more than you elevate it to the P1. Got it, Sandeep? Because you have worked in the SOC, you would have seen the same instances, right? Earlier, you determined something as P3, and while investigation, you understood that, no, this was not P3, this is a P1. Sandeep Saxena: Justin, you know, trying to understand, I'm not trying to be over-technical here, but... The thing is... Sandeep Saxena: Incident Response Teamwork. Sandeep Saxena: 24 by 7, okay? A system is affected with, ransomware.

At that point of time, you cannot talk to managers, right? Sandeep Saxena: It's midnight, they are not available to you. And determining the severity of an incident is the very first step that we take, so that we can deploy our resources, we can create the war rooms and everything, right? But managers are not available at midnight. Sandeep Saxena: Right? So that's why I'm thinking why, in CISM perspective, this is the right answer, so that I can, you know, think in that way. InfosecTrain Trainer: So, from a CISM perspective, it is not talking about how you create a severity criteria for stock. InfosecTrain Trainer: From CISM perspective, it is talking about any incident which has occurred. Now, you don't know that what is the severity level of that particular incident, what is the impact it has. Suppose you are confused at that point of time. Should we give it the P1 or P2? Whom you will give and call? You will give call to... suppose you are a manufacturing, or you will call to factory director and ask, right? InfosecTrain Trainer: that which manufacturing line is affected? Is... does this have a severe impact on the business? You will say, no, this manufacturing line does not contribute much. Even if this remains down, I have a separate line which will continue to give me the production. You will say, okay, then it's not a priority 1 incident, we'll mark it as priority 3 and continue to mitigate, right? That's what it's talking about. Got the context on the. Sandeep Saxena: I don't agree practically, but it's okay. Sandeep Saxena: Because managers, nobody will be available at midnight, you keep calling, they'll not pick up your phone.

InfosecTrain Trainer: No, you don't think from one particular incident... instance, that in the night, what will happen, in the morning, what will happen. It's talking from the overall perspective. How your SOC team works, that is not the case. Probably in the bigger organization, the scenario would be different. Sandeep Saxena: it's funny. InfosecTrain Trainer: So every... Sandeep Saxena: It's about my experience with the Fortune 50 company, and, you know... well, it's okay. It's okay, I mean... Sandeep Saxena: Manoj. InfosecTrain Trainer: So, from a CISM perspective, it's basically not only CISM. If you think practically also, who will tell you what is the effect of that particular incident? If, suppose, you don't, determine or understand a hundred InfosecTrain Trainer: records is a high severity incident, or 1,000 records is a high severity incident, that only the business people will be able to tell you, right? InfosecTrain Trainer: Was there a public information included as part of the breach? Was there a PII information? Then you will determine. InfosecTrain Trainer: That's why you need to involve the managers of the affected operational area to determine that. InfosecTrain Trainer: Which of the following is the most important element to ensure the success? Pudir: Salah, handsome girl. InfosecTrain Trainer: Yeah, yeah. Pudir: initial engineering, as the security teams do. Pudir: How an operational manager or department can be in the position to answer the leader? Pudir: And so, instead of that, can we consider maintaining inventory of assets and resources, so that what is the asset value?

How it is given value to the Pudir: like, department, so that the depth and ZV can be associable as a marathon... InfosecTrain Trainer: I completely could not hear you, because I think there was some disruption, and the voice was not clear, but what I understood, you are talking about, how... like, like, inventory would help you? You are going with option C? That's what you want to understand? Pudir: Yes, yes, because it is a security incident, really not an operational manager can not be in a position to identify the impact correctly. Pudir: You... the... Bye-bye. Pudir: said, I, listen. InfosecTrain Trainer: But does every time incident is related to one asset or the resource, right? Sometimes it's a non-tangible thing which are getting impacted. How you will determine those things? InfosecTrain Trainer: reputation of the organization is getting impacted. There is a lot of chatter in the social media around the incident. How you will determine that? InfosecTrain Trainer: Alright. Sandeep Saxena: The takeaway for me is that Sandeep Saxena: being into technical side of things, I go into the very, you know, worst cases, negative cases. Sandeep Saxena: And then the question that incident is happening in midnight, nobody is picking up the phone. So, which is good when you talk about, you know, technical terms, but in CISM perspective, think about the... Sandeep Saxena: general scenarios, right? InfosecTrain Trainer: Yes, yes. Don't relate any question from one particular specific scenario. Think from a general perspective. It can happen in the morning, also night.

Yeah, night, whatever InfosecTrain Trainer: the resources and whatever understanding you have, you will give a category at that amount of time, but probably when the morning everyone locks in, leadership comes in, the affected business comes in, then definitely you will engage with them to understand, right? As a SOC team, you might be also talking to the business, right? InfosecTrain Trainer: To understand what is the impact, what is the value, right? InfosecTrain Trainer: So, that's the case, yeah. Sandeep Saxena: Thanks. InfosecTrain Trainer: Now, which of the following is the most important element to ensure the success of a disaster recovery test at a vendor-provided hot site? We have not discussed the hot side, cold side, warm side. We will discuss InfosecTrain Trainer: So... so this is basically a type of site, so there are type of recovery site, hot, cold, warm. Hot means something which is almost exact replica of your main site, and InfosecTrain Trainer: In real time, there is a data synchronization happening, so if main site goes down, immediately the backup site will take over. There is no kind of a layover, or there is no kind of a disruption in between, right? InfosecTrain Trainer: Tests are scheduled on weekend. Network, internet protocol, address are predefined. Equipment at the hot site is identical. Business InfosecTrain Trainer: Management actively participates. InfosecTrain Trainer: If your business do not participate in that particular InfosecTrain Trainer: Disaster recovery test, how you are going to determine the success of that. InfosecTrain Trainer: Even if it's a hot side, business is the someone who is going to tell you that, was the test successful, was the test failed?

You have not involved business, as me being a VCP DRP coordinator, I just conducted, and I said, the test is successful, everything went well. InfosecTrain Trainer: So that's why you have to involve the business, so D is the correct answer. InfosecTrain Trainer: But yeah, overall, good discussion, so that's how we, build a reasoning. InfosecTrain Trainer: around all these questions, right? And this will help you to navigate when you are attempting the question in the exam. Next comes the incident response plan versus recovery plan. So, response plan is the main focus, is to InfosecTrain Trainer: Reduce the impact, detect, assess, and eradicate. InfosecTrain Trainer: and the containment. Till then, the response plan will work. But beyond that, the recovery plan will come into the picture, and it's not necessary that every incident you have to initiate the recovery. Sorry. InfosecTrain Trainer: Only the major incident where there is a requirement for the restoration, backup. InfosecTrain Trainer: restoration, engaging the... your data center team, disaster recovery team. There, the recovery plan will come into the picture. So, goal here is to minimize the damage and limit the scope of an ongoing security breach. Here, the goal is to resume normal or the critical business function as quickly as possible. Timeline is InfosecTrain Trainer: You have to address the active phase of an attack from initial alert to throttle removal. InfosecTrain Trainer: Here, the timeline would be to follow the threat eradication and focus on the rebuilding and normalizing. Here, the activities you already... identification, containment, and eradication, and the communication. Here, the activities is data restoration, system rebuilding, verification, post-recovery.

InfosecTrain Trainer: Now, what are the phases in the incident response, right? So, the first phase is the preparation. InfosecTrain Trainer: you develop the SOP, you develop the policy, You create the playbook. InfosecTrain Trainer: you do all the awareness, training, exercises, and all, that is the preparation phase. Now... now there is an incident. InfosecTrain Trainer: This is something which you do before the incident. Now, there is an incident which has

happened. First step is identification. You identified the incident, be it through tech stack, some person reported it, any means could be there. Once the identification is done, now next step is the... InfosecTrain Trainer: In the identification only, you do the triage. InfosecTrain Trainer: This is a part of the identification phase. You first validate, then you do the triaging, then you contain the incident, so that overall impact could be reduced. First, your... InfosecTrain Trainer: main step is to contain it, right? You identified that there was a phishing email sent to one particular machine, user opened the phishing email, clicked it, entered his credential. InfosecTrain Trainer: Now, your immediate step is to InfosecTrain Trainer: probably immediately force reset his password, so that the impact is reduced. Maybe he could be an admin, or whatever role he's taking, right? InfosecTrain Trainer: Then you will check that, are there any login attempts done by his login to those platforms, right? InfosecTrain Trainer: then you will eradicate, you will see where all the footprints of his login you can see.

You will remove all those logins, you will reset his identities and everything, you will eradicate the thing from the environment so that the completely InfosecTrain Trainer: the threat is removed, now there could be a possibility of recovery. If his particular machine got impacted, or the attacker could be able... he was a server admin, he went there, and he did some issue with the server image. Now you have to again restore that image from the backup, so recovery team will come into the picture. Now, you will close the incident, during that, you will learn the lesson. InfosecTrain Trainer: How you went ahead with the process, how was the identification, containment, are there any gaps in the process, how did our playbooks came into picture? All those things you will analyze. InfosecTrain Trainer: Now... Testing the incident is very important, and these... InfosecTrain Trainer: Particular testing... testing techniques are testable in the exam. InfosecTrain Trainer: So it's very important for all of you to understand the key difference between all of these, right? If you want to. InfosecTrain Trainer: get a correct answer, right? So, there are 4 testing techniques. InfosecTrain Trainer: So, if you created a plan, there is an incident management plan, you want to test also, right, is your plan effective or not? InfosecTrain Trainer: Is your plan working the way you want that plan to or not, right? Will that plan work when actually there is an incident, right? So there are four phases. First phase is document review. InfosecTrain Trainer: You will call all the individual subject matter expert, your incident response team, all the people, those who are involved as part of the incident response, and then you will go over your overall plan which you have in place.

InfosecTrain Trainer: You will... you will understand that everything is working well, it's just reviewing that document, that's it. InfosecTrain Trainer: As part of that review, you will find some gaps, and then you'll fix it. Next step to document reviews walkthrough. You arranged a roundtable conference. In the roundtable conference, all the people, those who need to work in that incident management InfosecTrain Trainer: incident, with the incident... managing the incident, they all will sit together. They all will go over their duties, responsibilities, they will discuss everything step by step, and then it's going to be a kind of a simulation in a tabletop exercise environment. InfosecTrain Trainer: Next step to walk through is the simulation. Now, you want to simulate an incident. Rather than doing a live incident, what you do, you simulate it, like, fire drill. InfosecTrain Trainer: You are not actually lighting up fire somewhere, right? You are just simulating you. In your offices also, you will see, right? There is going to be the buzzer, fire alarm would be played, then they... they will tell all the employees to go and assemble in one particular area, they will see that are the people able to understand where are the fire exits? InfosecTrain Trainer: Were all the people able to understand what are their roles in that particular, situation? So, simulation. Now comes the live fire. Live fire is EQL... is actually your red team exercise. InfosecTrain Trainer: So you can do it internally, or you hire some external third party who is going to be scanning your entire infrastructure and launching an attack.

InfosecTrain Trainer: Once they're launching an attack, you're... InfosecTrain Trainer: your blue team means your SOC team is not aware that there is a red team exercise going on, and then you will check their response, that how they act in that scenario, how they detect that incident, what are the key lesson learned. So, live fire means, actually. InfosecTrain Trainer: conducting an attack, and then testing the plan. So these are the four phases, and what are the objectives, what you want to achieve out of this testing? First thing is that you want to validate the effectiveness of plan. InfosecTrain Trainer: Right? InfosecTrain Trainer: how effective your plan is. If you will not conduct the red team exercise, how you will understand that are all those playbooks are coming into picture. InfosecTrain Trainer: Are your SOC team is doing the proper triaging? InfosecTrain Trainer: Do they understand the severity levels or not, right? InfosecTrain Trainer: They also need to familiarize with the responder, with their roles, all the different types of playbooks which you have created. It will help you determine the gaps, bottlenecks, any key issues in your current tech stack, right? InfosecTrain Trainer: probably in the detection mechanism, some probably new lock sources need to be onboarded in new SIM solution. Probably the current lock sources were not effective. InfosecTrain Trainer: And then comes the... InfosecTrain Trainer: Then comes the... Measuring the detection, response, and containment timelines, and then driving the continuous improvement, right? InfosecTrain Trainer: And the testing cadence that you have to decide as per your organization, right? You need to tailor, but what all the important regulations and the framework says, at least annually, you should do.

InfosecTrain Trainer: Even the penetration testing, what you do, whenever you onboard any tool or service, what you check, you say to them that, have you tested this annually or not? Because InfosecTrain Trainer: That was the credibility, because in a year time, there is going to be a lot of changes in the environment, so at least once in a year, you should test it. InfosecTrain Trainer: Right. InfosecTrain Trainer: And then you have to report the outcomes to the senior leadership, to the CISO, to the steering committee, so that you can work on them. InfosecTrain Trainer: Now, next step is the communication and the escalation. So, you need to have a proper incident communication and the escalation protocol defined. InfosecTrain Trainer: Right. InfosecTrain Trainer: So, you need to have a proper internal communication, right? So that... InfosecTrain Trainer: all the internal teams can be informed, they are aware, right? All the... InfosecTrain Trainer: Actual stakeholders who will be contributing, they are aware that there is an incident going on. InfosecTrain Trainer: And then only they'll be able to contribute. If you do not inform your senior management that there is a P1 incident, which is having an impact on the production, and your revenue is getting affected because of it, tomorrow, if you go to them for the additional resources and funding, how they'll give you. InfosecTrain Trainer: Because they were not aware, you did not make them informed about it. So it's very important to communicate the incident properly to all the stakeholders, right? If you do not inform that there was a data breach and the credentials of your customers was stolen as part of it, you've not told them that please reset your InfosecTrain Trainer: credential, right? Reset your password.

InfosecTrain Trainer: probably they will have a wider impact, right? So that's why communication is important, right? So effective communication keeps all the incident responders and the affected party informed about InfosecTrain Trainer: What was the incident about? What was the exact impact, right? And this will consider the using out-of-band communication as well. So, normal communication is what normal communication, and you send email, you ping someone on the Teams. InfosecTrain Trainer: Suppose incident happened in the night around 2 AM, InfosecTrain Trainer: You have to wake a couple of people up, right? You have to make them aware, so you should have an out-of-band, probably you will use the call, or mobile phone, or cell phone, you will call them and make them understand that there is an incident going on, we need your help. InfosecTrain Trainer: So, you should have an escalation form, you will notify the appropriate level of the upper management when an incident has been detected based on the incident type and impact, right? You need to also notify the appropriate level of management when incident response SLA have not been met. InfosecTrain Trainer: You would have some SLA, you're not able to meet those SLA, something is broken, not able to fix it, now they have to probably... InfosecTrain Trainer: Manage those escalations, engage with the media, and also they need to be involved. InfosecTrain Trainer: So, incident, how you classify the incidents? InfosecTrain Trainer: So, we discussed one question around it, right? So, how to classify the incident as priority 1, priority 2, priority 3, or a benign incident with no impact before?

InfosecTrain Trainer: That classification only helps you Define and decide what level of effort is needed to handle the incident, right? InfosecTrain Trainer: If in a night, there is a P4 incident, why the L1 will engage everyone and disturb them? InfosecTrain Trainer: But if we determine there is a P2 going on, he would definitely initiate a bridge call and tell everyone to join, so that all of them can help support, contribute, and prioritize, right? So that's why incident classification and categorization play a very important role. InfosecTrain Trainer: But that classification and categorization depends on multiple things. So you should create a broad-level guidelines, right, which you're... InfosecTrain Trainer: SOC team should be able to understand, your incident management team should be able to understand, and on the basis of those broad-level guidelines, they are able to categorize the incident accordingly. InfosecTrain Trainer: Right? So this particular classification helps you prioritize Right? InfosecTrain Trainer: So, every incident category will... InfosecTrain Trainer: actually help you to determine what sort of engagement is required. Should we give call to CISO? Should we give call to SOC manager? Should we call... give call to some other departments, right? So that prioritization, it will help, also help with the responding. InfosecTrain Trainer: So, once you do an effective triage. InfosecTrain Trainer: after the detection and the confirming the incident, then the organization need to respond to incident within the limited resources. Those limited resources, how to channel those resources would depend on this categorization. InfosecTrain Trainer: Then you need to define how the enterprise would respond in advance of an incident occurring.

InfosecTrain Trainer: if incident is going on, how you will respond if... because, let me tell you how actually the incident happened. So, Sandeep was in SOC, so he would have seen it, right? So, the attackers, they actually do your... InfosecTrain Trainer: Rekki reconnaissance of your system. They do reconnaissance of your infrastructure for years. InfosecTrain Trainer: It's not like that today they identified vulnerability, and in a hurry, they will just come exploit it, and then launch an attack. They will create a complete footprint of your organization. If they are able to compromise, they will create a simulated environment in their InfosecTrain Trainer: area of your organization. They'll understand your organization in a better manner, so that once they are able to get into it, the quickly they will be able to propagate into other systems, right? InfosecTrain Trainer: So that's why you should have a... InfosecTrain Trainer: a proper protocol, proper management, proper crisis management plan in place, so that in case of such crisis where incident is InfosecTrain Trainer: Quickly disrupting one system InfosecTrain Trainer: to another system, you should be able to manage that, right? And then you need to tailor... you have to tailor the approach as per your environment, as per your... InfosecTrain Trainer: enterprise, enterprise setup, right? Because every organization is different. InfosecTrain Trainer: So now, when you classify the incident, so the classification of incident would define these. First thing is the resource allocation. InfosecTrain Trainer: So, P4 can be managed by a L1 analyst who is sitting in the shift in the night, right?

InfosecTrain Trainer: But if it's a P3, probably he will give call to the P... call to the L2 also, to help him analyze, mitigate, and understand, and then close the incident. But if it's a Priority 2 or priority 1, then he will create a bridge. He'll give call to the SOC lead, he will call... give call to the SOC manager. InfosecTrain Trainer: And then, accordingly, they'll say, but if it's a priority one, they will probably involve CISO also. CISO, they'll give update to CISO that there is a priority one incident with a significant impact in the enterprise. We have to mitigate the InfosecTrain Trainer: impact, right? So that's the... resource allocation. InfosecTrain Trainer: How many resources to pull in for one particular incident, that would be determined on the basis of the classification. InfosecTrain Trainer: Then, communication. InfosecTrain Trainer: So, every incident, you won't be sending communication to the CISO, right? He's already busy. Also, every incident, you won't be communicating to the senior management. InfosecTrain Trainer: So, that communication, you will determine on the basis of classification level. You will say all the priority one incident need to be communicated to the senior management. InfosecTrain Trainer: Because they need to understand the impact. But CISO will only get informed on the Priority 2 and Priority 1. And priority 3, probably monthly report you will share. InfosecTrain Trainer: Right? Then the financial control. If there is a priority 1 incident, there is an incident like JLR, InfosecTrain Trainer: you have to have emergency spending capabilities, right? So that you can invoke InfosecTrain Trainer: those protocols, probably invite some external forensic experts, external agencies to help you mitigate the impact, right?

And also helps you with the workforce management. InfosecTrain Trainer: So... What are the workforce requirements? What are the issues? InfosecTrain Trainer: You have to understand those. InfosecTrain Trainer: So, this is a... this is just a kind of an example matrix, right? So, when you escalate any incident, it would depend on the severity of that particular event. InfosecTrain Trainer: Number of organizations affected because of it, and what is the specific need to notify. I'll give you my personal experience with the Move It. InfosecTrain Trainer: How many of you heard about this movie? InfosecTrain Trainer: It was a typical supply chain attack. InfosecTrain Trainer: Or Log4J, which was very common and impacted a lot of organization. InfosecTrain Trainer: So, the moveit was actually used by the Klop. Now, I think they are not... no more active. I think their infrastructure and everything, they've teared down. Klop Ransomware is a Russia-based ransomware, gang. There was a zero-day InfosecTrain Trainer: SQL injection vulnerability in the platform. MoveIt is a data transfer platform, which is used by... very popular platform, used by multiple organizations in the world, and InfosecTrain Trainer: As this is a data transfer InfosecTrain Trainer: solution, organization use it to move a lot of PII, PHI important data. And this particular affected 2,700 enterprises across the world. InfosecTrain Trainer: Almost around 100 million people got impacted because of it. Imagine. That's what I'm saying, number of organizations affected. If you see you are using MoveIt, however you are not impacted. InfosecTrain Trainer: But your third parties would get impacted, you are sharing your information, your probably healthcare... health insurance provider will get impacted.

InfosecTrain Trainer: So those kind of issues will also help you to understand and give a priority or rating to an incident. InfosecTrain Trainer: Right. InfosecTrain Trainer: And then, when you need to notify the people, right? InfosecTrain Trainer: So... so you have to understand the category, right? What is the description of that incident? What is the resolution which need to be done? What is the expected response time for each, and expected resolution time? And then, as per that, you will give the rating low, normal, high, urgent, like. InfosecTrain Trainer: you can say the same thing. Mostly SOC team uses the same, like, B1... P2... P3, and P4. Sandeep Saxena: Just a cushion. InfosecTrain Trainer: Yeah. Sandeep Saxena: Here, we are talking about only the incidents and not the events, right? InfosecTrain Trainer: Yeah, these are only about incidents, not the events. Sandeep Saxena: Yeah, because in this slide, it's written severity of events, so I got confused. InfosecTrain Trainer: But severity of those events only would get converted into the incident, right? Initially, you don't know that that event is an incident or not. Earlier, you will get an event, then only you will convert it into incident, right? InfosecTrain Trainer: Initially, when something is reported to the SOC team, that is an event only. Now, SOC team will determine the severity of event, and then that event should become an incident or not, that would be determined. That's what it is trying to say. Understood. Sandeep Saxena: It's okay, but in CISM perspective, whenever there's a question, I will consider it incident, not event, right? InfosecTrain Trainer: not true in all the cases. It depends on, in the context of the question, what it is trying to say. Sandeep Saxena: Boom.

Sandeep Saxena: I mean, there's a difference. There's a lot of difference, so... InfosecTrain Trainer: Yeah, if... probably if you can give example, what... what... what exactly is your confusion, then probably I'll be able to clarify on that. Sandeep Saxena: There is an event, there is an alert. Sandeep Saxena: that... a server. Sandeep Saxena: is... talking to an IP, Which belongs to China, okay? This is an alert. Sandeep Saxena: This is an event. Sandeep Saxena: Okay? Now, how I will determine the severity of that, that is purely technical, purely based on the correlation is my area is also saying something, and other security devices are also saying something. Based on that, I will define the Sandeep Saxena: Severity of that. Sandeep Saxena: But in case of incident, as we were discussing earlier. Sandeep Saxena: we talk to managers or whatever, the business unit's getting impacted. So there are a lot of difference in different phases. Sandeep Saxena: So, that's why I initially thought that it's all about incidents. InfosecTrain Trainer: No, no, no, it's about... that's why we discussed about event also. First thing, what would be coming is an event, then that event will become an incident. If, suppose you saw that there is a... there was one machine. InfosecTrain Trainer: Which got infected with the malware. InfosecTrain Trainer: Now, your tech stack came into picture, it probably... so per person, actually, there was a phishing email which he received, we clicked on it, and the person... the malware got affected him. Tech stack did it. One machine. InfosecTrain Trainer: Now... InfosecTrain Trainer: you got the alert, there are the similar kind of email was sent to the 500 people. Out of those 500 people.

InfosecTrain Trainer: Actually, 35 of them clicked on it, or all of their machines are down. InfosecTrain Trainer: So, one particular activity could be an... probably not causing multiple impact, but once the severity of the activity you see affecting multiple places, then it becomes a major incident. Same thing with... Sandeep Saxena: In these two examples. InfosecTrain Trainer: Yeah. Sandeep Saxena: An attack is already... Sandeep Saxena: established that, yes, this is an attack, and a phishing email is sent to 500 people, or malware is installed, we know that. But, actually, events Sandeep Saxena: come to a SOC guy, and even say, like, this is the machine, it started talking to an IP in China, okay? Now it can be a valid business case, it cannot be, it may not be. So, you need to first figure out, and then Sandeep Saxena: It's purely technical based on some of the things we define the severity, and when it reaches to L1, the severity is already decided by some sort of tools and all. So. Sandeep Saxena: solve events. Sandeep Saxena: we handle a bit differently. It's... and incidence is a different thing. It happens once in a year or something. Sandeep Saxena: Late? InfosecTrain Trainer: I think you are relating, because you have the experience with the SOC, right? So that's why you are relating most of the thing with the way you have been working there, right? But in terms of the theory, from the CISM perspective, it mostly talked about the InfosecTrain Trainer: the all kind of incidents. It's not only talking... if you see in the incident, I also talked about the earthquake and tsunami in your data center. InfosecTrain Trainer: It's not only talking about a cyber incident. InfosecTrain Trainer: Anything which is affecting your organization to operate becomes an incident.

Cyber is a part of it. So, incident management is not only talking about those cyber... some hacker is trying to steal information, there is some ransomware attack going on, there is a malware attack, no. Incident InfosecTrain Trainer: And events is basically a broader impact into the organization. Even if there is earthquake in your data center, and the data center is not operating, end of the day, it will disrupt your organization, right? However, it's not done by a cyber attack. InfosecTrain Trainer: So that's why you have to think it from the broad perspective. Sandeep Saxena: This is something I understand, but... Earthquake is an incident, right? Sandeep Saxena: what I'm saying is that, should we think about the events? For example, my table is shaking. Okay, it can be an earthquake, it can... it can be something else. That's an event, right? There's an alert why this table is shaking. Now, I need to first analyze Sandeep Saxena: Whether it's a... Incident, there is an earthquake, or it's just due to something else. InfosecTrain Trainer: Yeah, so that's what it is saying. So you only said it, right? So, what is the severity of that event that will determine you? That should we determine it as a InfosecTrain Trainer: incident or not. That's what it is

saying. InfosecTrain Trainer: Got it? InfosecTrain Trainer: That my table is only shaking, or complete office building is shaking. InfosecTrain Trainer: That is the severity. If, what is the magnitude of that InfosecTrain Trainer: magnitude of that particular earthquake or that particular cyber attack. If it's affected one machine, then InfosecTrain Trainer: probably not an issue, but if it's affected 100 machines, or it's probably caused a power failure in the data center, then it becomes an incident, right? Got it?

Sandeep Saxena: I mean, here I'm clear. In this slide, it is all fine, but if we are considering events also, then you remember we had a discussion some time back. Sandeep Saxena: that we connect with the managers to determine the severity of that. But we are not going to talk to managers for every event. We can only talk to in case of incidents, not Sandeep Saxena: In all events, right? InfosecTrain Trainer: So that's why you should have a protocol in place, that's why you should have a proper process in place, so that you determine the severity of those events, how many of those events are actually true positive ones, which has a possibility of becoming an incident, then this particular protocol will come into the picture. That's what it is saying. Sandeep Saxena: Yeah, I mean, my question is that, in the exam, CISM exam. Sandeep Saxena: Will it happen that they ask a question, and they are saying incident management or incident response, what... Sandeep Saxena: The main events also. InfosecTrain Trainer: No, no, no, that won't happen. InfosecTrain Trainer: Incident response won't occur for events. You only do incident management for incidents. That's the simple thing. InfosecTrain Trainer: Events keep happening in the SOC team also. Every day, you get so many alerts which are being generated. You don't respond to everything, right? You only respond to those which are actually an incident, right? Otherwise, the SOC team will continue to work all day, right? Sandeep Saxena: Yeah. InfosecTrain Trainer: So this domain is about incident management, it will only talk about the incidents, not the events. You will only do action on those InfosecTrain Trainer: Where there are actually incidents, not events. Sandeep Saxena: Thank you, yeah, thanks.

InfosecTrain Trainer: Now, coming to the escalation matrix. What are the benefits, right? We had a long discussion. What is the benefit of having an escalation matrix? InfosecTrain Trainer: Why do you involve the CISO? Why do you involve the team lead? Why do you probably give call to other departments, affected departments? Because that's why the escalation matrix is made for, right? So that even if the issue happens overnight, but if InfosecTrain Trainer: There is a wider impact which is being caused across the organization. You have to have... give call to the multiple people, or inform them, make them aware, right? InfosecTrain Trainer: So that the timely response can be done. InfosecTrain Trainer: It gives you clarity what is the roles and responsibilities of the people in that particular scenario, right? Every person have a different role to play in case of that particular issue, right? Then, it will also help you with the decision making. InfosecTrain Trainer: Right? What is the critical information which need to be... which need to be informed to the leadership? Do we need an emergency funding or not? Do we need to inform the law enforcement agencies or not, right? InfosecTrain Trainer: Should we inform our customers? InfosecTrain Trainer: And help you minimize the impact and downtime. InfosecTrain Trainer: So if you quickly escalate, quickly you will get the support, and immediately you'll be able to close the issues, right? Then comes the compliance, so... InfosecTrain Trainer: You have to report to the GDPR, you have to report to NISTU, DPDPA, that compliance you will be able to ensure, or you have to report to the SART team. InfosecTrain Trainer: local cert. InfosecTrain Trainer: And then help you optimize the resources.

It will help you prevent InfosecTrain Trainer: Over or under escalation, and ensuring the appropriate skill sets is there in the organization. InfosecTrain Trainer: Let's discuss some questions, yeah. InfosecTrain Trainer: Alright, let's discuss... Most of you got it correct. InfosecTrain Trainer: Mukesh, for you... The critical infrastructure is more important than the safety of people. Mukesh Thakur: From my perspective, the critical infrastructure will involve the data, records, and personal safety as well. That's why I selected critical infrastructure as the umbrella answer. InfosecTrain Trainer: No, no, no. Critical infrastructure means infrastructure only. How come infrastructure would include people? Infrastructure means infrastructure, your building, your servers, your data center. Mukesh Thakur: So working force will not be part of the infrastructure? InfosecTrain Trainer: Yes, working for safety of personnel will be always take precedence in any scenario. Even if there is a fire in the building, you will first evacuate the people, then you will see that InfosecTrain Trainer: the records, PCs, and servers, they are being managed, right? InfosecTrain Trainer: Yeah, so let's discuss. The information security manager is tasked with developing an incident response plan. What is the most critical first step to ensure this plan is strategically aligned with the business? Defining the escalation matrix for all potential incidents. InfosecTrain Trainer: Identifying all potential security threats and vulnerabilities, aligning the plan with the organization's business continuity and disaster recovery plan. InfosecTrain Trainer: securing an advanced prem solution. InfosecTrain Trainer: It's saying that you want to develop a response plan.

What is the first step to ensure that it's strategically aligned? InfosecTrain Trainer: how you align it strategically, if your plan is not mapped with the BCP and the DRP plan, even if it's the most successful plan, even if it's a... it's a very good plan, how you will be able to recover on time, right? So this is something which is strategically focused, not A, B, and D. InfosecTrain Trainer: Now comes... InfosecTrain Trainer: highest priority when defining the emergency response plan, always keep it in mind. Any question in the exam where they talk about InfosecTrain Trainer: highest priority, what is the most important thing, and all. Always the safety of personnel will be take precedence with respect to all other aspects. InfosecTrain Trainer: Right? The primary purpose of creating a crisis communication plan related to handling major cybersecurity incidents is to InfosecTrain Trainer: Provide details on when and how to conduct stakeholders, minimize the loss of information from a major cybersecurity incident, outline details and procedures for communicating the cyber insurance provider. InfosecTrain Trainer: address how and when to communicate with media, including who is authorized to skip. What is the umbrella answer, A? InfosecTrain Trainer: Conduct stakeholders. InfosecTrain Trainer: media... And all are what your stakeholders? InfosecTrain Trainer: Cyber insurance provider is whom? A stakeholder. InfosecTrain Trainer: Right? C and D are part of A, so A is the umbrella answer. InfosecTrain Trainer: An incident response team has contained a widespread malware outbreak. InfosecTrain Trainer: What is the primary importance of the information security manager ensuring all incident-related information is meticulously recorded?

InfosecTrain Trainer: To create a formal legal record for potential litigation against the attacker, to provide a definitive audit trail for post-incident review and procedure improvement, to immediately communicate the technical detail to all employees as lesson. InfosecTrain Trainer: To simplify the process of notifying regulatory bodies about the breach. InfosecTrain Trainer: So... InfosecTrain Trainer: Why you record, we discussed in detail, right? You record the incident so that you can do the post-incident review, you can improve the overall process, right? InfosecTrain Trainer: It will be helping you with the legal record and all those things, but the major thing is for this. InfosecTrain Trainer: Right? It will... this is also a close answer, but this is the most important thing. You will not create the record because you want to share the technical detail with the employees, and regulatory body also you want to notify. InfosecTrain Trainer: That is also a major portion of the record, but the main thing is that you want to create an audit trail, you want to do post-incident review, and improve the process. That is the most important thing here. InfosecTrain Trainer: to address. InfosecTrain Trainer: Now, this is not part of the CISM syllabus, but I am just discussing this more from the understanding perspective that how exactly a cyber attack takes place in the environment, right? So, there is a MITRE InfosecTrain Trainer: people called it the MITR, or something different, different, right? MITR attack framework, right? InfosecTrain Trainer: which actually mimics how, actually, a cyber attack being taken care, right? How attack take place. And there is the opposite to it, which call as the cyber kill chain.

InfosecTrain Trainer: So, these are all the steps InfosecTrain Trainer: Which, if suppose tomorrow you want to launch a cyber attack against an enterprise, these are the different, different steps which you will take InfosecTrain Trainer: do that. InfosecTrain Trainer: To make it happen. And then there is an opposite to MITRE attack, which is called the cyber kill chain. So what you do, you kill the chain. InfosecTrain Trainer: After the reconnaissance, you don't let that person develop the resources, you don't let them begin the initial access. So you kill the chain, that is called the cyber kill chain. So these are the steps. First step is the reconnaissance. InfosecTrain Trainer: I want to launch an attack against an enterprise, what I will do? I will do a reconnaissance of their public-facing infrastructure. InfosecTrain Trainer: So, how the JLR attack happens, I'm not sure that it was true, but probably the person, guy whom he did a social engineering attack, he would have published some information over the LinkedIn. InfosecTrain Trainer: which attacker was able to understand, okay, the guy is handling this particular critical infrastructure, he's a SAP admin. InfosecTrain Trainer: No, it's very easy, right? If they are able to get the credential of SAP admin, then they will gain the privilege access in the environment. They have to just do the credential surfing. InfosecTrain Trainer: And through social engineering, you... you follow their social media trail, you follow how the person is present in the social media, you will be able to understand exactly what is their behavior. Okay, he is very much into attending the seminars. InfosecTrain Trainer: He is, very much into watching the YouTube podcast or something like that, so that reconnaissance helps you that.

InfosecTrain Trainer: Then comes the next step, is the resource development. InfosecTrain Trainer: Now you want to launch an attack, you have to create a payload. InfosecTrain Trainer: to deploy that particular malware or ransomware in the organization. So that resource development you do, then you begin as initial access. InfosecTrain Trainer: So first, you compromise, you... you got hold of his particular ID, you are into his particular account, right? InfosecTrain

Trainer: Then you run and execute that code which you want to execute, then you maintain foothold. InfosecTrain Trainer: You will maintain the presence in the environment of the organization, then you want to escalate the privilege. InfosecTrain Trainer: Suppose you got an access to one particular environment, now you want to move around, you want to gain access to database, other servers, other application and systems, you want to escalate the privileges, and then you will avoid detection. InfosecTrain Trainer: Because if you get detected, the SOC team will get alerted, and then they will contain the incident, or they will eradicate it for the environment. So you want to keep yourself as much anonymous as much possible, right? You don't want them to know that there is an attack taking place. InfosecTrain Trainer: Then you will do the credential access, you will steal the credentials of the people, you will do the discovery, explore the environment, you do the lateral movement, laterally move, then you gather the targeted data, and maintain command and control, communicate with the attacker, right? InfosecTrain Trainer: And then you will do the exploitation, steal the data, and cause a destroyer, disrupt, or impact.

InfosecTrain Trainer: So this is a complete MITRE attack framework, which is used by attacker to actually launch an attack. And this same framework is used by the organization to establish the control, create the playbook. InfosecTrain Trainer: do the threat hunting, and all the red teaming, blue teaming, perma team exercises. So this is a very important framework. InfosecTrain Trainer: which is used. InfosecTrain Trainer: So now, just oppose it to that MITRE attack is the cyberkill chain. InfosecTrain Trainer: So, CyberKill Chain was developed by Lockheed Martin, which is a very, very well-known defense manufacturing company of US. InfosecTrain Trainer: all those F-35s, F-22 Raptors, and all those big... InfosecTrain Trainer: fighter planes are produced by Lockheed Martins, right? InfosecTrain Trainer: So they actually created this cyber kill chain. InfosecTrain Trainer: So... so that one attacker is launching an attack, how to kill that chain? InfosecTrain Trainer: how to... Actually. InfosecTrain Trainer: From an attacker's perspective, how to... how to not let them do the reconnaissance, how to stop them in the weaponization, how to, send the delivery, how to stop the exploitation, installation, command control, and all the... achieving all the action and objective. InfosecTrain Trainer: So... From this, then comes... InfosecTrain Trainer: the six course action, which target, which organization I have to create. So, for reconnaissance, you have to create the detection, so that when they are doing the reconnaissance, they are scanning your external perimeter, your infrastructure, you get alerted. InfosecTrain Trainer: Right? Once they are, actually creating the execution of the environment, you deny the access. You disrupt InfosecTrain Trainer: the flow of the attack, right?

You... you degrade the effectiveness of that particular attack which they're launching, right? You deceive, you mislead, you... you place the honeypot so that people, so that attacker InfosecTrain Trainer: And think that this is the actual system which they're trying to attack, and then they launch and attack you. InfosecTrain Trainer: analyze their pattern, right? And then you destroy it. You... InfosecTrain Trainer: So this is the CyberKill chain and the MITRE attack framework. InfosecTrain Trainer: Now, next topic is the incident notification. InfosecTrain Trainer: So... It's very important InfosecTrain Trainer: to have a proper incident notification protocol, right? All the organization, they have it. So, you do it through automation, you do it through manual mechanism, I'm not sure how you are doing it, but you notify to the respective people on the basis of the severity. InfosecTrain Trainer: Most of the organization, they have automation in place, so as per the severity, P1, P2, P3, P4, automatically, the automation will detect the severity, and automatically it will copy all the people, those who need to be notified in those cases or those incidents, right? InfosecTrain Trainer: So, information security managers must set up a mechanism so that the notification process is there, all the relevant stakeholders and relevant people need to be involved or notified in case of an incident. InfosecTrain Trainer: You may notify using email, fax, phone, emergency phone line, or through website notification, depends. InfosecTrain Trainer: What is the process you are following in the organization? It depends, right? But who all need to be notified? InfosecTrain Trainer: First is the backup facilities.

InfosecTrain Trainer: If there is a ransomware attack, and there is a requirement or need to evoke... need to actually invoke the, InfosecTrain Trainer: the BCP and DRP plan, you need to inform the backup facility person, right? The data center guy. InfosecTrain Trainer: Who have to probably initiate the backup facility, or initiate the restoration, they need to be aware. InfosecTrain Trainer: You need to also inform the business partners. InfosecTrain Trainer: Right? So there could be an impact on the business partners, impact on the critical business functions, so they also need to be aware on that, right? InfosecTrain Trainer: Then comes the customer support. I gave an example. If... if you are not able to access the banking website because there is a DDoS attack. InfosecTrain Trainer: Whom you will give call. You will give call to the customer support team. If the customer support team is not aware that exactly what is an issue going on with their application, with their web application, website, how they'll be able to tackle those issues. So you need to inform them as well about an incident. Then the customers. InfosecTrain Trainer: So that if their data is getting impacted, they need to be aware that there is some incident going on in your environment, and they will not be able to access the website due to a disruption and all, right? Then legal counsel. InfosecTrain Trainer: So the legal team will help you InfosecTrain Trainer: communicate to the regulatory bodies or important people, right, than HR team. InfosecTrain Trainer: if broader communication need to be sent to the... all the employees, they need to be aware about something, right? So, HR team also need to be aware. Then, insurance company.

If you have a cyber insurance, you need to claim the insurance, you need to inform them that we are impacted with a cyber incident, and we are facing a cyber incident, which may require InfosecTrain Trainer: insurance, Provider to help you set up the insurance, then you have to tell them that internal audit. InfosecTrain Trainer: Why internal audit? Because internal audit team is something InfosecTrain Trainer: They need to understand what was the kind of the cyber... InfosecTrain Trainer: incident took place, right? So that when next time they are doing an audit, they will consider those aspects. They will do the audit, the infrastructure accordingly to understand what are the key gaps, right? InfosecTrain Trainer: Then regulators. All the regulatory bodies, regulators, like, I talked about in the banking, right? Like, RBI. InfosecTrain Trainer: If I'm an Indian bank, there is a cyber incident, I have to inform RBI, which is a regulator. If I'm a bank in the European region, I have to inform ECB. InfosecTrain Trainer: In the US, I have to inform the feds. So, regulators you need to notify. Then your privacy department, if there is a data breach, a PII, PHI information is involved. Your enterprise risk management team. InfosecTrain Trainer: They also need to... they are maintaining the risk register and all. If there is any changes in the risk appetite, risk, or probably changes in the inherent risk level, they have to be aware about it, right? InfosecTrain Trainer: Then the security operations team, the senior management, and the vendor supplier. So, there are multiple stakeholders and multiple teams. Those will get notified in case of an incident.

InfosecTrain Trainer: Now... This is the... the slide which helps you give an overview of overall incident management process, right? InfosecTrain Trainer: So, first step we discussed was defining the incident management process, creating an incident management plan, right? Creating SOPs, creating policies, and everything. Once that is done, then you need to train the people. InfosecTrain Trainer: If people are not aware, they don't know what is an incident management protocol, how to handle those incidents, how they are supposed to hand... how they will act if tomorrow there is a cyber incident going on, right? You need to train them. InfosecTrain Trainer: Then you need to have a mechanism in place of the detection. InfosecTrain Trainer: So that you should monitor all the important alerts, you should monitor all the important events, you should have a proper threshold in place, detection mechanism in place, so that the system generates you those events, and then your team, is it management team, should be able to determine that what of the InfosecTrain Trainer: Which all of them are... High priority one, which may impact the organization and possibility of an incident. InfosecTrain Trainer: Then you need to ensure the quick identification, containment, resolution, and recovery. InfosecTrain Trainer: So we... the first slide was the same, right? Which we discussed. First slide was talking about what is an overall goal of incident management. InfosecTrain Trainer: Overall goal of incident management is to, first. InfosecTrain Trainer: To reduce the impact. And then, second thing is that, respond and recover quickly as possible.

InfosecTrain Trainer: So... InfosecTrain Trainer: All these steps are doing the same thing for you, and then you have to provide the fast response and reduce the overall impact as much as possible. InfosecTrain Trainer: Now, There are some tech stack or technology tools which are there which help you with the overall detection. InfosecTrain Trainer: and overall mitigation of the incident, right? So, understanding these technical tools is very important. So, one thing is called the InfosecTrain Trainer: One thing is the incident management system, another one is the EDR. InfosecTrain Trainer: Can someone tell me what is EDR? InfosecTrain Trainer: What does India do? SrinivasanJ: Endpoint detection and response. InfosecTrain Trainer: Yeah, but what does it do, actually? Fatha: Like, antivirus or malware in the laptops? SrinivasanJ: No. Antivirus is not, EDR. Fatha: And that's for endpoint links. InfosecTrain Trainer: Anyone else? Pudir: Yeah, I'm going to have been put on the table. Pudir: What do you need? Pudir: Sustainable shooting, sir. InfosecTrain Trainer: Okay, let me, let me... Mukesh Thakur: basically, used to detect and investigate and then, stop the malicious activities. This is a tool, right? InfosecTrain Trainer: Yes. So let me take an example. So you have a... if you see a typical organization infrastructure, right? So whenever the traffic come from internet, right, so you have a proper... we discussed the DMZ, right? You have a proper setup, you will have one InfosecTrain Trainer: Core firewall, where the traffic would hit, and from this core firewall, then you will distribute the traffic accordingly to different, different systems, servers, and all, right?

InfosecTrain Trainer: Then, after the core firewall, you will again have a specific firewall for each application, each system, and all. After those firewall, you will have IDS, InfosecTrain Trainer: or IPS installed. InfosecTrain Trainer: Then there could be a web application or an endpoint from where the person is

accessing all these things. InfosecTrain Trainer: But how many times you have seen the attacker taking this path? InfosecTrain Trainer: Never. InfosecTrain Trainer: Because this is a very difficult path to choose. InfosecTrain Trainer: You will hardly see any attack taking place this path, because this is very difficult. You will not be able to crack the firewall. InfosecTrain Trainer: You will not be able to break into IDS and IPS and get into systems. This is a very typical network flow, where multiple layers are there. It's very difficult to crack this, until unless you get an admin access to that firewall, and you are able to change the firewall rules, which will also eventually generate the alerts. InfosecTrain Trainer: you will get detected. And this is... the possibility of that is very difficult. So what does the attacker do? InfosecTrain Trainer: They follow the another route. InfosecTrain Trainer: They take the reverse approach. InfosecTrain Trainer: That's why awareness is very much important, right? Most of the thing will... how the JLR attack happened? Through social engineering. InfosecTrain Trainer: Through credential surfing. InfosecTrain Trainer: you inputting your details on some website, you are receiving and phishing email, anything can happen, right? So... InfosecTrain Trainer: If something is happening on this endpoint, how those endpoint-related issues will get mitigated, that's what EDR does.

InfosecTrain Trainer: So, EDRs sit on all the endpoints, be it your PCs, be it your servers, right? InfosecTrain Trainer: And then it help detect and mitigate those threats. There are multiple types of EDR, which is not there as part of the CISM syllabus, we'll not get into the details of that, but there is something called EDR, there's one more, something called the XDR. InfosecTrain Trainer: So, EDR is only having a telemetry data with respect to this endpoint, but XDR is something which is having the telemetry data from multiple sources. Like, your entire ecosystem is InfosecTrain Trainer: actually sending the information here, right? So it will be able to correlate information from here, it will be able to correlate data from your AD, InfosecTrain Trainer: It will be able to correlate the information from the multiple machines, multiple platforms, and then it will help you mitigate and InfosecTrain Trainer: actually reduce the threat, right? So that is what EDR does, right? So that is the significance of EDR, because the endpoint also needs to be protected. InfosecTrain Trainer: Now, after EDR, there is one more thing called the DLP. InfosecTrain Trainer: What is the major role of DLP? SrinivasanJ: Data loss prevention, like, we use, to ensure there is no infiltration of data, like, only SrinivasanJ: Authorized processor personnel can copy files. InfosecTrain Trainer: Correct. So, DLP is another control which helps you mitigate the impact or reduce the data exfiltration out of organization. Now, attacker is able to evade into it, he is there in your system. Now, he's trying to move out InfosecTrain Trainer: the data of the organization, out of organization.

So now you have a proper rule in place that InfosecTrain Trainer: confidential information cannot go out of your organization, he'll not be able to do it because you have a DLP in place, right? InfosecTrain Trainer: So that's how the tech stack comes, and that's how the tech stack works. So there is two things. One thing is called the Incident Management System, another one is the EDR. So Incident Management System is the centralized incident coordination platform. InfosecTrain Trainer: like, organization uses either ServiceNow, Or something else. InfosecTrain Trainer: you might be using, right? So this incident management system is not only this, it will be... is an ecosystem. You will use NO, you will use SIEM, InfosecTrain Trainer: you will use the information and information from other sources, probably you will use the information coming from the endpoints, from the cloud, other sources, right? Overall, all collectively working together becomes an incident management system, which help you manage the incident. InfosecTrain Trainer: So, it is the centralized incident coordination platform which you have InfosecTrain Trainer: So, you will do the workflow automation and playbook integration in the same platform. InfosecTrain Trainer: It will help you do the metric reporting for the governance, evidence preservation, audit trail, and collaboration in communicating to the important people. InfosecTrain Trainer: So the EDR, what it does, it do the continuous endpoint monitoring and data collection, right? So the limitation of EDR is there, it's only... InfosecTrain Trainer: telemetry and presence and information correlation is only limited to the endpoint. Either it's an endpoint as a laptop, PC, or it's a server.

InfosecTrain Trainer: It do advanced threat detection using behavioral analysis, provide the proactive threat hunting, rapid incident containment, and forensic capability. You can fetch the information for the forensics from here, right? InfosecTrain Trainer: That's the difference. Tomorrow, we will discuss from here, not tomorrow, next week. And next week, also, we will complete this particular domain, and then we'll discuss the strategies. So it's very important, all of you, to please InfosecTrain Trainer: attend the next week, because it's not only the syllabus which we will be finishing, we will also discuss the important things, what you need to do. InfosecTrain Trainer: to crack the exam, because the CISM exam is not only limited to... you have only, read all the topics, you understood all the topics, it's done. You have to build that strategy so that you can crack the exam. So that strategy also we will discuss in the next InfosecTrain Trainer: Saturday, and we'll finish. So, all of you, please complete now Domain 3 questions, right? InfosecTrain Trainer: Most of you were able to complete till Domain 2, so you have one week time, completed Domain 3, so that even if you have time, you can even start the Domain 4, so that in the next week, once we finish. InfosecTrain Trainer: you can quickly complete the QA manual questions, and then you can start with your preparation. InfosecTrain Trainer: How many of you feel confident that you can book an exam with some date? InfosecTrain Trainer: So far. Sandeep Saxena: Based on the result of the mock test, I'll decide. InfosecTrain Trainer: Okay. InfosecTrain Trainer: But what suggestions I'll give to all of you, right? InfosecTrain Trainer: CISM gives you a flexibility. 48 hours before the exam, you can reschedule.

InfosecTrain Trainer: So, at least target a date and book an exam. InfosecTrain Trainer: Once we complete, in the next week, you can decide and book an exam, book a date. InfosecTrain Trainer: I'm not saying immediately, you can keep it 20 days, 25 days, so that once you know the date accordingly, you will start preparing for that. Otherwise, if you don't plan it, and you don't book it, you will continue to delay it for a longer period of time. I have seen people, those who InfosecTrain Trainer: did completed training one year back, they have not yet able to write. Now it's very difficult for them to again go back and write the exam. InfosecTrain Trainer: After one year, because they would have forgotten all the topics. InfosecTrain Trainer: It's very difficult to, again, come into flow. All of you are already in the flow. We have been studying, so it's better you plan exam, probably 2 weeks... three weeks after is the best date, which I can recommend. Three-week time is good enough for all of you to revise, prepare, and then go ahead and crack. Fatha: Like, otherwise, if you want to, brush up everything and then, revise and then give, like, how much time you think, is required, if we put, like, consistent efforts, InfosecTrain Trainer: Three weeks is a good time. InfosecTrain Trainer: To do everything. Fatha: 3 weeks soon. Fatha: Okay. InfosecTrain Trainer: Because I'm not sure how much... InfosecTrain Trainer: Busy you are with your work. Fatha: Yeah. InfosecTrain Trainer: It depends on that also, right? Fatha: So, what's... InfosecTrain Trainer: Every day, every day you are working. Fatha: people. InfosecTrain Trainer: more LinkedIn Lite, then every day you won't be able to spend much time. You probably will be able to take out one hour time, right?

Over the weekend, you have much time, so it depends on that also. Fatha: They're like, yeah, that's the problem. InfosecTrain Trainer: It's better if you are actually InfosecTrain Trainer: crack... want to crack this exam, I would recommend take a week off. Fatha: Mmm. InfosecTrain Trainer: Because this is the most important thing, you have invested money and effort, take a week off. InfosecTrain Trainer: Take a holiday? Fatha: fake. InfosecTrain Trainer: And then study, and then write the exam. At least in the week when you want to write, at least take that complete week off, or 10 days off, whatever you can manage, and write the exam. InfosecTrain Trainer: It's going to be much better. I'll not recommend with the office, because InfosecTrain Trainer: You will be in that mindset, you'll be busy with the project and whatever is happening in the office, then it becomes difficult for you to concentrate. Fatha: Yeah. Fatha: It's better to take before I think it changes the version. InfosecTrain Trainer: Yes, yes, yes. So, because this version, all of you are familiar with, I'm also not familiar with the new version. When the people will start writing the exam after November, then they will share me the feedback that what are the new kind of questions are coming in. InfosecTrain Trainer: Because no one knows what kind of questions comes, right? This exam is already being... been there from 2022, so all of us know what kind of questions comes. InfosecTrain Trainer: Alright then, everyone. Thank you so much, and... Fatha: Yeah. InfosecTrain Trainer: Yeah, yes, Sandeep. Sandeep Saxena: Have a lot. Thank you. InfosecTrain Trainer: Alright, then. Thank you so much, everyone. Have a great week. Sandeep Saxena: Don't. Manoj Kamble: Nope. Fatha: Thanks, Mahal.

Vijayakumar: Thank you, lovely. Fatha: Thank you.

Day 8: Full Cleaned Transcript

Approximate source length: 33,769 words.

InfosecTrain Trainer: Hello, good evening, everyone. Sandeep Saxena: Hi, good evening. InfosecTrain Trainer: So... I think this is where we stopped last time. We were discussing same thing, right? SDXDR, DLP, IDS. Sandeep Saxena: Yes. InfosecTrain Trainer: Yes, so we even discussed that, how... what is the actual difference between the XTR, what does DLP do, and what does IDS do, right? InfosecTrain Trainer: So yeah, so I think this is the last session which we have, right? So before we get moving. InfosecTrain Trainer: Any doubts? You people might be solving the questions. So, who all have completed Domain 3? InfosecTrain Trainer: Who all have completed the Domain 3 questions? InfosecTrain Trainer: Anyone? InfosecTrain Trainer: Who has completed the Domain 3 questions? InfosecTrain Trainer: Alright, so... so... so the ISACA has launched... before we get moving, right, ISACA has launched the new manual, new PA manual, and the new, reference material, the new book, right? Which is the 17th edition and the 11th edition, right? InfosecTrain Trainer: So anyone... who... is not able to write before InfosecTrain Trainer: the first week of November, which is the third November, I think, is the date. After that, all the exam content will move to the new syllabus, right? Someone who is not able to write post that, then let me know. I have already started InfosecTrain Trainer: Started the... Kind of adding the new topics, what they have introduced. InfosecTrain Trainer: So, let me tell you, it's not a lot of changes, so they have not done a lot of changes, right? Just the first domain is... has got 1% additional weightage, because they have added the enterprise architecture as a full topic there in the first domain, right?

InfosecTrain Trainer: And the last domain, they have reduced the, reduced the weightage by 1%, right? But I'm yet to see what are the changes there, but I have InfosecTrain Trainer: Till today, I've gone through Domain 1 and Domain 2. Even Domain 2, there was not much change. It was just a little bit here and there, they have just aligned the language and all. Rest, everything, the topics and everything remains same for the Domain 2 also. Domain 3, they have added a new topic, which is called the security architecture, and they have added the SAPSA, Jackman, and all those InfosecTrain Trainer: Framework which we discussed at high level, which is used InfosecTrain Trainer: for creating the architecture, right? So those are the new things, and Domain 4, I'll... InfosecTrain Trainer: get to see... but 17th, I am planning one webinar, which is there in the evening India time, right? So anyone who is interested to see what are those changes happening, you can follow that. But I would recommend follow this InfosecTrain Trainer: pattern only, it is well known, well tested, because once people will start going and writing as per the new InfosecTrain Trainer: pattern, then only I'll also get the feedback, get to know exactly what are the changes they have done, because I'm not sure what they'll... what kind of changes they will do in the questions which they are asking, right? However, the pattern and everything will remain same, but they will change something InfosecTrain Trainer: they will probably try to put it in something different manner, right? So that, I'm not sure what they will do. So once you people will go write, give me feedback, accordingly, I'll be able to probably improve the content and add something new.

InfosecTrain Trainer: But I would recommend following this content, this is the best one. A lot of people have passed recently, right? Following the same content, so you follow this and just clear the exam. That's the best possible way of doing that, right? InfosecTrain Trainer: So now, starting with the next topic... InfosecTrain Trainer: Yeah. So now, the next topic is the SIM. InfosecTrain Trainer: So, SIM is what kind of control? InfosecTrain Trainer: It's, detective. Detective control, good. So SIM is a detective control, right? So, earlier, people used to, before when SIM came into the picture, right? Sim has been there from a good number of years, but before the SIM was there, people used to use some log management, InfosecTrain Trainer: solutions, where they're used to run the queries, correlate the multiple log sources, and then gain the insights that exactly what is happening, right? But now the SIM is here. SIM, what it does, you imagine the overall environment in the organization. So many log sources, right? Logs are being generated by your network infrastructure, logs are being generated by your endpoints. InfosecTrain Trainer: Even your cloud infrastructure is generating logs, your email gateway, all the... main sources InfosecTrain Trainer: All of them are generating logs. Now, is it possible for a human to go check, see the logs from so many sources, and then probably correlate and give the results? Probably is possible, but how much time it will take? InfosecTrain Trainer: Because once the incident happens, you will have a split-second time to immediately analyze, detect, and InfosecTrain Trainer: contain, because the more time you spend on, probably, correlation and all.

InfosecTrain Trainer: the... probably that particular attacker would move around, he will do the lateral movement in your environment, and then move to the other systems, right? So that's why it's better to do that, right? So the SIM helped with the same thing. So SIM, what it does, it collects, it correlates, detects and respond in one platform, and these days, SIM InfosecTrain Trainer: is coming with the SOAR capabilities, which we discussed in the Domain 3, right? Security, orchestration and automated response, which is a way of automating InfosecTrain Trainer: the playbooks and runbooks within the CIM solution. So, all the things what SIM can do, detect you... there are some basic, InfosecTrain Trainer: steps which need to be taken when the incident is detected, those SOAR will take care of it, right? InfosecTrain Trainer: So this... so... so if in the exam, any question asked on the SIM, so the main thing is that it's a centralized platform which helps you aggregate the logs from across the enterprise. InfosecTrain Trainer: Right? And what are the... so it actually do three steps. First step is collect, next step is process and correlate, and third step is detect and respond, right? So, in the collect, what it does, it actually gathers the logs from multiple sources. InfosecTrain Trainer: So the logs are being generated from OS, EDR, firewall, your Active Directory, your IAM, MFA, SSO, your cloud and the SaaS solutions, application databases, and the security tools, like vulnerability tools, DLP, WAF, antivirus, right? InfosecTrain Trainer: No. InfosecTrain Trainer: Probably you are a global enterprise. InfosecTrain Trainer: And the location of the server for these particular systems may differ geographically. InfosecTrain Trainer: And also, the timing may differ, right?

And the kind of logs they are sending, the method may differ. InfosecTrain Trainer: Right? InfosecTrain Trainer: So all of them need to be normalized. InfosecTrain Trainer: Right? Then only the system will be able to understand those things, right? So aggregation and normalization is the first step. InfosecTrain Trainer: Where, once the log is collected from so many sources, it's normalized InfosecTrain Trainer: to a understandable format for the sim, and then aggregation is done. Because so many sources... so if attacker came in and then he moved laterally, so there is a lot of correlation which need to be done, right? That sim will do. InfosecTrain Trainer: Once that correlation and analytics is done, then the rules are applied. InfosecTrain Trainer: And then the alert and the prioritization is done, right? So... so the SOC analyst, he will get a generated alert, so the system will throw that this is a... we discussed, right? Priority 1, 2, 3, 4. They'll say this is a priority 2 incident. InfosecTrain Trainer: So that the... that particular analyst also gets alerted by looking at that priority 2, right? His focus will shift. But if CISM marked it as priority 4, he... InfosecTrain Trainer: He'll be able to probably process it with the ease. InfosecTrain Trainer: So that prioritization happened, or probably at one point of time, multiple incidents are there, he will be able to prioritize that, okay, first go with the high priority, and then I'll go to the low priority incident. And then also helps you with the storage and retention. So you have to do forensic investigation, analysis, and other things, later steps. InfosecTrain Trainer: So that, also, you can... it will help you with. And then it generates the output, which is the detect and respond.

InfosecTrain Trainer: So, real-time alerts, which are being generated, you can create a very good dashboard, from which you will be able to see KPIs, KRIs, threat trends, right? Also, will help you with the investigation forensic. InfosecTrain Trainer: Compliance reporting also it helps you with, right? Help you with the GDPR, PCI, ISO compliance. SOAR integration will help you automate the basic responses, and also helps you with the threat gathering, the threat intelligence. InfosecTrain Trainer: So, why SIM matters for the security program? It offers you a faster detection, Gives you a central visibility. InfosecTrain Trainer: help you collect the evidence for compliance, because if, suppose, there was a data breach, then tomorrow, if there is a GDPR-related incident, and regulatory body asks you that, InfosecTrain Trainer: share me... show me the evidence that you have all the detection mechanism, you follow... followed all the protocols and everything, so what you will share. You have the SIM logs and the details which you can share with them, right? And also helps you generate the mattresses. InfosecTrain Trainer: So this is overall what SIM is, and I already asked, SIM is a detective control. InfosecTrain Trainer: Do not prevent incident. Any question in the exam which talks about preventing an incident and SIM is a solution, don't go with that. InfosecTrain Trainer: It's just detect, and it help you respond to it, and that's it. InfosecTrain Trainer: It's not preventing. Prevention happen with what? Prevention happen with other control, like you have encryption, you have access management control, you have firewalls, you have the DLP, you have antivirus, those, you have an EDR, EDR, so those are something which helps you prevent, right?

InfosecTrain Trainer: This diagram helps you explain how the modern-day SIM works, right? So it gathers the inputs and the information from the cloud sources. InfosecTrain Trainer: Right? It gathers the information from firewall, ideas, servers, workstations, switches, laptops, and once this is done. InfosecTrain Trainer: Aggregation database collects the record, then SIM apply its algorithm to identify, sort, and tag those logs, and then SOC alerts are

generated, reports are generated, and the threat hunting can be performed. InfosecTrain Trainer: Now, what are the benefits of using a SIM? InfosecTrain Trainer: First thing is that enhanced threat detection. InfosecTrain Trainer: So, I gave you an example, right? Suppose There is no SIM. InfosecTrain Trainer: How it will happen, right? InfosecTrain Trainer: You have to correlate the log sources from multiple things, right? And we also discussed about the APT. What is APT? InfosecTrain Trainer: Someone, what does APT mean? Johnny Souriar: Advanced or persistent. InfosecTrain Trainer: And what is this? What does APT do? Johnny Souriar: We will gather and sit in the... Environment for a long time. Johnny Souriar: Then it will start. InfosecTrain Trainer: Okay. Johnny Souriar: I've taken. InfosecTrain Trainer: So, APT are the advanced threat, right, which actually gets into your environment undetected, it causes the harm in the system, and then it leave without InfosecTrain Trainer: leaving any... much of the footprint, right? So those kind of threats, where there are multiple things what the attacker is trying to do, and try to remain as much as possible anonymous, right?

InfosecTrain Trainer: That time, the SIM will help you, because SIM has a correlation of the log with multiple sources, so it will be able to correlate and detect those kind of complex threads. InfosecTrain Trainer: Second thing is the faster incident response. So. InfosecTrain Trainer: So, as the system is automatically detecting those incidents and generating you the alerts, so it becomes quick for your organization to quickly respond and get onto the task. Your SOC team can quickly initiate the incident management protocol and go to the InfosecTrain Trainer: mitigation, containment, and all the steps, what we discussed, right? Offers you central visibility. InfosecTrain Trainer: So, central team, your leadership team, your CISO, your SOC manager, your SOC lead, all of them have a central visibility where they can see all the information and help you simplify the complex, compliance, right? InfosecTrain Trainer: So, you have to submit the evidence. After any incident, you have to show your compliance towards it. You can do it. Also, incident reporting. That is a very important part of compliance. So, every... InfosecTrain Trainer: every regulation has a different incident reporting timelines, like GDPR, say, 72 hours, NIST to say 24 hours, DPDPA also has something different than all other countries. HIPAA would have something different, and... InfosecTrain Trainer: any other act. So you have to... InfosecTrain Trainer: have this particular meet this timeline, how you will do it if you are not able to detect the incident properly, and able to understand what incident is about. So, simplified compliance you will achieve. InfosecTrain Trainer: Now, coming to the incident management team composition.

InfosecTrain Trainer: So, every incident management team in the organization will follow this composition. So, the team will have a team leader. Most of the time, team leader is the security manager. InfosecTrain Trainer: He would lead the team. InfosecTrain Trainer: Right? Apart from this, they... he will also have a supporting team member. So, first supporting team would be SOC team. InfosecTrain Trainer: And when the SOC bridge opens, sometimes the SOC team, if they are not able to understand a couple of things, they may involve the business also. InfosecTrain Trainer: Suppose there is a cloud-related incident, and the persons are not able to understand, they will get someone from the cloud team. InfosecTrain Trainer: If there is a sophisticated AI-related incident, probably they will involve some AI subject matter expert. If something related to database and they are not able to understand, they will involve the database team to understand what is going to be impact on the containment and all. So those InfosecTrain Trainer: Team members with specialized skill also form as part of the team, and then the steering committee, because imagine a big incident. What is steering committee? We discussed it in the first domain. InfosecTrain Trainer: What is the main purpose of a steering committee in the organization? Johnny Souriar: To guide, guide and oversee the day-to-day operations. InfosecTrain Trainer: Day-to-day operations. Johnny Souriar: ZRA means, what we call this, for example. Johnny Souriar: IT-related project, project budget utilization, project approval, resource allocation. InfosecTrain Trainer: Steering committee... steering committee is a strategic body. InfosecTrain Trainer: Not an operational function.

It's a strategic body which helps you with the good governance, right? So it helps you run the security, and also InfosecTrain Trainer: encourage with the... encourage the class collaboration, right? So, we discussed the composition of a steering committee, right? Steering committee consists of the people from the multiple business, right? CISO would be there, then all subject matter experts, people from legal. InfosecTrain Trainer: HR... Now, imagine a big ransomware attack where multiple things are impacted. InfosecTrain Trainer: Now, a steering committee will help you with what? Legal team will help you analyze and help you establish the incident protocols and make sure that all the legal steps are followed. InfosecTrain Trainer: PR team will help you... PR and the communication team will help you prepare the comm, right? You have to inform your customers, you probably need to inform media, because your company is there, because somehow the news will get leaked, right? Before the news gets leaked to the public, you have to create a response and tell to the people, right, that we are able to manage. InfosecTrain Trainer: HR team will help you onboard new resources, or new InfosecTrain Trainer: Specialized skilled people, if needed, right? Then also is going to be some sponsor. InfosecTrain Trainer: who sponsor your security. That sponsor will help you with the budget if additional budget allocation is needed in case of cyber incident, right? You understood the significance of steering committee in the incident?

InfosecTrain Trainer: I'm not talking from the day-to-day incident which keep happening, that some small attack happened, and your SOC team is able to monitor and close it, or some small, incident which... even a lot of priority one or priority 2 incident also, you may not involve steering committee. They will come into picture when there is something of the significant impact, where there is a big impact to the organization. InfosecTrain Trainer: Right? InfosecTrain Trainer: Yeah, someone unmuted. Yeah, Premant, you want to ask something? Johnny Souriar: Yeah, here, strategic committee is also there, na, right? InfosecTrain Trainer: Yes, yes, strategy community was a different purpose, right? So we... We, when we discussed, Right? InfosecTrain Trainer: So we discussed... let's revise. We discussed board of directors. Under board of directors, the senior management works. InfosecTrain Trainer: Then senior management, consists of the CEO, CFO, COO, likewise, and then they appoint the CISO. InfosecTrain Trainer: Right? InfosecTrain Trainer: So, under this, whenever a strategy InfosecTrain Trainer: Org strategy need to be created, so then you can create a... Strategy Committee. InfosecTrain Trainer: Because the org strategy is not only done for one particular business, right? Org strategy will InfosecTrain Trainer: be something which would impact the entire organization. Can CEO alone can create it? No. He needs information, inputs, and other suggestions from all the business leaders, right? All the business function heads.

InfosecTrain Trainer: So he will include all the senior management people, all the people, or the department, or the business heads, like CISO would be there, CIO would be there, HR head would be there, legal, head of legal would be there, head of compliance would be there. All of those will also provide the inputs in creating the strategy. InfosecTrain Trainer: So that's what strategy committee do. They will help create the strategy. InfosecTrain Trainer: Then, Under cyber, there is something called the staring... community. InfosecTrain Trainer: Now, there are multiple projects which require a cross InfosecTrain Trainer: collaboration between the organization, because whatever you do within the security, if something which is being done only for the security, not impacting much thing, you cannot... you need not to go to steering committee. But most of the project, most of the initiative, what you take InfosecTrain Trainer: For the organization, would have an impact InfosecTrain Trainer: Right? Like, suppose you say we want to deploy EDR across organization. Now, those EDRs would also get deployed on the servers? InfosecTrain Trainer: also on your local machine, so you need inputs from the people, right? Some business owner will say that deploying this EDR may affect my... InfosecTrain Trainer: application. It's causing the latency issues and a lot of issues, there is no, issues, right? So that's why... so when you are evaluating the vendor, all the inputs you will take from the people, and then you approve the solution. InfosecTrain Trainer: So this is one example. Got Johnny? Johnny Souriar: It's a... you have this... Johnny Souriar: Strategy committee is a board-level subcommittee, but steering committee is, normally different verticals, groups. InfosecTrain Trainer: Yes.

Johnny Souriar: Yes. Johnny Souriar: And they are reporting to Strategy Committee on a quarterly or half-yearly basis. InfosecTrain Trainer: Yes, yes, yes, correct. InfosecTrain Trainer: Now... InfosecTrain Trainer: This is what the team composition will look like. Now, how the team size will size and team geography, the number of people are needed, what kind of skills would be there in the team, that would differ on these parameters. InfosecTrain Trainer: That's what I'm saying. Every organization will have a different setup. InfosecTrain Trainer: Right? It's not like that my previous organization had that setup, I'll go and implement the same for my current organization, because it all depends on these factors. First thing is the size and structure. InfosecTrain Trainer: Now, can you have the similar size of the team for a team InfosecTrain Trainer: Which, for a \$3 billion enterprise versus the organization like Amazon. InfosecTrain Trainer: Can you have that? No. InfosecTrain Trainer: Imagine the size of Amazon. Imagine the number of incidents which will get generated. InfosecTrain Trainer: That small-sized team won't able to handle InfosecTrain Trainer: this level of incidents, right? So, that's why it depends on organization size and the structure. Then, industry regulatory environment. InfosecTrain Trainer: So... so the most regulated industry is banks. InfosecTrain Trainer: Then, healthcare. InfosecTrain Trainer: So all of these are most regulated industries. They have to focus on the data breaches, they have to focus on the compliance, there are going to be the multiple reportings and all, right? So there are so many things, so on the basis of that, also, you need to think and then add additional resources to help you with that.

Then the budget and resources, most important thing. InfosecTrain Trainer: So, how much budget is allocated to you? InfosecTrain Trainer: to handle this, on the basis of that, you will decide the team composition, right? If you have a huge amount of budget, a billion dollar budget is given to you, then you can build a

good, sophisticated team with the best tool available in the market and all, but if you have a limited budget, you have to maintain within that. InfosecTrain Trainer: Then the maturity of the program InfosecTrain Trainer: So, probably, for a startup where the program is not that matured. InfosecTrain Trainer: the composition would differ, but for a matured program, the composition will differ. If probably your SOC playbooks, your lock correlation, your tools and everything is very well optimized. InfosecTrain Trainer: So probably you need not to have a huge number of engineers to maintain it, so you will reduce on that side. Or if you have deployed some artificial intelligence and other things which helps you reduce some basic L1-related tasks. InfosecTrain Trainer: So that, you need not to have the people there. So, maturity of program will also help you create it. Then, risk appetite and criticality of assets. InfosecTrain Trainer: So, how much is the risk organization is willing to take? If organization was not willing to take even a slightest of the downtime. InfosecTrain Trainer: and they are maintaining very critical assets, then they should have a big security team and well-matured security team, right? Then geographical distribution, right? If you have InfosecTrain Trainer: you are working globally, then you... all the global organizations, what I've seen, they maintain a geographically distributed team.

InfosecTrain Trainer: So that it supports the local geography, right? So... so in my previous organization, one team was sitting in USA, InfosecTrain Trainer: which was maintaining one shift. One team was sitting in the... EU region. InfosecTrain Trainer: And one team was sitting in India. InfosecTrain Trainer: So, you have a 24 across 7 coverage, so 8, 8 hours. InfosecTrain Trainer: Shipped, they will maintain, and they are able to support the local time zone. InfosecTrain Trainer: Right? InfosecTrain Trainer: Then the technology stack. So I already mentioned, if you have AI, good SOAR, good SIM, XDR, EDR, and good block sources are onboarded, and also on the basis of that, you can decide that how much is the team size, composition, and threat landscape. InfosecTrain Trainer: So you know which organizations are more prone to attacks, right? Like the banks. InfosecTrain Trainer: healthcare industry. InfosecTrain Trainer: energy infrastructure, or some infrastructure companies which are supporting directly to the government or to the nation. So they are actually more prone to attacks, right? InfosecTrain Trainer: So, threat landscape also will help you demonstrate, and then the availability of external expertise. So, external expertise means the third parties. InfosecTrain Trainer: Right? So, you can onboard any third parties, right? You can have some retainer. We discussed, right? Unit 42. InfosecTrain Trainer: Mandiant. InfosecTrain Trainer: You can have some retainers From them, which will help you manage the overall Security and the incidents. InfosecTrain Trainer: Now, coming to the roles. What are the roles each and every person will play? Now you will understand the role of steering group.

InfosecTrain Trainer: We already discussed, but yeah, let's see in detail, what is the role of each and every individual when there is a cyber incident? InfosecTrain Trainer: Alright, let's take an example. Let's take there is a XYZ FinTech company. InfosecTrain Trainer: Right? InfosecTrain Trainer: In the morning at 5 AM, InfosecTrain Trainer: A SOC analyst got an alert that there is... there is one particular server database is gone. It's not getting booting up, and one critical application which was being supported from this particular server database is not working. It's down. InfosecTrain Trainer: After some time... now, this is one alert. After some time, another server is also gone, and then attack is spreading one by one. Now, the team, one, they correlated, they understood this is one ransomware. InfosecTrain Trainer: which is spreading very fast in the organization, so you imagine the big impact. 5 AM he detected, and by 9am, when everyone logs in, one of their global regions, it's a global organization, one of their EU region InfosecTrain Trainer: is completely shut down. People are not able to log in, they are not able to access that particular InfosecTrain Trainer: assets and that particular network infrastructure, which was isolated from other InfosecTrain Trainer: System is completely gone and shut down. InfosecTrain Trainer: So this is the level of the incident which is going on. Now, let's see what each and every person will do, play a role here. InfosecTrain Trainer: First, we'll go with the manager. InfosecTrain Trainer: As I told you, he is the first responder, right? So the SOC team, they will immediately create a bridge. That's what we call it. Bridge means triage bridge.

InfosecTrain Trainer: As soon as he detected service shutdown, he already know that this is a big impact, right? So he will initiate, he will probably give a phone call to the person, because 5 AM, no one is awake, right? He needs to give phone call to his team lead, his managers, then probably manager will involve the CISO by looking at the incident, right? And then the call gets initiated. So he's the first responder. He... InfosecTrain Trainer: Did the first respond, right? InfosecTrain Trainer: So this is what happened during the incident, but before the incident takes place, in the normal peacetime also, his role is very important, because all the action, what that analyst did. InfosecTrain Trainer: what he did, he followed a SOP, which was created for him, right? InfosecTrain Trainer: So that SOP who will develop, the security manager will do. InfosecTrain Trainer: So he have created, maintained the incident management program, policies, and the processes which this guy is following, right? InfosecTrain Trainer: Now, he is also making sure the people are trained. If this person was not able to detect, probably he would have thought or ignored this particular incident, made this as a benign incident, not knowing. InfosecTrain Trainer: Then, how he will initiate the bridge? Because he do not know what is the severity and what are the severity criteria and all. InfosecTrain Trainer: Right? InfosecTrain Trainer: Now, the next step comes. InfosecTrain Trainer: Now, he's involved in the bridge, he have to inform to the high... if this is a high-level incident. InfosecTrain Trainer: He need to inform The risk impact to the executive leadership, right? InfosecTrain Trainer: So... so the business leaders and all, all they need to know, because this is a big impact.

EU region is gone. InfosecTrain Trainer: information must go up to CEO. InfosecTrain Trainer: Now, in this case, What does a steering group do? InfosecTrain Trainer: So, the steering group, now, as the incident impact is high, they understood that there would be involvement of some InfosecTrain Trainer: outside retainer. InfosecTrain Trainer: They also need to onboard some additional resources, they need to contract, so there are some big agencies or big organizations in the world, they are expert in handling such kind of big incidents, right? They also help InfosecTrain Trainer: You negotiate with the ransomware gangs, so you need to onboard them. If they don't have a retainer, so additional funding resources are required, right? InfosecTrain Trainer: Also, during the incident, so many activities are going on, right? So the strategic oversight, direction, and everything is required, which they will do. InfosecTrain Trainer: they will approve that budget, resource allocation, incident response capabilities which is needed, also report the major incident reports and the lesson learned, right? Now, there are two things. One is the security manager, another one is the incident response manager. So, he can wear both the hats. InfosecTrain Trainer: So, Security Manager... InfosecTrain Trainer: We are the boards, the hats, also the security manager somehow... sometimes also referred as the CISO also. InfosecTrain Trainer: If you see, the CISO is responsible for maintaining all these things, right? InfosecTrain Trainer: However, he will himself not create those plans and those things. He have the people, but he is actually responsible for creating those. The incident response manager is the SOC manager, actually.

InfosecTrain Trainer: Now, when the incident is going on, he will lead. InfosecTrain Trainer: Because the people are less... InfosecTrain Trainer: experienced, he has seen multiple incidents, he know, what are the protocols, what are the things to look after, right? InfosecTrain Trainer: He will assign the task, manage the team resources, he will make the shift, because he knows now the incident will go for probably 3, 4, 5 days, so he have a limited number of people, so people have to go rest InfosecTrain Trainer: Continuously, people need to work, right? So that ship, he have to create. Then he will also... InfosecTrain Trainer: facilitate the communication and the coordination, because he needs to engage with the legal team. InfosecTrain Trainer: He needs to engage with the communication team, he need to send the reports, continuous reports, to the senior management on an hourly basis, so that they understand what has happened. If the incident is contained, what is the impact? InfosecTrain Trainer: Right? Now, incident handler. Incident handler is a person who actually first detected this. InfosecTrain Trainer: The first person who detected the incident at 5 AM, he is incident handler. What he did, he executed the predefined incident response playbook on triage, containment, and eradication. That's why he created that, we discussed. He created open the bridge. InfosecTrain Trainer: and then called everyone, right?

He also would be ready with some initial analysis, which he will share with the people, because he was the first one to look at the incident, so he would have probably correlated some data, which he'll share with the people, as a context that this is how the incident came in, this is how I detected InfosecTrain Trainer: These are the things what I've observed so far. He will also continue to document all the actions which he's taking. InfosecTrain Trainer: So, these actions will help with the evidence collection at the later part. Now, coming to the investigator. So, investigator comes into the picture once the incident is contained. InfosecTrain Trainer: Now, you need to investigate how this ransomware actually entered in our environment, how it was able to propagate into the multiple systems, because we have a good tech stack, everything is there, right? Why we could not detect it? InfosecTrain Trainer: So you need their support, right? So they will conduct the in-depth forensic analysis, determine the root causes, also help you collect, preserve the digital evidence, right? And prepare the detailed technical report, which you need to probably share with your stakeholders. InfosecTrain Trainer: Right? Then comes the security specialist. Specialists are the additional people which you will onboard. Subject matter expert, AI expert, database expert, any... InfosecTrain Trainer: any external party, those who will be there, right? Any external technical expertise, right? So, they will provide a specialized technical expertise, like network, cloud, application, AI, right? They will also assist in implementing the containment eradication recovery measures. InfosecTrain Trainer: and suppose the incident handler and the investigator during deep dive.

I hope all of you understood with the example. InfosecTrain Trainer: How, actually, the incident management happens in the organization, and how all the people play a... Major role there. InfosecTrain Trainer: And this example was more... important for the people, those who have not worked in the SOC. InfosecTrain Trainer: I know here, a couple of people, those who have experience with the SOC, they would have already seen this thing happening in day-to-day. But there are people here, those who have not worked with the SOC, so you need to understand exactly how the SOC and the incident management operates. Fatha: Sorry, one question on that. Is there a flow diagram, kind of, you know, representation where if the incident is known, unknown, there's some other fix, it leads to patch management, all those things? Flow diagram representation, is there anything like that? InfosecTrain Trainer: I have not created any flow diagram, but if you want, I can create one through AI and share it with you using the same context, or you can also create, you now understood the context, right? InfosecTrain Trainer: So, Alan, one more thing I'll tell you. The best part of you people, those who are preparing for the CISM now, so when I prepared, there was no generative AI, there was no ChatGPT, no Claude and all, right? I... I passed the AI SM yesterday. InfosecTrain Trainer: I used completely AI. InfosecTrain Trainer: I only purchased one AISACAM manual, which I could read, that's it. I did not purchase any books and anything. I completely rely on AI for that, right? I use the AI to create good questions and answers for me, right? InfosecTrain Trainer: So, any topic where I used to feel that I'm less confident, I'm not able to understand the technical concept, you know.

You have to do a prompt engineering. InfosecTrain Trainer: help me with the tricky answers, use this CISM mindset, use the first, most, greatest, main. InfosecTrain Trainer: And these keywords in the questions. Keep the questions maximum two lines, keep the options very strategic, and think like a manager mindset, and it used to generate me, and it helped me a lot. InfosecTrain Trainer: doing the practice. So you people also need to do this same thing. Fatha: cloud... InfosecTrain Trainer: Yeah, just do not only rely on the QA manual and the question banks shared by the InfosecTrain. Use extensive use of AI. It will actually help you in preparing for exam and also clearing the exam. InfosecTrain Trainer: So, that's what... even... even need not to go and read the topics from book these days, right? AI explains you in a much better manner, right? InfosecTrain Trainer: It even explain you in the very simplified manner, like the kid can understand. So you can... if you are not able to understand the technical know-how, you can say it, that I'm not able to understand, explain me like a kid. So it will do it. So that's what happens, right? So use the AI extensively when you are preparing for exam. InfosecTrain Trainer: Now, coming to the other important roles. So, other than the roles which we discussed, there are going to be the business managers. InfosecTrain Trainer: who are business managers? You're someone who is heading the... heading the... your... other... InfosecTrain Trainer: finance function, someone who is heading the... heading the development team, someone who is managing one particular region. Suppose you are a manufacturing organization, someone who is heading the factory, directors of factory, those are all the business managers.

They will also come into picture if their asset, their business is impacted. InfosecTrain Trainer: Then the risk management professionals, so your ERM team. InfosecTrain Trainer: They know what is the risk appetite, what is the overall risk from organization perspective, so they will also help you manage the risk properly in that scenario. Then the physical security manager. InfosecTrain Trainer: via them, if someone entered your... in your data center through force entry and caused some damage and all, so it's a physical security-related incident, right? But end of the day, it would be impacting information security. He went to your server and stole some information, right? InfosecTrain Trainer: So, they also need to be involved. Then, IT specialists, all the subject matter experts and the people from the diverse background, they will help. Legal representative, they're very important. Even the DPO, InfosecTrain Trainer: BPO Data Protection Officer InfosecTrain Trainer: Most of the time, what I have seen is a legal guy. I'm not sure in your organization if the role is being played by an IT person, but most of the time, I have seen the DPO being a legal person, so those legal person know InfosecTrain Trainer: the legal know-how, they know the compliance, they know the impact of this, they know the legal terminology, so they will help you manage. HR. InfosecTrain Trainer: If some insider threat was there, some internal employee was involved, he needed to be immediately terminated. InfosecTrain Trainer: Additional contractors from your contracting organization need to be onboarded. Suppose you have a contract InfosecTrain Trainer: With some organizations. So there's additional people need to be onboarded quickly in your environment, so they will help you.

Then, public relations team. InfosecTrain Trainer: Now, there is a big impact, like we've discussed in the previous case study, right? InfosecTrain Trainer: your entire EU region is gone, the news will get circulated in the media. InfosecTrain Trainer: probably news channels will also start covering by morning, right? So you have to engage media InfosecTrain Trainer: You have to inform them exactly what is the impact, what incident happened, and we are continue to focus, we are plan... trying our best to mitigate the impact, or you say it's already contained, now we are doing the forensic investigation. InfosecTrain Trainer: Now, what is the types of events? InfosecTrain Trainer: types of events which will happen. So, technical events are something... why I'm calling them events, not incidents. InfosecTrain Trainer: So if those are... those things are causing an impact to your organization, then it becomes an incident, right? Till the time there is no impact to you, it becomes... it's just an event, right? So technical events would be... InfosecTrain Trainer: Any network or virus Attack. InfosecTrain Trainer: DOS attack against your web application, system intrusion, process failure, someone caused a data breach, anything. Technical event can be any number of things, right? Someone, someone bypassed your firewall rules. InfosecTrain Trainer: Physical is something which physically visible or physically caused the damage, like someone stole some proprietary item. InfosecTrain Trainer: Someone did a social engineering. Person was sitting next to you, and then, actually listened to your conversation, saw, watched your screen in your laptop, and caused the damage. InfosecTrain Trainer: Your backup media was stolen from your... organization.

InfosecTrain Trainer: Your laptop or the phones got stolen. InfosecTrain Trainer: Environmental events which may become an incident could be floods, fire, earthquakes, or power outages. InfosecTrain Trainer: Now, how do you contain it? InfosecTrain Trainer: So you detected an incident, there is a ransomware incident going on, going back to the same case study which I took. InfosecTrain Trainer: Right? Now you have to contain the impact. Now your entire EU region is gone. Do you want it to propagate to the US also? InfosecTrain Trainer: You need to immediately make sure that incident is contained. InfosecTrain Trainer: Now... You remember I told you a story last week about, the JLR? InfosecTrain Trainer: People remember that story? JLR incident? Johnny Souriar: It's just... InfosecTrain Trainer: So, imagine such kind of incidents. InfosecTrain Trainer: Imagine such kind of incidents where there is a big impact InfosecTrain Trainer: You are not able to contain it on time. Imagine the kind of impact it did. Their business was shut down. InfosecTrain Trainer: Right? A 800 million euro was lost. InfosecTrain Trainer: 24 to 30 days it took them to recover. InfosecTrain Trainer: So, if they would have contained it on properly, they would have used the proper containment method. InfosecTrain Trainer: the impact could have been less, right? So that's why... what does containment do? InfosecTrain Trainer: Containment is a first step which you take After detecting the incident. InfosecTrain Trainer: To prevent the incident from spreading further. InfosecTrain Trainer: So, what you will do, To do that. InfosecTrain Trainer: But to take this action, you need a good knowledge of the incident, right? What type of malware is this?

InfosecTrain Trainer: What is this which is causing the incident? InfosecTrain Trainer: Right? If you don't know about the incident or know how initial information is not with you, how you are going to contain it properly, right? Once you do and know that, then you can do these steps. These are not limited to this, but there can be other steps also. The best thing is doing the network isolation. InfosecTrain Trainer: So, suppose I detected one particular machine is infected with the malware, what should I do? I should isolate it from network, or I should shut down the machine. InfosecTrain Trainer: What should I do? Should... shutting down is the best method, or should... network isolation is the best method? Johnny Souriar: Isolation, isolation. Fatha: Network isolation. InfosecTrain Trainer: Correct. InfosecTrain Trainer: So the isolation, why you do? Because if you... Because, if you actually... InfosecTrain Trainer: shut down the machine, the information which was captured in the RAM, And your cache is gone. InfosecTrain Trainer: So, always remember. InfosecTrain Trainer: Whenever you see a question in the exam, never, ever go with the option where it is saying the InfosecTrain Trainer: shut down. You always... first thing is that you pull out the network label. That's... is the literal sense what I'm saying, but these days, you do not pull out the network cable. Actually, you do isolate it through virtual or the logical rules, which you can set up in the firewall or any other means, right? InfosecTrain Trainer: So that network communication, if you cut down, now that person or that entity, that threat actor, that malware won't be able to propagate further to other systems or machines, right?

So you can create the firewall changes, you can create some IPS rule, you can do some changes in the Azure router setting, or block the traffic. InfosecTrain Trainer: Completely. InfosecTrain Trainer: What is CNC disruption? Command and control. Someone tell me, what is command and control? InfosecTrain Trainer: disruption. Fatha: from SOC or NOC, you try to contain or, you know, restrict that machine to that particular area or region or... Johnny Souriar: CC is the hacker, where he's collecting information from the agent and giving instruction to the Agent. InfosecTrain Trainer: Basically, the cyber attacker would have established a backward connection with your system, right? InfosecTrain Trainer: through a back door and whatever means he would have created, now you want to cut down this connection. InfosecTrain Trainer: Till the time he has this connection, he would be able to continue to propagate, launch an attack, do more damage. So you have to identify this particular mean, from which particular mean, he established the connection, and you have to cut down this

connection first. InfosecTrain Trainer: So, you have to block the command and control communication from infected system to attacker control server, from where he is controlling it. InfosecTrain Trainer: And this can be also done through networking method, through IPS system, or creating the DNS blocking. InfosecTrain Trainer: Next thing is the isolating the system. InfosecTrain Trainer: So you can isolate the system completely from the network, from the communication, right? So that person could not reach there, and from there further. InfosecTrain Trainer: the things cannot be propagated further to other systems, right?

So these are some of the method of the containment, but there are other... can be... these are at high level, what people can take InfosecTrain Trainer: Right? InfosecTrain Trainer: No. InfosecTrain Trainer: When you contained it, now, There are 4 servers. InfosecTrain Trainer: which are impacted due to the ransomware. You have isolated it from the network. Now, how about the business? InfosecTrain Trainer: How about the business application, which was running on these servers? How they will work? InfosecTrain Trainer: Now the application is stopped. InfosecTrain Trainer: now you have to activate the DR and BCP team. You have to engage them, because they are the one InfosecTrain Trainer: They are the one, those who will help you InfosecTrain Trainer: Actually, restoring it from the backup, creating 4 new servers, and then InfosecTrain Trainer: Handing it over to the business so that application can go online. InfosecTrain Trainer: It's not like that, that you... till the time you eradicate and remove forensic investigate, the application will continue to shut down, right? InfosecTrain Trainer: So that's why, in the incident or the... or the event which I explained to you, such kind of big impact incidents, often you need to, with the containment activities when you are creating, or the rules you are doing, you have to initiate the BCP as well. InfosecTrain Trainer: Right? InfosecTrain Trainer: When the attack has been contained through network curtailment, or CNC... or isolation, or any other things what you are doing, you need to do it. InfosecTrain Trainer: And where you require BCP, some example, suppose ransomware make critical production data enable. Now, ransomware is in 4 servers. InfosecTrain Trainer: These servers are gone.

InfosecTrain Trainer: there is a wiper malware, which actually removes the critical data. It goes and removes the data. The critical production data is gone. InfosecTrain Trainer: If denial of service attack has InfosecTrain Trainer: encapsulated your production system, it's not available, you have to use the standby system, right? You have to create it from the backup. InfosecTrain Trainer: And also. InfosecTrain Trainer: Apart from this, if the forensic team need to work on incident investigation, they cannot work on the production system. InfosecTrain Trainer: They will be working on these isolated systems, right? Because if they start doing a forensic investigation on production system, it may hamper InfosecTrain Trainer: the operations, right? Because of the tools they'll be running, or the queries they'll be running. So that's why you isolate the system, create the new system from the backup, and give that backup system to the business for the operations, so that forensic team can also help analyze this. InfosecTrain Trainer: Questions? InfosecTrain Trainer: Alright, let's discuss. InfosecTrain Trainer: Okay. InfosecTrain Trainer: I'll not show the answer. Let's go with the third... go with the elimination. InfosecTrain Trainer: First question, a SIM system generates an alert for multiple failed login attempts on a server. What is the primary factor that elevates this event to a formal incident requiring a structured response? Which two options you want to eliminate? InfosecTrain Trainer: Someone, which two options you want to eliminate? Johnny Souriar: Handy. InfosecTrain Trainer: A and... Johnny Souriar: B. InfosecTrain Trainer: B. InfosecTrain Trainer: Okay, why you want to eliminate B?

Johnny Souriar: The activity is confirmed to violate an information security policy. The policy... Johnny Souriar: when this event becomes an incident, it's not defining, right? Policy is a general overall Thing, actually. InfosecTrain Trainer: Is it? Or policy is something which is a broad term? Johnny Souriar: It's a broad term, right? InfosecTrain Trainer: Yes. InfosecTrain Trainer: So, anything which is a violation, broad term means everything is covered in the policy, right? InfosecTrain Trainer: Data breach is also covered, ransomware is also covered, social engineering is also covered, everything is covered in the policy. However, you do not mention it specifically InfosecTrain Trainer: But it covers... that's how you create a policy. If your policy is not covering everything overall. InfosecTrain Trainer: So that is not a good policy. Policy will only determine or say that anything which is significantly impacting the business to operate, business to function, or organization to operate is an incident. Pudir: Paul, this is... this is Pudir. Pudir: Policy is a very comprehensive word. Perhaps it may be defined under the definition for an event, an incident, how it can be ensured. But as far as D is concerned, it is, threat intelligence feedback. Basing on that feedback, it is a known indicator. Multiple times, the attempt was indicated Pudir: Failed indication. So that's a confirmed indication now. InfosecTrain Trainer: This, actually, you have forgot the first day when I talked about that think like a manager mindset. InfosecTrain Trainer: Anything which is looking too technical in nature. InfosecTrain Trainer: Also, something which is not an umbrella answer.

InfosecTrain Trainer: does indicator of compromise from a threat intelligence feed is not also part of the policies. I'm not saying the policy actually specifically mentioned an indicator of compromise, but policies say that, right, something which is actually InfosecTrain Trainer: something which is not... something which is causing an impact to the organization becomes an incident. So that indicator of compromise and everything is part of the policy also. Pudir: Okay, your version is... D is also covered in the B. InfosecTrain Trainer: Yes. Pudir: Okay, okay. InfosecTrain Trainer: So, A is eliminated, D is eliminated. Number of failed attempts exceeds the configuration... configured threshold. This is also covered of the policy. So, policy is an umbrella answer. InfosecTrain Trainer: So, whenever you are attempting question in the exam, just look for these umbrella answers, umbrella terms, which somehow cover all other options, right? InfosecTrain Trainer: Next, coming to the option... question number two, after an EDR system alerts on a successful malware infection, what is the main responsibility of a security manager regarding the incident notification process? Here, which two options you want to eliminate? InfosecTrain Trainer: Anyone, which two options you want to eliminate? Johnny Souriar: A and D. InfosecTrain Trainer: E and? InfosecTrain Trainer: D, right? Johnny Souriar: DDD. InfosecTrain Trainer: D, okay. Yes. Why you will inform all the employees about it? InfosecTrain Trainer: If they are... all of them are not impacted, right? So, it's eliminated. Directly quarantine the affected endpoint from network. So, question is talking about the notification, not talking about the quarantine, so it is, as such, out of context.

InfosecTrain Trainer: Now, manually verify the EDR alert, and immediately start the eradication. This also you can easily eliminate, because this is also not InfosecTrain Trainer: Related to notification process. Now you are left with C. InfosecTrain Trainer: Which is the best answer, assess the incident's business impact and determine who needs to be notified based on established escalation metrics. InfosecTrain Trainer: Alright, so this is the correct answer. InfosecTrain Trainer: That's how you have to build a reasoning, and that's what is the approach I want all of you to follow when you are attempting any question InfosecTrain Trainer: Currently, during the practicing, Also in the exam. InfosecTrain Trainer: If you are able to build this particular methodology, I can guarantee you 99.9% you will pass the exam. InfosecTrain Trainer: If you have this particular methodology, you master it, 99% I'm telling you, you will pass the exam. If you have a understanding around the topic, you will clear the exam, right? Next comes the next... which of the following is the first step in developing an incident response plan? InfosecTrain Trainer: So, what we discussed about the first, we go, we read all the options, and then we say that which will come first, right? Which two options you want to eliminate? InfosecTrain Trainer: Which, are the thing which would probably come last. InfosecTrain Trainer: Anyone, which two options you want to eliminate here? Pudir: Y ain's CISM. InfosecTrain Trainer: Okay, reasoning? Why you want to eliminate them? Pudir: Minimum time requirement to respond indicators, that can be an initial stage, a policy stage, that is not the first stage. As far as ensuring the availability of skilled resources, this is not the first step.

First of all, we'll have to categorize the issue, what is the impact it is having. InfosecTrain Trainer: Hmm, correct. InfosecTrain Trainer: So, A and C is gone, correct? Establish a process to report incident to senior management. InfosecTrain Trainer: That, also, you will do last, right? That is not the first step. InfosecTrain Trainer: How you will make sure that which incident need to be reported to incident? Can you do it without doing the InfosecTrain Trainer: Will you report all the incidents to them? InfosecTrain Trainer: You will only report those incidents which are a very... InfosecTrain Trainer: categorized P1 incidents, or critical incidents, with a significant impact. Even the option C would come after D. InfosecTrain Trainer: Once you know likelihood and impact, on the basis of that, you will decide that what should be the formulation of team. InfosecTrain Trainer: Right? So we discussed the incident management team, right? So that triaging which is happening between the SOC team. InfosecTrain Trainer: Does that SOC analyst and the SOC manager need to call the CISO, need to call other departments? How he will decide? InfosecTrain Trainer: Will every incident, he will keep calling everyone and create a bridge and invite 20 people to the call? Or he will only do it on the significant incident? So that's why first step is option D, then comes the other. InfosecTrain Trainer: The fourth question. A critical business application fails due to successful cyber attack, and the incident response team is unable to restore the services. Which plan is most strategically important for incident management program to leverage for containment of the impact? Talking about the containment. InfosecTrain Trainer: Which two options you want to eliminate?

InfosecTrain Trainer: We just discussed What is the next step from containment, right? InfosecTrain Trainer: Once you contain the incident, what you do next? Johnny Souriar: Assessed to the Korean business plan. InfosecTrain Trainer: Hmm. Yes. InfosecTrain Trainer: It's a straightforward. InfosecTrain Trainer: We

just discussed this topic, that as soon as you contain the incident, you have to initiate the BCP and DRP plan. So I hope everyone is clear with the reasoning. What is the reasoning you have to do? Sandeep Saxena: I didn't matter. InfosecTrain Trainer: However, you... Yes, indeed. Sandeep Saxena: Well, question 3. Sandeep Saxena: The question is. Sandeep Saxena: For example, I join a new company, and there is no incident response plan. I want to build that plan, right? Sandeep Saxena: So, this is what the question is all about. The first system in developing the plan, right? InfosecTrain Trainer: Yes. Sandeep Saxena: Am I getting it right? InfosecTrain Trainer: Yes, correct. Sandeep Saxena: Okay. So... I'm thinking about the plan, and categorize the incident based on likelihood and impact. Sandeep Saxena: What does it actually mean? What should I think? Sandeep Saxena: In that direction. Sandeep Saxena: Like, what incident may happen, or what? InfosecTrain Trainer: No, no, no. This is talking about... First, you need to understand InfosecTrain Trainer: How you will classify the incidents. InfosecTrain Trainer: When you are developing the plan, first you need to understand how you will classify those incidents, then you will InfosecTrain Trainer: Actually, incorporate that... InfosecTrain Trainer: What kind of skilled resources is required whenever you are handling those incidents. It's not talking about the skilled resources to develop that plan.

InfosecTrain Trainer: For creating a plan, you will not, hire a team. InfosecTrain Trainer: Plan would be created by your security manager only. InfosecTrain Trainer: It's talking about the availability of skilled resources to handle the incidents. InfosecTrain Trainer: It's not talking about the availability of critical resources to create the plan. InfosecTrain Trainer: I think you misunderstood, Sandeep. You thought that this is talking about the skilled resources to create the plan. Plan would always be developed by the security manager only. InfosecTrain Trainer: Yeah, so... so... so now you understood why option C is incorrect? Sandeep Saxena: Okay, thanks. InfosecTrain Trainer: Yes, so these are the correct answers. InfosecTrain Trainer: Now, communication. InfosecTrain Trainer: Now, you have... contained the incident. InfosecTrain Trainer: initiated the recovery plan. System is isolated, right? InfosecTrain Trainer: Now... InfosecTrain Trainer: the business is running, you have already handed over the new servers to the business, business is able to operate, now you need to notify and inform key stakeholders, right? InfosecTrain Trainer: So, communication is also very important. If you are not informing people on time, you are not communicating them on time, and InfosecTrain Trainer: If you are not... if it contained the incident, incident is still ongoing for multiple days. InfosecTrain Trainer: You need to inform to multiple people. Probably you need to inform the law and enforcement, you need to inform the regulators, you need to inform the external stakeholders, those who will be helping you with that. So how you will inform that? You read a good incident response communication plan, right? InfosecTrain Trainer: First thing. First rule is that timely, Right?

InfosecTrain Trainer: Next is that specific InfosecTrain Trainer: specific details. Customers... suppose there is a bank which got impacted due to a cyber incident. Will that bank InfosecTrain Trainer: actually give details to the customers that, this was the ransomware gang who came in, this was the indicator of attack, this was the indicator of compromise, it went, bypassing our email gateway, came via phishing and all. Why do they need to know those things? InfosecTrain Trainer: They need to only know that there is a cyber incident impacting their data, or there is a cyber incident impacting their banking application, and application would remain unavailable for XYZ time, and then we are making all our effort to make it live, so... InfosecTrain Trainer: So that, you have to make sure. Then limit the communication only to the authorized people. InfosecTrain Trainer: So, in the previous question which we saw, communicate to all employees. Why all employees need to know? InfosecTrain Trainer: consider using out-of-band channel. So the case study which I explained to you, right? InfosecTrain Trainer: What was out of band channel? Phone. WhatsApp call. InfosecTrain Trainer: Because in the... over the night, if you ping or drop an email to your man... your SOC manager or team lead, will they be able to check? No. They are sleeping. InfosecTrain Trainer: So you have to call them or the mobile, right? This is something which is going on, we need your help. InfosecTrain Trainer: And then crisis management. So, many organizations employ the crisis management or crisis communication InfosecTrain Trainer: procedures. So, what is the crisis? InfosecTrain Trainer: Crisis is something which is having wide impact.

InfosecTrain Trainer: And the scenario which I explained was very well fitting into that particular criteria. Your entire European region services are down. A crisis. InfosecTrain Trainer: Right? InfosecTrain Trainer: So then, you have to create a crisis management protocol, right, so that you can mobilize the resources, mobilize the leaders, mobilize the people, have... assemble steering committee, inform senior management, so that the adequate amount of effort and adequate amount of due diligence can be done on the internet. InfosecTrain Trainer: Now, how you establish a communication channel? InfosecTrain Trainer: So, incident happened. InfosecTrain Trainer: You know the impact, Now you are doing the... Containment, eradication... InfosecTrain Trainer: and recovery, all the things are going on. You have to establish some communication channel a little this time, right? So, communication channel, you need to establish with the senior management. InfosecTrain Trainer: With the incident management team, with the stakeholders. InfosecTrain Trainer: So that all of them are informed, right? InfosecTrain Trainer: So this communication channel, you can actually, in a normal scenario, all those people who have worked in the SOC team, right? Something is called the SOC bridge. InfosecTrain Trainer: So you establish one SOC bridge, where all the people will join. It's going to be a normal Teams call, Zoom meeting call and all, where all the people will join, join, and they will continue to help and support till the time incident is contained. InfosecTrain Trainer: This is first method. Second method, you will establish one email chain, or a regular meeting, which probably your CISO will drive.

InfosecTrain Trainer: Where he will continue to inform, probably, your senior management people, business... Business heads InfosecTrain Trainer: all those peoples, right? They also need to know what is happening with that incident, if their information, their departments are impacted. So this is the second communication channel. InfosecTrain Trainer: This is how you establish the communication channel. InfosecTrain Trainer: Then, once you establish these communication channels, then you need to understand, are there additional audience who need to be added, or additional communication channels need to be established? Then you will ensure that information is conveyed properly to the respective audience. InfosecTrain Trainer: So, senior management, you will properly communicate what they need to know. InfosecTrain Trainer: You will properly communicate the information, what your customers need to know. InfosecTrain Trainer: you will properly communicate the information, what people need to know in the SOC bridge, because those are the technical people in the live scenario solving the issues, right? And then you will provide the alternative sources also, if this is not working. InfosecTrain Trainer: If, suppose, you have a web... website, web application, which is impacted. InfosecTrain Trainer: What is the alternate source? You have the email IDs of your customer. You will probably drop a bulk email to them to notify them, inform them about it. InfosecTrain Trainer: If your email gateway is compromised, you will probably do a notification through your website. So... InfosecTrain Trainer: alternative method, or if all of them are compromised, you will use the media.

You will probably contact the local media channel and to tell them to InfosecTrain Trainer: circulate that communication to all their customers so that they can take all the steps, right? InfosecTrain Trainer: Now, incident notification. InfosecTrain Trainer: So, the incident notification is a very important legal and regulatory InfosecTrain Trainer: item, which helps you notify the important people, right? It emphasizes that the requirement InfosecTrain Trainer: Of the regulations are being met, and every organization is actually InfosecTrain Trainer: facing different, different regulations. So, healthcare is facing different regulations. InfosecTrain Trainer: Financial institutes, facing different regulation, and also depends on the region. InfosecTrain Trainer: And all of them have a different notification protocol, so you have to create a consolidated comm protocol so that all of those requirements are being met. InfosecTrain Trainer: Then, contractual obligations. So, if you have third parties, those who are supporting you or working with you, they also create obligations. They say, whenever there is an incident impacting our data and information, please inform us in 24 hours. InfosecTrain Trainer: So you have to avoid to those things. Then, severity and risk assessment. Also depends on the how severe the incident is, then the InfosecTrain Trainer: The frequency may change. InfosecTrain Trainer: Right? InfosecTrain Trainer: So that severity will also determine that, and then what is the information which you need to include in that incident? That also depends. What is the data? What is the information? What details about the incident you want to notify to the people?

So the incident notification going to InfosecTrain Trainer: CEO and the senior management would be different. Incident notification going to your customers would be different. Incident notification going to your other third-party partners would be different. InfosecTrain Trainer: And then accuracy and timeless is very important. If you are not able to do within the time, like 72 hours, 24 hours. InfosecTrain Trainer: then you are breaching that particular contract and that particular regulation guidelines. And then information should be always accurate. You should never hide any important data, right? Otherwise, later you will face the ethical and the regulatory challenges. InfosecTrain Trainer: So, this is a slide which I have created. However, they are not going to ask you these regulatory reporting timelines in the exam, right? This is just to give you a perspective how InfosecTrain Trainer: Actually, so many regulations impact the overall communication protocol, right? You see GDPR InfosecTrain Trainer: Now, imagine a country, a healthcare country. InfosecTrain Trainer: Doing business in EU also, doing business in US also? InfosecTrain Trainer: also having a business in India. InfosecTrain Trainer: Now, they get applicable with the GDPR also, they need to apply NISTU also, they need to apply DPDP also, HIPAA is also applicable to them. InfosecTrain Trainer: So many of them and all of them have a different timeline. GDPR says 72 hours, NISTU says 24 hours, US SEC public company says 4 business days, HIPAA says 60 days. InfosecTrain

Trainer: If more than 500 record, DPDPA says the without delay, as soon as possible. PCI IDI says the immediate to CRAD brands and acquirer, right? So you see, different notification timeline you have to meet. Otherwise, see the penalties.

InfosecTrain Trainer: GDPR charges you 20 million euros, or 4% of global turnover. It's a big amount. InfosecTrain Trainer: NIST tool charges you 2% of turnover, big amount. InfosecTrain Trainer: So, if you want to avoid these penalties, get adhered to these notification timelines. InfosecTrain Trainer: Now, the next step is the eradication. You have contained the incident. InfosecTrain Trainer: You have initiated the BCP TRP plan. InfosecTrain Trainer: You have notified to the people now coming to the eradication, where you want to eradicate that particular malware, that particular ransomware. InfosecTrain Trainer: whatever was the threat actor who came into your environment, you want to remove it from your environment, right? Otherwise, if it still persists in your environment, it will continue to propagate, or probably at the later stage also can InfosecTrain Trainer: Cause a damage, right? InfosecTrain Trainer: So you want to completely remove the threat agents and the root causes of the incident, right? InfosecTrain Trainer: But it will be done after the containment, and before the recovery begins. InfosecTrain Trainer: So, in the eradication, you follow the five key steps. First step is understanding the root cause. If you know what was the root cause, what was the indicator of attack, what was the back door. InfosecTrain Trainer: Used by... what was the command and communication established by the person? InfosecTrain Trainer: You will be able to do the proper eradication. InfosecTrain Trainer: Then you will remove all the malicious artifacts left by the attacker. You will delete the malware, rogue account, any backdoors, any persistent mechanism, any command and control channels, any altered configuration, any configuration changes the person has done.

InfosecTrain Trainer: You will also... InfosecTrain Trainer: rebuild, re-image the system, right? For deep infection, right? If they have established the rootkit firmware or hypervisor-related issues they have caused, or there is a wiper, they have wiped the rebuild from the trusted verified golden images that you need to do, then you need to patch and harden. InfosecTrain Trainer: You need to apply the necessary patches if they... suppose it was a zero-day attack. Now the patch is available from the... InfosecTrain Trainer: company, you have to immediately patch it so that that particular vulnerability is gone. And then, need to validate the removal, so you have to do a scanning, integrity check, also perform a threat hunting to ensure InfosecTrain Trainer: That the completely threat is removed from your environment. InfosecTrain Trainer: And why, in the modern days, it's hard? InfosecTrain Trainer: Let me tell you. InfosecTrain Trainer: It's hard, actually, these days, because... InfosecTrain Trainer: The kind of malware these days the attacker prepares, they actually hide in such kind of processes, which is very difficult to actually make note of. InfosecTrain Trainer: like, living off the land, like living in the PowerShell script, PSX, right? InfosecTrain Trainer: Or there are some fileless malware, which do not leave any... create any files, run only in memory. There is no disk artifacts available. Or there are some anti-forensic malware, which are... which actually are encrypted in nature. InfosecTrain Trainer: What is technography? Pudir: It looks like a normal document, but some... Pudir: Hidden message is available in the text documents. InfosecTrain Trainer: Yes, it can be text or image, anything. Pudir: Yes, yes, yes. InfosecTrain Trainer: Yeah.

InfosecTrain Trainer: Or hiding behind the memory registry slack space, or below the operating system, or supply chain implants. So what are the key considerations for the manager? He needs to confirm first the containment is done. InfosecTrain Trainer: He need to preserve all the evidences, he need to coordinate with the legal and HR team, used all trusted InfosecTrain Trainer: offline tools, If it's a ransomware, need to rebuild, he cannot decrypt InfosecTrain Trainer: In the ransomware, you cannot decrypt, there is no possibility, because the breaking the encryption from an advanced supercomputer also will take a lot of time. InfosecTrain Trainer: Then need to rotate all the credential of the people, right, those who are affected, update the threat intelligence and the indicator of compromise, and documenting the actions. InfosecTrain Trainer: Now, what are the common eradication activities? You can delete the malicious code file persistent mechanism for all systems. You can apply critical security patches, update and configuration fix to exploit the system, right? You can disable the compromised user service account and force password reset. We already discussed, right? Identify and remove any unauthorized persistent access mechanism, backdoors. InfosecTrain Trainer: by them. InfosecTrain Trainer: Any severely compromised system, you probably need to rebuild, re-image from the trusted sources. You need to scan the infrastructure for any additional IOCs, and also identify InfosecTrain Trainer: And physically or logically remove any unauthorized hardware or the software. InfosecTrain Trainer: Now, once the eradication is done, now you need to recover. InfosecTrain Trainer: So what you do as part of recovery.

InfosecTrain Trainer: So, you need to validate, monitor, search, remove, and remediate. These are the five things what you will do. In the validation, once you recovered the system to the normal, you need to check all the baselines are being met or not. If, suppose, it was an end point. InfosecTrain Trainer: For a server, you need to see, okay, my baseline says there should be antivirus, there should be an EDR agent running and installed, this should be the minimum version of the OS, should be there, you will validate all those things. InfosecTrain Trainer: Then you will also monitor in the recovery for any additional known indicators of attacks and the compromise, if it is available, right? InfosecTrain Trainer: You will also actively search any adversary artifacts. Any adversary has left, any backdoors, any malware, or anything which they have left. Then you will move recovered system back to the production. InfosecTrain Trainer: Like, I took an example of those 4 servers, right? InfosecTrain Trainer: Now, those four servers, the forensic is done. Now, those four servers, you give it back to the normal, to the operations, right? Because, system, or probably those four servers would... may get utilized for some other purpose. InfosecTrain Trainer: You will not continue to keep them in containment, because you have already paid the amount to the cloud vendor, or you are already paying price in the on-prem setup, right? Then you need to remediate the root cause of the incidents. InfosecTrain Trainer: Once everything is done, now time comes to close the incident. InfosecTrain Trainer: Officially, you can close the incident, right? So, first thing is that you will archive the evidence.

InfosecTrain Trainer: All the log files, all the systems what you used, all the data what you used. InfosecTrain Trainer: probably all the meeting notes, all the communications which was used, everything need to be archived, right? You have to create separate folder, because tomorrow there can be an audit, or probably there can be a forensic investigation, or an investigation launched by any external parties, so you need complete evidence. InfosecTrain Trainer: Also, you keep all the communication records. InfosecTrain Trainer: You check that all the people are notified, that we have completed our forensic investigation, we have recovered the system, everything is done properly. InfosecTrain Trainer: Now, system is back to normal, there is no incident, or there is no, threat remains in our environment if we are completely secure and running normal. InfosecTrain Trainer: Then, reporting the insurance. Suppose you have a cyber insurance, and you need to claim the amount and the effort which you InfosecTrain Trainer: Invested, or suppose in the process, if you have paid the ransom to the ransomware gang. InfosecTrain Trainer: So that amount you need to recover from the cyber insurance company. InfosecTrain Trainer: And always remember, the everything, whatever you are doing, the recording, right, always need to be protected properly. InfosecTrain Trainer: If you're keeping these artifacts in the normal drive, then it's, again, a problem, because it will contain a lot of sensitive information in it. InfosecTrain Trainer: Now, what are the other post-incident activities? You will document the incident. InfosecTrain Trainer: You will gather the stakeholder review and their feedback, all the people, your customers, your senior management, and all the people.

You need their feedback. What went wrong, what went bad. You will report finalization for the senior management. Now, they need to know. InfosecTrain Trainer: what was the lesson learned? Why actually that incident happened? What was the bad what you did? You also need to identify the issues and the challenges if something is there in the current process. Update the existing processes if needed. InfosecTrain Trainer: develop the remediation plan and seek resources and the funding and the approval, whatever, if needed. Suppose you need to onboard new tools, you want to upgrade the infrastructure, you identify there are the gaps in the current resource level, you have to onboard new resources, those approval, you will see. InfosecTrain Trainer: So, what are the benefits you get if you maintain a comprehensive incident documentation? InfosecTrain Trainer: First thing, it helps you in the thorough forensic investigation. InfosecTrain Trainer: So the forensic investigations sometimes may go InfosecTrain Trainer: further for the longer period of time, or may also order later stages also. So they will be reviewing these records, everything. Even in case of normal murder, I told you, right. InfosecTrain Trainer: The forensic investigation in the cyber is almost equivalent to what you do in the murder cases. So you would have seen, whenever there is a murder. InfosecTrain Trainer: and the doctor do a post-mortum, right? He do autopsy of the body. All those things are preserved for a longer period of time. InfosecTrain Trainer: Because later on, again, court may order another investigation, or they want to check something, so that's why the things are always stored.

InfosecTrain Trainer: Then, it helps you enable the effective lesson learned for improvement that you will gather, helps you with the legal and the regulatory compliance, right? InfosecTrain Trainer: So that tomorrow, if GDPR, DPDPA, NISTU, they came back to you saying that you, there is an insignificant incident in your environment, you don't have followed the protocol, you are violating the laws. So, you have to prove it to them. InfosecTrain Trainer: Helps you facilitate the accurate stakeholder communication, and helps you guide the precise recovery and the restoration efforts. InfosecTrain Trainer: Now, this is a very important topic. InfosecTrain Trainer: data preservation procedures. You will get some couple of questions on these topics, right? So, first thing. InfosecTrain

Trainer: What do you mean by a legal holder? InfosecTrain Trainer: A forensic expert InfosecTrain Trainer: come and collect the evidence from your environment. He should have a legal hold, he should have a legal notice to him that he is authorized person to InfosecTrain Trainer: Fetch those relevant documents, because tomorrow you want to file a case in a court, or you want to fight against someone. InfosecTrain Trainer: these things will come into picture, right? So you have to immediately issue a formal legal hold notification to all relevant custodians to suspend the routine data destruction policy so that they don't destruct... they continue to retain the logs, and they have to potentially InfosecTrain Trainer: Relevant digital and the physical information is completely restored, right? InfosecTrain Trainer: Now, there are two terms. Something is called the chain... Alt... custody. InfosecTrain Trainer: viruses. InfosecTrain Trainer: All... evidence.

Someone tell me, what is chain of custody, what is chain of evidence? What is the difference? InfosecTrain Trainer: Anyone? Johnny Souriar: Okay, enough custody is the matter, how you are collecting and preserving data, which is acceptable in the court of law. InfosecTrain Trainer: And what is chain of evidence? Pudir: It's a relevant document, sir, connected to the incident. InfosecTrain Trainer: Okay, let me, let me, let me give you an example. InfosecTrain Trainer: So... Your forensic investigator came. InfosecTrain Trainer: He went to... logged into this PC, he collected the logs from this endpoint. Then, from here, he accessed one server. InfosecTrain Trainer: From here, here he collected the logs, then he went to a database, he collected the log, then he went to the CIM solution, he collected the log. Likewise, this is actually called the chain of evidence. The sequence in which the evidence is obtained is called the chain of evidence. InfosecTrain Trainer: Chain of custody is actually InfosecTrain Trainer: preserving the integrity of the evidence, what you have collected. So, all the information what person has collected would probably store in a InfosecTrain Trainer: Hard disk or a media drive where he is collecting it. InfosecTrain Trainer: Now... InfosecTrain Trainer: What if someone tamper with this? What if this particular media is presented into the court, and court say... and the person who is getting prosecuted, he will say, no, I do not believe it. They have tampered it, and they are trying to frame me. InfosecTrain Trainer: how you are going to prove it. So that's why you have to preserve the integrity of this. So how you do that? You would have heard about the hashing. InfosecTrain Trainer: Hashing, do you have heard?

InfosecTrain Trainer: All of you are aware about what is the hashing? InfosecTrain Trainer: So, hashing is something which helps you InfosecTrain Trainer: preserve the integrity. So once you got all the evidence here, you will create a hash. InfosecTrain Trainer: You will create a hash function of this complete evidence. Now, once the information is handed over to some another person. InfosecTrain Trainer: This another person is probably another expert, who will again run some commands, do some information, he will check that whatever was there in the evidence and all. InfosecTrain Trainer: Again, he will create the hash. InfosecTrain Trainer: Then he will go deposit this in some InfosecTrain Trainer: Storeroom, or wherever you conserve these evidence. InfosecTrain Trainer: Again, he'll show that this is the hash. InfosecTrain Trainer: So that there is a chain of custody, who handled the evidence at what time, and what were the change... there were no changes being introduced by this person in the evidence, so the integrity of the evidence is maintained throughout the life cycle. So it is basically meticulously document every transfer, access, and handling of evidence, including timestamps. InfosecTrain Trainer: Who was the person handling it, and the reason to maintain the integrity in the legal and the court of law. InfosecTrain Trainer: Then comes the forensic imaging. So, there is something called the bit-by-bit copy. InfosecTrain Trainer: This is the best way of preserving the forensic investigation... forensic evidence in... whenever you are taking... so whenever you go and fetch the evidence for the forensic investigation, you... InfosecTrain Trainer: go with the bit-by-bit copy, which capture all the information from the system, not the normal imaging.

So this bit-by-bit copy is called the immutable, or the forensic image. InfosecTrain Trainer: of all the drives, RAM, and all the things you will do, then you will generate the cryptographic hashes, so that you can ensure that the integrity of the evidence is maintained, and store this in the secure storage, as I told you. InfosecTrain Trainer: Secure storage access wall, so that no one without authorized permission could reach there. InfosecTrain Trainer: Now, what are the legal aspects of the forensic evidence? Chain of custody, I've already explained, so you need to maintain a chain of custody. InfosecTrain Trainer: And all the forensic team, they generally have a standard operating procedure checklist, right, which they use InfosecTrain Trainer: To follow all the steps, so that they are not missing any steps in between. InfosecTrain Trainer: And they need to sign an NDA with the organization, because they will be looking at very sensitive information, data, and may have some information which may cause harm to the organization at the later stage. It is necessary that organizations sign an NDA with them. InfosecTrain Trainer: Maintain up-to-date logs, and have a template of evidence reporting, which they should follow. InfosecTrain Trainer: some questions. InfosecTrain Trainer: Yeah, on the topics, what we just discussed. InfosecTrain Trainer: Follow same elimination technique, what we discussed. InfosecTrain Trainer: Alright, let's see the correct answers. InfosecTrain Trainer: So the first question, a CISO is leading an incident response effort where a sophisticated attacker has gained a foothold during the eradication phase. Which actions represent the most critical consideration to prevent a rate crash? Which two options you want to eliminate?

InfosecTrain Trainer: Which two options you want to eliminate? Anyone? Johnny Souriar: B... B and C. InfosecTrain Trainer: B and C, OKY. Johnny Souriar: This disconnecting compromised host from network, it is not a recurrence. InfosecTrain Trainer: Yes, and as such, the question is talking about the eradication phase, and this is a containment. InfosecTrain Trainer: Got it? InfosecTrain Trainer: So, eliminated. Johnny Souriar: concier. InfosecTrain Trainer: Yes. Deploying and firewall rule to block, this is also a containment, not an eradication activity. InfosecTrain Trainer: Now, you are left with the option A and D. Now tell me, which is the correct answer, Johnny? Johnny Souriar: D. InfosecTrain Trainer: DYD. Johnny Souriar: CA tech, which are the controls, gaps in the organization, that we need to fix it. InfosecTrain Trainer: Correct. InfosecTrain Trainer: Patching-only vulnerability is just one method. There can be other gaps also left in the system, right? This is not... InfosecTrain Trainer: Some... this particular is also part of it, which is somehow addressing the issue, but there could be other gaps also in the system, right? Vulnerability is just one part of it. This is something which is... which covers A also, that's why correct answer here is D. InfosecTrain Trainer: Now, next. InfosecTrain Trainer: Which of the following technique would primarily include the method and the practices aimed to unveil the intention and the extent of cyber attack against an enterprise? InfosecTrain Trainer: Which is the best method here? InfosecTrain Trainer: Which two options you want to eliminate? Johnny Souriar: A and B can be eliminated. InfosecTrain Trainer: A and BY?

Johnny Souriar: Vulnerability assessment is... Just kind of identifying any vulnerabilities in the systems, so... InfosecTrain Trainer: Okay, and B, via routine. Johnny Souriar: The team is also in an attack simulation. InfosecTrain Trainer: Then which is the correct answer? Johnny Souriar: Post-incident review. InfosecTrain Trainer: No, correct answer is forensic analysis. The question is saying... InfosecTrain Trainer: unveil the intention and extent of cyber attack. Post-incident review, I told you multiple times. Post-incident review is a process to analyze the incident management process. InfosecTrain Trainer: not to analyze the incident technical know-how, how the incident came into environment, those things you will do as part of the forensic analysis. Lot of people get confused between the forensic analysis and post-incident reviews. Please keep this in mind. InfosecTrain Trainer: Whenever you are approaching the questions. A post-incident review is about how to improve the incident management process, right? How to improve the communication protocol, how to... probably is the people training are lacking? What... was there a method we could have improved the containment? InfosecTrain Trainer: Was there a method we could have improved the engagement with the BCP TRP team? So, all those things are part of post-incident review. But the forensic analysis is something where you will dig deeper, you will understand what are the practices used by the attacker, and how the extent was attacked was against the enterprise. So, correct answer here is D. InfosecTrain Trainer: Last question. Following a major data breach, the CISO is tasked with preserving digital evidence for potential legal action. What is the most critical element to ensure the evidence admissibility in the court?

We just discussed this. Which option... which is the correct option here? Johnny Souriar: Trainer custody. InfosecTrain Trainer: Yes, so it was straightforward, we just discussed, the chain of custody is something which helps you with the admissibility of, evidence in the court. InfosecTrain Trainer: So this is the correct answer. InfosecTrain Trainer: Alright, so this is the next topic, which is the BCP DRP, right, in this particular domain, and we'll start this after the break, right? InfosecTrain Trainer: So let's take a break, and after a break, we'll get started with this topic. InfosecTrain Trainer: Alright, I hope everyone is back. InfosecTrain Trainer: Let's get started with the next topic, right? InfosecTrain Trainer: Which is the business continuity planning. So, we have discussed that how disaster recovery and business continuity plan come into the picture when there is a containment method which gets evoked. InfosecTrain Trainer: Now, first to understand how you build a BCP in organization. So, BCP plan is also directly related with your risk management. InfosecTrain Trainer: How? This particular diagram I'll show you. InfosecTrain Trainer: So, in the risk management, what was the process we discussed? Someone tell me, just walk me through. InfosecTrain Trainer: In the risk management, what was the process we discussed? What we did first? InfosecTrain Trainer: What was the first step in the risk management? Supriya Mhatre: Identification. InfosecTrain Trainer: Yes, risk identification. As part of the risk identification, what were the activities we did? InfosecTrain Trainer: What were the key activities we did as part of the risk identification? InfosecTrain Trainer: Identify asset, identify vulnerability, identify threats, right?

InfosecTrain Trainer: What is the next step in the risk management? After risk identification? Let's do a quick revision. InfosecTrain Trainer: Once risk identification is done, then what you do? InfosecTrain Trainer: Risk analysis. InfosecTrain Trainer: What you do as part of it. What are the three techniques we discussed? Fatha: B.A. InfosecTrain Trainer: BIA, qualitative, semi-quantitative, and quantitative, right? InfosecTrain Trainer: And then the risk. InfosecTrain Trainer: Response. What were the four risk response techniques we discussed? InfosecTrain Trainer: Anyone? What are the four techniques which we discussed? Shweta Sundar: That should be risk mitigation, transfer, Avoid... InfosecTrain Trainer: mitigate. Avoid... Transfer, and what was the last? Shweta Sundar: Excellent. InfosecTrain Trainer: Right. You need to have these things in your mind, on your fingertip, I'm telling you. If you don't know these processes, it would be very difficult for you to approach the questions. So that's why, once we finish this particular domain, I'll quickly give you the tips InfosecTrain Trainer: If you follow those steps, follow those steps till the time you write the exam, it would become very easy for you to clear the exam, right? So you have to follow those steps. Otherwise, you will start forgetting these topics, right? InfosecTrain Trainer: So, first thing, what we did, risk identification. So, you identified the potential risk for your organization. InfosecTrain Trainer: Then you assessed these risks, and already the things are written here in the slides only. Then you assess the risk. InfosecTrain Trainer: Out of those identified risks, there would be some potential risk which is impacting your organization as per the assessment.

InfosecTrain Trainer: Then you actually do the risk response, where you deploy some security controls to mitigate these risks. InfosecTrain Trainer: But even after the mitigation, there is some residual risk which is left, which you cannot completely 100% roll out. InfosecTrain Trainer: All the residual risk, you have to create a contingency plan. InfosecTrain Trainer: So, whatever you could not InfosecTrain Trainer: mitigate, you have to have a contingency plan, and that contingency plan is the BCP. InfosecTrain Trainer: So this is the BCP BIEA process. InfosecTrain Trainer: Take a screenshot of this. Very important. InfosecTrain Trainer: Thing to remember from exam perspective. InfosecTrain Trainer: First step is... structure. InfosecTrain Trainer: What you do as part of the structure is scoping. InfosecTrain Trainer: It's part of the structure. InfosecTrain Trainer: First, you have to do the scoping, you have to structure the BIE exactly what you want to assess. InfosecTrain Trainer: which all processes would be included, which all business functions you will assess as part of this. Once you have that structure ready, then you will identify who all are those stakeholders who will support me in this BIA process. InfosecTrain Trainer: Then you will establish the meeting with all those business leaders, business ads, stakeholders, to understand about their business, which are the critical processes. We discussed the BIA process, right? InfosecTrain Trainer: then you... Do those interviews InfosecTrain Trainer: Where we note down all the things, right? Okay, Business A, business B, business C has 5 critical processes, 6 critical processes, 7 critical processes.

Overall, this business, if it is down for 1 hour, it will have the... the... the 10 million impact, this will have the 20 million impact, this will have the 15 million impact. InfosecTrain Trainer: So, likewise, you analyze the responses, you review the minutes of meeting, and then you do the final analysis. You create a BIA process, okay, you say, okay, Business B InfosecTrain Trainer: is the priority 1, C is the priority 2, A is the priority 3 in terms of the recovery. InfosecTrain Trainer: What is the output of BIA process? We discussed. What is the output of BIA process? Johnny Souriar: Business Criticality Process and Systems Identification. InfosecTrain Trainer: Correct. You get the business criticality. InfosecTrain Trainer: You get to know from this which all businesses, which all processes are more critical in nature in the organization. InfosecTrain Trainer: Now, what are the important goals of BIA? Discussed. First. InfosecTrain Trainer: Goal is to criticality prioritization, understanding which all are the critical business Processes, critical business units. InfosecTrain Trainer: Then... and then you need to evaluate the impact of incident on them. InfosecTrain Trainer: So, if there is an incident, which critical process will get impacted more, which will have the more downtime, and then you do this crea... then you get this criticality list. Second thing what you... InfosecTrain Trainer: get from the BIA, you can get an estimate for the MTD and MTO. What is MTD and MTO? InfosecTrain Trainer: We discussed in the last domain, MTD and MTO. Shweta Sundar: I think next week, sometime in, both are... Max? InfosecTrain Trainer: Maximum tolerable outage and maximum tolerable downtime.

InfosecTrain Trainer: And this is equivalent to risk capacity, means... InfosecTrain Trainer: If your system remains down even one second beyond this time, there is going to be significant impact to the enterprise, in terms of loss of reputation, revenue, and all. So, it is basically the maximum time a system can remain down. InfosecTrain Trainer: So you estimate this. Also, you identify the resources which are needed for those critical processes to restore, and then you prioritize the time-sensitive and high-impact processes accordingly. InfosecTrain Trainer: So this is what you do in the BIA process. What are the elements of the BIA, right? InfosecTrain Trainer: So, in the BIA process. InfosecTrain Trainer: you need to first describe what is the critical mission of each business process, what exactly that business process do, what is their role in overall business to work? Like, like, if I talk about the Amazon. InfosecTrain Trainer: e-com. InfosecTrain Trainer: So, Amazon e-commerce, if you go to Amazon, has a multiple line of business. InfosecTrain Trainer: They have on Amazon now, They have one Amazon Fresh. InfosecTrain Trainer: They have one Amazon... e-comm... InfosecTrain Trainer: which is... which covers other things, like ordering electronics, ordering clothes, and all, right? Amazon Pay, and other. InfosecTrain Trainer: So, all of these are the different, different line of business, right? So, what is the mission of each of them in achieving our overall objective? So, all of them might not be generating same amount of revenue for e-com, for the overall Amazon as a business, right? Some of them would be more critical in nature, like probably this one. InfosecTrain Trainer: this process generates the maximum amount of revenue for them.

So that's how you need to understand what is the mission of each business processes, each business function, in overall our achieving the business objectives. InfosecTrain Trainer: You need to identify the functions that characterizes the each business function. Under these functions, also, there are going to be some critical processes. InfosecTrain Trainer: Some critical application, critical server, critical people... InfosecTrain Trainer: critical technology, all those things you have to categorize. Also, you need to determine the dependencies between them. Let's say there is an API integration with Amazon paid with this. InfosecTrain Trainer: If this goes down, then people will not be able to do the payment in this, this, this. InfosecTrain Trainer: So if Amazon pays down, people are not able to do the payment, all of them. So... InfosecTrain Trainer: It's a critical process, right? InfosecTrain Trainer: Also, you need to determine the subsequent operations dependent on each function, right? InfosecTrain Trainer: identify the critical process cycles in terms of the time interval of each function. How much time InfosecTrain Trainer: This function requires in terms of the recovery, in terms of the restoration, right? And then you need to estimate the impact of incident on each business function. And overall, this exercise, what it will give, it will help you determine the RTO. InfosecTrain Trainer: Recovery time objective means how much time you require to recover this particular business if tomorrow it's down. It will help you determine how many resources, activities, and funding I needed to restore this. InfosecTrain Trainer: Also, we'll help you determine the amount of data That can be lost.

InfosecTrain Trainer: if this particular business process is down, also help you estimate the amount of time that a recovery could take relative to RTO. So, all these particular things, this BIA process will determine for you. InfosecTrain Trainer: Now... Criticality analysis. InfosecTrain Trainer: So, once you did a BIA, as part of this, you will find some particular systems, some particular processes, which are very critical in nature, like which dependence on multiple, like your payment gateway. InfosecTrain Trainer: In Amazon example, payment gateway was critical process, because if that is down, even if your e-commerce, your Fresh, your Amazon Now business is up and running, people will not be able to do the payment. If they are not able to do the payment, how they will purchase those items, so is a critical process. InfosecTrain Trainer: So, those critical processes are not only in terms of processes, this is also in terms of other things, like network. InfosecTrain Trainer: Your traffic is coming from single firewall switch. InfosecTrain Trainer: If this goes down, your entire system is down. Your organization is receiving the InfosecTrain Trainer: optical fiber connection or internet connection from one provider only, from... and the traffic is coming from one direction. There are no other point of source from where you have a connection. If this goes down, your entire system shut down. InfosecTrain Trainer: Single point of failure. InfosecTrain Trainer: or one particular staff member handling every procedure, everything. If that person is down, probably reports sick. If not available on the day of critical activity or incident, things are gone. InfosecTrain Trainer: backup.

InfosecTrain Trainer: If systems are not being backed up properly, there is no backup available. Even if the process gets failed, how you are going to recover. InfosecTrain Trainer: There is a resiliency gap. InfosecTrain Trainer: Right? If there is... there are no redundant system, like this firewall, there is no redundant system. These, your internet connection, there is no redundant system. If this goes down, there is no other system to take it over. InfosecTrain Trainer: Process limitation. If procedures... InfosecTrain Trainer: This... that cannot be performed remotely. You want a person to be there in person to probably do hard reset, restart the system on there, sitting at there. So those are also process limitations. So whenever all BIA information has been collected and charted, this criticality analysis becomes important, right? InfosecTrain Trainer: In which you will understand the impact, likelihood, encapsulation, all those things you will note down, and this will also include the vulnerability analysis, examining the processes, and all those things collectively. InfosecTrain Trainer: Now, how do you fix this? InfosecTrain Trainer: To fix this, first thing... Yeah. Sandeep Saxena: Yes. So, critical back. Sandeep Saxena: This process criticality analysis is a part of the BAA, or it is done after the BAA? InfosecTrain Trainer: No, this is part of the BIA. Sandeep Saxena: Open. Sandeep Saxena: Thanks. InfosecTrain Trainer: So this slide, you can take a screenshot, because this slide is something which actually explains and summarizes key mattresses with

respect to InfosecTrain Trainer: BCP and BIA. InfosecTrain Trainer: Now, once you do... done with the BIA, then you will determine what is the MTD, RTO, RPO, MTO, SGO, and AIW. InfosecTrain Trainer: Right?

InfosecTrain Trainer: So you will determine all of this. So, with this slide, I'll explain you how all of them are interrelated with each other. InfosecTrain Trainer: So, as soon as a disaster or an incident occurs. InfosecTrain Trainer: Right? Here, at this time, the disaster occurs. InfosecTrain Trainer: This is a data loss window. So, last backup was taken here. Now the incident occurs here. This is your RPO. Before this, whatever was the data, you can restore, you will take that backup. InfosecTrain Trainer: then you will use the RTO, which is the recovery time objective, target time to restore the system. Suppose it's 2 hours, you took InfosecTrain Trainer: And you... Went to your recovery site, and you went live. InfosecTrain Trainer: Now, when you are in a recovery time, or running in recovery mode, it means you are running InfosecTrain Trainer: On your backup side, right? InfosecTrain Trainer: Can you continue to operate completely? Your operation will now switch to run from backup side, you have to InfosecTrain Trainer: some point of time, you have to come back to the primary site, right? Till the time the work is going on. So that particular time, till the time you can support your business or continue to run on that backup or the recovery site is called the MTO. InfosecTrain Trainer: So you say, okay, we will require an 8-hour time where we will continue to run on this recovery site, then the normal operations will restore. And when you are working in recovery mode, you will probably not be able to restore everything. InfosecTrain Trainer: In your organization, do you have the RTO, RPO, and everything defined for each and every 100% system? InfosecTrain Trainer: You go and check. You will not.

InfosecTrain Trainer: Because maintaining RTO, RPO, and doing the... keeping the backup of each and every system in the organization is practically impossible. Imagine the cost which you would require to maintain the backup for all of those activities. It's very difficult. InfosecTrain Trainer: So when you are working in a recovery mode, that time you will only restore the critical business processes which help your operation to run. Probably non-critical processes, like internal HR portal or something like that, will... they can wait. InfosecTrain Trainer: Right? InfosecTrain Trainer: So now, understanding all these things. So, MTD is the maximum tolerable downtime, like, the maximum time InfosecTrain Trainer: The... the system can... Continue to run in this mode, because after this, then... InfosecTrain Trainer: everything would be gone. If you are not able to restore it within the 2 hours. InfosecTrain Trainer: Beyond this would be... InfosecTrain Trainer: gone. Beyond this, if you're not able to do... 2 hours... if you're set RTO, so your, probably, MTO would be 3 hours. You always keep the RTO below your MTD, so that if you remain down more than 3 hours, you are not able to restore the critical processes within 3 hours. InfosecTrain Trainer: you will lose significant amount of business. ITO, we already understood. RPO, you know. MTO have explained. Now, service delivery objectives. InfosecTrain Trainer: During this particular recovery time when you are running, there are going to be some minimum level of services which you will InfosecTrain Trainer: support. InfosecTrain Trainer: or minimum level of services which you will offer to the business.

You will say, okay, I will restore the critical business process, I'll restore the... restore the other critical servers, critical databases. InfosecTrain Trainer: But non-critical processes, I'll restore once I go back to the normal. I don't have a backup or recovery for the same, so that... those InfosecTrain Trainer: systems which you will include as part of the BCP BIA would become a STO, and AIW is basically the time incident occurred. So, incident occurred at this time when you initiated the RTO, InfosecTrain Trainer: and till the time you restore the function. That is called the AIW. Means the longest time a critical function can be down before survival is threatened, it's basically equivalent to MTD. InfosecTrain Trainer: So, allowable interruption window, maximum time system can remain down. So, this is how all the mattresses are related to each other. You can take a screenshot of this so that whenever you are revising a before exam, you remember all of them. Sandeep Saxena: I'm sharing my understanding, you let me know if it is correct or not. Sandeep Saxena: So if I'm running a website, my entity says to us, which means, Within 2 hours. Sandeep Saxena: customers should be able to see my website, whether on the recovery site or the original site, it doesn't matter. My site should be available for the users. That is... Sandeep Saxena: MTD. Yes. And if I am running my services on a recovery site, then maybe due to some cost constraint. Sandeep Saxena: Okay, or any other factor. Maximum time, I... Sandeep Saxena: Should run my website on, recovery side, this is MTO. InfosecTrain Trainer: Yes, correct. Sandeep Saxena: Okay, and service delivery objective... Sandeep Saxena: should be a bit less than MTD, because it is saying that not the full functionality, but some of the.

InfosecTrain Trainer: Yes, yes, yes, yes, yes. Sandeep Saxena: So maybe. InfosecTrain Trainer: So when you are running on recovery site, you may probably have some latency issues and all those things, right? Because InfosecTrain Trainer: kind of latency what you have at the primary site, you may not be able to maintain at the recovery site. Like, suppose I take example of Netflix. Probably it may not happen, but probably the hit count of the Netflix at each minute is probably, 10,000 users. InfosecTrain Trainer: But when they are running in a recovery mode, they won't be able to support 10,000 users, so they will keep it to the 8,000 users only. InfosecTrain Trainer: So that they are able to maintain the operations also, and so... so that is an STO. That 10,000... 8,000 user support is an STO. So whenever you are shifting to the backup, at least those minimum SGO level, whatever you have defined or written, should be able to meet. Got, Sandeep? Sandeep Saxena: Yes, so if my empty day is 2 hours, then SGO should be less than that, STO should be 1 hour or something, right? Because... InfosecTrain Trainer: Correct, correct. Sandeep Saxena: Yeah, okay. And AIW and MTD is all the same. InfosecTrain Trainer: Yes, yes, correct. Sandeep Saxena: Okay, cool, thanks. InfosecTrain Trainer: So this is... this is another which... which helps you probably remember. InfosecTrain Trainer: All these particular things, right? InfosecTrain Trainer: So, and then as due is not in time, this is basically in terms of capacity, what you have, right? So, as due, you were saying the time, Sandeep, right? It's more around the capacity. So, MTD, you say the 7 days for some organization. So, the RTO, you say the 4 hours we will recover.

InfosecTrain Trainer: RPO, you say, every 15 minutes we are taking the backup. MTO is the 30 days. You can run on the DR side for 30 days, because InfosecTrain Trainer: That's what you have the contract with those DR people. As DOEs say. InfosecTrain Trainer: that whenever we are running on this DR side, we will be running in the 50% capacity, right? InfosecTrain Trainer: And the AIW is for one payment gate. InfosecTrain Trainer: away is 24 hours. So, AIW is generally decide on the specific business application or a specific business process, right? That this particular process can only remain down for this particular maximum time, but MTD is actually... is synonym to AIW, but AIW is generally for specific processes. MTD is for overall business or overall organization, right? InfosecTrain Trainer: Got everyone. InfosecTrain Trainer: I think now, with this, it's more clear to you, Sandeep, right? Sandeep Saxena: Yes, yes. Sandeep Saxena: Thanks. InfosecTrain Trainer: So all of you want, if you can take a screenshot of this, this is another example. InfosecTrain Trainer: which summarizes all other mattresses, KPI, RPO, SGO, AIW, IOC, KGI, RTO, MTO, and IOA. However, we have discussed all of them again. This is again. InfosecTrain Trainer: We discussed multiple times IOC and IOA, right? So, these are the examples. So IOC means InfosecTrain Trainer: if there is a presence, what indicates that there is one particular attacker has caused damage or caused an attack to your enterprise, that's called the IOC, like presence of a malicious code in a system, which indicates that someone has InfosecTrain Trainer: caused the damage. If there is an unauthorized access to a sensitive data, which indicate that someone has caused damage.

Indicators of attack means... which gives you an advance indication that attack may happen InfosecTrain Trainer: or attack have already happened. So, it just gives you an indication. If there is unusual network traffic patterns, it will give you an indication that InfosecTrain Trainer: there is a possibility attack is happening. If there is a failed login attempt from unusual location, it gives you an indication the attack might happen. However, probably system might have already InfosecTrain Trainer: contain the incident automatically. You have the... all the technical means to do it, right? They would have already contained it, but IOA and IOC, that's what is there. Rest, all we have already discussed, right? InfosecTrain Trainer: Yes, Shweta. Shweta Sundar: So, similar to the difference between the AIW and MTD, right? Can you provide one example between MTD and MTO? InfosecTrain Trainer: I just gave the example of MTD and MTO. InfosecTrain Trainer: So, MTD is... MTD is about the maximum time the Amazon InfosecTrain Trainer: If Amazon suffered a ransomware attack overall as an organization, MTD's maximum time Amazon can remain down. InfosecTrain Trainer: If tomorrow the Amazon has a ransomware attack, like we take an example of JLR, InfosecTrain Trainer: JLR was down for 24 days. InfosecTrain Trainer: Everything was shut down. People were not able to access the system and all. You imagine this is a big time, but Amazon, probably 7 days is a big time, Amazon say 1 day. InfosecTrain Trainer: One day, if Amazon business is down, they will probably be able to sustain that damage. If it goes beyond one day, then the amount of revenue loss they will have is significant, and probably then people will not prefer Amazon, they will move to the Flipkart, Myntra, and other platforms.

That is an MTV. MTO is mainly InfosecTrain Trainer: When this particular ransomware stuck Amazon, Amazon will try to recover and restore from their DR site, which is an alternate site they have, but at alternate site, you do not maintain 100% capacity. InfosecTrain Trainer: Because maintaining the 100% capacity is very expensive in nature. Probably they have catered for the 80% of the system. So till the time these 80% of system will continue to support from this, rest 20% will still remain down. InfosecTrain Trainer: How much time they can continue to run on this DR site is MTO. Got Shweta? Clear now? Shweta Sundar: It's, and isn't that overlapping with SDO? Because SDO also talks about the acceptable capacity of the uptime, right? I mean. InfosecTrain Trainer: So, SDO is

something which supports the MDO. InfosecTrain Trainer: Okay. When you are running in this DR side, what is the actual capacity you want there? That is an SGO. However, don't worry, SGO won't... they will not ask in the exam. InfosecTrain Trainer: More important matrices here from the ISACA perspective is MTD, RTO, and RPO. Those are the things which you will ask. This more... these are all things I'm covering so that you... you are able to understand the complete picture, how the DR and BCP works, right? Shweta Sundar: Okay, okay, thank you. InfosecTrain Trainer: So this is what is. InfosecTrain Trainer: SDO is always smallest, then the RTO, then AIW, then MTD. InfosecTrain Trainer: Got it. InfosecTrain Trainer: This is what the circle represents. InfosecTrain Trainer: Now, coming to the life cycle of BCP. InfosecTrain Trainer: Right? InfosecTrain Trainer: So, first thing, when you create a BCP plan, it always starts with this. You have to first assign ownership to a person, to a team.

InfosecTrain Trainer: the one who will designate the program, the one who will run the BCP in the organization. Once you gave the responsibility to someone, he will develop the policy. InfosecTrain Trainer: or create a framework how to do the BCP, then he will conduct the BIA. InfosecTrain Trainer: He will perform the criticality analysis, identify the critical system and the processes. He will establish the recovery targets, RTO, RPO, and other things. InfosecTrain Trainer: also define the key risk indicators and performance indicator to check the performance, and then develop the strategies and plan. Then there is a testing methodologies to test the plan, which we will discuss. InfosecTrain Trainer: Then he will train the people on this, and then he will maintain and update it. InfosecTrain Trainer: This is an overall BCP process, or life cycle, what person follows. InfosecTrain Trainer: Now, whenever you make... you say the high availability. InfosecTrain Trainer: So, high availability is something which is synonymous to resiliency. InfosecTrain Trainer: Whenever I say resiliency means you have a high availability. We discussed, right? Your organization is only having one internet connection. If you have a two-inter connection coming from two providers, it makes your high availability. It's going to be very low probability that both of them will go down at the same time. InfosecTrain Trainer: Right? Or you say the first internet connection is coming from the optical fiber, next one is coming from the InfosecTrain Trainer: Coming from the, probably, the space... X... fiber services. InfosecTrain Trainer: What they call that, the one which they provide the internet via satellites. InfosecTrain Trainer: What is the name of the service? I'm forgetting the name.

InfosecTrain Trainer: Elon Musk provides some connectivity through satellites, right? Madhes: Totally. InfosecTrain Trainer: Yeah, Starlink. Starlink, yeah, Starlink. InfosecTrain Trainer: So this is how you maintain the high availability. If this wired connection is down because of any issues, at least you will maintain a connectivity through Starlink. InfosecTrain Trainer: So that's why you have to maintain high availability, so whenever you create a plan, you have to ensure you are making note of all the failover methods. InfosecTrain Trainer: How you are going to recover the key servers, databases, and the storage as well. InfosecTrain Trainer: Because the data is the one which will power those servers and the databases, if data is not available, those servers won't work. InfosecTrain Trainer: So, how you achieve the data storage high availability? These are the methods. InfosecTrain Trainer: So, there are 3 types of drives, right? One is the direct attached storage. It's basically synonym to the hard disk which is sitting in your laptop. So, you use your laptop, there is one hard disk attached to it. Similarly to your servers, if the hard disk which is attached to that particular same server unit. InfosecTrain Trainer: If that server unit is not working, there is a power failure in the unit, that hard disk will also not work. InfosecTrain Trainer: for direct attached storage. Another one is called the Network Attached Storage. InfosecTrain Trainer: Suppose you have one storage which is sitting InfosecTrain Trainer: in some cloud location, which I have rented, I can InfosecTrain Trainer: Attach this, use this, access this particular storage via network. InfosecTrain Trainer: It's called the Network Attached Storage.

InfosecTrain Trainer: comes the storage area network. Storage area network is that, in a data center. InfosecTrain Trainer: Or probably in multiple data centers, you create a farm of databases and the storage. InfosecTrain Trainer: Even if this is down, you will be able to support from this particular database, so it's a network. InfosecTrain Trainer: which is able to handle the capacity of your overall storage. So, call the storage area network. So, these are some of the key things which helps you maintain a high availability InfosecTrain Trainer: Now, coming to the network continuity. InfosecTrain Trainer: So, network is something which is a backbone of your system, right? Which will power your system to run. InfosecTrain Trainer: So your data centers, your cloud services, your local offices, all of them are running on the network. InfosecTrain Trainer: First thing, is the redundancy. InfosecTrain Trainer: So, I gave you example. InfosecTrain Trainer: That was the classic example of redundancy. You have one wired connection, another one you are using the... using the Tesla-provided the system, right? Which is coming from the satellite. Redundancy. InfosecTrain Trainer: or you have a two firewall, three firewalls, you have 3 network routes to reach your organization. Alternate routing. So, there are... InfosecTrain Trainer: alternate methods, or the routing methods available, so that you can use that alternate network path to route the traffic if this main path do not work. Like the internet connection, how it works around the world. InfosecTrain Trainer: So there are the C cables, which runs from one country to another country, and then there are landing points at each country. InfosecTrain Trainer: But these sea cables do not only come from one direction.

So, if you see how internet works in India, there is a map, you can Google it. InfosecTrain Trainer: So, in India also, these C cables come from two, three directions. InfosecTrain Trainer: Like, if the Ukraine and that Iran war is going on tomorrow, if Iran decide to cut one cable, at least there is going to be another route probably coming via South China Sea or another way, which will ensure that internet is running in India. InfosecTrain Trainer: It's not down. InfosecTrain Trainer: diverse routing. InfosecTrain Trainer: So, you create the same media, but Sep... InfosecTrain Trainer: separate physical path, right, you mitigate the single conduit cut. If one conduit is cut, at least, like, the parallel networking. InfosecTrain Trainer: Then, dynamic protocol. So, there are some dynamic protocols, like BGB, Border Gateway Protocol, OSPF, SD-WAN protocols. All these protocols also help you ensure that the system is InfosecTrain Trainer: routed via the dynamic routes, and the configuration, and the backup, and the standby devices, which I already covered, right? InfosecTrain Trainer: So whenever you are thinking from the high availability, make sure there are no single point of failure in your environment. InfosecTrain Trainer: Failover should be automatic. If... if the one device fails, second device should automatically take over. It should not be manually done. InfosecTrain Trainer: Right? InfosecTrain Trainer: And you have to have an investment in that, and do the testing regularly. Because if tomorrow, actually, like, Starlink and the regular connection you have, but you have never tested that Starlink connection, if the main connection goes down, how that Starlink would power your system, you have never tested.

InfosecTrain Trainer: If tomorrow there is actual incident, you won't be able to understand how it is behaving, right? InfosecTrain Trainer: So, like scenarios. InfosecTrain Trainer: So these are a couple of scenarios which gives you that how it happens. First thing is that the Border Gateway protocol detects that one particular link is down. InfosecTrain Trainer: Automatically, your traffic reroutes via secondary internet service provider, like... InfosecTrain Trainer: The main internet fiber optical cut down. InfosecTrain Trainer: the Starlink will take over. Now, the SD-WAN will balance the load so that the remaining bandwidth can be managed, there is no outage. User experience the minor slowdown, because Starlink will not have the same bandwidth what the fiber link offers, right? You all know. So... InfosecTrain Trainer: So, in that limited bandwidth, you have to operate. Then the network operations center alerted the failed link. InfosecTrain Trainer: Now, they will repair that fiber, they will contact that particular network provider, and then you will restore. So, understood how the network connectivity works, right? InfosecTrain Trainer: Now, what is the fault tolerance? InfosecTrain Trainer: What is the fault tolerance? Fatha: The amount of, hit one can take, keep the operations going on. InfosecTrain Trainer: So, fault tolerance is basically, A characteristic of a system. InfosecTrain Trainer: To quickly recover, or the amount of fault or amount of attack or incident it can tolerate. InfosecTrain Trainer: And that comes with high availability. That comes with the restoration. That comes with the... all the methods what we discussed so far, right?

So if you say, my system is fault-tolerant, it means InfosecTrain Trainer: all those mechanisms in the background are taking place, that's why the system is fault-tolerant, right? So, strategies to ensure the data is available, recreation, how you will... quickly you will be able to recreate an event of incident using RPO or RTO, right? Use of dependent or InfosecTrain Trainer: business needs and varies among industries. So, how poll tolerance will work will vary from organization to organization. So, for banking industry, it would be different. For manufacturing, it would be different. For probably for the manufacturing, they will have one, two lines. InfosecTrain Trainer: Right, so manufacturing have a line. InfosecTrain Trainer: So there is a conveyor belt where the product continues to go, become a finished coat, gets packed, and all. So the problem is they may have two lines. InfosecTrain Trainer: So if one line goes down, second line will continue to operate, but InfosecTrain Trainer: Would not be able to have 100% InfosecTrain Trainer: Thing, but system will continue to run. InfosecTrain Trainer: Then you put... Johny Souriar: Ford tolerance and resilience is both are saved in. InfosecTrain Trainer: So, resiliency is basically that would come after fault tolerance. So, if you see, say, my system is fault tolerance, it will ensure that system is also resilient enough, hard enough to withstand the attack. InfosecTrain Trainer: And would be able to quickly recover and support the operations. Scott, Johnny? Johny Souriar: Okay, I mean, what is the difference between these two, actually? Johny Souriar: My system is... fault tolerance means it is very quickly come back to the... Johny Souriar: operations, if it is an issue is there.

So, resiliency is also like that in my capacity to restore the business. InfosecTrain Trainer: Yes. InfosecTrain Trainer: So, fault tolerance is basically the ability of any system, right. InfosecTrain Trainer: To run normally without any interruption whenever any component fails. InfosecTrain Trainer: So that is called the fault tolerance. Like, if you have a... InfosecTrain Trainer: If you have a firewall, in this firewall, even if there is something which fails, something which is not working, still the firewall will continue to run. Like, so fault tolerance, the best example is your airlines. InfosecTrain Trainer: So, so the aircraft which you sit, the normal transport aircraft, you know, even if the single engine fails, secondary engine has enough power to land the aircraft back to safely. It's the fault tolerance, classical example of fault tolerance. InfosecTrain Trainer: I think, Johnny, you are able to relate now? InfosecTrain Trainer: While the resilience is a more broad ability beyond the fault tolerance. InfosecTrain Trainer: Now, whenever the single engine fails, secondary engine will help you to land, but is there a capability where you can recover from this? InfosecTrain Trainer: You are probably have some mechanism in the flight, so that you will be able to. InfosecTrain Trainer: You will be able to, probably extinguish the fire, or whatever was the, issue happened in this, in the flight itself, and the system again come back normal. InfosecTrain Trainer: Got Johnny? No. Johnny Souriar: With this example. InfosecTrain Trainer: Yeah. InfosecTrain Trainer: Now, what is the key difference between the BCP and the DRP? InfosecTrain Trainer: So BCP and DRB, as I told you, BCP... InfosecTrain Trainer: is an umbrella, and DRP is a subset of BCP.

So, BCP talk about the overall business, overall organization. DRP only specifically talks about the IT system. InfosecTrain Trainer: Your data, your servers, your database, anything which is digital in nature, supported by your data centers and your end equipments, right? InfosecTrain Trainer: But BCP also talk about the processes, people, your building, all those things. So a scope of BCP focuses on maintaining critical business functions. InfosecTrain Trainer: during and after disruption, a scope of DRP is to focus specifically on restoring IT system data infrastructure. InfosecTrain Trainer: So, objective of BCP is to ensure the continuous operations of the business, often involving alternate or manual processes. InfosecTrain Trainer: Here, the objective is to enable the rapid recovery of technology-dependent operations to normal service levels. InfosecTrain Trainer: So, BCP will have a broad focus InfosecTrain Trainer: also covers the process, facilities, operations, IT, everything would be covered. And the DRP focus is narrow, specific to dedicated IT recovery, data backup, and all those things. And the perspective is that, how do you keep the business operating, even with compromised IT? Perspective is, how do you get an IT system back on. InfosecTrain Trainer: online. InfosecTrain Trainer: And time frame. InfosecTrain Trainer: gets initiated as soon as the disruption to full recovery occurs. Time frame starts after a disaster has occurred, and the systems are impacted. InfosecTrain Trainer: Now, you need to evaluate the plans, right? Whatever plants you have created, how do you evaluate? Yes, Sandeep. Sandeep Saxena: Go back, I want you to take a screenshot of that. InfosecTrain Trainer: Yeah, yeah, please. Sandeep Saxena: Yeah, it's okay, then, thanks.

InfosecTrain Trainer: Sure, sure. InfosecTrain Trainer: Now, building a plan. InfosecTrain Trainer: So, whenever you create your disaster recovery plan. InfosecTrain Trainer: First thing in the exam and from the CISM perspective, you should make sure it is InfosecTrain Trainer: something which is aligned with the organization BCP plan. InfosecTrain Trainer: Right. InfosecTrain Trainer: And DRP should support overall BCP so that the critical business processes have a companion DRP plan to support them, and they continue to run. InfosecTrain Trainer: And when you do an audit of the disaster recovery plan to understand what are the gaps, first thing you will determine how effective the DRP plan is. InfosecTrain Trainer: How effectively it is documented. InfosecTrain Trainer: You will also evaluate all the methods InfosecTrain Trainer: which is incorporated or written in a plan for recovering those critical processes. You will also examine all environmental and physical security controls, right, and assess whether off-site locations are in the same geographical region InfosecTrain Trainer: or distributed. InfosecTrain Trainer: because... If you have a data... two data centers, suppose in a Bangalore. InfosecTrain Trainer: You have your recovery site also in the Bangalore, and the main site is also in the Bangalore. Tomorrow, if there is a disaster event which has impacted the complete Bangalore region, your secondary site is also gone. InfosecTrain Trainer: That's why all those recovery sites should be physically located or geographically distributed, so that you have a better, recovery. InfosecTrain Trainer: or resiliency. InfosecTrain Trainer: So, when you are evaluating these recovery strategies, what are the recovery strategies? We will discuss those.

That hot side, cold side, warm side, and all, right? InfosecTrain Trainer: You will consider that... It depends on the enterprise size, complexity, and current state of the planning. InfosecTrain Trainer: Every organization may not need the similar size of the data center, similar size of the recovery size, right? It depends on that. Also, what are the alternative strategies, your redundancy, failover mechanism, availability mechanism you have? Also, there is always the trade-off between the scope, capability, risk, and cost of alternative strategy. InfosecTrain Trainer: Always, this is a trade-off, right? I told you, you cannot have an recovery mechanism or the backup provided for all 100% of your system, because it's very expensive. InfosecTrain Trainer: Go check with your cloud person how much they're paying for the backup. InfosecTrain Trainer: and recovery. It's very expensive cost, what you have to pay. Probably it would be in the millions of dollars what you are paying annually. InfosecTrain Trainer: to... only just for the backup, for a day when the... actually that you need to initiate the recovery. Also, you need to outsource some of the capabilities with respect to that. InfosecTrain Trainer: And the business interruption insurance, it's a type of insurance which you can take. InfosecTrain Trainer: Right? InfosecTrain Trainer: Once you select that strategy, you should make sure it meets the management's objective. InfosecTrain Trainer: provide a basis to develop the detailed incident management plan, because InfosecTrain Trainer: the BCP DRP plan is linked with your incident management plan, right? InfosecTrain Trainer: So, when to initiate this would depend on that.

InfosecTrain Trainer: Also, help you address the InfosecTrain Trainer: Also, help you with address the probable event with acceptable recovery times at the reasonable cost, and consider cost of preparing for possible disruption and activating the capability whenever an event occurs. InfosecTrain Trainer: So, how you select these disaster recovery sites, which we'll discuss in the next slide. First thing, what is the probability of major outage occurring? InfosecTrain Trainer: If there is a high probability, you will select the hot site, or warm site, cold site, you will use that on the basis of that. What is the nature and extent of impact on the enterprise to continue to operate? InfosecTrain Trainer: What are the operational requirements designated and defined by your business impact analysis? If you have multiple critical processes, if you have less critical processes, which all critical processes should have a hot InfosecTrain Trainer: site, which all have, have warm site. InfosecTrain Trainer: Also depends on the manager risk appetite. InfosecTrain Trainer: If management has a very low risk appetite, probably you will decide and go with the hot side. InfosecTrain Trainer: Also, always, there is a trade-off between cost and benefit. InfosecTrain Trainer: If maintaining those recovery sites is more expensive than the current revenue, what you are generating, then you will not go with them, right? Now, the next slide, a most important slide. InfosecTrain Trainer: So these are the different types of the sites which we have. InfosecTrain Trainer: Right? InfosecTrain Trainer: So, first is the hot site. InfosecTrain Trainer: Hot site is actually something which is the real-time backup.

InfosecTrain Trainer: You imagine you have data center A, you have data center B, InfosecTrain Trainer: Everything, the data sync, everything is happening in the real time. InfosecTrain Trainer: As soon as this goes down, the B will take over, even... even your organization won't be able to get to know that there is a disruption going on. But... InfosecTrain Trainer: Maintaining exact replica of your site A to the B is very expensive, because you are paying the InfosecTrain Trainer: 2X cost. InfosecTrain Trainer: You are paying the cost for maintaining two exact replica of data centers. InfosecTrain Trainer: Right? InfosecTrain Trainer: Now, coming to the warm side. InfosecTrain Trainer: Which offers you some flexibility. So you have all the systems and everything similar to what you have in the hot... in the main site, but the latest backup is not there. InfosecTrain Trainer: So then comes the RTO in picture. InfosecTrain Trainer: So, in the warm side, you have to restore the latest backup there. InfosecTrain Trainer: from this site, where you will restore the latest backup, or from some other site where you have keeping, and the site will come function. So whatever is your RTO time, if 2 hours you require to restore the backup, that is going to be the time you will take. InfosecTrain Trainer: Coming to the cold side, it just... you can imagine an empty building with some server racks are kept. InfosecTrain Trainer: probably the HVAC system is also there, air conditioning, power supply, and some basic infrastructure is there. Now, once your sites are down, you have to go send resources there and build.

InfosecTrain Trainer: You have to move the servers, you have to move the cables, you have to establish the connection, then build it, so if you, you have a cold site kind of setup, you will probably say 30 days InfosecTrain Trainer: is required to... do the recovery. InfosecTrain Trainer: Next comes the mobile site. So, if you can go and check the AWS and Azure, both of them have the same setup. InfosecTrain Trainer: They call the data center on the wheels. So they bring a big Container and the trucks. InfosecTrain Trainer: the multi... 40 feet or 80, 60 feet container they will bring. This particular container will already have some servers established. InfosecTrain Trainer: you... they... if you have contract, they'll bring 2 or 3 containers also. You connect InfosecTrain Trainer: This container to your data center, restore the backup, and then this will continue to support your operations till the time you recover, if you are not maintaining an actual dedicated server. InfosecTrain Trainer: Now, coming to the duplicate site versus mirror site. InfosecTrain Trainer: So, mirror site is actually basically an exact replica or copy of one particular System. InfosecTrain Trainer: So, exact replica of your one particular system is called the mirror site, right? It can be... InfosecTrain Trainer: There, in terms of warm, cold. InfosecTrain Trainer: Any site, whatever you refer. If another site is exact replica of the same, it's called the

mirror site. Duplicate site, however, is any collection of the, InfosecTrain Trainer: So, duplicate site is actually... is actually the... mainly in terms of the hot side or the warm side. InfosecTrain Trainer: Now, next. InfosecTrain Trainer: Next comes the disaster recovery as a service. So, all the cloud vendors offer this.

So you pay them, if tomorrow there is a disaster, their team will come and support you, all the activities. And the reciprocal site, it's very important. InfosecTrain Trainer: You will get the question in the exam on this. InfosecTrain Trainer: However, duplicate site and mirror site, you will not get. Hot site, warm site, cold site are important, and the reciprocal site is the most important for item. Reciprocal means having a reciprocal agreement with a company. If I talk about a... suppose I talk about the Tata group of companies. InfosecTrain Trainer: So rather than all the companies which function under Tata Group, like TCS, InfosecTrain Trainer: Tata Motors, Tata Technologies, Tata Manufacturing, likewise, they have good companies. Titan. InfosecTrain Trainer: all of them maintaining their own hot site, warm site, they all will have a reciprocal agreement. They will maintain one particular data center, where all the... all the data farm, all the servers, everything is there. Tomorrow, there is a disruption. InfosecTrain Trainer: All of them, any company who has a disruption, they can go and use this particular site as a backup site. InfosecTrain Trainer: They will use this to restore their system and run recovery as soon as the primary site is up online, they will again move back. So, reciprocal agreement. All of you clear on this? InfosecTrain Trainer: Now, when you are developing the recovery plan. InfosecTrain Trainer: The recovery plan should be clearly documented. InfosecTrain Trainer: If the recovery plan is not clearly documented, people are not able to read and understand what recovery plan says, then how people are going to act upon that plan and then take action.

InfosecTrain Trainer: Then, each task, what you will be doing, who is responsible for the backup, restoration, who is the person who is plan for the initiation, who will do what, all the person should have a exactly responsibility per task allocated in the plan. InfosecTrain Trainer: Then, for each and every activity, you should have a clearly defined procedure. InfosecTrain Trainer: How you will restore the backup from this server, how you will take this particular database and migrate here, what is the procedure and the steps followed, so that people don't... InfosecTrain Trainer: Make their own judgment in that scenario, and miss some critical step, and due to which, the system is not able to restore. InfosecTrain Trainer: Then, always maintain a copies of your plan at the off-site location. If there is no communication, or there is an issue, at least person has the copy of the plan, which they will follow and start the process, right? InfosecTrain Trainer: An other important consideration when you are developing the plan, always have a pre-incident readiness. InfosecTrain Trainer: Right? InfosecTrain Trainer: So that... You are not... working on the plan when actually the incident has happened. You should always InfosecTrain Trainer: follow a proactive approach. InfosecTrain Trainer: also considered from the logistic perspective. Let's say you are in a warm site, or in a cold site kind of setup, or a mobile kind of... mobile site kind of setup. InfosecTrain Trainer: you have to consider about the logistics, right? People need to move there, or some servers need to be moved there, some additional stuff need to be migrated or moved there. InfosecTrain Trainer: Also, evacuation process. InfosecTrain Trainer: So disaster is not only about moving the data.

If there is a fire in your primary site, you need to evacuate the people from there, right? InfosecTrain Trainer: So, you have to consider this. Also, disaster declaration steps. How you will declare that there is a disaster happening in the organization, those steps you should have. Also, transition steps to DR if incident response flame. InfosecTrain Trainer: When you will take a decision now, our... InfosecTrain Trainer: Incident response failed, we are not able to contain the impact of the incident. InfosecTrain Trainer: Probably the primary data center won't support, we have to move through to the standby data center. InfosecTrain Trainer: Those steps you should clearly define. Also, the business processes and the IT resources who will be needed at that point of time to recover, and the step-by-step explanation of the... all the recovery options which you have. InfosecTrain Trainer: Now, it's very important. So, all the organizations generally do an insurance. InfosecTrain Trainer: Be it your cyber insurance or other insurance which you have done, or you would have the insurance of your data center. InfosecTrain Trainer: If tomorrow there is a fire, there is a damage to your servers, damage to your equipment, you need insurance to cover those costs, right? InfosecTrain Trainer: So, so you, you can even create the overall extensive insurance InfosecTrain Trainer: Can be part of your cyber insurance, that tomorrow, if there is a disaster event, there is a loss of data, loss of equipment, loss of people, loss of information, the insurance should be able to cover the cost. InfosecTrain Trainer: So, insurance should cover the IT equipment damage cost, if your IT equipments are damaged. InfosecTrain Trainer: It will also cover the cost of reconstruction of the media.

InfosecTrain Trainer: some extra additional logistical expenses, people need to move, some cost to the... of the travel, cost of some additional technologies which you have to do. Also, business interruption. Business was down for 5 hours, we lost InfosecTrain Trainer: \$1 million in this duration. So, this should get covered as part of the insurance. So, these are some of the considerations which you can have when you are planning for an insurance for the BCPDRP perspective. InfosecTrain Trainer: Right? Let's discuss some questions. Yes. InfosecTrain Trainer: On the topic, what we discussed so far. InfosecTrain Trainer: Alright, let's discuss the correct answers. InfosecTrain Trainer: So... InfosecTrain Trainer: The first question, an organization is reviewing its BCP plan, what is the most important reason for defining the MTO for critical business processes? Which two options you want to eliminate? Johnny Souriar: AND. InfosecTrain Trainer: E-A? Johnny Souriar: B. InfosecTrain Trainer: B, okay? Why you want to eliminate A and B? Johnny Souriar: Frequency of desired circulatory testing is not, MDO. Johnny Souriar: Defining criteria. InfosecTrain Trainer: Okay, alright. Johnny Souriar: Recently. InfosecTrain Trainer: Budget is also. Johnny Souriar: Budget is also a subsystem of strategy, how the recovery strategy is there, according to budget. InfosecTrain Trainer: Okay. So, which is the correct answer? Johnny Souriar: C... YC? InfosecTrain Trainer: Yeah, I'm just able to understand and build that process of thinking in all of your mind, right? So that you think InfosecTrain Trainer: Why... InfosecTrain Trainer: one particular option you selected as a correct, but why it is correct. That's how you will go a deeper understanding on those topics also, right?

Yeah, so YSC is correct, here. Johnny Souriar: appropriate recovery strategy, because IT performance metrics, this MDO is not like API for IT. InfosecTrain Trainer: Yes. Johnny Souriar: After the we had to define, and... InfosecTrain Trainer: MTO we discussed, right? MTO is that how much time you continue to run in your recovery site, right? InfosecTrain Trainer: So, on the basis of that, what kind of the recovery strategy you want, right? You want a hot site, warm site, and all. If the MTO of the organization is very low. InfosecTrain Trainer: Can you afford to get into cold side? No. You have to think from the hot side or warm side perspective, right? So those recovery strategies you will decide on the basis of MTO, not A, B, or D. InfosecTrain Trainer: Next one. An information security manager is assessing the organization's ability to respond to a cyber incident. Which of the following metrics would be most useful in determining how quickly normal operations can be restored? InfosecTrain Trainer: Which options you want to... Eliminate. Johnny Souriar: A and D. InfosecTrain Trainer: So, mean time to repair is of... out of context. Time to live is also not this one. This is talking about how quickly you restore the operations. This is the definition of which particular InfosecTrain Trainer: recovery objective. Johnny Souriar: deal. InfosecTrain Trainer: ideal, right? InfosecTrain Trainer: As soon as the incident occurs, how much time you require to recover to the operations, right? Third one. An organization is conducting annual disaster recovery plan testing. The test involves a tabletop exercise with key personnel. What is the main objective of this type of test? InfosecTrain Trainer: What do you do in the tabletop exercise?

We are yet to discuss this, tabletop exercise, what we do. Johnny Souriar: But yes, Christian. InfosecTrain Trainer: So what is the correct answer here? Johnny Souriar: B. InfosecTrain Trainer: Why be... Why not A, C, and D? Johnny Souriar: You see, tabletop exercise is a scenario-based circulation and communication and decision... how quickly decision is taking place. Johnny Souriar: That's a different topic. InfosecTrain Trainer: Yes. Physical relocation probably would happen in the live exercise. InfosecTrain Trainer: Realistic, full-scale simulation will also not be there in the tabletop, and validating all the systems will not... it's just a tabletop, people are sitting in a group and doing the testing. Last one. After the measures have been applied to contain the escalation of an security incident, the next step should be... what you do? InfosecTrain Trainer: It's talking about the process, what we learned. What is the next step? InfosecTrain Trainer: What is the correct answer here? Johnny Souriar: B. InfosecTrain Trainer: B or D? Johnny Souriar: Restoring systems to their operational state. InfosecTrain Trainer: Correct. InfosecTrain Trainer: So, what we see, the process, what we have discussed, right? Risk register would be a very last step. Post-incident review, you will done after the everything is done. InfosecTrain Trainer: updation of their incident response will also follow after this. First, your InfosecTrain Trainer: Priorities to restore system to the operational state. InfosecTrain Trainer: Got it. InfosecTrain Trainer: Let's see some couple of other... InfosecTrain Trainer: Try these questions, three questions. InfosecTrain Trainer: Alright, let's discuss the correct answers. InfosecTrain Trainer: So, the first question.

An information security manager is recommending an investment in a new security initiative to address the recently published threats. Which of the following would be most important to include in the business case? We discussed about the business case. InfosecTrain Trainer: Okay. InfosecTrain Trainer: Now, tell me, which options you want to eliminate here. InfosecTrain Trainer: Anyone? Which two options you want to eliminate? Johnny Souriar: PC. InfosecTrain Trainer: B and C. Okay, why you want to eliminate B and C? Johnny Souriar: And use to the fund is irrelevant. InfosecTrain Trainer: Okay. Johnny Souriar: Direct information from Remitable resources are not relevant to these questions. InfosecTrain Trainer: Okay, so what is the correct answer as per you, and why?

Johny Souriar: EA, business impact if threat not materialize. InfosecTrain Trainer: A or D? Read them again. Read them again. Johny Souriar: Gotcha. Johny Souriar: So, ballistic. Pudir: It is there, sir, alignment of the new initiative with the approved. Johny Souriar: beast. InfosecTrain Trainer: Because the business case is something. InfosecTrain Trainer: which help you pitch the idea in from front of the senior leadership, right? It helps them convince why you are proposing this particular InfosecTrain Trainer: solution to us, why we should approve the funding. So, if you show them the alignment with respect to the strategy, what... InfosecTrain Trainer: That's what the senior management is more concerned about, right? Not the business impact. InfosecTrain Trainer: Business impact would, however, would part of it, but not the primary or the most important. Most important is that you have to showcase that how this initiative will help you mitigate or help InfosecTrain Trainer: support the strategy.

That's why correct answer here is D. Now, coming to the next question. InfosecTrain Trainer: What is the most important reason for conducting security awareness program throughout the organization? Which options you want to eliminate here? Pudir: B and C, sir. InfosecTrain Trainer: Yes. So, maintaining evidence for training record to ensure compliance is not of that much importance. Informing the business unit about the security strategy is also not of that important. Now, what is the correct answer out of A and D? Pudir: Reducing herman disc. InfosecTrain Trainer: YA, Y not D? Pudir: Whenever any incident is happening, that, human resources are the... human resources are the most vitally important. InfosecTrain Trainer: But by doing the awareness program, you are training them in the incident response also, right? How to tackle the incident, how to report the incident, and all, right? That's what you are doing? InfosecTrain Trainer: Why not D? Pudir: Okay, okay, if you give training to the human resources, they will ultimately, themselves can protect them. Ashwin: A would be the umbrella answer, right? InfosecTrain Trainer: Yes, correct answer is A only. InfosecTrain Trainer: checking. D is not a correct answer, because the human risk, right? Is the risk only with respect to incident? InfosecTrain Trainer: In the A, you will train them on social engineering also. You will train them on the information security policy, you will train them on the awareness, general awareness, multiple things are... InfosecTrain Trainer: needed, right? Awareness training is not only about how to report the incident, it's about other things also, which they have to understand. That's my correct answer here is A.

InfosecTrain Trainer: If a forensic copy of a hard drive is needed, which of the following would be the most defensible from a legal standpoint, if used? InfosecTrain Trainer: A compressed copy of all content of hard drive, a copy that includes all file and directories, an encrypted copy of all content, or bit-by-bit copy. We discussed this. InfosecTrain Trainer: When I was talking about the forensic. What is a good answer here? InfosecTrain Trainer: What is the good answer here? Johny Souriar: C. InfosecTrain Trainer: Bit by bit copy. InfosecTrain Trainer: Whenever you see bit-by-bit copy, always go with that. That is going to be the good answer, because that is the copy which contains all the important things. It will also contain the copy of InfosecTrain Trainer: files. It will also contain the copy of all the logs, also contains all the important things which you need to capture from that particular computer or the system, right? So C is the... InfosecTrain Trainer: Best kind of copy which you could have. InfosecTrain Trainer: Done? Sandeep Saxena: Probably shouldn't. InfosecTrain Trainer: Yes, Sandeep. Sandeep Saxena: So, I actually create the business case sometimes for the initiatives? Sandeep Saxena: And it always starts with Y. Sandeep Saxena: Why this new initiative? Sandeep Saxena: And Y means to me is, for example, this business impact if threat materialize. Sandeep Saxena: So... Is white's not correct? InfosecTrain Trainer: So Y, when you initiate it with the Y, InfosecTrain Trainer: R0, that Y is something which you are actually... InfosecTrain Trainer: Relating with what business... how this will support the business. InfosecTrain Trainer: You think from a broader perspective, Sandeep, right?

That why is something which you will tell the business or the senior management that InfosecTrain Trainer: This is why we are deploying this solution, how it supports the business. Suppose you are proposing a new email gateway. InfosecTrain Trainer: For organization, for the protection. InfosecTrain Trainer: You will not only talk about that... how that email gateway... you know that email gateway will help you prevent the... the email coming from the... some falsified domains, reduce the phishing, and all. That is the end goal, but InfosecTrain Trainer: Overall, you will talk from the business perspective. You will say that if the email gateway is not there, this will help InfosecTrain Trainer: this will cause this much million of dollar because of the people clicking on phishing email. We have seen in a couple of other organizations happening this, something you will start with, right, Sandeep? Sandeep Saxena: Okay, okay, got it. Thanks. InfosecTrain Trainer: Yeah. Madhes: One more, just, no... Madhes: thought of sharing. Not all the... Madhes: Threads, you know, published threats applicable to that particular business. Madhes: So, when we do alignment of the new initiative with the approved business strategy. Madhes: Sometimes the published threats need not be, you know, applicable to the organization. InfosecTrain Trainer: Yes, yes, yes. Good, good thought, yes. InfosecTrain Trainer: Now, coming to the last topic of this domain, then we will discuss the strategy for the exam, right? InfosecTrain Trainer: So, we have discussed the complete incident management InfosecTrain Trainer: domain, BCP, DRP, everything. Now the training is the very important thing, right?

InfosecTrain Trainer: Everyone in the organization, be it your SOC team, be it your manager, be it your BCP DRP team, all your employees, they must understand what are their duties, capabilities, and skills, what are their InfosecTrain Trainer: Rule whenever there is an incident. InfosecTrain Trainer: Right. InfosecTrain Trainer: So, the training is very important. Even someone who would have worked in the SOC, you will receive a training. InfosecTrain Trainer: If someone who would have worked in the BCP DRP team, you will also receive a separate training. Your senior management receives separate training. InfosecTrain Trainer: Your normal employees receive separate training, your HR team goes with some separate type of training, so everyone is actually facing a different kind of threats, right? InfosecTrain Trainer: So, senior management is more prone to, probably, the new kind of AI Deepfake attacks. InfosecTrain Trainer: Which they will get. Because if they get compromised, the attacker would be able to leverage the maximum amount of damage they'll be able to cause, right? So that's why you have to create a proper understanding of the duties, capabilities, and skills needed, right? InfosecTrain Trainer: then you can arrange the training in multiple ways. You can either hire an external vendor, external instructor who have a good InfosecTrain Trainer: Ground-level, hands-on experience and knowledge in that area, so that he can explain the people how you will handle and mitigate. InfosecTrain Trainer: Also, you can do on-job training. So, in my organization, also, we do the crisis simulation. InfosecTrain Trainer: Exercises every year.

InfosecTrain Trainer: As part of this, we hire one external party who support us, who throw a... InfosecTrain Trainer: A kind of a challenge in front of us, and then... InfosecTrain Trainer: then we have to work upon it. Like, we discussed that one example, right? One system is down, then another system is down, then they will throw one more challenge, they say, okay, this something is also gone down. InfosecTrain Trainer: So, how you... multiple challenges are thrown at you, and then how you navigate and work upon that. That you will build with this. Also, it will understand that what are the skills InfosecTrain Trainer: which are needed, and what are the new threats which keep coming up in the market, so that your team stay relevant with respect to that. That's why you do the incident management training. InfosecTrain Trainer: So whenever you do an incident management effectively, it ensures InfosecTrain Trainer: that the rapid detection of the events are happening, because if your team is well-trained, you will be able to record the incident properly. If you have trained them properly, they will know that what is the importance of recording which all aspects to record, right? InfosecTrain Trainer: also help you efficiently manage the response, right? And the impact on the overall operations would be limited. InfosecTrain Trainer: And what are the documentation you do? You will document the complete details of the incident. InfosecTrain Trainer: Right? What are the response or the activities you are doing, you are containing, you are eradicating, you are doing the recovery when you initiated the BCP plan? InfosecTrain Trainer: when you initiated the communication plan, have you initiated the escalation plan properly? All those tracking you will do.

Also, it will help you plan the information collection, right? InfosecTrain Trainer: Like, which all activities you have to collect, you have to collect the information, also help you preserve the data for forensics. InfosecTrain Trainer: And what is the role of security manager in incident response? InfosecTrain Trainer: It's very important. InfosecTrain Trainer: He needs to make sure the organization and your SOC team, your incident management team, is always ready to tackle any kind of incident. InfosecTrain Trainer: That's why all the organizations do either red, Team... purple... Or blue team exercises. InfosecTrain Trainer: This is what help you InfosecTrain Trainer: actually understand the scenarios, understand the real-life attacks, if it is happening, and how your SOC team is able to navigate, detect, and respond to them. InfosecTrain Trainer: And that's the responsibility of Information Security Manager. You need to always make sure the team is ready InfosecTrain Trainer: of any kind of scenarios. Also, he needs to make sure when the incident happens, the impact InfosecTrain Trainer: is reduced, and the incident is contained as quickly as possible. Because the more time you spend on the containment, the more damage it will come. InfosecTrain Trainer: Also, he needs to make sure that all the important key stakeholders, your senior management, your regulatory bodies, your legal team, all the important people, they are notified on time. InfosecTrain Trainer: Right? Because if you are making a delay there, then it will again have a different kind of impact. Also, the recovery happens quickly. InfosecTrain Trainer: and efficiently. So whenever there is an incident, the recovery should happen as quick as possible, right?

And helps you balance the operational and the security processes. InfosecTrain Trainer: And you will be able to handle the legal and the raw enforcement-related issues if you are having a better incident response. InfosecTrain Trainer: Right. InfosecTrain Trainer: So this is the role of the security manager. If you want, you can take a screenshot of this. You will definitely get a question in the exam on this. Sandeep Saxena: Can you please explain the... Balance operational and security processes. InfosecTrain Trainer: Yes. InfosecTrain Trainer: So when... InfosecTrain Trainer: If you think from a security manager perspective, if there is an incident going on, there is a ransomware incident, will you stop other operations which are happening? Like. InfosecTrain Trainer: There is a vulnerability management process going on, there is an application security team is working, there are other business processes which are going on, because the incident probably would impact a couple of them. InfosecTrain Trainer: But you don't want any other mishap to happen in the organization, right? That's the balance you have to maintain, so that InfosecTrain Trainer: The operations also continue to work as it is, and the security InfosecTrain Trainer: things are also being prioritized. Got Sandeep? Sandeep Saxena: Yeah. Sandeep Saxena: Thanks. InfosecTrain Trainer: Now, coming to the two things. InfosecTrain Trainer: One thing is the testing, another one is the evaluation. InfosecTrain Trainer: So, testing means something when you test the plan. So, you have created the incident management plan, you have created the BCP plan, you have created all the plans which are there. So, there are two things.

You... InfosecTrain Trainer: In the testing, you test it thoroughly, but you are evaluating InfosecTrain Trainer: Evaluation would be at a high level, right? Testing ensures InfosecTrain Trainer: So that you validate the effectiveness of the plan. InfosecTrain Trainer: So, that red team exercise, blue team exercise, purple team exercise is a good way of testing your plan. InfosecTrain Trainer: It ensures that the individual know and understand their responsibilities and determine the effectiveness of the plan. InfosecTrain Trainer: But when you evaluate, Evaluation means that whenever there is a significant change in the environment. InfosecTrain Trainer: You have to, again, Probably change the plan, right? InfosecTrain Trainer: If so... suppose you... earlier you were on on-prem. InfosecTrain Trainer: Now you have added the cloud as well. InfosecTrain Trainer: Now, you have system in the cloud. From on-prem, there is a significant change. InfosecTrain Trainer: So, cloud systems recovery would happen in a different fashion as with respect to the on-prem. InfosecTrain Trainer: So that's why at least annually you should do at least one time where you evaluate and see your plan is effective, like the policies also. You review at least annually. InfosecTrain Trainer: You also perform to determine the efficiency and conformance with respect to plan. If there are any changes in the environment, there are changes in the resources. Probably the... your resourcing level would have gone InfosecTrain Trainer: dropped, or probably the person who was earlier handling have left. InfosecTrain Trainer: Also, you need to consider the processes individual capabilities and skill levels are matched with respect to that. InfosecTrain Trainer: Like, suppose organization has adopted AI.

Now, all the AI models, your Agentic AI systems, right, your AI agents, they are also very important part of system. So, their recovery will also need to be added as part of the plan, so you have to evaluate and do those changes. InfosecTrain Trainer: So, then you evaluate and do the changes in the plan, right? InfosecTrain Trainer: Now, how you handle the operational processes, operational handling processes, right? InfosecTrain Trainer: So, whenever there is an incident, where... whenever there is a disaster which you declare. InfosecTrain Trainer: Right? So, first step is the detection and the reporting, right? InfosecTrain Trainer: So, whilst you detected there is an event, there is an incident, there is an alert which came into your system. Like, we gave an... I gave an example, right? At 5 AM, there was an alert. InfosecTrain Trainer: Which was generated by the system. InfosecTrain Trainer: then immediately the person reported, initiated the plan. Now, the next step is treatment. InfosecTrain Trainer: So you need to categorize, prioritize, and assign to the respective people how many people would be handling reporting. Once you do that, next step comes the analysis. You will determine the overall impact, damage, and how... what is the kind of response required to handle this. InfosecTrain Trainer: Once this is done, then comes the response. So now, response is going to be the broad, which would require the... InfosecTrain Trainer: contain... eradicate... InfosecTrain Trainer: recover, or BCP DRP to be initiated as part of this, so the response will include all the activities. So this is how you handle overall operational, overall incident management in your organization, in your environment. InfosecTrain Trainer: Now, what are the different incident response team models?

InfosecTrain Trainer: So, you can either have a central incident response team. InfosecTrain Trainer: Like, one team managing everything. One single incident response team working in ship, 24 across 7, handling everything. InfosecTrain Trainer: Or you can have it distributed, which I just, InfosecTrain Trainer: discuss. Suppose you have business unit working distributed in nature, they have a very less, probably, interconnection or less communication with each other, so you say all business function unit will maintain their own incident response team. InfosecTrain Trainer: Will... you will see this particular thing is rarely. InfosecTrain Trainer: But... may happen. InfosecTrain Trainer: I have seen this rarely. Most of the time, I have seen the Coordinated Incident Response Team. InfosecTrain Trainer: So, you have one particular SOC team. So, the SOC team is distributed geographically, I told, right? One team in US, one team in EU, one team in India, and probably one team in your headquarters. Suppose it's there in Australia. InfosecTrain Trainer: This team will... be actually given the direction, because your CISO sits here. InfosecTrain Trainer: But he will give the direction to all the teams that how to function, how to work in case of disaster and recovery. Outsource means these days, organizations go with the managed SOC. InfosecTrain Trainer: Has anyone organization has this managed SOC? Mukesh Thakur: Yes. InfosecTrain Trainer: So rather than managing your own SOC team, you outsource it to some XYZ third parties, they will handle everything for you. InfosecTrain Trainer: you have no, headache in your mind, you are just having one manager who is coordinating with them. Tomorrow, they will have some SLA with you, they will have a dedicated team of SOC people.

If tomorrow there is an incident, they will make sure that InfosecTrain Trainer: Incident is happened, incident is tackled, contained, and recovered on time. InfosecTrain Trainer: Now, how do you update the recovery plans? InfosecTrain Trainer: So, all the recovery plans, they need to be updated on some time, right? So, what are the factors that impact the plan requirements? If there is an inadequate strategy which is not aligning to the enterprise need, like AI, organization adopted InfosecTrain Trainer: AI? InfosecTrain Trainer: There are AI agents running, there are AI-based processes running, there... currently, you have no... nothing to support it, so you have to update the plan. InfosecTrain Trainer: If there are new applications which are developed, acquired, or deployed, and there is no recovery plan set up for them, then you have to update the plan. If there is changes in the business strategy, like I gave example of the on-prem to cloud. InfosecTrain Trainer: Or going from regional too global. InfosecTrain Trainer: It's a change in a complete strategy for the organization. In such kind of scenario, you have to update the plan. InfosecTrain Trainer: If there are changes in the environment that render the present provision inappropriate, this is a change InfosecTrain Trainer: like, on-prem to the cloud, current setup is no more applicable, right? You have to now, have no data center, you have... you are completely on cloud, you have to see the recoveries, things are also happening in the cloud. Also, if they are changing in the physical and the environmental circumstances, so... InfosecTrain Trainer: If there is... this is the physical changes, like, regional to the global.

InfosecTrain Trainer: You had your complete recovery plan set up for the regional, you are... your company was only there operating in India. InfosecTrain Trainer: Now you are having business in Singapore, business in EMEA and all, so you have to go with that. InfosecTrain Trainer: So, to maintain the plan, the information security manager should make sure he establish a process to update these recovery plans as there are changes in the enterprise. He always needs to make sure he's assessing responses and recovery plan requirements during change management process. Whenever there are any changes InfosecTrain Trainer: Happening in the plan, you have to follow the same change management process which we discussed. InfosecTrain Trainer: You need to review and update the plans and strategies for response and recovery according to the schedule. So you have annual schedule, and whatever schedule you have set, you have to follow the schedule and do those changes. InfosecTrain Trainer: So, when you are maintaining these recovery and continuity plans, you have to make sure the business processes and technologies always go changes in the environment, every year. InfosecTrain Trainer: In your organization also, you will see there are going to be some significant changes, some new acquisitions, some mergers, some new application being onboarded, some changes happening in the environment. InfosecTrain Trainer: So you have to make sure that you maintain a strategy, you establish a schedule. InfosecTrain Trainer: like, at least annually, it should be done, but if the changes are happening more frequently, you can set the frequency accordingly. Also, you need to include the DR document, disaster recovery document review, in every business process or system changes.

InfosecTrain Trainer: makes document update a required step in your system development lifecycle. It's not the software development lifecycle... system development lifecycle. Whenever you are developing a new system, as part of this, there should be an step to update the plan. InfosecTrain Trainer: And you have to periodically test. InfosecTrain Trainer: If you have changed the plan, now you have to test, because if you don't test it, how you will understand that the plan is working effectively? InfosecTrain Trainer: Now, a very important slide. InfosecTrain Trainer: Testing a plan. InfosecTrain Trainer: Right? So... so once you test the plan, the testing will help you understand The collaboration between the team. InfosecTrain Trainer: Right? I told you, there is one, if you are working in a hot, Warm. InfosecTrain Trainer: Cold, those kind of setup. InfosecTrain Trainer: You need a dedicated set of people, those who know, those who test the plan, right? InfosecTrain Trainer: So, testing promote the collaboration, coordination among the team, right? Because you're... InfosecTrain Trainer:

primary data center, your standby data center. People need to coordinate, right? In your organization, also, you would see testing happening. InfosecTrain Trainer: Like, you will receive the email that we are testing the Wi-Fi BCP plan, Wi-Fi disaster recovery of this particular building on this day. InfosecTrain Trainer: So they will do it on the weekend, or they will say, we will test the disaster recovery over the weekend for this system, so system will remain down. InfosecTrain Trainer: So you will provide a usual training tool, cost, and all the time to the resources, and how you decide the success? Is the testing was successful? You need to define that success criteria.

InfosecTrain Trainer: If you're testing the plan, you should have a matrix to say that, okay, now plan was tested and remains successful. So you need to define the relationship between the teams clearly, understand and integrate the scope and capabilities of the existing team. InfosecTrain Trainer: So, plan and the control test carefully to avoid placing the business at increased risk. If you're not testing the plan and the controls. InfosecTrain Trainer: carefully, you are placing it at risk, because tomorrow, if there is an event, like we discussed in the business case, multiple systems are affected, or you have an event like JLR, InfosecTrain Trainer: You are putting your business at risk. InfosecTrain Trainer: Also, you need to develop the methodical test objectives so that you help ensure the measurable benefits are achieved. InfosecTrain Trainer: So the test objectives which you create, those objectives should be InfosecTrain Trainer: defined it in such a manner so that it supports your overall business objectives, then you maintain a testing schedule, which you will follow annually, semi-annually, and whatever you say, and then you will consider the testing after InfosecTrain Trainer: completion of major draft updates, major changes. Now, the next and the most important topic, what are the testing InfosecTrain Trainer: techniques. InfosecTrain Trainer: So, there are 5 type of testing technique to test your business continuity plan. And let me be very clear, we are discussing this second time. So, there were testing techniques for the incident management plan, which was different, which we discussed.

InfosecTrain Trainer: So, if you are getting confused, you can review the recording of the previous session, where we discussed the... when you test the incident management plan. InfosecTrain Trainer: I have the slide, I can show you, probably. InfosecTrain Trainer: Let me say... Let's show... InfosecTrain Trainer: So we dispersed... InfosecTrain Trainer: this one. InfosecTrain Trainer: This one. InfosecTrain Trainer: So I wanted to show you so that you don't get confused. InfosecTrain Trainer: This is the incident response testing method, documentary view, walkthrough, simulation, and live fire. InfosecTrain Trainer: Be clear. InfosecTrain Trainer: what question is asking? Is question is asking about the incident response plan testing, or the question is asking about the InfosecTrain Trainer: BCP plan testing. So, there are four methods to test the incident response plan. InfosecTrain Trainer: And... InfosecTrain Trainer: there are five methods to test the BCP plan. So, you can take the comparison, you can, once you see, review the recording, you will get that. So, BCP response plan is tested in four of five methods. One is the checklist review. InfosecTrain Trainer: Now, this particular attack is propagated to another environment, this is also down. Now, your overall... this XYZ application is completely shut down. InfosecTrain Trainer: how you will tackle this? So, it's a simulation, where you will test the complete plan. Now they... at this step, he will say, now you have to restore it from the backup. InfosecTrain Trainer: Initiate the DR. InfosecTrain Trainer: You are not actually doing anything, it's just on the table, you are throwing those challenges to the people, and then they are going over step by step. You see that they know their duties and responsibility, you are running the simulation. InfosecTrain Trainer: Now, second, Fourth step, which is a parallel test.

InfosecTrain Trainer: Next thing is the structured walkthrough. A structured walkthrough is where you assemble a team. InfosecTrain Trainer: You assemble all the peoples who are responsible. InfosecTrain Trainer: And then the team read all the steps one by one, right? So, checklist review can be done by one person, but for a structured walkthrough, you require the people, those who will be InfosecTrain Trainer: working in the scenario where they review all the recovery steps on paper. It's just an on-paper test, you're not doing anything. And facilitator guide each stages, and they all go over their duties and responsibility and understand this. Now, next come the tabletop. InfosecTrain Trainer: So, tabletop exercise is where you are doing the simulating the actual incident on table. One person is become an empire, one person become a facilitator, right? So, facilitator will throw alerts to the people. They say, okay, team InfosecTrain Trainer: XYZ server in EU region is down. InfosecTrain Trainer: Now, this particular attack is propagated to another environment, this is also down. Now, your overall... this XYZ application is completely shut down. InfosecTrain Trainer: how you will tackle this? So, it's a simulation, where you will test the complete plan. Now they... at this step, he will say, now you have to restore it from the backup. InfosecTrain Trainer: Initiate the DR. InfosecTrain Trainer: You are not actually doing anything, it's just on the table, you are throwing those challenges to the people, and then they are going over step by step. You see that they know their duties and responsibility, you are running the simulation. InfosecTrain Trainer: Now, second, Fourth step, which is a parallel test.

InfosecTrain Trainer: Parallel test you can do if you have the two parallel sites. So, in the parallel test, you will not do any disruption to the primary site, you will activate your recovery site, and then you will see that, is this site InfosecTrain Trainer: is able to support those particular business applications, all the applications, all the recovery thing, what this site is supposed to run, are they running properly or not? So, a recovery site is activated and process real business transaction, while primary will continue to support. InfosecTrain Trainer: But in full interruption test, If you are, suppose, in the warm side kind of setup, You will initiate InfosecTrain Trainer: completely shut down the primary site, and move the backup to the recovery site, and you will operate here. Or suppose you are working in the hot site kind of setup, you will completely cut off the secondary site and try to operate from the secondary site. InfosecTrain Trainer: Understood the difference between all of them. InfosecTrain Trainer: And when you are running these tests, what you will validate, you will validate all the key matrices, RTO, RPO, MTD, SGO. InfosecTrain Trainer: Are the ops site backups are able to retrieved and restored? Is the alternate site capacity is sufficiently defined, whatever we have? Are the vendor and third-party responses are committed, right? InfosecTrain Trainer: And when you're testing, you have to make sure that you start with a checklist. It's one by one. InfosecTrain Trainer: If you want to do a full interruption test, you will not directly jump to the full interruption test, and your business is suffering. You will first do first, then go to the second, then go to the third, then fourth, then you do the fifth.

InfosecTrain Trainer: At least annually, you should do it. InfosecTrain Trainer: and document all the results, include all the key business functions, those who will support, and update the BCPDR plan immediately after each test. So after test, you will identify some key gaps, key things which you have to InfosecTrain Trainer: Note. InfosecTrain Trainer: So these are the tests what we discussed, paper, preparedness, and the full operational test. So, the paper test, include two types of tests, which is the InfosecTrain Trainer: your checklist test, and so we discussed two tests, right? Checklist and the structured walkthrough, these are the paper-based tests. InfosecTrain Trainer: Preparedness tests are the Are the tabletop exercise. InfosecTrain Trainer: And then the full operation test is actually these parallel and the interruption. So these are part of this, right? So in the paper-based test, you do the walkthrough of the plan involving major players in the plan execution. You determine what can happen during a different type of disruption, and usually. InfosecTrain Trainer: before the preparedness test. In the preparedness test is the localized version of the full test. Use actual resources, simulation, and determine the plan effectiveness. And this is the one step away from the actual disruption you... and required a paper, local, and all test altogether. InfosecTrain Trainer: Now, once you have done everything, you have to document the test result, right? You have did... InfosecTrain Trainer: A lot of exercises, a lot of... InfosecTrain Trainer: time you have spent. So every type, iteration, recovery plan steps, all the things, whatever you have done, totally you have to document, right?

You will also need to understand what are the most important part of testing, right? InfosecTrain Trainer: That, something you need to rework, some changes you have to do in the plan. If you don't document how you will do it. InfosecTrain Trainer: Right? So you will note... make note of key matrices. Time required to perform key tasks. InfosecTrain Trainer: accuracy of those tasks, how accurately the people performed, amount of data required, have you met SGO, RTO, RPO, and all the key matrices, RTO, RPO, and all those things were met or not. InfosecTrain Trainer: Now... We are done with this domain, we are done with the... CISM syllabus. InfosecTrain Trainer: But before we discuss the strategy. InfosecTrain Trainer: before we get onto that, anyone has any doubts, any questions with respect to the topics which we discussed. However, strategy will get into it, like, how you will now start preparing for your exam today onwards. InfosecTrain Trainer: Anyone has any doubt on any topic, whatever we discuss. From domain 1 till Domain 4, anything. InfosecTrain Trainer: And also, before we get onto the strategy, I hope all of you have InfosecTrain Trainer: given the feedback of this training, I think the feedback link was shared by the... by Saxam in the group. Please provide the feedback. Your valuable feedback matters. InfosecTrain Trainer: It helps me improve the training content and everything. And also, I request all of you to give feedback once you InfosecTrain Trainer: Actually, go write the exam and pass it, because then you will come and share InfosecTrain Trainer: that these are the topic which you... probably you did not cover, or something you saw, surprisingly in the exam is not being covered.

At least I'll add those content in the slide so that the next people, those who are coming for the training, they get benefited. Yeah. InfosecTrain Trainer: Someone was asking any question. Sandeep Saxena: Yeah, I was just saying, I'm going through the push-in and outside installation, so maybe after some time, I may have some doubts, then I can probably connect with you. InfosecTrain Trainer: Yeah, you, you can ping... so, so, best thing is that, that group. InfosecTrain Trainer: So, whenever you post those questions in the group, right, so kind of discussion we had, right. InfosecTrain Trainer: A is eliminated, B is

eliminated, YC is correct answer, right? So all of you will discuss in the group and build that reasoning, that is the first thing. Even if you feel InfosecTrain Trainer: you have any doubt and all, you can ping me over the WhatsApp, and we can connect over the call. I have done same for a couple of people. Recently, a lot of people passed the exam, they connected with me 15-20 minute session, or 30-minute session. InfosecTrain Trainer: We can directly get onto WhatsApp call, and we can discuss. If you want, probably, to share a screen, share something over the call, you can set up a call. Google Meeting or something, you can share me link, I'll join. Sandeep Saxena: Cool, thanks. InfosecTrain Trainer: Now, get onto strategy. This is very high-level strategy. InfosecTrain Trainer: But I will cover a couple of more things. What I have also understood from the experience of the people, right? So this is something which all of you have to follow, but before we get onto this, first thing, what you will do. InfosecTrain Trainer: First thing, book an exam. InfosecTrain Trainer: You have to decide a date, otherwise you will never able to prepare.

Let me tell you, when I passed the AAISM exam yesterday, right. InfosecTrain Trainer: I... I had a voucher for this exam, which I purchased in the jam. InfosecTrain Trainer: I wrote the exam, Yesterday. InfosecTrain Trainer: I... actually started preparing in between, then I stopped... started... the day I booked the exam. InfosecTrain Trainer: Then, actually, my studies started, because I know this is the exam date, and if I am not able to probably complete my studies, I'll fail, and then I'll lose that voucher cost, whatever I have invested there, right? That's why. The first thing, book your exam. InfosecTrain Trainer: So that you know your date, that this is the date I'll write, and then that fear... it's the basic human nature. You get that fear, I have to... InfosecTrain Trainer: Now, start preparing for my exam. This is the date, otherwise I'll lose my money and the effort, so you will start preparing. InfosecTrain Trainer: That is the first step. Now, second step is that InfosecTrain Trainer: we have almost... it's... we have spent a good amount of time, 4 hour... 8 hours for each domain, right? A lot of video recording. You would have probably forget InfosecTrain Trainer: what I do... Even for AISM, right? InfosecTrain Trainer: I, again, reviewed the recording. So, I did not attend any instructor-led training for AISM. I went with the Parab's video. Parab's has a good InfosecTrain Trainer: video series which he created for the same, right? So I reviewed those recordings twice. First time when you listen the topic, right, you grab only 50% of it. But once you listen that recording once again, you will... your understanding will become 80%. InfosecTrain Trainer: And that's fact. InfosecTrain Trainer: So now, tomorrow onwards, start watching the video recording of Domain 1, Domain 2.

InfosecTrain Trainer: As soon as you finish a recording. InfosecTrain Trainer: solve the question with respect to that domain. So, we have given you those question banks, use those. InfosecTrain Trainer: And make a habit, every day, minimum. InfosecTrain Trainer: Keep a note of it. Say, every day, minimum, I'll solve the 50 questions. InfosecTrain Trainer: I told you AI would help you if the questions which are there in the QA manual and provided by InfosecTrain are not sufficient, make use of AI. But at least minimum 50 questions you solve every day. InfosecTrain Trainer: So that you build the pace, you build an understanding, because when you see a question, when you see that topic, when you build that reasoning, your understanding around that topic becomes more solid. So do that. Third thing, you can create a study group. InfosecTrain Trainer: Because it's a divide and conquer. I think we are almost 20-plus students as part of this training, right? All of them are part of this particular WhatsApp group. InfosecTrain Trainer: So, whatever is the date you decide to write an exam, you can create a group, you can probably do, do a collaborative session where you can discuss those things. It's the best way, right? InfosecTrain Trainer: Then, always make notes. InfosecTrain Trainer: So, there are some key topics. Probably, if you have not made those notes when you were doing InfosecTrain Trainer: the session, whenever you are listening to those recordings, I would have mentioned about important topics. Keep a note of them. InfosecTrain Trainer: So that, a day before the exam, you can go over those notes, and those notes should not be more than 4 to 5 pages.

InfosecTrain Trainer: Because suppose tomorrow morning you are writing the exam, you will review those notes, and then you will go and write the exam. InfosecTrain Trainer: Right? InfosecTrain Trainer: And when you feel that you are ready for the exam, there is one master set, which is already there, but if it's not, you have not received it, we'll share it with you. InfosecTrain Trainer: And the Think Like a Manager video, I have already shared those resources with you, but let me share once again. InfosecTrain Trainer: So, first thing is this video, which you will watch again. InfosecTrain Trainer: And this Think Like a Manager video, this is a series. InfosecTrain Trainer: from the GEN battery, Which you have to watch. InfosecTrain Trainer: No. InfosecTrain Trainer: Now, I will share something from the experience of the people, those who have recently written. This is what I wanted to talk more from that. Now, I will more go from the experience perspective. What I have spoken to a couple of people, those who have given the exam recently, right? InfosecTrain Trainer: Fasting. InfosecTrain Trainer: Adhere to the flagging thing. InfosecTrain Trainer: I told you. InfosecTrain Trainer: Never, ever flag more than 20 questions in the exam, even if you have urge to do so. InfosecTrain Trainer: And exam is a 4 hour. Even if you are able to complete the exam in 3 hours. InfosecTrain Trainer: You have a 1 hour left. Don't utilize that 1 hour to review complete 150 questions. InfosecTrain Trainer: Only review those 15-20 questions which you have flagged, because InfosecTrain Trainer: Recently, one participant from my previous Batch, she failed. She was already a CISSP, let me tell you.

InfosecTrain Trainer: But what she did, she completed the exam in two and a half hour, one and a half hour was left with her. She went back and completely again went over all 150 questions which she reviewed. She had that urge, and in that process, she changed multiple answers. InfosecTrain Trainer: Because first time when you are reading the question right. InfosecTrain Trainer: And you will have some mindset through which you will answer. Second time, when, again, you see that questions, you will get confused, you will get fear, you will say that, okay, I probably answered this incorrectly, and you will keep changing the question. So only flag those questions which you feel are very difficult, very tricky. InfosecTrain Trainer: You can go to up to 25 also, if you are feeling more questions are tricky, but not more than that. InfosecTrain Trainer: And only review those. System has capability, they have offering where you can use flag, and you can only review those flagged questions. First point. InfosecTrain Trainer: Second point. InfosecTrain Trainer: One participant failed because he did not follow this elimination technique, which I followed with you. That's why I was following this. I was saying which two options you want to eliminate, why you want to go with this, correct? InfosecTrain Trainer: He just read the question, read the answer, he felt that this option looking better among them, it just went ahead, and... InfosecTrain Trainer: Marked it as correct. InfosecTrain Trainer: Because when you follow that elimination technique. InfosecTrain Trainer: In that, first thing, you have already eliminated two options which you feel that are totally irrelevant. Now you have a 50-50% probability.

Now, those two options, you have to give full emphasis, and once you read the question options again and again, you will easily able to answer what is the correct answer. Second tip. InfosecTrain Trainer: Third tip. InfosecTrain Trainer: all the basic all the topics, which has a sequence. InfosecTrain Trainer: Which have the processes. InfosecTrain Trainer: go over them again and again, so that you memorize those steps clearly, right? Like, risk... InfosecTrain Trainer: management process, your business continuity planning process, your incident management process, how your overall program works, what is the BIA, what is the risk assessment? What is the gap assessment. InfosecTrain Trainer: You need to have a clear understanding around these topics. You will get good number of questions where you will get confused that should we go with the gap assessment, should we go with the risk assessment, should we go with the BIA? I've already given you another tip. Use the AI. InfosecTrain Trainer: If you're getting confused with topic, tell AI to generate some good, hard questions for... on those topics, so that you InfosecTrain Trainer: generate the reasoning, you understand why, where you have to go with the gap assessment, where you have to go with the risk assessment, where you have to go with the BIA, right? InfosecTrain Trainer: Now, the last tip... InfosecTrain Trainer: you already went through complete process of this training, right? We completed a 32-hour of course and the training, and as a human, we are... we have a tendency to keep forgetting, right? InfosecTrain Trainer: So what you have to do, as soon as you complete one domain, go domain by domain. InfosecTrain Trainer: Do not directly jump onto a master set with all four domains.

First, you have to make a good understanding around a domain. InfosecTrain Trainer: Domain 1, Domain 2, Domain... I told you, all domain, you should have an equal and solid understanding. InfosecTrain Trainer: It's not like that, that Domain 3 and Domain 4, you got 500 marks, and Domain 1, Domain 2, you only got 300 marks, you will fail. InfosecTrain Trainer: Every domain, you have to score above 450. That's your target. InfosecTrain Trainer: So every domain gives full weightage till the time you are not able to get that full confidence, 100% able to achieve that 75% marks, don't leave that domain, right? InfosecTrain Trainer: So these are the tips from my side, now open to questions to all of you. Any questions, any doubts you want to ask, I'm able to answer. Sandeep Saxena: So, issue... Johnny Souriar: existing... sorry, yeah, Sandeep, I will proceed. Sandeep Saxena: Do we have the transcript of all the sessions? I know there is video recording, but a transcript is also available? InfosecTrain Trainer: I think transcript gets enabled automatically. Transcript is already on. InfosecTrain Trainer: In my slide also, transcript is already on. It's there. I think transcript also gets captured. You can, you can, you can reach out to, InfosecTrain Trainer: to the support team, probably they will be able to share the transcript as well. Probably you'll be able to create notes using AI. InfosecTrain Trainer: Through transcript, yeah. Sandeep Saxena: Sure, second doshit, what resources I have, what is the QA manual? I'll go through the questions over there. Then there are some, mock exams on the portal, Infosec Portal. I'll go through that. Sandeep Saxena: And then there is something else, which is some master. InfosecTrain Trainer: Master, master, master set.

InfosecTrain Trainer: Which is... which... which is not there in... InfosecTrain Trainer: form the simulator, it's a PDF document. You can... you can reach out to me, I'll share it with you. InfosecTrain Trainer: It has the question and the answer keys there in the Excel sheet, so... so that you can probably record the answers, and then you can compare with the Excel sheet how many you corrected. Sandeep Saxena: Okay, so first the QA, then the assessment on the portal, then this master list, right? InfosecTrain Trainer: Yes, yes. Sandeep Saxena: Thanks. InfosecTrain Trainer: And third thing I already told Sandeep, use AI. InfosecTrain Trainer: So, if you are using... if you... in your organization, also, you have probably the Cloud license and all, you can use it. If you don't, you can probably buy a premium license for a month, till the time you're preparing for exam, because the higher level of model, don't use the basic version of model. Sandeep Saxena: Right, right. InfosecTrain Trainer: because those premium version of model, premium license, you get the higher version of model, right? They give better InfosecTrain Trainer: Responses, and they generate the better questions. Sandeep Saxena: I have started using AI. I'm worried that what if it goes too technical and not the right CISM. InfosecTrain Trainer: No, no, you have to, you have to train the AI, right? You already have the QA manual. InfosecTrain Trainer: You can... you can give the QAE manual to train the model, you tell that this is the QAE manual from ISACA. Sandeep Saxena: Mano is, you know, there are images, and, at least chat GPD. InfosecTrain Trainer: AI can read, AI can read. I am using Claude, Claude can read. Even Chad GPT higher level model can read.

InfosecTrain Trainer: Even not completely, they'll be able to read. Even you can go to the ISACA portal, and then they have some couple of documents that what kind of questions they ask and all. You can share those documents also with them. Also, you can do a prompt engineering, say that all questions should have the most, greatest. InfosecTrain Trainer: first, as a keyword, questions should not be more than one or two lines, so that it should not generate the Tendi, it should be tricky, and you can give the prompt engineering, it will generate the good questions too. I use it for the AISM exam, and it generated the good questions, which are close to the questions what I got in the exam. Sandeep Saxena: Okay. Sandeep Saxena: Thanks. InfosecTrain Trainer: Yes, now Johnny, yeah, I saw you raise the hand. Johnny Souriar: Yeah, yeah, this, existing, test book is up to November 3rd, right? For exam booking now. InfosecTrain Trainer: Yes, yes, yes. Johnny Souriar: Oh. InfosecTrain Trainer: But I'll tell you, I have already gone through content, I've done the analysis with respect to the 16th and the 17th edition. InfosecTrain Trainer: 5% is change overall. 95% is same. InfosecTrain Trainer: So, imagine there's not, some, something they have changed drastically. Only 5% syllabus, they have changed. InfosecTrain Trainer: The rest, everything remains same, so no need to worry. Even if you are, postponing it beyond that. InfosecTrain Trainer: only you have to read those 5% topic. Probably, if a lot of people approach to me, I will probably set up one more class for my all old students, those who have gone through the older pattern of the training.

Probably two-hour class would be more than sufficient to cover all those InfosecTrain Trainer: important new changes or new topics which have changed. But I would suggest target before November. Johnny Souriar: Okay, fine, yeah, thank you. InfosecTrain Trainer: Anyone else? Pudir: Sir, regarding this CPE hours, to whom should I make a request? InfosecTrain Trainer: You will automatically get. InfosecTrain Trainer: Once you share... so, for CPE reporting, the feedback is mandatory. As soon as you submit the feedback, you can reach out to the support team. They will share you a complete certification. So, InfosecTrain will give you certificate also. InfosecTrain Trainer: that you have completed a 32 hours of training for the CISM with them, and you can report back to report CPs. Pudir: Moreover, sir, drive that material that was provided during InfosecT fine-tuning manner, so it needs mostly fine-tuning. Pudir: notes and. InfosecTrain Trainer: So that's what I'm Pudiram, suggesting. Those notes and all, don't refer to them. Refer these video recordings, because I have already cleared most of... made all of you clear those important topics, right? Second thing. InfosecTrain Trainer: refer, the, Hemang Doshi book for any doubts, and use AI. InfosecTrain Trainer: These are the things which you have Yes, yes. Pudir: The two-end answers that were given by the InfosecTrain, one question, sir, but 250 questions. Pudir: Once we started questions in between the questions were at 1, 120, 130, again, I had to start from question number one. Pudir: That system is not good, because multiple times, you would have to answer the entire questions. Pudir: Save button not available in the system.

Pudir: If you have... that control is available with you, you can modify other ways, you can leave it not. InfosecTrain Trainer: I think that particular question bank is good when you are sitting, so only attempt those when you have a long time available with you, because you have to sit it in a simulated environment, right? But if any technical challenges you are facing, you are pinged to the support team, they'll help you. Pudir: The mind to it is having 250 questions. After completion of 200 questions, the system was restarted. Again, I had to... I had to start coaching number one. It was... InfosecTrain Trainer: But you... but the report goes and gets saved in the backend. Pudir: I'd say, okay, okay. InfosecTrain Trainer: You can, you can talk to them, they'll share you the report. Pudir: Okay, I never asked it, I made it again. No, I shouldn't. InfosecTrain Trainer: Yeah. Pudir: Thank you. Fatha: Sasha, do we first also need to register on ISACA and take the membership so that we can get the voucher also? InfosecTrain Trainer: You know, taking membership is optional, but registering on ISACA, I told you on the first day when I started, I told all of you to please register on ISACA portal. It's first step to begin, right? You can go ahead, create your account, register, it's free of cost. There is no cost involved, right? Fatha: Yeah. Johnny Souriar: That master document is not shared as part of in the drive, right? I think you are going to suppose to share this. InfosecTrain Trainer: I can, I can, I can share with you all, if you need, if you want, I can share it now also. Let me share it. Johnny Souriar: Yep. InfosecTrain Trainer: But don't use it now.

Use it once you... InfosecTrain Trainer: once you actually understand all the topics, and you attempt it at least a week, 10 days before exam, not now. Once you have a solid understanding on all the domains, then only use it. Otherwise, don't use that. InfosecTrain Trainer: Also, I forgot... to share... The domain for... Mind map, yeah. InfosecTrain Trainer: This is the mind map. InfosecTrain Trainer: This is one more I have. This is called the cheat sheet. InfosecTrain Trainer: which you can use to quickly revise the topics. And then, this is also helpful before exam. InfosecTrain Trainer: Yes, Manoj, you have raised a hand. Manoj Kamble: Yeah, so I just want to ask, like, can we have multiple mock, test, questions? InfosecTrain Trainer: Where? Manoj Kamble: Multiple mock test papers, or, like, which we can practice, like, 2-3 sets of multiple, like, mock tests, something like that. InfosecTrain Trainer: Multiple mock tests. Already, we have shared you 4 or 5 tests, right? Manoj Kamble: No. One is QAE, then the next one is, like, this practice link, that is domain-wise. Okay, let's say, if we are not able to reach the desired percentage of 70, then how can we use that again? Means, like, the questions are already Manoj Kamble: means, like, we have gone through. So, in this case, if we have, like, multiple mock test papers or, like, question types, then it will be easy to us, like, to understand and give the exams. InfosecTrain Trainer: Yes, so actually, these are the ones which we have from the ISACA side, but I can suggest you can use the Udemy also. So, Udemy offers some couple of good, question banks. InfosecTrain Trainer: of the similar nature, 100 questions, which you can purchase, you can see the reviews. I've suggested my students using them.

They will give you an addition set of questions. InfosecTrain Trainer: But don't attempt too many questions, right? If you attempt, probably, InfosecTrain Trainer: hundreds of questions, that does not, if you attempt probably 5,000 questions, that does not make sure you will pass. You will get confused more. You'll continue to delay. InfosecTrain Trainer: I am sharing that master set and the question... answer key, which you can use. InfosecTrain Trainer: Also. InfosecTrain Trainer: I told you, use AI. It's the best tool, but don't use the basic origin of AI. Use the good model, like Opus probably is a good model from the Claude, or probably ChatGPT if you're using, so you can use the 5.6. InfosecTrain Trainer: Think Deeper one, which is the premium model, they... generates the better quality of responses and content. InfosecTrain Trainer: Yeah, Manoj, I can see you have raised a hand. Manoj Kamble: No, no, I got it. Thank you. InfosecTrain Trainer: Okay, okay. InfosecTrain Trainer: So, I have shared all the resources also. I've shared all of you, additional resources which I had. I shared you the master set, I've shared you Cheat Sheet, which you can use to review the recording, review the key topics before the exam, right? InfosecTrain Trainer: So all of these things you can use. Yeah, Shweta. Shweta Sundar: So we have... you... there is only one master's set that, is available for practice. InfosecTrain Trainer: Yes, so master set is only one which we have prepared, which you should do it before the exam, right? But all those four sets are there, which actually helps you train on those different, different topics, right? InfosecTrain Trainer: So... so that's how we have prepared. So only we have one master set that's... we share. Shweta Sundar: Okay.

InfosecTrain Trainer: That's why I suggested you can use the Udemy course. So, Udemy CISM Questionnaire Bank, they have a good InfosecTrain Trainer: Sources, which you can subscribe and then solve those additional questions to make your understanding clear. Shweta Sundar: Thank you. Johnny Souriar: Now you have shared one more, right? InfosecTrain Trainer: But I've shared one master set only. Johnny Souriar: Okay, okay. InfosecTrain Trainer: But I'll suggest... InfosecTrain Trainer: you will not have the time and energy to solve so many. Imagine, to solve 100 question set, you require dedicated 2 hours. InfosecTrain Trainer: Can you spare 2 hours or 3 hours of time every day, or a period of time? Probably all of you not be able to do that, right? You're already working somewhere. InfosecTrain Trainer: So... so that's... and yeah, one more thing which I forgot to mention, take leave. InfosecTrain Trainer: Take time off from your office. InfosecTrain Trainer: When you book your exam, take a week off. InfosecTrain Trainer: And then, then go and, write the exam. InfosecTrain Trainer: If you want to actually pass, if you continue, if you give the exam with your work, it will become very difficult. If you take a break, a dedicated one week, you will have 100% time, you will be able to study, read, clarify doubts, and then go and write. Just don't directly go InfosecTrain Trainer: with overconfidence

and write the exam with your work. That I'm working from Monday till Friday, Saturday, I book the exam and write. InfosecTrain Trainer: You will be very difficult, because all those things, what going around in your office would be there in your mind, and then it becomes difficult. InfosecTrain Trainer: Yes. InfosecTrain Trainer: Anything else?

InfosecTrain Trainer: Don't worry, I am there, part of that group. InfosecTrain Trainer: I am there part of that WhatsApp group. Anything, any issues, you can reach out to me, I'll be there supporting till last day. Madhes: The last file shows that this content can't be viewed. InfosecTrain Trainer: Which one? That master's dataset? Madhes: After the master, jet seed. InfosecTrain Trainer: Bonsai app. Johnny Souriar: like, this content cannot be viewed here, something like that, I ask her. You share one PDF, right? CSM. InfosecTrain Trainer: Yes, yes. Johnny Souriar: After that, it is shared? InfosecTrain Trainer: I have shared one Excel sheet. Johnny Souriar: That is so much. InfosecTrain Trainer: Download. InfosecTrain Trainer: Can you download this? I don't know why... Johnny Souriar: Evening System. InfosecTrain Trainer: Okay, here, it's movement. InfosecTrain Trainer: Don't worry, I'll probably share it. InfosecTrain Trainer: Or the WhatsApp group? Pudir: I had downloaded it. InfosecTrain Trainer: It's working? Pudir: Yeah, yeah, cool. InfosecTrain Trainer: You can download it, probably, then it will work on your laptop. Johnny Souriar: Let me... What, a PDF you downloaded, or Excel you had downloaded? Pudir: Boot... Johnny Souriar: What? Johnny Souriar: ERT showing this content cannot be viewed. InfosecTrain Trainer: Because this is op- getting opened for me. Madhes: Even I. Pudir: We think... Madhes: The same thing, this content can't be viewed. Johnny Souriar: Oh, okay, so, can you share it in the WhatsApp so that people can... InfosecTrain Trainer: Okay, okay, I'll share it over the WhatsApp also. InfosecTrain Trainer: All right. Johnny Souriar: Thank you, thank you very much. InfosecTrain Trainer: Thank you, thank you so much, everyone. Everyone have, so, best wishes.

InfosecTrain Trainer: All of you. Fatha: You can... InfosecTrain Trainer: So, so I wish all of you clear the exam, right? InfosecTrain Trainer: And, please, continue to keep posting in the group if any help, any support is needed. So, thank you so much. Johnny Souriar: Thank you. Pudir: Thank you. Ashwin: Thank you. Mukesh Thakur: Thank you. Nathan S: Thank you.